



**SECOND
EDITION**

AN INTRODUCTION TO PRIVACY FOR TECHNOLOGY PROFESSIONALS

**Travis D. Breaux, CIPT
Executive Editor**

An **iapp** publication

An Introduction to Privacy for Technology Professionals

Second Edition

Executive Editor

Travis D. Breaux, CIPT

Contributors

Chris Clifton Lorrie Faith Cranor, CIPT

Kira Fuller, CIPM

Simson L. Garfinkel, CIPP/US

Hanan Hibshi

David James Marcos, AIGP, CIPM, CIPT

Florian Schaub, CIPP/US, CIPT

Stuart S. Shapiro, CIPP/G, CIPP/US

Blase Ur, CIPT

Nicole Uribe, CIPP/US

Zhiwei Steven Wu

An IAPP Publication

CIPP®, CIPP/A®, CIPP/C®, CIPP/E®, CIPP/G®, CIPP/US®, CIPM®, and CIPT® are registered trademarks of the IAPP.

© 2024 IAPP

All rights reserved. No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form or by any means, mechanical, photocopying, recording or otherwise, without the prior, written permission of the IAPP. For more information contact copyright@iapp.org.

Indexer: Hyde Park Publishing Services

ISBN: 978-1-948771-84-9

Contents

[About the IAPP](#)

[Acknowledgments](#)

[Marla Berry, CIPT](#)

[Preface](#)

[Travis D. Breaux, CIPT](#)

[Introduction](#)

[Jason Robie](#)

[CHAPTER 1](#)

[Introduction to Privacy for the IT Professional](#)

[Travis D. Breaux, CIPT](#)

[1.1 Who Should Use This Book?](#)

[1.2 What Is Privacy?](#)

[1.3 What Are Privacy Risks?](#)

[1.4 Security, Privacy, and Data Governance](#)

[1.5 Privacy Principles and Standards](#)

[1.6 The Data Life Cycle](#)

[1.7 Individual Expectations of Privacy](#)

[1.8 Summary](#)

[CHAPTER 2](#)

[Engineering and Privacy](#)

[Stuart S. Shapiro, CIPP/G, CIPP/US; Travis D. Breaux, CIPT](#)

[2.1 Privacy in an Information Technology Ecosystem](#)

[2.2 Privacy Risk Management](#)

[2.3 Requirements Engineering for Privacy](#)

[2.4 High-Level Design](#)

[2.5 Low-Level Design and Implementation](#)

[2.6 Testing, Validation, and Verification](#)

[2.7 Summary](#)

[CHAPTER 3](#)

[Encryption and Related Technologies](#)

[Simson L. Garfinkel, CIPP/US](#)

[3.1 Encryption: the Mathematics of Privacy Protection](#)

[3.2 Secret Key \(Symmetric\) Encryption](#)

[3.3 Cryptographic Hash Functions](#)

[3.4 Public Key \(Asymmetric\) Encryption](#)

[3.5 Public Key Infrastructure](#)

[3.6 Cryptographic Systems: Putting It All Together](#)

[3.7 Other Cryptographic Applications and Concepts](#)

[3.8 Summary](#)

CHAPTER 4

Identity and Anonymity

[Chris Clifton](#)

[4.1 What Is Identity?](#)

[4.2 Authentication](#)

[4.3 Identity Issues](#)

[4.4 Anonymization](#)

[4.5 Summary](#)

CHAPTER 5

Usable and Useful Privacy Interfaces

[Florian Schaub, CIPP/US, CIPT](#); [Lorrie Faith Cranor, CIPT](#)

[5.1 Why User-Centered Privacy Design?](#)

[5.2 Privacy Decision-Making, Behavior, and Concerns](#)

[5.3 Usability and User Experience](#)

[5.4 Design of Privacy Interfaces](#)

[5.5 Usability Testing and User Studies for Privacy](#)

[5.6 Summary](#)

CHAPTER 6

Tracking and Surveillance

[Lorrie Faith Cranor, CIPT](#); [Blase Ur, CIPT](#)

[6.1 Internet Monitoring](#)

[6.2 Web Tracking](#)

[6.3 Blocking and Controlling Web Tracking](#)

[6.4 Location Tracking](#)

[6.5 Audio and Video Surveillance](#)

[6.6 Sensor-Based Surveillance](#)

[6.7 Behavioral Modeling](#)

[6.8 Uses and Abuses of Tracking and Surveillance Technologies](#)

[6.9 Summary](#)

CHAPTER 7

Interference

[Travis D. Breaux, CIPT](#)

[7.1 Framework for Understanding Interference](#)

[7.2 Interference from a Technology Perspective](#)

[7.3 Summary of Lessons Learned and Recommended Actions](#)

[7.4 Summary.](#)

[CHAPTER 8](#)

[AI and Machine Learning](#)

[Zhiwei Steven Wu](#)

[8.1 Overview](#)

[8.2 Basics of Machine Learning](#)

[8.3 Summary.](#)

[CHAPTER 9](#)

[Cybersecurity and Privacy.](#)

[Hanan Hibshi](#)

[9.1 The Breadth of Computer Security Work](#)

[9.2 Attacks and What Makes Them Possible](#)

[9.3 Security Properties and Types of Adversaries](#)

[9.4 Access Control](#)

[9.5 Principles for Building and Operating Systems to Be More Secure](#)

[9.6 Summary.](#)

[CHAPTER 10](#)

[Privacy Governance](#)

[David James Marcos, AIGP, CIPM, CIPT; Kira Fuller, CIPM; Nicole Uribe, CIPP/US](#)

[10.1 Privacy and IT: Roles and Responsibilities](#)

[10.2 Privacy Governance and Engineering: Bridging the Gap](#)

[10.3 Privacy Engineering: Effective Implementation within an Organization's IT Infrastructure](#)

[10.4 Evaluating Success: Assessing Sufficiency and Effectiveness of IT Privacy Governance](#)

[10.5 Summary.](#)

[About the Contributors](#)

[Index](#)

About the IAPP

The IAPP is a not-for-profit association founded in 2000 with a mission to define, promote, and improve the professions of privacy, AI governance, and digital responsibility globally.

We are the largest association of our kind in the world, helping practitioners develop and advance their careers, and assisting companies and institutions in managing and protecting data.

We are committed to providing a forum for professionals to share best practices, track trends, network, advance management issues, earn, certifications that validate their knowledge and skills, and provide guidance on career opportunities.

The IAPP offers the only globally trusted credentials in our fields: the Artificial Intelligence Governance Professional certification, Certified Information Privacy Professional, Certified Information Privacy Manager, and Certified Information Privacy Technologist.

The CIPP, CIPM, and CIPT are the leading privacy certifications for thousands of professionals around the world who serve the data protection, information auditing, information security, legal compliance and/or risk management needs of their companies and institutions.

In addition, the IAPP offers a full suite of education and professional development services, including annual conferences around the world that are acclaimed as leading forums for the discussion and debate of critical issues at the intersections of data, technology, and humanity.

Acknowledgments

The IAPP is delighted to present the second edition of *An Introduction to Privacy for Technology Professionals* in support of the Certified Information Privacy Technologist (CIPT) credential. Much has changed since the previous edition of this book. Technology is evolving and being adopted at what feels like an increasingly rapid pace. Most of the global population has their personal data covered by privacy and data protection laws. And the EU AI Act brings the first comprehensive regulation focused on artificial intelligence. This book is updated to address new challenges faced by technologists who build privacy and data protections into products and services.

There is much that goes into the creation—and update—of a textbook. I am grateful for all the individuals who provide their time and expertise to write and review content. Thank you, Travis D. Breaux, CIPT, for your continued support and guidance. Your leadership as executive editor for all three editions of this book has ensured we are presenting critical content from top thought leaders in the field. You are an invaluable partner and contributor, and it is always a pleasure working with you.

To the individuals who wrote or updated chapters for this edition: Travis D. Breaux, CIPT; Chris Clifton; Lorrie Faith Cranor, CIPT; Kira Fuller, CIPM; Simson Garfinkel, CIPP/US; Hanan Hibshi; David James Marcos, AIGP, CIPM, CIPT; Florian Schaub, CIPP/US, CIPT; Stuart S. Shapiro, CIPP/G, CIPP/US; Blase Ur, CIPT; Nicole Uribe, CIPP/US; and Zhiwei Steven Wu; we are so grateful to you for sharing your expertise in these pages.

To the individuals who reviewed the draft manuscript: Ben Daley-Gage CIPP/E, CIPM, CIPT, FIP; Francesco Gualtieri, CIPP/E, CIPM, CIPT, FIP; Kok Kwang Lui, CIPP/E, CIPM, CIPT, FIP; Tiina Suomela, CIPP/E, CIPM, CIPT, FIP; David James Marcos, AIGP, CIPM, CIPT; and Brenda Leong, CIPP/US; thank you for the thoughtful feedback and perspectives you provided that helped shape the final text.

Our training advisory board provides ongoing support for all our training products. We are grateful for their guidance and contributions. Current members include:

Adam Higgins, CIPP/E, CIPM, CIPT, FIP

Adebola Hamed, CIPP/US, CIPM, FIP

Agnès Marie-Noëlle Terreau, CIPP/E

Alfonso Yi, AIGP, CIPP/E, CIPP/US, CIPM, FIP

Beatrice Botti, CIPP/E, CIPM

Ben Daley-Gage, CIPP/E, CIPM, CIPT, FIP

Benjamin Wilczynski, CIPP/E, CIPM, FIP

Camila Tobón, CIPP/E, CIPP/US, CIPM, FIP, PLS

Costanza Pollini, CIPP/E

Dave Brown, CIPP/US, CIPM, FIP
Erin Butler, CIPM
Fiona Makaka, CIPP/E, CIPM
Francesco Gualtieri, CIPP/E, CIPM, CIPT, FIP
Jason Peterson, CIPP/A, CIPP/C, CIPP/E, CIPP/US, CIPM, CIPT, FIP
Jonathan Cantor, CIPP/G, CIPP/US
Kalpana Sundaram, CIPP/US
Kathryn Fox, CIPM
Kok Kwang Lui, CIPP/E, CIPM, CIPT, FIP
Laura Weiss, CIPP/US, CIPT
Leyla Gurbanova, CIPP/E
Liisa Thomas
Maria-Cristina Macocinschi, CIPP/E, CIPM
Mary Kay Thurlkill, CIPP/US, CIPM, FIP
Matthew Ford, CIPP/E, CIPP/US, CIPM, CIPT
Natasha Petterson, CIPP/E, CIPM
Nitin Dhavate, CIPP/E, CIPM, FIP
Olufunke Babatunde
Parinati Sarnot, CIPM, CIPT
Paul Törnblom, CIPP/E
Petruta Pirvan, CIPP/E, CIPP/US, CIPM, FIP
Preeti Dhawan, CIPP/C
Roberto Girardi, CIPP/E
Robin Anise Benns, CIPP/US
Rongfei Lu, CIPT
Ross Parker, CIPM
Shahayda Babb, CIPP/C, CIPM
Sok Woo Yoon, CIPP/US
Tahir Latif, CIPP/A, CIPP/E, CIPP/US, CIPM, FIP
Trinity Car, CIPP/US, CIPM, FIP, PLS
Victoria van Roosmalen, CIPP/C, CIPP/E, CIPP/US, CIPM, CIPT, FIP

Finally, thank you to Hyde Park Publishing Services for creating the index for this book. As always, we hope that you will find this book to be both an indispensable resource in preparing for your certification as well as a practical resource for your professional career.

Marla Berry, CIPT

Training Director

IAPP

Preface

Since the first edition of this book, *Introduction to IT Privacy*, was published in 2014, we have observed significant advances in information technology (IT) and public policy that affect privacy. In many ways, this ten-year period tells a story in which technologies that historically lived in research laboratories have seen wider commercial adoption as new forms of automation. These technologies include autonomous and semiautonomous vehicles, voice-activated assistants, smart devices, and biometrics. Generative artificial intelligence (AI) in the current form of generated text, audio, images, and video is promising a future with personal AI assistants. While the conveniences arising from such automation are still being understood, the deployment is raising new privacy challenges. Google Glass, smart eyeglasses that could snap photos and later record video, were introduced in 2012 and quickly raised questions about reasonable expectations of privacy in public spaces. While this technology did not become mainstream with the public, voice-activated smart speakers, which consumers deploy in their homes to check the weather and play music, have been quite popular, with multiple manufacturers including Amazon, Apple, and Google competing for market share.

The privacy risks introduced by these technologies are varied, including new ways to acquire personal data, new ways to build richer personal profiles, and new challenges in discerning the truth about a person from mere fabrication. Machine learning (ML) and robotics, for example, have led to commercial drones that allow individuals to acquire overhead video and sensor data, smart televisions that detect which content is being viewed and then share this information with device manufacturers, and health sensors that track real-time fitness and blood pressure. In many ways these advances integrate with and extend the smartphone revolution that led to the novel collection of real-time location by mobile apps and advertisers. Additionally, increased deployment of sensors, often to enable new consumer products and safety features, allow for the creation of richer personal profiles. In 2015, telematics devices introduced by insurance companies were capable of recording driving distances, braking patterns, and speed traveled for the purpose of informing insurance rates. In 2024, we are now seeing evidence of the commercialization of automotive telematics data for insurance rate adjustments. In 2016, a popular social media site deployed an algorithm to classify its users by political preference, which contributes to other factors in behavioral profiles such as affinities for specific racial groups. Finally, generative AI now allows one to create fake images, video, and voice. These are called “deepfakes” because they rely on deep neural networks to generate the content. This includes an app designed to “auto undress” photos of women, as well as an app that allows a person to record audio that is transformed into the video and audio of a public personality. To thwart identity thieves,

companies are having to develop defenses against deepfaked customer voices. These technologies raise new questions about the veracity of information and the use of data to misrepresent a person's character or beliefs, potentially poisoning the public record.

Finally, in recent years, we have seen major advances in regulatory practices aimed at addressing privacy in a world where data is increasingly shared globally. In Europe, the General Data Protection Regulation (GDPR) that replaced the Data Protection Directive (Directive 95/46/EC), has become a de facto standard for legal compliance with privacy law. In the U.S., states including California, Colorado, and Virginia, among others, have established or are working to establish their own general privacy laws. Four years since its original inception, the National Institute for Standards and Technology (NIST) Privacy Framework continues to guide companies in selecting actions to reduce privacy risk within their enterprises. Going forward, regulators face great challenges in ensuring regulations keep pace with emerging technology as it shapes how we define and promote privacy. For example, how should companies treat ML models trained on data of EU citizens who choose to be forgotten?

In this new edition, we enshrine advances in technology, policy, and practice in updates to all the existing chapters. This includes updates to privacy standards and to the role and location of the privacy engineering within a mature organization in chapter 2. In chapter 10, we added clarification about the ethical, moral, and statutory obligations of the privacy engineer, new information on handling individual rights requests, oversight and auditing, and developing key performance and risk indicators. In chapter 9, we added new content to highlight the important relationship between privacy incidents and response, as well as the relationship between security vulnerability and incident management. Finally, we added a new chapter on ML that introduces the fundamentals and specifically draws connections to privacy, including advances in generative AI. This includes the role of data scientists, the data ecosystem used to train ML models, sources of privacy risk in model development, and examples of privacy threatening ML-based applications. While these are a few highlights for the new edition, I believe you will find this updated volume offers a comprehensive, single source on the topic of IT privacy that is simply unparalleled in terms of breadth and depth.

Travis D. Breaux, CIPT
Executive Editor

Introduction

In the rapidly evolving digital landscape, modern technologies offer us unprecedented freedoms and opportunities for innovation, communication, and convenience. However, these advancements also lead to unparalleled invasions of privacy, as personal data becomes increasingly accessible and vulnerable to exploitation. In this complex electronic business environment, relying solely on a check-the-box compliance model creates a false sense of security and does not address the nuanced and ever-changing challenges of modern data protection.

The growing emphasis on regulating the use of artificial intelligence (AI) systems and algorithms that handle personal data underscores the critical importance of these privacy concerns. As AI capabilities advance at an unprecedented pace, the risk of their misuse for surveillance, manipulation, or perpetuating harmful biases intensifies, worsening privacy issues. Privacy engineering will become increasingly vital to ensure technological advancements do not compromise individual privacy but rather enhance it.

For software and data engineers, architects, and technology professionals, incorporating privacy-by-design principles is not just a recommended best practice—it is an imperative necessity. This approach involves integrating privacy considerations into every stage of the software development life cycle, from initial conception and design to deployment and ongoing maintenance. By embedding privacy directly into the architecture and code, engineers ensure applications and services are inherently privacy-preserving, rather than attempting to retrofit privacy features as an afterthought.

The significance of this approach cannot be overstated. As the builders and shapers of these technologies, engineers and architects are at the forefront of the privacy battle. Their decisions—whether choosing how to securely store and process user data, designing user interfaces that clearly communicate data usage, or implementing robust encryption and anonymization methods—directly impact user privacy and trust. By adopting privacy by design, they can proactively prevent privacy breaches before they occur, saving their organizations from reputational damage, financial penalties, and loss of user trust and loyalty.

This textbook serves as an instrumental resource for technology professionals, equipping them with a deep understanding of privacy concerns and their far-reaching implications in the modern technological landscape. Through its comprehensive exploration of concepts, guidelines, tools, and frameworks, this book empowers readers to seamlessly integrate privacy considerations into their solutions from the ground up.

With this knowledge, professionals can ensure privacy remains a paramount consideration throughout the entire solution life cycle, from design and development to testing and

support. By leveraging the insights and best practices outlined in this textbook, technology professionals can play a pivotal role in creating solutions that prioritize privacy while meeting the demands of today's data-driven world.

Jason Robie

Chief Information Officer

IAPP

CHAPTER 1

Introduction to Privacy for the IT Professional

Travis D. Breaux, CIPT

Information technology (IT) continues to revolutionize modern life through increasing automation and innovation. Automation includes transforming existing, often paper-based, practices into electronic, form-based processes that aim to save time and reduce waste. The migration from paper-based medical records to electronic health records and the transition to electronic voting are just two examples of IT automation. Alternatively, IT innovation occurs when new services are realized that were previously out of reach due to technological

limitations. Social networking and handheld mobile devices have led to extensive innovation by bringing data and information into the context of personal and professional activities. These have led to a paradigm shift in how we manage and interact with information on a daily basis. Advances in machine vision, speech recognition, and wearables have led to further personalized and hands-free computation. The challenge for modern IT, however, is that new forms of system quality and value are necessary to sustain this emerging ecosystem. Whereas the early days of IT were driven by value produced primarily from improved performance, better reliability, and stronger integrity, modern IT systems must increasingly contend with value produced from better usability, security, and privacy. In particular, increasing privacy concerns arise as personal information is collected, processed, and transferred in new ways that challenge existing legal and social norms.

To prepare IT professionals with the skills they need to support the privacy goals of their organizations, this book provides a roadmap for navigating the complex IT ecosystem from the viewpoint of an IT administrator or developer. As a roadmap, the book cannot reasonably cover every detail needed to train an IT professional to become an expert in privacy. However, it does include several important signposts that direct the IT professional to more easily identify and understand critical terminology for discovering and incorporating privacy and security best practices into their workplace responsibilities. This terminology can later be studied in depth in a manner commensurate with the role and responsibilities of the IT professional in their larger organization. Furthermore, the book aims to prepare the professional to identify common pitfalls that have previously led to privacy harms that, in some cases, cost companies millions of dollars in fines and lost revenue. In this chapter, we begin by defining what we mean by IT professional, make the case for why some IT professionals *must* become privacy experts, and finally conclude by providing a brief, multi viewpoint definition of privacy and laying out an initial privacy framework IT professionals can use to contextualize content from the remaining chapters as they work to become privacy experts. After studying this book, the IT professional should be knowledgeable about how privacy integrates into their daily practices and the daily practices of others around them, and with whom they should coordinate to improve privacy throughout their information systems.

1.1 Who Should Use This Book?

Today, IT has evolved into a rich ecosystem of stakeholders who participate in the development, acquisition, and administration of IT systems. Together, these stakeholders ensure IT systems are sustainable over time and that these systems continue to deliver value to customers and others. In this book, we focus on three broad categories of IT professionals:

- IT developers: Personnel who are responsible for researching, designing, developing, and testing IT systems to meet broad market demand, or to more

narrowly satisfy an organization's business needs. For many organizations, IT development includes translating customer or other stakeholder requirements into system specifications. For other organizations, a separate research and development group is responsible for envisioning "leap ahead" technologies that can surface new, unforeseen privacy risks. In either situation, privacy concerns are less expensive to address in the early stages of development than during the later stages. Privacy engineers, who are increasingly found in companies with advanced privacy programs, fall into this category. So do business analysts, software developers, software engineers, software architects, quality assurance analysts, and user interface/user experience designers, among others.

- IT acquisition: Personnel who are responsible for acquiring open-source or commercial software and hardware to fulfill their organization's business needs. The IT professional should be able to identify privacy-enabling and privacy-threatening product features and their relationships to privacy risks. When an IT professional is working on the potential acquisition of IT systems, they are responsible for reviewing contracts to ensure the necessary privacy requirements are included in the system targeted for acquisition.
- IT administration: Personnel who are responsible for installing, configuring, and maintaining IT systems. These professionals sustain and manage the connection between IT and business functions, often finding ways to bend and flex existing systems to meet the unique needs of their organization. Similar to IT acquisition personnel, administrators need a strong vocabulary for describing the technologies that concern privacy. However, the administrator is more like the IT developer when they are required to integrate technology into the organization's infrastructure and command the technical details of various technologies, sometimes refactoring or gluing systems together to share information in new ways.

This book aims to cover these three perspectives in different ways. Chapter 2 describes engineering practices for IT developers who design and construct their own IT systems. These practices include methods for identifying privacy requirements from a variety of recognized sources, tracing these requirements into system design and implementation, and finally, testing these systems for conformance to privacy. Strategies for identifying and managing privacy risk that build on legal and philosophical foundations of privacy are also presented in chapter 2. Integrators, administrators, and acquisition staff should use these risk-management practices when assessing privacy-preserving technology in off-the-shelf products. The next three chapters cover specific technologies IT developers may use in their designs, such as technologies to support confidentiality and encryption in chapter 3, identifiability and access control in chapter 4, and user interface design in chapter 5. Next, we

summarize technologies that introduce privacy harms to individuals in two chapters: chapter 6 on tracking and surveillance and chapter 7 on interference. These two harms have received increasing attention over the past decade as technology is increasingly used to quantify personal behavior. Chapter 6 is organized by the list of technologies used for tracking, including cookies, browser fingerprinting, radio-based geolocation, and much more. Chapter 7 is organized as a series of case studies to illustrate the effects of poorly designed IT systems that failed to preserve privacy. Together, these five chapters are relevant to IT acquisition and IT administration personnel, who can use this information when selecting and evaluating products and systems to support privacy in their organization. Chapter 8 examines privacy risks due to artificial intelligence (AI) and machine learning (ML), which are outpacing society's ability to understand and respond to these risks. This includes advances in generative AI, which can be used to generate deepfakes and gender, racial, and age-related biases, among others, that are encoded in datasets used to build ML-based decision support tools. Chapter 9 describes how cybersecurity practices relate to privacy. This chapter can inform all three roles (development, acquisition, and administration) in terms of how they leverage and coordinate existing IT security frameworks and practices to address issues in privacy. Notably, security and privacy are not equivalent, and one cannot rely on security practices alone. Finally, chapter 10 describes privacy governance, risk, and compliance terminology, as well as best practices, particularly for cloud-based and service-oriented systems. These techniques address the human dimension of IT management, including the role of privacy policies and notices, and several techniques mature organizations use to manage privacy compliance through IT asset management, training, and incident response.

The topics presented in this book may be applied to any system that processes personal information. This coverage ranges from general business systems, such as customer relationship management (CRM) systems, human resources (HR) systems (e.g., payroll, benefits), and enterprise resource planning (ERP) systems, to domain-specific systems, such as electronic medical records, online storefronts, and industry-specific, self-service kiosks. The practices can be applied to desktop systems or mobile apps. They can inform how we review AI and ML algorithms for privacy risk, in order to make these algorithms safer. One challenge for IT professionals is understanding when information is personal or when it describes a data subject. Examples of personal information include an individual's contact information, account numbers, or unique biometric or health data. In this case, payroll systems, workplace computers that may be used for personal reasons, and corporate wikis all contain personal information. Less obvious examples include information that describes personal preferences, such as political or lifestyle preferences, or information generated by systems that may be uniquely linked to an individual, such as their personal vehicle or mobile computer. We cover in-depth issues of identifiability in chapter 4, and how technology can be used to track and surveil individuals in chapter 6.

1.2 What Is Privacy?

Privacy has a rich history in law and philosophy that can meaningfully inform how IT professionals think about privacy in their IT systems. Because many definitions of privacy consider one or more separate perspectives on privacy, the IT professional should be prepared to work in a privacy pluralistic world. In other words, privacy experts are prepared to distinguish different definitions of privacy and recognize when another person is using a particular definition to review and analyze an IT system. Each definition is not exclusive of the other; rather, the definitions serve to highlight specific issues. To briefly illustrate, we consider a few prominent viewpoints on privacy that have served to define privacy in different ways:

- **Alan Westin's Four States of Privacy:** These are solitude, intimacy, anonymity, and reserve. Solitude is when the individual stands by themselves, separate from the group and remains free from the observations of others. Intimacy is when the individual is part of a small unit wherein trust, information sharing, and the rules of secrecy are negotiated with members of the unit. Anonymity is when the individual still maintains freedom from identification and surveillance while in public. Lastly, reserve is when the individual maintains the ability to withhold communication or disengage from others to create a psychological barrier against unwanted intrusion, while in a large group.¹ These four states can be used to characterize individual expectations of privacy and how IT works to achieve or conflict with those expectations.
- **Helen Nissenbaum's Contextual Integrity:** Privacy can be expressed as norms that should govern information access. Norms are domain specific. For example, the norms governing banking information will differ from the norms governing medical information. In addition, norms are context specific, such that each individual can have their own reasons for controlling access to their information in specific situations based on their own expectations, which govern those situations.² This viewpoint presents a challenge to IT professionals: how to identify relevant norms and preserve norms when they introduce new or changing technology?
- **Daniel Solove's Taxonomy of Privacy:** Privacy is understood by the activities and mechanisms that violate privacy as described in court proceedings. This includes activities such as interrogation and surveillance to compel information disclosure, secondary use and appropriation or distortion, especially of another's image.³ These activities can be used to determine when IT enables privacy-threatening outcomes. See chapter 2 for more discussion of the individual activities and risks posed to individuals.

- Ryan Calo's Harm Dimensions: Objective harms are measurable and observable, wherein a person's privacy has been violated and a direct harm is known to exist. Subjective harms exist without an observable or measurable harm, but where an expectation of harm exists.⁴ Subjective harms may have the same impact on individual privacy because the individual takes similar steps to protect themselves. For IT professionals, the challenge is to recognize that the perception of harm is just as likely to have a significantly negative impact on individual privacy as experienced harms. Thus, IT professionals may need to rely on privacy notices and privacy controls to build and retain trust from individuals.

Information technology provides the capability to shift the states of privacy defined by Westin for a particular individual. For example, IT can be used to interrupt one's solitude, reveal an intimate moment, identify a person in a crowd, or infer and expose an individual's attitudes and opinions despite their active reserve. This may occur in social networking environments, where others have the freedom to disclose intimate details about another person, or where participation is preconditioned on easing access to information about oneself by others. Finally, Solove's taxonomy and Calo's dimensions both reflect the risks that can result from an IT system violating a person's privacy or creating the perception of a potential violation. While these concepts form a strong philosophical foundation for privacy, IT professionals bear the unique responsibility of translating these concepts into IT system features that work to protect an individual's sense of privacy.

1.3 What Are Privacy Risks?

In the context of this book, privacy risks concern the *likelihood* that a privacy threat will exploit an IT vulnerability and the *impact* of this exploit on the individual and organizations that retain information on them. The source of a threat, called the threat agent, may be internal to an organization (i.e., "insider threats") or external. Common insider threats include malicious threats, such as an employee stealing personal information about a customer to use later to conduct fraudulent transactions in the guise of that person, called "identity theft." According to the 2023 Javelin Strategy & Research Report on identity theft, 40.4 million U.S. adults were victims of identity theft in 2022.⁵ The average out-of-pocket cost of identity theft to the consumer was USD1,064 per incident.⁶ With respect to the companies that host personal information, IBM reports companies lost USD4.45 million on average as a result of data breaches in 2023, including costs from legal defenses.⁷ Within that average loss, USD1.3 million is associated with system downtime, lost customers, reputation losses, and diminished goodwill.⁸

Celebrities or high-profile customers are subject to a different kind of insider threat, where employees steal personal details about the customer or their family and plan to sell this information to tabloids and newspapers. This risk is especially high in hospitals, where

medical details of a celebrity's newborn baby or psychological assessment may be purchased for publication, to out these personal details.

Nonmalicious insider threats can be due to carelessness, mistakes, insufficient training, weak security policies, and ineffective controls, just to name a few causes. Lost or stolen mobile devices are frequent sources of gross data losses. This situation arises when employees take laptops out of the office for business or other travel purposes and the laptop is lost, misplaced, or stolen. If the laptop hard drive is unencrypted, then anyone who discovers it can easily gain access to the company files. This is particularly threatening to individual privacy when those files contain sensitive personal information, such as Social Security numbers, financial account numbers, or medical information. Other examples of lost or stolen devices include unencrypted USB flash drives and unencrypted backup drives and tapes stored in offsite locations that may be less secure than the primary work location.

External threats employ many of the same techniques to steal information that IT security analysts use to prevent it. These techniques include “phishing,” which is a form of social engineering that uses a routine, trusted communication channel to capture sensitive information from an unsuspecting employee. Phishing occurs most commonly in email messages that appear to be authentic and encourage the employee to click on a link or respond to the message with personal information, such as passwords, birth dates, and/or financial account numbers. When clicking a link, the employee may be led to a website that collects the information, or they may unknowingly install malicious software that aims to collect the information on their computer. Phishing is called “spear-phishing” or “whaling” when the activity targets high-profile personnel, such as corporate executives or HR managers who have more extensive access or access to more sensitive information. Advances in generative AI have enabled a new level of social engineering, for example, wherein attackers can generate a person's voice from three seconds of audio to attack voiceprint fraud detection mitigations in call centers.² To reduce these risks to an organization's IT infrastructure, IT staff must combine a technical understanding of the available privacy-enabling and privacy-threatening technology described in this book with strategies for managing data through IT governance, which is discussed further in chapter 10.

For individuals, threats may exploit how they use a broad range of computing devices. For example, individuals may install on their computers otherwise innocuous browser plug-ins or personal software, such as file-sharing software, that engage in covert collection of personal information. This can affect IT staff as well because workplace computers succumb to the same threats when employees use their work computers for both work-related and personal reasons. Throughout this book, we explore in greater detail the kinds of threats that affect individuals with respect to various dimensions of privacy, including tracking and surveillance in chapter 6, interference in chapter 7, AI and ML-based threats in chapter 8, and threats due to security lapses in chapter 9.

1.4 Security, Privacy, and Data Governance

Before privacy became a prominent focus for many organization's IT departments, security was receiving increasing attention within those departments. Prior to 2012, this increasing focus was evident in the rising number of companies with a dedicated security executive position, reported at 29% in 2008, 44% in 2009, and 53% in 2011.¹⁰ Today, 100% of Fortune 500 companies employ a chief information security officer (CISO). Security is traditionally defined as a set of activities that supports three different quality attributes: "confidentiality" ensures information is only accessible by authorized individuals, "integrity" ensures information has not been unintentionally modified, and "availability" ensures information is readily available whenever it is needed. Some have argued privacy is simply a subset of security, because it includes restricting access to information or ensuring confidentiality. These arguments resonate most with practices described in chapter 3 on encryption and chapter 4 on identity and anonymity.

This viewpoint suggests organizations that practice good security have already addressed privacy. For example, one might argue existing security standards, such as the International Organization for Standardization's ISO 27000, already cover those concerns that are raised by privacy. Even today, updates to ISO standards, including 27001 and 27002, have been made to include substantive privacy guidelines and controls. However, multiple privacy theories show that privacy is much broader than security. For example, the well-respected jurist Charles Fried argues people do not always enjoy more privacy when others know less about them, which means confidentiality or restriction of access to personal data alone cannot increase a person's sense of privacy.¹¹ While privacy certainly includes an individual's ability to grant and deny access to their information, privacy also concerns an individual's ability to control the granularity of information others can access. Privacy scholar Julie Cohen further expounds upon the value of privacy to individual autonomy, noting the ability to make first moves and false starts is necessary to develop individual identity.¹² Recent research on "regrets" illustrates how individuals will willingly share information, only to later regret that this information will be permanently remembered and made available by technology.¹³ Whereas a security expert will see access control in these examples, a privacy expert will see a broader range of issues that concern information access, including surveillance, interrogation, feelings of insecurity, and exposure, appropriations and distortions of one's image, and so on.¹⁴ To support IT security professionals with a broader perspective on privacy, chapters 5-8 look at privacy challenges through multiple nonsecurity lenses, including user interface design, tracking and surveillance technologies, interference, and AI and ML. In chapter 9, we review the set of security problems and practices that commonly align with privacy to discuss the intersection and dissimilarity of privacy and security.

Within an organization, privacy is commonly situated in the legal department or other group responsible for data governance. This creates a challenge for IT professionals, as the focus on privacy has often followed compliance with laws and regulations, which generally hold a narrower view of how privacy impacts individuals. Furthermore, weak or infrequent communication between the legal and IT departments is problematic, as legal needs to communicate the goals of privacy protections to IT, and IT must be allowed to determine the appropriate IT controls to support those goals. Organizations that invest in corporate-level expertise in privacy will have a chief privacy officer (CPO), who can lead this effort in ways that extend beyond legal compliance. Moreover, the chief executive officer (CEO), CISO, and CPO can work together to comprehensively address security and privacy.¹⁵ Regardless of how an organization assigns privacy to its reporting structure, chapter 2 aims to provide a roadmap to bridging traditional engineering practices with privacy engineering practices that support holistic privacy by design (PbD), as well as legal compliance. As organizations invest more in privacy, they often develop separate organizations for privacy governance. Chapter 10 is written from the perspective of privacy governance, which includes a greater emphasis on the legal perspective and thus complements the developer view embodied in chapter 2. This includes traditional engineering techniques that can be generally adapted to any privacy context, such as requirements trace matrices, use cases, and software architecture, to privacy-specific threat modeling techniques, such as the LINDDUN.

Lastly, and in addition to IT security and privacy departments, U.S. regulations and international standards have led to the development of data-governance groups within organizations. Examples of regulations and standards that affect data governance and can support internal, organizational privacy standards include

- Sarbanes-Oxley (SOX), which aims to improve corporate accounting;
- Basel II, which aims to improve credit risk calculations;
- The Health Insurance Portability and Accountability Act (HIPAA) Privacy Rule, which requires accounting for medical information disclosures.

These rules affect data-management practices, and thus organizations respond by developing internal data-governance policies to comply. Data-governance policies are implemented by IT managers and leverage many of these same practices in the pursuit of improved privacy, such as identifying data assets and mapping regulatory controls onto IT systems that store governed data. In chapter 10, we discuss how governance, risk, and compliance practices can be extended to include compliance with privacy regulations. However, data-governance policies are only complementary to strong privacy programs, and IT professionals must also develop risk-management strategies, such as those discussed in chapter 2, and account for specific privacy-preserving and privacy-threatening technologies, such as those discussed in chapters 3-9.

1.5 Privacy Principles and Standards

The privacy profession is led by established principles and standards that should be used to guide IT professionals, particularly developers in requirements, design, and testing, toward better privacy-preserving systems. Privacy principles have their origin in the Fair Information Practices (FIPs), which were first established by the Health, Education, Welfare (HEW) Advisory Committee on Automated Data Systems in 1972.¹⁶ Today, there are several interpretations and extensions to the original FIPs, and recent calls for PbD have sought to use the FIPs as the foundation for an early integration of privacy into software.¹⁷ The more prominent principles that developers should be familiar with include the following:

- Fair Information Practice Principles (FIPPs), published in 1977 by the Federal Trade Commission (FTC) and used as guidance to businesses in the United States;
- Guidelines on the Protection of Privacy and Transborder Flows of Personal Data, published in 1980 by the Organisation for Economic Co-operation and Development (OECD);
- Privacy Framework, published in 2005 by the Asia-Pacific Economic Cooperation (APEC);
- Generally Accepted Privacy Principles (GAPP), published in 2009 by the American Institute of Certified Public Accountants (AICPA) and the Canadian Institute of Chartered Accountants (CICA);
- NISTIR 8062, An Introduction to Privacy Engineering and Risk Management in Federal Systems, published in 2017 by the U.S. National Institute of Standards and Technology (NIST).

The 1980 OECD Guidelines provide a foundational and international standard for privacy. The guidelines contain principles that are not found in the FTC's FIPPs, such as the collection limitation principle, and the GAPP largely refine the guidelines into more concrete privacy controls in a similar manner to the NIST privacy controls. The principles of the guidelines are listed below:¹⁸

- **Collection Limitation:** There should be limits to the collection of personal data and any such data should be obtained by lawful and fair means and where appropriate, with the knowledge or consent of the data subject.
- **Data Quality:** Personal data should be relevant to the purposes for which they are to be used, and, to the extent necessary for those purposes, should be accurate, complete, and kept up-to-date.

- **Purpose Specification:** The purposes for which personal data are collected should be specified not later than at the time of data collection and the subsequent use should be limited to the fulfillment of those purposes or such others as are not incompatible with those purposes and as are specified on each occasion of change of purpose.
- **Use Limitation:** Personal data should not be disclosed, made available or otherwise used for purposes other than those specified, except: (a) with the consent of the data subject; or (b) by the authority of law.
- **Security Safeguards:** Personal data should be protected by reasonable security safeguards against such risks as loss or unauthorized access, destruction, use, modification or disclosure of data.
- **Openness:** There should be a general policy of openness about developments, practices and policies with respect to personal data. Means should be readily available of establishing the existence and nature of personal data, and the main purposes of their use, as well as the identity and usual residence of the data controller.
- **Individual Participation:** An individual should have the right: (a) to obtain from a data controller, or otherwise, confirmation of whether or not the data controller has data relating to him; (b) to have communicated to him, data relating to him within a reasonable time; at a charge, if any, that is not excessive; in a reasonable manner; and in a form that is readily intelligible to him; (c) to be given reasons if a request made under subparagraphs (a) and (b) is denied, and to be able to challenge such denial; and (d) to challenge data relating to him and, if the challenge is successful to have the data erased, rectified, completed or amended.
- **Accountability:** A data controller should be accountable for complying with measures which give effect to the previously stated principles stated.

The principles provide a common language through which to speak about privacy. CPOs, CISOs, and legal departments should have a reasonable understanding of the meaning of purpose specification, but IT professionals are more likely to know the technical details of tracing data through various databases, servers, and client applications to ensure data is not repurposed. Moreover, the principles work in tandem, and IT professionals can apply them in a systematic manner to their systems by using the data life cycle.

1.6 The Data Life Cycle

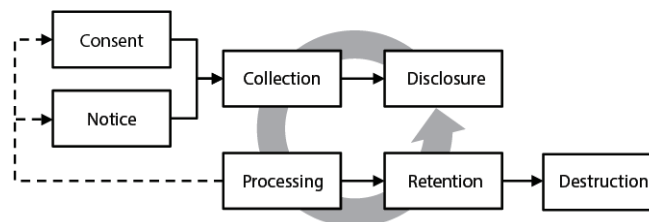
As we explore further in chapter 2, privacy-preserving systems exist in a rich ecosystem of diverse actors with different viewpoints: Lawyers aim to maintain a defensible position in a court of law; IT developers focus on developing robust, extensible, and useful software; IT

managers aim to deliver value to their customers; and so on. The unifying theme across all these professions is how data lives in the IT ecosystem and how IT developer can take steps to protect the data's privacy in a manner that is consistent with these other viewpoints. To this end, we present the data life cycle and refer to activities in the life cycle throughout this book.

The data life cycle (see Figure 1-1) provides a generic, high-level overview of how data flows through an organization, including through its business processes and supporting IT systems. The life cycle is generic as a means to be adaptable in different situations; however, the technical details of how data is collected or used, for example, can vary widely based on the technology, and thus these details can introduce additional considerations not captured by the life cycle. Despite this limitation, the life cycle provides a means for an IT professional to think about end-to-end privacy protection.

In the data life cycle, it is the responsibility of a privacy-respecting organization to specify the purpose for which information will be used and maintain consistency between actual uses and stated uses. The challenge for IT professionals is that the users of the data determine the purposes, and these purposes will evolve as the organization evolves their business practices. Under EU General Data Protection Regulation (GDPR), for example, organizations that decide the purposes for which data will be processed are data controllers and users of data for those purposes are data processors.

Figure 1-1: The data life cycle



Data collection occurs at various points within an information system. A few types of data collection include

- first-party collection, when the data subject provides data about themselves directly to the collector, e.g., in a web-based form that is only submitted when the data subject clicks a button;
- surveillance, when the collector observes data streams produced by the data subject without interfering with the subject's normal behavior;
- repurposing, which occurs when the previously collected data is now assigned to be used for a different purpose, e.g., reusing a customer's shipping address for marketing;
- third-party collection, when previously collected information is transferred to a third-party to enable a new data collection.

Each of the four collection types may be either “active,” when a data subject is aware of the collection, or “passive,” when the data subject is unaware of the collection. Various consent mechanisms exist to engage the data subject in the collection activity to make it more overt. Best practice is to obtain consent prior to collection, to avoid any misconceptions and allow the data subject to opt out of or opt in to the collection before it occurs. In an “explicit consent,” the individual is required to expressly act to communicate consent. Examples of explicit consent include

- clicking a checkbox that appears alongside the collection disclosure statement in a web-based or other data-entry form, e.g., “By clicking this checkbox, you agree to allow us to collect...”
- clicking a button to acknowledge the receipt of a privacy notice, which may be displayed above the button or made obtainable through an additional step, such as a hyperlink or file download, e.g., “By clicking this button, you agree to the terms and conditions stated in...”
- responding to an automatically generated email or other type of private communication to indicate receipt of the privacy notice, e.g., “This notice was sent to you by email because...” and “Please click the link in this email to acknowledge...”

“Passive consent” or “implied consent” is generally obtained by including a conspicuous link to a privacy notice that describes the collection activities. These links may appear at the foot of a web page, for example, or be embedded in installation instructions or a user manual. However, no actions are taken by the IT system to engage the individual with the notice. Instead, use of the system is assumed to imply consent.

The extent to which the data subject obtains the privacy notice and infers the specific types of collections taking place determines whether the collection is overt. For example, a privacy notice may state collections are performed for marketing purposes (e.g., to enable third-party collection by a marketing service). Such general purposes may not lead a data subject to believe they would be the subject of online behavioral advertising through this type of collection. If collection disclosure statements are intentionally or unintentionally vague, the collection may reasonably be viewed as covert when the data subject cannot anticipate the scope of collection.

IT professionals should ensure the purposes for which data is collected trace to appropriate uses and disclosures of that data throughout their information system. The act of “repurposing” occurs when data is collected for one purpose and then used for an entirely different purpose. This can be a source of privacy harms to the individual and may be illegal under some regulatory frameworks. Examples include collecting airline passenger data directly from passengers to schedule airline travel and then reusing this information to

develop a terrorist threat detection system or collecting a mobile user’s location to provide a route between two locations and then reusing repeated location samples to develop general profiles of traffic patterns.¹² ML has further raised the stakes, as personal data is used to build statistical models that can make novel inferences previously unforeseen at the time of collection. This new type of privacy risk underpins the EU Artificial Intelligence (AI) Act, which aims to require organizations to conduct safety assessments for systems that can create new surveillance and interference risks. While repurposing is not always viewed negatively by data subjects, it is important to assess the risk to privacy before proceeding to repurpose data.

Finally, IT professionals should consider how long data is retained by their system and, when retention is no longer needed, how they choose to destroy it. Data may be retained to fulfill ongoing business needs or legal obligations. For example, an airline must retain consumer travel information for their bookings at least until the traveler has completed their flight; however, this information may be retained longer to comply with government regulations, fulfill the internal requirements of customer loyalty programs, profile their customers for marketing purposes, or offer their customers improved services. However, this data may eventually have limited value to any of the company’s existing practices, at which point, the company may consider destroying the data to reduce the risks associated with retaining it. The U.S. NIST Special Publication 800-88, Appendix A, describes several media-appropriate techniques for sanitizing storage devices and destroying data that range from clearing the data by overwriting it with pseudorandom data to degaussing electromagnetic devices to, finally, incinerating the physical media. The level of destruction required is determined by the sensitivity of the data, and, in many situations, simply deleting the data may offer adequate protection.

The data life cycle is shaped by the privacy objectives and business practices of an organization, and the systems they develop will be adapted to meet these objectives. Table 1-1 presents the data life cycle from two extreme perspectives: (1) a “maximize information utility” objective, which views data as the basis for monetization and new revenue and seeks to collect and retain as much data as possible, and (2) a “minimize privacy risk” objective, which views data as potentially toxic with inherent risks that can result in significant, irreversible privacy harms. Depending on the data type, a single organization may prefer to mix these two cultures in its philosophical approach to engineering privacy-preserving systems.

Table 1-1: Envisioning two data life cycle extremes from the perspective of the data collector

	Maximize information utility	Minimize privacy risk
Collection	Collect any available data, as the value will be realized later when we envision new services and products. Post generic privacy notices to accommodate broadly defined, future collections.	Only collect data for established purposes and always collect consent from data subjects for sensitive data. Allow data subjects to opt out of services they deem unnecessary and before collecting the data, when possible.

Processing	Ensure open access to data within the organization. Easy access drives innovation and creative new uses and leads to increased utility and market competitiveness.	Only use data for the purpose of the original collection. Any new uses require additional consent from the data subject, and/or the sending of new privacy notices.
Disclosure	Enable disclosures with third parties to leverage new marketing and outsourcing opportunities or to enable previously unplanned third-party services.	Limit disclosures to those purposes for which data was originally collected. Any new disclosures require additional consent from the data subject and/or sending new privacy notices.
Retention	Retain data as long as reasonably practical. Long-term retention enables longitudinal analysis of data subjects to better accommodate their long-term needs and build lifetime services.	Destroy data when it is no longer needed to complete the transaction. Any new uses that motivate longer retention periods require additional consent from the data subject and/or the sending of new privacy notices.
Destruction	Avoid destruction by using long-term backups, or reduce access to data, but retain original data or a summary of the data for future uses or for reinstating services.	As soon as data is no longer needed, ensure the data and any derivatives are removed from all systems using appropriate methods to prevent recovery.

As we see in Table 1-1, organizations have different viewpoints based on their business objectives. In the maximize information utility culture, information is broadly collected and shared, and retention persists up to the physical limits of the organization's storage devices. In the minimize privacy risk culture, collection and retention are driven by need and new uses are planned commensurate with consent from the data subject. While both views are extreme, they may be practiced separately for different types of data within the same organization.

1.7 Individual Expectations of Privacy

Individuals, whether they are employees, students, customers, or citizens, are concerned about their privacy. A privacy study by Acquisti and Grossklags found 73% of individuals believe they do not have enough privacy.²⁰ At 90%, an overwhelming majority of those surveyed define privacy as control over their information. At 61%, more than half of those surveyed view privacy as necessary to preserve their personal dignity, and 50% view it as necessary to develop personal autonomy. However, it was further discovered that individuals do not behave in a manner consistent with what they say. In other words, while individuals value privacy, they may be observed as freely exchanging their privacy for services and other conveniences. Acquisti and Grossklags effectively argue that bounded rationality limits the human ability to acquire, memorize, and process all relevant information when making privacy choices. This includes information about the long-term impact of sharing personal details with others, all the various ways personal information might be used, and how that use can affect the person's long-term desire to feel safe from outside interference and surveillance and remain free to express themselves within a private community.

Even with complete information, such as information that could be gleaned from an extensively detailed privacy notice, individuals are still susceptible to weigh losses heavier than gains, miscalculate their own future preferences, draw inaccurate conclusions from past experiences, and trade future utility for immediate gratification. These behaviors may lead individuals to assume a given situation is private because their past experiences do not include new technologies that challenge their previous experiences by collecting sensitive, personal details. It also could lead an individual who suffers a privacy harm to reject a service indefinitely—never trusting that it can be adapted to protect their privacy in the future.

For IT professionals, these insights present important ethical and risk-related challenges to how technology is used to collect and protect personal information. One approach is to transfer control to the individual whenever possible, allowing them to manage their own privacy risks. While this approach requires designing systems to expose this level of control to users, the underlying premise is that individuals know their unique privacy risks better than outsiders, whereas IT professionals may misjudge the risk or be unfamiliar with the individual's personal circumstances. However, this cannot be the whole solution, as individuals can still miscalculate their long-term preferences. Thus, IT professionals must be vigilant to observe privacy harms and refactor their systems with privacy controls to prevent these harms in the future. Often, to protect an individual, more information (e.g., gender, age, lifestyle) must be collected to determine the person's privacy risks, which only further exposes them to additional privacy threats. Thus, IT professionals must strike the right balance that respects individual expectations of privacy against the business needs for the data.

1.8 Summary

In this chapter, we provided a general overview of this book by identifying who should read this book, comparing alternative definitions of privacy and illustrating a few sources of privacy risk to organizations and individuals. In addition, we briefly introduced a framework for IT professionals that can be reused across the remaining chapters of this book. The framework defines the relationship between privacy and security, which explains security can be used to support privacy but does not alone ensure IT privacy. Rather, privacy requires that IT professionals coordinate technology and policy to construct a holistic solution. This framework includes the privacy principles that have become the foundation for discussing privacy in a domain-independent manner and that can be used to evaluate technology and policy to identify and mitigate privacy risks. For IT professionals, the privacy principles are most meaningful in the context of the data life cycle. We discuss how the data life cycle can be used to envision two extreme perspectives on personal information use: the maximize information utility culture, and the minimize privacy risk culture. These two perspectives illustrate the trade-offs that organizations face when making choices about privacy-enabling and privacy-threatening technology and policy—choices that impact the acquisition,

development, and deployment of IT systems. Finally, we close by discussing the inherent conflict in how individuals view their personal privacy. On one hand, they freely exchange very private details for convenient products and services and, on the other hand, wish they had more privacy. As stewards of personal data, IT professionals must grapple with this tension throughout the data life cycle and recognize when to invoke ethical decision-making as an individual's personal rewards exceed the personal protections afforded by IT and IT policy.

Endnotes

- 1 Alan Westin, *Privacy and Freedom*, (The Bodley Head Ltd, 1970).
- 2 Helen Nissenbaum, *Privacy in Context: Technology, Policy, and the Integrity of Social Life*, (Stanford Law Books, 2009).
- 3 Daniel J. Solove, "A Taxonomy of Privacy," *University of Pennsylvania Law Review*, no. 3, (2006).
- 4 M. Ryan Calo, "The Boundaries of Privacy Harm," *Indiana Law Journal*, vol. 86, no. 3, (2010), 1131–1162.
- 5 Javeline Strategy & Research, *2023 Identity Fraud Study: The Butterfly Effect*, March 28, 2023.
- 6 Javeline Strategy & Research, *2023 Identity Fraud Study*.
- 7 IBM Security, *Cost of a Data Breach Report 2023*.
- 8 IBM Security, *Cost of a Data Breach Report 2023*.
- 9 Emily Flitter and Stacy Cowley, "Voice Deepfakes are Coming for Your Bank Balance," *The New York Times*, August 30, 2023
- 10 PriceWaterhouseCoopers, *2010 Global State of Information Security: Trial by fire*, October 2009; *PriceWaterhouseCoopers, 2011 Global State of Information Security: Respected – but still restrained*, 2010.
- 11 Charles Fried, "Privacy," *The Yale Law Journal*, 77: (1968), 475–93.
- 12 Julie E. Cohen, "Examined Lives: Information Privacy and the Subject as Object," *Stanford Law Review* 52, (2000), 1373–1426.
- 13 Yang Wang, Gregory Norcie, Saranga Komanduri, Alessandro Acquisti, Pedro Giovanni Leon, and Lorrie Faith Cranor, "I regretted the minute I pressed share': a qualitative study of regrets on Facebook," *Proceedings Seventh Symposium on Usable Privacy and Security*, (2011), 1–16.
- 14 Solove, "A Taxonomy of Privacy."
- 15 PriceWaterhouseCoopers, *A C-suite united on cyber-ready futures: Findings from the 2023 Global Digital Trust Insights*, August 2023.
- 16 U.S. Department of Health, Education, and Welfare, *Secretary's Advisory Committee on Automated Personal Data Systems, Records, computers, and the Rights of Citizens*, (1973).
- 17 Ann Cavoukian, *Privacy by Design: Take the Challenge*, 2009.
- 18 OECD *Guidelines on the Protection of Privacy and Transborder Flows of Personal Data*, Organisation for Economic Co-operation and Development, 2001, <https://www.oecd-ilibrary.org/science-and-technology/oecd-guidelines-on-the-protection-of-privacy-and-transborder-flows-of-personal-data>.
- 19 Annie Antón et al., "Inside JetBlue's Privacy Policy Violations," *IEEE Security and Privacy*, 2004.
- 20 Acquisti, Grossklags, "Privacy and Rationality in Individual Decision Making," *IEEE Security and Privacy* 3(1): (2005), 24–30.

CHAPTER 2

Engineering and Privacy

Stuart S. Shapiro, CIPP/G, CIPP/US; Travis D. Breaux, CIPT¹

In this chapter, we examine the role of information technology (IT) systems engineering in protecting personal privacy and explore in particular how IT developers can integrate privacy into system development. System development can encompass hardware, as well as software of varying scale, scope, and complexity. It therefore often involves a variety of distinct technical disciplines and subdisciplines, including systems engineering, software engineering, security engineering, and, of course, privacy engineering.

IT professionals should consider how their systems affect privacy whenever these systems contact personal information (sometimes referred to as personal data). Information-intensive systems include web-based retail, hospitality and travel reservation systems, banking systems, electronic health records, and social networking. However, under the privacy theories of autonomy and freedom, privacy also concerns systems that may not directly collect or use personal information but still affect the personal development, free expression, and movement of individuals throughout society.² This includes transportation systems, electronic voting systems, and systems that provide citizens with information about the activities of their local and national governments. Because of the personal nature of privacy, it is critical that IT developers consider the role software plays in privacy and design systems to protect individual privacy. In section 2.1, we examine the larger privacy ecosystem and discuss how it relates to different software-development models. This section illustrates how various professions play an important role in privacy-preserving IT engineering and presents a brief introduction to the software engineering practice. In section 2.2, we introduce the fundamentals of risk management and demonstrate how risk can drive decisions to increase or decrease a project's investment in privacy. Sections 2.3 through 2.6 address specific techniques for managing privacy during all stages of software engineering, including requirements, design, testing, deployment, and beyond.

2.1 Privacy in an Information Technology Ecosystem

A useful way of thinking about how privacy is situated within a large IT project is to consider the broader ecosystem, which consists of multiple professions that all interact during the development and use of hardware and software.³ In addition to the developers who write the software, the surrounding ecosystem includes other roles that hold a stake in how the system is developed (see Figure 2-1):

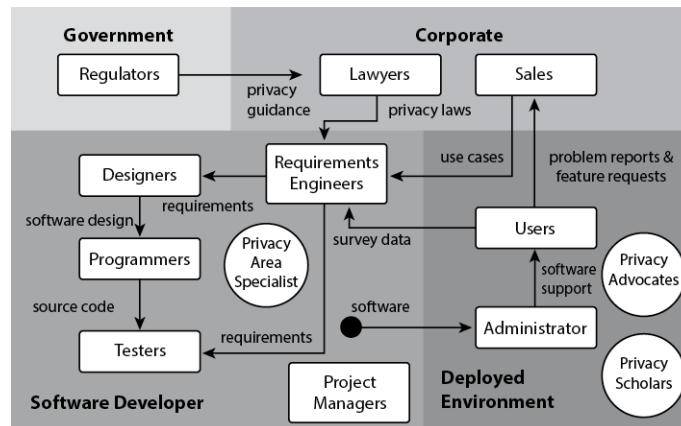
- **Project managers:** Ensure adequate resources are available to construct the system and team members communicate effectively during construction, deployment, and maintenance.
- **Marketing and sales:** Work with customers to establish new requirements and promote the software in the marketplace. Salespeople should understand how their software protects the privacy rights of individuals at an appropriate technical level for their clientele.
- **Chief privacy officer (CPO) or data protection officer (DPO):** Oversees the structure and operation of the organization's privacy program, including its technical aspects. As specified by the EU General Data Protection Regulation (GDPR), DPOs have a remit that includes (personal) data security, unlike some

CPOs. They also enjoy independent decision-making authority, also unlike some CPOs.

- Chief information security officer (CISO): Bears overall responsibility for the structure and operation of the organization's information security program, cybersecurity in particular. As a result, they must closely coordinate with the CPO or DPO to ensure systems and processes protect personal data appropriately and are consistent with the organization's privacy program.
- Lawyers: Track regulatory issues relevant to the software's function or manner of construction. This includes monitoring privacy legislation developments in markets where software is deployed, monitoring emerging threats to privacy that could reshape the regulatory environment or consumer trust, and communicating these issues to the developers responsible for aligning software with legal and social norms.
- Regulators: Promulgate, interpret, and enforce legal requirements about privacy with which public and/or privacy sector organizations must comply. In the United States, the Federal Trade Commission (FTC) is the best-known, though not the only, national privacy regulator, while in the European Union national data protection authorities (DPAs) fill this role. Many countries outside the United States and European Union have comparable bodies. More localized regulatory authorities may also have cognizance, as is the case in many U.S. states, most notably California.
- Requirements engineers: Collect, analyze, and manage requirements.
- Designers: Translate software requirements into an architecture or design. Designers are responsible for tracing privacy-related requirements, such as anonymity, confidentiality, and integrity requirements, throughout the software architecture.
- Programmers: Translate software design into source code using best practices and standard libraries and frameworks.
- Testers: Validate that the software conforms to the requirements. Testers must discover ways to "break the system" or ways in which privacy may be violated by a misuse or abuse of the software's functionality.
- Users: Operate or interact with the software to perform their daily work or recreation. Users who are also data subjects must be aware of and informed about how software uses their personal information, and they must be provided a reasonable degree of, or legally required, control over that information.
- Administrators: Install and maintain the software. Administrators, who may also be users, have responsibilities to ensure the operational assumptions behind the

software's design are implemented, whether these assumptions are in the physical environment or in the operating system. Administrators rely on adequate documentation to ensure software is properly installed and maintained.

Figure 2-1: An incomplete view of the software ecosystem for privacy



2.1.1 The Privacy Engineer

The diversity of stakeholders in the software and larger engineering ecosystems can be managed by “privacy engineers” who serve as both an active part of project teams and as a repository of knowledge when interacting with the different stakeholders. In our experience, this engineer often begins as a software developer and later becomes a software project manager before taking on the role of privacy engineer. The privacy engineer has several responsibilities, including to

- collect critical regulatory requirements from lawyers to validate that marketing and other requirements are consistent with laws and social norms;
- propose additional privacy-related requirements based on the specifics of the project;
- work with designers to discuss best practices and to develop and assess potential solutions when translating requirements into design specifications, including potential use of privacy-enhancing technologies;
- help verify that those specifications are correctly implemented and have the intended privacy-related effects;
- assist with post-deployment support, including privacy-related bug fixes and enhancements;
- collect user feedback and monitor privacy blogs, mailing lists, and newspapers for new privacy incidents, updating relevant practices in response when appropriate.

The privacy engineer develops a “community of practice” or “a collective process of learning that coalesces in a shared enterprise,” such as reducing risks to privacy in technology.⁴

The community of practice includes professionals outside the engineer’s organization. For example, prominent bloggers, including privacy law scholars and nonprofits, track emerging issues and report on newsworthy items that affect their profession. In June 2012, emerging state legislation on driverless vehicles and autonomous aircraft (drones) was closely monitored by Ryan Calo, a prominent privacy scholar at the University of Washington. The Center for Democracy and Technology also maintained policy research and analysis on a range of privacy-sensitive topics, such as behavioral advertising, location, identity management, data breaches, and more. In addition, regulators often provide guidelines to organizations that inform how to interpret various regulations. The FTC regulates privacy using its statutory authority to pursue unfair and deceptive trade practices.

In privacy, such practices arise from a misalignment between privacy policies, which promise a level of privacy protection to consumers, and broken information practices that violate those policies. Through decades of experience, the FTC has published case highlights, guidelines, reports, and workshop summaries that privacy engineers can integrate under the constraints of their IT enterprises to explore where consensus is forming around emerging issues in privacy. Finally, organizations such as the IAPP sponsor workshops and training seminars to improve the privacy profession by enabling networking opportunities across industries and government. By monitoring these varied sources of information and learning about prominent thought leaders, privacy engineers can remain current on how privacy evolves in response to technology and learn to improve how they deliver relevant input into their organization’s software and related engineering processes.

Communities of practice are typically also the source of guidance that supports ethical engineering practice. Engineering ethics has a long history in the form of both an academic discipline and ethical codes promulgated by major engineering professional societies. In the case of privacy engineers, relevant codes have been developed by organizations such as the Association for Computing Machinery (ACM),⁵ the Institute of Electrical and Electronics Engineers (IEEE),⁶ the British Computer Society (BCS),⁷ and the International Council on Systems Engineering (INCOSE).⁸ While, historically, such codes tended to emphasize professional standards of conduct, the increased complexity of sociotechnical environments, including recent developments in artificial intelligence (AI), has heightened awareness of the need to grapple with ethical issues as part of substantive technical practice. Moreover, many codes now explicitly articulate an ethical obligation to address system privacy and security. Ethical codes are further discussed in section 2.1.5.

2.1.2 The Engineering Landscape

As the heterogeneity and complexity of the sociotechnical environment has steadily increased over time, a broader array of technical disciplines has evolved of necessity.

Considering such developments as the proliferation of mobile devices, cyberphysical systems (i.e., information systems that interact with the physical environment), and the Internet of Things (IoT), one quickly realizes a sea change has occurred. Unlike the relatively constrained environment of the past, where, as a practical matter, sources of concern were generally restricted to front and back-office enterprise systems, personal computers, and the internet, the current setting is rife with devices and data flows interacting in ways both apparent and hidden, anticipated and unforeseen.

One complication that is garnering more attention of late is the distinction between IT, typically thought of as supporting enterprise business processes, and “operational technology” (OT), traditionally thought of as supporting industrial processes. OT systems are the preeminent example of cyberphysical systems and for a period could be, and were, safely ignored from the standpoint of privacy (or, for that matter, security). Now, not only are IT and OT systems increasingly interconnected, but their contexts are also widening along with the growth of smart everything—cars, homes, buildings, cities, and so on. A smart home, for example, may be characterized by myriad data flows involving various IoT devices (e.g., climate controls, virtual assistants, robotic vacuums), some of which may dynamically interact with the environment via a range of modalities, including mechanical manipulation. Much of this data will be or could be construed as personal information, which might provide the basis for further interactions both within and beyond the home, possibly unwanted, unintended, and even potentially harmful.

Dealing effectively with these environments in engineering terms often requires the appropriate application of diverse disciplines. Systems engineering can be thought of as providing a holistic perspective, concerning itself with the totality of a system—hardware, software, interfaces with other systems, system properties such as security and privacy—across the entirety of the system’s life cycle from initial conception to retirement. As part of this process, other specialized disciplines may be brought to bear. Of these, the most prominent tends to be software engineering. Software engineering is a disciplined approach to the construction of software. While considerable amounts of software are created by end-user programmers who initially work to solve a personally familiar problem, these personal projects quickly become large-scale endeavors developed and maintained by hundreds, if not thousands, of professional engineers.² The emerging complexity that results from scaling small software projects into large ones requires a sophisticated IT ecosystem consisting of well-trained professionals and well-established processes.¹⁰ These professionals and processes often must include those equipped to address areas such as user experience (UX), security, and privacy.

2.1.3 Software Process Models

Since the 1968 North Atlantic Trade Organization (NATO) conference on software engineering that produced the Garmisch report, software engineers have employed software

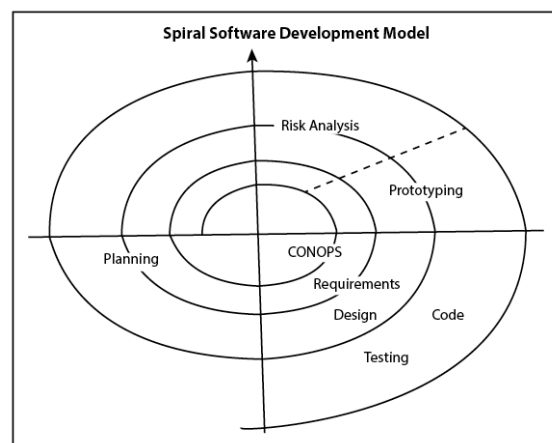
process models and methods to manage engineering complexity and coordinate the steps in constructing software.¹¹ Software process models define the various stages of software development and the conditions by which development is allowed to transition from an early stage to a later stage, as well as the artifacts produced at each stage. These models may also designate developer roles and responsibilities. Today, one can choose from a variety of software processes from plan-driven methods, such as the waterfall and spiral models that emphasize up-front documentation and planning to lighter-weight, agile methods, such as extreme programming and scrum, which emphasize personal communication and small, dynamic development teams.¹² There is even a middle ground, such as the team software process, which emphasizes process measurement and team building early on.¹³ This is not an exhaustive list, but independent of the process one uses, software developers will address the following six activities in some capacity:

- **Requirements Engineering:** The activity that yields requirements describing constraints on the software system. Requirements include environmental factors, stakeholder goals, and functional and behavioral properties of the system, such as privacy, performance, and reliability.
- **Design:** The activity that yields software designs and architectures, which describe how a particular system will operate and may include modular components with assigned functionalities, as well as connectors that link components, such as an information flow between a client and a server.
- **Implementation:** The activity of writing the source code to implement a particular design, including the development of the setup and configuration process that supports the system for the very first time.
- **Testing:** The activity of verifying that the runtime system conforms to the requirements. This includes developing test cases, which test specific functions in the software, and conducting user testing to discern how users operate the software.
- **Deployment:** The activity of installing and configuring the software in its operational environment. This may include user training to ensure they can operate the software.
- **Maintenance:** The activity of extending and fixing software over the course of its lifetime, either to repair bugs after deployment or to provide users with new functionality.

In plan-driven and agile software-development methods, software-development activities are coordinated at different development stages and levels of developer commitment. In Figure 2-2, the spiral model requires multiple iterations of development that yield working

prototypes to manage engineering risk. Going from the center of the spiral outward, this model shows how developers begin with a concept of operations (CONOPs) and proceeds to refine these ideas into requirements, design, and eventually code and test cases. At each iteration point, the development team reassesses project risks, such as ensuring the requirements are correct and the system is design feasible. In the scrum model, developers employ timeboxing in 24-hour and 30-day cycles to achieve similar effects on controlled portions of functionality within a limited time frame. Requirements, called “user stories,” are contained in a product backlog managed by the product owner. The team, which generally excludes the product owner, decides which portion of the backlog to implement in each iteration, taking working functionality, priorities, and time constraints into account.

Figure 2-2: Spiral software development model



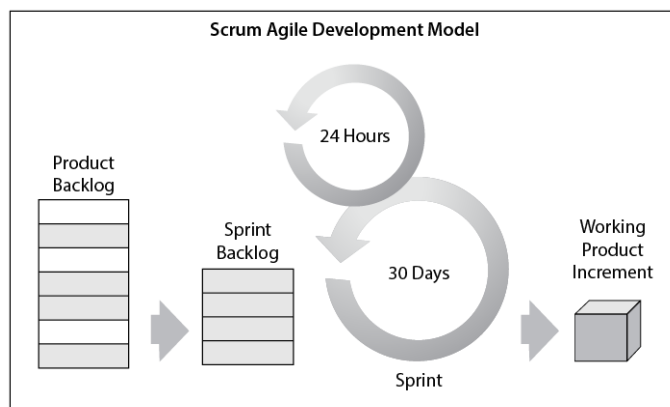
Barry Boehm and Richard Turner, authors of *Balancing Agility and Discipline: A Guide for the Perplexed*, characterize the choice between plan-driven or agile methods as determining which types of risk dominate a software project.¹⁴ Privacy can be integrated into either type of method; however, the preservation of legal requirements and the privacy engineer’s observations from monitoring the community of practice necessitate a minimum level of planning to respond to privacy risks systematically. In the spiral model, privacy must be considered from the very beginning, at the CONOPs and requirements stage in the center of the spiral. Alternative designs are produced to address privacy requirements before project planning begins in the lower-left quadrant. The risk analysis phase of the upper right quadrant concerns “project risks,” raising questions such as:

- Is the scope of planned effort feasible?
- Which design alternative is best suited to solve a particular problem?
- Can we explore designs and reduce risks using prototypes of novel or complex functionality?

While IT developers can return to or repeat earlier iterations in the spiral model, this type of revision is costly and should be avoided. Therefore, in plan-driven methods, there is a need to address privacy early using a comprehensive toolkit of requirements and design techniques.

As Boehm and Turner argue, even agile methods can include some planning when the risks outweigh the benefits of increased agility. In the Scrum process, for example, the product owner prioritizes user stories, which will be developed during an iteration, called a sprint. Developers determine how much time is required to implement each story. (See Figure 2-3). To bridge scrum and privacy, the privacy engineer can participate in developing user stories to help identify privacy risks and harms and then propose strategies to mitigate those risks.

Figure 2-3: Scrum agile development model

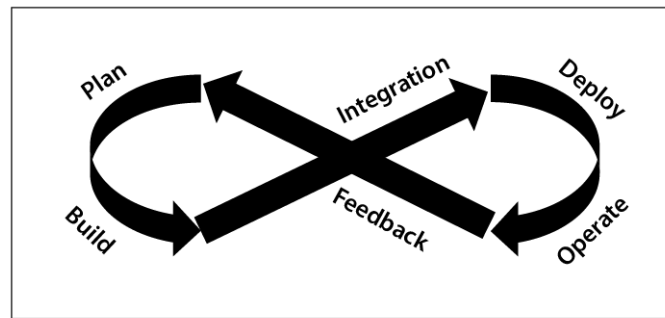


Furthermore, the privacy engineer may review the sprint backlog, which contains the list of stories that will be implemented during the current sprint, to ensure the working increment produced by the iteration does not contain major privacy risks. For example, imagine a new web-based product developed for children under 13 that would be governed by the Children’s Online Privacy Protection Act (COPPA). In an upcoming sprint, the product owner may wish to see a new login facility for the product. To comply with the COPPA, however, this working increment will need to support a parental consent mechanism before collecting the child’s personal information. While the login facility could be prototyped without this privacy control, it should not be tested on children without the control in place, since the control plays a critical role in protecting privacy. Therefore, the privacy engineer can intervene and review the sprint plans to catch dependencies between privacy-enabling and privacy-threatening functionality and suggest changes to the sprint backlog before these functions go live. In general, the project manager should decide when and where to involve the privacy engineer to reduce privacy risks during software development and to ensure other developers respect this person’s contributions.

More recently, an agile-related model under the general rubric of software development and operations (DevOps) has been gaining favor. DevOps aims to more closely integrate system development and system operations, speeding up both the development and the deployment

of updated systems.¹⁵ DevOps emphasizes a continuous, looping activity stream that takes feedback on system performance, identifies a set of necessary or desired changes and enhancements, rapidly engineers them, and then fields them. As a result, the DevOps model (see Figure 2-4) is frequently visualized as a figure eight. While it enables the fast evolution of IT systems, in part by heavy use of automated tools, the velocity of DevOps can present challenges to ensuring properties such as privacy and security are appropriately embedded and maintained in a system.

Figure 2-4: DevOps model of software development



Recognition of this issue has led to the evolution of DevOps into development, security, and operations (DevSecOps). DevSecOps aims to integrate security throughout this life cycle, supported by specialized automated tools. These include automated security control selection and provision, vulnerability scanning and patching, and security testing. Privacy (beyond security-based confidentiality), though, has yet to be similarly integrated.

It should be noted some proposed methods for engineering privacy into systems basically amount to specialized life cycles themselves. These include the Organization for the Advancement of Structured Information Standards (OASIS) Privacy Management Reference Model and Methodology (PMRM) and the PReparing Industry to P_rivacy-by-design by supporting its A_pplication in R_earch (PRIPARE) privacy and security-by-design methodology, funded by the European Commission.¹⁶ Other privacy engineering methods, in contrast, are much more atomic and aimed at specific engineering activities. These include the LINDDUN threat modeling method developed at KU Leuven in Belgium, discussed in section 2.2.1.1, and the Privacy Risk Assessment Methodology (PRAM) developed by the U.S. National Institute of Standards and Technology (NIST), discussed in section 2.2.2.3.¹⁷ While more focused methods enable flexible mixing and matching of techniques, the more holistic approaches can potentially (but not necessarily) reduce the number of distinct decisions that must be made. Which method or combination of methods makes the most sense will be highly contextual and dependent on system and environmental characteristics, including the extent to which the system may be considered complex and the process standards and supporting tools of the organization engineering it.

2.1.4 Defect, Fault, Error, Failure, and Harm

Our premise is that many functional violations of privacy can be avoided by the correct design, implementation, and deployment of software. The IT developer can limit privacy violations by carefully managing steps leading up to system failure. IEEE, one of the largest engineering professional associations, defines software engineering defects, faults, errors, and failures as follows. We include the definition of harm as it relates to privacy.¹⁸

- Defect: A flaw in the requirements, design or implementation that can lead to a fault.
- Fault: An incorrect step, process or data definition in a computer program.
- Error: The difference between a computed, observed or measured value or condition and the true, specified or theoretically correct value or condition.
- Failure: The inability of a system or component to perform its required functions within specified performance requirements.
- Harm: The actual or potential ill effect or danger to an individual's personal privacy, sometimes called a hazard.

A functional violation of privacy results when a system cannot perform a necessary function to ensure individual privacy. For example, this occurs when sensitive, personally identifiable information (PII) is disclosed to an unauthorized third party. In this scenario, the “defect” is the one or more lines of computer source code that do not correctly check that an access attempt is properly authorized, and the “fault” is the execution of source code that leads to the error. The “error” is the unauthorized access, which is an observed condition that is different from the correct condition, under which “no unauthorized access will occur.” The “failure” is the unauthorized third-party access. Failures are often described outside the scope of source code and in terms of business or other practices.

“Privacy harms” may be objective or subjective. An “objective harm” is “the unanticipated or coerced use of information concerning a person against that person” and a “subjective harm” is “the perception of unwanted observation,” without knowing whether it has occurred or will occur.¹⁹ In public reports, we frequently learn about a system failure and subjective privacy harms or potential for harm. Less often do we hear about the underlying errors, faults, and defects that led to the system failure, and occasionally we learn about specific individuals who suffered objective harms.

In “A Taxonomy of Privacy,” George Washington University Law School Professor Daniel Solove identifies four risk categories of privacy harm: “information collection, information processing, information dissemination and invasion.”²⁰ Solove writes that information collection harms resulting from surveillance and interrogation may lead to a degree of coerciveness. Observing a user click on age-relevant website links (e.g., links to music from a particular age-specific era) is an example of surveillance, whereas asking a user to provide

their age as a condition of using a service is a form of interrogation. We discuss Solove's harms in further detail in section 2.2.1.4 under risk management. While these harms can overlap in practice, a robust privacy design applies special consideration to each of these harms to avoid unintended threats to an individual's privacy.

When a privacy incident occurs, the reported description often refers to the failure or harm. Because individuals personally experience harms and share these experiences with others, the engineer may discover harms reported in news articles or blogs. In addition, regulatory agencies conduct investigations in response to reported harms and, as a consequence, regulatory enforcement actions can detail additional evidence in the form of errors or failures that link the software's operation and installation to the reported harm. As we discuss in section 2.3, there are techniques IT developers can use to anticipate and mitigate the risk of potential harms based on regulatory enforcement reports and news articles. In addition, there are techniques for identifying and removing defects from design documents and programs, which we discuss in sections 2.4 and 2.5 on high- and low-level design, respectively.

2.1.5 Relevant Frameworks

Several frameworks, some of them constituting standards, are potentially applicable to or usable by privacy engineers and privacy engineering processes. These frameworks have been developed by a variety of agencies, standards bodies, and professional societies and align with different aspects of privacy engineering practice. It is not expected that any organization would employ all of them, in part because of overlaps. Rather, they should be viewed as a collective resource to be leveraged in support of privacy engineering. Some of these frameworks are oriented around risk controls while others address requirements, design, skills, and ethics. Section 2.2.2.5 discusses control implementation in more detail.

One of the best known privacy-specific frameworks is the Generally Accepted Privacy Principles (GAPP) promulgated jointly by the Canadian Institute of Chartered Accountants (now the Chartered Professional Accountants Canada) and the American Institute of Certified Public Accountants. While the GAPP itself can be used as a source of general privacy requirements, an associated maturity model specifies GAPP criteria at a level of detail that can be employed as a more specific requirements framework.²¹ In a somewhat similar vein, the U.S. NIST, as part of its wide ranging cybersecurity and privacy program, has promulgated a privacy framework that breaks down fundamental privacy risk management activities (identify, govern, control, communicate, protect) into categories and subcategories, which can be thought of as high-level requirements.²² In both cases, one would expect more specific system-level controls to be applied to implement requirements derived from the frameworks.

A larger and more specific framework is the NIST's Special Publication 800-53, Revision 5, which is a comprehensive catalog of security and privacy controls.²³ While intended for use by U.S. government agencies, nongovernment organizations have leveraged it due to its

breadth and level of detail, including assessment guidance (in a separate volume). Its defined privacy-relevant controls include ones applicable to organizations and to systems, some of which are privacy-specific and others are joint privacy and security controls. These controls represent specific ways of meeting higher-level privacy requirements and mitigating risks through the design and implementation processes. Residing somewhere between the NIST Privacy Framework and NIST Special Publication 800-53, International Organization for Standardization (ISO)/International Electrotechnical Commission (IEC) 27701—an extension of ISO/IEC 27001 addressing information security management systems—articulates types of (mainly security) controls particularly relevant for privacy information management systems. Orthogonal to these other frameworks is ISO/IEC 27550, which addresses how privacy engineering relates to other relevant types of engineering (e.g., systems engineering, security engineering) and to common life cycle processes (e.g., requirements analysis, architecture design).²⁴

One of the difficulties in carrying out meaningful privacy by design (PbD) has been the absence of frameworks effectively addressing the “design” part of the equation, as opposed to the privacy part. The recently published ISO 31700 PbD standard attempts to supply this, describing thirty discrete, albeit high-level requirements.²⁵ The Institute of Operational Privacy Design (IOPD) also recently issued its Design Process Standard, which specifies process requirements for building privacy into products and services across the life cycle, including risk management.²⁶

While requirement, control, and process frameworks are valuable, they, and other aspects of privacy engineering, require an appropriately skilled workforce to make good use of them. The NIST’s National Initiative for Cybersecurity Education (NICE) Framework (Special Publication 800-181, Revision 1) establishes a standard structure for defining roles and competencies.²⁷ The NIST is leveraging this framework through its Privacy Workforce Public Working Group to create a Privacy Workforce Taxonomy aligned with its Privacy Framework.²⁸

Ethical codes related to privacy engineering, as discussed in section 2.1.1, can also be thought of as frameworks governing ethical engineering practice. These are often articulated at a fairly high level, though, which can make them challenging to apply to engineering decisions in situ. A noteworthy exception to this is the ACM Code of Ethics, which consists of twenty-five principles—each with substantive elaboration—a number of which have implications for privacy engineering.²⁹ Not least of these are Respect Privacy (Principle 1.6) and Avoid Harm (Principle 1.2). Other principles address IT’s potential to discriminate, security, and societal implications of infrastructure systems. Taken together, these principles can inform design choices generally and trade-off decisions particularly. Trade-off analysis is discussed in section 2.4.2.7.

2.2 Privacy Risk Management

Risk management is an integral aspect of developing reliable systems. IT development projects must address multiple types of risks, including programmatic risk, such as the risk of project cost and schedule overruns, and technical risk, which includes the risks associated with specific technologies. Thus, an IT professional may be required to perform the role of a privacy risk analyst.

Risk is defined as a potential adverse impact, along with the likelihood that this impact will occur. The classic formulation of risk is an equation: $\text{risk} = \text{the probability of an adverse event} \times \text{the impact of the event}$. In practice, analysts may express probability and impact numerically and compute a numerical result that can be used to compare risk levels across different events. Risk comparisons are used to prioritize risks, nominally based on the risk score but sometimes based primarily on the highest impact or highest probability. However, it is often a technical or empirical basis for one or both numbers is nonexistent, in which case an ordinal measure is used, such as assigning a value of low, medium, or high impact to an adverse event.

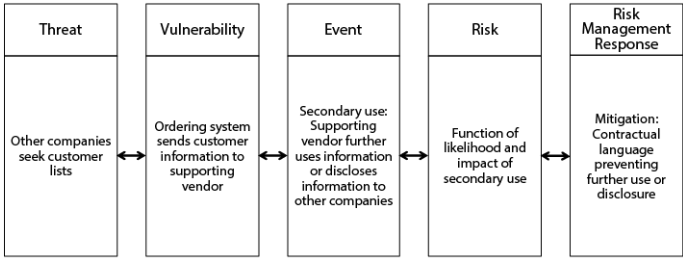
Ordinal measures are subject to the limitations of human perception and bias, as are numerical measures, and all measures with the same level (e.g., low) remain contextually relative and not easily comparable. One approach is to identify a relative median event that a risk analyst can use to assign values to other events (e.g., event X is higher or lower impact than event Y). However, caution should be used when treating such measures as quantitative data, because normal arithmetic may not be applied to this data: One cannot, for example, take the sum of two or more ordinal values, that is, $\text{low} + \text{high} \neq \text{medium}$, though explicit relations that map combinations of ordinal values to a resultant value can be rationalized. Douglas Hubbard and Richard Seiersen in *How to Measure Anything in Cybersecurity Risk*, as well as Jack Freund and Jack Jones in *Measuring and Managing Information Risk*, though, assert that when properly approached, quantitative measures are readily ascertainable and any imprecision pales in comparison to that of qualitative, ordinal measures.³⁰

In pursuit of a quantitative risk score, Jaspreet Bhatia and Travis Breau introduced an empirically validated privacy risk scale based on the theory of perceived risk described by Paul Slovic in *The Perception of Risk*.³¹ The scale is used to measure how willing data subjects are to share their personal data based on their social and physical distance to the privacy harm. The scale can be incorporated into a survey that is distributed to a company's data subjects to measure the perceived risk to specific data types. The measurements are multiplicative, such that a data type with a risk score of four is twice as risky as a data type with a risk score of two. The scale has been used to grade data types as more or less risky in the event of different types of privacy harms, and these grades can be used to prioritize data protections for types with the most risk. The findings of the evaluation further include that induced disclosure harms are perceived as lower risk than surveillance and insecurity harms in Solove's privacy risk taxonomy, that subjects perceive lower risk when they perceive the

greater benefits of sharing (consistent with the Privacy Paradox), and that likelihood was not a multiplicative factor when computing privacy risk.³²

Effective privacy risk management employs a risk model that an analyst uses to identify and align threats with the system vulnerabilities that they may exploit to yield risks, which are adverse events associated with degrees of likelihood and impact (see Figure 2-5). For guidance in applying the risk model, the analyst uses a risk management framework, which is a step-by-step process for identifying threats, vulnerabilities, and risks and deciding how best to manage the risks. Conventional risk management options can include (1) accepting the risk as is, (2) transferring the risk to another entity, which is how cyber insurance works, (3) mitigating the risk by introducing an appropriate privacy control or a system design change, or (4) avoiding the risk, e.g., by abandoning particular functionality, data, or the entire system. Risk avoidance may be impractical or impossible in many situations. For example, the risk of laptop theft is generally impossible to avoid, and thus assuming this vulnerability will always exist may lead to using encryption to mitigate the loss of private data stored on these devices. Furthermore, any one of these risk management options may introduce a new risk, thus creating a risk-risk trade-off. A risk-risk trade-off is not risk avoidance per se, but the result of interdependent risk mitigation and acceptance decisions.

Figure 2-5: Risk model alignments



2.2.1 Privacy Risk Modeling

As previously implied, a comprehensive risk model addresses potential threats, vulnerabilities, and adverse consequences (i.e., events), as well as impact and likelihood factors for resultant risks. However, each of the components that align to identify a risk—threats exploiting vulnerabilities to produce an adverse consequence—constitutes a model itself. While this fact tends to be most explicitly acknowledged by common references to threat modeling, defining universes of relevant potential vulnerabilities and consequences are equally understandable as modeling activities. For each of these, one has the choice of developing a system-specific model or using a preexisting model. A hybrid approach can also be taken by using a preexisting model as a starting point and then tailoring it to better match the context of the system. Indeed, privacy risk analysts frequently employ preexisting consequence models, several of which are well-known, as discussed in section 2.2.1.3, as a starting point and use them to build out the other component models by implication.

Unfortunately, this approach can also lead to an abbreviated risk analysis exercise that relies solely on the consequence model owing to its direct connection with impact.

Privacy risk analysts can now choose from a number of privacy risk component models to employ individually or in combination. The most frequently used and long-standing privacy consequence models are the compliance model and the Fair Information Practice Principles (FIPPs). Over the last decade or so, other models have been introduced, including Calo's subjective/objective dichotomy (S/OD) and Solove's taxonomy of privacy problems. There are fewer options for vulnerability models, chief among them Helen Nissenbaum's contextual integrity heuristic and the NIST's problematic data action model. As part of its larger privacy risk model, the NIST also addresses consequences. Preexisting privacy threat models have been even thinner on the ground, with the LINDDUN threat model long the only generally available option. However, the MITRE Corporation's Pattern and Action Nomenclature of Privacy Threats in Context (PANOPTIC™) threat model recently joined it. We discuss system-specific threat model construction in section 2.3.4.2.

We review each of these models in the following sections. In addition, a number of emerging models aim to provide analytical leverage in specific areas, including online manipulation and the interdependencies of social media participants. While this list is not exhaustive, these models serve to illustrate the variety of options privacy engineers can incorporate into their projects.

2.2.1.1 Privacy Threat Modeling

2.2.1.1.1 LINDDUN

The LINDDUN privacy-specific threat modeling methodology has been inspired by Loren Kohnfelder and Praerit Garg's Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service and Elevation of Privilege (STRIDE) methodology for security threat modeling.³³ The acronym itself represents the model, as each letter stands for a particular type of system threat:

- **Linking:** Associating data items or user actions to learn more about an individual or group.
- **Identifying:** Learning the identity of an individual, through leaks, deduction, or inference.
- **Nonrepudiation:** Being able to attribute a claim to an individual.
- **Detecting:** Deducing the involvement of an individual through observation.
- **Data disclosure:** Excessively collecting, storing, processing, or sharing personal data.
- **Unawareness and unintervenability:** Insufficiently informing, involving, or empowering individuals in the processing of their personal data.

- Noncompliance: Deviating from security and data management best practices, standards, and legislation.

As indicated, LINDDUN is as much a threat-modeling process as a preexisting threat model, and its documentation describes a methodology for identifying relevant system-specific threats using data flow diagrams, including profiling potential threat actors that might be in a position to execute identified threats.

2.2.1.1.2 MITRE PANOPTIC™

A more recent privacy threat model has been developed by the not-for-profit MITRE Corporation. Just as LINDDUN was inspired by the STRIDE approach to security threat modeling, the PANOPTIC™ threat model was inspired by the widely used MITRE ATT&CK® security threat model. PANOPTIC defines categories of sociotechnical context together with categories of privacy activities, with specific contextual elements and threat actions respectively residing under each.³⁴

The PANOPTIC contexts address:

- Environment: The contextual domain in which a data action occurs.
- Distribution: How many entities with which the information holder shares information.
- Interaction: The extent to which the data subject or their proxy interacts with the data custodian, processor, third party, or their proxy (entities other than the data subject).
- Engagement: Targeted subpopulations with which the entity or their proxy interact.
- Data type: Classes of data upon which data actions are performed.

The PANOPTIC privacy activities address:

- Notice: Informing the data subject or their proxy of one or more data actions.
- Consent: Assent from the data subject or their proxy to one or more defined data actions.
- Collection: The gathering or extraction of information.
- Insecurity: Insufficient data protection controls.
- Identification: How information is associated with the data subject.
- Quality assurance: Implementing policies or processes to ensure quality throughout privacy-related activities.

- **Manageability:** Enabling the data subject or their proxy to access, modify, copy, or destroy information about themselves.
- **Aggregation:** Assembling data from one or more sets of data.
- **Processing:** Extracting and developing value and utility from information.
- **Sharing:** Making information available to another entity.
- **Use:** Leveraging information to achieve a goal.
- **Retention and destruction:** Actions that affect the persistence of information.
- **Deviations:** Data action diverges from established limits bounding the data action in question.

In addition to its taxonomy, PANOPTIC will define generic threat “patterns,” consisting of recurring sets of contextual elements, threat actions related to privacy attacks that have been observed “in the wild.” Like ATT&CK, PANOPTIC was developed from the bottom up and is based on empirical data.

2.2.1.2 Privacy Vulnerability Models

2.2.1.2.1 Contextual Integrity

Helen Nissenbaum defines contextual integrity as maintaining personal information in alignment with informational norms that apply to a particular context.³⁵ The contextual integrity heuristic posits that privacy problems arise out of disruptions to these informational norms. Contexts are socially constructed settings characterized by, among other things, norms or rules and internal values in the form of purposes or goals. Context-relative, informational norms involve actors (information senders, recipients, and subjects), attributes (information types), and transmission principles that govern the flows of information. An IT system violating or otherwise disrupting a context’s informational norms can result in a perceived privacy problem. Using the contextual integrity heuristic entails analysis to surface what norms govern a given context. To apply this heuristic, an analyst must first establish the existing informational norms and, second, determine how the system may disrupt those norms. Once identified, these disruptions can be interpreted as privacy vulnerabilities, thereby enabling a stable reference point from which to identify threats and, by extension, adverse events.

Consider an example in health care. A patient may share information about a medical condition to help the doctor provide an accurate prognosis. The doctor expects the patient to be candid, although she may also expect them to be cautious during the first encounter. When the doctor has obtained the patient’s trust, the doctor and patient will freely exchange information under the norms of this medically necessary engagement. However, the information the doctor obtains may be shared categorically and electronically with a pharmaceutical company that has treatment options available to the patient. If these

treatment options were mistakenly communicated by postal mail to the patient's home or work address, thus unintentionally revealing the presence of the condition to others, then the system would have disrupted the informational norms governing the patient-doctor transaction. To mitigate this risk, the system can explicitly ask the patient to opt in to these communications, or the system may consider exposure risks under Solove's taxonomy and how to mitigate these risks.

2.2.1.2.2 NIST Problematic Data Actions

The specifics of the NIST's privacy risk model are embedded in its Privacy Risk Assessment Methodology, though its structure is discussed elsewhere.¹⁷ The NIST's model is noteworthy as it is relatively complete, explicitly addressing vulnerabilities, adverse events, and the relative likelihoods and impacts of those events. However, the NIST employs different terminology in referring to these vulnerabilities and events. In the NIST's model, vulnerabilities are problematic data actions. These describe system behaviors with privacy implications that, while they may be authorized, create the potential for adverse events.

While not necessarily exhaustive, the NIST's catalog of problematic data actions is wide ranging:

- "Appropriation" occurs when personal information is used in ways beyond what is expected or authorized by the individual.
- "Distortion" involves the use or dissemination of inaccurate or misleading personal information.
- "Induced disclosure" takes place when individuals are pressured to provide personal information.
- "Insecurity" involves lapses in data security.
- "Surveillance" occurs when personal information is tracked or monitored out of proportion to system objectives.
- "Unanticipated revelation" is unexpected exposure of facets of an individual as a result of processing.
- "Unwarranted restriction" involves the imposition of unjustified constraints on individuals regarding access to the system and its information as it relates to them.

2.2.1.3 Privacy Consequence Modeling

2.2.1.3.1 The Compliance Model

Most systems that handle personal information do so within a related legal and/or policy regime. Legal regimes, which include statutory and regulatory mandates at any level of government, usually prescribe or proscribe certain aspects of a system in terms of what data it contains, what the system does with that data and how the system protects that data. While

the GDPR has garnered much attention owing to its scope, many other relevant statutory and regulatory mandates could be of concern depending on jurisdiction. Some, such as the Health Insurance Portability and Accountability Act (HIPAA) Security Rule, are designed to be flexible and therefore require analysts to make interpretations based on their own security risks and available security controls. This flexibility manifests itself in the Security Rule in the form of prescribed security controls that are “addressable.” This means an organization, if its environment renders such a control unreasonable or inappropriate, may substitute alternative controls that achieve equivalent levels of risk management. The organization can even forgo alternative controls if they are not reasonable and appropriate.

In addition, systems may fall under an organizational policy regime with obligations and prohibitions that must be met. The compliance model is relatively straightforward: risks are delineated as the failure to do what is required or to avoid what is prohibited. For laws, like HIPAA, that require a risk assessment or reasonableness standard, however, a privacy risk model can be used to comply with this requirement. Under the compliance model, identification and alignment of threats and vulnerabilities amounts to examining the elements of the system that relate to each specific legal or policy requirement. To maintain a record of compliance, the privacy risk analyst can employ a traceability matrix, as discussed in section 2.3.3.

2.2.1.3.2 Fair Information Practice Principles

The FIPPs often dovetail with the compliance model, as they frequently form the basis of privacy-related legal and policy regimes. For example, the FTC and U.S. Department of Homeland Security (DHS) both adopted the FIPPs in their privacy risk management recommendations. The FTC recommends the FIPPs to industry, whereas DHS applies the FIPPs to their internal practices, including privacy impact assessments. The presence or absence of an associated compliance regime notwithstanding, the FIPPs can be used in a similar fashion to laws, regulations, or policies. The FIPPs mostly prescribe, and in some cases proscribe, specific qualities and behaviors of systems that handle personal information. However, because the FIPPs typically sit at a higher level of abstraction than legal and policy strictures and because most of the principles are relative to the “purpose of the system,” significant interpretation by analysts and developers is necessary to determine how the FIPPs should manifest in a given system. Once an appropriate interpretation has been established, it can be employed as a risk model in much the same way as a legal and policy regime. The identification and alignment of threats and vulnerabilities entails examining the elements of the system that relate to each specific FIPP.

2.2.1.3.3 Subjective/Objective Dichotomy

Calo’s S/OD focuses on privacy harms, which he argues fall into two categories: “Subjective harms” are grounded in individual perception (irrespective of accuracy) of unwanted observation, while “objective harms” arise out of external actions that include the

unanticipated or coerced use of that person's information.³⁶ The relationship between subjective and objective harms is analogous to the legal relationship between assault and battery. Assault is the threat of unwanted physical contact, while battery is the experience of unwanted physical contact. Similarly, subjective privacy harms amount to discomfort and other negative feelings, while objective privacy harms are actual adverse consequences.

Harms are equivalent to adverse events in terms of risk models. Thus, this model establishes a coarse-grained point of reference for events, to which threats and vulnerabilities must be aligned. Under the S/OD model, any privacy threat that is perceivable by individuals corresponds to a subjective privacy harm. Julie Cohen and Alan Westin argue the fear of privacy harm can limit an individual's sense of freedom and expression, which may negatively affect the target system, such as a user choosing not to use a system due to a subjective harm.³⁷ To assess the potential for subjective and objective harm, an analyst may examine elements of the system that relate to individuals' expectations of how their information may be used, actual usage—including surveillance or tracking—and consent, or lack thereof, to the collection and use of that information.

2.2.1.3.4 Taxonomy of Privacy Problems

Daniel Solove's taxonomy of privacy problems arose out of specific cases.³⁸ Rather than promoting high-level privacy precepts, (as in the FIPPs and S/OD models for example, Solove surveyed specific instances that are recognized as problematic from a privacy standpoint based on cultural analysis using historical, philosophical, political, sociological, and legal sources. From these observations, he derived a generic set of privacy problems. The taxonomy consists of 16 distinct privacy problems, organized into four categories: information collection, information processing, information dissemination and intrusion, and decisional interference.

Information Collection

- **Surveillance:** Involves the observation and/or capturing of an individual's activities. For example, an advertising website embeds HTML iframes into multiple third-party news, social networking, and travel websites to track users by the pages they visit and the links they click on.
- **Interrogation:** Involves actively questioning an individual or otherwise probing for information. For example, a website requires a user to enter their mobile phone number as a condition of registration, although the website's primary function does not require the phone number and there is no statutory or regulatory requirement to do so.

Information Processing

- **Aggregation:** Involves combining multiple pieces of information about an individual to produce a whole that is greater than the sum of its parts. For example, a retail company correlates purchases of unscented lotions, large tote bags, and prenatal vitamins to infer that a customer is likely pregnant.
- **Identification:** Links information to specific individuals. For example, a website uses cookies, a recurring IP address or unique device identifier to link an individual's browsing history to their identity.
- **Insecurity:** Results from failure to properly protect individuals' information. For example, a website fails to encrypt private communications, thus exposing users to potential future harm.
- **Secondary use:** Involves using an individual's information without consent for purposes unrelated to the original reasons for which it was collected. For example, a retailer uses an email address for marketing purposes when the address was originally collected to correspond about a purchase.
- **Exclusion:** Denies an individual knowledge of and/or participation in what is being done with their information. For example, a marketing firm secretly purchases consumer data to advertise to the customer under a different company name without their knowledge.

Information Dissemination

- **Breach of confidentiality:** Results from revealing an individual's personal information, despite a promise not to do so. For example, a platform releases a user's data to a third-party plug-in despite the platform's privacy notice promising not to disclose the data to anyone.
- **Disclosure:** Involves revealing truthful information about an individual that negatively affects how others view them. For example, a private "lifestyle" service discloses a list of members, which is obtained by groups who disapprove of the lifestyle.
- **Distortion:** Involves spreading false and inaccurate information about an individual. For example, an employment history verification service incorrectly identifies a job applicant as a felon.
- **Exposure:** Results from the revelation of information that we normally conceal from most others, including private physical details about our bodies. For example, a person's prior purchase of a urinary incontinence product is used as a promotional endorsement and sent to the person's broader social network.

- **Increased accessibility:** Involves rendering an individual's information to make it more easily obtainable. For example, a children's online entertainment service allows any adult to register and interact with child members, leaving these children accessible to strangers without parental consent.
- **Blackmail:** Involves the threat to disclose an individual's information against their will. For example, an overseas medical claims processor threatens to release patient data online unless new employment conditions are met.
- **Appropriation:** Involves using someone's identity for another person's purposes. For example, an online dating service uses a customer's personal history, including age, biography, and education, to promote its website to new customers.

Intrusion and Decisional Interference

- **Intrusion:** Consists of acts that disturb an individual's solitude or tranquility. For example, a mobile alert notifies potential customers that they are within the proximity of a sale.
- **Decisional interference:** Involves others inserting themselves into a decision-making process that affects the individual's personal affairs. For example, a website limits access to negative product reviews to bias a new user toward a specific product selection.

A few of these potential problems, such as breach of confidentiality and blackmail—which amount to harms and adverse events—can be quickly ruled out by well-intended, ethical IT developers. However, the increasing extent to which IT systems are distributed across multiple firms means IT developers may depend on subcontractors to fully protect the system against these more ethical harms. Moreover, identifying and aligning threats and vulnerabilities for the remaining harms requires a risk analysis that includes an assessment of the likelihood that a particular problem will arise. Similar to the FIPPs, three of Solove's categories correspond to the data life cycle or how data moves through a system. These categories can be addressed by analyzing the system's data collection, processing, and dissemination practices for the risk of these problems.

2.2.1.3.5 NIST Problems for Individuals

These adverse events are prosaically termed “problems for individuals” and represent how problematic data actions may affect individuals negatively.

The catalog of problems for individuals is equally expansive:

- **Loss of autonomy:** Involves self-imposed restrictions on behavior.

- **Exclusion:** Denies individuals knowledge about their personal information or the ability to act upon that knowledge.
- **Loss of liberty:** Improperly raises the possibility of arrest or detainment
- **Physical harm:** Involves direct bodily harm to an individual.
- **Stigmatization:** Links information to an identity so as to stigmatize the person associated with that identity.
- **Power imbalance:** Enables abusive or unfair treatment of an individual.
- **Loss of trust:** Can result from violations of implicit or explicit expectations or agreements regarding the treatment of personal information.
- **Economic loss:** Involves direct or indirect financial loss.

The relationship between problematic data actions and problems for individuals is not necessarily one to one. A single problematic data action can result in multiple problems for individuals.

2.2.1.3.6 Combining Models

As the astute reader will have noticed, the previously described models are not mutually exclusive. If there is any applicable compliance model for a system—and there is often at least one, since the compliance model includes policy as well as legal requirements—then use of the compliance model becomes mandatory. Even the most comprehensive compliance models, however, are unlikely to foresee every possible privacy risk for every system envisioned. Similarly, relevant risks can slip past a FIPPs-based model, because the FIPPs model is data-purpose centric. There is no reason to presume any other model is infallible either. Because there are likely diminishing marginal returns to integrating each new privacy risk model into an organization's risk-management framework, privacy analysts should pursue limited but advantageous combinations instead.

It is also possible to synthesize new risk models using existing models as inputs.³⁹ One could, for instance, combine a version of the FIPPs with the taxonomy of privacy problems and group-related, and in some cases effectively identical, adverse privacy events. In the case of the FIPPs, adverse privacy events are negations of each of the FIPPs. Each of the constructed categories can then be contextualized based on the nature of the system and its environment, yielding both a significant reduction in the resulting model's number of adverse privacy events and a set of adverse events whose definitions are contextually specific. For example, in the context of a connected vehicle deployment, one could combine data minimization FIPPs with the surveillance and aggregation problems to synthesize tracking as an adverse privacy event instead of the original individual events.

We have discussed model combination and synthesis in the specific context of consequence models, as this potentially can be relatively straightforward and because of the

somewhat privileged position of consequence models in risk modeling. However, combination and/or synthesis may also be possible for threat and vulnerability modeling. Further research is required, though, to determine both feasibility and practicality.

2.2.2 Privacy Risk Management Framework

Risk management frameworks provide a process for applying a risk model to a specific information system to identify and address risks. Risk models directly address domain-specific issues, while risk management frameworks are more about process and are therefore more generic. ISO 31000 is an example of an existing generic risk management framework. Indeed, ISO 31000 is so generic that it essentially includes construction of a risk model as part of the process. The risk management framework described here is a synthetic framework based on a variety of frameworks across multiple domains and adjusted to better accommodate the different ways privacy risk models are built out. It should be noted risk management frameworks are far more similar than they are different. As long as a framework is capable of incorporating an appropriate privacy risk model, it should suffice. This framework proceeds in six steps: (1) characterization; (2) threat, vulnerability, and event identification; (3) risk assessment; (4) risk response determination; (5) risk control implementation; and (6) monitoring and reviewing.

2.2.2.1 Characterization

The first stage of any privacy risk management framework involves characterizing the system that is the target of privacy threats in a way that renders it amenable to privacy risk analysis. This includes identifying the purpose of the system, what and how personal information flows throughout and is processed by the system, and what technologies are in place to support this system. The privacy risk analyst may employ the data life cycle as an additional framework to walk through the various system components that handle the data or use requirements and design artifacts, such as use cases, goal diagrams, or data flow models. For example, Figure 2-6 presents a basic use-case template instantiated as a retail website that links customer purchase histories to their social networks to personalize promotions of the retailer’s products to the customer’s friends.⁴⁰ This characterization identifies the primary actor as the friend and assumes the secondary actor, the original customer who bought the product, is no longer of issue. Because use cases may focus on the primary functional intent, e.g., to promote products, a privacy analyst may need to modify or extend the use case to include additional information about who may be harmed, in this case, the original customer.

Figure 2-6: Example use case for performing characterization

Name	Personalized customer promotions
Description	The system shall share a customer’s product purchase with people in their social network, called friends

Primary actor	Friends in the customer's social network
Precondition	The customer has purchased a product
Trigger	The customer's friend visits a product previously purchased by the customer

Fortunately, the choice of risk model may determine the amount of additional context required during the characterization stage. For example, the contextual integrity heuristic specifically targets the human-computer interactions between the system and its environment. These interactions include the various stakeholders that interact with each other and the norms that govern those interactions. Under contextual integrity, the original customer may expect the retailer to use their purchase information only for the purpose of completing the transaction and will not share this information and the customer's identity with third parties, even friends. Similarly, the S/OD and taxonomy of privacy problem models both concern the data subject and their perceptions of privacy risk. Accounting for those perceptions will require characterizing stakeholders outside the system's physical boundary and data flows, but it will enable the next stage in risk analysis.

2.2.2.2 Threat, Vulnerability, and Event Identification

Risk models may emphasize a particular reference point in the form of threats, vulnerabilities, or adverse events. In practice, vulnerabilities and events tend to be more commonly used than threats. Events become risks when associated with some notion of impact and likelihood, possibly based on threats and/or vulnerabilities. To the extent the events or vulnerabilities are specified, each one acts as an initial fixed or quasi-fixed point from which the analysis can extend out to identify and incorporate the specifics of the other elements for a given system. For example, once we know a given event, we can work backward to identify the relevant vulnerabilities and threats. The S/OD and taxonomy of privacy problem models emphasize adverse privacy events, i.e., what can go wrong, whereas the contextual integrity heuristic emphasizes vulnerabilities, i.e., which information norms can be disrupted. Thus, the analyst begins by identifying the elements that correspond to the privacy risk model in use.

Returning to the use case in Figure 2-6, the events may be characterized using Solove's taxonomy. This includes disclosure and exposure, depending on what products the customer has purchased. Products that are linked to lifestyle choices or are used to treat bodily functions, for example, could lead to harassment or embarrassment when revealed to the customer's coworkers. Alternatively, coworkers may view this information as an unwanted intrusion. The use case also leads to an appropriation event because the company is using the customer's likeness to market the product. In all cases, the threat is the implementation of the use case wherein the customer would not want to be associated with certain products.

Once the risk model's elements have been identified, the privacy risk analyst completes the risk analysis. If vulnerabilities were identified under the contextual integrity heuristic, then the analyst proceeds to identify the threats that seek to exploit those vulnerabilities and the adverse events that would result from a successful exploitation. At this point, combining multiple privacy risk models that complement each other may be helpful. After identifying a vulnerability, the analyst may, for example, apply the taxonomy of privacy problems to discover potential events.

2.2.2.3 Risk Assessment

Risk assessment is the process of assigning likelihoods and impacts to previously identified events, which yield risks. Likelihood may be expressed as an ordinal value (low, medium, or severe) or as a numerical value (0.0–1.0). Likelihood is sometimes assumed to mean the probability of the vulnerability being exploited to yield the given event. Where specific threats can exploit specific vulnerabilities, the likelihood associated with that risk is significant. Where a vulnerability does not align with any specific threat, the likelihood may be less significant. The ability to identify threats depends on an analyst's knowledge of a variety of political, social, and economic issues that change over time (i.e., threats may be functionally required by the system to process information, or they may be motivated by politics, social groups, or economics). Thus, the inability to identify a specific threat does not imply that the threat does not or will not eventually exist.

While impact may also be expressed numerically, this is a subjective judgment in the absence of metrics like calculated or statistical financial cost or loss. Using a numerical scale for purely subjective judgments could be an exercise in misleading or false precision. Similarly, likelihood could be treated as a numerical value as well, in the absence of any objective basis for its estimation. It can be argued that a less misleading approach is to use ordinal values to measure likelihood and impact. However, this can produce its own problems when attempting to “multiply” or “average” these values to score the risk. Depending on the circumstances, assigning a combined ordinal value of low, moderate, or severe may be used to represent a combined judgment regarding the level of concern merited by the risk, though caution should be used when viewing these measures as ground truth.

In Table 2-1, we present a list of threats, adverse events, and risk scores. Some threats to personal information arise from conducting normal business, such as determining whether a person is an adult, whereas other threats are external, such as law enforcement access. Still other threats arise from the imperfect design of systems, e.g., restoring a system from outdated backups as a patch to a periodically failing system or database. The events in Table 2-1 were identified using Solove's taxonomy of privacy problems as the risk model. Other events could have been identified for these same threats. For example, law enforcement access to data could also produce insecurity, such as exposure to possible future harm due to the failure to protect a person's information, and secondary use, such as use of information for purposes other than those for which it was originally collected.

Table 2-1: Example assessments that link threats and events to risk scores

Threat	Adverse event	Risk score
Law enforcement may request that we disclose a user's IP address from web server logs.	Identification: The disclosure allows others to link pseudoanonymous comments to a person's real identity.	Low
We collect a person's date of birth to determine if they are over 18, which is a condition of using our service.	Interrogation: The person may not wish to provide date of birth.	Moderate
We periodically refresh our financial database from weekly backups when we encounter a system crash.	Distortion: The backup may introduce data errors that misrepresent a person's financial history.	Severe

While it is possible to apply generic risk assessment methods to privacy, as well as those drawn from the related area of security, a number of privacy-specific risk assessment methodologies may prove more effective at surfacing less obvious privacy risks.⁴¹ We now describe several examples for illustrative purposes. This is not intended to be an exhaustive list.

The NIST's Privacy Risk Assessment Methodology was designed to leverage its privacy risk model, as described in section 2.2.1.⁴² It consists of four steps, each documented by a worksheet: business objectives and organizational privacy governance, assessing system design, prioritizing risk, and selecting controls. Selecting controls is more relevant to the following section on risk response. A stylized data map is also constructed as part of the process to support system design assessment. Design assessment breaks down and analyzes the system in terms of discrete data actions. Risk prioritization associates specific problematic data actions, i.e., vulnerabilities, and resulting problems for individuals, i.e., consequences, with those data actions where appropriate. Each problematic data action-problem pair must then be scored for likelihood and multidimensional impact on a ten-point scale. This allows a risk score of likelihood x total impact to be calculated for each pair and a total risk score to be generated for each system data action, providing a basis for prioritization. It is important to recognize, though, that absent any organizationally defined criteria, these scores are potentially arbitrary and, in all cases, relative rather than absolute. This makes cross-system comparisons difficult and can also pose problems for the interpretation of system-specific results.

Factor Analysis of Information Risk for Privacy (FAIR-P), in contrast, employs a more rigorous approach to quantification.⁴³ An adaptation of the original FAIR, FAIR-P breaks down the constituent components of frequency (corresponding to likelihood) and magnitude (corresponding to impact) that the risk "factors" in a hierarchical fashion. FAIR-P, like FAIR, aims to employ probabilistic estimates to achieve some measure of relatively objective quantification, including using standard probability distributions in the absence of

sufficient empirical statistics. FAIR-P differs from the original FAIR in two key respects. First, it focuses on risks to individuals rather than risks to organizations. Second, rather than express magnitudes exclusively in financial terms, it uses relative scales, ideally based on empirical data like surveys, and considers both intangible and tangible harms. The latter, where appropriate, may be represented in financial terms.

The System-Theoretic Process Analysis for Privacy (STPA-Priv), on the other hand, eschews quantification altogether, but imposes a degree of qualitative rigor based on a conceptual model of accidents in complex systems.⁴⁴ This model postulates problems arise when systems violate behavioral constraints as a result of erroneous control actions, such as when:

- a control is not applied when it should have been;
- a control is applied when it should not have been;
- a control is applied too early or too late; or
- a control is applied for too short or too long a time.

An adaptation of STPA-Sec, which is a security-specific adaptation of the original STPA, STPA-Priv involves formulating privacy-related behavioral constraints, identifying potential corresponding vulnerabilities, conducting a control action analysis of the system's privacy control structure, and generating causal scenarios that could produce erroneous control actions, which constitute risks. If the system privacy constraints can be rank ordered by importance (i.e., violation impact), that ordering can be used to prioritize risks. However, risks are not treated probabilistically as this is not necessarily meaningful in the context of a complex system.

2.2.2.4 Risk Response Determination

After the risks have been assessed, the privacy risk analyst can determine how to respond. The type of response must account for real-world resource constraints, such as time, money, and people, in addition to the risks themselves. Recall, the analyst has four choices when responding to a risk:

- Accept the risk: If the risk is low, it may be reasonable and necessary to accept the risk. In Table 2-1, if the disclosure reveals only consumer reviews about products, then privacy risk of identification may be minimal. The person may suffer from other risks—for example, the risk of being connected to a crime for reasons outside the scope of the system. However, accepting the risk may make sense for a low-level risk. Another reason to accept risk is when the cost to transfer, mitigate, or avoid it is too high.

- **Transfer the risk:** If there are other entities that can do a better job managing the risk, transferring it may be the best option. For example, using third-party services that manage payroll, payment, and other financial services using high privacy and security standards may be preferable to developing an equivalent system from the ground up. This is especially important when using a compliance model, where these third-party services have been engineered to conform to specific privacy laws, such as the variety of data breach notification laws. While the original organization may still bear the ultimate legal responsibility, it has nonetheless transferred relevant risks in part to the third-party service, as it is the service that must contend with those risks at an operational level.
- **Mitigate the risk:** Mitigation is the best option when the IT developer can implement privacy controls that reduce the risk. This may be through a software component or through a change in business processes. In Table 2-1, the distortion risk may be mitigated by performing daily backups and consistency checks on the data or remedied by allowing the person access to correct errors in their data. We discuss this mitigation in more detail in the following section.
- **Avoid the risk:** Avoidance occurs when one can avoid the adverse event by changing the system design or business process. In Table 2-1, the interrogation risk can be avoided by replacing the function that collects the person's date of birth with a function that asks a yes/no question, such as "Are you over 18 years of age?" This change is sufficient to address the original requirement of determining if the user is a legal adult by local law and avoid the specific event of probing to reveal a person's date of birth or exact age.

2.2.2.5 Risk Control Implementation

Risk controls fall into three categories: "administrative controls," which govern an organization's business practices, "technical controls," which govern software processes and data, and "physical controls," which govern physical access to hard copies of data and the systems that process and store electronic copies. In privacy, examples of administrative controls include:

- appointing a privacy officer who is responsible for organization-wide privacy practices;
- developing and documenting privacy and security procedures;
- conducting personnel training in privacy; and
- creating an inventory of personal information to track data practices.

We discuss administrative controls in more detail in chapter 10, which covers governance, risk, and compliance.

Technical controls target information systems and should be the focus of IT developers in designing privacy-preserving systems. They include:

- implementing access control mechanisms;
- auditing information access;
- encrypting sensitive data;
- managing individual consent; and
- posting privacy notices.

As discussed in section 2.1.5, the NIST publishes a security and privacy control catalog for U.S. federal information systems in the form of Special Publication 800-53, Revision 5. The privacy engineer may employ these controls as a standard means to mitigate several classes of privacy risk. For example, control PT-4 on consent requires the system to provide individuals a mechanism enabling them to consent to the processing of their personal information prior to its collection. This control may address a range of adverse privacy events, such as exclusion, which occurs when the individual does not have knowledge of or participate in, the use of their personal information. If this use is made overt and the individual is permitted to authorize the use of their information for this purpose, then this risk to the individual is mitigated.

2.2.2.6 Monitor and Review

Information systems evolve over time, and so do the risks to personal privacy. Thus, it is imperative for privacy risk management frameworks to include periodic reviews. An effective framework includes automatic triggers that require a subsequent review before a change can be initiated. In systems engineering, these triggers may be linked to modifying critical program code segments or configuring critical services. For example, before modifying any consent mechanism or adding new tables to a personal information database, a privacy risk review is required.

In addition, there is a need to monitor the existing set of controls. This requires collecting sufficient information to trigger awareness of a control failure or probing individuals to test their knowledge of failures. Certain privacy controls may serve this goal directly. Examples include personnel training controls that involve performance tests or assessments and complaint collection and resolution mechanisms that may surface an individual's report of a privacy harm.

2.3 Requirements Engineering for Privacy

Requirements describe constraints on software systems and their relationships to precise specifications that change over time and across software families.⁴⁵ For IT professionals, understanding and applying privacy requirements is important both when creating new system designs and when selecting a proprietary or open-source component to address a particular problem.

Whether the requirements are formally documented in a software requirements specification (SRS), expressed in a mathematical model, or briefly summarized in an agile user story, requirements provide engineers an early opportunity to capture critical privacy properties prior to embarking on design and other deep technological commitments. Barry Boehm, an expert on the economics of software engineering, found the cost to fix a requirements defect during implementation increases a hundredfold over fixing the defect during the requirements or design phase.⁴⁶ This guideline is also true for privacy: any changes to reengineer a software application in response to a known privacy threat will be more costly than addressing the privacy threat during requirements engineering. Thus, it is critical for engineers to capture privacy requirements by participating in the community of practice and monitoring existing sources of information about privacy.

In this section, we will review techniques for acquiring, eliciting, managing, and analyzing privacy requirements.

2.3.1 Documenting Requirements

Requirements engineers often distinguish between two types of requirements: functional and nonfunctional. “Functional requirements” describe a specific function of the intended information system. A product tester can evaluate a running system to verify the following functional requirements: “The system shall provide a link to a privacy notice at the bottom of every page” and “The system shall encrypt credit card numbers using AES 256-bit encryption.” “Nonfunctional requirements” describe a constraint or property of the system that an engineer can trace to functional requirements or design elements. Examples of nonfunctional requirements: “The system shall not disclose personal information without authorization or consent” and “The system shall clearly communicate any privacy preferences to the data subject.” In the first nonfunctional requirement, the designer must trace this requirement to all uses of personal information to ensure authorization or consent is verified before disclosure. In the second requirement, the analyst must trace this requirement to any functional requirements governed by the data subject’s privacy preferences, such as the use of user email addresses or activities for marketing purposes. In addition to a requirements statement, the engineer should provide context for understanding the requirement and attempt to answer any critical questions to aid designers in applying the requirement to their designs.

Requirements are collected in an SRS that uses a standard format or template for presentation. IT professionals can reuse and adapt existing formats to their purposes. Figure

2-7 illustrates a generic example of a requirements template that describes an authorization and consent requirement. The template header includes summary information, such as a unique requirement ID that may be used to cross-reference the requirement, the requirement statement in the optative mood “shall,” the author who can be contacted for additional information, the revision number used to track changes to the requirement, the release date, and the keywords used to identify related requirements across the SRS document. In this example, the legal compliance section provides legal cross-references to related regulations that this requirement attempts to fulfill. These and similar cross-references are typically included in trace matrices, which we discuss in section 2.3.3 and which are used to show conformance among various software artifacts. The template body describes a scenario in which the requirement appears and several design assumptions underlie the successful implementation of the requirement.

Figure 2-7: Example of an instantiated requirements template

Requirement ID:	REQ-68
Requirement statement:	The system shall not disclose personal information without authorization and consent.
Author:	Sam Brown, System Specialist III
Revision:	1.1
Release date:	January 1, 2014
Keywords:	Confidentiality, consent, access
Legal compliance:	HIPAA Privacy Rule §164.506, §164.508, EU Directive 95/46/EC (30)
Scenario description:	Whenever an agent attempts to access personal information, the system will check that the agent is authorized to access this information based on their assigned user role or the purpose for which the data will be used. If consent is required prior to disclosing the information to this recipient, the system will check that the data subject has previously provided consent for disclosure based on this user role or data purpose.
Design assumptions:	The system maintains a list of approved user roles and data purposes. The system maintains linkages between data subjects, types of personal information, and consent decisions and data purposes.

In addition to requirements, the SRS document includes a technical glossary that provides standard definitions to be reused across requirements. Figure 2-8 presents a sample glossary for requirement REQ-68: the term “agent” may be defined as a user or process to denote that this requirement applies to both types of objects in the system design. This glossary also contains the term “personal information,” which is refined into a list of appropriate data types: the combination of a person’s name and address, or the person’s email address, telephone number, or credit card number. In addition to standardizing terminology, the technical glossary provides the engineer a mechanism to collect and negotiate descriptions of

the system in text before committing to more specific descriptions in design and source code. Designers can ask critical questions based on definitions in the glossary, such as “Should all requirements be applied to personal information equally, or should a separate category of information, called sensitive personal information, be created for a subset of these requirements, such as encryption requirements?”

Figure 2-8: Example of a requirements glossary used to standardize terms

Agent: A user or process that performs a function within the system.

Data purpose: The approved work-related activities for which data will be collected, used, or disclosed. The complete set of approved roles or purposes consists of product or service fulfillment, internal operations, fraud prevention, legal compliance, first-party marketing, third-party marketing, and product research.

Data subject: The identified or identifiable, natural person about whom information is related (see EU Directive 95/46/EC, Article 2, paragraph (a)).

Personal data: Any information that relates to a data subject. This includes the data subject’s first and last name, physical or mailing address, electronic mail address, telephone number, or credit card number.

Requirements can be written to be reusable across multiple systems. Reusable repositories of privacy requirements allow privacy engineers to coordinate standard approaches across their organizations and to discern strategies for handling exceptions, such as a novel technology that deviates from traditional norms. As we discuss in section 2.4, designers translate requirements into system designs and consider alternative designers to fulfill requirements. For example, designers may distinguish between different types of consent. Under a website’s privacy policy, certain types of information like browsing history may be collected, whereby use of the site corresponds to passive consent. In this context, the consent record is inferred from the website’s access log. A user agent request for a web page that is linked to the privacy policy corresponds to consent to collect information described in the policy, such as the visitor’s IP address, browser type, operating system, and so on. Alternatively, the designer may choose to use an explicit checkbox at the start of a transaction with at least two design choices: (1) recording the date and time of the selection in a database or (2) restricting the transaction to those who select the checkbox, in which case evidence of the collected data subsequent to the checkbox can exist only if the checkbox was selected, meaning the checkbox is required, not optional, and no other workflow leads to the data collection. The decision about which approach is best may depend on the need for retaining and exhibiting evidence of consent to auditors.

In addition to textual documentation, privacy requirements may be specified using visual models. These include process diagrams, information flow diagrams, role and permission matrices, and state diagrams, to name a few.⁴⁷ These models serve to make relationships between the objects of discourse (actors, data, systems, and processes) explicit and enable additional analysis. We describe a few analytics that rely on these models in section 2.3.4.

2.3.2 Acquiring and Eliciting Requirements

Privacy requirements may be acquired from multiple, diverse sources. This includes eliciting requirements from stakeholders using interviews, case studies, and focus groups, as well as by extracting or mining text documents—such as contracts, standards, laws, newspapers, and blogs—for requirements. There are standard elicitation techniques for working with subject-matter experts. Interview and survey techniques have been established for conducting surveys and focus groups.⁴⁸ In addition to elicitation, privacy-relevant standards, such as the FIPPs and the NIST control catalog, serve as sources of high- and low-level requirements respectively (see chapter 1). For example, the use limitation principle stating that “personal data should not be disclosed, made available or otherwise used for purposes other than those specified” may be directly adapted to a nonfunctional requirement using the given template. Similarly, NIST SP 800-53 control PT-3, which, among its elements, requires organizations to “Restrict the [organization-defined processing] of personally identifiable information to only that which is compatible with the identified purpose(s)” can be adapted to any IT system and not only to those systems governed by the U.S. Privacy Act of 1974.⁴⁹

While standards and guidelines are formatted for easier consumption by software developers, the format of less structured texts, such as laws and regulations, requires analysis to infer requirements. Regulations are publicly available, and IT professionals can work with their legal counsel to identify relevant privacy regulations that govern their industry. Regulations may be generic or specific in their descriptions of principles and processes that software engineers should employ. “Legal standards” refer to nonfunctional requirements or properties that cut across a system’s design and functionality.⁵⁰ The HIPAA Privacy Rule includes the minimum necessary standard, which requires covered entities, such as hospitals and health insurance companies, to disclose only the minimum information necessary to complete a transaction (see HIPAA §164.502). Alternatively, “legal rules” describe specific steps that should be taken to ensure compliance with a privacy law. Consider the following excerpt from the COPPA Rule:⁵¹

§312.5 Parental Consent.

(a) General requirements.

(1) An operator is required to obtain verifiable parental consent before any collection, use, and/or disclosure of personal information from children . . .

(b) Mechanisms for verifiable parental consent.

(1) An operator must make reasonable efforts to obtain verifiable parental consent . . .

(2) Existing methods to obtain verifiable parental consent that satisfy the requirements of this paragraph include: providing a consent form to be signed by the parent and returned to the operator by postal mail, facsimile or electronic scan; requiring a parent, in conjunction with a monetary transaction, to use a credit card, debit card or other online

payment system that provides notification of each discrete transaction to the primary account holder; having a parent call a toll-free telephone number staffed by trained personnel; having a parent connect to trained personnel via video-conference; verifying a parent's identity by checking a form of government-issued identification against databases of such information, where the parent's identification is deleted by the operator from its records promptly after such verification is complete; or provided that, an operator that does not "disclose" children's personal information, may use an email coupled with additional steps to provide assurances that the person providing the consent is the parent.

In this excerpt, the COPPA Rule describes specific steps to obtain consent before collection, including details about approved methods for obtaining consent. These rules frequently include statements with modal verbs, such as may and must, which indicate discretionary and mandatory requirements, respectively.⁵² In addition, they contain terms of art whose definitions are needed to determine legal coverage. In the example, "verifiable parental consent" is a term of art defined in 16 CFR §312.5(b)(2). From this example, a requirements engineer can extract or mine the regulatory text to yield a corresponding requirement. The following requirement was derived by tracing phrases from paragraphs (a)(1), (b)(1) and (b)(2):

REQ-72: The system shall obtain verifiable parental consent by having the user complete a credit card transaction prior to collecting a child's personal information.

In this requirement, the engineer commits to one of the five mechanisms permitted by COPPA §312.5(b)(2) in the excerpt.

Regulatory enforcement actions, newspapers, and blogs provide insight into what went wrong when a system fails to meet a privacy requirement. Travis D. Breaux and David L. Baumer performed a retrospective analysis on the FTC's regulatory enforcement actions.⁵³ This analysis yields several security requirements that could have been used to avoid system failures that violated consumer privacy policies and the Gramm-Leach-Bliley Act (GLBA). Alternatively, the IT professional or privacy engineer can monitor newspapers and blogs for early indications of potential privacy risks. By watching what other companies do and how the press and the public interpret these privacy-related practices, software engineers can avoid privacy pitfalls in their own systems.

2.3.3 Managing Privacy Requirements Using Trace Matrices

The requirements engineer uses trace matrices for encoding relationships between requirements and other software artifacts. Each trace link has a special type that describes the meaning of the link. For example, a trace link from a requirement to a privacy law means the requirement *implements* the law, whereas a trace link to a design element, such as a role-based access control mechanism, means the requirement *is implemented by* the design element. These trace links are many-to-many relations, as a requirement can simultaneously have

different relationships to multiple laws, design elements and test cases. Consider the four requirements numbered REQ-32 through REQ-35:

REQ-32: The system shall only disclose the minimum information required to complete a transaction.

REQ-33: The system shall restrict uses of personal information to only those purposes for which the information was collected.

REQ-34: The system shall only disclose information for purposes for which the data subject has provided explicit or implicit consent.

REQ-35: The system shall provide law enforcement access to personal information by administrative subpoena.

In Figure 2-9, we present a trace matrix that links the previously stated requirements to privacy laws and standards, listed down the first column, and to software requirements, listed along the top row. Where a trace link means the requirement implements the standard or law, an “X” appears in the matrix. We observe that some requirements implement multiple standards and laws, such as REQ-32, which implements both the HIPAA Privacy Rule’s minimum necessary standard and the Organisation for Economic Co-operation and Development (OECD) Use Limitation Principle. Other standards or laws may be implemented by a conjunction of multiple requirements, such as the GAPP Standard 5.2.1, which simultaneously limits the uses of personal information to specific purposes (REQ-33) and requires consent for all disclosures (REQ-34), but has an exception for law enforcement purposes (REQ-35).

Figure 2-9: Example trace matrix linking regulations to requirements

Privacy laws and standards	REQ-32	REQ-33	REQ-34	REQ-35	...
Data minimization					
HIPAA Privacy Rule, 45 CFR §164.502(b), Minimum Necessary Standard	X				
OECD Use Limitation Principle	X	X			
GAPP 5.2.1 Use of personal information		X	X	X	
Government access					
Stored Communications Act, 18 U.S.C. §2703 (b)(1)(B)(i)				X	
GLBA, 16 CFR §313.15(a)(4)				X	

Because software engineers and legal experts must interpret standards and laws when creating trace links in the trace matrix, the engineer may keep track of the rationale for each link to record these interpretations for future reference. When conducting a traceability exercise, one can use the rationale to answer the question, “Why is this trace link important?” Figure 2-10 presents an example where the rationale is recorded for REQ-35, which allows law enforcement access to personal information by administrative subpoena. The trace link rationale for GAPP 5.2.1 explains that this link is an exception, which describes how requirement REQ-35 should be viewed in the context of REQ-33 and REQ-34. In advanced trace matrices, these exceptions are encoded into separate tables to ensure designers who implement REQ-33 integrate the exception into their design. The trace link rationale for the GLBA Privacy Rule includes the cross-reference from the GLBA to the Right to Financial Privacy Act of 1978 (RFPA) that the engineer had to follow to discover this exception.

Figure 2-10: Example trace link rationale

Source	Target	Rationale description
REQ-35	GAPP 5.2.1	GAPP 5.2.1 provides an exception for any disclosure that is required by law or regulation.
REQ-35	GLBA Privacy Rule, 16 CFR §313.15(a)(4)	An administrative subpoena is permitted by cross-reference to the RFPA, 12 U.S.C. §3405.

While the examples shown cover upstream tracing of requirements to their origin in laws and regulations, separate trace matrices are also used to trace requirements to downstream artifacts, such as software designs, source codes, and test cases. In privacy, trace matrices should also trace requirements to user agreements, such as privacy policies, terms of use (ToU) agreements, end-user license agreements (EULA), and so on. Whenever a requirement or IT system component changes, the trace matrices should be consulted to determine the impact of the change on other parts of the system, including privacy policies.

2.3.4 Analyzing Privacy Requirements

Requirements analysis describes activities to identify and improve the quality of requirements by analyzing the system and deployment environment for completeness and consistency. This includes identifying relevant stakeholders to ensure no one was overlooked and examining user stories and requirements for ambiguities, conflicts, and inconsistencies. In this section, we focus on two activities that concern privacy: completeness arguments and threat analysis.

2.3.4.1 Developing Privacy Completeness Arguments

For systems of any reasonable size, requirements documents are never complete. There is always some description of the intended system that has been overlooked or only partially described. This incompleteness provides designers flexibility, because they are able to fill in the gaps with different technical approaches based on prevailing technology and other

business needs. However, some omissions lead to unwanted behavior, such as privacy harms. To improve requirements quality in general, we recommend constructing completeness arguments that ensure limited aspects of the requirements are complete. These arguments are constructed using stepwise analyses to ensure a finite list of concerns has been reviewed in its entirety. For privacy, this includes reviewing the requirements' trace matrices to ensure all privacy standards, guidelines, and laws have been traced to a requirement. Completeness arguments can be used to cover every step in the data life cycle for especially sensitive data types and to expand one's interpretation of a privacy law or regulation, which we now discuss.

Is tracing complete? Completeness arguments can be constructed for privacy policies, wherein the argument determines whether the tracing is complete from privacy policy statements to software artifacts that implement those statements. A privacy policy is a promise to users that their personal information and their privacy will be respected according to certain rules. Misalignment of privacy policies with information practices is a great source of concern and can lead to privacy violations.⁵⁴ Goal-based analysis can be applied to privacy policies to identify "protections," which are statements that aim to protect a user's privacy, and "vulnerabilities," which are statements that threaten a user's privacy.⁵⁵ Consider this excerpt from Google's privacy policy, which was last modified on June 24, 2013:⁵⁶

We may collect device-specific information (such as your hardware model, operating system version, unique device identifiers, and mobile network information including phone number). Google may associate your device identifiers or phone number with your Google Account.

...

We encrypt many of our services using SSL.

We offer you two step verification when you access your Google Account, and a Safe Browsing feature in Google Chrome.

The first two statements in the excerpt describe a general permission allowing Google to collect device-specific information, such as mobile phone numbers, and link this information to a user's Google account. These statements are potential vulnerabilities, because they enable the surveillance and tracking of a user's movement and linking to other information through the account. For example, this vulnerability enables Google's passive collection of the mobile phone unique device identifiers of Android and iPhone users when the user accesses wireless routers, as well as Google's active collection of mobile phone numbers when users log in to their Google account online.⁵⁷ Any changes to the policy affecting these collections should be traced to these technologies, and vice versa.

The last two statements describe protections: the use of the secure sockets layer (SSL) to encrypt communications, such as access to Gmail, and an optional two-step verification that consists of (1) supplying the username and password and (2) supplying a code sent to the

user by text message or voicemail. The first statement improves confidentiality and reduces the likelihood that a third party can read a user's email when they use an unencrypted wireless connection. The second statement provides users a higher level of assurance that third parties cannot access their account without also obtaining access to their mobile phone or to the wireless networks used to send messages to their mobile phones.

Protections and vulnerabilities can be traced to other downstream software artifacts to promote alignment between the privacy policy and system functionality and behavior. Whenever privacy policies change, due to changing laws or new business practices, these changes should be propagated into the trace matrices to determine what aspects of the system have been affected by the policy change. When policies are managed in this way, the IT developer can argue that a software artifact accounts for each privacy statement in the company's privacy policy. However, the issue of quality, or the issue of how well that artifact satisfies the policy statement, may require a more advanced, risk-based argument.

Is the life cycle complete? Completeness arguments can be constructed for a specific data life cycle, wherein the argument asserts that *every step* in the data life cycle was visited for a particular data element or dataset. An inventory of PII, which could take the form of a data dictionary, can be invaluable for this purpose, helping to ensure every relevant data element is addressed. At each step in the data life cycle for a specific data type, the engineer considers whether the data type requires special consideration. Does a shopping history have special retention requirements, for example, based on either business needs (to service refunds or warranties) or law enforcement needs (to investigate crimes)? The IT developer may choose to develop only these arguments for especially sensitive data elements, such as financial account numbers or detailed purchase histories. To construct the argument, the IT developer begins by (1) selecting the data element to trace and (2) for each data life cycle stage, identifying requirements in the SRS document that cover the data element. Figure 2-11 illustrates the outcome of this tracing for the data element "credit card numbers" in a fictitious system that processes online shopping orders. The life cycle stages appear in the first column, followed by the ID and requirement statement in subsequent columns. Because requirements describe data at different levels of abstraction from data elements to datasets, the IT developer must map the data element of interest to the datasets that contain this element. The technical glossary can aid the engineer when performing this mapping, assuming the terminology has been standardized across the SRS. In Figure 2-11, the italicized phrases for customer orders, customer's payment method, billing information, and credit card numbers all refer to data or datasets that contain a credit card number.

This example analysis yields two interesting findings for the IT developer. First, the credit card number is not observably shared with third parties, because no requirements that map to data disclosures were discovered. Unwanted disclosures may still occur, but this finding suggests such disclosures are not required. Second, the need to retain billing information is potentially too broad (see REQ-63). While billing information is needed to process certain

requests, such as refunds or warranties, this does not include the credit card number. For refunds, the company may retain an approved one-way hash of the credit card number and ask the customer to resupply the number only when they request a refund. Thus, the IT developer can modify REQ-63 to exclude the credit card number from this retention requirement and introduce a new requirement to retain only the one-way hash of the credit card number.

Figure 2-11: Example matrix for a data life cycle completeness argument for “credit card numbers”

Life cycle stage	ID	Requirement statement
Collection	REQ-31	The system shall process <i>customer orders</i> and ship products to customers within three business days.
Use	REQ-47	The billing agent shall charge the purchase amount using the <i>customer’s payment method</i> .
Disclosure	None	
Retention	REQ-63	The system shall retain <i>billing information</i> for two years.
Destruction	REQ-89	The system shall destroy <i>credit card numbers</i> immediately after completion of the payment transaction.

Is our legal interpretation complete? Completeness arguments can be constructed for compliance with regulatory requirements. While it is impossible to completely cover every prospective interpretation by an auditor, regulator, or judge, there are steps engineers can take to broaden the scope of their interpretations to capture missed requirements. Travis D. Breaux et al. identified five patterns to analyze legal requirements extracted from laws and regulations to improve completeness of the SRS.⁵⁸ These patterns were discovered through empirical analysis of a large manufacturer’s SRS and a national technology law. The patterns are applied directly to requirements statements acquired from either laws or standards and can yield new, potentially missing requirements for the system. The patterns are presented with examples from U.S. data breach notification laws.

Remove or generalize preconditions. Preconditions include phrases in a requirement statement that must be satisfied before a requirement is applied in the system design. These phrases can be recognized by *if* and *when* keywords. Removing or generalizing preconditions for obligations and prohibitions causes the statement to generalize. In other words, the engineer must apply the requirement to more situations than were originally intended. A more general form of this pattern is to apply a requirement to a broader class of stakeholders than legally required, or to a broader class of data and information types. For example, Nevada law governing the security of personal information requires organizations that conduct business in Nevada to take reasonable measures to destroy personal information.⁵⁹ Applying this pattern to this requirement would entail generalizing the requirement so it

applies to any personal information, regardless of whether the information concerns practices conducted in Nevada or any other state. This pattern has the benefit of streamlining business practices at the cost of extending those practices to other situations where they may not be otherwise required by law or standards.

Preclude preconditions, assume exceptions. In legal compliance, some privacy requirements concern specialized situations that can be avoided by writing product or service requirements that assume the exception, which may be a higher standard of care. For example, the Virginia data breach notification law defines a “breach of security of the system” as unauthorized access to unencrypted computerized data.⁶⁰ In the event that an organization detects a data breach, notices are sent to consumers and others to comply with this Virginia law only if the data was not encrypted. By ensuring that this data is encrypted in transit and in storage, the IT developer assumes the exception and defines the system as not covered by this legal requirement. Privacy scholars have also called this exception the encryption safe harbor.

Ground legal terms in the domain. Legal terms determine when a privacy regulation applies and are often purposely written to be abstract to make laws flexible and adaptable to new situations or technologies. Based on a company’s products and services, these terms may be grounded in industry-specific terminology or product or trademarked names. For example, California Civil Code §1798.29 requires protecting access codes that can be used to access a personal financial account. This code chapter does not define access code or financial account, thus leaving the interpretation to IT developers and their legal counsel. In computing, accounts that allow users to conduct financial transactions during routine use of the system may be subject to these rules. As new technologies arise, traditional interpretations of banking are evolving. In 2008, the U.S. Internal Revenue Service (IRS) explored the tax implications of virtual currencies in online games.⁶¹ If the IRS determines these virtual currencies and other property to be taxable, would California state data breach notification law cover the user’s account and password? IT developers should consider the various ways these legal definitions apply to their systems and document when the terms both increase and decrease their perception of coverage by privacy laws.

Refine by refrainment. Privacy laws often describe goals to be achieved or obligations a covered organization must meet. In software systems, however, activities can create obstacles to compliance or yield privacy-threatening outcomes that are not explicitly prohibited by the law. This pattern concerns identifying what should not occur as a means to reinforce compliance with mandatory privacy requirements. Under Virginia Code §18.2-186.6(A), the act of stealing the cryptographic keys that can be used to decrypt encrypted personal information is not included in the definition of a security breach. However, because this outcome can enable a privacy-threatening scenario, wherein a data thief can now decrypt encrypted personal information, the IT developers can choose to adopt a refrainment, or prohibition, that requires the systems not to make these keys accessible to unauthorized

users. By expressing this prohibition explicitly, IT developers can conduct analysis on the system to check whether the design violates this requirement.

Reveal the regulatory goal. The rules in privacy laws serve to achieve a broader privacy goal or norm. For example, a privacy goal may be to protect an individual from public embarrassment by an unwanted disclosure or to protect an individual's freedom to travel without fear of excessive surveillance. While an IT developer can seek to comply with the letter of the law, the alternative is to comply with the goal of the law to acquire longer-term benefits, and often the privacy engineer can help identify these goals. By identifying the regulatory goal and then broadly applying this goal to their systems, IT developers can discover new requirements that are not described in a law. These new requirements may reflect novel technologies in their systems that were not previously foreseen by regulators, or they may leverage emerging interpretations of privacy goals that did not exist when the original regulation was written. This approach may have the added benefit of aligning these technologies with users' broader privacy expectations or of heading off new regulation earlier in the software engineering life cycle. For example, treating online gaming accounts as virtual financial accounts and sending out data breach notices in accordance with privacy law may benefit users as they can take steps to protect those accounts and review account histories for suspicious activity, which is consistent with how users react to more traditional financial accounts.

2.3.4.2 Identifying Privacy Threats

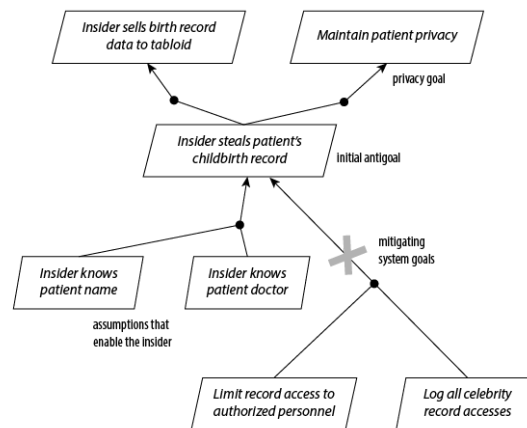
IT developers use threat modeling to identify risks to the system based on concrete scenarios. Threat modeling considers the negative outcomes enabled by a particular threat agent or type of agent. While this analysis has grown out of security engineering, the same techniques may be used to anticipate potential privacy threats. In addition to the preexisting privacy threat models discussed in section 2.2.1.1, there are several examples of security threat analysis artifacts and methods available to engineers to enable them to construct a system-specific threat model from scratch, such as antagoals and misuse and abuse cases, that can be adapted to privacy.⁶²

Antigoals are an attacker's own goals or malicious obstacles to a system.⁶³ Goal-oriented analysis to identify antagoals begins with the engineer identifying the system's positive goals, before identifying antagoals that describe how an attacker could limit the system's ability to maintain or achieve the positive goals. For example, in a hospital, an electronic health records system has the goal of ensuring doctors and nurses access patient medical records only for authorized purposes. A prospective antagoal includes a nurse who accesses a patient's medical record to steal their Social Security number or to reveal the name and gender of a celebrity's expected or newborn baby.⁶⁴ The first three steps of the procedure are as follows: (1) identify the antagoals that obstruct relevant privacy goals, such as confidentiality and integrity goals, (2) identify the attacker agents who would benefit from each antagoal, and (3) for each attacker agent and antagoal pair, elicit the attacker's higher-level goal that explains why they

would want to achieve this antigoal. This step continues in a series of *how* and *why* questions to elaborate the antigoal graph. The final steps are: (4) derive antimodels that identify the attacker, object of the attack, and antigoals, and (5) operationalize the antimodel in terms of potential capabilities that the attacker agent may use in this scenario.

In Figure 2-12, we illustrate an example antigoal hierarchy. The blocks represent goals and antigoals, and the arrows point from subgoals that achieve higher-level goals. The initial antigoal is that an insider, such as a nurse, steals a celebrity patient's birth record. This theft is intended to fulfill the attacker's goal of selling the record data to tabloids. To accomplish this attack, the insider must know the patient's name and doctor. The system designer, realizing this information cannot be restricted in the health care setting, chooses to use technology to mitigate this antigoal by limiting access and logging accesses. While limiting access may prevent unauthorized insiders, the additional goal of logging access improves the chances of identifying authorized insiders after the attack has occurred.

Figure 2-12: Example antigoal hierarchy with mitigating goals

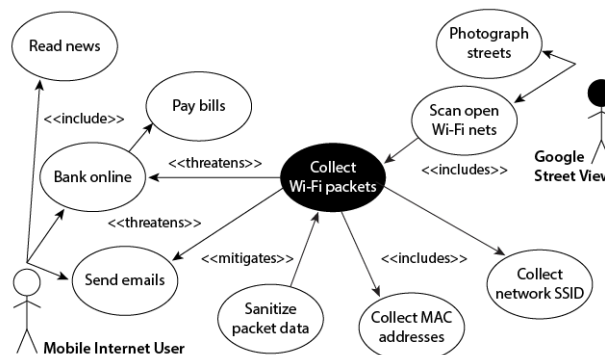


Goals and antigoals are expressible in first-order logic to yield a more precise specification. However, this may be too cumbersome or time consuming for broad adoption in every situation. For IT developers preferring a lighter-weight method, misuse and abuse cases were developed to adapt the existing use case methodology to describe negative intents. Similar to antigoals, an abuse case describes a complete interaction between a user and the system that results in a harmful outcome.⁶⁵ Although misuse and abuse cases were originally developed to describe security attacks, the same notation can be used to describe potential privacy pitfalls. In Figure 2-13, we present an example misuse case. The white actor is the user, and the shaded actor is the misuser. It should not be assumed that the shaded actor in a privacy setting is a bad actor. Rather, he or she is an actor who may be prone to misusing personal information in a privacy-threatening manner. Thus, the products and services provided by the misuser are often desirable by some actors, with privacy-threatening side effects that are undesirable by other actors. In the example, actions appear as ovals and are linked to other actions by arrows. The <<includes>> keyword indicates links to an action that is a part of another action, a similar meaning to how subgoals link to goals. The <<threatens>> keyword

indicates when an action threatens another action, and the <<mitigates>> keyword indicates when an action serves to reduce the privacy threat from an action.

The Google Street View service is enabled by automobiles that are driven along public streets to capture images of streets and adjacent scenery. The project provides significant value to consumers because they can use Street View to preview their routes on a computer before driving to their final destination. However, this service raised privacy concerns because unsuspecting individuals had their photographs taken in public and published online. In addition, the Street View automobile collects wireless packet data from public Wi-Fi networks to provide more precise geolocation to Wi-Fi users who access these networks. Many wireless routers remain installed in the same location, which improves the reliability of this dataset. As the Street View automobile passes by a public Wi-Fi network, the vehicle collects the wireless packet data to determine the wireless router's service set identification (SSID), or unique device identifier, and the media access control (MAC) addresses of any machines connected to the network. During this collection, the car also intentionally or unintentionally captures user login credentials that are sent over the network while a user accesses other internet services, such as online shopping and email accounts. This collection threatens a mobile internet user's goal to securely and privately bank online and send personal emails. In Figure 2-13, we capture this threat by coloring the action "collect Wi-Fi packets" black. The IT developer can mitigate this threat by introducing a new action, "sanitize packet data," which removes all unwanted, PII. What about the "photograph streets" action? What actor does this affect and how would the engineer mitigate this threat?

Figure 2-13: Example misuse case applied to unwanted collection of Wi-Fi data



As previously mentioned, the "photograph streets" action threatens the ability of individuals to perform daily activities without the fear of surveillance. These individuals might approach surveillance differently, either by dressing differently or avoiding the area altogether. To mitigate this threat, the engineer can use face-detection technology to blur faces or allow individuals to report unwanted intrusions that can be remedied by blurring the threatening images.

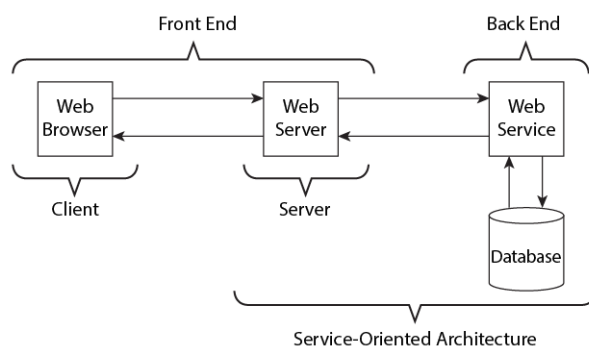
2.4 High-Level Design

Whereas requirements describe what functional and nonfunctional behaviors the system is supposed to exhibit, designs begin to describe how the system is supposed to implement those behaviors. Designs are generally expressed using notations that define the processes and the data that those processes operate upon, as well as the high-level components that serve to group these processes and data together into categories of functionality. This includes the Unified Modeling Language (UML), which provides object-oriented diagrams, sequence diagrams, state diagrams, and more for describing composition and temporal relationships between elements in the design.⁶⁶ Expert designers will use sophisticated architecture component-and-connector diagrams, architectural styles, and other techniques to manage the complexity of working with larger and larger information systems.⁶⁷ In this section, we briefly introduce common IT architectures, quality attributes, and design representations for reflecting on PbD.

2.4.1 Common Information Technology Architectures

During the past several decades, architectural paradigms have emerged to describe the relationship among software components. These paradigms serve to orient developers by communicating how their contributions integrate with those components under development by other members of the development team. To orient developers, each architectural paradigm encapsulates a limited viewpoint of the overall system design. Figure 2-14 presents a simple illustration of the various paradigms that we cover here.

Figure 2-14: Common IT architectures that describe different system viewpoints



The “front end” is the part of the system the user experiences. It includes user interface elements that mediate between the user and the rest of the system. This involves converting user actions into something that is understandable by the system and converting system responses into something that is understandable by the user. In Figure 2-14, the front end consists of a web browser that a user employs to search for a particular product on an e-commerce site. The search request is translated into a database query by the web server or web service. The response from the database is appropriately formatted and returned to the user for display by their browser. In this example, the database and any intermediary services that encapsulate the database and are not directly connected to the user’s experience constitute the “back end.” The back end contains the information stores—products, orders,

accounts, and so on—that underlie the activities the user and the site owner engage in. The front end facilitates communication and manipulation of that information, but it is essentially a façade, in the same way as any storefront.

Privacy affects these two viewpoints in different ways. Ensuring privacy in a system design requires designers to attend to the usability of the front end. Are users effectively notified about the company’s privacy practices? Are users able to express their consent about the use of their information, for example, by effectively opting in or out of secondary uses? Poor design practices or frequently changing front-end design can cause the user to become confused or to incorrectly express privacy preferences. Agile designs that rapidly evolve in response to competitive markets, such as Facebook’s changing façade, can be accompanied by online tutorials, one-time introductions to features, and other contextual tips that help users navigate new and evolving privacy settings. Back-end components concern what data is collected, when it is used or for what purposes, with whom it is shared, and how long it is retained, among other practices. In this case, designers may consider how to map the privacy principles, such as use limitation or data minimization, to their back-end services.

“Client-server architecture” describes the relationship between the *client*, which is typically a program that runs on a local computer, and the server, which is the program that runs on a remote computer. The client-server architecture commonly describes the relationship between a user’s website and a remote website (see Figure 2-14). The designer may choose to define the boundary of the server to include any back-end services that facilitate the client-server interaction. However, the server is typically the computer process that responds to client requests. Thus, the back-end architecture may be composed of multiple client-server arrangements. For example, a web server is a client to a database server.

One advantage of this architectural paradigm is it allows the service to store computer data on the client side for the purpose of completing transactions. Because the web is asynchronous—that is, the hypertext transfer protocol (HTTP) does not maintain shared data between the client and server and each request is independent—designers use creative mechanisms to track client behavior across multiple HTTP requests through cookies (see chapter 6) or session identifiers used in each communication request from browser to server. Storing data on the client may introduce privacy risks if the client data is insecure, if the storage of this data is not clear to the user, and if storage of this data serves the purpose of surveillance or identification when the user would otherwise prefer to remain anonymous. Session identifiers, when used, may be guessable or stolen, allowing an attacker to interact with the server as though they were the victim.

“Service-oriented architectures” are similar to client-server architectures in that they aim to decouple services from large-scale servers. This enables reuse and separation of concerns and, for increasingly larger systems, improved load balancing by allowing designers to replicate services across multiple machines. Last, “peer-to-peer architectures” are an extreme alternative to client-server architectures whereby each peer is both a client and a server. To

enable this distributed scenario, peers often use a directory service to find other peers. This is how peer-to-peer networks, such as BitTorrent, operate. Peer-to-peer architectures can improve performance by reducing the need to work through intermediaries, but the emergent nature of the network allows for peers to be largely anonymous. Anonymity in this context is both a benefit to privacy and a burden because peers may be malicious, and users may be unsuspecting when they transfer their personal information to these anonymous intermediaries in the peer-to-peer network.

In addition to client-server architecture, a “plug-in-based architecture” can be used to extend an application with new features. Modern web browsers support plug-in-based architectures and application platforms, such as Facebook’s Application Developer API, and the Apple iOS or Android platforms allow third-party developers to extend a user’s experience with new programs, called apps. Plug-in-based architectures and especially app platforms can introduce new privacy risks for users. These risks emerge because the user has a direct relationship with the platform and the platform developer has a vested interest in protecting its user base to widen the adoption of the platform. For example, a user of an iPhone or Android phone has a relationship with Apple or Google, which owns, develops, and maintains the platform. However, the platform owner has a third-party relationship with the app developer, who delivers the app to a repository, sometimes called a marketplace, where the user can acquire it.

To enable these apps to interact with the user and their data, the platform exposes services to the app. In the case of mobile phones, these services may include the user’s location, contact list or address book, and mobile web browser history. Privacy risks arise when the app accesses information in a manner that is undesirable, either by violating the privacy policy of the platform or by exceeding the privileges required by the app. For designers, the challenge arises in how they enforce the user’s privacy settings provided through the platform in the behavior of their services and the behaviors of the apps themselves. A recent enforcement case by the FTC highlights these risks.⁶⁸

“Cloud-based computing” describes the shift of client-based services or services typically run on a company’s intranet to an off-site third party. Clouds refer to the collection of services, which may be accessible by anyone (public clouds), restricted to a particular organization (private clouds), or some hybrid of these two options. The NIST defines multiple levels of cloud services: infrastructure as a service (IaaS), platform as a service (PaaS), and software as a service (SaaS).⁶⁹ Organizations may choose to outsource their infrastructure or hardware and install, administer, and maintain their own platforms or software. The challenge for privacy is that users of a cloud must relinquish control to the third party to protect their data. For example, a cloud provider could have access to data on the clouds it operates, unless a sophisticated cryptographic scheme was used to decrypt the data once it returned to the client’s intranet. Enforcement of privacy in clouds managed by third parties is typically achieved through contract language. In public clouds, users may be

required to accept the terms and conditions or privacy policy of the cloud provider, whereas private clouds may be purchased and customized by the client to fit specific needs. A European company that wishes to purchase a private cloud operated in the United States, for example, may seek to use binding corporate rules, under GDPR Article 47 to ensure the cloud provider employs sufficient safeguards to protect personal data of EU citizens. Ultimately, it is the responsibility of the designer to ensure these safeguards are implemented through privacy and security controls in software and hardware.

“Federated architectures and systems” combine multiple distributed resources to be used together, while keeping these systems under the autonomous control of the system owners. Federated search, for example, enables a search to be performed across multiple distributed databases without integration of their content or without centralized control of the databases. Instead, the search query is decomposed and parceled out based on the logical organization of the constituent databases. Each database responds to its specific piece of the query, and the results are then integrated and presented as a single result. A more specific example of a federated system is a virtual data warehouse, in which a functional data warehouse can be developed without actually bringing together and integrating the data from multiple data sources. Integration in response to specific queries permits different policies to be applied to different collections of data and mitigates some privacy risks related to comprehensive aggregation. The privacy impact of federation concerns what information can be learned from aggregated data that was originally collected with the purpose of storing the data separately. This also can affect surveillance, as data points are linked together to track a person’s behavior over time and across multiple separate data sources.

2.4.2 Design Representations

Designers use notations to identify and organize various system elements and express critical relationships between these elements. This includes object models, which describe the discrete entities (e.g., servers, program modules, data elements), and process models and data flow diagrams, which describe the order of operations and data exchanges within the system. Historically, entity-relationship (ER) diagrams provided the basis for these representations. Today, there are multiple notations tailored to the specific tasks of high-level and low-level architectures, such as the UML, database schemas, and component-and-connector (C&C) diagrams. We now discuss a few of these representations using industry standard notations.

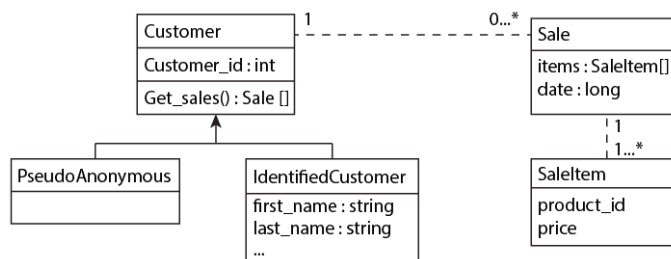
2.4.2.1 Object and Data Models

Object models are used to describe elements of a system and the compositional relationships between these elements. The UML object-oriented class diagram is a commonly used notation for describing object models because of the wide variety of supporting tools available to draw these diagrams and because some of these diagrams can be used to generate program code. UML class diagrams describe classes, their data elements and functions over that data, and associations between objects when one class contains a reference to another

class. Privacy analysts can use object models as a lingua franca to enable developer discussions about how personal information will reside in the system, at what fidelity the data will be stored and shared, how to support pseudoidentification, and how to segregate information to limit or avoid unwanted inferences across large datasets that reveal private details about a person.

Figure 2-15 presents a UML diagram for a customer class. The customer class is named “Customer” and the class has a data element, “customer_id,” which is a type of integer, abbreviated as “int.” This class also has a function called “get sales()” that returns an array of type sale. The dashed line between the “Customer” class and the “Sale” class denotes that each customer has a relationship to zero or more sale objects. In this design, the designer chose to use “information hiding,” which is a common object-oriented design practice, to separate the PII into a subclass called “IdentifiedCustomer.” In Figure 2-15 the arrow points from the subclass to the superclass. For large systems where developers reuse these classes across their components, one developer can design an interface that shares only “PseudoAnonymous” objects with outsiders and internally operates on the IdentifiedCustomer object to limited unwanted accesses to personal information at runtime. Because the PseudoAnonymous class still inherits the customer_id from its superclass Customer, the PseudoAnonymous customer objects can be used to uniquely identify customers without revealing their personal names or other sensitive information contained in the IdentifiedCustomer class.

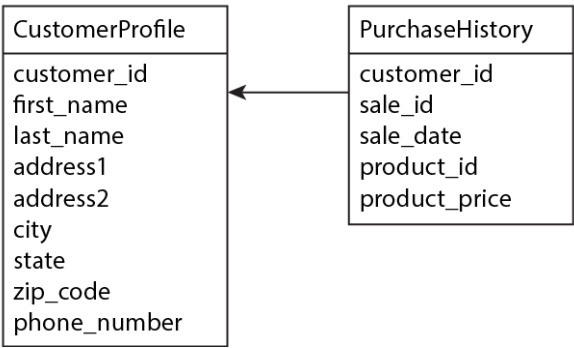
Figure 2-15: Example UML diagram for a customer purchase history



The wide use of databases to store information has led to the development of database schemas. Databases consist of tables containing columns that describe the data elements and rows that describe the data records. Tables may include distinct keys to cross-index records among multiple tables. Figure 2-16 illustrates a database schema for a customer purchase history. The schema includes two tables: “CustomerProfile,” which contains the customer’s personal information, and “PurchaseHistory,” which contains records of purchases indexed by a “sale_id.” The key symbol in the CustomerProfile means this schema element is unique. That is, each customer has only one unique customer_id. Unlike the UML diagram, this schema is simple and keeps the customer information in a single table. However, the purchase history is still separated into a second table. The link between the two tables is the customer. Thus, to cross-reference data, a program requires access to both tables and the

customer id. In this design, designers can limit access to customer information by granting access only to the PurchaseHistory table. This table describes the customer’s purchases, some of which may still be sensitive, but does not disclose the customer’s personal information. To gain access to that information, the program would need to use the customer id to access the CustomerProfile table containing the customer’s address, phone number, and so on. Commercial database systems include access control features that allow developers to restrict access to tables and, in some cases, individual cells (i.e., row-column locations). This topic is discussed more in chapter 4.

Figure 2-16: Example database schema for a customer purchase history



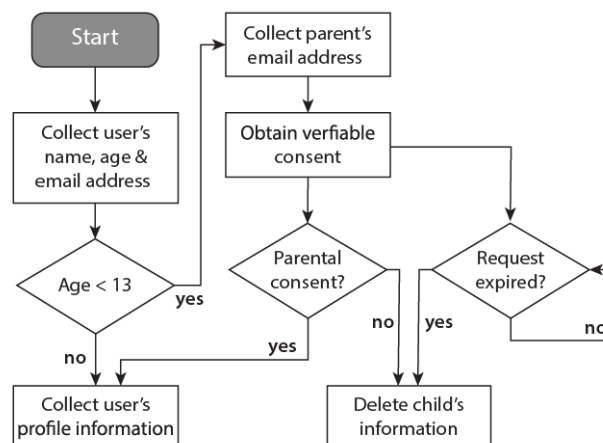
As designers consider how to map requirements into the design, they should pay special attention to the data dictionary and special requirements pertaining to each data type. The trace matrices that map legal requirements to data types may limit how data can be used, and it is the designer’s responsibility to ensure those limits are translated into their design. This translation can be further expressed using process models, which are discussed in the next section.

There is also a level of data beyond what directly supports the functionality of a system: metadata. Metadata is data about data and can be crucial for ensuring appropriate data governance at the necessary level of granularity. Metadata can specify important characteristics of personal data, including sensitivity, permitted uses, consents, and dates related to collection, modification, and retention. Metadata can also be attached to data as a byproduct of processing, such as the header information that is included in a typical email. Metadata that is bundled with personal data is, of course, personal data as well. In some cases, in fact, metadata, like the locations and dates of credit card transactions for example, can be at least as revealing as the data it is describing. Large amounts of metadata can lend itself to what has been dubbed the “mosaic effect,” revealing patterns of personal behavior that can in turn enable all manner of inference. Metadata, therefore, is very much a double-edged sword and designers must be cognizant of the metadata needed to support privacy-related functions, such as automated deletion upon retention period expiration, and the incidental metadata that processing may generate.

2.4.2.2 Process Models

Process models complement data models by representing what will be done with the data. Flowcharts are a simple type of process model. Flowcharts represent the system's operations and the sequencing of those operations, including conditional decision points. Figure 2-17 presents a flowchart fragment to express how a user registers for a service. Because some users may be under age 13, and therefore considered children under COPPA, the system must obtain verifiable consent from the parents of those children. This flowchart has two critical design features that are necessary, but not sufficient, for COPPA compliance. First, if the user is under age 13, the system will only collect more information from the child, other than name, age, and email address, if the parent provides verifiable consent. Second, if the parent does not consent, or if a response to the consent request is not received within a reasonable time or if the request has expired, then the system will delete the child's information, including their name, age, and email address. COPPA allows for some other exceptions not represented here, but this example demonstrates how a designer can model the regulatory process in their system design prior to implementation.

Figure 2-17: Example flowchart describing a partial COPPA-compliant user registration process



In addition to flowcharts, designers may use UML sequence diagrams or other notations to express the order of operations for functions in a UML class diagram. Furthermore, they may use flowcharts or similar diagrams to describe data flows among components.

2.4.2.3 Model-Based Systems Engineering

Model-based systems engineering (MBSE) enables the construction of a single integrated representation of a system under development. By combining architectural, process and data models, MBSE supports all life-cycle phases from requirements definition through verification. MBSE is typically performed using supporting tools, which maintain the system representation in machine-readable form and carry out consistency checks. Some of these tools also support dynamic system simulations and provide for the definition of system functionality using programming languages like Java. However, overall system definition is done using appropriate modeling languages, including UML and the Systems Modeling Language (SysML).

If a system is being developed using MBSE, privacy and other specialty engineers will need to apply their disciplines in the context of the model and the supporting tool, which can be challenging. Since the point of MBSE is to evolve and maintain a single reference model of the system, privacy engineers will have to interact with the system design via its MBSE representation and avoid creating independent, descriptive artifacts. Instead, privacy-related system artifacts should be generated directly from the system model. Industrial-strength MBSE tools include the capability to generate different types of engineering artifacts based on the model. While these tools usually come with a variety of predefined document types, they also permit tailoring those artifacts and defining new types. Generating system documentation in this way both ensures currency and consistency, since the basis for all artifacts is the model at the time they are created, and greatly facilitates their production as necessary.

Related to but different from MBSE is the concept of a digital twin. A digital twin simulates an actual artifact, or specific aspects of it, with high fidelity. Moreover, data generated via sensors from operation of the artifact are fed into its digital twin to maintain that fidelity. This enables users to analyze the behavior of the artifact, forecast its performance, and even run experiments without having to engage with the artifact directly. A useful way of distinguishing between MBSE and digital twinning is to think of MBSE as primarily about prescription and digital twinning as primarily about description. This is an unavoidably simplistic distinction, though, as the model MBSE produces as part of the design process can potentially morph into a digital twin. Once the artifact being designed is actually created, the model could potentially be elaborated or otherwise adjusted to precisely mirror the operation of the artifact, including taking operational data as input. However, just as it can prove difficult to incorporate nonfunctional properties such as privacy into the models produced by MBSE, it can prove difficult to reflect those properties in digital twin simulations.

2.4.2.4 Design Patterns

Erich Gamma, Richard Helm, Ralph Johnson, and John Vlissides introduced design patterns into mainstream software engineering through object-oriented programming.⁷⁰ Design patterns describe recurring problems through a shared solution that can be repeatedly reused to solve the problem. As originally conceived, design patterns are considered approaches that can be emulated to solve particular types of frequently encountered problems or achieve common goals, including privacy-related ones. As templates, though, they must be tailored and otherwise configured to produce a contextually specific solution. Conversely, patterns can also capture things to be avoided. So-called dark patterns include those that reduce, rather than enhance, privacy and are discussed in section 2.4.2.6.

The design patterns proposed by Gamma et al. serve to improve program code maintenance by providing developers with a common mental model for approaching a recurring problem. They identify four elements of a design pattern:

1. A “pattern name” that enables easy reference to, and communication of, the pattern.
2. A “problem description” that the pattern is intended to solve. This includes sufficient information to recognize when the pattern applies.
3. A “solution” that describes the elements of the design, their relationships, their roles, and how they interact. The solution may be presented as a template the designer must instantiate in the context of the design through some modification or extension.
4. The “consequences” that describe the results from applying the pattern and any trade-offs that occur by using or not using the pattern. This information assists the designer in determining whether the pattern’s benefits are an improvement to the design.

Recently, work has been done in academia to identify privacy patterns.⁷¹ Researchers at the University of California, Berkeley School of Information maintain the privacypatterns.org website, which disseminates information on emerging privacy patterns. For example, the ambient notice pattern, which appears in this online repository, describes a general solution to the problem of providing unobtrusive, ongoing notice of real-time location tracking. The challenge with location tracking for mobile users is they may not realize when their location is being monitored or how often, and providing intrusive notices can be as disruptive to the user’s privacy as monitoring their movement through private settings.

Patterns in the repository are grouped by topic, including notification, minimization, access, and transparency, among other topics, and are presented in a format similar to the previously described common pattern format. In addition to reuse, an added benefit of design patterns is the ability to combine multiple patterns to yield more robust solutions. For example, the ambient notice pattern may be combined with the privacy dashboard pattern, which provides an individual with an overview of all the information that an organization maintains on that person. This combination provides both specific indications of when information is used in a nonintrusive manner, as well as an overview of how different pieces of information are used together by a broad range of services.

2.4.2.5 Design Strategies and Tactics

Positioned at higher levels of abstraction, privacy design strategies and tactics describe broad avenues for addressing privacy in systems and particular methods within those avenues, respectively. While privacy design *patterns* constitute solution templates aimed at frequently encountered problem types, privacy design *strategies* are intended to represent general approaches which might be implemented in any of several different ways.⁷² Indeed, privacy design strategies were originally presented as categorizations of design patterns, with the patterns supplying the more specific solutions serving to implement the strategies. Design

tactics reside at an intermediate level of abstraction between strategies and patterns, lending additional structure that can facilitate progression to specific implementable solutions.⁷³

There is no requirement that a privacy design strategy be implemented via a privacy design tactic nor that either be implemented via a privacy design pattern, and the available privacy design patterns are not exhaustive in any event. However, if organizations are so inclined, they can construct their own internal privacy design patterns to address recurring privacy problems that are particular to their environments and missions. These design patterns can then serve as implementation templates supporting privacy design strategies and tactics.

Eight privacy design strategies and twenty-five supporting tactics (noted parenthetically) have been identified to date:

- minimize (exclude, select, strip, destroy)
- hide (restrict, mix, obfuscate, dissociate)
- separate (distribute, isolate)
- abstract, formerly aggregate (summarize, group)
- inform (supply, notify, explain)
- control (consent, choose, update, retract)
- enforce (create, maintain, uphold)
- demonstrate (audit, log, report)

They can be employed as a language during system design to drive thinking about how the system will address privacy and have been used as such in at least one design methodology.⁷⁴ Even if they are not used beyond this, simply invoking a design vocabulary with which to talk about the privacy properties of a given system can prove enormously helpful. Other vocabularies are possible as well, though, with no universal expectation regarding the use of any specific one.

2.4.2.6 Dark Patterns

Designers can use techniques, called dark patterns, to de-emphasize, obscure, or make ambiguous more privacy-preserving response options; for example, by making opt-out buttons smaller and lower contrast, by not clearly differentiating between required information and information that is optional, or by (and sometimes in combination with) repeatedly asking users to opt in within the same process in anticipation of fatigue or a mistake. The goal of dark patterns is to encourage the disclosure of personal information, but it could also include agreement to unexpected or more expansive uses and/or disclosures of personal information. Dark patterns and similar practices should be discouraged to ensure users are given the freedom to express their consent. Dark patterns are treated in greater detail in chapter 5.

2.4.2.7 Trade Studies

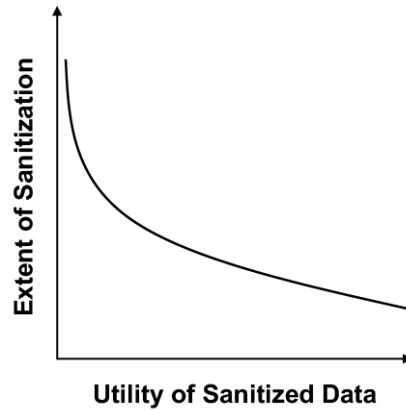
Trade-offs are an inescapable part of designing systems. There are often instances in which no obviously optimal design choice exists. Instead, one is forced to choose between design elements that involve some combination of relatively positive and negative characteristics. A collection of such choices can be plotted, at least in the abstract, on a multidimensional graph, typically in two dimensions, thereby depicting the relevant trade space. Trade studies are a particular form of decision analysis that help engineers, including privacy engineers, think through design trade-offs.²⁵

A “trade tree,” which is similar to a decision tree, can be used to rigorously identify system dimensions and choices that are potential subjects of trade studies. Each layer of the tree represents a system dimension or property while the nodes at that layer in each subtree represent the dimension’s possible choices, which follow prior choices in the given dimensions. Every path from the root node at the top of the tree to a leaf node at the bottom constitutes a complete set of design choices across those different dimensions. The result is a defined overall trade space. If this space is for the system as a whole, privacy can be included as one of these dimensional layers. But there may also be trade-off decisions relevant only to privacy. In that case, a privacy trade tree can be used to construct a privacy-specific trade space for the system. Like any such tree structure, though, trade trees can grow very large, very fast as alternatives multiply. Judgement therefore must be exercised to keep trade trees reasonably bounded (“pruning”), including a priori rejection of alternatives due to feasibility or constraints.

Though a trade study can amount to just structured articulation and comparative evaluation of pros and cons, other types of decision analysis techniques may be of use. These include relatively simple ones, such as influence diagrams, as well as more sophisticated ones like the analytic hierarchy process. However, the specific approach taken is less important than the choice to conduct trade studies in the first place.

A trade space most privacy professionals are familiar with is the one juxtaposing the extent of data sanitization, aka deidentification, with the utility of the sanitized data. It’s generally recognized that the more extensively personal information is transformed, the less privacy risk it presents but the less useful it is likely to be. The exact nature of that relationship is contingent on the nature of the original data and the intended use, but one can reasonably expect a trade-off curve somewhat similar to the one in Figure 2-18. The trade-off curve represents the feasible design choices. The design choice ultimately made will be a point somewhere on that curve. In some cases, it may be possible to establish actual values along the two dimensions and plot a curve based on the anticipated relationship between those values. However, even if a specific curve cannot be plotted, just the concept and explicit recognition of a trade space can support thinking about the available design choices.

Figure 2-18: Notional trade-space for data sanitization versus utility



A less familiar example of a privacy-specific trade space involves biometrics. Biometrics vary in the amount of ancillary information they reveal about people. Fingerprints, for instance, tend to reveal relatively little additional information, such as whether someone has engaged in significant manual labor, reflected by worn ridges. Retinal images, on the other hand, have the potential to indicate a number of health conditions, including diabetes. Fingerprints, though, by virtue of being a frequently employed biometric, probably second only to facial images, potentially offer a multitude of linkages with other datasets containing auxiliary information. Retinal images, in contrast, are still relatively uncommon as biometric use goes and therefore tend to offer fewer linkage opportunities. Thus, fingerprints and retinal images constitute two differently positioned points in a trade space defined by the two axes of ancillary information and linkage potential. Neither point would be considered optimal, i.e., superior along both dimensions. Even an informal plot with the relative positioning of the biometrics under consideration could help structure the analysis of alternatives.

2.4.2.8 Tools

Tools for privacy engineering consist of two types. The first type are tools that support engineering processes generally and into which relevant aspects of privacy engineering must be integrated. The second type are tools that implement specific kinds of privacy mechanisms or controls that are integrated into a product or service. Particular instances of the first type likely will be dictated by the larger development environment and its infrastructure, while instances of the second type will be driven more by privacy engineers and processes specific to privacy engineering.

Modern system development typically makes use of a variety of tools, although the nature and capabilities of those tools will likely vary depending on the environment. The tools used by a large enterprise will almost certainly differ from those used by a small startup, though the increasing availability of development tools as cloud-based services helps to address at least some of that disparity. Tools run the range of both scope, supported by life cycle phases or activities, and scale, supported by number of users and degree of coordination. Examples of the former include requirements management and test management platforms focused on those specific activities, as well as workflow management solutions intended to span the life

cycle. Examples of the latter include single-user integrated development environments, as well as server-based design modeling platforms intended to support large project teams. Privacy engineers must ensure privacy is appropriately reflected in tools and tool use, for example by incorporating privacy requirements into a requirements management tool and appropriate privacy design tactics into a design modeling tool.

Privacy-specific tools, in contrast, are incorporated into the systems being developed rather than the development process. These too can range in scope, with the amount of system functionality they encompass, and scale, with where in the system they are situated. Examples of the former include privacy-preserving record linkage, as well as analytics systems utilizing differential privacy. Examples of the latter include centralized data subject request solutions, as well as privacy-preserving identity management solutions with device-based clients and server-based adjudication mechanisms.

2.4.3 Quality Attributes

In addition to translating requirements into designs to show how a system implements a client's need, designers must pay special attention to quality attributes. Quality attributes in software engineering describe crosscutting concerns that cannot be addressed by a single function. Privacy is an example of a quality attribute, as are security, usability, and accessibility. In security, some quality attributes, such as confidentiality and integrity, are also called security objectives. Because of the complex nature of implementing quality attributes, different designs embody or emphasize different priorities. The next sections discuss several quality attributes required to improve privacy in design.

2.4.3.1 Identifiability

Identifiability concerns the extent to which a person can be identified within a system. Sarah Spiekermann and Lorrie Faith Cranor conceptualize a four-stage scale running from "identified" at stage 0 through "pseudonymous" at stages 1 and 2, all the way to "anonymous" at stage 3.⁷⁶ In each progressive stage, the linkability of data to personal identifiers decreases and privacy protections are based increasingly on technical rather than policy mechanisms. From a privacy perspective, less identifiability is preferable to greater identifiability. While collecting no personal information reduces privacy risk, personal information may be necessary to provide business value. Thus, storing personal data separately from other information when no requirement exists to keep this information together is a strategy to reduce identifiability.

Identifiability manifests in many forms. Information can be identifiable in the absence of a single identifier. Latanya Sweeney demonstrates through *k*-anonymity (see chapter 4) that the combination of gender, birth date, and zip code can likely uniquely identify 87% of the population in the United States.⁷⁷ If such quasi identifiers can be applied to different databases with other personal information such as name and address, then a degree of identifiability exists in the system. Therefore, when assessing identifiability, one must

examine combinations of nonunique identifiers and evaluate how their system design isolates the collection and use of these identifiers to limit drawing unwanted inferences from the data in a privacy-threatening manner. Another example is browser “fingerprinting,” in which the configuration attributes of a user’s browser (e.g., operating system and version, browser version, browser settings) combine to act as a unique identifier and link information together when they are sent in the HTTP request header to the server.⁷⁸ This type of identification constitutes pseudonymity, because the identifier is a substitute for the person’s real identity. To reduce this level of identification, web server log files can be configured to record less information from the HTTP request header. Care must be taken to ensure the design of the system is actually consistent with goals and assertions regarding identifiability.

2.4.3.2 Fairness

The proliferation of AI and AI-based systems over recent years has raised awareness of the importance of fairness as a system property. This takes a variety of forms depending on the nature of the system. One of the most straightforward and high-profile manifestations has been the disparate performance of facial recognition systems on individuals depending on skin color or ethnicity.⁷⁹ Other types of systems based on machine learning (ML), though, have achieved equal notoriety, including systems supporting criminal risk assessment, hiring, policing, and social services decisions.⁸⁰ Not all such systems employ so-called “deep learning” to evolve their capabilities. Many use more mundane forms of ML, including statistical modeling. These differences can have important implications for explainability, but the common thread that unites them is their potential to subject individuals, groups, and communities to arguably, and in many cases indisputably, unfair decisions and treatment.

Complicating matters is the fact that discussing fairness outside of a specific case inevitably leads to abstract framings revolving around ethics and social justice. Systems, though, do not operate using abstract concepts, they produce results based on specific criteria encoded at some level within their processes. In other words, systems reflect some particular contextually relevant definition of fairness, whether consciously established by their developers or not. Depending on the context, a range of potential definitions may be available and, importantly, they might be mutually exclusive.⁸¹ This presents important design choices with a variety of privacy implications, especially with respect to autonomy and intrusion.

2.4.3.3 Network Centricity

Network centricity concerns the extent to which personal information remains local to the client.⁸² When using a client-server architecture, for example, the designer may choose to retain personal information on the client side and transfer this information only for the limited purpose of completing a transaction. Weighting personal information and processing toward the client rather than the server can reduce inappropriate or unwanted disclosures and secondary uses, among other risks, and enhance individuals’ control over their personal

information. This may create new challenges, however, because the designer must distribute application logic across the client and server, as opposed to centralizing this processing on the server side. One consequence may be frequent updates to the client application to offer new value-added services.

While network-centric systems can pose privacy risks by consolidating data in server-oriented architecture, a middle ground that potentially offers privacy benefits exists. For example, if network centricity enables personal information to be disaggregated while still making it available for legitimate uses, the end result may be positive. Federated systems, which distribute personal information across multiple systems but provide clients with a single interface, can potentially mitigate inappropriate dissemination and use, since any given database contains only some fraction of each individual's personal information. This benefit assumes appropriate policy and technical controls are in place to prevent inappropriate aggregation. Without such controls, network centricity can yield more risk than it serves to mitigate. Moreover, in situations where the client is insecure, network centricity may be desired to avoid a breach of security on the client side.

2.4.3.4 Confidentiality

Confidentiality is the extent to which personal information is accessible by others. Access control lists that specify who is allowed access, role-based access control mechanisms that assign sets of permission to generic roles, which are then assigned to individuals, and attribute-based access control mechanisms that base access decisions on particular characteristics of the requester are a few design choices that can be used toward this end (see chapter 4). Access can also be controlled using data encryption and tokenization, such as a format-preserving encryption that maintains the readability of some but not all of the data (see chapter 3). For the designer, determining when to use confidentiality mechanisms depends on tracking business needs throughout the design and aligning authorization with these needs. Tax processors at the IRS, for example, are authorized to access personal information, but only in the context of the specific tax returns being processed. "Browsing" or "snooping" on other returns is expressly prohibited. Complex systems can be designed to cross-reference access logs with role or work assignment logs to identify confidentiality breaches. More generally, confidentiality requires access control schemes to align with business functions and responsibilities. Poor alignment results in excessive accessibility and correspondingly increased risk of compromised confidentiality. If poorly segmented, role-based access control is used, for example, users will have to be assigned many roles to carry out their tasks, providing access to personal information that is too broad in scope.

2.4.3.5 Availability

Availability is typically referred to as a security property, and the need to ensure information is available to satisfy business needs. While confidentiality may naturally fit with privacy by restricting access, one might view availability as inherently in conflict with privacy. When

choosing to lock down data, the designer should consider whether emergency access to personal information is a requirement. This requirement arises in health care situations and is expressly permitted by the U.S. HIPAA Privacy Rule when a patient requires immediate treatment but is incapable of consenting to the access of their medical records. In such situations, strong auditing is recommended as a compensating design control that ensures, whenever emergency access is invoked, logs record this access so any inappropriate uses may be investigated after the emergency is addressed. Because of the potential for misuse, the structure of such mechanisms should be carefully considered. The designer should consider the means to scope emergency access: who is allowed to invoke this access? What information is made available during this access? How long should this access be available? What are the exit conditions to access? And, who is responsible for reviewing audit logs or approving access after the incident?

Availability should also be considered with regard to data persistence across the entire system, including on- or off-site backup and storage. Although data may have been deleted from a production database, that data can persist in the form of backups, replication sites, and archives. The total time required to delete personal information from the system must be considered, as well as the risk implications of data persistence, which may allow data to be accessible outside the scope of normal confidentiality controls. While persistence can provide a safety net—that is, it enables recovery of information in the event of a failure or forensic investigation—it can also provide an opportunity for inappropriate use and disclosure. Establishing retention requirements in the early phases of system development and then tracing these requirements to design and implementation using the data life cycle viewpoint is a means to mitigate such risks during development.

2.4.3.6 Integrity

Integrity refers to the extent that the system maintains a reliable state, including the quality of data as being free from error. For data, integrity can be broken down into three crosscutting concerns: “accuracy” concerns whether the information is correct and free from errors, “completeness” concerns whether there is missing information, and “currency” concerns whether the information is up to date. Inaccurate data can lead to decisional interference—a privacy harm in Solove’s taxonomy discussed in section 2.2.1.3. For example, in February 2000, a Kentucky woman named Ms. Boris made several insurance claims to the Kentucky Department of Insurance.⁸³ The back-end data broker, ChoicePoint, incorrectly recorded these claims and later fed false information to the insurance department, which caused Ms. Boris to lose her coverage due to decisions based on incorrect data. Similarly, incomplete information can lead to privacy harms. Missing or outdated information in a person’s medical record can lead to misdiagnosis. To address these risks in design, the designer should consider how data is collected and restored: is data entry manual, and if so, are there cross-checks in place so the data entry specialist can verify the entries are correct? Is the data restored from backups, and if so, are there mechanisms to ensure corrections

propagate to backups or are restored when a backup is pushed online? Allowing individuals to participate in maintaining the accuracy of their data can limit designers' reliance on other mechanisms that may be outside their control or prone to failure.

2.4.3.7 Mobility

Mobility is the extent to which a system moves from one location to another. Mobility has become of increasing importance with improvements in laptop and mobile phone hardware. Increasingly, location data and the ways it is collected and used introduce privacy risks. In June 2011, Casey Halverson identified a mobile privacy threat in the Nissan Leaf entertainment system, Carwings.⁸⁴ The system included a Rich Site Summary (RSS) news receiver that, upon establishing a remote HTTP request with any server, broadcasts the car's global positioning system (GPS) location, including latitude, longitude, and speed. While this information was made available by the new design of the Carwings system, it was not needed to download the RSS feeds. In addition to tracking location, designers should consider the possibility that mobile devices can be lost, misplaced, or stolen. Locally storing data on a mobile device may require increased security for the possibility that the device falls into the hands of an unauthorized individual. Alternatively, minimizing the amount of data stored locally may also reduce this risk.

2.4.3.8 NIST Privacy Engineering Objectives

The NIST's Privacy Engineering Program has proposed three privacy engineering objectives intended to be the privacy version of the traditional security objectives of confidentiality, integrity, and availability, which make up the CIA triad.⁸⁵ "Predictability" aims to enable reliable assumptions about a system, particularly its data and the processing of that data, by all stakeholders and is needed, for example, to avoid function creep. These stakeholders include not only the individuals to whom the data pertains, but also system owners and operators. "Manageability" refers to the ability to granularly administer personal information, including modification, disclosure, and deletion and is necessary, for example, to respond to data subject access requests (DSARs). "Disassociability" is the minimization of connections between data and individuals to the extent compatible with system operational requirements to reduce privacy risk. This minimization can take many forms, from maximally disassociated data in the form of high-level aggregated data, for example, to deidentified records pertaining to distinct individuals. Disassociability can also take the form of architectural data separation, in which identifiable personal information is kept segregated but is still linkable to transactional data.

2.5 Low-Level Design and Implementation

The implementation of software follows the requirements and design phases to yield working source code that can be tested for conformance to requirements. There are several opportunities to engage engineers in how to improve the quality of their programming

practices with respect to privacy. In this section, we briefly review the state of best practice before discussing these opportunities, which include good coding practices, code reviews, and reuse of standard libraries and software frameworks.

Programmers sit at the center of a software-development project. In small projects, the programmer may take on multiple roles, such as requirements engineer, designer, and tester. In large projects, they coordinate with these other roles through software-development infrastructure, tools and meetings. This includes source configuration management (SCM) systems, such as the stable Concurrent Versions System (CVS) and more modern systems, such as Subversion and several web-based systems designed for agile teams. All these systems allow developers to periodically commit files they are working on, lock files to prevent others from modifying them, and track changes to files with the ability to roll back changes to prior versions. An SCM system can be used to control source code only or to control versioning on other software artifacts, including requirements, designs, and test cases.

In many development environments, a separate system is used to report and track bugs, which include defects, errors, and failures. Companies that provide public access to bug reporting are open to receiving error and failure reports from users. Open-source projects that use bug reporting even accept defect fixes by outside developers. For privacy, software developers can especially benefit from privacy complaint monitoring, i.e., failure or harm reporting, that includes a detailed description of how the system came to offend a user's privacy. While, like any other individual, developers are not well suited to receiving negative criticism, these reports can provide early feedback that can be used to complement other types of requirements analysis, such as the completeness arguments and threat analysis discussed in section 2.3.4.

2.5.1 Good Coding Practices and Code Reviews

Good coding practices that improve maintainability of code have emerged: easy maintenance can improve a programmer's ability to improve other qualities, such as privacy. This includes using secure coding practices and an object-oriented programming language that supports information hiding and loose coupling to control information processing. "Information hiding" is the practice of encapsulating data in classes and restricting access to it through limited class functions and methods that operate on it. Programmers can design a class to be an open container that provides other developers complete access and control over the data, including reading it to compromise its confidentiality and rewriting it to compromise its integrity. Alternatively, a programmer can restrict access to the data by using information hiding and allowing only select, approved classes access to the data. While another programmer can circumvent good information-hiding practices by modifying the class or creating a class of the type approved for access, a standard SCM system would expose such circumventions. Rather, strong interfaces that hide information by controlling access to data and operations on data are more likely to reduce casual errors and misuse of data.

In addition, programmers can employ loose coupling to reduce information flows. Coupling *tightens* when objects depend on the inner workings of other objects. By *loosening* coupling, a programmer reduces dependencies among objects. This practice can be used to isolate information processing to a select group of approved classes and reduce the likelihood that other developers can unintentionally repurpose data, for example, when a marketing system reaches into the billing system to collect email addresses by bypassing privacy controls.

Finally, in addition to routine documentation, a programmer can use special codes to annotate source code with privacy attributes. This includes using programming assertions that state compile-time and runtime assumptions about privacy controls. Figure 2-19 illustrates a Java code snippet in which the programmer uses a runtime assertion to check if a user's profile permits the system to publish their data in a global directory (see line 6). While this check could be made with an if-condition that allowed for a false return value, this programmer assumes the assertion is always true by design. Such assumptions can be made only if the design ensures no state exists that violates this assumption in the program execution leading up to this point. Thus, if the function “consentForPurpose” were to return false on line 6, the defect is in the software's design, which has been modified outside the assumptions of the programmer.

Figure 2-19: Example assertion in Java to check an assumed data purpose

```
1 // The user has selected the option to publish their profile in
2 // in the global user directory.
3 UserProfile p = profileManager.getUserProfile();
4
5 // User consent for this function is true
6 assert(p.consentForPurpose(ApprovedPurposes.USER_DIRECTORY));
7 publishUserProfile(p);
```

Code reviews are organized by developers to review critical source code for defects. Unlike branch and path testing, wherein an executable test case identifies defects by visiting code branches and paths, code reviews are in-person meetings to identify defects in logic or poor practices that cannot be found in a standard testing regime. Code reviews are conducted by three to five developers, with special roles to organize the meeting: the “reader” who reads the code out loud and offers questions to the developer, the “moderator” who remains independent and serves to mediate disagreements and conflicts, and the “developer” who authored the code and listens to the review feedback and answers questions about the code. The developer cannot be the reader or the moderator because they may be prone to take a defensive position to critical feedback. Furthermore, the meetings are best limited to two hours. Longer meetings can lead to participant fatigue and reduced quality of feedback.

Code reviews provide an opportunity to involve privacy engineers in the in-depth discussion about how software implementations satisfy privacy requirements. Unlike privacy

legal experts, who typically have a law background, privacy engineers have a technical programming expertise that allows them to engage developers in technical discussions about how to write and organize source code. Furthermore, the privacy engineer is likely to be an independent reviewer with broad experience from participating in multiple projects. This diverse experience translates into design alternatives that the privacy engineer can introduce to the review, as well as knowledge of existing, reusable privacy software frameworks developed by other project teams that may be relevant to the topic of the review.

2.5.2 Reusing Standard Libraries and Frameworks

Programmers can reuse standard application programming interfaces (APIs) and frameworks to reduce defects in source code. Security APIs can be used to improve confidentiality and integrity in support of privacy. Most general-purpose programming languages, such as C++ and Java, and many web-based scripting languages, such as PHP and Python, include standard libraries for performing a variety of critical security functions. Whenever possible, programmers should reuse these libraries and react to critical security vulnerabilities in existing standards.⁸⁶ Libraries are available to solve multiple standard privacy and security problems, including:

- authentication and authorization APIs, including fine-grained and role-based access control
- encryption algorithms, including standard implementations for RSA or AES
- public key cryptography, including key and X.509 certificate management
- secure communications, including SSL and transport layer security (TLS)

In addition to using standard libraries, programmers can build their own frameworks for addressing privacy principles using a standard protocol. These frameworks should be documented, shared, and reused across the organization's products and services. This kind of reuse is typically a characteristic of the higher maturity levels of process improvement frameworks such as the Capability Maturity Model Integration (CMMI).⁸⁷ Through reuse, the effort expended to validate these frameworks against legal and standards-based privacy requirements, including review by the in-house legal or privacy office, reduces privacy risk in many ways. Because reuse reduces project costs, it helps ensure privacy remains a priority as opposed to an intractable expense. When projects run over budget or past deadlines, privacy requirements may receive less attention than the core functionality required to deliver a working product. Reuse also reduces deviation from best practices. Feedback from legal experts and privacy engineers can help reduce the defects and incorrect interpretations of privacy requirements in validated frameworks; thus, reuse lowers the likelihood of making common privacy mistakes multiple times across different projects. Opportunities for developing privacy-enabling frameworks include:

- user registration services designed to comply with specific regulations, such as COPPA or the GDPR;
- privacy notice mechanisms, including reusable web-based links and email notification services;
- marketing services that are compliant with the Controlling the Assault of Non-Solicited Pornography and Marketing Act of 2003 (CAN-SPAM);
- report-generation services for law enforcement and other requests based on the Electronic Communications Privacy Act of 1986 (ECPA).

2.6 Testing, Validation, and Verification

Testing is perhaps the most crucial phase of the software-development process with regard to managing privacy concerns. As defined by the IEEE, a test is “[a]n activity in which a system or component is executed under specified conditions, the results are observed or recorded, and an evaluation is made of some aspect of the system or component.”⁸⁸ In general, testing consists of two sets of activities: “verification” ensures a resultant system performs according to its requirements and “validation” ensures those requirements themselves satisfy the original needs of the user base for whom the system was developed.⁸⁹ While a system may have been designed and implemented with consideration given to privacy-related requirements, it is only through testing that requirements are deemed satisfied.

Like design, implementation, and deployment, testing can be broken down into various phases, based upon the object being tested or the purpose for which testing is conducted.⁹⁰ This includes unit testing, which covers individual functions and system components, integration testing, which covers the interactions between groups of components, and system testing, which covers completed portions of the whole system. Further levels of testing exist beyond system testing as well, including acceptance testing, which covers requirements validation or whether customers accept the system as delivered, and regression testing, which ensures changes made to an existing system do not affect (or at the very least, predictably affect) other components within the system. Just as requirements definition produces and is supported by dedicated documents and artifacts, so too is testing. In particular, test plans and test cases are developed to specify and record testing activities and results in the different testing phases. Testing related to quality attributes like privacy and security is sometimes specified and carried out separately, and even independently, rather than together with the testing of functional requirements.

Although considered a phase, testing often occurs alongside many of the other phases of the development life cycle, notably implementation and deployment. However, privacy-related concerns will vary depending on when testing occurs in this process. For example, a developer is tasked with writing a function that copies a subset of thousands of user records from one table in a database to another. Ideally, the developer reviewed requirements

pertaining to this function in advance and followed any relevant design specifications. When it comes time to test this function via a unit test, the developer must provide it with suitable data. The most representative data yields the best test results, because the data reflects real-world use of the system. In some cases, this data may be obtained from a data vendor or collected from other runtime systems owned or operated by the manufacturer.²¹ Usage of real data to test a component before deployment raises a number of issues regarding how the data was obtained, which dedicated tester performs the test in question, and how the data is accounted for during and after completing the testing process.

Testing functions and system components with representative datasets is tremendously valuable because failures in the system are more likely to reflect real-world use of the system. However, the data supplied is at best a proxy for the real thing, no matter how closely it may represent that of anticipated users. To improve testing fidelity, a portion of the system may be exposed to real users through alpha and beta testing. These testing methods involve inviting real people to use the system and provide live data, which raises a number of new privacy issues regarding management of their data and their expectations.

Once testing has concluded and further changes or adjustments made to the system, it will be deployed for active use. Testing continues, however, in the form of both new features and updates that may use the testing methods already discussed and runtime monitoring and auditing of the current system. This may include log analysis, issue tracking, and testing of APIs, which allow other software and remote services to communicate with a system.

In the following section, we briefly review the more common types of testing (unit, integration, system, acceptance, and validation) before devoting our primary discussion to usage of data in testing, alpha and beta testing, and runtime monitoring and auditing.

2.6.1 Common Types of Testing

“Unit testing” is focused on system components, usually the smallest cohesive or self-contained pieces of the implementation. In software, this includes object classes in object-oriented programming and subroutines or procedures in procedural programming. In addition, a single web page or a database script embedded in a web page can be the unit in unit testing. The fundamental principle in unit testing is to determine whether a unit will yield an expected output when given a predefined input. For testing purposes, some requirements can be assigned to specific units. For example, a privacy requirement to allow a user to configure a privacy setting can be tested by ensuring a form submission from a privacy setting configuration web page would yield a change in a database entry that stores this setting. However, additional testing would be needed to ensure the database entry is later read by the parts of the system that must behave in accordance with the setting, such as restricting access to the user’s personal information.

“Integration testing” is focused on testing the individual units as members of a subsystem. Unlike individual units, subsystems enable more complex transactions that can be tested

against more complex requirements that describe larger behaviors of the system. Returning to our example in unit testing, a tester may wish to observe the effect of changing a privacy setting on the other units of the system that must behave in accordance with the setting. For example, if the setting restricts sharing the user's email with third parties for marketing purposes, and the system has a unit to generate a list of customer emails for an approved third party, the tester can check whether the generated list excludes a user who has configured this setting. While these two units may be tested independently, engineering experience has shown when components are integrated, additional design assumptions are revealed that lead to failures that would otherwise not be expected. Thus, it is important to incrementally test privacy requirements as portions of the system are completed and delivered, rather than waiting to complete the whole system.

"System testing" is focused on the complete system, including nonfunctional requirements of the system as a whole, that cut across individual units and subsystems. System-testing activities include security, performance, and stress testing. Privacy requirements that relate to the gross behavior of the system can also be tested at this time. For example, a requirement to ensure the system does not expose an individual's personal information may be tested by implementing test cases that search for sensitive data in network traffic, text files, or other media that results from operating the entire system. The tester may discover network traffic that contains unencrypted, sensitive information and attempt to trace this issue back to the set of system components responsible for this failure. System testing may feature attempts to "break" the system by using it in unanticipated ways or by trying to defeat controls.

Unlike unit, integration, and system testing, which *verify* that the privacy requirements were implemented correctly, "acceptance testing" *validates* that the system reflects the correct privacy requirements. Thus, acceptance testing involves the users of the system or those charged with representing those users. Systems may have multiple distinct types of users, and each of these types should be represented. Moreover, even if the system does not interact directly with the individuals to whom its information will pertain, those individuals are still stakeholders in the system. During acceptance testing, it is important to review data subject expectations and the extent to which the behavior of the system is compatible with those expectations. If, on the other hand, data subjects will directly interact with the system, such as a social networking platform, then it is preferable to concretely incorporate their perspective. This can be done via a variety of mechanisms, such as alpha and beta testing, focus groups, or having employees independent of the development team stand in for external users. However, employees can be biased by the company culture and may make assumptions about what is acceptable that do not generalize to the target user population.

As changes are made to the system in response to bugs and other defects, the tester may need to perform "regression testing" by repeating existing tests to ensure these changes have not created new defects. This may occur when a bug fix to a function that supports a business value, such as delivering a web feature to a client browser, leads to disabling a privacy feature

that interacts with the bug fix. By establishing test cases for privacy features, changes that break the privacy feature may be detected using regression testing. The scope and nature of the change will determine which tests should be repeated. To the extent that system components exhibit high cohesion and low coupling, i.e., minimal interdependence, with other components, the potential impact of changes can be contained, and regression testing reduced.

2.6.2 Testing with Data

Testing requires data that is representative of the range of operations the system is expected to experience. Privacy requirements that apply to the runtime system should also apply to a testing environment. In a health care context, for example, if a tester is testing a function that assigns a wellness score derived from the health data of a real person, then this data must be protected to the same degree it would be in a deployed system. However, these privacy requirements may not be met because the testing environment differs significantly from the real environment, such as if the complete system is not available, or the tester uses rough, quickly assembled scaffolding to simulate missing pieces of the system. To address this and related issues, the tester should complete a test plan that includes privacy requirements for protecting test data. In addition, the tester may mitigate these problems by using synthetic data, public data, transformed data, or purchased data, discussed next.

2.6.2.1 Synthetic Data

Synthetic data is data generated for the purposes of testing when access to real-world data is difficult or restricted. Synthetic data aims to mimic the desired attributes of the real data.²² The level of sophistication involved in the data-generation process may vary based on the test being conducted. For example, consider a tester who is testing a function that populates a table in a database within a specified time period. Synthetic data may be used if the values in the data do not influence the test outcome. Whether a database entry is populated with “John Smith” or “first and last name” is not a significant difference, assuming the second string reasonably represents the first string with respect to the length of average strings in the real dataset. If the tester wants to test the function’s ability to handle non-English characters in the test data, e.g., the character *æ*, they could use synthetic data that accounts for this variation. If the tester has access to a real dataset, they could derive a statistical profile from the data that is used to generate a synthetic dataset that contains strings with the proper distribution of characters and string lengths as represented by the real dataset. The benefit of using synthetic data is that testers and other developers do not need special privacy training to prevent privacy harms when handling this data. A potential drawback to using such data, though, is that it may not adequately represent the variety and messiness, including errors, of real data.

2.6.2.2 Public Data

Using publicly available datasets, such as U.S. census data, can be extremely valuable.²³ Census data is comprised of real data about specific individuals that is protected as PII. Furthermore, statistical disclosure controls are applied to this raw data to enable the public release of aggregated information that has very low risk of revealing PII. In the case of anonymized data, which has key identifiers removed, correlations with other public datasets raise the possibility for connections that violate privacy requirements to be developed. See chapter 4 for more discussion on identifiability. In 2006, the online video rental company Netflix released millions of records it believed comprised anonymized data about subscriber video-viewing tastes in a contest to discover a better recommender system. Although the data had been stripped of personal identifiers, researchers were able to predict the identity of certain reviewers by cross-linking that data with publicly available reviews on the online movie database IMDb.²⁴ Thus, data that is publicly available may introduce or be vulnerable to reidentification and other privacy risks.

2.6.2.3 Transformed Data

In light of the risks that can be incurred by using real datasets, some organizations turn to data transformation as a means to avoid privacy risks. Data transformation—also known as data masking, data scrubbing, data anonymization, and data sanitization—takes real data as its starting point and applies various kinds of manipulation to reduce the risk represented by the original data, while preserving desired properties. Note this is different from statistically representative synthetic data, which is new fabricated data generated from a statistical model of the real data. Transformation techniques include the removal of particular fields, suppression of particular values, shuffling of values across records, encryption or hashing of values, and generalization of values to render the data less precise. A variety of commercial products aim to support this process, either as standalone tools or as special-purpose add-ons to larger data management tools.

While transformed data can be effective, it is easy to underestimate the difficulty of creating it. Particularly for large database schemas with many interdependent tables, the act of designing and executing transformations that produce usable data with the needed reduction in privacy risk is not straightforward and can be very labor intensive. There is no simple approach that allows a developer or tester to press a single button and yield perfectly deidentified data. However, if the tester anticipates that the transformed data will be used across multiple IT development efforts, then the cost and time needed to implement this approach may be worthwhile.

2.6.2.4 Purchased Data

An organization may acquire testing data from another source. This has numerous benefits, as the data is often immediately available in a format convenient for testing. However, it is possible the data provider will not legally be allowed to divulge the data—and consequently, the organization that receives the purchased data may not be allowed to use it. Notably, this

occurred in 2002 when Torch Concepts, a U.S. Department of Defense (DOD) contractor, acquired passenger data from the airline JetBlue to test an algorithm that was developed for the purpose of identifying suspected terrorists. This violated JetBlue's privacy policy and may have violated national privacy laws.⁹⁵

2.6.3 Testing with Live Users

Testing with live users provides developers the opportunity to put their system in front of the actual users for whom the system was designed. Doing so can provide extremely valuable information during the development process, as live users may use a system in unintended ways and attempt actions that have not been anticipated by the designers. Such attempts can then be addressed and accounted for in the system, especially if they lead to failures.

However, live user testing comes with privacy risks because the users populate the system with their personal information or reveal their personal behaviors in ways that the system collects as data. In this section, we discuss some of the attributes of different types of live user testing and address concerns associated with alpha and beta testing, in particular.

While alpha and beta tests share similarities, we believe their differences can be specified along the following attributes, which also are strong determinants of the privacy precautions that should be taken:

- **Feature completeness:** The number of a system's features that are made available to users during the test. This ranges from a small subset, e.g., only user registration and account confirmation, to the entire gamut of features the system is intended to deliver.
- **Scale:** The number of users who test the software. This can range from small groups of users to the public.
- **Goal:** The intent of the test, with different intents requiring different measurements and evaluations. For example, testing the system's ability to handle peak user load, which is the greatest number of users on the system at any one time, requires access to a large pool of users. Testing the average time it takes a user to complete a specific task in the system may be performed with a smaller sample.
- **Location:** The place where testing is performed, which could include an on-site lab, an outsourcing agency overseas, or individual users' PCs or smartphones.
- **Officiator:** The entity conducting the test. Is it the organization developing the software, or another agency performing testing as a service? This could also include the organization for which the software is developed.
- **Test data acquisition:** The means by which data is collected and stored for analysis.

2.6.3.1 Alpha Testing

Alpha testing occurs early in the implementation process when a system is not considered feature complete.⁹⁶ Alpha testing is seldom open to the public and is frequently conducted with small groups of in-house users. Often, this is the first time a significant portion of the system is exposed to users, or to professional testers acting as users. Thus, alpha testing can serve to both identify prominent issues early in development and offer an opportunity for requirements validation based on user input in a manner similar to acceptance testing. Based on the previously specified attributes, alpha testing:

- is performed on feature-incomplete systems;
- occurs on a small scale, with tens to hundreds of users, rather than thousands or tens of thousands;
- is seldom open to the public;
- is intended to determine major bugs and offer early requirements validation;
- is conducted in-house or through a third-party testing service that will also conduct tests “behind closed doors;”
- will feature extensive means of data collection, given the low number of users involved in the test.

Privacy concerns during alpha testing are driven largely by the incomplete and knowingly underdeveloped nature of the system in question. While the absence of some expected functionality might be obvious to users, the absence of proper data handling and security measures may not be transparent to the users who volunteer to test early versions of the system. Thus, any data these users provides to the system may not be fully protected, as it would be in later versions. Consider, for example, a user who volunteers to be an alpha tester for a new social networking site. Logging in, the user populates their profile with personal data and then begins exploring various features made accessible to them. Because this is an alpha test, however, developers focused primarily on implementing the functionality for the user that aligns with core business value and did not address the additional privacy and security requirements. The user may be able to access information about others that has not been adequately protected and could also be at risk of exposing personal information to unintended parties; for example, if the site has not yet been configured to use a secure (encrypted) connection and the user accesses it using an unencrypted public wireless network.

When developers aim to alpha-test new features, they must ensure each increment of the system is vetted by a privacy and security analyst. In a fast-paced, highly competitive environment, this analysis may be overlooked. Integrating privacy early in requirements and design will improve the likelihood that privacy concerns are identified and incorporated early, rather than later, at which point alpha tests are at risk of causing privacy harms. Because

data gathered from alpha tests may also contain personal information (e.g., recording the screen of a user while they go through the registration process and profile creation screens), the organization must make sure the data is marked as being personally identifiable and treat this data as it would the same data in a fully operational system. Before using a third-party service for testing, the hiring organization should conduct appropriate due diligence and determine that the testing service has levels of privacy and security protection at least as strict as those in the hiring organization. In chapter 10, we discuss governance, risk, and compliance practices that may be used to assess a third-party testing service.

2.6.3.2 Beta Testing

Many of the concerns that arise during alpha testing apply to beta testing as well, which is usually performed on feature-complete systems with a much larger testing population. Beta tests are often open to the broader public, although they may be capped at a maximum number of participants and often are the last tests conducted prior to live deployment of a system. Regarding the testing attributes, beta tests:

- are performed on feature-complete systems;
- occur on a large scale and are often open to the public;
- are intended to identify bugs and issues that may interfere with the live deployment of the system;
- are often conducted on users' personal or employer-owned machines, which may feature a variety of configurations and states;
- are officiated by the organization developing the system;
- rely on user issue reporting and other means of data collection that may continue to be available once the system goes live.

Privacy concerns during beta testing largely relate to the scale and openness with which the test is conducted. As this is the first time the system is made available to the public, any privacy violations or oversights could have drastic implications and should be addressed immediately. Failure to identify and address these issues can result in a significant negative impact to user adoption. In 2010, Google deployed Google Buzz, a social networking platform, for all existing users of its Gmail electronic mail platform.²⁷ Google Buzz was deployed with a number of privacy issues, such as exposing a list of the user's most emailed contacts to other users by default. This exposure resulted in heavy criticism for these practices.²⁸ Alpha testing can be used to identify concerns early, similar to the use of focus groups in requirements engineering. Unlike alpha testing, user accounts and associated personal information created in beta testing may be retained for the live version of the system.²⁹ Changes in privacy policies or other privacy mechanisms for the live system should be introduced to beta users to transition these users to the live system.

2.6.4 Testing after Deployment

Testing is an ongoing process that continues after systems have been deployed. Post-deployment testing is similar to runtime monitoring, or analyzing usage and performance data collected from a running system. In addition, some unique testing-related concerns occur after a system is live, including privacy-sensitive bug handling and API testing.

2.6.4.1 Log Analysis

Systems can collect or log a large amount of data regarding user activity, and these logs themselves can become an unintentional source of personal information.¹⁰⁰ In 2006, AOL released the search terms of over 650,000 of its users. These terms and identifying personal information had been collected while these users interacted with the AOL search service.¹⁰¹ The search queries, though not directly attributable to the users, contained enough personal information that the users could be identified. Because it is difficult to anticipate how runtime data may be used, strict policies should be put in place to limit repurposing of the data. During design, developers may plan for secondary uses as they consider the various ways data may be sanitized or summarized and the periods for which data may be retained. Once these data sources have been identified, they can be protected or otherwise isolated from the rest of the system, as well as regularly sanitized, summarized, or destroyed to comply with any applicable data retention policies.

2.6.4.2 Bug Tracking

Bug tracking involves the collection and organization of bugs, or errors, in a system. When users encounter bugs, they may be guided to a bug tracker, a piece of software explicitly designed for collecting bug-reporting data.¹⁰² To report a bug, users are asked to provide sufficient detail regarding the context in which the error occurred, as well as the effect of the bug itself, such as the system becoming unresponsive or the user being unable to save data. Systems may be designed with an automated means of collecting and reporting runtime failures to a bug tracker, and the automated report may contain data leading up to the failure, including personal information.

To address these concerns, bug trackers should make the personal information that is collected explicit and present the bug report to the user for review before submitting the report. Systems that are transparent about what information is contained in an automated bug report can improve the likelihood that users will enable submissions. In the event personal information must be collected and reported, that information should be encrypted or otherwise protected and appropriately handled during transmission and after receipt.

2.6.4.3 Application Programming Interface Testing

Many systems implement APIs, which allow other services to connect to the system in innovative ways.¹⁰³ For example, Google Maps provides users with the means to integrate Google Maps into their websites, generating driving directions, obtaining elevation profiles, and enabling other interactive activities. Although an API may be active alongside system

deployment, many are released after the system has seen extensive use. When a developer uses an API, they may unknowingly expose personal information under their own control through the API. If the data pertaining to an API remote procedure call is logged, it may become a potentially unacknowledged repository of personal information or other sensitive data. In this situation, API developers should be careful to extend privacy protections to this data and work with developers who use the API to notify their users about how the API uses personal information.

2.7 Summary

This chapter presents an overview of the software-development life cycle and risk management as these topics relate to developing IT systems that preserve, enhance, and enable privacy. From requirements and design to implementation and testing, privacy is a crosscutting concern for IT professionals. Armed with the knowledge in this chapter, IT professionals can aim to incorporate privacy into IT-system development and engage in deeper discussions to ensure privacy requirements trace throughout the software-development life cycle. For example, in chapter 10 we illustrate the critical role of appointing a dedicated privacy engineer to bridge the technical gap between IT and privacy, consult across multiple IT projects within an organization, share privacy knowledge, and reach a higher standard of care. In addition, we introduce and review several privacy risk models and illustrate how they can be used to drive privacy requirements elicitation that may contribute to addressing privacy risk. Finally, we show how many modern software engineering practices can be applied to address privacy requirements in design, implementation, and testing.

Endnotes

- 1 Stuart Shapiro, Travis Breaux, and David Gordon wrote the original chapter. Stuart Shapiro and Travis Breaux continue to provide updates.
- 2 Alan Westin, *Privacy and Freedom*, (New York: Atheneum, 1967); Julie E. Cohen, “Examined Lives: Informational Privacy and the Subject as Object,” *Stanford Law Review* 52, no. 5 (2000): 1373–1478.
- 3 David G. Messerschmitt and Clemens Szyperski, *Software Ecosystem: Understanding an Indispensable Technology and Industry*, (Boston: MIT Press, 2003).
- 4 Etienne Wenger, *Communities of Practice: Learning, Meaning, and Identity*, (New York: Cambridge University Press, 1998).
- 5 ACM Code of Ethics and Professional Conduct, accessed March 2024, <https://ethics.acm.org/>.
- 6 IEEE Code of Ethics, accessed March 2024, <https://www.ieee.org/about/corporate/governance/p7-8.html>.
- 7 BCS Code of Conduct, accessed March 2024, <https://www.bcs.org/membership-and-registrations/become-a-member/bcs-code-of-conduct/>.
- 8 INCOSE Code of Ethics, accessed March 2024, <https://www.incose.org/about-incose/code-of-ethics>.
- 9 The predecessor to Facebook was first developed by Mark Zuckerberg as a local tool to search student profiles at Harvard University: Alan J. Tabak, “Hundreds Register for New Facebook Website,” *Harvard Crimson*, February 9, 2004. The online auction site eBay was single-handedly created by Pierre Omidyar over a single weekend: Adam Cohen, *The Perfect Store: Inside eBay*, (Boston: Back Bay Books, 2003).

- 10 Messerschmitt and Szyperski, *Software Ecosystem*.
- 11 Peter Naur and Brian Randell, eds., "Software Engineering: Report on a Conference Sponsored by the NATO Science Committee," (Garmisch, Germany, October 7–11, 1968).
- 12 Winston W. Royce, "Managing the Development of Large Software Systems," *Proceedings, IEEE WESCON*, 1970, 1–9; Barry W. Boehm, "A Spiral Model of Software Development and Enhancement," *ACM SIGSOFT Software Engineering Notes*, 14–24, (August 1986); Kent Beck and Cynthia Andres, *Extreme Programming Explained: Embrace Change*, 2nd ed., (Boston: Addison-Wesley, 2004); Mike Cohn, *Succeeding with Agile: Software Development Using Scrum*, (Boston: Pearson Education, 2009).
- 13 Watts S. Humphrey, *Introduction to the Team Software Process*, (Boston: Addison-Wesley Professional, 1999).
- 14 Barry Boehm and Richard Turner, *Balancing Agility and Discipline: A Guide for the Perplexed*, (Boston: Addison-Wesley/Pearson Education, 2003).
- 15 Len Bass, Ingo Weber, and Liming Zhu, *DevOps: A Software Architect's Perspective*, (Boston: Addison-Wesley, 2015).
- 16 Organization for the Advancement of Structured Information Standards (OASIS), "Privacy Management Reference Model and Methodology (PMRM) Version 1.0," Committee Specification 02, May 17, 2016.
- 17 Mina Deng et al., "A Privacy Threat Analysis Framework: Supporting the Elicitation and Fulfillment of Privacy Requirements," *Requirements Engineering* 16, March (2011): 3–32; "Resources," NIST, accessed March 2024, <https://www.nist.gov/itl/applied-cybersecurity/privacy-engineering/resources>; NIST Privacy Risk Assessment Methodology (PRAM), U.S. National Institute of Standards and Technology (NIST), accessed March 2024, <https://www.nist.gov/itl/applied-cybersecurity/privacy-engineering/collaboration-space/focus-areas/risk-assessment/tools>.
- 18 IEEE Standard 610.12-1990, *IEEE Standard Glossary of Software Engineering Terminology*, IEEE, accessed March 20204, <https://standards.ieee.org/ieee/610.12/855/>.
- 19 M. Ryan Calo, "The Boundaries of Privacy Harm," *Indiana Law Journal* 86, no. 3 (2011): 1131–1162.
- 20 Daniel J. Solove, "A Taxonomy of Privacy," *University of Pennsylvania Law Review* 154, no. 3 (2006): 477–564.
- 21 AICPA/CPA Canada Privacy Maturity Model, March 2011, <https://www.cpacanada.ca/en/business-and-accounting-resources/other-general-business-topics/information-management-and-technology/publications/business-and-organizational-privacy-policy-resources/measuring-a-privacy-program>.
- 22 *NIST Privacy Framework: A Tool for Improving Privacy Through Enterprise Risk Management*, Version 1.0, National Institute of Standards and Technology (NIST)/U.S. Department of Commerce (DOC), January 16, 2020, <https://doi.org/10.6028/NIST.CSWP.10>.
- 23 *Security and Privacy Controls for Information Systems and Organizations*, Special Publication 800-53, Revision 5, National Institute of Standards and Technology (NIST)/U.S. Department of Commerce (DOC), Updated December 2020, <https://doi.org/10.6028/NIST.SP.800-53r5>.
- 24 ISO/IEC 27701:2019 *Security Techniques Extension to ISO/IEC 27001 and ISO/IEC 27002 for Privacy Information management—Requirements and Guidelines*, August 2019, <https://www.iso.org/standard/71670.html>; ISO/IEC 27001:2022 *Information Security, Cybersecurity and Privacy Protection—Information Security Management Systems—Requirements*, October 2022, <https://www.iso.org/standard/82875.html>; ISO/IEC TR 27550:2019 *Information Technology—Security Techniques—Privacy Engineering for System Life Cycle Processes*, September 2019, <https://www.iso.org/standard/72024.html>.
- 25 ISO 31700:2023 *Consumer Protection—Privacy by Design for Consumer Goods and Services*, January 2023, <https://www.iso.org/standard/84977.html>.
- 26 *Design Process Standard*, Version 1.0, Institute of Operational Privacy by Design (IOPD), January 3, 2023, <https://instituteofprivacydesign.org/wp-content/uploads/2023/01/Design-Process-Standard-v1.0-Final.pdf>.
- 27 *Workforce Framework for Cybersecurity (NICE Framework)*, Special Publication 800-181, Revision 1, National Institute of Standards and Technology (NIST)/U.S. Department of Commerce (DOC), November 2020, <https://doi.org/10.6028/NIST.SP.800-181r1>.
- 28 Privacy Workforce Public Working Group, National Institute of Standards and Technology (NIST), accessed March 2024, <https://www.nist.gov/privacy-framework/workforce-advancement/privacy-workforce-public-working-group>.
- 29 ACM Code of Ethics an Professional Conduct, Association for Computing Machinery, accessed May 2024, <https://www.acm.org/code-of-ethics>.

- 30 Douglas W. Hubbard and Richard Seiersen, *How to Measure Anything in Cybersecurity Risk*, (Hoboken, NJ: Wiley, 2016); Jack Freund and Jack Jones, *Measuring and Managing Information Risk: A FAIR Approach*, (Waltham, MA: Butterworth-Heinemann, 2015).
- 31 Jaspreet Bhatia and Travis Breaux, “Empirical Measurement of Perceive Privacy Risk,” *ACM Transactions on Human Computer Interaction (TOCHI)*, 25(6): Article 34, (2018); Paul Slovic, *The Perception of Risk*, (Earthscan, 2000).
- 32 Alessandro Acquisti and Jens Grossklags, “Privacy and Rationality in Individual Decision Making,” *IEEE Security and Privacy*, 3(1): 26-33, (2005).
- 33 DistriNet Research Unit, KU Leuven, “LINDDUN Privacy Threat Modeling,” accessed July 2024, <https://linddun.org/>.
- 34 “PANOPTIC™ Privacy Threat Model,” The MITRE Corporation, accessed March 2024, <https://ptmworkshop.gitlab.io/#/panoptic>.
- 35 Helen Nissenbaum, *Privacy in Context: Technology, Policy, and the Integrity of Social Life*, (Stanford, CA: Stanford Law Books, 2009).
- 36 Calo, “The Boundaries of Privacy Harm.”
- 37 Westin, *Privacy and Freedom*; Cohen, “Examined Lives.”
- 38 Solove, “A Taxonomy of Privacy.”
- 39 Stuart S. Shapiro, “Deriving and Using Synthetic Consequences for Privacy Risk Modeling,” in *ICT Systems Security and Privacy Protection*, ed. W. Meng, S. Fischer-Hübner, and C.D. Jensen, SEC 2022 IFIP Advances in Information and Communication Technology, vol. 648, Cham, Switzerland: Springer, 2022.
- 40 Frank Armour and Granville Miller, *Advanced Use Case Modeling: Software Systems*, (Boston: Addison-Wesley Professional, 2001).
- 41 *Guide for Conducting Risk Assessments, Special Publication 800-30, Revision 1*, U.S. National Institute of Standards and Technology (NIST)/ U.S. Department of Commerce (DOC), September 2012, <https://doi.org/10.6028/NIST.SP.800-30>.
- 42 NIST Privacy Risk Assessment Methodology (PRAM), U.S. National Institute of Standards and Technology (NIST).
- 43 R. Jason Cronk and Stuart S. Shapiro, “Quantitative Privacy Risk Analysis,” *2021 IEEE European Symposium on Security and Privacy Workshops (EuroSe&PW)*, Vienna, Austria (2021): 340-350.
- 44 Stuart S. Shapiro, “Privacy Risk Analysis Based on System Control Structures: Adapting System-Theoretic Process Analysis for Privacy Engineering,” *2016 IEEE Security and Privacy Workshops (SPW)*, San Jose, CA, USA (2016): 17-24.
- 45 Pamela Zave and Michael Jackson, “Four Dark Corners of Requirements Engineering,” *ACM Transactions on Software Engineering and Methodology* 6, no. 1 (1997): 1–30.
- 46 Barry Boehm and Victor R. Basili, “Software Defect Reduction Top 10 List,” *Computer* 34, no. 1 (2001): 135–137.
- 47 Joy Beatty and Anthony Chen, *Visual Models of Software Requirements* (Redmond, WA: Microsoft Press, 2012).
- 48 Don A. Dillman, Jolene D. Smyth, and Leah Melani Christian, *Internet, Mail, and Mixed-Mode Surveys: The Tailored Design Method*, 3rd ed., (Hoboken, NJ: Wiley, 2008); Roger Tourangeau, Lance J. Rips, and Kenneth Rasinski, *The Psychology of Survey Response*, (Cambridge: Cambridge University Press, 2000); Richard A. Krueger and Mary Anne Casey, *Focus Groups: A Practical Guide for Applied Research*, 4th ed., (Thousand Oaks, CA: SAGE Publications, 2008).
- 49 The Privacy Act defines the term “system of records” as a group of records under the control of any U.S. government agency “from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.” 5 U.S.C. § 552a(a)(5).
- 50 There are other kinds of standards, which are predictable or functional. Industry standards, for example, may be functional or nonfunctional, depending on their scope and level of detail.
- 51 COPPA, 16 CFR Part 312.
- 52 Travis D. Breaux and Annie I. Antón, “Analyzing Regulatory Rules for Privacy and Security Requirements,” *IEEE Transactions on Software Engineering* 34, no. 1 (2008): 5–20.
- 53 Travis D. Breaux and David L. Baumer, “Legally ‘Reasonable’ Security Requirements: A 10-Year FTC Retrospective,” *Computers & Security* 30, no. 4 (2011): 178–193.
- 54 Breaux, “Legally ‘Reasonable’ Security Requirements.”
- 55 Julia B. Earp, Annie I. Antón, and Ryan A. Carter, “Precluding Incongruous Behavior by Aligning Software Requirements with Security and Privacy Policies,” *Information and Software Technology* 45, no. 14 (2003): 967–977.

- 56 “Privacy Policy,” Google, www.google.com/policies/privacy/.
- 57 Julia Angwin and Jennifer Valentino-Devries, “Apple, Google Collect User Data,” *The Wall Street Journal*, April 22, 2011.
- 58 Travis D. Breaux, Annie I. Antón, Kent Boucher, and Merlin Dorfman, “Legal Requirements, Compliance and Practice: An Industry Case Study in Accessibility,” *Proceedings of the 16th IEEE International Requirements Engineering Conference, Barcelona, Spain*, (2008), 43–52.
- 59 NRS 603A.200.
- 60 Va. Code Ann. §18.2-186.6(A).
- 61 *National Taxpayer Advocate: 2008 Annual Report to Congress*, Department of the Treasury, Internal Revenue Service, vol. 1, 2008, 213–226.
- 62 Axel van Lamsweerde, “Elaborating Security Requirements by Construction of Intentional Anti-models,” *Proceedings of the 26th IEEE International Conference on Software Engineering*, 2004, 148–157; Guttorm Sindre and Andreas L. Opdahl, “Eliciting Security Requirements with Misuse Cases,” *Requirements Engineering Journal* 10, no. 1 (2005): 34–44; John McDermott and Chris Fox, “Using Abuse Case Models for Security Requirements Analysis,” *Proceedings of the 15th Annual Computer Security Applications Conference*, 1999, 55–64.
- 63 van Lamsweerde, “Elaborating Security Requirements by Construction of Intentional Anti-models.”
- 64 In 2004, a nurse became the first criminal defendant convicted under the HIPAA Privacy Rule. The nurse stole a cancer patient’s name, birthdate, and Social Security number and used that information to obtain several credit cards: Mike Scott, “HIPAA Gavel Drops—A Message to Healthcare,” *Radiology Today* 5, no. 24 (2004): 38.
- 65 McDermott and Fox, “Using Abuse Case Models for Security Requirements Analysis.”
- 66 Grady Booch, James Rumbaugh, and Ivar Jacobson, *The Unified Modeling Language User Guide*, 2nd ed. (Boston: Addison-Wesley Professional, 2005).
- 67 Paul Clements et al., *Documenting Software Architectures: Views and Beyond*, 2nd ed., (Boston: Addison-Wesley Professional, 2010).
- 68 In the Matter of Facebook, Inc., a corporation, U.S. FTC Decision and Order, FTC File No. 0923184, Docket No. C-4365, Commissioners: Jon Leibowitz, J. Thomas Rosch, Edith Ramirez, Julie Brill, Maureen K. Ohlhausen, July 27, 2012.
- 69 “NIST Cloud Computing Program – NCCP”, National Institute of Standards and Technology (NIST), updated May 12, 2022, www.nist.gov/itl/cloud/.
- 70 Erich Gamma, Richard Helm, Ralph Johnson, and John Vlissides, *Design Patterns: Elements of Reusable Object-Oriented Software*, (Reading, MA: Addison-Wesley Professional, 1994).
- 71 Sasha Romanowsky et al., “Privacy Patterns for Online Interactions,” *Proceedings of the 2006 Conference on Pattern Languages of Programs*, Article 12, 2006.
- 72 Jaap-Henk Hoepman, “Privacy Design Strategies,” Radboud University, Institute for Computing and Information Sciences, October 25, 2012, <https://www.cs.ru.nl/~jhh/publications/pdp.pdf>.
- 73 Michael Colesky, Jaap-Henk Hoepman, and Christiaan Hillen, “A Critical Analysis of Privacy Design Strategies,” *2016 IEEE Security and Privacy Workshops (SPW)*, San Jose, CA, USA, 2016, 33-40.
- 74 R. Jason Cronk, *Strategic Privacy by Design*, (Portsmouth, NH: IAPP, 2018).
- 75 U.S. National Aeronautics and Space Administration (NASA), *NASA Systems Engineering Handbook, Revision 1*, NASA/SPP-2007-6105, December 2007.
- 76 Sarah Spiekermann and Lorrie Faith Cranor, “Engineering Privacy,” *IEEE Transactions on Software Engineering* 35, no. 1 (2009): 67–82.
- 77 Latanya Sweeney, “k-Anonymity: A Model for Protecting Privacy,” *International Journal on Uncertainty, Fuzziness and Knowledge-based Systems* 10, no. 5 (2002): 557–570.
- 78 Peter Eckersley and Electronic Frontier Foundation, “How Unique Is Your Web Browser?” *Proceedings of the 10th International Conference on Privacy Enhancing Technologies*, 2010, 1–18.
- 79 *Face Recognition Vendor Test (FRVT) Part 3: Demographic Effects*, NIST Internal Report (NISTIR) 8280, U.S. National Institute of Standards and Technology (NIST)/U.S. Department of Commerce (DOC), December 2019, <https://doi.org/10.6028/NIST.IR.8280>.
- 80 Julia Angwin, Jeff Larson, Surya Mattu, and Lauren Kirchner, “Machine Bias,” *ProPublica*, May 23, 2016, <https://www.propublica.org/article/machine-bias-risk-assessments-in-criminal-sentencing>; Roberto Iriondo, “Amazon Scraps Secret AI Recruiting Tool that Showed Biases Against Women,” October 10, 2018, *Medium*,

- <https://medium.datadriveninvestor.com/amazon-scraped-secret-ai-recruiting-engine-that-showed-biases-against-women-995c505f5c6f>; Issie Lapowsky, “How the LAPD Uses Data to Predict Crime,” May 22, 2018, *Wired*, <https://www.wired.com/story/los-angeles-police-department-predictive-policing/>; Virginia Eubanks, *Automating Inequality: How High-Tech Tools Profile, Police, and Punish the Poor*, (New York: St. Martin’s Press, 2018).
- 81 In the case of the COMPAS recidivism risk assessments (*supra* note 80), for example, one could define fairness as equal false positive rates or equal false negative rates across racial categories, but not both. For more on these kinds of definitional issues, see Solon Barocas, Moritz Hardt, and Arvind Narayanan, *Fairness and machine learning Limitations and Opportunities*, (Cambridge, MIT Press, 2023), <https://fairmlbook.org/>.
- 82 Spiekermann and Cranor, “Engineering Privacy.”
- 83 John McCormick, “Records ‘Full of Inaccuracies,’” *Baseline*, June 16, 2005, www.baselinemag.com/c/a/Projects-Security/ChoicePoint-Blur/5/.
- 84 Darlene Storm, “Nissan Leaf Secretly Leaks Driver Location, Speed to Websites,” *Security Is Sexy* (blog), *ComputerWorld*, June 14, 2011, <https://www.computerworld.com/article/2470123/nissan-leaf-secretly-leaks-driver-location-speed-to-websites.html>.
- 85 Sean Brooks, Michael Garcia, Naomi Lefkowitz, Suzanne Lightman, and Ellen Nadeau, *An Introduction to Privacy Engineering and Risk Management in Federal Systems*, National Institute of Standards and Technology (NIST)/U.S. Department of Commerce (DOC), January 2017, <https://doi.org/10.6028/NIST.IR.8062>.
- 86 In 1996, a critical flaw was discovered in the MD5 cryptographic hash function that led security experts to downgrade the use of MD5 in applications where a collision-resistant function was needed, such as signing digital certificates: Hans Dobbertin, “The Status of MD5 After a Recent Attack,” *RSA Laboratories’ CryptoBytes* 2, no. 2 (1996): 1, 3–6.
- 87 “What is CMMI?” ISACA, accessed March 2024, <https://cmmiinstitute.com/>.
- 88 IEEE Standard 610.12-1990, *IEEE Standard Glossary of Software Engineering Terminology*.
- 89 Stephen J. Andriole, ed., *Software Validation, Verification, Testing, and Documentation*, (Princeton, NJ: Petrocelli Books, 1986).
- 90 William C. Hetzel, *The Complete Guide to Software Testing*, 2nd ed., (Wellesley, MA: Wiley, 1988).
- 91 Privacy Rights Clearinghouse, “Data Brokers,” October 10, 2010, <https://privacyrights.org/resources/online-information-broker-faq>.
- 92 Joseph E. Hoag, *Synthetic Data Generation: Theory, Techniques and Applications*, (Ann Arbor, MI: ProQuest, UMI Dissertation Publishing, 2011).
- 93 “The Home of the U.S. Government’s Open Data,” Data.gov, updated February 2024, <https://www.data.gov/>.
- 94 Arvind Narayanan and Vitaly Shmatikov, “Robust De-anonymization of Large Sparse Datasets,” *Proceedings of the 2008 IEEE Symposium on Security and Privacy*, 2008, 111–125.
- 95 Annie I. Antón, Qingfeng He, and David Baumer, “Inside JetBlue’s Privacy Policy Violations,” *IEEE Security and Privacy* 2, no. 6 (2004): 12–18.
- 96 Carlos Delano Buskey, “A Software Metrics Based Approach to Enterprise Software Beta Testing Design,” *ETD Collection for Pace University*, Paper AAI3191871, January 1, 2005.
- 97 Miguel Helft and Brad Stone, “With Buzz, Google Plunges into Social Networking,” *The New York Times*, February 9, 2010.
- 98 Ryan Paul, “EPIC fail: Google Faces FTC complaint over Buzz privacy,” *Ars Technica*, February 17, 2010, <http://arstechnica.com/security/2010/02/epic-fail-google-faces-complaint-over-buzz-privacy-issues/>.
- 99 Juliet Lapidus, “Why Did It Take So Long to Get Gmail Out of ‘Beta?’” *Slate*, July 7, 2009.
- 100 Bernard Jansen, Amanda Spink, and Isak Taksa, *Handbook of Research on Web Log Analysis*, (Hershey, PA: IGI Global, 2009).
- 101 Michael Barbaro and Tom Zeller, Jr., “A Face Is Exposed for AOL Searcher No. 4417749,” *The New York Times*, August 9, 2006.
- 102 Sascha Just, Rahul Premraj and Thomas Zimmermann, “Towards the Next Generation of Bug Tracking Systems,” *Proceeding of the 2008 IEEE Symposium on Visual Languages and Human-Centric Computing*, 2008, 82–85.
- 103 Josh Poley, “Best Practices: API Testing,” Microsoft Corporation, February 2008, [https://learn.microsoft.com/en-us/previous-versions/software-testing/cc300143\(v=msdn.10\)](https://learn.microsoft.com/en-us/previous-versions/software-testing/cc300143(v=msdn.10)).

CHAPTER 3

Encryption and Related Technologies

Simson L. Garfinkel, CIPP/US

Encryption is the fundamental technology that protects confidentiality in today's digital world. With encryption, large quantities of data can be rapidly scrambled so they cannot be deciphered or understood by unauthorized entities. Scrambling protects information so it can be sent over the internet or stored on a laptop without having its confidentiality compromised if it is intercepted or stolen by unauthorized parties. Encryption also protects

information stored on most laptops and mobile phones, limiting the risk of data compromise when these devices are lost or stolen.

Beyond protecting confidentiality, encryption can be used to certify documents with digital signatures, making it possible for an unaffiliated third party to determine the identity of the person or organization that signed the document and to verify that the document has not been modified since signing.

Encryption is also used for both identification and authentication in the digital world. For identification, encryption can establish identities that are linked to legal identities, such as the name of a person or corporation. Alternatively, cryptography can provide the authenticity of pseudonyms—proving that many documents were authored by same person or organization, but without revealing identity information that is otherwise linkable. And unlike a name, Social Security number, or other identifier, cryptographic identities can be mathematically authenticated by a *relying party*, greatly reducing the chance that the identity is being fraudulently asserted—for example, by a criminal engaged in identity theft. As a result, encryption has long been used by organizations to identify their websites and internet servers, and it is increasingly used by individuals to prove their identities to remote computers over the internet.

In recent years still more uses of cryptography have emerged. One of the most significant is cryptocurrency, and more broadly the use of blockchain technology. These systems use digital signatures and cryptographic hash functions to certify transactions added to an append-only database called a “ledger.” The transactions can transfer value or ownership of digital assets from one account to another. In the case of smart contracts, these transfers can be dependent on external events. Bitcoin, Ethereum, and non-fungible tokens (NFTs) linked to artwork are all based on blockchain technology.

This chapter introduces the fundamental concepts, historical context, and modern uses of encryption. It explains the difference between so-called secret key and public key algorithms, also known as symmetric and asymmetric. The chapter presents a variety of applications for encryption in the modern information economy—some of which may be surprising and some of which really do no good at all. It explains the factors that go into the security of systems using cryptographic techniques, including the strength of the underlying algorithm, the cryptographic implementation, and quantitative measures such as the length of the password or key used to perform the encryption and decryption. To that end, the second half of the chapter is devoted almost entirely to asymmetric encryption, including the key distribution problem, how public key infrastructure (PKI) attempts to solve it, and modern systems that rely on public key technology. Finally, the chapter explains how poor implementations, poor key management, and other common security problems can render even the best cryptographic systems worthless.

3.1 Encryption: the Mathematics of Privacy Protection

Data encryption is a widely used tool that protects information belonging to individuals, businesses, and governments. It is often said sending information over the internet is like sending a postcard—any person or computer along the path can read it. If the information is encrypted, interlopers can still read the postcard, but they cannot decipher its meaning. A laptop left at a restaurant or in the back seat of a taxi can be a disaster for privacy—anyone who has the laptop can access all its information—unless the data on the hard drive is encrypted. Indeed, encryption is so powerful and trustworthy that most breach-notification laws do not require notification if the information available to the attackers was encrypted.

Encryption can even restrict what someone can do with your data *after* you give it to them. Field-level encryption, built into programs like MongoDB, allows individuals' data fields to be encrypted with their own keys, limiting what a database user or application can and cannot modify. Cryptographic techniques based on digital signatures can help verify that a document has not been modified since it was created.

Finally, encryption can improve the confidentiality of private data by providing additional mechanisms to identify and authenticate authorized users. As such, encryption is at the root of most two-factor authentication schemes, and schemes that do not use encryption, such as sending an SMS message with a code to a preregistered cell phone number, are now regarded as significantly less secure than schemes relying on cryptography. Indeed, some organizations no longer allow SMS as a second factor because it is not secure against a SIM-swap attack, which happens when an attacker takes over a mobile telephone account and has a new SIM card issued for an existing phone number.¹ Also, many phones are configured to display the contents of received SMS messages before the phones are unlocked, allowing a person who stole a cell phone to use it for SMS authentication even while it remains locked. Instead, organizations are adopting universal serial bus (USB) security keys as a universal second factor (U2F), as shown in section 3.7.1.

3.1.1 Vocabulary

Encryption can do all these things and more because it changes the way data is stored in the computer's memory; on solid state drives (SSDs), hard drives (HDs), tapes, and flash devices ("data at rest"); and how it is sent over a network, ("data in motion"). In all these cases, encryption scrambles, or encrypts, data so it cannot be understood or otherwise used without first being decrypted. Encrypting and decrypting are thus inverse operations. Encryption protects data by rendering it unusable, while decryption takes that encrypted data and makes it usable, leaving it unprotected in the process.

In recent years, "homomorphic encryption," has been developed. This new kind of encryption allows encrypted information to be manipulated without decrypting it first ("data in use"). Although homomorphic encryption was a research curiosity just a few years ago, it is now fast enough to make applications requiring high degrees of privacy and security practical. A related technology called "secure multiparty computation" allows two or more

computers to compute a mathematical result without otherwise revealing private information. For example, with multiparty computation, five people can get together and compute their average salary without revealing their individual salaries to anyone—not to each other and not to any trusted third party. Multiparty computation was used in 2016 as part of the Boston Women’s Workforce Council Salary Survey, allowing businesses to participate in the salary survey without revealing the salaries of individual employees.²

In today’s world, the words “encrypt,” “encipher,” and “encode” are often used interchangeably to describe the process of locking up information so it is not usable to unauthorized users. The word “scramble” serves a similar purpose. Likewise, the words “decrypt,” “decipher,” and “decode” are frequently used to describe the reverse process. Each of these words has a slightly different meaning. Knowing those meanings is important to avoid embarrassing usage mistakes.

According to the *New Oxford American Dictionary*, the encrypt and its derivative encryption mean to “convert (information or data) into a cipher or code, especially to prevent unauthorized access.”³ As the definition states, there are two ways to encrypt information—through the use of a cipher, “enciphering” the data, or through the use of a code, “encoding” the data. Ciphers are typically mathematical transformations of data, in which data is scrambled according to some kind of function. Codes are transformations that typically involve a one-to-one replacement of a word, letter, figure, or symbol with another word, letter, figure, or symbol. Interestingly, the word encrypt only dates to the 1950s, according to the *New Oxford American*, but the terms cipher and code have been around for hundreds of years.

Cryptographers—people who study the science of encryption—use the word “plaintext” to denote data encryption and the word “ciphertext” to denote the encrypted message. Encryption was originally developed to secure messages sent from one location to another—especially diplomatic and military messages. Locks and guards could protect the endpoints, but a message carried by a courier between two protected endpoints was vulnerable—hence the need for encryption. Encryption can also be used to secure messages that are sent to the future. Charles Wesley, the cofounder of the Methodist movement, wrote his eighteenth-century diary in code to protect the document and its salacious secrets from prying eyes, although presumably Wesley himself could still read those messages. More than two centuries later, Professor Kenneth Newport of Gresham College spent nine years and successfully decrypted Wesley’s code in 2008.⁴ Likewise, the coded letters Mary, Queen of Scots, sent from prison to France’s ambassador to England were decrypted, or “cracked,” in 2023 by three “amateur code breakers,”⁵ a profession that has the formal title of cryptanalyst.

Both ciphers and codes can be used in a *secure* manner, meaning the plaintext cannot be readily extracted from the ciphertext, but they can also be used in a manner that is not secure, allowing the messages to be deciphered by an adversary. The security or strength of a cipher or code is usually phrased in terms of a “work factor,” meaning the amount of effort an

adversary needs to expend to decrypt the message. In the case of the Wesley messages, the work factor was apparently nine years for a respected English professor.

It is both easy and common to overestimate the strength of an encryption scheme—that is, the amount of effort needed to decrypt a message. It is also both easy and common to underestimate the effort an adversary is willing to spend to decrypt a message or find a flaw in an entire encryption scheme. Moreover, once a flaw is discovered, the knowledge of how to crack the message can typically be applied to many other messages. Because of these tendencies, privacy professionals should never accept the argument that using a weak encryption system is not risky because no one would go to the effort to crack the data being protected. Instead, we should always require proposed encryption schemes to be strong enough to resist all the world's computers working together for millions of years.⁶ Such strength is readily obtainable using encryption systems on every laptop and mobile phone sold today.

It is also common to inadvertently damage the strength of a cryptographic system by using it incorrectly, and such mistakes can be devastating. During World War II, Germany's Third Reich possessed what should have been an unbreakable encryption system, but the Germans used the system in a way that made it susceptible to attack. The Germans also put unrealistic trust in their system. They never realized the messages they sent by radio were systematically intercepted and decrypted by the Allied forces. Historians believe the ability to crack the Enigma cipher machine shortened the war by roughly two years.⁷

It is easy to see how mistakes using cryptography can compromise message confidentiality. But encryption errors can also prevent encrypted data from ever being decrypted again, compromising both availability and integrity.⁸ Many organizations are so frightened by the possibility of losing access to their encrypted data that they leave unencrypted copies locked away in presumably secure locations—and sometimes suffer disastrous consequences when those unencrypted copies are compromised. For example, a shipment of unencrypted tapes might be lost on the way to a remote storage vault. Data can also be unexpectedly compromised when a storage system that is locked away inside a secure computing facility fails and needs to be serviced. For this reason, many organizations demand all stored data be encrypted—even data they never expect will leave the secure perimeter.

Encryption cannot prevent a document from being erased or altered, but it can detect unauthorized changes to files, documents, database records, and other kinds of stored data. The techniques used here, known as “cryptographic hash functions” and “digital signatures,” are discussed in sections 3.3 and 3.4.2.

All this cryptographic technology exists for one purpose—to frustrate the will of the “adversary.” This adversary is assumed to be a constant presence in security engineering. It can be an outsider trying to gain access to an organization's private data, or an insider attempting to make unauthorized changes. Sometimes the adversary is a natural force, such as bad weather or a fire. Whether you are attempting to design a new data protection system

or trying to understand a system created by someone else, it is important to understand the adversary the system was designed to protect against, the capability the adversary has, and the likely forms of attack the system may experience. This is called “threat modeling,” and it is a critical part of designing any system to protect privacy.² After all, without an adversary, there is no need for any protection.

A “cryptographic system” is the collection of cryptographic algorithms, protocols, software, and other items that use cryptography to achieve information security goals. Experience has shown it is very difficult to create cryptographic systems that provide confidentiality and integrity commensurate with the strength of their underlying mathematical algorithms, because cryptographic systems frequently contain implementation flaws. Such flaws can be the result of many factors, including:

- Bugs: Implementation errors.
- Back doors: Flaws that have been deliberately placed in a product for later exploitation.
- Weaknesses: Mathematical vulnerabilities that are unknown when they are developed and deployed but are later discovered.
- Obsolescence: Erosion over time. This occurred in the 1990s, when computers became too fast for the U.S. government’s Data Encryption Standard (DES), developed in the 1970s. It was replaced with the Advanced Encryption Standard (AES).

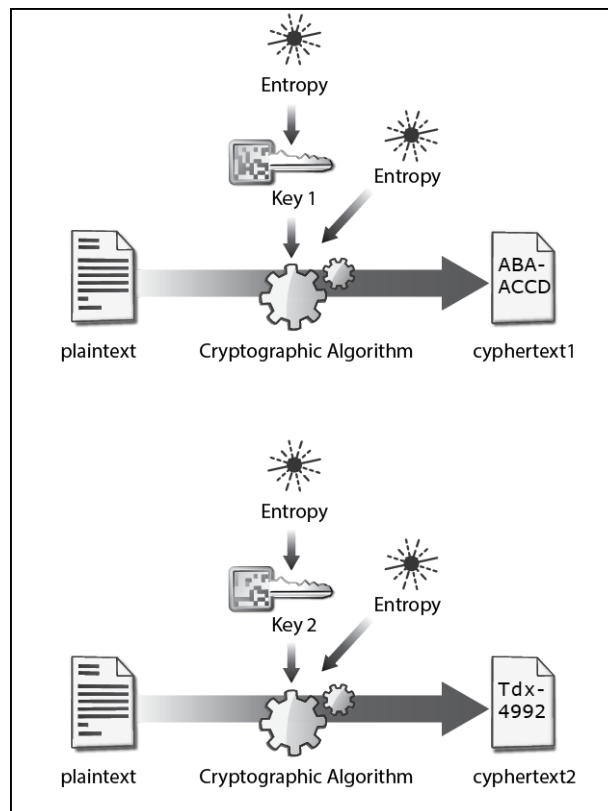
Finally, it is important to remember all cryptographic systems are designed to protect data against specific kinds of adversaries with specific technical abilities and limitations. Clearly, there is no need to design against an all-powerful adversary, as such an effort would be futile.

3.1.2 Encryption Algorithms and Keys

Digital computers perform encryption by applying a mathematical algorithm to a block of data. In addition to the algorithm, encryption requires a key, which is a small piece of data that controls the algorithm’s execution. The same plaintext encrypted with two different keys will produce two different ciphertexts. Likewise, most ciphertexts can be decrypted by one, and only one, key to produce the original plaintext.

It turns out merely encrypting with an algorithm and a key is not sufficient to ensure security. It is also necessary to use randomness, called “entropy,” to prevent an attacker observing the output of an encryption system from determining if the same message is encrypted a second time. This is shown in Figure 3-1.

Figure 3-1: Encryption algorithms use a key to transform plaintext into ciphertext



A cryptographic algorithm takes a key and a plaintext to produce a ciphertext. Making a key requires a source of entropy. Encrypting the same plaintext with a different key will produce a different ciphertext. Strong algorithms also use entropy for each encryption, so the same plaintext will encrypt two different ways if it is encrypted twice.

All modern cryptographic systems require entropy for both creating keys and encrypting messages. Indeed, the need to obtain a sequence of numbers that is truly random is one of the defining characteristics of modern cryptography. But high-quality entropy can be hard to obtain in many environments: The difficulty of obtaining a reliable stream of random numbers has been a source of exploitable weakness in many deployed encryption systems.

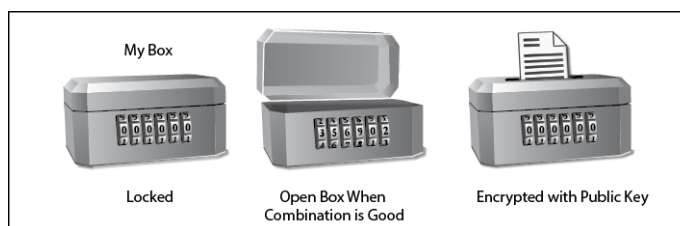
Broadly, there are two kinds of encryption algorithms. “Secret key algorithms,” also called symmetric algorithms, use the same key to encrypt and decrypt the plaintext, as described in section 3.2. “Public key algorithms,” also called asymmetric algorithms, are designed so the plaintext can be encrypted using only public information, but decrypting the ciphertext requires the use of private information, as described in section 3.4. Only some algorithms have this property. They were called “trap door functions,” in a 1976 article by Whitfield Diffie and Martin Hellman that introduced the world to the concept of public key cryptography.¹⁰ Today we call the public information a person’s public key and the private information their private key.¹¹

A common metaphor for encryption is a combination lock on a box. The plaintext is the message inside the box, the lock is the algorithm, and the combination is the key. With this metaphor, a secret key algorithm would use the same combination to lock and unlock the box, while a public key algorithm would use one combination to lock it and a second

combination to unlock it. Likewise, a public key algorithm can be thought of as a locked box with a slot on the top. Anyone can drop a message into the box, but you need the combination to get the message out (Figure 3-2).

A variety of asymmetric algorithms have been proposed. Most are based on some kind of deep mathematical or algorithmic property. One of the most common algorithms is RSA, named after its inventors Rivest, Shamir, and Adleman. However, many other public key systems have been created.

Figure 3-2: Symmetric encryption vs. public key cryptography



Modern encryption systems use keys that are very large numbers. The most common symmetric algorithm in use today, the AES, is typically used with keys that are either 128 bits or 256 bits in size. Each bit can be either a “0” or a “1.” A 128-bit key therefore has $2^{128} = 340,282,366,920,938,463,374,607,431,768,211,456 \approx 3 \times 10^{40}$ possible keys. This is an astoundingly large number.

One way to forcibly decrypt an encrypted message without knowing the key is to try every possible key, because the correct key, when tried, will decrypt the message. Such attack is called a “brute force attack” or a “key search attack,” and it is infeasible with 128-bit AES. To understand why, imagine that an organization had a billion computers (10^9), and each computer could try a billion 128-bit AES keys (10^9) every second, for a total of a billion billion (10^{18}) keys per second. Even with such impressive computing machinery, which is many times the computing power available on earth today, it would still take $3 \times 10^{40} \div 10^{18} = 3 \times 10^{22}$ seconds or 258 trillion years to try every possible combination. That’s approximately 13,000 times older than the age of the universe.

Here is another way to understand the difficulty of a key search attack on 128-bit AES—by comparing the difficulty of the problem to the mass of the earth. The mass of the earth is approximately 6×10^{24} kilograms, while the mass of a modern microprocessor and heat sink is roughly 100 grams. If we pretend for a moment the entire earth could be transmuted into microprocessors with heat sinks, and those processors could crack a million AES keys per second (which they cannot), and that somehow all those processors could run without power, memory, or other hardware, then we would have 6×10^{25} processors each trying 10^6 keys/second, for a total of 6×10^{31} keys/second. Even this earth-shattering computer would still require 5×10^{14} seconds to try all possible 128-bit AES keys, or roughly 16 million years.

Clearly, no one is going to seriously attempt cracking an AES-encrypted message by trying all possible 128-bit encryption keys. But there are ways other than brute force key search to forcibly decipher an encrypted message.

In recent years, significant progress has been made in the field of quantum computing. Today a quantum computer with a few hundred qubits can run programs lasting a fraction of a second, although the results are infused with noise. If a quantum computer with a few thousand qubits could run a program without any noise for a year, it would be able to crack a 128-bit AES key using a technique called Grover's Algorithm. However, even a fully realized quantum computer will not be able to crack 256-bit AES—at least not using Grover's Algorithm. For this reason, 128-bit AES has fallen out of favor, and 256-bit AES is recommended for all applications. We discuss this in further detail in sections 3.1.6 and 3.2.1.

The security of an encrypted message depends both on the security of the key and the strength of the encryption algorithm. Modern design principles hold that, while the key should remain secret, encryption algorithms should be publicly designed and vetted. This is a hard concept for many people to accept—it certainly *seems* since both the key and the algorithm are needed to decrypt a message, an encrypted message is probably more secure if both the key and the algorithm are kept secret. The flaw with this thinking is the assumption that secret algorithms are more secure than public ones. It is dramatically more complicated to design a strong encryption algorithm than to come up with a strong key. Any randomly chosen number is a strong key—modern computers can make hundreds of these keys every second. But creating a good algorithm takes years of careful design, analysis, and testing. If the algorithm is flawed, it may be possible to rapidly decrypt the ciphertext without knowing the key at all, no matter how long the key is. If the strength of secret algorithms and public algorithms were equal, it would indeed be more secure to use a secret algorithm than a public one. However, secret algorithms are usually far weaker than public ones because they have received far less scrutiny. Thus, the modern consensus is that it is far better to use a strong algorithm that has been publicly vetted with a randomly chosen key than a secret algorithm with unknown weaknesses. Indeed, programmers should never take it upon themselves to develop a new encryption algorithm, or to take an existing algorithm and attempt to strengthen it by making changes to the underlying cryptographic machinery. Instead, programmers should use existing, vetted implementations of strong algorithms.

A “cryptosystem” is the entire collection of materials necessary to encrypt and decrypt information. Cryptographers define this term as the algorithms that are necessary to perform encryption or decryption. In practice, security engineers expand this definition to include the collection of hardware, software, equipment, and procedures needed to encrypt, decrypt, transmit, and otherwise manipulate the information being protected—that is, the cryptosystem is anything that will jeopardize the security of encrypted communications if it does not perform as expected. Research over the past decade in usable security makes it clear this traditional definition needs to be expanded to include training, the human context in which the equipment is used and even the psychological state of the human operators.¹²

The strength of the overall system determines the security of encrypted data, not the strength of any single part. For example, a system could have a secure key, but that key could be transmitted in the clear along with the encrypted message. This would be akin to securing a vault with a USD1,500 combination lock but then affixing the lock's combination to the vault's door with a sticky note.

One of the primary goals of a security or privacy professional is to minimize the amount of risk faced by users and customers—and to understand the risk that remains. This is another reason why it is better to use a well-known algorithm than to a secret algorithm. With algorithms that are well known and vetted, the security of the message lies with the key: keep the key secret and the message is indecipherable; release the key and it is open. But with a secret algorithm, the message security requires both that the key be kept secret and that the algorithm be strong. A weak algorithm can compromise a message just as effectively as a weak key. Minimizing risk means minimizing the number of things that can compromise security, which means using algorithms that are widely understood, vetted, and accepted.

3.1.3 Cryptographic Keys versus Passwords

Cryptographic keys are similar to passwords in that both are secrets that can be used to control access to information. But keys and passwords are different in a few important ways.

With a cryptographic key, access to the controlled information requires the information to be first mathematically transformed from the ciphertext back into the plaintext. When information is encrypted, there is no program or agent that decides to grant access—the correct key can decrypt the data, and incorrect keys cannot. Similarly, there is no way to reset the encrypted information and grant access to a new key if the first key is lost. Keys can be changed, but doing so requires the information be decrypted with the correct key and then reencrypted with a second in a process called “reencryption.”

With a password, access to the controlled information is mediated by a program running on some computer. The program compares the password provided by the user with a password on file and grants access if the two passwords match.¹³ Because the program is making a decision about granting access, the decision can be manipulated by factors other than the correctness of the provided password. For example, the program could be modified by malware so access is always granted on Tuesdays at 5 p.m. local time. Note also, the access-granting software has access to confidential parts of the system even when a password is not being provided. Thus, password-protected information can usually be accessed by a system administrator or a sufficiently skilled attacker, even if the password itself is unknown.

These are important differences. As a result, cryptographic approaches typically provide stronger confidentiality assurances compared to password-only approaches—but cryptography is more susceptible to catastrophic data loss. In practice, cryptographic approaches offer less flexibility because access control policies need to be implemented in the rather restrictive language of cryptography. For example, a password system can rather

trivially be programmed with time-based access controls, so even authorized individuals don't have access to data when they are on vacation. It is currently not possible to implement such a restriction solely with cryptography in a manner that cannot be readily subverted.

3.1.4 Encryption before the Rise of E-Commerce

The principles of symmetric cryptography have been understood since the 1960s, and in 1977 the U.S. government published Federal Information Processing Standard (FIPS) Publication 46, the Data Encryption Standard (DES), as a private key algorithm that U.S. businesses could use to protect digital information. DES was a surprisingly strong encryption algorithm. It was not until 1998 that a public demonstration showed a message encrypted with DES being forcibly decrypted, and the weakness the attackers used could be easily overcome by encrypting a message with DES three times over, each time with a different key, in a technique called "triple DES" or "3DES."

Despite the widespread availability of both cryptographic knowledge and DES implementations, cryptography was not widely used in computing until the rise of e-commerce in the late 1990s. This delay was primarily the result of three factors:

- **Lack of workable public key cryptography implementations:** For two parties to communicate privately, they must share a cryptographic key. Without public key cryptography, the only way to exchange keys is by courier or a trusted third party—and then that third party can decrypt any communication it might intercept. Securely agreeing upon a key shared by those two parties and no one else, without having to send it by courier, is the precise problem for which public key cryptography was invented in 1976. But after this invention, it took more than two decades for the technology to move from the world of computer science research labs to software systems that could be readily used by nonexperts.
- **Export controls:** Cryptography's long association with diplomatic and military communications resulted in the technology being legally regulated as a dual-use military technology for most of the twentieth century. In the 1980s, for example, the U.S. government restricted the exportation of computer hardware and software that could perform any kind of cryptography. The government even restricted software systems that allowed so-called "cryptography with a hole," meaning systems that did not implement cryptography directly, but allowed end users to add their own. In the early 1990s, the U.S. government modified its stance on cryptography, allowing the export of cryptosystems that used specific algorithms (RC2 and RC4) at a key length of 40 bits. In 2000, restrictions were eased further, and today most cryptographic systems can be freely exported, provided the underlying cryptographic software is also available as open-source software.

- Central processing unit (CPU) speed: One of the first uses of digital cryptography outside of government sectors was to protect automatic teller machine (ATM) networks, but this was done by special-purpose hardware. Over the following 30 years, computers became dramatically faster, while the algorithms themselves became more efficient. The result is the percentage of CPU power that needs to be expended on cryptography has dropped precipitously. Whereas the impact of software cryptography was crippling on computers in the 1980s and merely significant in the 1990s, today's computers can encrypt and decrypt data with hardly any perceptible impact. Indeed, Apple's iPhone automatically encrypts data as it moves from the CPU to flash storage and decrypts data when it moves back. Encryption on these devices is essentially free.

The real breakthrough in promoting the widespread use of cryptography came in 1995 with the release of Netscape Navigator, the first web browser to incorporate transparent cryptography. Netscape Navigator, and practically every web browser since, allowed information sent over the internet to be automatically encrypted as it traveled between the web server and the web browser. Netscape Navigator did this with an encryption protocol called the secure socket layer (SSL). This protocol was revised several times, renamed the transport layer security (TLS), and adopted as an internet standard in 1999.¹⁴ Today TLS, originally called SSL/TLS, is one of the most widely used forms of encryption in the world. It protects virtually all information sent over the internet, from YouTube streaming videos and Facebook status updates to stock purchases worth hundreds of millions of dollars. Both these low- and high-value transactions are protected using the same TLS protocol.

TLS is generally regarded as a strong protocol. However, it has had many vulnerabilities disclosed over the years. One of the most recent is CVE-2011-3389, which allowed a man-in-the-middle attacker to obtain the plaintext of HTTP headers in an HTTPS session due to an error in the way the TLS Cipher Block Chaining (CBC) mode was implemented. Fundamental cryptographic attacks like this are infrequent but reoccurring.

TLS implementations have also seen their share of flaws. One of the most significant was the Heartbleed bug in OpenSSL (CVE-2014-0160), which allowed attackers to extract cryptographic keys, passwords, and other information from web servers. Heartbleed was not a bug in TLS, but in a popular TLS software implementation. The continuing reoccurrence of both protocol flaws and implementation errors is why it is important for organizations and users alike to keep all software up to date and properly patched.

3.1.5 Encryption Today: Data in Flight, Data at Rest, and Data in Use

Because TLS encrypts data before it is sent over the internet and decrypts the data when it is received at the other end, TLS is said to protect data in flight, in transit. TLS does not

provide security for data once it arrives at the other end. TLS also does not provide assurance that the recipient of the data is trustworthy.

Web browsers use a web page's URL to determine if a page is downloaded over TLS. If the URL begins with *http://*, such as *http://www.iapp.org/*, then TLS is not used. If the URL begins with *https://*, such as *https://www.iapp.org/*, TLS is used. However, a single web page may be built from many individual resources, such as JavaScript libraries, fonts, images, and data from remote servers. All these individual resources must be protected with TLS, or an attacker can subvert the pages' integrity. Once a cryptographic channel is established, it protects both information sent from the server to the client, including the content of the web pages and any downloaded files, and information sent from the client back to the server. TLS can also provide cryptographic authentication of both the server and the client, although in practice only the server is authenticated. It was once common practice to use TLS solely for password forms and not for other resources (such as graphics), but web browsers are increasingly demanding all a pages' resources must be downloaded with TLS or they will be ignored.

TLS is known as a pluggable cryptographic protocol, meaning the single protocol supports the use of multiple hash functions and ciphers. When a TLS client connects to a TLS server, the two negotiate the most secure version of each algorithm from the set of algorithms that each implement. This means TLS can be configured so it offers strong authentication and integrity, but poor confidentiality—a configuration that has been required by some governments in the past. Thus, simply using TLS is no guarantee of security. It depends on the specific algorithms in use.

There are many things TLS encryption does not protect, such as information about the amount of the data exchanged, the location of the endpoints, or the very fact that data is being exchanged at all. Analyzing this kind of information is called “traffic analysis,” and it can be very easy to do. We can explain this by saying TLS provides neither anonymity nor stealth.

To achieve anonymity, it is necessary to hide one's traffic within a crowd using systems such as proxies and mix networks, also called onion-routing networks. These systems work by combining traffic from multiple computers into a single channel sent between multiple computers and then separating out the traffic again. Simple mix networks might involve a single node where traffic is combined. This is how most commercial mix networks work. The onion router (Tor) uses a more sophisticated system that relies on multiple layers of encryption and sends every user's traffic to at least three different computers in sequence, so not even the nodes of the mix network know with whom the users are communicating.

For stealth, it is necessary to masquerade one's traffic so it cannot be observed. This can be done by hiding the traffic using a masking protocol or steganography.

TLS is just one of several internet protocols for protecting data in flight. Some internet telephony protocols use encryption at the application layer. Encryption is also built into the

various 802.11 Wi-Fi Protected Access (WPA) wireless network protocols. Nearly all virtual private network (VPN) systems use encryption to ensure the encapsulated network traffic cannot be decoded by the networks it transverses.

Encryption is also used to protect information that is stored for an extended period on a computer system—called “data at rest.” Two approaches are commonly used for data-at-rest encryption:

- **Application-level encryption:** Also known as file-level or document-based encryption, this approach encrypts data on a file-by-file basis or record-by-record basis. The technology for performing the encryption is usually built into the application program itself. For example, Microsoft Word and Adobe Acrobat both support application-level encryption when the user saves a file with “password to open.”¹⁵ Encryption can also be applied to a file after it is created with add-on file encryption programs.
- **Device-level encryption:** This technology is built into the computer’s storage subsystem and performs encryption on a block-by-block basis. Disk-level encryption is typically done by the computer’s operating system, through a special device driver or inside the hard drive. Apple’s laptops, desktops, and handheld devices are equipped with a special chip that automatically encrypts data when sent from the microprocessor to the flash memory and decrypts the data when it is read back. The encryption key is derived from the user’s password combined with a random key stored inside the chip. The chip is configured so the chip automatically wipes itself, rendering the data unrecoverable, if the wrong password is provided too many times. And, because the key cannot be extracted from the chip, it is not possible to move the encrypted data to a supercomputer cluster and try to crack it there. There just isn’t enough time in the universe.

Encryption is increasingly used to protect information while it is in use. These techniques open fundamentally new kinds of applications. For example, it is now possible to add encrypted numbers together without first decrypting them. One application for this technology is secure telephone conferencing. The participants in the conversation each run software that digitizes their voices, encrypts them, and then sends the data to a central server. The server adds the encrypted numbers together and sends the encrypted sums back to each participant, where the software decrypts the numbers and uses the resulting data to drive a speaker. Each participant can hear the encrypted voice, but malware running on the server cannot eavesdrop on the contents of the conversation.

Currently there are three approaches for working with encrypted data:

- **Secure enclaves:** These rely on modifications to the microprocessor to provide security. Some of these systems, such as the Arm TrustZone, rely on special hardware that prevents the microprocessor from accessing the memory where the secure application is running. Another approach, such as Intel's Software Guard Extensions (SGX), uses specialized hardware within the microprocessor to automatically encrypt memory as it is written and decrypt it as it is read. In this case the cryptographic key is only available to certain programs running with certain privileges. Secure enclaves offer the highest performance for working with confidential data, but the security of these systems have been repeatedly compromised by various implementation flaws found by security researchers.
- **Homomorphic encryption:** This is a collection of mathematical techniques for working with encrypted data. Generalized approaches for working with encrypted data were first developed in 2009 and have steadily improved since then, to the point that they are now deployable for some classes of computation. See section 3.7.3.
- **Multiparty computation:** This class of algorithms allows programs running on different computers to participate in computations so results can be computed without compromising each party's private data. Currently, multiparty computation algorithms are faster than homomorphic encryption algorithms, but harder to set up because the computations must be coordinated. Most multiparty systems allow parties to reveal private information if they conspire together. As a result, many of these systems assume the participants are honest but curious, meaning they faithfully execute the multiparty protocol (they are honest), and the multiparty protocol prevents each party from learning confidential information (so it does not matter that the parties are curious).

Finally, encryption can also be used to certify that a document has not been modified since some time in the past, a technique called “digital signatures.”

In the following sections, we discuss the building blocks from which these capabilities are built.

3.1.6 Encryption Tomorrow: Quantum Computing and Quantum Key Distribution

Big changes may be coming to the world of cryptography in a few years—but then again, they may not. It depends on the success of entrepreneurs in moving quantum technology from the research lab to the marketplace.

“Quantum technology” refers broadly to technology based on the various kinds of physical processes that happen at the atomic and subatomic level. At that small scale, the laws of quantum physics do a better job explaining physical processes than the laws of Newtonian

physics, which were developed to explain behavior at the macroscopic scale. These systems are based on a quantum effect known as “entanglement,” first described in a 1935 paper by Einstein, Podolsky and Rosen and sometimes called “spooky action at a distance.”¹⁶

Three kinds of quantum technology are relevant to this chapter:

- Quantum computers: If they can be made large enough and reliable enough, quantum computers will be able to crack many of the algorithms described in this chapter. The primary threat is to the RSA and Elliptic Curve-based public key encryption systems, since AES can be made quantum-resistant by moving from AES-128 to AES-256, and most hash functions can be made quantum-resistant by using longer hash sizes.

The National Institute of Standards and Technology’s (NIST) Post-Quantum Cryptography program has identified and is now standardizing new algorithms thought to be resistant to number-theory based attacks that could run on a fully realized quantum computer. On July 5, 2022, the NIST issued a status report regarding its standardization effort, and indicated draft standards for the new encryption algorithms should be available in 2024.¹⁷ Once the algorithms have been standardized, it will take years for vendors to create hardware and software systems that implement the new algorithms. And that is just the beginning. Due to the widespread nature of the algorithms that need to be replaced, most experts estimate it will take five to ten years to shift to the new algorithms. As an added complication, the new algorithms are significantly slower and have keys that are significantly larger than those currently in use.

- Quantum key distribution (QKD): This approach distributes an encryption key to two endpoints so, according to our understanding of physics, it is physically impossible for a third party to get a copy of the key. Currently, commercial QKD systems can distribute keys over fiber-optic cables between two endpoints that are up to 100 kilometers apart. In 2018, the government of China launched a satellite that uses lasers to distribute keys between any two ground stations within the satellite’s view. In 2020, South Korean communications provider SK Telecom and QKD vendor ID Quantique announced plans to secure some of its long-distance telecommunication lines using quantum cryptography. SK Telecom is also pushing for the adoption of international standards for the technology.
- Quantum networking: This approach combines aspects of quantum computing and quantum key distribution by allowing two quantum computers to communicate over a distance and collaboratively perform a single quantum

computation. One use of quantum networking combines several small quantum computers to create a medium-sized quantum computer.

Although many scientists believe quantum computing systems will one day be widely available, there is general disagreement about when that day will come. Advocates of quantum computing argue quantum computers that can solve important problems in physics and chemistry will be available before 2030. However, those machines will not likely impact on cryptography. It may be that a fully realized quantum computer, which can decrypt RSA-encrypted messages, will also be available by the year 2030. Alternatively, such a machine may not be created until well after 2050.

3.2 Secret Key (Symmetric) Encryption

In the last section, we learned there are fundamentally two kinds of encryption used by digital computers today: secret key or symmetric encryption, where the same key is used to encrypt and decrypt data, and public key or asymmetric encryption, where one key encrypts and a second key decrypts. In this section, we dig deeper into the specifics of secret key cryptography.

3.2.1 Algorithms and Key Sizes

There are two kinds of secret key algorithms:

- Stream ciphers: Encryption algorithms that transform one byte of data at a time.
- Block ciphers: Encryption algorithms that transform a small block of data at one time, typically 16, 32 or 64 bytes. Both DES and AES are block ciphers.

Ciphers are based on two mathematical operations: “substitution,” substitutes one pattern for another according to a code book and “transposition,” scrambles the bits within a set of bytes. Traditionally, stream ciphers only used substitution, whereas block ciphers could use both operations, making them somewhat more secure but also somewhat slower. Today’s computers are fast enough to allow stream ciphers to be used as block ciphers and vice versa without any perceptible performance impact in most applications. The practical differences between these two kinds of ciphers are no longer as relevant as they once seemed.

The RC4 algorithm was widely used in the 1990s with the Netscape SSL protocol. Attacks of theoretical interest against RC4 were discovered in the early 2000s, and practical attacks were demonstrated in 2015. As a result, RC4 should no longer be used.

ChaCha20 is a high-performance stream cipher invented by Daniel J. Bernstein and published in 2008. A variant of this algorithm that provides for authenticated encryption, see section 3.2.3, called TLS_CHACHA20_POLY1305_SHA256 is one of the five ciphers included in the TLS1.3 specification, see section 3.6.1.

The AES algorithm was developed in 1998 by two Belgian cryptographers, Joan Daemen and Vincent Rijmen, and adopted as a U.S. government standard in 2001. After more than two decades of exhaustive analysis, AES is widely regarded as containing no significant algorithmic weaknesses. This is an impressive accomplishment for an algorithm that is now more than twenty-five years old. The only known way to forcibly decrypt a message encrypted with AES is to try all possible keys one by one, until the correct decryption key is found. Although some theoretical attacks on AES have been published, none can be performed in practice—at least not yet.

AES is actually a family of algorithms. The basic version of AES uses a 128-bit key and is unsurprisingly called AES-128. The algorithm can also be run with a 192-bit or 256-bit key, with the corresponding names AES-192 and AES-256. The AES algorithm itself consists of an inner mathematical operation that is repeated. AES-128 repeats this function ten times and is therefore said to have ten “rounds.” AES-192 has 12 rounds and AES-256 has 14 rounds. Additional rounds make messages encrypted with AES harder to decrypt without knowing the key.¹⁸

Because AES-256 has both a longer encryption key than AES-128 and more rounds, the algorithm is widely regarded as more secure than AES-128. But how much more secure is it? There is really no way to know. Block mode encryption algorithms cannot be proven secure. They can only be shown to resist specific attacks. It is possible in the future some new attack will be discovered that makes AES less secure than it is today. If the past provides any guidance, such developments are likely. The only thing we do not know is when the vulnerabilities will be discovered. If or when such an attack is discovered, it may be possible for an attacker to decrypt some AES-128 messages but no AES-256 messages.

Another factor that distinguishes AES-128 and AES-256 is their resistance to computers based on quantum mechanics. Today such “quantum computers” are exceedingly expensive and quite limited in function. However, those who research quantum computing believe a fully functional quantum computer would be able to quickly crack messages encrypted with AES-128, but not with AES-256.¹⁹ This may be one of the reasons that the U.S. National Security Agency (NSA) still approves AES-256 when operated in the “Galois/Counter Mode” (GCM) for encrypting top secret data, but no such approval has been given for AES-128.²⁰

It’s important to realize “quickly” is a relative term here. Instead of the billions or trillions of years it would take a fleet of conventional computers to crack a single AES-128 key, it is currently thought a fully realized quantum computer might be able to crack a single AES-128 key in roughly one year. But this cracking process could be parallelized. With 256 reliable, fully realized quantum computers, the AES-128 key could be cracked in a month and a half. Quantum computers would speed up cracking AES-256 keys as well. Instead of taking inconceivably longer than the age of the universe, a fully realized quantum computer might be able to crack an AES-256 key in only billions or trillions of years.

For these reasons, AES-128 and AES-192 should no longer be used for encrypting data. Although AES-256 keys are longer than those used with AES-128, and both encryption and decryption take approximately 20% longer, these costs are insignificant in the vast majority of applications. This is a change in recommendations from previous versions of this book, which suggested privacy professionals should carefully weigh the costs and benefits of AES-128 compared with AES-256. Today's computers are so fast that the performance differences are no longer relevant, whereas the security differences will be increasingly relevant.

There are other symmetric encryption algorithms, and many may be just as strong as AES, such as the previously mentioned ChaCha20. The government of China has developed its own suite of cryptographic algorithms so its networks will not be dependent upon algorithms developed elsewhere. One of these algorithms is SM4, which has been standardized in China for protecting wireless networks. Finally, there is increasing interest in so-called lightweight encryption algorithms designed to encrypt small amounts of data—just a few bytes—or that must run in low-power environments. The NIST has a lightweight cryptography standardization effort as well, and it announced the selection of the Ascon family of algorithms in February 2023.²¹ The NIST may one day adopt a lightweight cryptography standard.

3.2.2 Symmetric Cryptography Attacks and Threats

“Cryptanalysis” is the process of trying to decipher an encrypted message without knowing the key in advance. The most basic form of cryptanalysis is the brute force attack, in which an attacker tries to decrypt a single message by systematically trying all possible keys. It is important to understand this kind of key search attack because there is fundamentally no way to protect against it. An attacker that gets an encrypted message can *always* try to decrypt it by trying all possible keys. In practice, more sophisticated approaches are used.

Some people believe a good way to protect against a brute-force key search attack is to prevent the attacker from ever acquiring a copy of the encrypted message. Of course, if it is possible to prevent the attacker from acquiring a message, then the message does not need to be encrypted in the first place. More realistically, modern cryptographers always assume the attacker has both the encrypted message and the full system required to decrypt the message, and only lacks the necessary cryptographic key. In part, this is because it is much easier to evaluate the security of a system if the only thing kept secret is the key, and, in part, this is because the key is the only thing that changes from message to message, so everything else is eventually knowable by the attacker.

Other attacks typically rely on analyzing the individual mathematical operations that create the encryption algorithm and correlating many applications of the algorithm over a large set of data. These approaches invariably make it possible for an attacker to break an encryption system with far less work than trying every possible key.

An encryption algorithm can be considered broken under the following circumstances:

- Known ciphertext attack: Given a ciphertext C , the attacker can determine the plaintext P .
- Known plaintext attack: Given a plaintext P and a ciphertext C , the attacker can determine the encryption key K .
- Chosen plaintext attack: Given a plaintext P of the attacker's choosing and the encrypted ciphertext C of that message, the attacker can determine the encryption key K .
- Differential cryptanalysis attack: Given a number of similar plaintext messages P_1 through P_N and the corresponding ciphertext messages C_1 through C_N , the attacker can determine encryption key K .
- Related key attack: Given a number of related keys and a collection of ciphertext encrypted with each key, it is possible to learn some or all of the keys and, therefore, decrypt some or all of the ciphertext.

While these attacks may not seem particularly realistic, they are all within the realm of possibility. Consider the chosen plaintext attack. This attack might have been performed in the past by giving a document to the ambassador of a country during diplomatic negotiations. The ambassador would then provide the document to the embassy cryptographers, who would dutifully encrypt it and send it back to the home country. If the opposing country's analysts intercept the encrypted message, they would have both a message of their choosing and the encryption of that message using the target country's diplomatic cipher. Similar attacks can be accomplished on modern cryptographic systems as well.

Cryptanalysis makes some encryption algorithms far weaker in practice than one might assume based on their key size. For example, the DES algorithm was based on an algorithm called Lucifer developed in 1971. IBM submitted Lucifer to the National Bureau of Standards (NBS), the precursor of today's NIST, as a candidate for the national standard. Lucifer had a 128-bit key, while the algorithm NBS eventually adopted in 1974 as the DES had 56 bits. At the time, many people thought the NSA put pressure on IBM and NBS to purposely weaken Lucifer so the U.S. government could crack messages encrypted with DES.

In the 1980s, cryptographers Eli Biham and Adi Shamir developed an elaborate variant of the chosen plaintext attack they called differential cryptanalysis. Instead of sending just a few messages to be encrypted, the attacker would send millions or even billions of messages to be encrypted with the same key and then analyze all the results to determine the secret key. Reportedly, the two would have published their technique several years earlier, but they spent most of their time analyzing DES, which was surprisingly resistant to differential analysis. But Lucifer was not. Lucifer could be cracked if the same keys were used to encrypt

just 2^{36} —roughly 68 billion—chosen plaintext messages, well within the capabilities of a medium-sized corporation or a middling government by the late 1980s.²²

As it turns out, those who blamed the NSA for weakening the DES were wrong. The original Lucifer, even with its longer key, was in fact weaker than the 56-bit DES. The change to the substitution boxes that was applied to the original algorithm submitted by IBM made the algorithm stronger, but it strengthened the algorithm against an attack that was secret at the time.²³

By the mid-1990s, it didn't matter much that DES was resistant to differential cryptanalysis, because the algorithm's 56-bit key was no longer sufficiently long. It could be brute-forced by Deep Crack, a million-dollar special-purpose computer created by the Electronic Frontier Foundation (EFF) for the purpose of demonstrating the algorithm's weakness.

At the time DES was shown to be not secure, parts of the U.S. government were attempting to get U.S. industrial partners to standardize a new 80-bit encryption algorithm embedded in a semiconductor called the "Clipper chip." Despite the apparent closeness of the numbers 56 and 80, an 80-bit encryption algorithm has $2^{(80-56)} = 2^{24} = 16,777,216$ times more keys than a 56-bit algorithm. This means if it previously required 22 hours to crack a 56-bit key, it would take 369 million minutes, or 701 years, to crack an 80-bit key.

The U.S. computing industry had three main objections for the Clipper chip:

- First, and most publicly, the Clipper chip featured a mandatory key escrow that would have let the U.S. government decode Clipper-encoded messages with a valid court order. This mandatory key escrow was the chip's *raison d'être*. Because it featured key escrow, the chip posed no threat to law enforcement or intelligence agencies, and the government proposed that products containing Clipper would be freely exportable. But many industry insiders felt they would be unable to sell products that could be explicitly monitored by the U.S. government, especially in an international market.
- Less publicly, but probably equally important, hardware vendors did not want to accept the additional costs and manufacturing complexities of adding a U.S. government chip to their products.
- Finally, organizations that needed more than 56 bits of security but still wished to follow government standards could simply secure their systems using 3DES, which involved using the existing DES algorithm three times in a row, creating an encryption system with a key length of $56+56+56 = 168$ bits.

The Clipper Chip was not commercially successful, but the discussion did draw attention to the need to replace DES.

On January 2, 1997, the NIST announced its intent to replace DES and launched an open competition to select a new algorithm. The NIST received multiple submissions and ultimately chose an algorithm proposed by Belgian cryptographers Joan Daemen and Vincent Rijmen called Rijndael on December 6, 2001.²⁴ Today AES-128 and AES-256 are widely used, as they are both faster and more secure than DES and 3DES. It is possible vulnerabilities in the AES algorithm will be discovered in the future, of course.

Because encryption algorithms come and go, modern encryption protocols such as TLS, see section 3.6.1, allow the algorithms to be specified at runtime. Such systems are sometimes said to implement “pluggable encryption” because different algorithms can be literally plugged in using an application programmer’s interface (API). In this way, it is possible to migrate from old algorithms to new ones when vulnerabilities are discovered with minimal software change (see Table 3-1).

Table 3-1: Comparison of encryption algorithms

Symmetric algorithm	Type	Key size	Block size	Status
DES	Block cipher	56 bits	64 bits	Not secure; do not use
3DES (Triple DES)	Block cipher	168 bits	64 bits	Not secure; do not use.
RC4	Stream cipher	40-2048 bits	8 bits (1 byte)	Not secure; do not use
AES	Block cipher	128, 192 or 256 bits, although only AES-256 should be used in new applications.	128 bits	Used in TLS1.3 with 128-bit and 256-bit key length. Generally thought to be secure
ChaCha20	Stream cipher	128 or 256 bits	8 bits (1 byte)	Used in TLS1.3 with a 256-bit key length

3.2.3 Symmetric Cryptography Modes of Operation

Block encryption algorithms operate on relatively small blocks of data. Encrypting larger amounts of data requires encrypting multiple blocks. Cryptographic “modes of operation” describe precise mechanisms for combining repeated invocations of block algorithms. Understanding modes of operation is important for those developing or evaluating cryptographic software because the mode of operation can impact the security and flexibility of the system.²⁵

While many modes of operation have been devised, only a few are widely used. These are:

- Electronic codebook (ECB): This is the simplest mode of operation to implement, but it's also the least secure. This mode uses the same key to encrypt each block of data. The problem with ECB is blocks that have the same content will encrypt to yield the same output. In practice, this makes it possible for an attacker to learn a great deal of information about the plaintext merely by observing the repeated portions of ciphertext. For most applications, this mode should not be used.
- Cipher block chaining (CBC): This mode overcomes the problem of ECB by encrypting each block as a function of the block's plaintext and the previous block's ciphertext. As a result of this chaining, the same block of plaintext will be encrypted differently each time. Because the first block of the message does not have a previous block, it is encrypted by combining the plaintext and a randomly generated block of data called the "initialization vector" (IV). The IV does not need to be kept secret, but it does need to be different for every message that is encrypted. Because the IV is needed to decrypt the message, it is usually attached to the ciphertext. Disclosing the IV does not jeopardize the security of the ciphertext.
- Counter mode (CTR): This mode is like CBC, except the IV is replaced with a counter. It shares the advantage of having long blocks of data that repeat encrypted differently with CBC. CTR has another advantage: it is possible to start decrypting at any point in the encrypted data. This makes CTR a popular choice for disk encryption algorithms. In contrast, CBC must begin decrypting from the first block in the sequence. Further, in CTR, errors in the cipher text do not propagate, and CTR encryption and decryption can be parallelized. Despite these advantages, CTR is not widely used.

One of the problems with the three previously discussed modes is there is no way to validate the authenticity of encrypted data. Any ciphertext can be decrypted with any key. There is no way, in principle, to look at decrypted information and determine if it is correct or not, meaning there is no way to tell if the encrypted data was not modified or corrupted after it was encrypted. Usually this is not a problem because most data files have internal structure, and this structure is incorrect if the encryption fails. However, it is inappropriate to rely on a chance property, such as being able to display a JPEG or open a file in Microsoft Word, to determine if a file is intact because this property can sometimes be exploited by an attacker.

For this reason, there is another family of modes that implement authenticated encryption (AE). These modes rely on additional information injected into the ciphertext so the decrypting program can verify the decryption was performed using the correct key and the decrypted plaintext was not modified after it was encrypted. Of these modes, the most popular is GCM, an advanced mode that provides high-performance, parallelized encryption

(similar to counter mode) and authentication. Authenticated encryption with associated data (AEAD) because associated data (AD) is added to the ciphertext used to authenticate the decryption. Like CBC, GCM also requires an initialization vector. Because of its high performance, GCM is increasingly the encryption mode of choice for high-speed communications or applications requiring large amounts of data to be encrypted.

3.2.4 Entropy, Random Numbers, and Key Generation

The security of an encrypted document depends on both the algorithm and the encryption key. Until now, this chapter has mostly focused on technical matters having to do with the algorithm, such as making sure the algorithm itself is strong and correctly implemented. However, other than discussing the key's length, this chapter has been silent on the characteristics of a good key or how to make a key.

In general, there are only two hard and fast rules for strong encryption keys. First, the key should be truly random. Second, the key should be used as infrequently as possible—ideally just to protect a single message.

Creating a random key is surprisingly difficult. People are notoriously bad at picking random numbers. Surprisingly, so are computers. Computers are designed to be deterministic machines. Given the same input, computers are supposed to generate the same output. But the same output is precisely wrong when it comes to generating encryption keys. We want every key to be different, even if they were generated in the same way.

Because encryption keys are both so important and so common, modern computers have special-purpose hardware and software solely for creating random numbers appropriate for use in cryptography. Most systems collect randomness from many different sources and use that randomness to scramble the bits in a mathematical structure called an “entropy pool.” Most entropy pools are implemented as a collection of several thousand bits. Every time another random bit is collected, that bit is used to flip *half* the bits in the pool. The half that are picked depends upon the new random bit and all the existing bits in the pool—essentially, the pool is a giant cryptographic hash function. When random numbers are needed for generating keys, those numbers are extracted from the pool with additional processing.

Many sources of randomness can be used for the entropy pool. For example, a computer can generate a few bits of randomness every time the user strikes the keyboard or moves the mouse—the random bits might be related to the number of nanoseconds since the previous keystroke or mouse movement. Digital cameras, microphones, and even network activity are other potential sources of randomness. The best sources, though, derive their randomness from thermal noise or quantum mechanics. For this reason, modern microprocessors frequently have a hardware random number generator that can provide a limitless amount of randomness.²⁶

3.2.5 Applications of Symmetric Cryptography

Throughout this section, we've seen a few uses of secret-key encryption. Here they are again, each with a bit more explanation:

- **Documents with passwords:** One of the most common uses of symmetric encryption is to encrypt documents. Both Microsoft Office and Adobe Acrobat use symmetric encryption when a document is given a password to open. Typically, these systems are implemented with a two-step encryption, where the document is encrypted with a randomly generated 128-bit or 256-bit encryption key and then the key itself is encrypted with a hash of the user's passphrase. The encrypted passphrase can be stored with the document or separately for added security. Document encryption systems can also make multiple copies of the encryption key and encrypt each copy with a different passphrase, allowing multiple passphrases to unlock the document. This is how some systems implement a so-called "master password."
- **Block-level disk encryption:** Instead of encrypting at the document level, this approach applies encryption at the driver layer, separately encrypting each disk sector. Block-level disk encryption transparently encrypts every file stored on the disk. It can encrypt non-file data as well, such as virtual memory and hibernation data, e.g., the contents of physical memory stored on disk during hibernation. Disk encryption schemes typically use a variant of counter mode or GCM, so any disk block can be decrypted without the need to decrypt all the preceding blocks.
- **Persistent VPNs:** If two networks are going to be connected for a long period of time using a VPN, it may be advantageous to connect them with a static encryption key. In this case, the system administrator would create a random encryption key and program it into all systems that require access to the VPN. Advanced systems may use the keys for authentication but use an ephemeral key for the actual data encryption. This approach provides for forward secrecy if the encryption keys are compromised.
- **Transport Layer Security (TLS):** After a cryptographic session is established using asymmetric cryptography, symmetric encryption algorithms are used for bulk data encryption for data sent over the world wide web using TLS.
- **Wireless networks:** Symmetric encryption can also be used on wireless networks. For example, the typical use of the WPA2 and WPA3 encryption system requires all units to be programmed with the same passphrase or key. This passphrase or key is then used to derive a specific symmetric encryption key used to secure data sent over the wireless network. WPA3 further provides for forward secrecy and should be used if it is available. Both provide for an enterprise mode in which users must be authenticated with a username and password, or with a PKI certificate.

Here are some additional uses of secret key encryption:

- **Encrypted databases:** Instead of storing encrypted data in a file, it can be stored in a database. There are many strategies for database encryption. The entire database file can be encrypted with a single key; individual rows or columns can be encrypted; rows, columns, or cells can be encrypted with keys stored in other rows, columns, or cells; the database can be encrypted but the index left unencrypted to allow for rapid searching; and so on. Each strategy has different trade-offs regarding security, performance, and recoverability. There is no one right way to encrypt databases, as different schemes are designed to address different threats and satisfy different performance requirements. Advanced approaches for encrypting data in databases are discussed in section 3.6.4.
- **Cryptographic erasure and retention rules:** There are several schemes for ensuring the complete erasure of a storage media by simply erasing the key, taking advantage of the fact that encrypted data cannot be decrypted without the key. For example, it typically takes two to three hours to overwrite all the sectors of a hard drive and another two to three hours to verify that they have been overwritten. If the drive is encrypted with a key, its entire contents can be rendered indecipherable by erasing the key. At a law firm, each case file could have its records encrypted with a file-specific key. Then, if all the records having to do with a case file need to be erased, this specific key could be wiped. This approach would even make document backups stored on tape, on optical media, or in the cloud inaccessible.
- **Secret sharing:** A single document can be encrypted with a single key that is then split into multiple shares using a mathematical approach called “secret sharing.” These schemes are quite flexible, allowing a key to be split into any number of shares and be recovered with any number of those shares. For example, if an organization has seven auditors, the key could be split so any three auditors, working together, can recover the encrypted data.

3.3 Cryptographic Hash Functions

Hash algorithms are fast mathematical functions that take an input of any length and produce a small output, typically 16 to 128 characters, that looks random, but is in fact completely determined by the input. In strong hash functions, the output cannot be predicted from the input without running the algorithm, and changing any bit in the input will change half of the bits in the output on average. Hash functions that do not have this property should not be used.

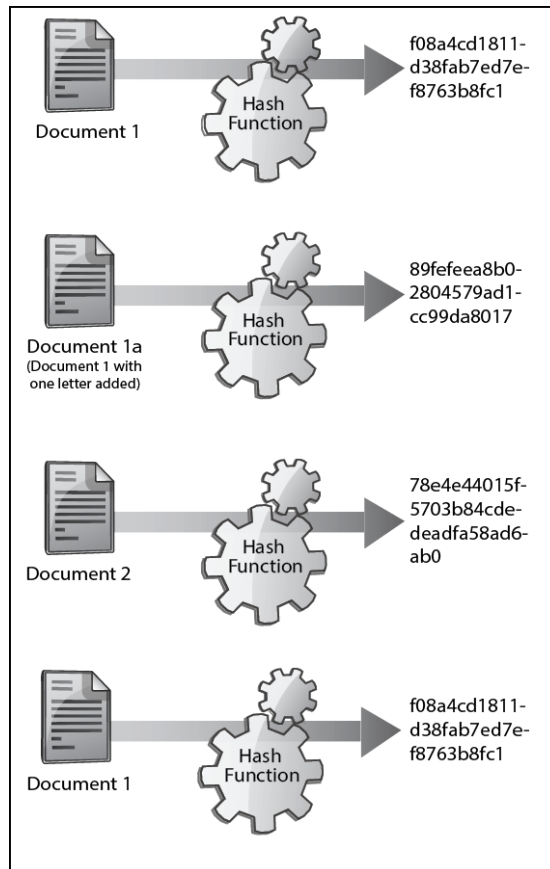
Hash functions are sometimes erroneously referred to as “digital fingerprints” because, in practice, a specific cryptographic hash function for a specific file is distinctive the same way every person has their own set of distinct fingerprints. But the term is erroneous for a variety of important reasons:

- Different hash functions will produce different outputs for the same document. In addition to knowing a document’s hash, it is important to know the algorithm used to produce the hash. Some hash functions can also be keyed, so the document’s cryptographic hash depends on the algorithm, the document, and the key.
- Even though no two people have the same fingerprints, it is possible for many different documents to have the same hash value. Such occurrences are called “hash collisions,” and they are the mark of a hash that is no longer secure.
- Because fingerprints are created by a physical process and people’s fingerprints change over time, each set of fingerprints or latent prints from the same individual is slightly different. As a result, human fingerprints must be matched with a comparison function that allows for slight variations. Cryptographic hashes, by contrast, are precisely matched bit for bit.
- Latent prints left at the scene of a crime are typically partial prints and can sometimes match many different people. Only an expert can determine whether two prints match. File hashes, on the other hand, are always complete and can be matched by anyone or any program—no special training is required.
- Files don’t have fingers, so they cannot have fingerprints.

Figure 3-3 shows that different inputs, with minor changes, result in profoundly different hash values.

The idea of cryptographic hash functions was first proposed by Ralph Merkle in his 1979 PhD thesis. Since then, hash functions have been widely adopted for many applications in computer security and elsewhere.²⁷ “Digital signatures” combine hash functions with public key cryptography in a way that makes it possible to certify a document has not been changed since it was digitally signed, as shown in Figure 3-3. Cryptographic hash functions are also a key building block for Bitcoin and other cryptocurrencies.

Figure 3-3: A hash function applied to a variety of inputs



3.3.1 Cryptographic Hash Algorithms

There are many different cryptographic hash algorithms. Table 3-2 provides a comparison of popular algorithms currently in use.

MD-5 (Message Digest #5) and SHA-1 (Secure Hash Algorithm, version 1) were the first widely used cryptographic hash algorithms. Exploitable mathematical flaws are present in each, and as a result, they should no longer be used.

SHA-2 (Secure Hash Algorithm, version 2) is a family of hash functions developed and currently approved by the NIST. There are six variants in the SHA-2 family, each named after the output size (see Table 3-2). These functions replace SHA-1.

SHA-3, the newest member of the NIST hash algorithm family, is based on a different set of mathematical principles. SHA-3 is not intended to replace the previous algorithm. Instead, it is an alternative algorithm that can be used in systems that support pluggable algorithms, such as most TLS implementations. With multiple algorithms based on different underlying mathematics, organizations have more flexibility when algorithmic vulnerabilities are discovered in the future. Instead of having to distribute both new clients and new servers, only changing a configuration file on the server—a far easier task—is required.

Table 3-2: Comparison of popular hash algorithms. SHA-256, SHA-384 and SHA-512 are all variants of the SHA-2 algorithm.

Family	Hash Algorithm	Output Size (bits)	First Published	Status in 2023
--------	----------------	--------------------	-----------------	----------------

MD	MD5	128	1992	Obsolete and not secure; should not be used.
SHA-1	SHA-1	160	1995	Being phased out; should not be used for new applications.
SHA-2	SHA-224	224	2004	The SHA-2 family of algorithms is widely used. The SHA-384 and SHA-512 variants are roughly twice as fast as SHA-224 and SHA-256 on 64-bit processors as they use 64-bit math.
	SHA-256	256	2001	
	SHA-384	384		
	SHA-512	512		
	SHA-512/224	224	2012	
	SHA-512/256	256	2012	
SHA-3	SHA3-224	224	2015	Chosen by the NIST through an open competition in 2013. Significantly slower than SHA-256 without hardware support.
	SHA3-256	256		
	SHA3-384	384		
	SHA3-512	512		

3.3.2 Applications of Hash Functions

There are many applications for hash functions.

They can convert pass phrases to cryptographic keys. Encryption keys are typically displayed as hexadecimal strings. For example, a 256-bit key could be written as d0e47486bbf4c16acac26f8b653592973c1362909f90262877089f9c8a4536af. Such keys are hard to type and even harder to remember. Instead, a standard approach is to ask the user to type a passphrase, e.g., “Hello World!,” and convert it to a hexadecimal string using a hash function. Here, the conversion is done with SHA3-256.

Hash functions can identify versions of documents. No two documents have the same value for a given hash function, and the hash value of a document does not depend on either its file name or its modification time. As a result, the file’s contents can be uniquely identified by simply specifying the document’s value when it is hashed with a hash function—assuming the hash function hasn’t been broken, of course.

Hash functions can also digitally sign documents. After a document’s contents are hashed, the hash can be cryptographically signed using a public key algorithm and a person’s signing key. The document can then be verified by anyone with the document and the person’s public key by hashing the document and seeing if the signature matches.

Hash functions are easy to use, but like most things in cryptography, it is also easy to use them in an unsecure way. For example, although it is common to derive an encryption key by simply taking a person’s passphrase and hashing it, this is not secure because attackers have compiled password cracking dictionaries of billions of hashes of popular passwords and passphrases. Instead, it is now regarded as best practice to combine the provided passphrase and a random number, called a “nonce,” and to hash the two together thousands of times. The

system then stores the random nonce along with the encrypted document. This approach both eliminates the usefulness of those hashed passphrase lists and significantly slows down brute force attacks that try many different passwords and passphrases.

Password-Based Key Derivation Function version 2 (PBKDF2) is an internet standard that specifies a secure approach for performing this operation. PBKDF2 allows the implementation to specify how many repeated hashes should be applied. In 2023 the Open Web Application Security Project (OWASP) recommended developers use 600,000 iterations for PBKDF2-HMAC-SHA256 and 210,000 iterations for PBKDF2-HMAC-SHA512.²⁸

3.4 Public Key (Asymmetric) Encryption

Asymmetric encryption algorithms use one key to encrypt data and a second key to decrypt the data. These keys are typically called the “public” and “private keys,” and as a result asymmetric cryptography is frequently called “public key cryptography” because one key is made publicly available and the other key is kept private.²⁹ The terms public and private can be misleading, however, since the email encryption schemes perform encryption with the public key, while digital signature schemes perform decryption with the public key. To avoid confusion, this section uses the phrases “encrypting key” and “decrypting key” when discussing encryption, and “signing key” and “verifying key” when discussing digital signatures.

3.4.1 Algorithms and Key Sizes

Asymmetric algorithms, also called public key algorithms, are typically much slower than their symmetric counterparts. Many are based on mathematical properties that arise by manipulating prime numbers. Because of their reliance on certain mathematical properties, they have been harder to discover, but it is easier to understand their security because it is directly related to a hard problem in mathematics, such that cracking the encryption system is the same as solving a long-studied, hard problem. Some of these problems have been studied for decades or centuries, making them well understood and allowing the strength of the cryptographic protection to be readily ascertained.

It is generally easier to crack an asymmetric encryption key than a symmetric key of the same length. This is partly because symmetric keys are simply random collections of bits, while asymmetric keys are numbers with specific mathematical properties. Another reason is that public keys are public, so an attacker targeting a public key system can create any number of chosen plaintext/ciphertext pairs. There are several public key systems currently in use.

RSA relies on the fact that it is easy to multiply two prime numbers together to create a composite number, but it is relatively difficult to take a large composite number and decompose it into its prime factors. With RSA, the private and public keys are

interchangeable, meaning messages encrypted with the RSA public key can be decrypted with the private key, and messages encrypted with the private key can be decrypted with the public key. In this way, RSA keys can be used both for message secrecy and for digital signatures. This leads to occasional confusion, as some RSA implementations use a single private key for decrypting messages and signing digital signatures, while other implementations use keys that are distinctly created and used for each purpose. The personal identity verification (PIV) and common access card (CAC) smart cards used by the U.S. government contain three RSA key pairs: one for encryption and decryption, one for electronic signatures, and one for logging in to remote systems.

The Digital Signature Algorithm (DSA) (FIPS-186) is a public key algorithm created by the U.S. government in the 1990s and published on December 1, 1994, as an alternative to RSA. Compared with RSA, the DSA had three distinguishing features:

- the algorithm was not covered under the RSA patent;
- when it was created, the algorithm could be used for digital signatures but not for encryption, and as a result did not fall under export control regulations at the time; and
- the DSA requires significantly more computational effort to verify signatures than RSA.

Both the RSA and DSA algorithms make use of mathematical properties that arise from performing mathematics in a restricted range of numbers called a “number field.” It is possible to perform the same kinds of operations in a different kind of mathematical range called an “elliptic curve.” Performing the math in an elliptic curve has the advantage that the mathematical problem the algorithm is based on is harder to solve than the equivalent RSA mathematical problem for the same size private/public key pair. As a result, these “Elliptic Curve Cryptography” (ECC) systems can provide similar security to RSA systems with significantly shorter keys.

All these algorithms are vulnerable to attack from large-scale, fully realized quantum computers and, as such, will be replaced when the NIST completes the selection of new encryption and signature algorithms as part of its post-quantum cryptography program.

3.4.2 Digital Signatures

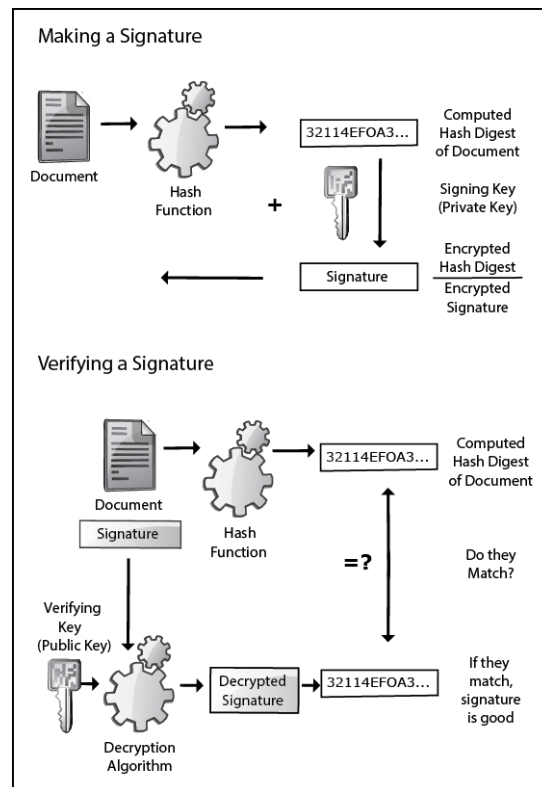
Digital signatures are similar to other kinds of signatures in many ways. Like a human signature, a digital signature is a kind of mark that can be affixed to a digital document to identify the signer. Just as a person can have many ways that they sign their name, a person can have more than one digital signature. Just as corporations and governments can have their own “signatures,” such as the Great Seal of the United States, corporations and governments can have their own digital signatures. Signatures can be used to authenticate

other signatures. For example, in the physical world, a driver's license typically displays a photo and signature of the driver, and on the sealed plastic is a seal of the certifying state. In the same way, one digital signature can be used to certify another. This process is performed with "digital signature certificates," which typically contain a name, an address, and other kinds of digital identifiers, signed by a certifying authority called a "certificate authority" (CA).

But digital signatures are more powerful than physical signatures in specific ways. Unlike physical signatures, digital signatures certify that a document has not been modified since it was signed. This property is called "integrity." To verify a physical signature, it is necessary to have a copy of the signature. Thus, any organization that can verify a physical signature can forge it as well. Digital signatures, in contrast, are created with a private key but verified with a public key. As a result, the only way to dispute the authenticity of a digital signature is by claiming the private key was compromised or by asserting the digital signature scheme itself is mathematically broken. This property is called "nonrepudiation." As a result of integrity and nonrepudiation, a valid digital signature cannot be lifted from one document and fraudulently used to certify another. Although a physical signature must necessarily be affixed to the document it certifies, this is not true of digital signatures. Thus, a signature can be distributed without a document, and then the document can be distributed later. Such signatures are called "commitments" because they commit the signer to a statement that might itself be revealed later. Commitments can be used to implement closed-bid auctions, so that not even the auctioneer knows the identities of the bidders. In this application, the bids consist of a bid value and a digital signature. The winning bid is published on the internet. At this point, the winner reveals the document that matches the signature. The document contains the bidder's bid and their name.

Digital signatures combine two mathematical techniques discussed earlier in this chapter, cryptographic hash functions and public key cryptography (see Figure 3-4). To *sign* a document, a program first computes the hash value of that document. Next, the program encrypts the hash value with the asymmetric signing key. To *verify* the signature, the signature is decrypted with the verification key, which has been widely distributed. For example, the verification key may be on an organization's web page, it may be downloadable from a public directory, or it may be built into software such as a web browser. This produces the claimed hash value of the document. Finally, the document is re-hashed to see if the hash values match. If the two hashes match, the verifier knows two things: (1) the document has not been modified since it was signed and (2) the document was signed by the signing key that matches the verification key.

Figure 3-4: Signing and verifying a digital signature



A private signing key can be thought of as a signature stamp in the physical world—it can stamp a signature on a document or on a piece of paper affixed to the document. Just as with the theft of a signature stamp, if person’s private signing key is stolen, the thief can sign the victim’s signature without anyone being able to tell the difference.

A person or program that verifies a digital signature is called the “relying party” (RP). Verifying the signature requires the RP to obtain the signer’s public verification key. These keys are distributed as “digital certificates,” which are themselves digitally signed by organizations called “certificate authorities.” See section 3.5 for further details.

3.5 Public Key Infrastructure

The inventors of public key cryptography did not give a lot of thought to the problem of matching up people’s names with their public keys. In their seminal paper, “New Directions in Cryptography,” Whitfield Diffie and Martin Hellman suggested:

Each user of the network can, therefore, place his enciphering key in a public directory. This enables any use of the system to send a message to any other user enciphered in such a way that only the intended receiver is able to decipher it... The enciphering key E can be made public by placing it in a public directory along with the user’s name and address. Anyone can then encrypt messages and send them to the user, but no one can decipher messages intended for him.³⁰

That is, Diffie and Hellman envisioned some kind of public directory containing every person’s enciphering key that would be implicitly trusted by all users of the system. Things have not worked out that way—at least not yet.

Diffie and Hellman's original vision was a massive directory of public keys belonging to individuals that other people could use to send secure electronic mail. Today's public keys are mostly used to certify the identity of organizations—and in particular, their web servers—not individuals. Instead of looking up a public key in a directory, web servers send their public keys directly to the web browser in a digital package containing the organization's name, its public key, and the functions for which the public key can be used. The keys are trusted because they are digitally signed by yet another organization, this one trusted to certify that the public key belongs to the organization. The entire system is called “public key infrastructure” (PKI).

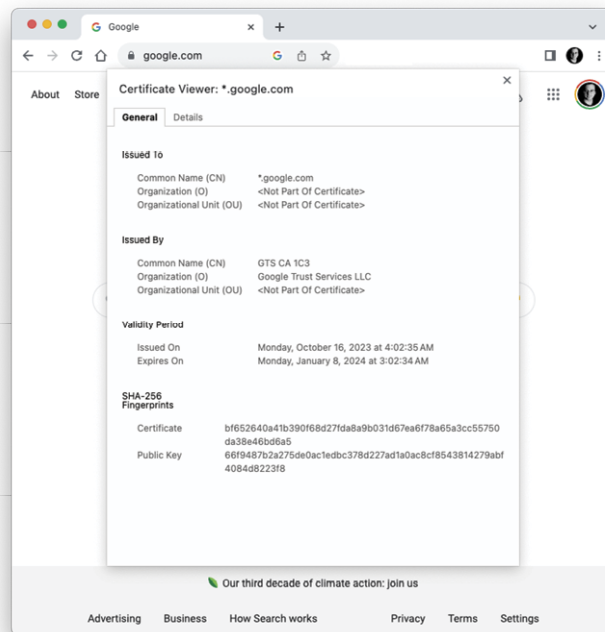
When properly implemented, PKI provides tools for obtaining and verifying public keys that belong to individuals, web servers, organizations, and most other kinds of entities that require some form of digital identification. PKI also contains schemes for revoking keys after they have been abandoned or compromised. But today's PKI implementations have proven too complicated for most computer users to comprehend and too technical for them to care much about. Instead, PKI operates mostly behind the scenes, securing web servers, mobile phones, chats, and even chip-based credit cards.

3.5.1 Certificates

PKI is based on the principle of certification. An entity called a “certificate authority” (CA) asserts (or certifies) that a particular public key belongs to a particular entity. These assertions are stored in small electronic documents that are called “certificates.”

Figure 3-5 shows a portion of a digital certificate as displayed by the Google Chrome web browser for the `www.google.com` domain name. The certificate says it was issued by the Google Internet Authority and that authority's certificate was itself certified by the Equifax Security CA. The Equifax authority is built into the computer on which the browser is running, which is why it has a different icon. The certificate was valid from October 16, 2023 through January 8, 2024.

Figure 3-5: The `www.google.com` certificate as shown by Google Chrome on MacOS³¹



The portion of the certificate display that says “SHA-256 Fingerprints” shows the SHA-256 cryptographic hash function values for the entire certificate and for the public key. Both these values are useful for security professionals when attempting to diagnose encryption problems. In this case, the certificate’s public key begins with the hexadecimal digits bf65 while the public key begins with the digits 66f9.

This certificate was provided to a web browser when a TLS connection was initiated to the server google.com, but the asterisk in the certificate’s common name (CN) field allows the certificate to also certify any subdomain within the google.com parent domain. This certificate claims to have been issued by an organization (O) called Google Trust Services LLC. Of course, the issuing entity can put any name it wishes on the certificate. Having received this certificate, the browser can create a randomly generated session key, encrypt it, and send it back to the server—the very steps that are described in section 3.4.2.

The digital certificate represents a promise made by a third party, in this case an organization called Thawte SGC CA, that the public key on the certificate really does belong to a company called Google that operates a web server at www.google.com. Here’s how:

1. The digital certificate contains not only the server’s public key, but also the server’s domain name system (DNS) name and the name of the company that runs the web server. The browser uses the DNS name to verify that it has the certificate for the correct server. The browser shows the company name to the user, allowing the user to verify the corporate name.
2. Google got the certificate sometime before October 25, 2011. To get the certificate, Google gave Thawte SGC CA a document called a “certificate signing request” (CSR), which consisted of Google’s public key, its corporate name

(Google Inc), its domain name (www.google.com), and various legal documents that establish the people presenting the information to Thawte actually had permission to act on Google's behalf. Thawte verified this information, put it on a digital certificate, signed the certificate with the Thawte private key, and then gave the signed certificate back to Google. At this point, Google took the signed certificate and put it on its web server.

3. The browser can verify the information on the certificate by verifying the digital signature. To verify the signature, the browser computes the cryptographic hash of all the information on the certificate other than the signature. Let's call this hash H_1 . Next, the browser takes the signature that's on the certificate and decrypts the signature with the CA's public key. Let's call this decrypted value H_2 . Finally, the browser checks to see if $H_1 = H_2$. If they are equal, the signature is validated, and the information on the certificate is the same information that was there when the signature was signed.

The previous three steps rely on two presuppositions. First, that the browser has a copy of Thawte's public key, and second, that Thawte behaved in a trustworthy manner. Both presuppositions are the result of a deal between Thawte and the company that created the web user's web browser. The companies that make web browsers, including Microsoft, Apple, Google, the Mozilla Foundation, and others, have all evaluated Thawte and concluded it is a trustworthy CA. That is, they trust Thawte's promises on certificates. As a result of this evaluation, the browser vendors agreed to put a copy of Thawte's public key into their browsers.

Recall that a primary vulnerability of TLS is that a TLS proxy can intercept a TLS connection, decrypt it, and then open a new connection to the destination. Digital certificates cannot stop such interception attacks, but they make it possible to discover them when they happen. If the web browser in Figure 3-5 were connected to a TLS proxy, then the certificate would be signed by the proxy, and not by Thawte.

3.5.2 Client-Side Public Key Infrastructure

In addition to verifying the identity of websites, PKI can also verify the identity of users. This process is similar to how websites are validated, except the certificate is issued to an individual, not an organization.

Client-side PKI systems require a means for the individual to securely maintain their private key and to use it to prove their identity with the key when this proof is required. Currently, there are two ways individuals can maintain their private keys:

1. The private key can be stored inside a smart card or another kind of physical token. This is the most secure means for an individual to maintain a private key. The

private key never leaves the smart card. Instead, when the individual needs to sign something, the cryptographic hash is provided to the smart card. Most smart cards also require that the individual have a personal identification number (PIN), which is typically four to eight digits long. The user inserts their smart card into a reader, provides the PIN, and the identity is proven. Most smart cards will lock if the wrong PIN is provided three times in a row.³²

2. The private key can be stored in an encrypted file on the user's computer. To use the private key, the user provides a password to decrypt the key.

There are two reasons smart cards are significantly more secure than storing the private key in an encrypted file. First, the private key does not leave the smart card under normal circumstances. This makes the key more resistant to malware since malware cannot directly access the key and copy it to another system. Second, the user normally removes their smart card from the reader when the smart card is not in use. This significantly reduces the chances of the key being used without the user's knowledge.

Currently, there are four common uses for client-side PKI:

1. Using a web browser, users can provide their identity to a remote website. Here PKI is a useful alternative to a system of usernames and passwords.
2. With client-side PKI, a user can add a signed name to a digital document. Adobe Acrobat provides this functionality.
3. Client-side PKI can also be used to certify the contents of the digital document. Both Microsoft Word and Adobe Acrobat provide this functionality.
4. Users can digitally sign software, asserting that they are the author and the software has not been modified since it was created. Digital signatures on software are available on Microsoft Windows, MacOS, iOS, and Android. Sometimes the signatures are created on behalf of organizations, rather than individuals, but even these signatures are created with client-side PKI.

3.5.3 Certificate Revocation

Private keys are valuable, and they can be stolen, which allows the thief to impersonate the certificate's owner. Private keys can also be lost or destroyed, which would prevent the owner from decrypting messages that are sent. To address these two possibilities, workable PKI systems include a feature called "certificate revocation" that allows the certificate's owner or issuer to indicate that a certificate should no longer be used or trusted.

There are three approaches for certificate revocation:

1. When a certificate is issued, the certificate's owner can also obtain a "revocation certificate." This revocation certificate can then be kept in a secure place and published if the private key is compromised.
2. Alternatively, most CAs operate a "certificate revocation list" (CRL), which is a list of all the certificates they have issued that have subsequently been revoked. These lists can become quite large, as certificates that have been revoked remain on the CRL until they expire.
3. Finally, most CAs operate an online certificate revocation service. Most of these services are based on the "Online Certificate Status Protocol" (OCSP) standard.

While it is possible to revoke individual certificates, it is not possible to revoke a CA. For example, in July 2011, the CA DigiNotar, a Dutch CA owned by VASCO Data Security International, apparently issued a certificate for the domain name google.com. The problem was DigiNotar didn't issue the certificate to Google—it appears it was issued by the government of Iran, which allegedly used the certificate to spy on Iranian citizens accessing Gmail and Google docs.³³ After this was discovered, vendors such as Apple and Microsoft had to distribute patches for web browsers and operating systems to remove the DigiNotar CA certificates from their systems.

3.5.4 Time

Because certificates have validity periods, it is necessary for computers that use PKI to know the current time. And they must know it securely. If a computer can be forced to have the wrong time, then it can be convinced a certificate is valid when it has, in fact, already expired. Time is also used by computers to determine if updates can be applied, and for a whole host of other functions. As a result, it is necessary for modern computers to know the correct time.

There are many ways for computers to reliably learn the correct time, including:

- using the internet network time protocol (NTP);
- using a global positioning system (GPS) receiver;
- learning the time from a cellular network;
- using Windows Time Service.

Currently, none of these protocols use cryptography to assure the time provided is correct. Fortunately, attacks on network time are rare.

3.5.5 Public Key Infrastructure Limitations and Extended Valuation Certificates

The PKI system works well, but it is far from perfect. In fact, today's PKI system is increasingly frayed. Worse, the more it is used, the more problems are exposed.

Thawte is a widely trusted CA, but it is hardly the only one. Modern web browsers have more than 100 CAs built into their browsers, including well-known companies like AOL Time Warner and Wells Fargo, the national CAs for Belgium and China, and companies with suspicious-sounding names, such as “AAA Certificate Services” used by commercial CA Comodo.

The current system of multiple CAs was designed to allow different countries to have their own CAs, but also to enable competition in the free market. The problem is that there is no practical means for users to distinguish between high-quality CAs and bargain basement ones. As a result, all CAs are equally trusted. This can create problems, as different CAs have different procedures and different security standards. Organizations can publish “Certification Authority Authorization” (CAA) records with their DNS to inform web browsers to only trust certificates from a specific authority. CAA is specified in RFC 6844 and implemented by some web browsers.

3.6 Cryptographic Systems: Putting It All Together

In this chapter, we have separately introduced symmetric cryptography, cryptographic hash functions, and asymmetric cryptography, discussing the applications and limitations of each. However, most cryptographic systems combine all these kinds of algorithms. Such systems are sometimes called “hybrid systems.”

In this section, we discuss three such kinds of systems that are used to secure data sent over the web, email, and digital documents.

3.6.1 Securing the World Wide Web with Transport Layer Security

TLS is a protocol used to encrypt data as it is sent over the internet. The most common use of TLS is to encrypt web pages. When a web browser attempts to access a web page that begins with the letters “https,” the browser attempts to download the page using TLS encryption. Asymmetric cryptography is used to encrypt and send a randomly generated symmetric key that, in turn, is used to encrypt the contents of the internet connection and to sign a separate, randomly generated number to establish the authenticity of the website and optionally the client. As mentioned in the introduction, TLS was originally called the SSL and is still occasionally called SSL or SSL/TLS.

TLS encryption performs several important purposes. The technology prevents an adversary that can monitor the internet between the web browser and the server from learning the content of the data exchanged between the two endpoints. This protects the content of web mail messages viewed over the web, for example. However, it does not prevent the adversary from learning *which* website the user is viewing. The technology also prevents an adversary from modifying the content as it passes over the Internet. This prevents an adversary from adding malware to a web page while it is in transit.

TLS can only encrypt data sent over the TLS connection. Because web pages consist of many parts that can be loaded over multiple connections from multiple servers, it is possible for some parts of the web page to be sent over TLS and other parts to be sent without encryption. All that is required is for some of the web page's embedded content to be downloaded from a URL that begins with *http://* instead of *https://*. Modern web browsers will warn when this is happening. Unfortunately, users typically have no recourse when this happens other than to not access the website.

One way system administrators can improve the security of their websites is to configure the site's web server to send the HTTP Strict Transport Security (HSTS) header "Strict-Transport-Security: max-age=31536000" as one of the HTTP headers sent with every web page. This header instructs the web browser to communicate with the web server *exclusively* over TLS for the following 31,536,000 seconds, or 365 days.

In August 2018, the Internet Engineering Task Force (IETF) released version TLS version 1.3, the most significant update to the protocol since its adoption in 1999. TLS 1.3 improved security and performance, while simultaneously reducing the number of configuration options for system administrators. It did this by reducing the number of allowable combinations of encryption algorithms, called "cipher suites," from 37 to 5, eliminating algorithms such as RC4, 3DES, MD5, and SHA1 that had exploitable attacks. This update shows the importance of keeping security software up to date.

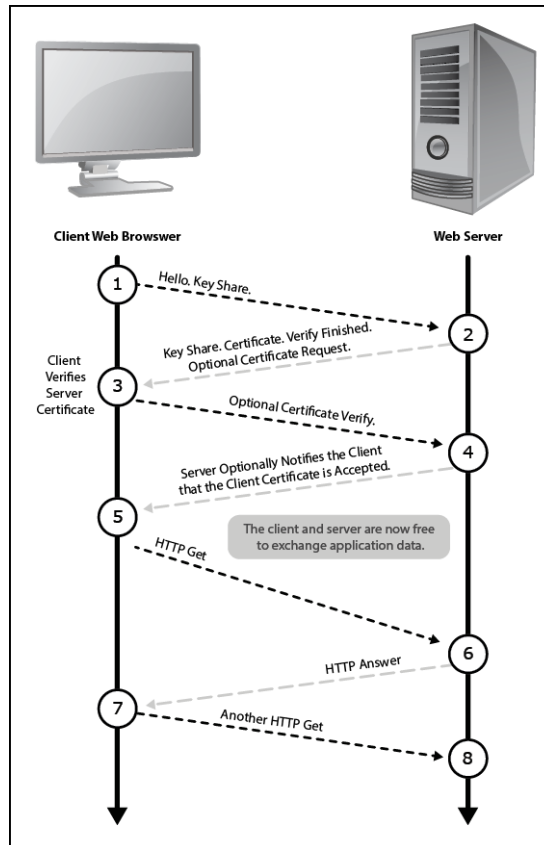
TLS1.3 also removed the RSA-based key exchange, replacing it with a new key agreement protocol that supports "forward secrecy." Forward Secrecy is a property of cryptographic systems that ensures data encrypted in the past remains secure if a long-term secret is compromised at some point in the future. In the case of TLS1.2, losing control of a server's private key meant any message previously sent to the server could potentially be decrypted. With TLS1.3, the server's private key is only used to certify the per-session encryption key that is agreed upon using one of two variants of the Diffie-Hellman key agreement protocol.

When a user types the URL *https://www.company.com/* into a web browser, the following typically happens:

- The web browser issues a DNS request to convert the name *www.company.com* into an IP address that is not shown.
- The web browser opens a TLS connection to the web server at the specified IP address. See step one of Figure 3-6.
- The web browser and server use either the Diffie-Hellman key exchange (DHE) or the elliptic curve Diffie-Hellman key exchange (ECDHE) to agree upon an encryption key that will secure the remainder of the communications, called the "session key." See step two of Figure 3-6.

- The server optionally sends the client a CertificateRequest message, asking for the client to prove its identity with a client-side certificate. See step three of Figure 3-6.
- If requested, the client sends a CertificateVerify message to the server, signed with the client's private key, using PKI to prove its authenticity. See step four of Figure 3-6.
- The server and client are now free to exchange application data. See steps five to eight of Figure 3-6.

Figure 3-6: Client-server TLS1.3 communications



The security of this scheme depends upon many assumptions:

- The Diffie-Hellman key must be negotiated between the web server and the web browser.
- Both the web server and the client must have access to a source of unpredictable random numbers for the initial Diffie-Hellman key exchange and to send the secure authentication messages. Modern computers have random number generation built into their microprocessors. Nevertheless, if an attacker can somehow control the random numbers used as inputs to the encryption operations, then the interaction will have the appearance of security but the attacker will nevertheless be able to decrypt the data.

- More broadly, if the attacker can modify the web server or browser, or gain access to the operating system or the hardware on which either program is running, then the attacker can either set or steal the session key. With the session key, the attacker can then decrypt the encrypted TLS stream.

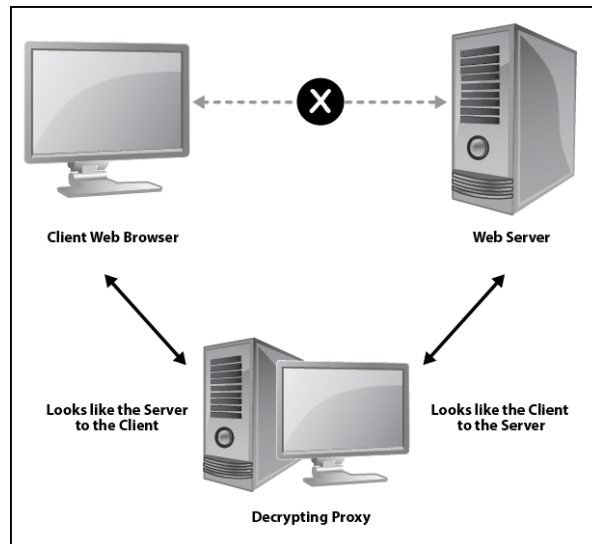
Sometimes a web browser does not connect directly to the web server but instead connects to a TLS decrypting proxy. The browser creates a secure connection to the proxy, which then creates a secure connection to the remote website. This configuration allows the proxy to view the unencrypted contents of the connection. Today we call this configuration a “machine-in-the-middle” (MiTM) or a “proxy” attack. However, this sort of configuration can also be used for legitimate purposes, such as an organization that is required by law or policy to monitor the communication of its employees with the rest of the internet.

Here is one way a TLS decrypting proxy can eavesdrop on TLS communications. The changes specific to the decrypting proxy are presented in **bold**:

- The web browser issues a DNS request to convert the name `www.company.com` into an IP address, **but instead gets the IP address for the attacker’s TLS proxy server.**
- The web browser opens a TLS connection **to the attacker’s TLS proxy server.**
- The web browser connects to the attacker's proxy server and sets up an encrypted session. The proxy server connects to the browser’s original intended destination, **`www.company.com`**, and sets up a second encrypted session.
- The server sends a message to the **proxy server** signed with its server’s private key, proving its authenticity. **The proxy server sends a message to the client and signs it with a fake certificate claiming to be `www.company.com`, falsely attesting its authenticity to the client.**
- The client optionally sends a message to the proxy server, signed with the client’s private key, proving its authenticity. The proxy server optionally sends a message to the legitimate server, signed with a fake client certificate, falsely claiming to be the client.
- The server and the proxy server are now free to exchange application data. Everything that the proxy server receives from the server it decrypts, and then reencrypts and sends to the client. Likewise, the proxy server decrypts all messages from the client, and then reencrypts them and sends them to the server.
- To make a decrypting proxy server work, the client must trust the CA key the proxy server uses to sign its fraudulent certificate for `www.company.com`. If the server uses PKI to verify the identity of the client, then the server must trust the

CA key the proxy server uses to sign its fake client certificate. This is shown graphically in Figure 3-7.

Figure 3-7: A decrypting TLS proxy



Decrypting TLS proxies are controversial. They are widely deployed by organizations that wish to monitor their users' access of the internet, and are also used by authoritarian governments to monitor the web use of their citizens. Proxies can be detected by web browsers because the certificate they receive is that of the proxy, not of the remote web server. To help address this potential vulnerability, web browsers and apps that use TLS to communicate with servers can implement "certificate pinning" that alerts users or even stops operation if a remote website's public key changes in ways that are not consistent with a preestablished policy.

TLS is a complex protocol that is the result of many years of engineering, analysis, experience, and revision. Although the initial version of the protocol was thought to be secure, additional analysis found important flaws that were later corrected. This is yet another example of why it is better for most organizations to use existing encryption protocols rather than attempt to create their own. When organizations use an existing protocol, they benefit from the work that others have performed in the past and will continue to perform after the organization adopts the protocol. When flaws are discovered in the future, the organization again benefits from the use of standards, because the software will be patched and the organization can adopt the patches. On the other hand, organizations that design and implement their own protocols must continue to look for flaws in their implementations and patch those flaws as they are discovered. Otherwise, their systems will become less secure with the passage of time.

3.6.2 Email Encryption with Secure/Multipurpose Internet Mail Extensions and Pretty Good Privacy

Modern email systems are tremendously complex. Email messages can be created in web browsers and processed by webmail systems like Google's Gmail and Microsoft's Office 365. Alternatively, messages may be created using client programs like Apple Mail or Microsoft Outlook. Messages may remain on the computer where they are composed or be sent from one mail server to another, potentially circling the planet as they are forwarded from one email address to another. Mail messages can be sent to mailing lists, which can result in sending a single message to dozens or thousands of individuals. Messages can be delivered to web pages and can be read by programs and interpreted as commands.

In the early days of the internet, email was sent without any encryption at all. This meant anyone monitoring a network link could surreptitiously eavesdrop on messages and exploit their content. In the early 2000s many mail systems implemented the STARTTLS command, allowing messages sent between mail servers to be encrypted using TLS. However, TLS only encrypted the messages while they were in *transit*. Once they were delivered at the other end, they were decrypted.

Secure/Multipurpose internet Mail Extensions (S/MIME) and Pretty Good Privacy (PGP) are encryption standards that apply to stored messages. The standards use public key cryptography to encrypt each message for a specific set of recipients when the message is created. After that point, only recipients who have the matching private key can decrypt the message. S/MIME and PGP also provide for digital signatures, so the recipient of the message can validate the message sender or at least validate that the message was signed by a specific digital certificate.

Both S/MIME and PGP require users to create public keys for themselves and obtain the public key or digital certificate of anyone with whom they wish to exchange mail. This has proven to be one of the biggest barriers to adoption.

S/MIME has been an internet standard since 1999 and is fully supported by Microsoft Outlook, Apple Mail (on both the desktop and iPhone), and Mozilla's Thunderbird mail client. Nevertheless, S/MIME is rarely used outside a few select organizations because of the difficulty users face in creating their digital certificates. Organizations that have successfully deployed S/MIME to their users typically make each users' public key for them. For example, the U.S. government provides every employee with an S/MIME certificate on the PIV card used by civilian employees and the CAC used by employees of the U.S. Department of Defense (DOD).

PGP is an alternative system for encrypting email. Unlike S/MIME, PGP uses an alternative model for PKI called the Web of Trust. Instead of relying on CAs to certify an individual's public key, individuals create their own PGP public keys and then either publish those keys on a web page or upload the key to the PGP key server. Because anyone can upload any public key to the key server, PGP allows individuals to sign each other's public keys. This allows, for example, the human resources department of an organization to create its own PGP key and then use it to sign the public keys of the organization's employees.

Alternatively, managers in the organization can sign the keys of their own employees as well as the keys of other managers and then instruct their employees to trust the signatures of the other managers. PGP's bottom-up approach to trust made it easier for the technology to take hold in highly technical communities, but the lack of tools for distributing keys to large numbers of people at the same time has limited its scalability. While millions of people use S/MIME daily, PGP is still largely restricted to small groups of technologists, although the protocol has also been used by some civil liberties activists throughout the world.

3.7 Other Cryptographic Applications and Concepts

This section briefly discusses other cryptographic systems and applications that privacy professionals might encounter.

3.7.1 Universal Serial Bus Security Tokens

USB security tokens, also called USB security keys, are typically small devices that plug into a USB or connect to a cell phone using either the Bluetooth or near field communication (NFC) standard. These devices typically implement the Fast Identity Online (FIDO) 2.0 standard.

USB security tokens are significantly different from PKI-based smart cards. PKI systems use a certificate authority to certify that a public key belongs to a specific individual. Thus, PKI-systems allow multiple websites to tie together different interactions from the same person over the course of time. This is important for an organization like the U.S. DOD that may operate hundreds of different websites but requires that all have the same assurance that a specific user is who that user claims to be. PKI smart cards are designed to be primary identifiers and authenticators.

USB security tokens, in contrast, are designed to be second, after a username/password combination, that helps establish that a person accessing a website today is the same person who previously accessed the website. That is, they establish continuity of identity, rather than absolute identity. These systems are specifically designed so the tokens cannot be used to track an individual across multiple websites.

Please note, however, the USB token form-factor has a lot of flexibility, and vendors are free to add additional functionality to these tokens, including PKI-based identification. This is why it is important to review the manufacturer's specifications for the specific device being used or considered, rather than relying on generalized assurances or journalistic accounts of the hardware capabilities.

3.7.2 Digital Rights Management

Digital rights management (DRM) systems are another cryptography application that have been widely deployed. Documents, movies, and other kinds of digital media are distributed in encrypted form. These systems then use public key technology to identify computers

belonging to specific individuals. If an individual is authorized to access the content, the individual's computer is provided with an appropriate decryption key.

Some organizations use DRM systems to control access to documents, so documents sent by email from one person to another cannot be accessed unless the recipient is authorized. Such systems typically require the recipient to connect to the internet so they can access the content. Access can be granted for a period of time, after which the individual needs to reconnect to the authorization server to retain or regain access.

Some DRM systems perform the decryption in hardware—for example, in a graphics coprocessor—so the decrypted content can be viewed on a screen or played through a speaker but is less susceptible to being captured in decrypted form and used for other, unauthorized purposes. However, it is usually possible to use a cell phone or digital camera to record the computer's screen during playback. This is sometimes called the “analog hole.” Defeating this hole has been a topic of research and innovation, especially to address surreptitious recording and subsequent pirating of motion pictures shown in theaters.

Many DRM systems use cryptographic erasure to block access to a document after a time period has expired. The software does this by automatically wiping the decryption key at a predetermined time.

3.7.3 Database Encryption

Encryption can be applied to individual rows or cells of data in a database. Such database encryption adds a further layer of security for the data and can further limit opportunities for unauthorized access.

Some modern database systems directly support database encryption. For example, the database engine built into Apple's iOS operating system integrates with the phone's hardware encryption and access control system to implement record-level encryption. Encryption provided within the database can be quite sophisticated, allowing for multiple tiers of authorized access, key recovery and administrator access approaches, and addressing the encryption of the database index's policy issues. If the index is encrypted, then the database may not be able to respond to certain search queries.

“Format preserving encryption” (FPE) is an approach for encrypting data so that the encrypted values have the same format as the plaintext values. FPE makes it possible to add encryption to legacy systems that restrict what kinds of data can be stored in what kinds of database fields. For example, many database applications may store credit card numbers in a 16-character field and may further restrict that field so it can only store numbers. With traditional encryption, encrypting a 16-character number would result in a 16-byte binary object in which each byte might have any value of 256 possible values, of which only 95 are printable. With FPE, the encrypted 16-digit credit card number is also 16-decimal characters. Properly implemented, there is no loss of security using FPE, although some FPE systems have been shown to be not secure.

“Order preserving encryption” (OPE) is an approach for encrypting data such that sort order is preserved. OPE inherently leaks information about the encrypted data, although this leakage may be considered acceptable in some circumstances.

“Oblivious Random-Access Memory” (Oblivious RAM, ORAM) describes a system in which monitoring read-and-write operations between the user and the database reveals no side channel information. ORAM operates by encrypting the data written with a key only accessible to the user. This prevents an observer, or the memory system itself, from decoding the stored data. To prevent an observer from learning about the access patterns, ORAM systems typically perform additional read-and-write operations to different parts of memory whenever any information is read or written. Perfect security is obtained by reading and writing *every bit* of the remote memory system for every read or write operation. However, this is highly inefficient and is not done in practice. Instead, work has focused on building systems that trade off increased efficiency by providing less than perfect security. These systems use the word “memory” to describe the part of the ORAM system that stores information. Mathematically, there is no difference between a memory bank and a database.

Using additional layers of encryption combined with sophisticated data access protocols, it is possible to mathematically protect these patterns so an observer monitoring access patterns learns nothing, even if the observer can observe every read-and-write operation between the user and the database. Because this information is protected from any observer, it is protected from the database as well. This makes it possible for organizations to use cloud providers without fear of leaking sensitive information.

“Private information retrieval” (PIR) describes a range of protocols in which data can be retrieved from a database without revealing the information retrieved to the database or another observer the information. PIR systems are a subset of ORAM systems that provide for data access but not necessarily for data modification. Some PIR systems allow for the database to perform sophisticated operations, such as searching for documents that match a particular keyword or retrieving encrypted documents in sorted order, all without knowing the underlying data that is being operated upon.

“Homomorphic encryption” refers to a set of cryptographic techniques that allow computers to perform computations on encrypted data without revealing the contents of the data. For example, with homomorphic encryption it is possible to send a query designed to uncover a money laundering scheme to a bank's computer. The bank's computers could run the query, perhaps computing the results of a statistical model, and then send the results back to the auditors, without ever revealing the query, its results, or the conclusion of the statistical model to the bank. This example is well within the current state of the art for homomorphic encryption systems.

In the future, homomorphic encryption may allow a cell phone to encrypt a photo and send it to a cloud computing service, which would sharpen the photo, apply advanced artificial intelligence (AI) algorithms to identify the individuals, and determine where the

photo was sent. Then it would send the results back to the cell phone, where they would be decrypted and shown to the camera's owner. Despite providing significant computation and data enhancement, the owners of the cloud service would be mathematically prevented from determining the contents of the photo or knowing the database records that had been accessed. Although the homomorphic encryption scenario described in this paragraph is beyond the current state of the art, at the current rate of development it is likely to be a realistic scenario before the year 2030.

Finally, “blockchains” such as the data structure used by the Bitcoin and Ethereum cryptocurrencies are special kinds of data structures in which each transaction is digitally signed and contains a cryptographic hash of the previous transaction plus some additional information. The data structures are validated by some sort of additional information, such as the solution to a cryptographic puzzle. The blockchain transactions themselves can contain additional information, such as programs to run or instructions to transfer value or other information from one account to another, or “ownership” of a digital object from one identity to another, as in the case with some kinds of NFTs. The information on blockchains can be public, in the case of Bitcoin, but can be protected by additional layers of encryption.

3.8 Summary

As this chapter has shown, encryption and digital signatures are two of the fundamental technologies for assuring privacy and providing security in the digital domain. They are not all-powerful—any technology running on a computer system can be circumvented. But unlike passwords and other technologies, encryption and digital signatures offer the promise of mathematically sound security. For this reason, encryption and digital signatures are likely to play an increasingly important role in preserving privacy and assuring accountability in the digital world.

Endnotes

- 1 Kevin Lee, Benjamin Kaiser, Jonathan Mayer, and Arvind Narayanan, “An Empirical Study of Wireless Carrier Authentication for SIM Swaps,” *USENIX Symposium on Usable Privacy and Security (SOUPS) 2020, August 9–11, 2020, Virtual Conference*.
- 2 Andrei Lapets, Nikolaj Volgushev, Azer Bestavros, Frederick Jansen, and Mayank Varia, “Secure Multi-Party Computation for Analytics Deployed as a Lightweight Web Application,” *Computer Science Department, Boston University, July 25, 2016*, <https://open.bu.edu/handle/2144/21786>.
- 3 *New Oxford American Dictionary* Third Edition, (Oxford University Press, 2010).
- 4 Alex Hudson, “The Secret Code of Diaries,” *BBC Today, August 29, 2008*, http://news.bbc.co.uk/today/hi/today/newsid_7586000/7586683.stm.
- 5 Euan Ward, “Lost Letters by Mary, Queen of Scots, Uncovered by Amateur Code Breakers,” *The New York Times*, February 8, 2023, <https://www.nytimes.com/2023/02/08/world/europe/mary-queen-of-scots-letters.html>.
- 6 A Vernam cipher is a special kind of cipher that cannot be decrypted by any amount of computer power, meaning it has an infinite work factor. The cipher, also known as a “one-time pad,” is not used in practice because the pad requires every message to be encrypted with a different encryption key, and each encryption key needs to be as long as the message being secured. If the encryption key is used twice, the Vernam cipher is no longer secure.

- 7 Andrew Lycett, “Breaking Germany’s Enigma Code,” *BBC History*, February 17, 2011, http://www.bbc.co.uk/history/worldwars/wwtwo/enigma_01.shtml.
- 8 The word “durability” is also used to describe the permanence of data stored for a long period of time. Data stored in off-site facilities may have poor availability but high durability.
- 9 Adam Shostack, *Threat Modeling: Designing for Security*, (Indianapolis, Indiana: Wiley, 2014).
- 10 Whitfield Diffie and Martin Hellman, “New Directions in Cryptography,” *IEEE Transactions on Information Theory* 22, no. 6, (November 1976): 644–654, <https://ieeexplore.ieee.org/document/1055638>.
- 11 Although the popular RSA encryption algorithm (invented by Ronald Rivest, Adi Shamir, and Len Adleman in 1977) has the property that public keys and private keys are symmetric—meaning either key can decrypt information that is encrypted with the other—this property is solely a result of the mathematics employed by the RSA algorithm and is not a property of public key cryptographic systems in general.
- 12 Simson Garfinkel and Heather Lipford, “Usable Security: History, Themes, and Challenges,” *Synthesis Lectures on Information Security, Privacy and Trust*, (Morgan & Claypool, 2014).
- 13 Modern password systems don’t actually store the user’s password. Instead, they process the password with a one-way function. The password provided by the user is processed by the same one-way function. If the two processed passwords match, then they must have been the same. More discussion about password hashing can be found in the classic paper by Robert Morris and Ken Thompson, “Password Security: A Case History,” *Communications of the ACM* 22, no. 11 (November 1979): 594–597.
- 14 Tim Dierks and Christopher Allen, “RFC 2246: The TLS Protocol Version 1.0,” January 1999.
- 15 These programs also use encryption when a file is saved with a “password to print” or “password to edit.” However, in these cases the decryption password is stored in the document itself. The restrictions against printing or editing provided by these programs are implemented in code, not with cryptography.
- 16 A. Einstein; B. Podolsky, and N. Rosen, “Can Quantum-Mechanical Description of Physical Reality be Considered Complete?” *Physical Review* 47, no. 10 (May 1935): 777–780, <https://doi.org/10.1103/PhysRev.47.777>.
- 17 Gorjan Alagic et al., *Status Report on the Third Round of the NIST Post-Quantum Cryptography Standardization Process*, National Institute of Standards and Technology (NIST), July 5, 2022, <https://www.nist.gov/publications/status-report-third-round-nist-post-quantum-cryptography-standardization-process>.
- 18 When attempting to break an encryption algorithm, it is common for cryptographers to first attempt their attacks against “weakened” versions of the algorithm that use fewer rounds. Variants of AES-128 with nine rounds and AES-256 with twelve rounds have been shown to be susceptible to attack. See Alex Biryukov, Orr Dunkelman, Nathan Keller, Dmitry Khovratovich, and Adi Shamir, “Key Recovery Attacks of Practical Complexity on AES Variants with up to 10 rounds,” *Cryptology ePrint Archive: Paper 2009/374*, July 29, 2009, <https://eprint.iacr.org/2009/374>.
- 19 Chris Hoofnagle, Simson Garfinkel, *Law and Policy for the Quantum Age*, (New York, NY: Cambridge University Press, 2022).
- 20 National Security Agency/Central Security Service, *Data at Rest Capability Package*, version 4.0, January 2018. <https://www.nsa.gov/portals/75/documents/resources/everyone/csfc/capability-packages/dar-cp.pdf>; National Security Agency/Central Security Service, *Multi-Site Connectivity Capability Package* version 1.1, June 26, 2018. https://www.nsa.gov/portals/75/documents/resources/everyone/csfc/capability-packages/MSCCPv1.1_20180626.pdf.
- 21 “Lightweight Cryptography Standardization Process: NIST Selects Ascon,” National Institute of Standards and Technology (NIST), February 7, 2023, <https://csrc.nist.gov/News/2023/lightweight-cryptography-nist-selects-ascon>.
- 22 Eli Biham and Adi Shamir, “Differential Cryptanalysis of Snefru, Khafre, REDOC-II, LOKI and Lucifer,” *CRYPTO* 1991:156–171.
- 23 Don Coppersmith, “The Data Encryption Standard (DES) and its Strength Against Attacks,” *IBM Journal of Research and Development* 38 no. 3 (May 1994): 243–250.
- 24 Miles E. Smid, “Development of the Advanced Encryption Standard,” *Journal of Research of the National Institute of Standards and Technology* 126, no. 126024 (2021), <https://doi.org/10.6028/jres.126.024>.
- 25 “Block Mode Ciphers,” National Institute of Standards and Technology (NIST), updated February 13, 2024, <http://csrc.nist.gov/groups/ST/toolkit/BCM/index.html>.
- 26 D. Eastlake, S. Crocker, and J. Schiller, “Randomness Recommendations for Security,” *Networking Group, Request for Comments*, December 1994.

- 27 Ralph Charles Merkle, "Secrecy, Authentication, and Public Key Systems," Department of Electrical Engineering, Stanford University, June 1979.
- 28 "Password Storage Cheat Sheet," Open Web Application Security Project (OWASP), accessed February 9, 2023.
https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html.
- 29 Many people think public keys are invariably used for encryption and private keys are used for decryption, but this is not necessarily the case. Further complicating matters, the most widely used public key algorithm (RSA) has the property that either key can be used for either encryption or decryption—a message encrypted with one key can be decrypted with the other—but this is not necessarily true of other public key algorithms. Further confusing the situation, email encryption schemes typically use the recipient's public key to encrypt the message, which the receiver decrypts with its private key, but the sender's private key to sign a message, which the receiver verifies with the sender's public key.
- 30 Diffie and Hellman, "New Directions in Cryptography."
- 31 Google and the Google logo are registered trademarks of Google Inc.
- 32 Although three times in a row is standard for smart cards, usability is dramatically increased when this number is increased to five or even ten, and increasing the limit does not significantly impact security. See Sacha Brostoff and M. Angela Sasse, "Ten strikes and you're out: Increasing the number of login attempts can improve password usability," *Proceedings of the CHI 2003 Workshop on HCI and Security Systems*, (2003).
- 33 "DigiNotar Hacked by Black.Spook and Iranian Hackers," *F-Secure Labs, News from the Lab* (blog), August 30, 2011, <http://www.f-secure.com/weblog/archives/00002228.html>.

CHAPTER 4

Identity and Anonymity

Chris Clifton

Information technology (IT) poses new challenges and new opportunities for managing identity and the resulting impact on privacy. These are nicely summed up in the now-famous cartoon that appeared in the *The New Yorker* magazine in 1993, with the caption “On the Internet, nobody knows you’re a dog.”¹ IT enables us to remain anonymous—conducting transactions without revealing who, or what, we are. But it also poses challenges—we may (wrongly) assume we know who, or what, someone is.

Furthermore, advances in IT make it easier to defeat anonymization measures. Perhaps nobody knows we're a dog, but based on purchases of dog food, visits to veterinary medicine websites, and so on, someone with access to all this information can make a pretty good guess. This poses real risks to personal privacy and the desire to remain anonymous during the course of everyday activities.

This chapter starts by categorizing types of digital identity, describing the different types of identity, how they can be used, and how they are typically represented in information systems. This is followed by authentication, giving an understanding of methods of validating the identities and the strengths and weaknesses of each. We then look at privacy issues that arise with digital identity, particularly how the types of identity map to privacy law and regulation. Finally, we discuss anonymization techniques and challenges, including the basic principles and techniques available to deidentify data and the challenges in adequately anonymizing data with respect to privacy legislation.

4.1 What Is Identity?

Information systems do not contain people, only data about people. So, when we refer to identity, we really mean the link between a piece of information and the individual, or individuals, associated with that data. For example, a data item can be about an individual, created by an individual, or sent to an individual. Identity captures what we know about who the individual is.

The clearest case of identity is when we know exactly who the individual is and can link the data to a single person. This gives us an “identified individual”—the strongest form of identity.

A weaker form of identity is a “pseudonym.” With a pseudonym, we can link different data items about the same individual, but we do not know the actual person the data is about. The ability to create and use pseudonyms is a big privacy advantage of digital identity since we can detach online presence from the actual person. However, this kind of privacy can be illusory, as it is often possible to identify the actual person behind the pseudonym. This will be discussed in section 4.4.1.

The weakest form of identity is “anonymity.” With truly anonymous data, we do not know the individual the data is about and cannot even tell if two data items are about the same individual.

While these concepts are intuitive, problems often arise because of subtle differences in people's understanding. It is often important to formally define these terms so we can clearly state how systems are, or should be, using identity. For example, we could formally distinguish identified individual, pseudonym, and anonymous as follows. Assume we have a set of data items $D=\{d_1, \dots, d_n\}$, and an identity function $I(d)$ that gives us information on whom the data item d is about. If we can say, for a known individual, i , $I(d)=i$, then $I(d)$ is an identified individual. If we can say $I(d_j)=I(d_k)$, the two data items are about the same

individual, but not if $I(d)=i$ because then $I(d_k)$ is a pseudonym. If we cannot make either statement, identified individual or pseudonym, then the data is anonymous.

A related concept is that of a “role.” Often, it is not important who an individual is, only that the person is authorized to perform an action. For example, a credit card account may have several authorized users, and the merchant only needs to know that one of the authorized users is making a purchase (a role), not which one (an identity). While this can be hard to do in person, electronic systems have capabilities that allow us to quickly distinguish between the role and the identity.

Another issue that arises is who can make the determination of identity. Say Alice sent an email to Bob. We normally think of the email as being identified if Bob knows it came from Alice, and he knows the actual person corresponding to the name Alice. However, an alternative exists when Bob does not know who Alice actually is, but the real Alice is able to prove she wrote the message. This provides pseudonymity and privacy for Alice, and the option of revealing identity resides with the individual to whom the identity belongs. Keyed hash functions, which are discussed in chapter 3, provide an easy way to accomplish this. A third alternative is when an independent third party is able to validate that the message came from Alice.

4.1.1 How Is Identity Used?

There are a variety of reasons why an information system may need to know the identity of an individual, or of the individual associated with a piece of data. The most obvious is access control. Should a given individual see a given piece of data? While this seems to be a clear case for having an identified individual, it is often not necessary and, from a privacy point of view, may be inappropriate. For example, access to a subscription-based patent search system needs to be limited to subscribers, but companies may be reluctant to use a system requiring individual identification because they fear revealing corporate intentions and plans. IT provides ways to support identification based on roles without requiring individual identification, which provides the ability to significantly improve privacy.

A second reason for obtaining identity is attribution, or the ability to prove who performed an action or generated a piece of data. For example, in a credit card transaction, the merchant needs to be able to show that a purchase is legitimate. Again, while systems are set up to require an identified individual for this purpose, all that is really needed is a role (an authorized user). Though this distinction may be difficult for face-to-face transactions, IT provides new opportunities to protect identity while ensuring the correctness of information.

Identity is also used in information systems to enhance the user experience—particularly personalization. For example, web searches by an identified individual can be customized based on the individual’s expressed desires or previous history. In this case, all that is needed is a pseudonym. Knowing a set of searches all come from the same individual, including

preferences provided by that individual, is equally effective even if one does not actually know the individual's identity.

4.1.2 Representing Identity

There are a variety of ways to represent identity, each with advantages and drawbacks. The most basic means is to rely on external, easy-to-remember identifiers, such as an individual's name. Unfortunately, names are rarely unique, leading to the possibility of misidentification. This is why hospitals and health insurance companies typically require name and date of birth, and online credit card transactions ask for name and address. The combination of multiple factors is often unique, or the nonunique cases are rare enough to be addressed after the fact. Such combinations typically result in an identified individual.

A second representation of identity is to allow a user to specify the identifier for a given system, typically referred to as "user IDs" or login names. This gives certain advantages—the system can guarantee uniqueness by forbidding the creation of an already taken ID—and it provides for pseudonymity if the individual is allowed to choose the ID, which is an additional measure of privacy. The disadvantages are that users may want the same user ID—for example, my use of the user ID "clifton" at some websites results in me being locked out due to authentication failures. Other individuals who have the same last name and do not remember their user ID can try the ID "clifton" and fail to give the correct password. After a number of failures, the system locks out future attempts, blocking the legitimate user from obtaining access. Some systems try to prevent this by requiring user IDs of a certain length, or requiring combinations of numbers and letters. This is a usability trade-off. While such user IDs are hard to remember, they reduce the chance of conflict.

An alternative is a system-generated user ID or unique number. This provides the same opportunity for pseudonymity and, if properly created, can ensure a degree of privacy, for example, by not using people's names as part of the user ID. While user-generated user IDs can provide privacy, a system-generated, unique user ID ensures privacy for all users, even those who do not realize the associated privacy risks of identifiability. To truly provide privacy, system-generated user IDs must not be based on other identifying data. For example, U.S. Social Security numbers, which are unique nine-digit numbers, are generated using location and date information that can help link individuals to their numbers.²

An increasingly popular approach is to use externally created and managed unique identifiers. This has advantages and disadvantages. Externally created identifiers are often a user-friendly option because the user can reuse another identifier, and this approach reduces the number of identifiers a user must remember. Externally created identifiers also outsource the burden of ensuring uniqueness. Finally, these identifiers make it easier to link information across multiple systems. However, linkability also creates a privacy risk. Linking information across multiple systems makes it easier to conduct fraud or other misuse of identity. In the United States, the Social Security number was once widely used as a unique

identifier, but this eased identity theft and fraud, as knowing an individual's Social Security number provided too much access to the individual's information. A better approach is to allow the user to choose the external identifier. Email addresses are a good example. The structure of the internet guarantees email addresses are unique, but it is possible for a user to have multiple email addresses, including addresses that were created without revealing identity, providing the option of pseudonymity for those who desire it.

Identity can also be represented using systems created for that purpose. The X.500 standard provides a flexible framework for storing and maintaining identifying information. Cryptographic certificates and public-key infrastructure, described in chapter 3, also provide mechanisms to verify identity. These systems generally combine representations of identity with other identity-related information such as name and address, and can provide authentication mechanisms as well. Authentication will be discussed in the next section.

Many of these approaches assume some centralized, or federated, management of identity. An alternative is the “self-sovereign identity,” where an individual manages their own identity.³ While the basic idea is not new, as Pretty Good Privacy (PGP) provided a form of self-sovereign identity as early as 1991, advances in cryptography such as zero-knowledge proofs and blockchain have enabled new possibilities for the self-managed identity.⁴ Through the use of cryptographic certificates to establish authorization without necessarily revealing identity and distributed ledgers (blockchain) to record activities, centralized systems accomplish many of its capabilities while allowing individuals to manage their own identity, without storing credentials in a centralized system.

Biometrics can also be used for identity. Ideally, this identifies a specific individual and does so with little effort. However, biometrics should be used with care. For example, a 2017 attempt to use facial recognition to find individuals on a police watch-list from a large crowd resulted in 92% false positives.⁵ Accuracy may be sufficient to distinguish between a small group of known individuals, e.g., users of a specific device, but care must be taken to ensure accuracy is appropriate for the planned use. Using the same biometric for both identification and authentication, shown in section 4.2.4, poses additional risks, as a false positive would give the wrong individual access.

To summarize, identity can come in a variety of manners: identified individual, pseudonymous, or truly anonymous, that provide progressively greater levels of privacy. It may be sufficient to know a role rather than an identity, and it is important to understand what identity is used to ensure an appropriate level of identity is used. Given these concerns, we can choose appropriate mechanisms to represent identity, providing appropriate trade-offs between level of identification, ease of use, and privacy.

4.2 Authentication

Authentication is closely tied to identity. While identity links information to an individual, authentication is used to ensure an individual performing an action matches the expected

identity. Authentication can be accomplished by a variety of mechanisms, each with advantages and drawbacks. These mechanisms fall into four main categories:

1. What you know: Secret knowledge held only by the individual corresponding to the identity.
2. What you have: Authentication requires an object possessed by the individual.
3. Where you are: The location matches the expected location.
4. What you are: Biometric data from the individual.

These mechanisms vary in terms of their ability to be defeated, ease of use, cost, and privacy implications. In addition to the trade-offs in using authentication mechanisms, any decision to use one should consider the challenges of both creating and revoking credentials. For a particular mechanism, establishing or changing the credentials used to authenticate an individual can be much more expensive and prone to misuse than for other mechanisms. For example, a personal identification number (PIN), such as a four-digit number used for a bank card, sent by postal mail can be compromised through theft or by picking through trash where the PIN may have been discarded. Requiring an individual to appear in person to select a PIN protects against these attacks but may result in a PIN that can be guessed by someone who knows the individual because the PIN was not randomized. A recent study of PINs shows many people choose four- and six-digit numbers according to specific patterns that increase their predictability.⁶ Revocation, which is the repealing and reissuing of compromised credentials, poses similar issues. In particular, revoking biometric data is generally impossible, so systems using biometric data for authentication must be constructed using strong cryptographic techniques to ensure such data is never compromised.

Authentication methods typically involve “authentication information” held by the user, “complementation information” held by the server/host, and an “authentication function” that takes a piece of authentication information and a piece of complementation information and determines whether or not they match.

4.2.1 Passwords

One of the most common approaches to authenticating a user is through passwords or PINs. This is an example of “what you know” authentication. It is assumed only the proper individual knows the password. Passwords can provide a high level of assurance that the correct individual is being identified, but when used improperly, they can easily be broken.

Attacks on password-based authentication fall into two categories: attacks on the password itself and attacks performed directly through the system. One approach, which is most useful with short passwords like four-digit PINs, is guessing passwords. This can be prevented by disabling access after too many failed attempts, but it also places a burden on legitimate users

who incorrectly enter the password. Setting an appropriate number of failed authentication attempts should balance the need for correct identification against the cost of resetting a password. If an easy and secure mechanism exists to reset passwords, then locking users out is not a big problem. But if a reset requires, for example, a trip to the bank, the system quickly becomes unusable.

The dictionary attack is an example of password guessing. Given a choice, users tend to choose easy-to-remember passwords—typically normal words. There are other forms of authorization, such as “what you have,” that are harder to obtain using social engineering without exposing the attacker to increased risks of detection.

A simple example of a password attack performed directly through the system is the man-in-the-middle attack, in which a computer program intercepts traffic and reads the password contained in the intercept. To combat this attack, passwords are typically encrypted. Instead of presenting the password (authentication information) to a system, the system uses a one-way hash of the password and stores only the hash (complementary information). As it is extremely difficult to discover the password from the hash, this prevents the man in the middle, or an intruder who has gained access to the system, from obtaining a user’s password.

While the man in the middle may not know the password, he only needs to replay the hash of the password to gain access. This is called a “replay attack.” This kind of attack is easily combated through system design. “Challenge response” authentication issues a unique challenge for each authentication. The response must be correct for each challenge. With a hashed password, the challenge is an encryption key sent by the system. The user application uses the key to encrypt the hash of the password, which is compared with the system’s encryption of the stored value of the hashed password. Each authentication uses a different key, and thus a replay attack fails because the replayed password (response) is not encrypted with the current key (challenge).

The proper design and implementation of password systems are important concerns for information security experts. Because of the risk of stealing an individual’s identity through a weak password system, however, there is a growing need for IT professionals who are responsible for privacy to be engaged in this discussion. In addition to passwords, systems will ask security questions (e.g., regarding the name of your high school or where you were born). These questions are often used as a secondary form of authentication; for example, during a password reset mechanism. To reduce the risk of a stolen identity, these questions must target information that is unlikely to be known by an attacker and is therefore likely to be private information. Consequently, the answers must be protected, such as through a hash mechanism similar to the one used for passwords, to ensure this data is not disclosed.

4.2.2 Devices

The “what you have” approach to authentication typically uses computing devices. Identification badges or smart cards can be used. These require the computing terminal to

have the ability to read the computing device. A convenient approach is to embed a radio frequency identification (RFID) chip in the device, which requires a reader, but the user does not actually have to swipe the card. This technology introduces a privacy risk in that a malicious actor with a remote RFID reader can detect when the user is nearby, even though they are not actually trying to authenticate anything. If the actor can read the RFID card, then they may be able to “become” that individual through a replay attack. More advanced RFID approaches use a challenge-response approach to mitigate these attacks.

Devices that do not require special hardware at the client’s terminal also exist. These are typically in the form of small devices that display a changing PIN. The timing and sequence of PINs are known to the system. The user can type the PIN being displayed by the device just like a password, and the system checks to see if the given PIN matches what the device should be displaying.

Lastly, the computing device may be the computer the person uses to access the system, e.g., a home computer, laptop, or smartphone. The system stores the IP address of the device or uses browser cookies to store a unique key on the machine. This allows the system to check whether the attempt to authenticate comes from a previously used device. Since the user already has the device, this requires no additional hardware. However, since the same technologies are used for tracking users, these device-based approaches may fail to authenticate users if they employ antitracking technology to preserve anonymity.

Device-based authentication becomes problematic when devices are lost or stolen. Until the loss is recognized and reported, access to the system may be compromised. As a result, these systems are typically combined with passwords or some other form of authentication so the lost device alone cannot be used to gain access.

4.2.3 Location

Location-based authentication is typically used in corporate networks. Access to corporate resources is limited to computers physically located in the company. This requires an attacker to gain physical access as well as defeat other authentication methods, such as passwords, making unauthorized access far more difficult. Of course, this also prevents legitimate use from outside the network, requiring the use of virtual private networks (VPNs). A VPN provides an encrypted link to the corporate network, and typically requires a high standard of authentication to make up for the loss of location-based authentication.

Note that location-based authentication can be used in other ways as well. Credit card issuers may reject transactions at unfamiliar locations unless the customer has provided advance notice of travel. While this may seem invasive from a privacy point of view, such location information will likely be made available anyway, for example from the credit card use or the IP address used to connect to the system, so little additional information is disclosed when providing a list of authorized locations, such as a travel itinerary.

While location is useful, it should almost always be viewed as a secondary form of authentication, used to provide stronger evidence that the primary form of authentication is correct.

4.2.4 Biometrics

“What you are” as a form of authentication is growing increasingly popular. Portable devices such as phones, tablets, and laptop computers typically have fingerprint readers, cameras, microphones, and other sensing devices. Fingerprints, face and voice recognition, iris and retinal scans, and other biometric methods for authentication are increasingly available. This brings advantages, but also raises privacy issues.

First, systems using biometric data must protect that data. If a user’s password is compromised, the user can change it—but cannot be asked to change a face or fingerprint. As with passwords, careful system design is needed to ensure attackers cannot obtain or spoof the biometric data. In 2009, Duc Nguyen demonstrated how face recognition software in three different laptop models, manufactured by Asus, Lenovo, and Toshiba, could be tricked into believing a photo of the laptop owner’s face was the physical owner and, thus, be bypassed.² The attack scenarios include obtaining a person’s face from their website, social networking site, or online chat. More advanced approaches include expression or gaze, preventing a static image attack and potentially incorporating a “what you know” type of authentication based on remembering the particular expression used.

Voice authentication has similar issues depending on how it is done. Text-dependent voice authentication, where a user enrolls a specific passphrase, provides the ability to change the authentication information if it is compromised. However, this could be subject to recorded authentication that is used for a spoofing attack. An alternative is text-independent voice authentication, in which a different passphrase is chosen for the user to repeat each time. This is a form of challenge response that prevents replay attacks, but then becomes subject to the problem that the authentication information cannot be changed. Speech-recognition technology, also called voice command, allows users to interact with and control technologies by speaking to them. This can be combined with voice recognition for a hands-free interface incorporating authentication.

Second, use of biometric data raises inherent privacy concerns. While passwords can be associated with a pseudonym, a fingerprint is inherently identifying, and a pseudonymous account using a fingerprint for authentication should probably be considered individually identifiable. There may also be cultural issues. Some users may be reluctant to have a photograph taken or to display their face for use in biometric authentication.

A second type of biometrics is based on behavior—for example, typing rate or patterns of mouse movement. While these give only a degree of assurance, they provide the opportunity for continuous authentication. Once a user authenticates to the system, their behavior with

the system can be used to ensure they have not walked away and has someone else step in to use the account.

4.2.5 Multifactor Authentication

Two-factor authentication is becoming an increasingly common practice. The idea behind multifactor authentication is to require two different mechanisms from two of the previously described categories. A common example is the use of a device, often an individual's cell phone, in addition to a password. Two-factor authentication can be quite transparent. An example is storing a cookie in a web browser after a successful authentication. On future authentications, after checking the identity and password, the server requests a corresponding authentication cookie from the web browser. If the browser has the appropriate digitally signed cookie, it proves the user has previously been logged in from that device, and the device becomes a "what you have" second factor.

One ubiquitous example of two-factor authentication is with apps on cell phones. Most require authentication only on the initial use or after a user explicitly logs out of the app. Otherwise, they assume if the user has the phone, device-based authentication, and is authenticated by whatever mechanism the user chooses, or chooses not, to employ, then the user is authenticated by the app. This leaves the possibility that the user disables authentication, and possession of the phone constitutes authentication to access everything the app allows. A better approach is to require reauthentication for critical actions; for example, direct app use of Apple's FaceID or TouchID.

Good implementation of two-factor authentication can make many types of attacks, such as man-in-the-middle attacks, more difficult. The key is that the two factors should proceed through independent channels, such as a password combined with a one-time temporary security code sent via text message (SMS). While this does not eliminate attacks, an attacker must now compromise two independent systems. Conversely, forms of two-factor authentication that draw both factors from the same category, such as a password and security questions, are much less effective. A targeted attack to use personal information to guess a password will likely acquire the personal information needed to answer the security questions as well.

4.2.6 Authentication Summary

Authentication is the means by which a system knows the identity matches the individual who is actually using the system. There are several approaches to authentication. Often, these can be used in combination, significantly decreasing the risk of a successful attack or attempt at impersonating the user.

Authentication can be separated from the systems requiring authenticity. This is a feature of single-sign-on systems. Authentication is performed by an external identity provider service that provides a time-stamped cryptographic token to the user's system, e.g., web browser. This token can be provided to other systems, which can decide if the source of authentication

(secured using a digital certificate), recency of authentication, and user identified by the token satisfy the access policy without requiring separate authentication. Security Assertion Markup Language (SAML) is a standard for exchanging identity and authentication, making for seamless integration of identity and authentication mechanisms across systems and service providers. Commercial systems, such as Microsoft account, Azure Active Directory, and Google Sign-in, provide external identification and authentication services as well.

Authentication must balance assuring the accuracy of an individual's identity and the usability of the system. While authentication needs to be strong enough to protect personal information, excessive use of technology to perform authentication can reduce the practical effectiveness of the system and create new privacy issues by collecting the sensitive personal information needed to implement complex authentication mechanisms.

4.3 Identity Issues

How are privacy and identity related? The key is privacy laws and regulations typically apply only to individually identifiable data. At first glance, this would suggest pseudonymous or anonymous data is not subject to privacy law. The problem is that “individually identifiable” is a somewhat broader concept than “individually identified.” From an identity point of view, data is individually identified if it specifically tells us which individual the data is about. From a privacy point of view, however, we are also interested in the question of whether or not the data could be linked to a specific individual. The difficulty is in determining if pseudonymous or anonymous data could be linked to the individual the data is actually about. This continues to be a challenging research problem, although there are several areas where legislation and regulation provide good guidelines.

4.3.1 Individually Identifiable Data

Almost all privacy regulations have some definition of the information to which they apply. For example, the EU General Data Protection Regulation (GDPR) applies to personal data, and the U.S. Health Insurance Portability and Accountability Act (HIPAA) applies to protected health information. What do these terms mean? Unfortunately, this is often not entirely clear.

While data that is not about an individual is obviously not covered, and data that is individually identified clearly is, there is a large middle area of data that is not overtly identified but may be identifiable. An obvious case pointed out by Latanya Sweeney is the use of home address and date of birth.⁸ Given a person's postal code, date of birth, and gender, which were contained in state-gathered hospital admission data presumed to be anonymous, she was able to identify numerous individuals by cross-referencing this data with publicly available voter registration data. In fact, she estimates that 87% of U.S. persons could be identified from date of birth, postal code, and gender. As a result, this data is

considered privacy sensitive and not subject to disclosure under U.S. freedom of information rules.

Little guidance has been given about exactly how much information is needed to cross the threshold into individually identifiable data. Is it okay if only 10% can be identified? Early guidance from the European Commission Article 29 Working Party (WP29) formed under Directive 95/46/EC, now carried on under the European Data Protection Board (EDPB), suggests no individuals should be identifiable. However, it is less clear on a related point: what if I am not certain about an individual, but I can identify the person with some degree of confidence? For example, suppose I know a data item is about a doctor in a town containing only two doctors. While WP29 suggested if there is only one doctor in town, the record is individually identifiable, the question of how many doctors are needed to make the data nonidentifiable is not clearly answered.² Furthermore, increased collection and sharing or disclosure of personal data makes reidentification, such as in Sweeny's example, increasingly possible, even using apparently innocuous data. This has resulted in a more specific definition for the GDPR, which defines personal data as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person."¹⁰ This results in almost any data derived from a person being deemed "personal data," even if the tie to specific individuals is unclear. A somewhat surprising example is database reconstruction, discussed in section 4.4.4.

In some cases, the answers are clear. For example, most U.S. data breach notification laws are triggered if a last name, first initial, and account number are disclosed. HIPAA provides a broader statement. It contains a safe harbor provision that specifies data can be considered nonidentifiable after the removal or generalization of 18 specific types of potentially identifying information. For example, dates, such as birth dates, must be no finer grained than a year, and postal codes can include only the first three digits or an area encompassing at least 20,000 people. Furthermore, birth year can only be included for individuals under 85 years old. Using this, we can conclude on average, 67 people could potentially be tied to a record for a male in his early 80s, suggesting a confidence in identification under 1.5% would not be considered individually identifiable. However, statistical analysis also shows a few individuals are expected to be unique, and thus reidentifiable, under these rules. While this guideline is only implied by the rule, it does suggest data can be sufficiently deidentified to prevent triggering this privacy regulation, without providing an absolute guarantee against reidentification.

HIPAA also provides a specific example of pseudonymity. A deidentified dataset may include:

A code or other means of record identification to allow information de-identified under this

section to be re-identified by the covered entity, provided that: (1) the code or other means of record identification is not derived from or related to information about the individual and is not otherwise capable of being translated so as to identify the individual; and (2) the covered entity does not use or disclose the code or other means of record identification for any other purpose, and does not disclose the mechanism for re-identification.¹¹

This is a somewhat convoluted, but precise, legal definition of pseudonymity. The challenge for IT professionals is identifying these various definitions and managing the definitions in a consistent and legally compliant manner across their systems.

4.3.2 Identity through History

Pseudonymous data and anonymous data pose different privacy risks. Given a set of data items about an individual, such as user purchases, it may be possible to identify the individual even if no individual data item can be linked to that person. Pseudonymous data may be identifiable even if the same data made anonymous is not by itself identifiable. Perhaps the most famous example of this is from web search log data made publicly available by AOL. Reporters were able to identify an individual based on a collection of queries, including information such as names and locations.¹² Similar studies found risks with transaction data released under the Netflix challenge.¹³

The need to treat pseudonymous data collections with particular care is recognized in law. The U.S. HIPAA Privacy Rule does not apply to *anonymous* data. However, it makes a special provision for “limited datasets” (LDSs), which are not individually identified. Individual identifiers must be replaced with a number. This gives a pseudonymous dataset. An LDS can be shared under a data use agreement but may not be publicly released.

There has been work on ensuring anonymity in such pseudonymous datasets.¹⁴ However, this is still an open challenge, and extra care must be taken when releasing log files or transaction data. The IT professional may use encryption, see chapter 3, or rely on contractual agreements with the receiving party, see chapter 10, to ensure privacy protections are afforded to potentially reidentifiable data.

4.3.3 Incidental or Unplanned Sources of Identity

There are many nonobvious sources of identifying information. For example, the IP address of a computer making remote Hypertext Transfer Protocol (HTTP) or Hypertext Transfer Protocol Secure (HTTPS) requests is frequently logged. For some network providers, there is evidence that even dynamically assigned IP addresses do not change frequently, thus allowing a client computer to repeatedly be linked to the same IP address for long periods of time. Early implementations of Internet Protocol version 6 (IPv6) used addresses in which a unique 64-bit number derived from a computer’s hardware address was used in every address regardless of which network the computer was on. In 2008 the WP29 suggested IP addresses should be considered personally identifiable information (PII), as many people’s computers

host a website identifying them.¹⁵ Thus, logs that contain IP addresses need to be treated as PII and protected appropriately. The 2013 U.S. Children’s Online Privacy Protection Rule (COPPA) explicitly lists IP addresses as PII.¹⁶ The California Privacy Protection Act of 2018 is somewhat more nuanced, stating IP addresses, and several other types information, are considered PII “if it identifies, relates to, describes, is reasonably capable of being associated with, or could be reasonably linked, directly or indirectly, with a particular consumer or household”.¹⁷

Browser fingerprinting is another example. In an effort to personalize or customize the user experience, websites can track the user with browser cookies or other techniques. Peter Eckersley demonstrates how advanced techniques can uniquely identify most browsers by using data reported to the web server, including the client operating system, browser plug-ins, and system fonts.¹⁸ While tracking can be beneficial to the individual, it also turns anonymous exchanges into pseudonymous exchanges—as seen previously, this can make data individually identifiable. In chapter 6, we discuss surveillance and tracking technology and the associated privacy risks in more detail. Finally, logs can include sensitive information that a user may assume is anonymous, resulting in serious privacy risk. Thus, any comprehensive collection of information must be carefully evaluated for privacy risk, and both the risk and cost of protecting the data must be weighed against the value obtained from collecting the data.

4.4 Anonymization

The least restrictive way to utilize data while ensuring privacy is protected is through anonymization. If data is not individually identifiable, it does not pose a privacy risk. Anonymization techniques attempt to ensure data is not identifiable. This is a challenging problem. For each anonymization technique, there are attacks showing conditions under which data can be reidentified. Though these attacks sometimes make very strong assumptions, it is clear any attempt at anonymizing data faces risks. However, these risks are likely to be much smaller than the risk of misuse of identifiable data, through either insider misuse or external attackers gaining access to data.

4.4.1 Strong versus Weak Identifiers and Individual Identifiability

Some information is clearly identifying—for example, identifying numbers such as a national identification, passport, or credit card number. These are referred to as “strong identifiers.” Names can be strong identifiers, but common names may not be uniquely identifying. This is why names are typically used in combination with other information such as birth date or address to identify individuals. Identifiers that must be used in combination with other information to determine identity are referred to as “weak identifiers.” Relatedly, “quasi identifiers” refer to data that can be combined with external knowledge to link data to an individual.

A related issue is linkable data versus linked data. Can we determine an individual's identity given either a strong identifier or a collection of weak identifiers? Given a bank account number and nothing else, most of us would not be able to determine who the individual is. The link from bank account number to the individual is generally protected. This raises an interesting issue. Is data individually identifiable if it requires substantial background knowledge to link the data to an individual? Laws on this issue are unclear, but state data breach notification laws provide some hints within the United States. Disclosure of a financial account number alone does not trigger these laws even though this is typically a strong identifier. The financial account number and name in combination trigger these laws. Generally, if a quasi identifier can be linked to an individual using publicly available information, it should be considered individually identifiable.

Even if linking data is not public, it is a good idea to consider strong identifiers or a combination of weak identifiers as sufficient to make data identifiable. For example, considering an IP address personally identifiable data clearly applies to an internet service provider (ISP). However, the EDPB notes IP address could be used to identify and geo-locate a social media user, *even* if they do not have an account with the social media provider.¹²

A somewhat murky area is the distinction between identifying a record, which triggers a privacy law, and identifying a sensitive value associated with an individual. While it is unclear whether the latter triggers privacy law, it pretty clearly poses a risk to privacy. This will be discussed further in section 4.4.3 on the role of microdata.

4.4.2 Approaches to Anonymization

Anonymization techniques hide identity in a variety of ways. The simplest approach is “suppression,” removing identifying values from a record. Names and identifying numbers are typically handled through suppression.

Some types of data are amenable to “generalization,” which is performed by replacing a data element with a more general element, for example, by removing the day and month from a birth date or removing a street from a postal address and leaving only the city, state, or province name. Replacing a date of birth with just the year of birth substantially reduces the risk of an individual being identified but still leaves valuable information for data analysis.

A third approach is “noise addition.” By replacing actual data values with other values selected from the same class of data, the risk of identification is lowered. The addition is often aimed at preserving statistical properties of the data, while disrupting future attempts to identify individuals from the data. In many ways, the protection obtained by noise addition is similar to generalization.

Generalization and noise addition not only reduce the risk of identification, they can also reduce the sensitivity of data. For example, birth date is frequently used as a form of “what you know” authentication. Generalizing a birth date to the year prevents this data from being

used to support identity theft. Note, generalized individually identifiable data may still be individually identifiable, and thus probably covered by privacy law. Generalization does reduce the risk of damage should the data be inadvertently disclosed.

4.4.3 Anonymization of Microdata

The most obvious approach to anonymizing data is using what are commonly referred to as micro datasets. A micro dataset contains the original records, but the data values have been suppressed or generalized, or noise has been added to protect privacy. The open question is how much suppression, generalization, or noise is needed for data to no longer be considered individually identifiable.

Government publishers of data about individuals, such as census bureaus, have a long history of studying this problem, and numerous techniques have been developed. In addition to generalizing values to ranges, e.g., birth decade rather than birth year, values are often “top- and bottom-coded,” e.g., reporting all ages over 80 as “>80” as opposed to reporting decades. Rounding can also be used as a form of generalization, e.g., to the nearest integer, or nearest 10. “Controlled rounding” ensures rounding is done in a way that preserves column summations. Where data must be suppressed, “data imputation” can be used to replace the suppressed values with plausible data without risking privacy. Another technique is “value swapping,” which means switching values between records in ways that preserve most statistics but no longer give correct information about individuals. Much of this work is summarized in a 2005 U.S. government report.²⁰

One particularly valuable resource from this community is the “Checklist on Disclosure Potential of Proposed Data Releases.”²¹ While it does not contain hard and fast rules, the checklist provides several guidelines, such as generalizing geographic units to regions containing at least 100,000 individuals and top-coding ages over 85. Furthermore, it provides a comprehensive list of questions that should be considered before releasing data. Though directed toward U.S. government agencies, the procedures and questions are worth considering for any release of microdata.

Perhaps the only clear legal answer to the question of what makes data individually identifiable is contained in the HIPAA safe harbor rules (see section 4.3.1). If these steps have been taken, and there is no other reason to believe the data is identifiable, then the data can be considered deidentified and no longer subject to the HIPAA Privacy Rule.

In addition to regulatory rules and guidelines, formal definitions have been established in computer science. One of the first such definitions was *k*-anonymity.²² The *k*-anonymity requires every record in the micro dataset to be part of a group of at least *k* records with identical quasi-identifying information. To achieve this, records with similar identifying information are formed into groups of at least *k* in size, and the identifying information is generalized or suppressed so all the records have identical quasi identifiers. This ensures no record can be individually identified. Given identifying information for an individual, there

are at least k records that are equally likely to belong to the individual. Note we are assuming there is only one record for each individual, and extending to cases where there are multiple records about an individual is straightforward.

The k -anonymity does not provide an absolute guarantee of privacy protection. For example, suppose we have a micro dataset listing occupation. If we assume occupation is not publicly known, but age and address are, then age and address are quasi identifiers. Table 4-1 is an example of a 2-anonymous table. For any given age range and address, there are at least two records corresponding to that age/address. Suppose we know Patricia is 19 years old and lives in West Lafayette. We know she is one of the first two records, but we have no idea which one. However, since the occupation of both people is “student,” we now know Patricia is a student even though the record is not individually identifiable.

Table 4-1: Sample 2-Anonymous dataset

Age	Address	Occupation
[18-22]	West Lafayette	Student
[18-22]	West Lafayette	Student
[18-22]	Lafayette	Steamfitter
[18-22]	Lafayette	Student
[23-30]	West Lafayette	Teacher
[23-30]	West Lafayette	Farmer

This issue is addressed by l -diversity.²³ The l -diversity extends k -anonymity by further requiring at least l distinct values in each group of k records. This prevents the previously noted privacy breach, as there are at least l possible occupations for an individual, even if we know which group of k people they belong to. For example, in Table 4-1, the records for 18–22 year olds in Lafayette satisfy 2-diversity. They could be either a steamfitter or student. The records for 18–22 year olds in West Lafayette do not. While they satisfy 2-anonymity, we know both are students.

Even l -diversity has issues. For example, suppose one of the occupations is CEO. Even though we do not know which record belongs to Patricia, we know CEOs are rare, and since she is one of k people, one of whom is a CEO, the probability that she is a CEO is much higher than we would think without having access to the microdata. This issue spawned a definition t -closeness, which ensures the distribution of values in a group of k is sufficiently close to the overall distribution.²⁴

While these definitions seem strong, given sufficient background knowledge, it is almost always possible to learn private information from such a micro dataset. This is even true of the HIPAA safe harbor rules, so it appears some level of risk to privacy is deemed acceptable. However, there is not yet a general legally accepted definition of what constitutes nonidentifiable data.

An alternative approach is “synthetic data,” which produces data that looks like microdata, but is generated statistically rather than containing actual data on individuals. Care must be taken to ensure the statistics used do not result in synthetic data that can be traced to specific data, e.g., statistics reporting the exact details of a very high net worth individual could result in synthetic data exactly matching that individual. The following section discusses how to ensure aggregate statistics do not violate privacy and statistics produced using such methods can safely be used to generate synthetic data.

4.4.4 Aggregation-Based Approaches

Instead of publishing deidentified, individual-level records, one can publish aggregate statistics derived from the data. On its face, this would eliminate privacy concerns.

Unfortunately, it is often possible to determine individual values from such statistics. For example, publishing a table of statistics on the number of individuals with given income levels broken down by age could reveal both age and income for certain well-known, high-income individuals. More subtle attacks on privacy come from the comparison of values across multiple cells. An example of such a problem, and a method to deal with it, can be found in a paper by Lingyu Wang et al.²⁵ The official statistics community has led the way in techniques to safely publish so-called contingency tables. Many of the techniques are similar to microdata: top- and bottom-coding, suppression, and noise addition, to name a few.

A key issue when releasing aggregates is to determine whether the data is “frequency” or “magnitude” data. The easiest way to distinguish these two types of data is to determine whether individuals contribute equally or unequally to the value released. For example, a count of the number of individuals at a given income and age is frequency data, as each individual contributes one to the cell they are in. A table giving average income by age is magnitude data, as someone with a high income will affect the average much more than an individual whose income is close to the average. For magnitude data, noise addition or entire suppression of the cell is typically needed to ensure privacy, while rounding techniques may be sufficient for frequency data. The previously described microdata checklist includes a section with recommendations for disclosure of aggregates.²⁶

Unfortunately, these approaches cannot entirely eliminate privacy risk. With a large enough set of aggregates, “database reconstruction” becomes possible.²⁷ Database reconstruction builds a dataset that would generate the aggregate statistics. In many cases, it can be shown that such a reconstructed database is unique, or at least many of the individual records in the dataset are unique, e.g., they must exist in any dataset that generated those aggregates. While this data is not identified, it is essentially a micro dataset and subject to the reidentification attacks discussed in the preceding section. Researchers have shown this is not just a hypothetical problem. Real-world published aggregates such as census tables are vulnerable to database reconstruction.²⁸ The box shows just how few aggregates are needed to inadvertently reveal individual information.

Database Reconstruction

by Simson Garfinkel

Consider a company that delivers continuing education services and publishes a brochure with the average age of professionals enrolled in their past classes. The first time the course was given there were three students; the second time, eight students. The average ages were forty-four and thirty-seven. Now, say a customer with a degree in statistics objects to the firm publishing the mean, arguing medians are far more useful for understanding populations. So, the next time the company publishes its brochure, it reports three cohorts with three, eight and fifteen people, with median ages of thirty, thirty-five, and forty. Three statistics have now been published for the first cohort: there were exactly three people, with median age of 30 and average age of 44. If the company separately publishes that the oldest person who ever took the training was seventy-two, the company has now exactly revealed that the individuals in the first cohort were thirty, thirty, and seventy-two, because there is no other combination of three ages that has a median age of thirty, a mean age of forty-four, and a maximum age of seventy-two.

Techniques such as top- and bottom-coding, rounding, and suppression do not guarantee protection against database reconstruction. The only way to provide guaranteed limits on the risk of database reconstruction is noise addition. The most widely accepted definition for noise addition at this time is “differential privacy.”²⁹ Perhaps the highest profile use of noise addition was the 2020 U.S. Census, which used differential privacy. The idea behind differential privacy is to add sufficient noise to the aggregates to hide the impact of any one individual. The key idea is to compare the difference in the aggregate result between two databases that differ by one individual. Differential privacy requires the added noise to be large relative to that difference, for any two databases and any individual.

Looking at the example in the Database Reconstruction box, imagine if the mean and median ages were published with a small amount of noise. In this case, even if we published a mean of forty-four, median of thirty, and maximum of seventy-two, we could not be certain that the ages were thirty, thirty, and seventy-two. This is because the true value for the mean could have been forty-five, forty-three, or forty-six. Our reconstruction attempt may give us an answer, but we cannot be confident that it is a *correct* answer.

Formally, the definition is as follows:

$$\text{For } S \subseteq \text{Range}(f), \text{ an } \epsilon\text{-differentially private mechanism } M \text{ satisfies} \\ \frac{\Pr[M_f(D_1) \in S]}{\Pr[M_f(D_2) \in S]} \leq e^\epsilon, \text{ where } D_1 \text{ and } D_2 \text{ differ on at most one element.}$$

We can see when $\epsilon = 0$, the answers must be the same for the two databases—perfect privacy. As ϵ increases, the quality of the answer improves, but the privacy provided decreases. Though perhaps not obvious from the definition, differential privacy is quite general. It can apply to a function f that returns a discrete value, a continuous value, or even a set of values, such as a contingency table. The definition can even be applied to the release of microdata, although in practice this would give something closer to synthetic microdata. One way to imagine this is to think of generating a set of differentially private contingency

tables, then do a database reconstruction on those tables. The result would be differentially private microdata. Furthermore, general mechanisms can be applied to provide differential privacy, such as adding noise from a Laplace distribution and selecting outcomes from all possible results with an exponentially higher probability of selecting those close to the true value (exponential mechanism). A survey of mechanisms for achieving differential privacy is given by Cynthia Dwork and Aaron Roth in “The Algorithmic Foundations of Differential Privacy.”³⁰

Differential privacy deals with a key challenge in the release of aggregates. Even though it may be safe to release two aggregate values, e.g., two tables, independently, given both, is it possible to reidentify individuals from these tables? The answer may be yes. A simple example would be releasing the total payroll of a company and the total payroll of the company exclusive of the CEO. While neither datum reveals individual salaries by itself, it is easy to determine the CEO’s salary given both the numbers. If we use differential privacy to release two aggregates, one providing ϵ_1 privacy, and the other providing ϵ_2 privacy, the two in combination give at least $\epsilon_1 + \epsilon_2$ privacy.

One open question is the appropriate value of ϵ for differential privacy. It turns out the parameter ϵ is really a measure of the quality of the aggregate rather than the risk to an individual. While the initial developers envisioned $\epsilon < 1$, the U.S. Census Bureau found $\epsilon = 19.61$ appropriate for the 2020 Census.³¹ Setting ϵ is dependent on the data and scenario, the value found appropriate for one domain, e.g., the U.S. Decennial Census, may be inadequate or overkill for another use, even if the data appears similar.

“Differential identifiability” is a reformulation of differential privacy that limits the confidence any particular individual has contributed to the aggregate value, given the assumption someone trying to reidentify an individual has no other reason to believe that individual is in the data.³² As with differential privacy, we have a formal, mathematical definition:

$$\forall D' = D - \{i\}, \forall i \in U - D', S \subseteq \text{Range}(f), \text{ a } \rho\text{-differentially identifiable mechanism } M \text{ satisfies } \Pr[I(i) \in D \mid M_f(D) = S, D'] \leq \rho.$$

The way we provide privacy is essentially the same as with differential privacy: we add noise so any attempt to reidentify an individual is likely to give the wrong answer. The difference is we state the privacy parameter p in terms of the privacy protection rather than the quality of the outcome, with the limitation that the privacy protection is only guaranteed in an ideal world where the adversary has no external information.

We can compute an expected value for p corresponding to the HIPAA safe harbor rules. Assuming a geographic area of 20,000 individuals, we would expect to find sixty-eight males of age eighty-three, giving $p = 1.7\%$. While the confidence in identifying younger individuals is likely to be lower and, in some cases, the safe harbor rules may not provide this level of protection in the presence of background information, we could assume the goal of the rule

is no stronger than this. Differential identifiability guarantees that we limit reidentification confidence to this level while preserving the protection against database reconstruction of differential privacy, providing an argument for the sufficiency of the mechanism.

Though still evolving, releasing data aggregates rather than microdata often provides significantly better privacy protection and still meets the need for data analysis.

4.4.5 Client-Side Control of Anonymization

While anonymization is typically viewed as something done by a data custodian, there are client-side techniques to enhance anonymity. For example, proxy servers can hide the IP address of a request by replacing it with that of the proxy server. Techniques such as onion routing and crowds further extend this notion of proxies by hiding IP addresses even from the proxy server.³³ Tor is a practical example of such a system. Tor is a peer-to-peer network where each request is routed to another peer, which routes it to another peer, and so on until a final peer makes the actual request. Encryption is used to ensure only the first peer knows where the request came from, and only the last peer knows the server where the request is being routed.

This hides only the IP address. Most internet traffic contains considerably more identifying information. For example, a typical HTTP request contains information on the browser, last page visited, type of machine, and so on. This can make such a request identifiable even if the IP address is unknown. Private web search is a browser plug-in that strips such information from the request.³⁴ This leaves only the search text itself, but as we have seen with the AOL query log disclosure, even this may be sufficient to identify an individual. Tools have been developed to generate “cover queries,” or fake query traffic that disguises the actual request.³⁵ Supporting such client-side approaches by requesting only necessary information, e.g., requiring use of cookies only when necessary for a transaction, enables users who are concerned about privacy to provide their own protection. This can increase comfort level for privacy-sensitive users.

Noise addition techniques can also be used at the client side. “Local differential privacy” allows individuals to add noise before sending data to a server. The server then computes the aggregate from the noisy data. Local differential privacy is not to be confused with local sensitivity, a measure of the impact of one individual on the result of a query on a particular dataset. A classic example of client-side noise addition is randomized response, where those surveyed randomly choose to either answer correctly or provide a random answer.³⁶ Any individual response is suspect: it could easily be just a random choice, but it is possible to construct aggregate results that have provable correctness bounds. Randomized response can provide differential privacy.

4.5 Summary

An important privacy concern for IT professionals is how to handle individually identifiable data. Data that cannot be linked to a specific individual is generally not constrained by privacy regulations. Unfortunately, it is not easy to determine if data can be linked to an individual. While anonymous data can be shared freely, it is difficult to ensure that data is truly anonymous. Pseudonymous data can also be safe to share, but it is easier to reidentify the individual associated with this data with anonymous data. As a result, all data about individuals should be treated with care. The level of protections afforded to this data should be commensurate with the privacy risk, a topic discussed further in chapter 2.

Access to individually identified data must be controlled and should be limited to those with a clear need to access data about the individual for purposes that benefit the individual. Authentication should be appropriate to the privacy risk. The main issue is the trade-off between strength of authentication and convenience. Authentication methods that impose a high overhead on users can backfire. For example, requiring complex passwords often leads people to write passwords down, often posting them near their computer, resulting in little security from the password (what you know) and replacing it with physical location security (where you are). A better approach for authenticating employees is through multifactor authentication, which combines several factors into a single authentication process. Reading an RFID-tagged ID badge (what you have) or using a fingerprint reader (what you are) along with a simple password can provide better protection and more convenience.

Authenticating external access, e.g., to give people access to data about themselves, is more challenging as techniques based on ID card readers or biometrics require special hardware that the public is not likely to have. An increasingly common approach is to use text messages as a second factor, but this requires the individual to have and carry a cell phone to authenticate. This leads to a privacy trade-off. Imposing higher hurdles on access to data about oneself does provide greater protection against violations of privacy, but preventing individuals from seeing data about themselves is itself a violation of privacy. The risk of harm to an individual from disclosure of the data needs to be compared with the risk from use of incorrect data or use without the individual's knowledge to determine how easy or difficult individual access should be.

The less likely it is that data can be linked to an individual, the lower the privacy risk. Therefore, data should be stored and used in anonymized form whenever feasible. Even when data must be kept in identified form, creating deidentified data for analysis and data warehousing is a good idea. A good model is the use of LDSs for health care research. While hospital records need to be identified for use in treating the patient, names, addresses, and identifying numbers may be removed for use in research. Though many of the records, such as birth dates and postal codes, in LDSs are identifiable and thus access to them must be restricted, the likelihood of a privacy breach is reduced. Reidentification requires active effort, as opposed to accidentally spotting the health record of a friend or neighbor when analyzing the data. The same principle should be applied to any use of data. Using anonymization

techniques to give access only to the information needed for the task greatly reduces the risk of privacy violations, even if the data could potentially be reidentified.

Data anonymization is still an open research area. Progress is being made in ways to both anonymize data and reidentify supposedly anonymous data. While there is often great value in publicly disclosing anonymous data, there is always some potential privacy risk from doing so. The principle of informed consent applies here as well. Informing data subjects that their data may be disclosed as part of an anonymized dataset and obtaining consent to do so can go a long way to alleviating fallout, should the anonymization fail to protect against identifying individuals.

Endnotes

- 1 Peter Steiner, "On the Internet, Nobody Knows You're a Dog," *The New Yorker*, July 5, 1993, 61.
- 2 Alessandro Acquisti and Ralph Gross, "Predicting Social Security Numbers from Public Data," *Proceedings of the National Academy of Sciences* 106, no. 27 (July 7, 2009): 10975–10980, www.pnas.org/content/106/27/10975.
- 3 Katharina Koerner, *Self-Sovereign Identity as Future Privacy by Design Solution in Digital Identity?*, IAPP White Paper, August 2022, <https://iapp.org/resources/article/white-paper-self-sovereign-identity/>.
- 4 Philip Zimmermann, *PGP Source Code and Internals* (Cambridge, MA: MIT Press, August 1, 1995).
- 5 "Welsh Police Wrongly Identify Thousands as Potential Criminals," *The Guardian*, May 5, 2018, <https://www.theguardian.com/uk-news/2018/may/05/welsh-police-wrongly-identify-thousands-as-potential-criminals>.
- 6 Joseph Bonneau, Sören Preibusch, and Ross Anderson, "A Birthday Present Every Eleven Wallets? The Security of Customer-Chosen Banking PINs," *Financial Cryptography and Data Security: The 16th International Conference, 2012*, 25–40.
- 7 Nguyen Minh Duc and Bui Quang Ming, "Your Face Is NOT Your Password," 2009, www.blackhat.com/presentations/bh-dc-09/Nguyen/BlackHat-DC-09-Nguyen-Face-not-your-password.pdf.
- 8 Latanya Sweeney, "Computational Disclosure Control: A Primer on Data Privacy Protection," (PhD dissertation, MIT, 2001).
- 9 Article 29 Data Protection Working Party, "Opinion 4/2007 on the Concept of Personal Data," adopted June 20, 2007.
- 10 Regulation (EU) of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.
- 11 HIPAA, 45 CFR 164.514 (c).
- 12 Michael Barbaro and Tom Zeller, Jr., "A Face Is Exposed for AOL Searcher No. 4417749," *The New York Times*, August 9, 2006, www.nytimes.com/2006/08/09/technology/09aol.html.
- 13 Arvind Narayanan and Vitaly Shmatikov, "Robust De-anonymization of Large Datasets," *Proceedings of the IEEE Symposium of Security and Privacy* (2008): 111–125.
- 14 Bradley Malin, "Trail Re-identification and Unlinkability in Distributed Databases" (PhD thesis, Carnegie Mellon University, May 2006), <http://reports-archive.adm.cs.cmu.edu/anon/isri2006/abstracts/06-105.html>; Manolis Terrovitis, Nikos Mamoulis and Panos Kalnis, "Privacy-Preserving Anonymization of Set-Valued Data," *Proceedings of the VLDB Endowment* 1, no. 1 (2008): 115–125, <http://doi.acm.org/10.1145/1453856.1453874>.
- 15 Article 29 Data Protection Working Party, "Opinion 1/2008 on Data Protection Issues Related to Search Engines," adopted April 4, 2008.
- 16 16 CFR Part 312, Children's Online Privacy Protection Rules (COPPA) §312.2.
- 17 TITLE 1.81.5. California Consumer Privacy Act of 2018 1798.140 (v).1.A
- 18 Peter Eckersley, "How Unique Is Your Web Browser?" Electronic Frontier Foundation (2010), <https://panopticklick.eff.org/static/browser-uniqueness.pdf>.

- 19 European Data Protection Board, “Guidelines 08/2020 on the Targeting of Social Media Users”, October 19, 2020, https://edpb.europa.eu/our-work-tools/documents/public-consultations/2020/guidelines-082020-targeting-social-media-users_en.
- 20 Federal Committee on Statistical Methodology, *Statistical Policy Working Paper 22 (Revised 2005)—Report on Statistical Disclosure Limitation Methodology*, Statistical and Science Policy, Office of Information and Regulatory Affairs, Office of Management and Budget, December 2005, <https://www.hhs.gov/sites/default/files/spwp22.pdf>.
- 21 Interagency Confidentiality and Data Access Group: An Interest Group of the Federal Committee on Statistical Methodology, “Checklist on Disclosure Potential of Proposed Data Releases,” Statistical Policy Office, Office of Information and Regulatory Affairs, Office of Management and Budget, July 1999, https://nces.ed.gov/FCSM/doc/checklist_799.doc.
- 22 Pierangela Samarati, “Protecting Respondent’s Identities in Microdata Release,” *IEEE Transactions on Knowledge and Data Engineering* 13, no. 6 (2001): 1010–1027, <http://ieeexplore.ieee.org/xpl/articleDetails.jsp?arnumber=971193>; Latanya Sweeney, “*k*-Anonymity: A Model for Protecting Privacy,” *International Journal on Uncertainty, Fuzziness and Knowledge-based Systems* 10, no. 5 (2002): 557–570, www.worldscientific.com/doi/abs/10.1142/S0218488502001648.
- 23 Ashwin Machanavajjhala, Johannes Gehrke, Daniel Kifer, and Muthuramakrishnan Venkitasubramaniam, “*l*-Diversity: Privacy Beyond *k*-Anonymity,” *Proceedings of the 22nd IEEE International Conference on Data Engineering (ICDE 2006, Atlanta, Georgia, April 2006)*, <http://ieeexplore.ieee.org/xpl/articleDetails.jsp?arnumber=1617392>.
- 24 Ninghui Li, Tiancheng Li, and Suresh Venkatasubramanian, “*t*-Closeness: Privacy Beyond *k*-Anonymity and *l*-Diversity,” *Proceedings of the IEEE 23rd International Conference on Data Engineering (ICDE 2007, Istanbul, Turkey, April 15–20, 2007)*, <http://ieeexplore.ieee.org/xpl/articleDetails.jsp?arnumber=4221659>.
- 25 Lingyu Wang, Duminda Wijesekera, and Sushil Jajodia, “Cardinality-Based Inference Control in Data Cubes,” *Journal of Computer Security* 12, no. 5 (2004): 655–692.
- 26 Interagency Confidentiality and Data Access Group, “Checklist on Disclosure Potential of Proposed Data Releases.”
- 27 Irit Dinur and Kobbi Nissim, “Revealing Information While Preserving Privacy,” *Proceedings of the 22nd ACM SIGMOD-SIGACT-SIGART Principles of Database Systems (2003)*: 202–210, <https://doi.org/10.1145/773153.773173>.
- 28 Simson Garfinkel, John M. Abowd, and Christian Martindale, “Understanding Database Reconstruction Attacks on Public Data,” *Communications of the ACM* 62(3):46–53, March 2019, <https://doi.org/10.1145/3287287>.
- 29 Cynthia Dwork, Frank McSherry, Kobbi Nissim, and Adam Smith, “Calibrating Noise to Sensitivity in Private Data Analysis,” in *Proceedings of the Third Theory of Cryptography Conference* (New York: March 4–7, 2006): 265–284, https://doi.org/10.1007/11681878_14.
- 30 Cynthia Dwork and Aaron Roth, “The Algorithmic Foundations of Differential Privacy,” *Foundations and Trends® in Theoretical Computer Science* 9, no. 3–4 (August 11, 2014): 211–407, <http://dx.doi.org/10.1561/04000000042>.
- 31 “Census Bureau Sets Key Parameters to Protect Privacy in 2020 Census Results,” Press Release Number CB21-CN.42, United States Census Bureau, June 09, 2021, <https://www.census.gov/newsroom/press-releases/2021/2020-census-key-parameters.html>.
- 32 Jaewoo Lee and Chris Clifton, “Differential Identifiability,” *18th ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, Beijing, China, August 12–16, 2012.
- 33 David Goldschlag, Michael Reed, and Paul Syverson, “Onion Routing,” *Communications of the ACM* 42, no. 2 (1999): 39–41, <http://dl.acm.org/citation.cfm?doid=293411.293443>; Michael K. Reiter and Aviel D. Rubin, “Crowds: Anonymity for Web Transactions,” *ACM Transactions on Information and System Security* 1, no. 1 (1998): 66–92, <http://dl.acm.org/citation.cfm?doid=290163.290168>.
- 34 Felipe Saint-Jean, Aaron Johnson, Dan Boneh, and Joan Feigenbaum, “Private Web Search,” *Proceedings of the 6th Workshop on Privacy in the Electronic Society* (Alexandria, VA: ACM Press, October 29, 2007), 84–90, <http://dl.acm.org/citation.cfm?doid=1314333.1314351>.
- 35 Daniel C. Howe and Helen Nissenbaum, “TrackMeNot: Resisting Surveillance in Web Search,” in Ian Kerr, Carole Lucock, and Valerie Steeves, *Lessons from the Identity Trail: Anonymity, Privacy and Identity in a Networked Society* (New York: Oxford University Press, 2009), 417–436; Mummoorthy Murugesan and Chris Clifton, “Providing Privacy Through Plausibly Deniable Search,” *Proceedings of the SIAM International Conference on Data Mining*, (Sparks, Nevada, April 30–May 2, 2009): 768–779, <https://epubs.siam.org/doi/10.1137/1.9781611972795.66>.
- 36 Stanley L. Warner, “Randomised Response: A Survey Technique for Eliminating Evasive Answer Bias,” *Journal of the American Statistical Association* 60, no. 309 (March 1965): 63–69, <https://www.jstor.org/stable/2283137>.

CHAPTER 5

Usable and Useful Privacy Interfaces

Florian Schaub, CIPP/US, CIPT; Lorrie Faith Cranor, CIPT

Privacy engineering and user experience (UX) design frequently intersect. Privacy laws and regulations require data subjects to be informed about a system's data practices, asked for consent, provided with a mechanism to withdraw consent, and given access to their own data—including options for data portability and data deletion. Certain privacy laws also require making specific opt-outs or privacy controls available to consumers, such as the requirement for a “do not sell my personal information” opt-out in the California Consumer Privacy Act

(CCPA). To satisfy these requirements and address users' privacy needs, most services offer some form of privacy notices, privacy controls, or privacy settings through a website or through the user interface of an app or other piece of software.

However, too often privacy notices are not readable, consent dialogs get in the way, people do not understand what they consent to, and people are not aware of data practices or the privacy settings or controls available to them. An emphasis on meeting legal and regulatory obligations is not sufficient to create privacy interfaces that are “usable” and “useful” for users. Usable means people can find, understand, and successfully use provided privacy information and controls. Useful means privacy information and controls align with users' needs with respect to making privacy-related decisions and managing their privacy.

This chapter provides guidance and best practices for user-centric privacy design that meets both legal obligations and users' needs. Designing effective privacy user experiences not only makes it easier for users to manage and control their privacy, but also benefits organizations by minimizing surprise for their users and facilitating user trust. Any privacy notice or control is not just a compliance tool but rather an opportunity to engage with users about privacy, explain the rationale behind data practices that may seem invasive without proper context, make users aware of potential privacy risks, and communicate the organization's measures and effort taken to mitigate those risks and protect users' privacy.

Privacy laws, privacy technology, and privacy management are typically centered on information—how information is collected, processed, stored, and transferred; how it can and must be protected; and how to ensure compliance and accountability. Designing privacy interfaces that are usable and useful requires a shift in focus. While information and compliance are of course still relevant, user-centric privacy design focuses on people, their privacy needs, and their interactions with a system's privacy interfaces.

Why is it important to pay attention to the usability of privacy interfaces? How do people make privacy decisions? What drives their privacy concerns and behavior? We answer these questions in this chapter and then provide an introduction to UX design. We discuss common usability issues in privacy interfaces and describe a set of privacy design principles and a user-centric process for designing usable and useful privacy interfaces, concluding with an overview of best practices.

5.1 Why User-Centered Privacy Design?

If you have ever tried to adjust your privacy settings in a mobile app or on a social media site or tried to figure out how to exercise privacy choices on a website, chances are you encountered a privacy interface that was not all that easy to use. Developers often add privacy interfaces to comply with regulations or company policy, but seldom engage user experience experts to design a usable privacy interface or evaluate its usability. However, privacy laws are increasingly including usability requirements, which means simply providing a choice *somewhere* in the user interface may not be sufficient to meet legal obligations. Furthermore,

people who encounter privacy notices and controls that are difficult to find, use, or understand may be surprised when they read a news report and find out about how an organization actually uses their data. Thus, even well-intended organizations may end up disappointing or surprising their customers and users, which in turn may decrease their trust in the organization. By taking a user-centered approach to privacy design, organizations can meet legal obligations while also minimizing user surprise and facilitating trust.

5.1.1 Meeting Legal Obligations

Many privacy laws include requirements for transparency and choice that include usability requirements. For example, the EU General Data Protection Regulation (GDPR) requires “clear and plain language” and transparency that is “concise, transparent, intelligible and easily accessible.”¹ A number of U.S. state privacy laws require privacy policies to be “clear and conspicuous.” Legal requirements related to privacy-notice usability focus on text that is readable to users, easy for users to find, and contains information users need to know.

Some laws also require users to be presented with easily accessible choices about the use of their data, ways to access the data an organization has collected about them, and mechanisms for requesting their data be deleted. While following the legal obligations and requirements is important, it is often not enough to ensure privacy notices and controls are actually useful and usable for users, which can potentially open up organizations to liability if their seemingly compliant privacy interfaces are found to be too difficult to understand or use by consumers.

In response to a rise in deceptive designs—sometimes also referred to as dark patterns—that aimed to lead consumers to make privacy choices that are preferable to the business, newer laws have added requirements against deceptive designs in privacy interfaces, such as consent and opt-out interfaces, instead requiring available choices to be presented equally and neutrally. For example, the CCPA regulations require “A business’s methods for submitting requests to opt-out shall be easy for consumers to execute and shall require minimal steps to allow the consumer to opt-out. A business shall not use a method that is designed with the purpose or has the substantial effect of subverting or impairing a consumer’s choice to opt-out.”²

5.1.2 Minimizing Surprise

When users are surprised at how their data is used by an organization, they are likely to become angry and lose trust in that organization.³

5.1.2.1 Aligning User Expectations and System Behavior

Users often have preconceived notions about how a system will use and share their personal information. As they use the system, the system’s user experience may further shape their expectations. Users may be unaware of data collection that occurs automatically or of inferences that are made based on their behavior. They may assume companies will use data

only to fulfill user requests and not for unrelated purposes. Any unexpected data use or sharing may come as an unpleasant surprise to users when they learn about it through news reports, social media, or because they are affected by how the data is used. For example, in 2018, it was revealed that Cambridge Analytica was able to obtain information about a huge number of Facebook users because Facebook apps could access information not only about the users who installed them but also about the friends of those users, without their knowledge. This data sharing with third parties by Facebook was met with shock and surprise by consumers and led to the largest regulatory penalty for a privacy violation to date.⁴ People were surprised and concerned when an announcement about new Google Assistant functionality coming to Google's Nest Secure hub via a software update revealed the presence of a hidden microphone. This incident highlights the need to be transparent about *all* sensors and capabilities in devices even if they are not active yet.⁵

Organizations can prevent these types of surprises by helping users understand what data their products can collect about them and how their data will be used and shared, as well as by drawing the user's attention to data practices most likely to be surprising. For example, an organization might highlight potentially surprising practices in a privacy policy and may also want to include just-in-time notices where appropriate throughout the system's UX to reduce users' surprise.

Likewise, organizations should make an effort to design privacy-related controls in such a way that users can fully understand what they do. When users check a box to opt out, they should know exactly what they are opting out of; for example, are they opting out of seeing advertising, ads that are targeted to them, or the actual tracking of their behavior for ad targeting? Most advertising-related opt-outs fail to clarify the actual effect of the opt-out.⁶ Likewise, access control settings for social media and calendars are often difficult to understand, and users may inadvertently grant access to more people than intended. Therefore, some calendar programs assist users who change the visibility of a calendar entry by displaying an explanation of how this will impact who can see that entry. The user interface should also make users aware of any side effects that may occur as a result of the settings they choose. For example, allowing an app to access location information might not only enable mapping features, but also enable the app to track the user's location for location-based advertising.

5.1.2.2 Reducing Opportunities for User Regret

Sometimes users take actions that may have an adverse impact on their privacy, which they may come to regret. This may occur when users misunderstand settings, select the wrong settings by mistake, or do not understand or misremember important details. For example, social media users may forget who is in their friends or followers group and thus may be surprised when their parent, boss, or coworker sees a post not intended for them, causing regret.⁷ Some systems use “nudges” or time delays to reduce opportunities for user regret. Researchers have developed and tested nudges for Facebook that remind users of who is in

the audience for their posts and provide a short countdown timer before posting.⁸ Facebook itself has implemented a nudge to address the problem of users changing their audience setting to public for one post and forgetting to change it back to a more privacy-protective setting the next time they post.² In 2022, Facebook introduced the option to set a “default audience” for future posts while still giving users the option to change a specific post’s audience. This is likely an even better solution than the previous nudge because changes to the current post’s audience will not affect future posts unless the user deliberately changes their default audience.¹⁰ Gmail offers users the opportunity to set a delay of five to thirty seconds before sent messages are actually sent, giving users a short opportunity to recall them.¹¹ Features such as these that reduce opportunities for user regret can help users help themselves and protect their privacy.

5.1.3 Facilitating Trust

Users are more likely to trust companies they believe will treat them fairly, communicate clearly about their data practices and privacy protections, and offer them meaningful choices and controls.

5.1.3.1 Communicating Privacy Protections

Users are not likely to trust privacy information or notices that appear as just a bunch of legalese meant to protect the organization or tout promises that the organization “values privacy,” which are then not actually reflected in the organization’s data collection, processing, and data sharing practices. Furthermore, when users, or the media, find an organization or product engages in surprising and privacy-invasive data practices, it can destroy trust and reputation.¹² Often practices are unexpected because they were not communicated clearly or conspicuously. For example, in 2019, multiple companies producing smart speakers and smart assistants were criticized because they had employees listen to and manually annotate people’s voice commands. While such manual annotation may be necessary to improve speech recognition, a statement in the privacy policy that “your data may be used to improve our services” does not properly convey that people might be listening to what you tell your smart speaker in the privacy of your home. To help build trust, organizations should communicate about privacy in a clear and straightforward way that will be meaningful to users. Privacy communication does not just serve compliance purposes—it provides opportunities for organizations to communicate about their efforts to protect their users’ privacy, which otherwise might be invisible to users.

5.1.3.2 Providing Meaningful Choices and Controls

Besides communicating clearly about privacy, organizations should offer meaningful choices and controls. A user who fully understands an organization’s practices but is not offered any meaningful way to control them may not have a positive view of the organization. On the other hand, privacy controls that enable users to manage their privacy settings in ways that

align with their privacy preferences and needs provide a sense of agency and control. This can help foster trust in the organization's ability and intent to properly protect its users' privacy.

A good example of fine-grained and specific privacy controls that offer actual choices to users are mobile permission requests on smartphones. When an app wants to access a user's location, contacts, or other phone resource, both iOS and Android devices pop up a permission request that includes a short explanation of why the permission is needed from the developer and make it equally easy for users to allow or deny the request.

5.2 Privacy Decision-Making, Behavior, and Concerns

"Transparency" and "user rights" are core concepts of privacy legislation and guidelines globally, ranging from the Organisation of Economic Co-operation and Development (OECD) privacy guidelines, to the U.S. Federal Trade Commission's (FTC's) fair information practice principles, to the EU GDPR, and privacy legislation in many other countries.¹³

While specific requirements may vary, companies that collect or process personally identifiable information (PII) typically have to be transparent about their data practices and inform data subjects about their rights and options for controlling or preventing certain data practices. This is often referred to as the "notice and choice model."

Given such transparency and respective choices, consumers are supposed to be able to make informed privacy and consent decisions. However, in practice, privacy decision-making is not quite as simple or straightforward. Understanding how people make privacy decisions and what shapes their privacy concerns is essential for designing usable and useful privacy interfaces that effectively make people aware of data practices and support informed privacy decision-making.

5.2.1 Privacy Preferences versus Behavior

The notice and choice model is based on rational choice theory, which postulates a rationally acting person ingests information about companies' data practices, uses this information to engage in a risk-benefit analysis, and makes rational decisions about the services to adopt or companies to trust with their personal information. Such decisions are assumed to be consistent with the person's privacy preferences to optimize their desired level of privacy.

They are also often assumed to be stable and consistent across decisions and time. This kind of rational decision-making about privacy is also referred to as the "privacy calculus."¹⁴

However, in practice people's privacy decisions and behavior are rarely rational or predictable but rather highly context dependent and malleable.

5.2.1.1 Privacy Paradox

Even though research studies and surveys frequently find people are concerned about their privacy and want to do more to protect it,¹⁵ people share copious personal details on social media,¹⁶ express regrets about sharing too much information online,¹⁷ are frequently

surprised by the data practices of services they use,¹⁸ and are often unaware of privacy controls and protections available to them.¹⁹

This contradiction of people being concerned and complaining about data practices while freely providing and sharing personal information is sometimes referred to as the “privacy paradox.” People express certain privacy preferences or intentions but act contrary to them.²⁰ For example, people may be sensitive about sharing their health information, yet may use fitness trackers, smart watches, or consumer genetic testing kits because they provide them insights on their health, even though by doing so, they also end up giving detailed health information to the companies behind those gadgets or services.

5.2.1.2 Self-Censorship, Chilling Effects, and Privacy Seeking Behavior

While people seem to be sharing information freely despite privacy concerns, research also suggests people engage in self-censorship because of privacy concerns. For example, some people may opt not to share personal opinions, political leanings, or certain updates about their lives online to avoid arguments or manage their self-presentation.²¹

Increased awareness about invasive data practices may also cause “chilling effects.” For instance, Edward Snowden’s 2013 revelations about the U.S. government’s online surveillance practices have been linked to a significant decline in searches for terrorism-related topics, e.g., Al Qaeda, jihad, chemical weapons, both on Wikipedia and Google Search.²²

Other evidence that people not only state privacy concerns, as the privacy paradox suggests, but also actively engage in privacy-seeking behaviors include people reporting to use restrictive settings on online and social media profiles; deleting invasive apps from their phones; using coded language in online interactions that only makes the true meaning apparent to intended recipients; and opting out of ad tracking if given a clear choice to do so, as shown by the impact on ad revenue of Apple’s introduction of App Tracking Transparency (ATT) options.²³ Researchers have also found evidence of a “reverse privacy paradox,” in which people engage in privacy protective behaviors despite expressing dismissive privacy perspectives.²⁴

5.2.2 Factors Affecting Privacy Decision-Making and Behavior

How can the privacy paradox, oversharing, self-censorship, chilling effects, and privacy-seeking behaviors all exist at the same time? Table 5-1 distinguishes between a set of related yet distinct concepts regarding privacy decision-making, providing a lens through which to view and understand seemingly contradictory privacy behaviors.²⁵

Table 5-1: Common concepts in privacy decision-making and behavior

Concept	Nature	Description
Privacy attitude	Normative	An individual’s predisposition toward privacy, which influences their stance regarding different privacy-related situations

Privacy preference	Aspirational	An individual's preferred outcome for a specific privacy-related situation
Privacy concern	Hypothetical	An individual's expression of worry toward a specific privacy-related situation
Privacy expectation	Anticipatory	An individual's expression of what they view as the likely specific privacy-related outcome of a situation or behavior from the other parties involved
Privacy decision	Intentional	What an individual intends to do in a specific privacy-related situation
Privacy behavior	Factual	What an individual actually does or has done in an attempt to achieve their preferred level of privacy
Data practice	Factual	The data processing that actually occurs regarding an individual and their data
Privacy harm	Factual	A negative impact of data processing on an individual's privacy
Privacy regret	Retrospective	An individual's realization that behavior and expectations were harmfully misaligned

An individual's "privacy preferences" are aspirational. They describe what the individual would prefer to happen in a certain privacy-related situation, which may be informed by one's general attitude toward privacy, sociocultural norms, and prior experiences. "Privacy concerns" are privacy risks or potential "privacy harms" an individual is aware of or worried about regarding a specific privacy-related situation. These may range from minor concerns to worst-case scenarios. "Privacy expectations"—what an individual views as likely privacy-related outcomes regarding data processing, privacy infringements, or related behaviors from other parties in a given situation—are shaped by the person's privacy preferences, concerns, and awareness of data practices. Such expectations may be consistent with the actual "data practices" or may be inaccurate, either assuming a lower privacy risk than exists or expecting privacy risks that are unwarranted.

Privacy preferences, expectations, and concerns all factor into a person's privacy decision-making process, both consciously and subconsciously. People rarely make fully rational privacy decisions in which they seek out all available information and optimize their decision to align with their preferences. Indeed, in many situations, this would be quite time consuming and may not even be possible. "Privacy decisions" are subject to both external influences, such as incomplete information or context, and internal influences, such as bounded rationality or experience. As a result, a person's privacy decision in a given situation may not be a consistent reflection of their privacy preferences or might even contradict them. Privacy decisions are intentions to act in a certain way. The implementation of a privacy decision, or "privacy behavior" may be further affected by external factors, such as choice architecture, in the given situation.

People experience “privacy regret” when they realize their privacy behavior or the actual data practices of a system or an organization were misaligned with their privacy expectations in a way that negatively affected them. Data processing can negatively impact the data subject’s privacy, resulting in “privacy harm”, especially when data practices and the data subject’s expectations are misaligned. Sometimes people observe tangible harm, but often they are not aware of the harm. Privacy harms may also not manifest immediately. For example, a person’s social media posts made as a college student on a long-forgotten social media service may be ingested by a data broker, which sells the information to a job-candidate vetting service, which in turn downgrades the person’s job application, resulting in the person not being invited for a job interview. The person might never learn not being invited to the job interview was a privacy harm. Privacy harms can take various forms, such as physical harms, economic harms, reputational harms, psychological harms, autonomy harms, discrimination harms, and relationship harms.²⁶

Considering the many factors influencing privacy decisions and behavior, the often-observed misalignment between people’s privacy preferences and actual behavior, called the privacy paradox, is less surprising. Incomplete information, context, and bounded rationality affect privacy decisions and behavior in ways that can result in substantial deviations from their privacy preferences.²⁷

5.2.2.1 Incomplete Information and Uncertainty

Informed consent and informed decision-making both assume a person has fully considered all available information to make an informed decision. However, more often than not people have to make decisions based on incomplete information. In the case of privacy, this might mean a person is likely not aware of all data collection, data processing, or data transfer practices associated with a transaction. This is particularly the case when information is seemingly collected for one purpose but also used for secondary purposes. For example, a navigation app needs the user’s location information to display the correct part of the map and provide navigation support, but the app provider might also use location information to identify roads with traffic congestion or to infer where the user lives and works or what businesses they frequent.

Even if a person is aware of a data practice, they may not be aware of the associated privacy risks or implications. For instance, in the navigation app example, it may not be apparent to all users that inference of their home and work locations not only makes it easier to quickly navigate to those places but may also reveal information about their socioeconomic status or family situation, and such information could negatively affect other parts of their lives, ranging from the advertisements shown to them to the interest rate they are offered on a home or car loan.

People may also have misconceptions about how their privacy is protected in a given context. They might assume companies securely transfer and store data, but frequent data breaches show this is not necessarily the case. They might assume they are protected by

privacy laws that limit what data can be collected or how it can be used. In practice, legal privacy protections can vary substantially between countries and even between industry sectors in countries with sectoral privacy laws like the United States. This can lead to misconceptions such as the common assumption that when a website has a link to a privacy policy, it does not share information about its users with third parties, even though the existence of a privacy policy alone does not guarantee privacy-protective data processing.²⁸

Misconceptions may also exist in the other direction. Because of incomplete information or uncertainty about data practices, consumers may assume a company or product is insecure or engaging in privacy-invasive practices, such as sharing or selling their information to third parties, even if it isn't. Thus, helping users develop an accurate understanding of data practices, privacy protections, and privacy controls not only provides transparency about data practices but also creates awareness about the measures taken to protect privacy and limit data use, as well as privacy controls and choices available to the user.

In fact, research has shown users may provide and share *more* information when they feel they have appropriate privacy controls to determine and adjust who has access to their information. This phenomenon has been dubbed the “control paradox,” as perceived control over privacy may lead to increased sharing, which in turn may increase privacy risks.²⁹

5.2.2.2 Bounded Rationality

Generally, humans are limited in their ability and time to acquire, memorize, and process all information relevant to making a fully informed and rational decision. Behavioral economists call this deviation from the ideal of a fully rational actor “bounded rationality.”³⁰ To compensate for the inability and impracticality of considering all potential outcomes and risks, humans rely on heuristics in their decision-making to reach a satisfactory solution rather than an optimal one. However, decision heuristics can lead to inaccurate assessments of complex situations.³¹ Rational decision-making is further affected by cognitive and behavioral biases and systematic errors in judgment and behaviors.

Bounded rationality also persists in privacy decision-making. Decision heuristics and biases have been shown to substantially affect people's privacy decisions and behavior.³² Prominent decision heuristics and biases that can affect privacy decisions and behavior include:³³

- Availability heuristic: Due to uncertainty about privacy risks, people may look for other available cues to judge the probability of risks and guide their behavior. For example, rather than reading an online store's privacy policy, people rely on readily available cues, such as the store's visual design, the presence of a privacy policy link, the vendor's reputation, or even just the company name and brand to make judgments about the privacy risks associated with providing personal contact and payment information to the online store.
- Representativeness heuristic: People may perceive privacy intrusions as low-probability events because they rarely encounter privacy intrusions online.

However, privacy intrusions, such as behavioral tracking and targeting, may occur frequently or continuously but may just not be visible to the individual.

- **Anchoring:** Available information creates a reference point for future decisions. For example, information or judgments about others' disclosure behavior informs how one reasons about one's own disclosure behavior.³⁴ Anchoring also manifests in ordering effects: survey participants disclose more information when a survey starts with intrusive questions and gradually reduces in sensitivity compared with a survey that increases in sensitivity.³⁵
- **Loss aversion:** Individuals dislike losses more than they like gains. In the context of privacy, loss aversion helps explain why people report being concerned about companies collecting information about them but are reluctant to pay for better privacy protection if it is offered.³⁶
- **Hyperbolic discounting:** Providing or sharing information often affords immediate gratification of some kind, such as the ability to use a desired app or service or social interactions like messaging or "likes," whereas privacy implications and risks are often hypothetical, shrouded by uncertainty, and not immediately apparent. Furthermore, privacy considerations are rarely the primary motivating factor for wanting to use a service or to enter into a transaction. Thus, even if people claim to care about privacy, they may discount privacy risks in the moment in favor of immediate gratification.³⁷
- **Optimism bias:** People systematically underestimate the likelihood of being affected by a negative event. For example, even though people recognize identity theft is a risk after a data breach, they underestimate the likelihood of personally having their identity stolen and, as a result, may not take sufficient protective action.³⁸
- **Default bias:** People have a general affinity for default choices. People often keep default settings even if they are privacy invasive, because they are not aware of the setting and/or its privacy implications; because of associated transaction costs, e.g., finding the setting, figuring out how it works, and its actual costs; or because they assume the default settings are set to protect them.³⁹

In practice, multiple such heuristics and biases can affect a person's decisions and behavior at the same time, further exacerbating inconsistencies in behavior and between privacy preferences and actions.

5.2.2.3 Context Dependence

Privacy preferences and concerns can vary from situation to situation. The information someone considers appropriate to share depends on contextual factors, such as the nature or source of the information, the activity or transaction in which the information may be shared,

as well as the people involved. For instance, you might reveal more about your personal life to a colleague at an after-work event than at work. You adjust how and what you talk about with your friends depending on where you are and who else is around. At the same time, you may also discuss sensitive topics in public spaces, e.g., at a restaurant or on a train, even though others might overhear the conversation. Similarly, people might reveal personal details to a stranger on a plane, their taxi or rideshare driver, or their hairdresser as part of making small talk. Privacy preferences are highly contextual or, as Alessandro Acquisti et al. state in their “Privacy and human behavior in the age of information” article, “the same person can in some situations be oblivious to, but in other situations be acutely concerned about, issues of privacy.”⁴⁰

Privacy preferences and expectations are shaped and affected by contextual factors. Gary T. Marx argues privacy violations can always be traced back to the breaching of one or more of the following boundaries:⁴¹

- Natural borders: Walls, closed doors, clothing, sealed envelopes, and encryption that protect information by limiting observation by others.
- Social borders: Assumptions or expectations of social norms about confidentiality and respect of one’s privacy, such as confidential relationships with doctors, lawyers, or priests; the integrity and confidentiality of personal correspondence; trust in colleagues, friends, and family members to not rifle through one’s personal effects; or the assumption that information is not retained longer than required or used for other purposes.
- Spatial or temporal borders: Physical distance or the passing of time separate information from different periods or aspects of a person’s life.
- Ephemeral or transitory borders: Assumptions that certain interactions or communications only exist in the moment and are not recorded permanently.

Each of these borders is increasingly weakened by advances in technology. The proliferation of smart home devices, most of which continuously exchange information with the manufacturer’s cloud back end, weakens the reliability of natural boundaries to protect privacy. Social, spatial, and temporal borders break down in the face of networked publics and social media. “Context collapse,” the overlapping and intermixing of previously delineated facets of one’s life like family life, work, different circles of friends, and hobbies, is now a common phenomenon in online interactions, especially interactions over social media.⁴² Assumptions of information being ephemeral or transitory run contrary to the vast digital traces people’s interactions with technology create, as well as consumer tracking and profiling efforts by companies.

Helen Nissenbaum’s framework of “contextual integrity” ties privacy expectations to context-dependent norms of information flow.⁴³ Information collection, processing, and

transmission practices that are in accordance with those norms are likely to be perceived as acceptable, whereas practices that do not follow those norms are perceived as privacy violations because they violate contextual integrity.

Contextual integrity can be used to analyze data practices for appropriateness by identifying the contextual factors of a situation, the informational norms associated with them, and whether an actual practice adheres to those norms or violates them. Context-relative privacy norms may be codified, in laws, rules, or procedures, but frequently such norms are implicit as part of conventions, moral values, and people's expectations of privacy. However, it is important to consider more than the broadly established norms when assessing potential privacy risks and harms, as those norms might not reflect privacy needs of marginalized populations.⁴⁴

As people go about their daily lives, they transition through many, sometimes overlapping contexts and, in doing so, engage in what Irwin Altman describes as a continuous and dynamic "boundary regulation process" to manage their privacy.⁴⁵ People's context-specific privacy preferences are affected by "external changes," such as changes in context, actors, information, or transmission principles, as well as "internal changes," such as changing privacy attitudes, preferences, prior experiences, or new knowledge. People adjust their behavior in attempts to achieve levels of privacy that align with their privacy preferences. As already discussed, this process is subject to uncertainty and bounded rationality, as well as external constraints, such as the inability to prevent a certain data practice.

An important aspect of this dynamic boundary-regulation process is the intention to balance privacy preferences, expectations, and achieved privacy. If the achieved privacy is less than what is preferred, a privacy invasion occurs. If the achieved privacy is more than desired, it results in social isolation. Thus, privacy regulation is not just about keeping information private, but rather about finding—and helping users find—the desired balance between privacy and information sharing for a given context.⁴⁶ This pertains both to managing one's privacy toward a data processor and managing information in contexts that involve interpersonal interactions. When multiple people or entities have access to certain information, privacy management becomes a collective task that relies on the negotiation of mutually acceptable privacy rules about further processing or sharing of that information. "Private information turbulence"—misalignment of or disagreement about what is appropriate or invasive—occurs when such rules are violated or have not been effectively negotiated in the first place.⁴⁷

5.2.3 Manipulation of Privacy Behavior

Privacy-related decisions and behavior, such as what information someone is willing to disclose, can be manipulated through system design. A system's "choice architecture," meaning what and how choices are presented to a user, has a substantial impact on users' information disclosure and sharing behaviors. Deceptive design patterns, also referred to as

“dark patterns” but we prefer the more inclusive term, are interface or system designs that purposefully exploit cognitive and behavioral biases to get people to behave a certain way, regardless of whether that behavior aligns with their preferences.⁴⁸ Some common deceptive design patterns are related to privacy, including:⁴⁹

- Default settings and preselection: Default settings frequently exploit default bias. Most people do not review or change default settings, which in the case of privacy means opt-out choices, such as opting out of targeted advertising or marketing use of contact information. People rarely exercise these opt-out choices even though they may not like the default practices. Similarly, preselecting a certain option nudges users toward accepting that choice.
- Cumbersome privacy choices: These unequal paths make it more difficult, arduous, and lengthy to select a privacy-friendly choice compared with a privacy-invasive one that deters users from privacy-friendly options.
- Framing and false hierarchy: How a choice is described and presented can affect behavior. An emphasis on benefits, de-emphasis on risks, or presentation of trust cues may lead people to make riskier privacy decisions than they would with a neutral presentation of choices.⁵⁰ A simple example of this is the “false hierarchy” pattern that describes the deceptive design of highlighting and emphasizing the choice that benefits an organization over the choice that benefits the consumer. For example, a large, colorful button for “accept all cookies” versus a smaller, gray link for “manage or reject cookies.”
- Rewards and punishment: Users are enticed to select a service’s preferred choice with rewards or are deterred from privacy-friendlier choices with punishments. For instance, granting a mobile app access to location data may enable certain services that are not available otherwise. Rewards and punishments are particularly problematic when they are not directly related to the choice, i.e., when choosing a privacy-friendly option poses stronger constraints than necessary. Rewards, such as a meter that goes up when you add more information to your online profile, leverage the human need for immediate gratification.⁵¹
- Forced action or registration: Users must accept a data practice to continue to a desired service, in hyperbolic discounting, regardless of whether they actually agree with the practice. They are forced to act against their privacy preference. Forced registration, e.g., in a purchasing process, makes users give up more information than may be necessary for the actual transaction.
- Norm shaping: Other people’s observed information-sharing behavior, say on a social media service, shapes the perceived norms of information sharing on a platform and individuals’ own disclosure behavior. For example, a controlled

experiment showed people who see more revealing posts in the feed of a photo-sharing service tend to consider such photos more appropriate and are more likely to share more revealing information themselves than those who see less revealing photos.⁵² Thus, the algorithm for determining news feed content, which might purposefully highlight or suppress certain content to activate such anchoring effects, has a lot of power in steering users' behavior, regardless of whether the displayed posts are actually representative of user behavior.

- Distractions and delays: Even small distractions or delays can create a distance between awareness of privacy risks and behavior that can cancel out the effects of a privacy notice.⁵³

Such manipulations of privacy behavior are unethical, as they constrain people in their self-determination and agency over their privacy. Moreover, manipulations of privacy behavior further exacerbate the misalignment between people's privacy preferences, expectations, actual behavior, and the data practices to which they are subject.

Furthermore, tricking people into agreeing to data practices that do not meet their preferences or behaving in ways that go against their privacy concerns and preferences can result in increased regrets by users. Such regrets may intensify the perception that their privacy has been violated, and ultimately can negatively affect people's adoption of technology or result in outcries on social media, bad press, and potential investigations by regulators.

Even if your intentions are good, the user interface of your privacy notices and controls can unintentionally mislead your users, cause surprise about unexpected data practices, get people to agree to data practices or set privacy settings in ways that do not align with their preferences, or accidentally promote oversharing resulting in regret. Therefore, UX design plays an important role in making privacy information and controls understandable and usable.

5.3 Usability and User Experience

The key to creating usable privacy notices and controls is UX design, sometimes also referred to as customer experience design. Well-designed privacy interfaces support users in forming an accurate understanding of a system's data practices and provide them with the right tools and support for managing their privacy. Depending on the size of your organization, you might have dedicated UX designers, UX researchers, or UX engineers who are responsible for the user-facing side of a product, or your organization might outsource UX research or design work. However, UX professionals are not necessarily trained or experienced in designing privacy user experiences. Therefore, it is important for privacy professionals to work with UX professionals to ensure privacy requirements and users' privacy needs are properly considered. It is useful for privacy pros to be aware of the UX design process and

general methods to make informed decisions about when and how to work with UX professionals on the design of privacy interfaces. Even just posting a privacy policy on your website is a UX design decision, and it is too often one made without properly considering the user experience and how it impacts the user.

5.3.1 What is UX?

UX design has one major goal: designing systems and processes to meet users' needs. This includes fostering an understanding of how the system works, building systems that are useful for people, and ensuring people can use the system as intended. Ideally, people should also enjoy using the system.

5.3.1.1 Usability

At the core of UX is usability, i.e., how easy a system or interface is to use. The International Organization for Standardization's ISO 9241-11 defines usability as the "extent to which a system, product or service can be used by specified users to achieve specified goals with effectiveness, efficiency and satisfaction in a specified context of use."⁵⁴ Jakob Nielsen, one of the pioneers of human-computer interaction, distinguished the following components that determine a system's usability:⁵⁵

- **Learnability:** How easy is it for users to accomplish basic tasks the first time they encounter the system?
- **Efficiency:** Once users have learned the system, how quickly can they perform tasks?
- **Memorability:** When users return to the system after a period of not using it, how easily can they reestablish proficiency?
- **Errors:** How many errors do users make, how severe are these errors, and how easily can they recover from the errors?
- **Satisfaction:** How pleasant is it to use the system?

Consider, for example, the task of unsubscribing from a promotional email. The effectiveness of an email opt-out mechanism would be determined by whether a person can find the opt-out mechanism in the first place and whether they can understand what steps to take to complete the opt out (learnability), execute those steps in the right order, achieve the intended result (success/errors), and later check or change their setting (memorability). Efficiency would be determined by the number of steps and the amount of time it takes to complete the opt-out. Satisfaction would be determined by the perceived ease or difficulty of completing the task and whether it was a pleasant and supportive process or one that was arduous and confusing.

5.3.1.2 Utility

A concept closely related to usability is utility.⁵⁶ Utility is about functionality. Does the system support users in satisfying their needs and accomplishing their goals? An interface can be very usable, but it is useless if it does not align with users' actual needs and expectations.

For example, the unsubscribe mechanism might be easy, fast, and pleasant to use (great usability), but only gives users the option to unsubscribe from all of an organization's communications or none of them, even though some users might want to unsubscribe from marketing emails but continue receiving important notifications about their account activity. As a result, people may not use the very usable opt-out mechanism because it is not useful to them.

A system with high utility meets the exact needs of users. A useful system has both good utility and good usability.

5.3.1.3 User Experience

As the discussion of utility and usability suggests, usability is important but, on its own, is often not sufficient to characterize what constitutes a good or bad experience for users. UX design takes a more holistic perspective that places users and their needs at the center and "encompasses all aspects of the end-user's interaction with the company, its services, and its products."⁵⁷ This might include the actual product; terms of service and privacy policies tied to the product; the product's purchase, unboxing and sign-up experience; as well as customer support, documentation, manuals, privacy settings and so on.

A system's UX encompasses the extent to which a system meets users' needs (utility), usability, aesthetics and simplicity, and the joy, emotional reactions and fulfillment a system provides. UX design therefore integrates user interface design, engineering, visual design, product design, marketing and branding, as well as business models and related considerations.

5.3.2 User-Centered Design Process

Good UX design does not just happen. Like engineering practice, UX design follows a principled and systematic process. At the center of the design process are users—typically a set of anticipated user populations and stakeholders. While different methodologies follow slightly different steps, generally the user-centered design process consists of three phases—research, design, and evaluation—with projects typically going through multiple iterations of the user-centered design process to iteratively refine designs and better align them with user needs.

5.3.2.1 UX Research: Understanding Context of Use and User Needs

UX design starts with research and analysis. The goal of this phase is to understand the context in which a certain system and its UX will operate and function. An important aspect of this is identifying a system's user populations and then analyzing their specific characteristics and needs as they relate to both the system and its context of use. This often

includes learning about people's mental models of systems or processes to identify and understand potential misconceptions.

Common user research methods and activities include semistructured interviews, diary studies, contextual inquiries, survey research, and usability tests with the current system or related competitors. User research is typically complemented by desk research, involving competitive or comparative analysis, heuristic evaluation, and review of relevant academic research and literature. Personas, scenarios, user journeys, and affinity diagrams are tools used for synthesizing findings into higher-level insights that can be used and referenced throughout the design process.⁵⁸

Based on the research findings, the requirements for the UX design are defined. This includes specifying which user needs and goals must be addressed to be successful, including respective metrics. Design requirements have to consolidate potentially contradicting user needs, business goals, and regulatory requirements.

Conducting UX research is quite comparable to conducting a privacy risk analysis or privacy impact assessment (PIA), despite the focus on the user versus on privacy. Like a PIA, UX research requires planning to ensure specific activities are generating relevant information and are comprehensive.⁵⁹ Both a PIA and UX research require identification and consultation of relevant stakeholders. A PIA includes mapping out a system's information flows; UX research involves mapping out users' journeys and interactions with a system. A PIA assesses and identifies privacy risks; UX research identifies user needs and usability issues. A PIA provides recommendations for mitigating privacy risks; UX research produces design requirements to meet user needs and mitigate usability issues. The parallels between PIAs and user-centered design go even further. Just as a PIA is not just "done," but is a continuous or recurring process in which PIA documentation is updated and adapted according to changes to the system, UX research is also iterative, accompanying development and deployment of systems. These similarities provide opportunities for integrating UX research aspects into privacy risk assessment and management and vice versa.

5.3.2.2 UX Design: Meeting User Needs

The requirements identified in the research phase inform the design phase. UX design aims to find and create solutions that meet user needs, as well as other system requirements. Good UX design takes users' cognitive and physical characteristics into account. UX design is highly iterative and user centric. Solutions are developed in an iterative process that aims to put potential solution designs into the hands of users early on and throughout the refinement process to ensure designs properly support user needs. Designs typically start with very basic prototypes, often sketches and paper prototypes, which look far from the final product but make it possible to simulate and test interaction flows before investing time, effort, and resources in further development. This facilitates creative exploration of the solution space—including unconventional, novel ideas—in relatively little time and at low costs. The fidelity of prototypes increases throughout the design process as ideas from

different designs get consolidated or trimmed away based on feedback gained through user testing, until the final design is fully implemented.

Good practice in UX design is to leverage established best practices—design patterns—when possible and appropriate. Design patterns encapsulate reusable solutions for common UX challenges. Leveraging established design patterns or language can substantially ease learnability because people are already familiar with a certain interaction. However, design patterns are patterns rather than off-the-shelf solutions, which means they typically have to be adapted to a system’s specific context of use and UX requirements.

While we discuss elements of privacy design patterns in section 5.4, unfortunately, we do not yet have a good set of tested design patterns for privacy interfaces to recommend. There are certainly many widely replicated design patterns for privacy interfaces across many products and websites, but some of these suffer from fundamental usability problems.⁶⁰ For example, many cookie banners ask users to accept a website’s use of cookies without actually offering a choice. This could be considered a forced-action deceptive pattern. Other cookie banners provide unequal options paths in which users can “accept all cookies” with a single click but rejecting cookies requires following a link to a cookie settings page. Concerningly, many of these deceptive cookie banners have been created with popular consent management tools, which underlines the importance of carefully vetting products offered by privacy solution providers for deceptive designs.⁶¹ Better cookie banners either provide an informational notice without requiring user consent or offer users meaningful and equally accessible choices. So, while we suggest looking for privacy patterns that you might replicate, choose your patterns carefully. Once you have designed and tested a privacy interface within your organization, try to use the same pattern when a similar interface is needed for your organization’s other products and services.

5.3.2.3 UX Evaluation: Validating that User Needs Are Met

Throughout the design process, designs should be iteratively evaluated with current or future users of a system. As such, the design phase and the evaluation phase are closely interlinked. The purpose of UX evaluation is to validate that the system’s designs and prototypes indeed meet the user needs and requirements identified in the research phase. Evaluation methods are often the same or similar to the user research methods mentioned in section 5.3.2.1, with the addition of A/B testing and production deployment of developed solutions. UX validation may include both quantitative assessments, e.g., log file analysis, interaction times, success rates, and qualitative assessments, e.g., perceived usability, perceived cognitive load, joy of use, comprehension, with both providing important insights to evaluate and further refine designs and potentially the design requirements. We discuss common user research methods for evaluating privacy user experiences and interfaces in section 5.5.

5.3.3 Value-Sensitive Design

An important realization for designing privacy interfaces and user experiences that meet people's privacy needs and address their privacy concerns is that privacy constitutes a *value*, i.e., privacy is considered important by individuals and society, but it also competes with other values and norms.

Value-sensitive design is a design approach that accounts for ethical values, such as privacy, in addition to usability-oriented design goals.⁶² Value-sensitive design methods help to systematically assess the values at play in relation to a specific technology and respective stakeholders and the ways the technology might meet or violate those values. They also help to iteratively develop designs that are sensitive to and respectful of those values. Batya Friedman et al. recommend the following steps to integrate value sensitivity into design practice in their article "A Survey of Value Sensitive Design Methods."⁶³ As you will note, many of the steps are also relevant in privacy risk impact assessments, as well as in UX research and design in general. The difference is value-sensitive design places not just people and their needs but also values important to them at the center of the design process.

1. Clarify project values. What values do a project and the project team aim to support? What do privacy, informed consent, transparency, or other privacy-related values mean for this project and team?
2. Identify direct and indirect stakeholders. A value-sensitive approach to stakeholder analysis aims to identify stakeholders directly impacted by technology, e.g., data subjects and data processors, as well as those that are indirectly affected, e.g., bystanders incidentally recorded by the sensors of a self-driving car passing by or other household members that may use a smart home device or be recorded by its sensors. Privacy needs and expectations may also vary based on stakeholders' characteristics and group identities. Individuals may be part of multiple stakeholder groups.
3. Identify benefits and harms for stakeholders. What are the potential benefits or harms for each identified stakeholder group? Benefits and harms should be considered on an individual, societal, and environmental level. This analysis can include both conceptual and empirical investigations, e.g., semistructured interviews or other user research methods. In interviews, a simple but illuminating practice is to ask why when people express positive or negative sentiments about a system or design to more deeply understand their reasoning, motivations, or concerns.
4. Identify and elicit potential values. Identified benefits and harms are a starting point for identifying corresponding values. This mapping can be straightforward, e.g., unanticipated data-sharing practices that affect privacy. But they can also be

indirect, e.g., surveillance practices may have a chilling effect, curtailing people's self-expression.

5. Develop working definitions of key values. Define what constitutes a specific value and spell out the components that make up the value to operationalize it for a specific context. For instance, on the one hand, informed consent is composed of discovery, processing, and comprehension of information and, on the other hand, voluntariness, comprehension, and agreement.⁶⁴ Rather than inventing new definitions for important values, it is useful to rely on prior definitions and research in the literature to more deeply understand a value and its components.
6. Identify potential value tensions. Values do not exist in isolation and frequently conflict with each other, as well as with other requirements. However, value tensions rarely pose binary tradeoffs. For example, “you can have security or privacy, but not both.” Rather, they may place constraints on potential designs. For example, “how might we satisfy the security requirements while also respecting the privacy requirements.”
7. Value-oriented design and development. Value-sensitive design focuses not just on the design of technology but rather on the co-evolution of technologies and social structures. In the case of privacy, this means considering the interplay of technological solutions, regulatory solutions, and organizational solutions and their social impacts when trying to resolve identified value tensions. The implications of technologies on values can be investigated early in the design process through value-oriented mockups and prototypes that are evaluated or potentially deployed with users. The ability to iteratively address and refine technologies and user experiences to align with stakeholders' values can be supported by building flexibility into the technical architecture so necessary changes can be made easily.

5.4 Design of Privacy Interfaces

While the previous section provided an overview of UX design more generally, we now focus on the design of user experiences specifically for privacy. We first discuss prevalent types of privacy interfaces, followed by common usability issues of privacy interfaces, before describing principles for usable privacy design and a process for implementing those principles in design and engineering practice.

5.4.1 Types of Privacy Interfaces

From an information-processing perspective, the data life cycle consists of multiple phases: data collection, data processing, data retention, data transfer, and data deletion.⁶⁵ From a UX

perspective, these phases need to be accompanied with privacy interfaces that implement established privacy principles and user rights:

- **Transparency:** About data collection, processing, and sharing practices, as well as privacy and security measures taken to protect user data and information about who in an organization is responsible for privacy oversight and how to file complaints. Transparency is typically addressed through privacy notices.
- **Choice:** Regarding nonessential data collection, processing, and sharing practices, including secondary uses of data. Choice is typically provided through consent interfaces.
- **Control:** Over the use and exposure of data, e.g., to other users on a platform. User control is typically provided through privacy settings.
- **Access:** To the data an organization has about a user to facilitate inspection, correction, deletion, and export of that data. User access is typically provided via privacy dashboards and data subject access requests.

Next, we provide an overview of common privacy interface types for each category.

5.4.1.1 Privacy Notices

Privacy notices aim to provide transparency about an organization's data practices and other privacy-related information, such as measures taken to ensure security and privacy of users' information. Privacy notices explain what information about data subjects is being collected, processed, retained, or transferred for what purpose. Laws and regulations in different countries may pose specific transparency requirements in terms of what information needs to be provided, when it needs to be provided, and how it needs to be provided. Privacy notices can take different shapes and forms:

- **Privacy policies:** Privacy policies are probably the most common type of privacy notice. A privacy policy holistically documents an organization's data collection, processing, and transfer practices and also includes other privacy-related information. While most common, privacy policies are also among the most ineffective privacy user interfaces. Most people do not read privacy policies, as they have little incentive to do so. Privacy policies are typically long documents. McDonald and Cranor estimated in 2008 that reading all privacy policies of the websites an American internet user visits in a year would take about 244 hours.⁶⁶ Thanks to the proliferation of mobile apps, wearables, and Internet of Things (IoT) devices since then, the number of privacy policies one would have to read and the actual time required for that are likely much higher today. Privacy policies further require advanced reading skills due to heavy use of legal jargon and often remain at

an abstract level, especially when organizations use a single privacy policy to cover a multitude of services or products with many different data-processing practices. Thus, even if a user reads a privacy policy, they may not understand what and how data about them is actually collected, used, or transferred in the context of a specific transaction. Finally, the effort required for reading and understanding a privacy policy is rendered useless when privacy policies also contain provisions that the policy may be updated at any time.⁶⁷

- **Informational privacy resources:** Organizations often complement privacy policies with informational resources that summarize or highlight important data practices and aim to communicate the value and role privacy plays for the organization to its users. These resources educate users about how their data is used and protected, as well as what privacy choices and settings are available to them. The content should be consistent with the organization's privacy policy but presented in a more accessible and easier to understand manner for a general audience, often with visual aids or videos. Videos, for example, have shown to be an effective complement or alternative to text-based privacy notices.⁶⁸ While they are better at informing users about data practices than privacy policies, these informational privacy resources still need to be actively sought out by users, which means most users will not see them.
- **Integrated privacy notices:** Privacy policies and privacy information resources are often decoupled from a user's interactions with a service and product, meaning a user must seek them out to learn the pertinent information. Integrated privacy notices are instead presented in a relevant part of the service or product's UX. For instance, an account creation process may include short explanations about how requested information, such as email addresses, will be used and protected.
- **Privacy indicators:** Privacy information can also be conveyed via privacy indicators, which are cues in a user interface or on a device. Privacy indicators are particularly useful for conveying either the state of a data practice, e.g., an LED indicating when a video camera is recording, or the state of a privacy setting, e.g., a small icon in a social media site's message posting interface indicating the post's audience.
- **Privacy reminders:** Organizations may choose or be required to remind people about data practices they are subject to. For instance, financial institutions in the United States are required to provide an annual privacy notice to their customers under the Gramm-Leach-Bliley Act (GLBA). However, privacy reminders can also take a more proactive shape and make users aware of data practices they had previously agreed to or nudge them to check and update their privacy settings.

5.4.1.2 Consent Interfaces

User consent is an established way to legitimize a data practice. To be valid, consent needs to be a freely given, specific, informed, and unambiguous indication of an individual's agreement.⁶² Individuals need to be provided with sufficient information to make a consent decision, and it must be equally possible to agree or disagree. Consent interfaces typically need to enable users to provide or deny initial consent as well as check their consent status and possibly change it, which may mean revoking consent.

Consent interfaces generally exist for two kinds of consent: opt-in consent and opt-out consent. In the case of an opt-in, consent is obtained before a data practice takes place, i.e., the data processing the consent request pertains to does not start until the data subject explicitly consents. In the case of an opt-out, the respective data practice occurs as if the data subject had provided consent. A person's use of a service or product is assumed to be an expression of agreement with the respective data practices. An opt-out then is an option for the individual to stop a certain data practice. Opt-in consent can serve to make users aware of a data practice for which they have a choice they might otherwise not be aware of. Opt-outs carry the risk of a user not being aware of a data practice and being surprised or angry when they find out the data practice had been going on without their awareness or agreement.

Consent interfaces can be implemented in many different ways—most privacy settings are also consent decisions of some kind—but there are some general types of consent interfaces that can be distinguished:

- Integrated consent prompt: Opt-in consent requests are typically integrated into a system's user experience. Examples include requests to accept a product's terms of service or privacy policy before use, or checkboxes to opt into data use for nonessential purposes during account creation. Requiring users to uncheck prechecked boxes to opt out of a data practice during setup is a discouraged deceptive design pattern. The risk is that people may overlook the option or see it as a recommendation and continue without properly considering it. While this might mean more people allow a data practice, i.e., they do not uncheck the prechecked box, it is useless as a documentation of informed consent because it cannot be guaranteed that a user made an actual decision to allow the practice.
- Decoupled opt-out: Opt-outs might be decoupled from a user's interaction with a system, e.g., when they are described in a privacy policy in separate advertising or cookie policies, or as part of privacy settings. The challenge with decoupled opt-outs is people have to seek them out and may not be aware of their existence or of the data practice they pertain to.
- Integrated opt-out: Certain opt-outs are integrated with the user experience. One example is an "unsubscribe" link in email communication. The advantage of integrated opt-outs is their presence in the context in which people might need and want to use them

- Delegated consent: Sometimes consent is not directly obtained by the first party but rather by a different service or platform provider. One example for delegated opt-in consent is a mobile permission. Apps do not directly ask users for access to resources like location, contacts, and text messages on the smartphone but instead programmatically declare required permissions to the smartphone. The smartphone operating system then generates a respective permission prompt, asking the user to accept or deny a permission request. An advantage of this model is that the presentation and functionality of permission requests are consistent across apps, which facilitates learnability of the interface and the types of permissions the user might get prompted for, and reduces cognitive load. An example of delegated opt-outs are opt-outs for ad targeting, which are often provided by third parties—either a specific ad company like Google or Meta, or an industry association such as the Digital Advertising Alliance (DAA), Network Advertising Initiative (NAI), and the Interactive Advertising Bureau (IAB). A challenge with such delegated opt-outs is that the first party has little control over the usability of the consent mechanisms.

5.4.1.3 Privacy Settings

Privacy settings typically aggregate the privacy choices and controls available to a user of a given product or service in one place. Privacy settings are typically available from within account settings or referenced in the privacy policy, ideally both. Privacy settings interfaces can integrate a multitude of controls, including controls to inspect and change previously made consent decisions, settings to regulate the granularity of information, settings to regulate the visibility of one's information (e.g., what information is public, visible to friends, or private), and settings to manage the sharing of information with users or with other apps or services. We distinguish two types of privacy settings:

- First-party privacy settings: Privacy settings commonly refer to settings made available by the service provider or product manufacturer. The service provider controls what settings are made available, how they are made available, and how they are integrated with the overall UX.
- Platform privacy settings: What information an app or service has access to is also often controlled by the privacy settings of the respective platform used to provision the service, such as a mobile operating system for mobile apps, a smart assistant platform for voice-based skills or actions, or a web browser. Platform privacy settings may be specific to a certain service or app, e.g., app X can access location while app Y can't, or may allow users to set general privacy settings, e.g., whether third-party cookies are accepted or tracking protections are enabled.

5.4.1.4 Privacy Dashboards

Privacy dashboards typically give users access to the data an organization has about them. This may be in the form of activity timelines, data summaries, or access to the actual data. Privacy dashboards should further provide support for other mandated data subject rights, such as enabling users to correct data or request rectification of inaccurate data. Users should further be able to export their data as well as delete some or all of it.

Often, privacy dashboards not only facilitate data access, editing, deletion, and support but also include all an organization's privacy settings, and possibly privacy information resources and privacy policies, to create a single destination for users for all things privacy.

5.4.2 Common Usability Issues of Privacy Interfaces

While privacy interfaces for transparency, control, and support of different user rights exist, many privacy interfaces still fail to help people make informed decisions with respect to the collection and processing of their personal information.⁷⁰ This is problematic not just for consumers but also for organizations, as it may lead to users being surprised by unexpected data practices and dissatisfied by frustrating user experiences, foster general distrust in the company, and lead to scrutiny by regulators or data protection authorities (DPAs). Many usability problems of privacy interfaces can be traced back to several common issues.

5.4.2.1 Conflating Compliance and User Needs

Frequently the creation of privacy interfaces, including privacy notices, controls, and privacy settings or dashboards is driven by the goal of achieving compliance with respective legal and self-regulatory requirements. As a result, privacy interfaces, and in particular privacy policies, are created in a way that will demonstrate compliance to regulators. In turn, regulators such as DPAs or consumer protection agencies rely on an organization's privacy notices and controls in their investigation and enforcement of regulatory compliance.⁷¹ Unfortunately, users' privacy needs are often neglected in the process. Privacy notices are written by lawyers for lawyers, resulting in lengthy privacy policies or terms of service that are unnecessarily complex because the respective laws, regulations, and business practices are complex.⁷² In addition, organizations may create purposefully vague policy statements to create leeway for potential future uses of collected data, which make notices even more difficult for users to understand.⁷³ Privacy notices are not written as tools for creating awareness and transparency for users. Similarly, privacy controls are implemented to meet regulatory requirements, but may not be sufficient to provide the level of control users need. Yet, those privacy notices and controls are treated as if they do provide transparency and control to users.

Designing for users' privacy needs does not require neglecting or ignoring regulatory requirements. Rather, it is essential to distinguish between the information that must be provided for compliance reasons and the information that users might need to make informed privacy decisions. They are sometimes the same, but often not. As users are unlikely to read privacy policies, relevant information needs to be provided to them through

additional means to reduce surprise. Similarly, privacy controls and choices required by regulation must be provided in a usable and useful manner. Furthermore, additional privacy controls may be necessary to ensure users can control privacy in alignment with their context-specific privacy preferences and expectations.

5.4.2.2 Lack of Meaningful Choices

Too often users are forced to make impossible choices: either accept everything in the terms of service and privacy policy or not use the service or product. Such take-it-or-leave-it choices are bad for both consumers and organizations. Consumers might accept the terms of service or privacy policy but are unlikely to have read or understood them. This fosters surprise about unexpected data practices and privacy harms, which can result in outcries on social media and in the press, which can lead to consumer distrust, damaged reputation, and possibly investigations by regulators for deceptive practices or violations of transparency requirements if user awareness of a practice is not a reasonable expectation.

Additionally, forcing users to accept data practices they disagree with, because they otherwise cannot use a service or product, fosters digital resignation.⁷⁴ If you rely on consent as the legal basis for processing, it is important to ensure that consent is specific, informed, and freely given.

5.4.2.3 Poor Integration with UX

Privacy notices and consent prompts are often shown at inopportune times, without regard for the user's primary task. Providing users with all privacy-relevant information when downloading an app or signing up for a service is common practice but futile from a UX perspective. When a consumer decides to download an app or sign up for a service, they do so because they want to use the app or service, and anything delaying use—such as asking to accept a long privacy policy or configuring privacy settings—is likely to be dismissed or accepted quickly without much scrutiny. Privacy management is almost always a secondary task, which means privacy interfaces need to be designed to augment the primary UX rather than blocking it.

In addition, repeated exposure to seemingly irrelevant privacy notices or dialogs results in habituation. This means that people dismiss the notice or prompt automatically without its content even registering in their cognitive processing system.⁷⁵

5.4.2.4 Poor Discoverability

Often privacy notices, opt-outs, and other controls are decoupled from a system's primary UX. This dissociation of privacy interfaces from a system has severe usability consequences. Without being exposed to privacy interfaces as part of the system's UX, users require substantial digital literacy and an advanced mental model of how a certain technology works to anticipate a system's data practices and what privacy information or privacy controls might be available to them.⁷⁶

Furthermore, if a user wants to seek out privacy information or controls, they must know where to look. However, where privacy information and controls are provided is not consistent across services and products. Some might have account settings that include privacy settings, some might have separate privacy settings, and others might have privacy settings but also provide additional privacy-related controls under other settings or in policy documents.⁷⁷ As a result, people may have to look in multiple places, search in the wrong places, or, even worse, assume they found all relevant privacy controls without realizing additional controls are provided in another place.⁷⁸

5.4.2.5 Confusing Interfaces

When privacy interfaces are not designed carefully, they may be confusing and suffer from usability issues that could have been uncovered through user testing. Some common issues include wording or signage, e.g., an icon, that is confusing or ambiguous, privacy choices and opt-outs with unclear effects, or privacy controls that behave contradictory to expectations.⁷⁹

5.4.3 Privacy Design Principles

Following a set of privacy design principles and a systematic process makes it possible to design privacy user experiences that are usable, useful, and meet users' needs for information and control while also being compliant with privacy laws and regulation.⁸⁰

5.4.3.1 User Centric

Privacy legislation, privacy technology, and privacy management are centered on information. What information flows and practices are permissible? How can information be protected, deidentified or processed to enhance privacy? What information does the organization collect, store, process, and transfer? What safeguards and processes are in place to ensure accountability and compliance with internal and external policy? Designing usable and useful privacy user experiences, however, requires a shift in focus. While information is of course still relevant, the focus needs to be on users and their interactions with a system's privacy interfaces. Privacy design must be user centric to be effective.

A user experience is successful when it meets users' needs. For privacy interfaces, that means first understanding what the privacy needs of different stakeholders and user populations are, both their informational needs and their control needs. Identifying those needs requires investigating and understanding people's privacy preferences, concerns, and expectations with respect to a specific information system. It further requires understanding users' mental models of the technology, its data practices, and its privacy protections. Such insights help determine what information may be necessary to help users make informed decisions or create awareness of otherwise unexpected data practices. Furthermore, it is important to understand users' privacy control needs in terms of managing privacy toward the organization and toward other users on multiuser platforms, as well as to regulate the visibility of their data.

When designing privacy notices and controls, it is helpful to be aware of how humans receive, process, and react to information. Michael Wogalter's communication-human information processing (C-HIP) model explains how humans perceive, process, and react to warnings.⁸¹ The human in the loop (HILP) model adapts the C-HIP model for security and privacy.⁸² These models describe a similar progression of steps in human information processing, which, if not considered properly, can present a hurdle for a privacy interface in achieving its goal. The key steps of the information processing model as they pertain to privacy are as follows:

1. **Communication:** Human information processing begins with how information is communicated to a person. A user interface aims to communicate something to the user, e.g., certain privacy information or the availability of a privacy control. This communication may be affected by environmental stimuli that compete with the privacy interface. For example, a user's primary task or other interface elements or system features may make it difficult to notice the privacy control. Interference may prevent users from even receiving the communication. For instance, being distracted by other activities, people nearby, or ambient noise when privacy information is shown, e.g., in a video may cause a user to miss it.
2. **Attention:** Users need to notice the privacy interface before they can process it. Thus, effective communication must get users to switch their attention to the privacy interface and maintain the attention long enough to process it. Environmental stimuli, interference, and characteristics of the communication, meaning how it is presented and delivered, affect attention switch and maintenance. Habituation also impacts attention, i.e., the effect of a stimulus decreases over time. For example, presenting too many or repetitive privacy notices to users will likely result in them ignoring the notice content.
3. **Comprehension:** Once users notice an interface, they need to understand its purpose. What is it there for and what is it communicating to the user? A person's digital literacy and privacy awareness may affect how they interpret provided privacy information or controls. Are they aware of the privacy risks and implications associated with the options presented in a consent prompt? How accurate is their mental model of the system's data practices and privacy protections?
4. **Intention:** Based on a user's comprehension of the interface, they may or may not be motivated to act upon the provided information or engage with a privacy control. The user's intention is further affected by their privacy preferences, concerns, and expectations.

5. Behavior: As discussed in section 5.2, actual privacy behavior can deviate from the user's respective privacy decision. Usability issues with the presentation of privacy settings and controls can further result in users making errors.

User-centric design of privacy interfaces should consider how to best support each of these phases. When analyzing usability issues of privacy interfaces, it is further helpful to isolate which information processing phases are affected to address them properly.

5.4.3.2 Relevant

Most privacy policies are ineffective at supporting privacy decision-making because they aim to provide a complete and comprehensive overview of an organization's data practices. While such an overview is useful for regulators and researchers to analyze an organization's data practices, it holds little value for most consumers. Consumers are asked to complete a complex cognitive task in trying to map a policy's abstract descriptions of data practices to the specific context and transaction in which they are engaging with an organization.

To be useful for privacy decision-making and behavior, privacy information and controls need to be relevant to the user's specific context or transaction. For example, for someone visiting a news website for the first time, there is very little use in reading the news site's privacy policy completely. At this point, it would not be relevant to them how the news site uses contact information provided during account setup, how financial information provided when signing up for a subscription is processed and secured, or what data is transferred when one enters a sweepstakes the news site might offer with a marketing partner. Instead, when visiting the news website without an account, it would be most relevant to the user whether the news site tracks what articles are being read, how that information is used, such as for site analytics or ad targeting, whether and which third-party trackers are present on the news site, and whether there is an option to opt out of such tracking. However, finding these pieces of information in a privacy policy is tedious because the information is often organized around data practice categories, e.g., collection, use, and sharing, rather than common types of interaction contexts, e.g., news reading without an account, account creation, site use with an account, subscriptions, or sweepstakes.

While organizing information in a privacy policy according to typical user contexts might be helpful, the information or controls that are relevant to a particular context should be provided within the respective user experience. This does not mean every part and step of a system's user interface should be covered in privacy policy text. Instead, relevant information and controls should be easily accessible from within a context and organized according to the steps in user journeys typical for different user populations.

Furthermore, the information and controls provided to users should support their understanding of specific data practices. Rather than providing abstract descriptions, privacy notices should be as explicit as possible about what information is specifically being collected, processed, or shared in a given context or transaction; why this data practice is

necessary and how it benefits the data subject, if at all; and what controls are available regarding the practice. Ideally, privacy notices and controls would not just be specific to a data practice but also to the individual user. In “Using Personal Examples to Improve Risk Communication for Security & Privacy Decisions,” Marian Harbach et al. proposed improving mobile permission dialogs by including personal examples from the user’s phone of what an app would gain access to if a request were granted. For example, a location request would show the current location, a photo access request would show thumbnails of a random selection of the user’s photos.⁸³ Following this approach, location permission requests in iOS 14 and later include the user’s current location on a map and visualize the effect of granting access to precise location data.

Users should also be informed about potential privacy risks associated with certain data practices. While it might seem counterintuitive to emphasize risks associated with one’s system—organizations like to highlight the benefits of their products, not associated risks—openly communicating risks can have multiple advantages. First, some users might be thinking of risks anyway, but may overestimate them. Open risk communication can help users calibrate their risk assessments. Second, users who are not aware of the risks might be surprised and angry if they find out about or are affected by them later. Open risk communication can help mitigate surprise and help shape users’ mental model of a system. Third, openly communicating risks is also an opportunity to actively communicate the protective measures put in place to mitigate risk and protect the user’s privacy.

5.4.3.3 Understandable

When presenting privacy information or providing privacy controls, it is important for the information and controls to be understandable by the users they are targeting. This UX best practice is starting to find its way into privacy regulation. For instance, the GDPR requires “any information and communication, where processing is addressed to a child, should be in such a clear and plain language that the child can easily understand.”⁸⁴

In practice, understanding privacy policies frequently requires advanced reading skills. In 2019, as part of their Privacy Project, *The New York Times* analyzed the privacy policies of 150 popular websites and apps.⁸⁵ They found that most analyzed policies required college-level reading skills. To put this into perspective they compared the reading skills required for privacy policies with those of popular books. Most of the analyzed policies required higher reading skills than are necessary for understanding Stephen Hawking’s *A Brief History of Time*—a book about the space-time continuum. Some policies even exceeded the reading level required to understand Immanuel Kant’s *Kritik der reinen Vernunft* (*Critique of Pure Reason*)—a foundational work in Western philosophy. Privacy policies are also too long to be useful for consumers. A longitudinal analysis of the 500 most popular websites in each EU member state, over 6,750 websites total, found privacy policies were on average 3,044 words long after the GDPR went into effect in May 2018— 42% longer than in 2016 when the GDPR was ratified.⁸⁶

Clearly, users cannot be reasonably expected to fully read the privacy policy of each service, website, or app they use. Instead, by focusing on providing user-centric information that is relevant to a user's specific context, transaction, or activity, the provided information can be much shorter and more specific, and thus also more understandable. Such information would complement the privacy policy rather than replace it, which would also mean the privacy policy could be written specifically for regulators and privacy experts without negatively affecting users.

User-centric privacy notices, such as integrated privacy notices and informational privacy resources, should be written in simple language that is understandable without advanced reading skills, avoiding legal and privacy jargon. For reference, in health care, it is recommended that patient educational materials should be written for sixth- to eighth-grade reading skills.⁸⁷ The readability of documents, including privacy notices, can be tested with online readability checkers, such as Readable.com.

5.4.3.4 Actionable

To be useful, information needs to be actionable.⁸⁸ It is typically not advisable to give users a privacy notice without an associated action or choice. While privacy information can support users in making more informed privacy decisions, as well as help correct potentially misaligned mental models or expectations, without something to do with that information, there is not much point in the increased awareness. Users have little incentive to engage with provided information unless there are also options for them to realize their privacy decisions. Therefore, privacy information and privacy controls should go hand in hand whenever possible.

The choices offered also need to be meaningful. Asking users to accept an entire privacy policy is not a meaningful privacy choice. Rather than providing users with agency over their privacy, it asks them to either not use the system or accept even if they disagree with statements in the privacy policy.

Instead, users should be given the option of making choices regarding specific data practices, and any kind of feature limitations due to the user's choice should be constrained to the immediate context of that choice. A reasonable example of this is mobile permissions in recent mobile operating systems. Users are presented with a concise prompt when an app wants to access a phone resource like location, contacts, or photos for the first time. Users have the option to allow or deny the request and can continue to use the app even if they select "deny," possibly with the exception of certain features. On the other hand, the privacy "nutrition labels," recently introduced in the iOS and Android app stores, have been criticized for offering no direct links to permission interfaces or other privacy controls.⁸⁹ Ideally, a privacy choice or prompt asks users to make a meaningful decision by providing them with options. Prompts that ask for confirmation only increase the risk of habituation—users clicking the prompt away without reading it—which in turn makes it difficult to rely on their action as an expression of freely given and informed consent.

5.4.3.5 Integrated

Privacy information and controls should be integrated with a system's primary user experience rather than added on. Relevant information should be provided at points in a system's user experience where users actually make privacy decisions, or where it might be important to make users aware of data practices or privacy risks to help them develop an accurate mental model of the system and its information flows. Similarly, privacy controls and indicators should be available at interaction points when they matter. For example, seeing and controlling a social media post's audience when writing the post.

Whenever possible, privacy interfaces should use the same interaction methods as the system's primary UX. This ensures interacting with privacy interfaces feels natural in a system's context and is as easy as any other user interaction with the system. For example, when designing privacy controls for a voice-controlled system such as a smart assistant, privacy controls like "mute" should also be available as voice commands because the user otherwise needs to make a shift in interaction modality, by walking to the device and pressing a physical mute button instead of speaking to the device, that deviates from their typical interaction with the system and may therefore be rarely used.²⁰

Furthermore, privacy information and controls that are integrated into the user experience can be more concise—both in terms of presented information and choices—than privacy policies and privacy settings because they can rely on the user's interaction context to contextualize the presented information for the user. The proper integration of privacy interfaces into the overall user experience can help prevent overloading users with information or presenting privacy prompts at inopportune times.

However, while integrated privacy interfaces are important, a system should still provide a privacy policy, informational privacy resources, privacy settings, and privacy dashboards in a centralized place so users and regulators can gain a more comprehensive overview of data practices or verify and adjust their privacy settings in a central place when necessary.

5.4.4 Privacy Design Process

To put the privacy design principles into practice, it helps to follow a systematic privacy design process. We discuss a general process that combines UX, PIA, and value-sensitive design.²¹ This process consists of six steps:

1. Build on privacy assessment, privacy management, and privacy engineering practices to systematically identify a system's user rights and transparency requirements.
2. Identify users and their privacy needs by identifying stakeholders and eliciting their privacy expectations and privacy concerns, as well as their privacy information and privacy control needs.

3. Identify unexpected data practices, those that users are unaware of or might be surprised by, to help prioritize which data practices and controls to highlight.
4. Integrate privacy interfaces into a system's user experience by determining which privacy notices and controls are most relevant to a user at which points in the user experience.
5. Leverage the available design space for privacy notices and controls to develop user-centric privacy interfaces that work within a system's constraints.
6. Conduct user testing to evaluate the usability and usefulness of developed privacy interfaces.

Next, we describe each step in detail and provide practical guidance. The process can and should be adapted to the needs and circumstances of your organization, systems, and users.

5.4.4.1 Build on Privacy Assessment, Privacy Management, and Privacy Engineering Practice

The essential precursor for designing usable and useful privacy user experiences is a solid understanding of the system's information flows and data practices, as well as the associated privacy implications. Organizations should conduct PIAs, risk assessments, and compliance checks with internal policies and external regulation as part of their internal privacy programs. Such assessments can provide a comprehensive overview of a system's data practices. The recommendations resulting from a PIA or privacy risk analysis may include proposed changes to data collection practices, opportunities for data minimization, or a requirement for opt-in consent for a certain data-sharing practice. Data minimization helps reduce the risk of using data in ways that deviate from users' expectations. You cannot misuse data you do not collect or retain. Diligent data minimization can further reduce the number or complexity of data practices that need to be communicated to users.

PIAs and compliance checks can also help systematically identify the user rights and transparency requirements pertaining to the system, which are important for the privacy design process. The outcome of a PIA is typically internal documentation of information flows, data inventories, and a comprehensive privacy policy for a product or the organization. While privacy policies are likely not read by users, they can serve as input for designing user-centric privacy notices and controls. Importantly, PIAs and privacy policies are just the starting point for designing user-centric privacy interfaces.

Considering the privacy implications of a system and associated transparency and privacy control needs early in a system's development also provides an opportunity to consider and improve constraints the system might pose for privacy interfaces. For example, recognizing that a smart home camera is collecting potentially sensitive information, the device designers may decide to include a recording indicator and a physical lens shutter in the device's

hardware design rather than trying to provide notices and controls solely through software at a later stage.

5.4.4.2 Identify Users and Their Privacy Needs

A common part of PIAs is the identification and consultation of stakeholders whose privacy may be potentially impacted by a system. This can be combined with identifying a system's different types of users and eliciting their privacy expectations and concerns, as well as their privacy information and privacy control needs. For the design of privacy user experiences, it is important to distinguish at least three groups of users:

- **Primary users:** These are a system's intended audience. The primary user would make the decision to use a certain system and complete an enrollment process, e.g., account setup or configuration wizard, and would be able to configure the system. This may include agreeing to the terms of service, activating, or consenting to certain optional practices, e.g., activating face recognition for a smart home camera, opting out of certain practices like analytics, and adjusting privacy settings. For websites and mobile apps, the primary user would be the person using the browser or downloading the app. For IoT devices, it would be the person setting up the device.
- **Secondary users:** These are other people who may use a system in addition to the primary user. Secondary users might be aware of a system and even actively use it, but they may have an incomplete or inaccurate mental model of the system and its data practices and less control over it compared with the primary user. Examples of secondary users would be a child using a parent's smartphone to play a game or stream a video, or a household member using a smart speaker associated with the device owner's account or a smart thermostat that has been configured by someone else. Secondary users may need to be informed about data practices, or even offered controls, in addition to and in different ways from the primary user.
- **Incidental users:** Other people might inadvertently and unwittingly become data subjects of a system's data collection and processing. For example, a smart door lock might collect information about all family or household members, including guests.²² House guests may be required to use a smart speaker to operate smart lights in the house.²³ Doorbell cameras, drones, or self-driving cars might incidentally record people passing by. Social media and mobile apps enable users to share information with and about others, e.g., by uploading a geotagged photo or video of someone else without their knowledge. Incidental users may not always be identifiable by a system, which constrains the potential means for providing them with privacy notices and controls.

Depending on the system, other or additional user groups may need to be considered. There may also be specific regulatory requirements for data collection, notice, and user rights regarding protected user groups, such as children.

System designers and privacy pros need to understand how the privacy of each identified user group may be affected by the system. Often a system's user groups are affected by the same data practices. For example, a smart home device may record the same sensor information about the primary user and other household members. However, sometimes user groups may be affected by different data practices, or certain groups may only be affected by a specific data practice. For example, a smartphone's data practices affect mainly the primary user and possibly secondary users, whereas incidental users may only be affected if they are being recorded by the device, for instance, when a primary or secondary user takes a photo or video.

Next, it is important to understand each group's privacy preferences, concerns, expectations, mental models, and control needs regarding the system and its data practices. This information can be gained by conducting user studies, which we discuss in more detail in section 5.5, and potentially through reviewing academic literature that has investigated privacy preferences of specific user groups in specific contexts.

5.4.4.3 Identify Unexpected Data Practices

A particular focus when seeking to understand users' mental models and privacy preferences should be to identify which of the system's data practices people are unaware of and might be surprised about. Knowledge about unexpected practices helps determine what information and controls need to be presented more prominently in the user experience. Data practices that are consistent with the transaction context, and therefore with the user's expectations, might not require immediate notice. However, practices that are unexpected or violate the transaction context should be highlighted. For example, in "How Short is Too Short?" Joshua Gluck et al. studied which of a fitness watch's data practices people expected. One finding was that, at 94%, almost all participants expected the watch to record steps, but only 31% expected the watch to also record location information. Recording steps is a key purpose of such a device and may not need to be specifically highlighted, whereas collection of location data was unexpected for many, indicating a need for user-centric privacy notices focusing on this aspect.²⁴ Making people aware of unexpected practices and ideally asking for opt-in consent reduces surprise and can potentially increase user trust.

Making users aware of an unexpected data practice is also an opportunity to explain the reasons for the practice, its benefits, and the associated privacy risks.²⁵ It also provides an opportunity to communicate what measures are put in place to limit associated privacy risks and protect user privacy. Privacy and security engineering often happens under the hood—privacy UX design is an opportunity to make the care and effort an organization puts into privacy and data protection concrete.

5.4.4.4 Integrate Privacy Interfaces into System's UX

Once information has been gathered about the system's data practices, its user groups, and the practices that might be more or less expected by different user groups, the next step is to decide when and where to integrate privacy notices, consent prompts, and other privacy interfaces into the system. Showing lots of information and controls at once in a single interface is rarely effective. Instead, the goal is to map specific privacy information and controls onto points in the system's user experience where they are most relevant to the user and where an opportunity exists for the privacy interface to gain the user's attention. Such privacy interfaces can be more concise and require less interpretation by the user because they are integrated into the user's interaction with the system, which makes them less disruptive. This might mean providing certain information and controls at multiple interaction points and with varying levels of detail.

The level of detail provided in a specific notice or control must be appropriate for the respective context and user group. However, notices and controls can be *layered*. A short notice may highlight a practice, fact, or control to gain the user's attention and provide a link to additional information or more controls, which in turn might consist of multiple layers users can reveal and explore as needed. In UX design, this design pattern, called "details on demand," provides an overview or summary first with options for users to retrieve details.²⁶ Thus, rather than trying to provide a single notice or control that does everything, it is better to craft a privacy user experience composed of many complementary privacy notices and controls at different levels of detail tailored to the respective user group and interaction context.

A privacy user experience combines privacy interfaces shown at different times, using different modalities and channels, and varying in terms of content and granularity in a structured approach. With such an integrated and multilayered approach, individual users still receive information and choices for data practices that pertain to them but won't be confronted with irrelevant data practices until they are using a respective feature of the system. Users should still have the option to read the full privacy policy and explore all privacy settings whenever they want.

Deciding what information or controls to include in a brief integrated notice presented as a top layer is a crucial aspect at this stage, because most users will not seek out more detailed privacy interfaces, even if they are referenced and only a click away. Thus, if such a short notice does not capture all relevant aspects of a data practice, it may hide information and impair transparency.²⁷ This is especially an issue for unexpected data practices. Therefore, privacy interfaces should be hierarchically structured in such a way that the initial notice, prompt, or control either already captures the main aspects of the data practice or serves primarily to draw the user's attention to more expressive privacy interfaces. For instance, in a study on mobile app privacy nudging, Hazim Almuhiemedi et al. showed just notifying smartphone users about how often their location has been accessed by different apps is

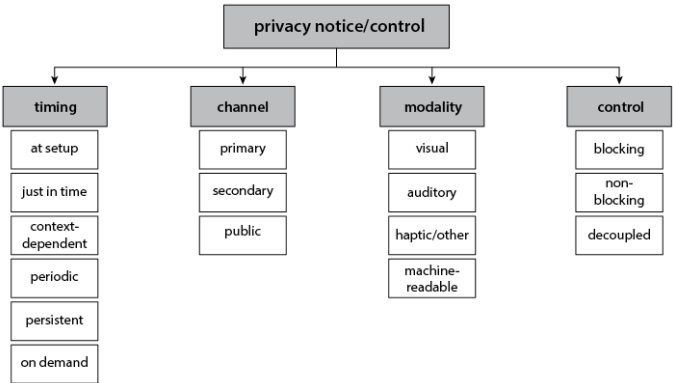
already an effective nudge for users to check and adjust their permission settings.⁹⁸ In contrast, a privacy policy that only shows section headings and requires users to click each heading to read the text is a bad design, because it requires users to make many more clicks and prevents keyword search.⁹⁹ A more effective approach in this context would be to summarize a section’s key data practices and respective choices and provide a “learn more” button to reveal all the details.

Creating and maintaining a privacy user experience composed of multilayered privacy interfaces does incur engineering and management costs, but it has multiple benefits. Users’ privacy needs and the system’s data practices can be better aligned. Where user consent is required, this approach can yield properly informed consent. Reducing surprise and explaining privacy protections is likely to facilitate user trust.

5.4.4.5 Leverage the Available Design Space

Once which information or controls need to be provided at which points in a system’s UX have been decided, the next step is the actual design of the user-centric privacy interfaces. Multiple aspects can impose constraints on the design of the privacy user experience. A system has certain input and output modalities, which can affect how different user groups can or cannot be provided with privacy information or express their privacy choices.¹⁰⁰ For instance, many IoT devices have no screens or only very small ones that may not be suitable for displaying privacy information or controls. However, a system and its context may also offer unconventional interaction opportunities for privacy interfaces. Identifying constraints and considering the full design space for privacy interfaces helps generate different design ideas for a privacy interface and identify viable solutions. Based on an extensive analysis of the design space for privacy notices and controls, in “A Design Space for Effective Privacy Notices” Florian Schaub et al. identified four design dimensions that should be considered in privacy interface design.¹⁰¹ The design space with its main dimensions and their design opportunities is shown in Figure 5-1. We next provide a short overview of each design dimension and respective key considerations.

Figure 5-1: The design space for privacy notices and controls



5.4.4.5.1 Timing

The point in time at which privacy information or controls are presented to the user has a substantial impact on a privacy interface's usability and utility. Users may ignore privacy interfaces shown at inopportune times but may seamlessly interact with a consent prompt that appears exactly when it is needed. Timing is a key factor in ensuring a privacy interface is relevant and aligned with users' needs.

- **At setup interfaces:** These are often shown on initial use. However, only information and choices that are truly essential before use should be communicated at setup time because users' attention is typically focused on the primary user experience at this point. Those privacy information and choices that must be presented at setup should be properly integrated into the setup process (e.g., a configuration wizard or account enrollment) in a way that provides value and meaning to users rather than nudging them to accept a privacy policy or terms of service they have likely not read in detail.
- **Just-in-time interfaces:** These are shown in the same transactional context as the data practice they pertain to, which supports reasoning in the moment and means they can be specific and short, communicating only the most relevant information and choices.
- **Context-dependent privacy interfaces:** These are triggered by certain aspects of the user's context.¹⁰² For instance, being in physical proximity to an IoT sensor may cause the device to announce its presence, such as by flashing an LED, beeping, or sending a description of its data practices to the user's phone. Other context factors might be someone accessing previously uploaded information or analyzing the user's previous privacy settings behavior to warn about potentially unintended privacy settings. For example, Facebook used to display a message warning users that they are about to post publicly when their last post was public, but they are typically not in the habit of posting publicly.
- **Periodic reminders:** These are useful to remind users about data practices that they agreed to previously and to renew consent if the practice is still ongoing, especially if the data practice occurs in the background, invisible to the user.
- **Persistent privacy indicators:** These are shown whenever a data practice is active. For instance, cameras often have lights to indicate when the camera is on and recording. Persistent indicators can provide an unobtrusive cue about especially critical data practices, but there's also a risk the indicator will not be noticed.¹⁰³
- **On-demand privacy information and controls:** These allow users to seek out and review privacy information or their privacy settings and opt-outs any time. On-demand interfaces should be made available in a well-known or easily findable location. For example, a website should have a "privacy" subdomain or "privacy/"

folder and provide links to privacy controls from their privacy policy and in relevant menus.

5.4.4.5.2 Channel

Privacy interfaces can be delivered through different communication channels.

- **Primary channel:** This is the primary device or system the user interacts with, such as a smartphone or computer. It is also the system primarily involved in the respective data practice, e.g., collecting, storing, or processing the data.
- **Secondary channels:** These are useful when the primary system is too constrained in its input and output capabilities to provide for meaningful interaction with the privacy interface. Typically, a secondary channel presents information on a different device or in a different context. For instance, privacy information and settings for a smart watch, smart speaker, or robot vacuum might be available through a companion app or website. Emails, mobile notifications, and even letters can also serve as secondary channels for privacy communication.
- **Public channels:** These can be used when the system's users or data subjects cannot be reached individually or are not known to the system. For example, public signs can be posted to inform about camera use or other sensing technology in a certain environment.

5.4.4.5.3 Modality

Privacy interfaces can be presented in different ways, with different interaction modalities.

- **Visual privacy interfaces:** These are most common. Privacy notices are presented as text or with icons and illustrations; privacy controls rely on graphical user interfaces. Many aspects can affect the usability of visual privacy interfaces, including color, font, white space, combinations of icons and text, layout of interface elements, and how the state of settings is conveyed. Privacy concepts are difficult to represent as icons only, so combining icons with explanatory text or using more expressive visualizations and videos is preferable.¹⁰⁴
- **Auditory privacy interfaces:** These use sounds or voice to convey privacy information, or voice commands to enable privacy controls. Certain sounds can convey data collection practices very effectively. Take, for example, a camera's shutter click, which is replicated by digital cameras and smartphones to indicate when a photo is taken, even though those devices do not have a physical shutter.¹⁰⁵ Support hotlines often play an auditory notice before one is being connected with a human operator. For example, "This call may be recorded for quality assurance purposes."

- **Haptic and other modalities:** These may also be leveraged as privacy interfaces. For instance, device vibration could be used as an indicator for data collection. Olfactory displays could be used to inform about privacy risks with different scents, e.g., lavender scent when visiting a privacy-friendly website versus sulphur when visiting a privacy-invasive one. Ambient lights could also serve as privacy indicators. Could taste or skin conduction be used in privacy interfaces? Although it might not be immediately apparent how less conventional modalities could be used for privacy interfaces, the important point is to creatively explore even unconventional design opportunities. Such exploration often leads to helpful insights that can inform practical solutions.
- **Machine-readable specifications of privacy notices and controls:** These enable the consistent presentation and aggregation of privacy information and controls from different systems or apps.¹⁰⁶ Mobile apps have to declare their permission requests in a machine-readable format, and the mobile operating system is responsible for providing permission prompts and managing the user's consent. IoT devices that lack screens and input capabilities could broadcast their machine-readable privacy notices to the smartphones of nearby users, which then present the respective privacy information and choices to the user.¹⁰⁷

5.4.4.5.4 Control

User choices, consent dialogs, and privacy settings can be delivered in different ways that affect how users interact with them.

- **Blocking privacy controls:** This forces users to interact with the privacy interface in order to be able to proceed. Blocking controls are useful when the user must make a choice, e.g., when consent is needed. However, how choices are presented affects whether the interaction is actually an expression of the user's preference, and so should be considered carefully. For example, presenting a complex privacy policy and providing only the options to accept or not use the app is not suitable for eliciting consent, as users are likely to click the warning away without reading. Preferable are prompts that are specific to a single data practice or group of related practices and provide options to both allow or deny the practice e.g., mobile permission requests. All choices should be equally easy for the user to exercise.
- **Nonblocking privacy controls:** These do not interrupt the interaction flow but are rather integrated as user interface elements into the user experience. For example, social media apps might provide an audience selector, e.g., private, friends, or public, within the interface for creating a post. The control is available but does not have to be used and, at the same time, reminds the user of their current privacy settings.

- Decoupled privacy controls: These are not part of the primary user experience. They are useful to give the user the opportunity to inspect their privacy settings or the data the system has collected about the user. Common examples are privacy settings and privacy dashboards. The advantage of decoupled privacy controls is they can be more comprehensive and expressive than integrated controls. The downside is users need to actively seek them out. Good practice is to provide decoupled privacy controls at a central place and then point to them from other, more concise privacy notices and controls where appropriate.

Frequently, multiple kinds of privacy notices and controls need to be combined in a multilayered privacy user experience to properly address the privacy information and control needs of a system's user groups.

5.4.4.6 Global privacy interfaces and localization

A further consideration, in particular with globally operating websites, services, or apps, is what privacy information and controls are required by privacy laws in different jurisdictions. Based on a user's location, estimated based on their IP address or determined based on address/region information in their user account, privacy information and controls can be tailored to specific local requirements. A less complex solution, when possible, can be to incorporate requirements from different jurisdictions into the design of the privacy interfaces made available to all users.

In addition to compliance with local laws and regulations, it is also important to consider whether and how sociocultural norms and privacy expectations might be different in different regions or countries and account for how the privacy information, controls, and interfaces are provided.¹⁰⁸

Whether and how to provide privacy information and controls in the user's local or preferred language is an additional consideration.¹⁰⁹ When a website, service, or app supports multiple languages, respective translations also need to be created for privacy information and controls and incorporated into the products' localization system.

5.4.4.7 Conduct User Testing

Privacy user experiences should be developed in a user-centric and iterative design process. Potential users should be involved in the design process from the beginning to account for user needs and to evaluate whether developed privacy notices or controls are usable. Privacy interfaces can be evaluated individually, such as by asking whether users understand a particular consent prompt, but the privacy user experience should also be evaluated holistically to gauge whether the combination of privacy interfaces appropriately serves users' needs and how the overall privacy user experience affects user trust in the system and its handling of users' personal information.

5.5 Usability Testing and User Studies for Privacy

Usability testing and user studies are a staple of both research and product development. Many books and guides have been written about how to conduct user studies. In this section, we provide a brief overview of the what, why, and how of user testing and user studies as they relate to privacy. Our goal is to convey the importance of user studies for the design of privacy interfaces and give privacy pros the necessary knowledge to effectively collaborate with UX professionals to design appropriate privacy studies.

5.5.1 Why Test Usability?

Usability testing and user studies play several important roles: they can help assess needs, examine tradeoffs, evaluate designs, and find root causes of problems.

At the beginning of a design process, exploratory user studies can inform design requirements by providing feedback on which user needs are not being met by existing systems, as well as identifying users' pain points and points of confusion. For example, before designing a privacy dashboard, a user study can help designers gain insights into what data users are most interested in seeing and at what level of granularity, as well as what types of controls users are most interested in exercising. Furthermore, designers may learn whether they are likely to satisfy most of their users with a single interface, or whether special interfaces might be needed for certain populations such as advanced or novice users.

Designers often face tradeoffs, and user studies can help provide insights into the pros and cons of each approach under consideration. For example, designers may realize more granular privacy controls may increase the complexity of privacy choices. Through usability testing, they can gather data that will allow them to weigh the benefits of providing more granular controls against this added complexity. They can observe whether users actually take advantage of the added granularity to adjust settings that best match their personal privacy preferences. They can also observe how much longer it takes users to configure the controls and how often users give up because the controls are too complicated.

While following established usability guidelines and principles is likely to improve usability, the only way to be sure a system is actually usable by its intended audience is to conduct usability tests with representative users. Thus, usability testing is critical for determining if a design actually meets its stated requirements. Before declaring that their privacy settings allow users to exercise privacy choices quickly and easily, organizations should run usability tests to assess whether users can find privacy settings (discoverability), use them to select the settings that match their personal preferences, and understand the effect of the settings they selected.

Finally, after discovering a usability deficiency, usability testing is useful to determine the underlying cause of the problem, which will hopefully lead to solutions. For example, a company may receive complaints from users that their privacy settings are not working. After determining there is no underlying technical problem, the company may conduct user

studies to understand how users believe the privacy settings are supposed to work and where their mental models differ from what the system actually does. This should provide insights that will allow the company to redesign its privacy settings to better align with users' expectations and privacy control needs or to communicate its current function more clearly.

5.5.2 What to test?

The details of what to test depend on the type of system being tested and when in the design process the test is being conducted. Exploratory testing early in the design process may be less about testing a user interface and more about understanding users' preferences, expectations, concerns, and mental models. Once a prototype or complete interface has been developed, testing will generally focus on the following: awareness and attention, discoverability, comprehension, utility, and behavior. However, testing may also investigate learnability, efficiency, memorability, errors, satisfaction, and other aspects of UX and information processing phases discussed in sections 5.3.2 and 5.4.3.

5.5.2.1 Preferences, Expectations, Concerns, and Mental Models

As discussed earlier, privacy preferences, expectations, and concerns collectively impact a user's privacy decision-making. In turn, they may impact the types of privacy features and controls users seek out or the types of explanations or assurances needed to ensure users' concerns are addressed. Surveys, semistructured interviews, and focus groups can all provide insights into users' privacy concerns and needs in a specific context. It can be valuable to conduct these exploratory studies early in the design process.

Numerous papers in academic research literature explore users' privacy preferences, expectations, concerns, and mental models generally, and in the context of specific technologies like behavioral advertising, health technology and IoT.¹¹⁰ Such research papers can provide insights to inform the design of privacy interfaces, supplementing or possibly even eliminating the need for exploratory studies in a specific design process.

5.5.2.2 Awareness and Attention

As we discussed earlier in this chapter, following the C-HIP and HILP models, our first big hurdle is getting the user's attention. A just-in-time privacy notice, a privacy-related warning, or an ambient privacy indicator are all useless to users who do not notice them or even briefly shift their attention to them. User studies can test whether users notice privacy-related notices, indicators, or controls as they carry out a primary task. For example, Rebecca Balebako et al. developed a mobile game app and created versions that differed only in when the privacy notice was presented to users, as described in "The Impact of Timing on the Salience of Smartphone App Privacy Notices." They asked study participants to test the app and answer questions about it, including questions about the privacy notice. The timing of the privacy notice presentation impacted whether users paid attention to and thus could correctly answer questions about the privacy notice.¹¹¹

5.5.2.3 Discoverability

Users who want to obtain information about data practices or make privacy choices need to be able to find the relevant interfaces. User studies can test the discoverability of privacy interfaces by evaluating whether users are able to find them at all, and if so, whether they can do so easily and efficiently. For instance, in a study of opt-out and data deletion choices on websites, Hana Habib et al. found opt-out choices placed in account settings were easier for participants to locate and use compared to choices only described in the privacy policy.¹¹²

5.5.2.4 Comprehension

Users may notice privacy indicators or find privacy interfaces, but they may not fully understand what they mean or how to use them. User studies can test comprehension of wording, symbols, interface components, and controls, either in isolation or in the context of relevant tasks. Comprehension testing is often iterative, as designers identify comprehension problems and then test alternative wording or symbols.

Pedro Leon et al. conducted a study to determine what users understood about the AdChoices behavioral advertising icon and associated taglines. They found comprehension rates were low overall, but that some of the taglines they tested resulted in significantly better comprehension of the icon.¹¹³ Using a similar approach, Habib et al. evaluated in a series of studies the effects of different icon and tagline combinations for the CCPA's "Do Not Sell My Personal Information" opt-out link. They found icons that were designed to convey 'choice' led to fewer misconceptions about the opt-out link than icons that tried to convey 'privacy' or 'sale of information.'¹¹⁴

5.5.2.5 Utility

Privacy notices may be discoverable and comprehensible, but they may still leave out important information or settings that users want. For a privacy notice or settings interface to provide utility, it must be aligned with user needs. User studies can help assess the utility of privacy interfaces. Exploratory user studies may also help identify desired utility early in the design process. For example, Pardis Emami-Naeni et al. asked IoT device owners about their device purchase experience, as well as their privacy and security concerns, and showed them early prototypes of privacy and security labels for IoT devices to explore whether the labels' information would address their needs. They found participants were especially interested in information about their privacy choices and wanted to see a summary rating, as well as detailed privacy and security information.¹¹⁵

5.5.2.6 Behavior

Users who discover and comprehend privacy indicators or warnings may still fail to act for a variety of reasons. Users may lack motivation, feel their actions will be ineffective, have concerns that privacy protective steps will be inconvenient or result in their inability to use desired features or services, or be uncertain about what to do. Even those who do act may still make mistakes, such as by pressing the wrong button or forgetting to press a final "submit"

button, rendering their action ineffective. Likewise, users presented with privacy controls may also make mistakes as they attempt to configure the controls to match their personal preferences.

Ed Hutchins, Jim Hollan, and Don Norman identified two common underlying challenges that lead to configuration mistakes in *User Centered System Design*: understanding the state of the system, or the “gulf of evaluation,” and taking action to accomplish a specific goal, or the “gulf of execution.”¹¹⁶ When users fail to understand the current state of the system, their decisions about what settings to change are based on faulty assumptions. An example of the gulf of evaluation may be a user examining a mobile app privacy setting, incorrectly interpreting the on/off toggle, and thus believing location tracking has been turned off when in fact it is on. Likewise, when users fail to take the correct actions, they will not achieve their desired goals. Thus, a user who clicks an opt-out button on a website but does not scroll to the bottom of the page and click the submit button will fail to achieve the desired goal of opting out due to the gulf of execution.

User studies can test both whether users take privacy actions and whether they execute these actions correctly and effectively to achieve their desired goals. For example, Serge Egelman et al. tested several approaches to providing privacy indicators on websites to determine which had the largest impact on user behavior, shown in “Timing Is Everything? The Effects of Timing and Placement of Online Privacy Indicators.” They found privacy indicators had the largest impact on user behavior when they appeared alongside search results rather than on an interstitial web page or at the top of a web page.¹¹⁷ In addition, when Leon et al. tested whether users could set up behavioral advertising opt-out tools to achieve a desired result, they found most users struggled to configure these tools. They recommended several design improvements to address the problems they observed, including removing jargon, adding more privacy-protective defaults, and providing feedback about what the tool does.¹¹⁸

5.5.3 How to Test?

UX professionals employ many different testing techniques that vary considerably in cost, time, and effort to complete, as well as the types of insights and conclusions they produce. The most appropriate testing may depend on where you are in the design process, available time and resources, and the reason for testing. For example, is testing being done primarily to improve an interface, to validate that an interface improves on a prior version or a similar product, to address regulatory requirements, or to produce generalizable knowledge that can be published in academic research papers?

5.5.3.1 Formative and Summative Evaluations

Usability evaluation can be categorized as either “formative” or “summative.”¹¹⁹ Formative evaluations are used to gain insights into which aspects of a prototype or product could use improvements, while summative evaluations are used to draw comparisons between a

prototype or product and some benchmark such as a previous version or competing product. Generally, formative evaluations are small scale and focus on gathering rich qualitative insights that can be used to improve a product. They may be conducted iteratively, with several rounds of evaluation and design changes. Summative evaluations are generally conducted once the design team believes they are done or even after the product has shipped. They are generally larger studies that focus on gathering quantitative data. Summative studies are usually done to validate that the product meets the design requirements or performs better than a previous version or competing product. Companies may make claims about their product based on these results. For example, a company may be able to show, compared with the prior version, the current version of their product allows users to opt out of behavioral targeting 50% faster or the new version improved the percentage of users who could correctly identify the audience of their social media posts from 40% to 80%.

5.5.3.2 Small-Scale User Testing

Small-scale testing often provides a large bang for your buck, especially when used as part of a formative evaluation. Relatively inexpensive and quick, a test with even a handful of users can offer important insights about where a user experience may need improvement. Such testing may uncover user concerns and confusing interfaces and help highlight differences in user attitudes and uses of a set of features or products. Small-scale user testing is often done in a lab or remotely via video conferencing so an experimenter can directly observe how a user interacts with an interface and ask follow-up questions. Sometimes the experimenter may ask users to think aloud during a test and provide a real time, blow-by-blow commentary of what they are thinking and doing.¹²⁰ This can be useful for capturing users' impressions and points of confusion as they try to understand and use a new interface. A related method is participatory design or codesign, in which UX designers work with affected stakeholders to identify and develop design solutions that better meet users' needs.¹²¹ Rather than only eliciting needs from users and then evaluating new designs with them, users actively contribute to the design.

Small-scale testing can be quite useful for exploratory studies and iterative design improvements. However, it generally cannot be used to validate a property of an interface or to make statistical claims.

5.5.3.3 Online Panels and Crowdsourcing Services

Recruiting large numbers of participants for a user study can be time consuming and expensive. Research companies maintain long-standing online panels of people who agree to receive emails recruiting them to participate in online surveys. Often these panels are comprised of people who have been screened for particular characteristics such as age range, gender, occupation, and geographic location. Researchers can pay to access these panels to recruit participants for their studies. Some organizations maintain their own in-house panels,

recruited from users of a particular product or members of a university community, for example.

Crowdsourcing platforms such as Amazon Mechanical Turk allow people to sign up as workers and perform tasks for pay, generally at minimum wage. These platforms can be a quick and inexpensive way to recruit participants for online surveys and other online user studies. If you use these services, you need to be especially careful about how you screen participants for desired attributes and make sure they do not just randomly click through your survey to get a quick payment. Some crowdsourcing services such as Prolific and CrowdFlower have been shown to deliver more diverse participants and achieve higher-quality survey results than Mechanical Turk.¹²²

While people often think about using panels and crowdsourcing services primarily for surveys, they can also be used for online user testing. If you can make relevant parts of a user interface available through a web interface or an instrumented download, you can ask participants to perform tasks using your interface, collect data about how they use it, and ask them questions afterwards. Services such as UserTesting.com specialize in unmoderated online user testing of interfaces and user experiences.

5.5.3.4 A/B testing

A/B testing refers to tests in which some users of a product or service see version A and others see version B. Generally, there are small differences between A and B, and some metric to compare the two. For example, A and B may differ based on the placement of buttons, wording of menu items, colors, page layout, graphics, or presence of a particular feature. This type of testing is not actually limited to two versions—companies may test many versions in a similar fashion. This testing may be done with users of a deployed service, who generally are not aware they are part of a test.

In the context of privacy, A/B testing might be used to test the impact of interface changes on the time users spend engaging with privacy settings, or the percentage of users who change privacy settings or opt out. For example, delivery company DHL used A/B testing to explore cookie banner design options.¹²³

5.5.4 Usability Testing Best Practices

Regardless of what type of usability test you choose, it is important to keep some best practices in mind. Here, we discuss testing metrics related to privacy, ways to provide a realistic context, sometimes using deception, and strategies for recruiting study participants. We conclude with a brief discussion of ethical considerations for usability testing and user studies.

5.5.4.1 Metrics

Before testing begins, it is important to identify a set of metrics to use. Metrics might relate to any of the areas discussed in section 5.2, including discoverability, awareness, comprehension, utility, behavior, and satisfaction. For example, when testing a privacy tool

or interface, metrics might include the speed with which users complete a task, number of errors made while completing a task, and accuracy of users when answering questions about the meaning of symbols or other interface components. Other relevant metrics include the percentage of users who exercise privacy choices and the types of choices they make. Choosing the right metrics is important for conducting a meaningful evaluation that is free of blind spots. You do not want to conclude that an interface is wonderful because it performs well on a particular metric you tested, while in reality it would perform horribly on several other highly relevant metrics you did not evaluate.

Besides identifying metrics, you should identify desired outcomes or objectives that will allow you to determine whether design requirements have been met. For example, one objective may be to increase speed by a specific percentage over the prior version. Another objective may be to reduce the error rate.

Measuring the effectiveness of consent or opt-out interfaces poses challenges. The percentage of users who consent or opt out is not an indicator of the effectiveness of the interface. What we really want to capture is user awareness and comprehension of choices, and whether they successfully select options that align with their personal preferences. One way to measure this is to survey users shortly after they engage with a consent interface to find out what they believe they consented, or chose not to consent, to and how this aligns with their preferences. Hana Habib and Lorrie Faith Cranor presented a framework for evaluating the usability of privacy choice mechanisms that encompasses twenty-seven specific evaluation criteria and offers examples and research method recommendations for each. These evaluation criteria address seven aspects of usability relevant to privacy choice interfaces: user needs, user ability and effort, user awareness, user comprehension, user sentiment, decision reversal, and nudging patterns.¹²⁴

Metrics regarding user privacy behavior may be difficult to agree upon, especially when they conflict with other values in an organization. For example, a privacy objective may be to increase the number of users who visit the privacy settings page and make changes to their settings. However, when users choose more privacy-protective settings, companies may lose opportunities to profit from user data. Thus, meeting privacy objectives may appear to conflict with meeting revenue objectives. On the other hand, users who select privacy-protective settings might be less likely to trust a company or may decide to take their business elsewhere if such settings are not available. Companies need to consider these issues and resolve internal tensions between privacy and business goals.

5.5.4.2 Ecological Validity, Context, and Deception

“Ecological validity” refers to the realism of the methods, materials, and setting of a user study or usability test. The most reliable results are obtained through field testing. In field tests, designs are evaluated as part of a production system. The advantage of field testing is that new designs are tested under real-world conditions with real users rather than artificial lab conditions with recruited participants. However, this also limits them to the late stages of

the design process, when a design has sufficiently matured to be used in production systems without placing users at risk or creating liabilities for the organization.

To observe the most natural behavior from non-field-study participants, studies should be designed to mimic the real world as much as possible. Thus, when studies are conducted in a lab, the lab may be set up to look like an office or living room, complete with relevant props. For example, when evaluating privacy settings related to smart home devices, conducting the study in a homey living room setting may elicit the types of privacy concerns and behaviors participants would exhibit when using these devices in their own homes.

One component of ecological validity is the context in which user study tasks are embedded. If a study participant sitting in a usability lab is shown a privacy policy or any other privacy interface and asked questions about it without being provided any context or reason for wanting to read the policy, the resulting usability evaluation will lack ecological validity. In this case, participants may pay more attention to the policy than they would in real life, when privacy is likely not their primary concern. Thus, comprehension testing without a real-world context will likely result in a best-case scenario. Awareness and behavior testing are difficult to conduct meaningfully without embedding tasks in context.

To evaluate a privacy interface in context, participants should be given a relevant task. For example, participants might be told a friend who is concerned about their privacy has asked for help in selecting an email service provider. In “Privacy as Part of the App Decision-Making Process,” Patrick Gage Kelley et al. evaluated prototype “privacy facts” labels in an app store by asking participants to select apps for a friend. They compared the selections made by participants who either used an app store that had privacy facts labels or did not, as a control condition. They found the privacy facts labels generally influenced which apps were selected. However, other factors also played a role, and sometimes had more of an influence than privacy.¹²⁵

Often context is provided by embedding study tasks in hypothetical scenarios such as those previously mentioned. However, participants may not be motivated to behave realistically in a hypothetical scenario, especially one in which they have to imagine a particular privacy or security risk.

Studies may use distraction tasks to focus participant attention on a task not related to privacy and observe their response to privacy-related prompts incidental to the assigned task. For example, Habib et al. conducted an online study in which they asked crowd workers to test a new e-commerce website, place items in their shopping cart, and then answer survey questions. When participants first visited the website, they were greeted with one of a dozen cookie banners, which were the interfaces the researchers were actually testing. The researchers collected data on the cookie choices participants made and asked survey questions to measure comprehension of banner information and sentiment toward the banners.¹²⁶

Sometimes study designs employ “deception” to increase ecological validity and observe how users behave when simulated privacy or security risks are introduced. For example, as outlined in “Your Attention Please: Designing Security-Decision UIs to Make Genuine Risks Harder to Ignore,” Cristin Bravo-Lillo et al. advertised a study evaluating online video games to crowd workers. Participants played and evaluated two games on real gaming websites not controlled by the experimenters. When they tried to play a third game, a simulated security warning appeared in their browser window. The researchers collected data on how participants responded to the warning and compared results across several warning designs.¹²⁷ In this case, there was deception about the purpose of the study and deception about the warnings, which were designed to appear real even though they were triggered by the experimenters. The deception was needed to observe participants’ natural behavior when confronted with warnings they believed were real and not a part of the experiment. Section 5.5.4.4 addresses ethical issues to consider when conducting deceptive studies, such as the need for debriefing participants.

5.5.4.3 Testing with Representative and Specific User Populations

The strategy used to recruit study participants can have a large impact on results, especially when conducting small-scale studies. The age, gender, race, socioeconomic status, digital literacy, technical skills, geographic location, cultural background, and other characteristics of study participants influence their privacy needs, behaviors, and responses to survey questions.

When conducting a user study, it is tempting to reach out to a convenient sample of coworkers, friends, or family. This can be useful for pilot testing, to test out and refine the study design before recruiting real participants, or to help detect problems with a product or service, and it is better than not doing any user testing. However, for the most useful evaluation, testing should be conducted with a representative sample of current or anticipated users of a product or service, or with specific populations that are of interest. Sometimes, it is helpful to recruit participants who represent particular types of users who may have special issues or represent extreme ends of a user spectrum. For example, a social media company that is aware older adults are now flocking to social media services may conduct a study to assess the privacy needs of adults over age 60 and how they use the service’s privacy settings. Likewise, a company developing a privacy tool for extremely privacy-conscious users should test the tool with those types of users.

When recruiting participants for privacy-related user studies, it is advisable to not mention privacy in the recruitment materials. Privacy is a contentious topic that can lead to self-selection bias. People who already have an interest or opinion regarding privacy will respond, but those who prefer to ignore the topic will not. However, the latter group can often provide more useful insights. Good practice is to be vague about the specific focus of the study in recruitment, for example by calling it a “study on mobile app use”.

Researchers sometimes conduct studies in which they aim to recruit a random, representative, census-balanced sample of a country's population. This is important if you want to make claims about the entire population of a country, such as "50% of all Americans believe..." However, these studies tend to be expensive to conduct, and this type of sampling is generally not necessary for usability tests. Nonetheless, it is generally useful to seek diverse participants and make sure your sample is somewhat balanced in terms of age, gender, race/ethnicity, and other factors, such as technology experience and general privacy attitudes.

5.5.4.4 Ethical Considerations

Depending on your country's legal requirements, corporate or institutional policies, and the type of testing, you may or may not be required to have your study reviewed by an ethics board or institutional review board (IRB) prior to beginning a usability study. In the United States, university research that involves identifiable individuals or their information and is designed to contribute to generalizable knowledge must be reviewed by an IRB. Research intended for publication is usually classified as contributing to generalizable knowledge, while research intended to guide the development of a specific product or conducted as part of a classroom exercise is usually not.

Even if not required to have a usability study reviewed by an ethics board or IRB, the user study team should still consider ethical issues in their study design. Studies should be designed to minimize the possibility of harm to participants and to treat participants fairly and with respect. If identifiable data is collected only to contact or pay participants, it should be separated from study data. Participants should be able to end their participation at any time and for any reason without penalty. The study team should generally obtain informed consent from participants prior to collecting their data. There are situations where this is not feasible because of concerns about priming participants or because the study uses previously collected data. In cases where consent is not obtained in advance or where deception is used, the study team should debrief participants about the study's true purpose, its conclusion, and offer them an opportunity to withdraw their data from the study without penalty.

While most usability studies related to privacy pose minimal risk to participants, some study techniques have the potential to cause harm and should be considered carefully. For example, a privacy study that collects sensitive data from participants, perhaps to motivate privacy concerns, could increase the risk that participants' information will be exposed. A deceptive study that simulates security or privacy warnings may leave participants uncertain about whether they have actually been the victim of an attack or breach. These participants may suffer from added anxiety and unnecessarily take steps to reset passwords, cancel credit cards, or otherwise recover from an attack that did not actually occur. Study teams should take precautions to minimize these and other harms, for example by establishing data security protocols and debriefing participants at the end of a study session.

5.6 Summary

This chapter provides an overview of people's privacy decision-making processes and common usability issues in privacy interfaces. We present design principles and a systematic process for creating privacy interfaces that can help avoid usability issues. We further discuss best practices for conducting usability testing and user studies related to privacy.

The design of usable privacy notices and controls is not trivial, but this chapter explains why it is important to invest effort in getting the privacy user experience right—making sure privacy information and controls are not only compliant with regulations but also addressing and aligning with users' needs. Careful design of the privacy user experience can support users in developing an accurate and more complete understanding of a system and its data practices. Well-designed and user-tested privacy interfaces provide responsible privacy pros and technologists with confidence that an indication of consent was indeed an informed and freely given expression by the user. Highlighting unexpected data practices and considering secondary and incidental users reduces surprise for users and hopefully prevents privacy harms, social media outcries, bad press, and fines from regulators. Importantly, a privacy interface is not just a compliance tool but rather an opportunity to engage with users about privacy, explain the rationale behind practices that may seem invasive without proper context, make users aware of potential privacy risks, and communicate the measures and efforts taken to mitigate those risks and protect users' privacy.

Endnotes

- 1 Article 29 Data Protection Working Party (WP29), "Guidelines on Transparency under regulation 2016/679," November 26, 2017, revised and adopted April 11, 2018, https://ec.europa.eu/newsroom/article29/item-detail.cfm?item_id=622227.
- 2 See § 999.315(h) in the CCPA Regulations Additional Amendments, March 15, 2021, <https://oag.ca.gov/privacy/ccpa/regs>.
- 3 See for example Kirsten Martin, "The Penalty for Privacy Violations: How Privacy Violations Impact Trust Online," *Journal of Business Research* 82 (2018): 103–116, <https://doi.org/10.1016/j.jbusres.2017.08.034>. See also Batya Friedman, Peter Khan Jr., and Daniel Howe, "Trust online," *Communications of the ACM* 43, no. 12 (2000): 34–40, <https://doi.org/10.1145/355112.355120>.
- 4 In 2019, the Federal Trade Commission (FTC) settled with Facebook on a \$5 billion fine and substantial changes to Facebook's privacy management and compliance structure, "FTC's \$5 Billion Facebook Settlement: Record-Breaking and History-Making," Federal Trade Commission, July 24, 2019, <https://www.ftc.gov/news-events/blogs/business-blog/2019/07/ftcs-5-billion-facebook-settlement-record-breaking-history>.
- 5 Alfred Ng and Megan Wollerton, "Google Calls Nest's Hidden Microphone an 'Error'," *CNET*, February 20, 2019, <https://www.cnet.com/home/smart-home/google-calls-nests-hidden-microphone-an-error/>.
- 6 Hana Habib, Yixin Zou, Aditi Jannu, Neha Sridhar, Chelse Swoopes, Alessandro Acquisti, Lorrie Faith Cranor, Norman Sadeh, and Florian Schaub, "An Empirical Analysis of Data Deletion and Opt-Out Choices on 150 Websites," *Proceedings of the Fifteenth Symposium on Usable Privacy and Security* (2019), <https://www.usenix.org/conference/soups2019/presentation/habib>.
- 7 Yang Wang, Saranga Komanduri, Pedro Leon, Gregory Norcie, Alessandro Acquisti, and Lorrie Faith Cranor, "I Regretted the Minute I Pressed Share: A Qualitative Study of Regrets on Facebook," *Proceedings of the Seventh Symposium on Usable Privacy and Security* (2011): 1–6, <https://dl.acm.org/doi/10.1145/2078827.2078841>.
- 8 Yang Wang, Pedro Leon, Alessandro Acquisti, Lorrie Faith Cranor, Alain Forget, and Norman Sadeh, "A Field Trial of Privacy Nudges for Facebook," *ACM SIGCHI Conference on Human Factors in Computing Systems* (2014): 2367–2376, <https://dl.acm.org/doi/pdf/10.1145/2556288.2557413>.

- 9 Florian Schaub, Rebecca Balebako, Adam Durity, and Lorrie Faith Cranor, "A Design space for Effective Privacy Notices," *Proceedings of the Eleventh USENIX Conference on Usable Privacy and Security* (2015): 1–17, <https://dl.acm.org/doi/10.5555/3235866.3235868>.
- 10 Facebook announced the new audience controls in May 2022. Michel Protti, "Here's What You Need to Know About our Updated Privacy Policy and Terms of Service, Meta, May 26, 2022, <https://about.fb.com/news/2022/05/metas-updated-privacy-policy/>.
- 11 Katie Rogers, "Gmail Formally Adds 'Undo Send' Option," *The New York Times*, June 23, 2015, <https://www.nytimes.com/2015/06/24/us/gmails-undo-send-option-can-help-end-email-embarrassment.html>.
- 12 Kirsten Martin, "The Penalty for Privacy Violations: How Privacy Violations Impact Trust Online," *Journal of Business Research* 82 (2018): 103–116, <https://doi.org/10.1016/j.jbusres.2017.08.034>.
- 13 The OECD Privacy Framework, Organisation for Economic Co-Operation and Development (OECD), 2013, <https://www.oecd.org/internet/ieconomy/privacy-guidelines.htm>; *Privacy Online: A Report to Congress*, Federal Trade Commission, June 1998, <https://www.ftc.gov/sites/default/files/documents/reports/privacy-online-report-congress/priv-23a.pdf>; European Parliament and Council, "Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC [General Data Protection Regulation (GDPR)]," 2016, <http://data.europa.eu/eli/reg/2016/679/2016-05-04>.
- 14 Tamara Dinev and Paul Hart, "An Extended Privacy Calculus Model for E-Commerce Transactions," *Information Systems Research* 17, no. 1 (2006): 61–80, <https://doi.org/10.1287/isre.1060.0080>.
- 15 Pew Research Center, "Public Perceptions of Privacy and Security in the Post-Snowden Era," November 12, 2014, <https://www.pewinternet.org/2014/11/12/public-privacy-perceptions/>.
- 16 Alessandro Acquisti and Ralph Gross, "Imagined Communities: Awareness, Information Sharing, and Privacy on the Facebook," *International Workshop on Privacy Enhancing Technologies*, (Springer: Berlin, Heidelberg, 2006): 36–58, https://doi.org/10.1007/11957454_3.
- 17 Manya Sleeper, Justin Cranshaw, Patrick Gage Kelley, Blase Ur, Alessandro Acquisti, Lorrie Faith Cranor, and Norman Sadeh, "I Read My Twitter the Next Morning and was Astonished," *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems* (2013): 3277–3286, <https://doi.org/10.1145/2470654.2466448>; Wang, "I regretted the minute I pressed share."
- 18 Ashwini Rao, Florian Schaub, Norman Sadeh, Alessandro Acquisti, and Ruogu Kang, "Expecting the Unexpected: Understanding Mismatched Privacy Expectations Online," *Proceedings of the Twelfth Symposium on Usable Privacy and Security* (2016): 77–96, <https://www.usenix.org/conference/soups2016/technical-sessions/presentation/rao>; Hazim Almuhimedi, Florian Schaub, Norman Sadeh, Idris Adjerid, Alessandro Acquisti, Joshua Gluck, Lorrie Faith Cranor, and Yuvraj Agarwal, "Your Location has been Shared 5,398 Times! A Field Study on Mobile App Privacy Nudging," *Proceedings of the 33rd Annual ACM Conference on Human Factors in Computing Systems* (2015), <https://doi.org/10.1145/2702123.2702210>; Joshua Gluck, Florian Schaub, Amy Friedman, Hana Habib, Norman Sadeh, Lorrie Faith Cranor, and Yuvraj Agarwal, "How short is too short? implications of length and framing on the effectiveness of privacy notices," *Proceedings of Twelfth Symposium on Usable Privacy and Security* (2016): 321–340, <https://www.usenix.org/conference/soups2016/technical-sessions/presentation/gluck>.
- 19 Josephine Lau, Benjamin Zimmerman, and Florian Schaub, "Alexa, Are You Listening? Privacy Perceptions, Concerns and Privacy-seeking Behaviors with Smart Speakers," *Proceedings of the ACM Human-Computer Interaction* 2, CSCW, article 102 (2018): 1–31, <https://doi.org/10.1145/3274371>; Alessandro Acquisti, Idris Adjerid, Rebecca Balebako, Laura Brandimarte, Lorrie Faith Cranor, Saranga Komanduri, Pedro Giovanni Leon, Norman Sadeh, Florian Schaub, Manya Sleeper, Yang Wang, and Shomir Wilson, "Nudges for Privacy and Security: Understanding and Assisting Users' Choices Online," *ACM Computing Surveys* 50, no. 3, article 44 (August 2017), <https://doi.org/10.1145/3054926>; Yixin Zou, Abraham H. Mhaidli, Austin McCall, and Florian Schaub, "I've Got Nothing to Lose': Consumers' Risk Perceptions and Protective Actions after the Equifax Data Breach," *Proceedings of the Symposium on Usable Privacy and Security, USENIX Association* (2018), <https://www.usenix.org/conference/soups2018/presentation/zou>.
- 20 Patricia Norberg, Daniel Horne, David Horne, "The Privacy Paradox: Personal Information Disclosure Intentions versus Behaviors," *Journal of Consumer Affairs* 41, no. 1 (2007): 100–126, <https://dx.doi.org/10.1111/j.1745-6606.2006.00070.x>. For more recent overviews of research related to the privacy paradox see Kokolakis, Spyros, "Privacy Attitudes and Privacy Behaviour: A Review of Current Research on the Privacy Paradox Phenomenon," *Computers & Security* 64 (2017): 122–

- 134, <https://doi.org/10.1016/j.cose.2015.07.002>; and Gerber, Nina, Paul Gerber, and Melanie Volkamer. "Explaining the Privacy Paradox: A Systematic Review of Literature Investigating Privacy Attitude and Behavior," *Computers & Security* 77 (2018): 226–261. <https://doi.org/10.1016/j.cose.2018.04.002>.
- 21 Manya Sleeper, Rebecca Balebako, Sauvik Das, Amber Lynn McConahy, Jason Wiese, and Lorrie Faith Cranor, "The Post that Wasn't: Exploring Self-Censorship on Facebook," *Proceedings of the 2013 Conference on Computer Supported Cooperative Work* (2013): 793–802, <https://doi.org/10.1145/2441776.2441865>.
- 22 See Jon Penney, "Chilling Effects: Online Surveillance and Wikipedia Use," *Berkeley Technology Law Journal* 31, no. 1 (2016): 117, <https://ssrn.com/abstract=2769645>; Alex Marthews and Catherine E. Tucker, "Government Surveillance and Internet Search Behavior," (2017), <https://ssrn.com/abstract=2412564>.
- 23 For an overview of a wide range of privacy seeking behaviors see Alessandro Acquisti, Laura Brandimarte, George Loewenstein, "Secrets and Likes: The Drive for Privacy and the Difficulty of Achieving It in the Digital Age" *Journal of Consumer Psychology* 30, no. 4 (2020): 736-758, <https://doi.org/10.1002/jcpy.1191>; For a list of 77 privacy-protective behaviors engaged in by study participants see Table 6 in Jessica Colnago, Alessandro Acquisti, and Lorrie Cranor, "Is there a Reverse Privacy Paradox?" *Proceedings on Privacy Enhancing Technologies*, 2023(1), <https://petsymposium.org/popets/2023/popets-2023-0027.pdf>. Regarding the use of restrictive settings see Mary Madden, "Privacy Management on Social Media Sites," Pew Research Center, February 24, 2012, <https://www.pewresearch.org/internet/2012/02/24/privacy-management-on-social-media-sites/>; Regarding deletion of mobile apps see "Americans' Privacy strategies Post-Snowden," Pew Research Center, March 16, 2015, https://www.pewresearch.org/wp-content/uploads/sites/9/2015/03/PI_AmericansPrivacyStrategies_0316151.pdf; For use of code language see danah boyd and Alice Marwick, "Social Privacy in Networked Publics: Teens' Attitudes, Practices, and Strategies," *Proceedings of A Decade in Internet Time: Symposium on the Dynamics of the Internet and Society* (September 22, 2011), <https://ssrn.com/abstract=1925128>; For consumers' use and effect of Apple Tracking Transparency see Daniel Newman, "Apple, Meta and the \$10 Billion Impact of Privacy Changes," *Forbes*, February 10, 2022, <https://www.forbes.com/sites/danielnewman/2022/02/10/apple-meta-and-the-ten-billion-dollar-impact-of-privacy-changes/>.
- 24 Colnago, Acquisti, and Cranor, "Is there a Reverse Privacy Paradox?"
- 25 The descriptions in Table 5-1 have been updated in 2023 to reflect some of the revisions suggested by Jessica Colnago, Lorrie Faith Cranor, Alessandro Acquisti, and Kate Hazel Stanton. "Is it a Concern or a Preference? An Investigation into the Ability of Privacy Scales to Capture and Distinguish Granular Privacy Constructs," *Proceedings of the Eighteenth Symposium on Usable Privacy and Security* (2022): 331-346.
- 26 For a typology of privacy harms see Danielle Keats Citron and Daniel J. Solove, "Privacy Harms," *Boston University Law Review* 102 (2022): 793, <https://ssrn.com/abstract=3782222>.
- 27 Alessandro Acquisti, Laura Brandimarte, and George Loewenstein, "Privacy and Human Behavior in the Age of Information," *Science* 347, no. 6221, (2015): 509–514, <https://www.cmu.edu/dietrich/sds/docs/loewenstein/PrivacyHumanBeh.pdf>.
- 28 Joseph Turow, Amy Bleakley, John Bracken, Michael X. Delli Carpini, Nora Draper, Lauren Feldman, Nathaniel Good, Jens Grossklags, Michael Hennessy, Chris Jay Hoofnagle, Rowan Howard-Williams, Jennifer King, Su Li, Kimberly Meltzer, Deirdre Mulligan, and Lilach Nir, "Americans, Marketers, and the Internet: 1999-2012," Annenberg Public Policy Center, University of Pennsylvania (April 11, 2014), <http://dx.doi.org/10.2139/ssrn.2423753>.
- 29 Laura Brandimarte, Alessandro Acquisti, and George Loewenstein, "Misplaced Confidences: Privacy and the Control Paradox," *Social Psychological and Personality Science* 4, no. 3 (2013): 340–347, <https://doi.org/10.1177/1948550612455931>.
- 30 Hebert Simon, *Models of Man, Social and Rational: Mathematical Essays on Rational Human Behavior in a Social Setting*, (New York: Wiley, 1957).
- 31 Daniel Kahneman, *Thinking, Fast and Slow*, (Farrar, Straus and Giroux: New York, NY, 2011).
- 32 Acquisti et al., "Nudges for Privacy and Security"; Acquisti, "Privacy and Human Behavior in the Age of Information"; Alessandro Acquisti and Jens Grossklags, "Privacy and Rationality in Individual Decision-Making," *IEEE Security & Privacy* 3, no. 1, (January-February 2005): 26–33, <https://doi.org/10.1109/MSP.2005.22>.
- 33 For a comprehensive discussion of privacy-related decision heuristics and biases, see Acquisti et al., "Nudges for Privacy and Security."

- 34 Daphne Chang, Erin L. Krupka, Eytan Adar, and Alessandro Acquisti, "Engineering Information Disclosure: Norm Shaping Designs," *Proceedings of the 2016 CHI Conference on Human Factors in Computing Systems* (2016): 587–597, <https://doi.org/10.1145/2858036.2858346>.
- 35 Alessandro Acquisti, Leslie K. John, and George Loewenstein, "The Impact of Relative Standards on the Propensity to Disclose," *Journal of Marketing Research* 49, no. 2, (2012): 160–174, <https://journals.sagepub.com/doi/10.1509/jmr.09.0215>.
- 36 Alessandro Acquisti, Leslie K. John, and George Loewenstein, "What is Privacy Worth?" *The Journal of Legal Studies* 42, no. 2 (2013): 249–274, <https://www.journals.uchicago.edu/doi/abs/10.1086/671754>.
- 37 Nicola Jentzsch, Sören Preibusch, and Andreas Harasser, *Study on Monetising Privacy: An Economic Model for Pricing Personal Information*, ENISA report (2012), <https://www.enisa.europa.eu/publications/monetising-privacy>.
- 38 Yixin Zou, Abraham H. Mhaidli, Austin McCall, and Florian Schaub, "I've Got Nothing to Lose: Consumers' Risk Perceptions and Protective Actions after the Equifax Data Breach," *Proceedings of the Symposium on Usable Privacy and Security* (2018), <https://www.usenix.org/conference/soups2018/presentation/zou>.
- 39 Acquisti et al., "Nudges for Privacy and Security."
- 40 Acquisti et al., "Privacy and human behavior in the age of information."
- 41 Gary Marx, "Murky Conceptual Waters: The Public and the Private," *Ethics and Information Technology* 3 (2001): 157–169, <https://doi.org/10.1023/A:1012456832336>.
- 42 Alice Marwick and danah boyd, "I Tweet Honestly, I Tweet Passionately: Twitter Users, Context Collapse, and the Imagined Audience," *New Media & Society* 13, no. 1, (2011): 114–133, <https://doi.org/10.1177/1461444810365313>; Jenny Davis and Nathan Jurgenson, "Context Collapse: Theorizing Context Collusions and Collisions," *Information, Communication & Society* 17, n. 4 (2014): 476–485, <https://doi.org/10.1080/1369118X.2014.888458>.
- 43 Helen Nissenbaum, *Privacy in Context: Technology, Policy, and the Integrity of Social Life*, (Stanford University Press, 2009). For an accessible introduction to Contextual Integrity see Nathan Malkin, "Contextual Integrity, Explained: A More Usable Privacy Definition," *IEEE Security & Privacy* 21, no. 1 (January-February 2023): 58–65, <https://doi.org/10.1109/MSEC.2022.3201585>.
- 44 Nora McDonald and Andrea Forte, "The Politics of Privacy Theories: Moving from Norms to Vulnerabilities," *Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems* (2020): 1–14, <https://doi.org/10.1145/3313831.3376167>.
- 45 Irwin Altman, *The Environment and Social Behavior: Privacy, Personal Space, Territory, Crowding*, (Brooks/Cole Publishing Company, 1975).
- 46 Leysia Palen and Paul Dourish, "Unpacking 'Privacy' for a Networked World," *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems* (2003): 129–136, <http://dx.doi.org/10.1145/642611.642635>.
- 47 Sandra Petronio, "Communication Privacy Management Theory," *The International Encyclopedia of Interpersonal Communication*, <https://doi.org/10.1002/9781118540190.wbeic132>.
- 48 Fredrick Royster, "Let's Stop Using the Term 'Dark Patterns' in UX Design," *Medium*, July 10, 2022, <https://fred-royster.medium.com/lets-stop-using-the-term-dark-patterns-in-ux-design-d976359597b3>.
- 49 This is a subset of the privacy dark patterns described in Forbrunder Rådet (Norwegian Consumer Council), *Deceived by Design: How Tech Companies Use Dark Patterns to Discourage Us From Exercising Our Rights to Privacy*, June 27, 2018, <https://www.forbrukerradet.no/undersokelse/no-undersokelsekategori/deceived-by-design/>; Acquisti et al., "Nudges for Privacy and Security"; Christoph Bösch, Benjamin Erb, Frank Kargl, Henning Kopp and Stefan Pfattheicher, "Tales from the Dark Side: Privacy Dark Strategies and Privacy Dark Patterns," *Proceedings on Privacy Enhancing Technologies Symposium* 2016, no. 4 (2016): 237–254, <https://doi.org/10.1515/popets-2016-0038>; Forbrunder Rådet (Norwegian Consumer Council), "Enough deception! Norwegian Consumers' Experiences with Deceptive Design," December 1, 2022, <https://www.forbrukerradet.no/side/companies-use-design-to-take-our-time-money-and-personal-data/>.
- 50 Sonam Samat and Alessandro Acquisti, "Format vs. Content: The Impact of Risk and Presentation on Disclosure Decisions," *Proceedings of the Thirteenth Symposium on Usable Privacy and Security* (2017): 377–384.
- 51 See example of the LinkedIn profile strength meter in Acquisti et al., "Nudges for Privacy and Security."
- 52 Chang, "Engineering Information Disclosure."
- 53 This effect has been shown in multiple experiments, see for example Idris Adjerid, Alessandro Acquisti, Laura Brandimarte, and George Lowenstein, "Sleights of Privacy: Framing, Disclosure, and the Limits of Transparency," *Proceedings of the*

- Ninth Symposium on Usable Privacy and Security* (2013): 1–11, <https://doi.org/10.1145/2501604.2501613>; S. Patil, R. Hoyle, R. Schlegel, A. Kapadia, and A. J. Lee, “Interrupt Now or Inform Later? Comparing Immediate and Delayed Privacy Feedback,” *Proceedings of the 33rd Annual ACM Conference on Human Factors in Computing Systems* (2015): 1415–1418, <https://doi.org/10.1145/2702123.2702165>.
- 54 See ISO 9241-11: *Ergonomics of Human-System Interaction—Part 11: Usability: Definitions and Concepts*, International Standards Organization, 2018, <https://www.iso.org/obp/ui/#iso:std:iso:9241:-11:ed-2:v1:en>.
- 55 Quoted from Jakob Nielsen, “Usability 101: Introduction to Usability,” Nielsen Norman Group, January 3, 2012, <https://www.nngroup.com/articles/usability-101-introduction-to-usability/>.
- 56 See Nielsen, “Usability 101.”
- 57 Don Norman and Jakob Nielsen, “The Definition of User Experience (UX),” Nielsen Norman Group, August 8, 1998, <https://www.nngroup.com/articles/definition-user-experience/>.
- 58 The following book provides a good overview of common design methods and tools: Bruce Hanington and Bella Martin, *Universal Methods of Design: 100 Ways to Research Complex Problems, Develop Innovative Ideas, and Design Effective Solution*, (Rockport Publishers, 2012).
- 59 See, for example, David Wright, “Making Privacy Impact Assessment More Effective,” *The Information Society* 29, no. 5, (2013): 307–315, <https://doi.org/10.1080/01972243.2013.825687>.
- 60 Initial efforts to compile libraries of privacy design patterns include <https://privacypatterns.org/> and <https://privacypatterns.eu/>.
- 61 Lorrie Faith Cranor, “Cookie Monster,” *Communications ACM* 65, no. 7 (July 2022): 30–32, <https://doi.org/10.1145/3538639>; Midas Nouwens, Ilaria Liccardi, Michael Veale, David Karger, and Lalana Kagal, “Dark Patterns After the GDPR: Scraping Consent Pop-ups and Demonstrating their Influence,” *Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems* (2020): 1–13, <https://doi.org/10.1145/3313831.3376321>; Utz, Christine, Martin Degeling, Sascha Fahl, Florian Schaub, and Thorsten Holz, “(Un) Informed Consent: Studying GDPR Consent Notices in the Field,” *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security* (2019): 973–990, <https://doi.org/10.1145/3319535.3354212>.
- 62 Batya Friedman, Peter Kahn Jr., and Alan Boring, “Value Sensitive Design and Information Systems,” in *The Handbook of Information and Computer Ethics*, (Hoboken, NJ: John Wiley & Sons, 2008), 69–101, <https://onlinelibrary.wiley.com/doi/abs/10.1002/9780470281819.ch4>.
- 63 Batya Friedman, David G. Hendry, and Alan Boring, “A Survey of Value Sensitive Design Methods,” *Foundations and Trends in Human–Computer Interaction* 11, no. 2, (2017): 63–125, <http://dx.doi.org/10.1561/11000000015>.
- 64 Friedman, “Value Sensitive Design and Information Systems.”
- 65 See information life cycle as described in Peter Swire and Kanesa Ahmad, *Foundations of Information Privacy and Data Protection*, (Portsmouth, NH: IAPP, 2012).
- 66 Alicia McDonald and Lorrie Faith Cranor, “The Cost of Reading Privacy Policies,” *I/S: A Journal of Law and Policy for the Information Society*, 4, no. 3 (2008): 540–565.
- 67 Paul M. Schwartz and D. Solove, “Notice and choice,” *The Second NPLAN/BMSG Meeting on Digital Media and Marketing to Children*, (2009).
- 68 Hee “Andy” Lee, Norman Au, and Rob Law, “Presentation Formats of Policy Statements on Hotel Websites and Privacy Concerns: A Multimedia Learning Theory Perspective,” *Journal of Hospitality & Tourism Research* 37, no. 4 (2012): 470–489, <https://doi.org/10.1177/1096348012436384>; Mark Keith, Jacob Frederickson, Shane Reeves, and Jeffery Babb, “Optimizing Privacy Policy Videos to Mitigate the Privacy Policy Paradox,” *Proceedings of the 51st Hawaii International Conference on System Sciences* (2018), <http://hdl.handle.net/10125/50355>.
- 69 This definition is based on the GDPR’s definition of consent in Article 7, which reflects the established understanding of what constitutes valid consent.
- 70 Florian Schaub, Rebecca Balebako, and Lorrie Faith Cranor, “Designing Effective Privacy Notices and Controls” *IEEE Internet Computing* 21, no. 3 (May–June 2017): 70–77, <https://doi.org/10.1109/MIC.2017.75>.
- 71 Lorrie Faith Cranor, “Giving Notice: Why Privacy Policies and Security Breach Notifications Aren’t Enough,” *IEEE Communications Magazine* 43, no. 8 (August 2005): 18–19.
- 72 Fred Cate, “The limits of notice and choice,” *IEEE Security & Privacy* 8, no. 2 (March 2010): 59–62.

- 73 Schwartz, "Notice and choice"; McDonald, "The cost of reading privacy policies"; Joel Reidenberg, Travis Breaux, Lorrie Faith Cranor, Brian French, Amanda Grannis, James Graves, Fei Liu, Aleecia McDonald, Thomas Norton, Rohan Ramanath, N. Cameron Russell, Norman Sadeh, and Florian Schaub, "Disagreeable Privacy Policies: Mismatches Between Meaning and Users' Understanding," *Berkeley Technology Law Journal* 30, no. 1 (2015): 39–88.
- 74 Nora Draper and Joseph Turow, "The Corporate Cultivation of Digital Resignation," *New Media & Society* 21, no. 8, (2019): 1824–1839, <https://doi.org/10.1177/1461444819833331>.
- 75 Nathaniel Good, Jens Grossklags, Deirdre Mulligan, and Joseph Konstan, "Noticing Notice: A Large-Scale Experiment on the Timing of Software License Agreements," *Proceedings of the SIGCHI Conference of Human Factors Computing Systems* (2007): 607–616; Bonnie Anderson, Anthony Vance, Brock Kirwan, David Eargle, and Seth Howard, "Users Aren't (Necessarily) Lazy: Using NeuroIS to Explain Habituation to Security Warnings," *Proceedings of ICIS '14* (2014).
- 76 The ability of users to find key user interface components is referred to as *discoverability* by user experience designers. Lawyers use this term to mean something quite different: the fact that one side in a legal case must provide certain documents or information to the other side.
- 77 Habib et al., "An Empirical Analysis of Data Deletion and Opt-Out Choices on 150 Websites."
- 78 Hana Habib, Sarah Pearman, Jiamin Wang, Yixin Zou, Alessandro Acquisti, Lorrie Faith Cranor, Norman Sadeh, and Florian Schaub, "'It's A Scavenger Hunt:' Usability of Websites' Opt-Out and Data Deletion Choices," *Proceedings of the 2020 CHI Conference on Human Factors in Computing* (2020): 1–12, <https://doi.org/10.1145/3313831.3376511>.
- 79 See, for example, Hana Habib, Yixin Zou, Yaxing Yao, Alessandro Acquisti, Lorrie Cranor, Joel Reidenberg, Norman Sadeh, and Florian Schaub, "Toggles, Dollar Signs, and Triangles: How to (in) Effectively Convey Privacy Choices with Icons and Link Texts," *Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems* (2021): 1–25, <https://dl.acm.org/doi/10.1145/3411764.3445387>; Rebecca Balebako, Richard Shay, and Lorrie Faith Cranor, "Is Your Inseam a Biometric? A Case Study on the Role of Usability Studies in Developing Public Policy," *Workshop on Usable Security* (2014), <https://lorrie.cranor.org/pubs/usec14-inseam.pdf>; Pedro Giovanni Leon, Justin Cranshaw, Lorrie Faith Cranor, Jim Graves, Manoj Hastak, Blase Ur, and Guzi Xu, "What Do online Behavioral Advertising Privacy Disclosures Communicate to Users?" *Proceedings of the 2012 ACM workshop on Privacy in the electronic society* (2012): 19–30, <http://dx.doi.org/10.1145/2381966.2381970>; Pedro Leon, Blase Ur, Richard Shay, Yang Wang, Rebecca Balebako, and Lorrie Cranor, "Why Johnny Can't Opt Out: A Usability Evaluation of Tools to Limit Online Behavioral Advertising," *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems* (2012): 589–598, <https://doi.org/10.1145/2207676.2207759>; Forbrunder Rådet (Norwegian Consumer Council), *Deceived by Design: How Tech companies Use Dark Patterns to Discourage Us From Exercising Our Rights to Privacy*, June 27, 2018, <https://storage02.forbrukerradet.no/media/2018/06/2018-06-27-deceived-by-design-final.pdf>.
- 80 The here-described principles are an expanded description of Schaub et al., "Designing Effective Privacy Notices and Controls."
- 81 Michael Wogalter, "Communication-Human Information Processing (C-HIP) Model," *Handbook of Warnings* (Mahwah, NJ: Lawrence Erlbaum Associates, 2006): 51–61.
- 82 Lorrie Faith Cranor, "A Framework for Reasoning About the Human in the Loop," *Usability, Psychology and Security* (2008), http://www.usenix.org/events/upsec08/tech/full_papers/cranor/cranor.pdf.
- 83 Marian Harbach, Markus Hettig, Susanne Weber, and Matthew Smith, "Using Personal Examples to Improve Risk Communication for Security & Privacy Decisions," *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems* (2014), <http://dx.doi.org/10.1145/2556288.2556978>.
- 84 Quoted from GDPR Recital 58, which expands on the child-specific transparency requirements described in GDPR Article 12.1.
- 85 Kevin Litman-Navarro, "We Read 150 Privacy Policies. They Were an Incomprehensible Disaster," *The New York Times*, June 2019, <https://www.nytimes.com/interactive/2019/06/12/opinion/facebook-google-privacy-policies.html>.
- 86 Martin Degeling, Christine Utz, Christopher Lentzsch, Henry Hosseini, Florian Schaub, and Thorsten Holz, "We Value Your Privacy ... Now Take Some Cookies: Measuring the GDPR's Impact on Web Privacy," *Network and Distributed Systems Symposium* (2019), https://www.ndss-symposium.org/wp-content/uploads/2019/02/ndss2019_04B-2_Degeling_paper.pdf.
- 87 Sameer Badarudeen and Sanjeev Sabharwal, "Assessing Readability of Patient Education Materials: Current Role in Orthopaedics," *Clinical Orthopaedics and Related Research* 468, no. 10 (2010): 2572–2580, <https://dx.doi.org/10.1007%2Fs11999-010-1380-y>.

- 88 Schaub et al., “Designing Effective Privacy Notices and Controls.”
- 89 Lorrie Faith Cranor, Mobile-App Privacy Nutrition Labels Missing Key Ingredients for Success,” *Communications of the ACM* 65, no. 11 (November 2022): 26-28, <https://doi.org/10.1145/3563967>.
- 90 Lau et al., “Alexa, Are You Listening?”
- 91 Parts of the process description originate from two prior publications of the authors, which describe the process in more detail in Schaub et al., “Designing Effective Privacy Notices and Controls”; Schaub et al., “A Design Space for Effective Privacy Notices.”
- 92 B. Ur, J. Jung and S. Schechter. “Intruders versus intrusiveness: Teens’ and parents’ perspectives on home-entryway surveillance,” *Proceedings of UbiComp ’14*, 129–139, (New York: ACM, 2014).
- 93 Lau et al., “Alexa, Are You Listening?”
- 94 Gluck et al., “How Short is Too Short?”
- 95 Microsoft, *Privacy Guidelines for Developing Software Products and Services*, Technical Report version 3.1, 2008.
- 96 Ben Shneiderman, “The Eyes Have It: A task by Data Type Taxonomy for Information Visualizations,” *Proceedings 1996 IEEE Symposium on Visual Languages* (1996): 336–343, <https://doi.org/10.1109/VL.1996.545307>.
- 97 Aleecia McDonald, Robert Reeder, Patrick Gage Kelley, and Lorrie Faith Cranor, “A Comparative Study of Online Privacy Policies and Formats,” *Proceedings of Privacy Enhancing Technologies* (2009): 37–55; Helen Nissenbaum, “A Contextual Approach to Privacy Online,” *Daedalus* 140, no. 4 (2011): 32–48.
- 98 Almuhiemedi et al., “Your Location has been Shared 5,398 Times!”
- 99 Habib et al., “An Empirical Analysis of Data Deletion and Opt-Out Choices on 150 Websites.”
- 100 Marc Langheinrich and Florian Schaub, “Privacy in Mobile and Pervasive Computing,” *Synthesis Lectures on Mobile and Pervasive Computing* 10, no. 1 (2018): 1–139, <https://doi.org/10.2200/S00882ED1V01Y201810MPC013>.
- 101 See the original paper for an expanded discussion of each dimension with extensive examples and pointers to relevant academic research: Schaub et al., “A Design Space for Effective Privacy Notices.”
- 102 Florian Schaub, Bastian Könings and Michael Weber, “Context-Adaptive Privacy: Leveraging Context Awareness to Support Privacy Decision-making,” *IEEE Pervasive Computing* 14, no. 1, (January-March 2015): 34–43, <https://doi.org/10.1109/MPRV.2015.5>; Florian Schaub, “Context-Adaptive Privacy Mechanisms,” *Handbook of Mobile Data Privacy*, eds. Aris Gkoulalas-Divanis and Claudio Bettini, (Springer, 2018), https://doi.org/10.1007/978-3-319-98161-1_13.
- 103 Rebecca Portnoff, Linda Lee, Serge Egelman, Pratyush Mishra, Derek Leung and David Wagner, “Somebody’s watching me? Assessing the effectiveness of webcam indicator lights,” *Proceedings of the 33rd Annual ACM Conference on Human Factors in Computing Systems* (2015): 1649–1658, <https://dl.acm.org/doi/10.1145/2702123.2702164>.
- 104 Habib et al., “Toggles, Dollar Signs, and Triangles.”
- 105 Ryan Calo, “Against Notice Skepticism in Privacy (and Elsewhere),” *Notre Dame Law Review* 87, no. 3 (2012): 1027–1072, <https://ndlawreview.org/wp-content/uploads/2013/06/Calo.pdf>.
- 106 A standard for machine-readable website privacy policies was published by the World Wide Web Consortium in 2002 but has been retired after failing to receive widespread adoption. See Lorrie Faith Cranor, “Necessary But Not Sufficient: Standardized Mechanisms for Privacy Notice and Choice,” *Journal of Telecommunications and High Technology Law* 10, no. 2 (2012), http://www.jthtl.org/content/articles/V10I2/JTHTLv10i2_Cranor.PDF.
- 107 Marc Langheinrich, “A Privacy Awareness System for Ubiquitous Computing Environments,” *International Conference on Ubiquitous Computing* (2002): 237–245, https://link.springer.com/chapter/10.1007/3-540-45809-3_19; Anupam Das, Martin Degeling, Daniel Smullen, and Norman Sadeh, “Personalized Privacy Assistants for the Internet of Things: Providing Users with Notice and Choice,” *IEEE Pervasive Computing* 17, no. 3, (July-September 2018): 35–46, <https://doi.org/10.1109/MPRV.2018.03367733>.
- 108 Blase Ur and Yang Wang, “A Cross-Cultural Framework for Protecting User Privacy in Online Social Media,” *Proceedings of the 22nd International Conference on World Wide Web* (2013): 755–762, <https://doi.org/10.1145/2487788.2488037>.
- 109 Blase Ur, Manya Sleeper, and Lorrie Faith Cranor, “{Privacy, Privacidad, Приватность} Policies in Social Media: Providing Translated Privacy Notice,” *Proceedings of the First Workshop on Privacy and Security in Online Social Media* (2012): 1-4, <https://dl.acm.org/doi/abs/10.1145/2185354.2185360>.
- 110 Maggie Oates, Yama Ahmadullah, Abigail Marsh, Chelse Swoopes, Shikun Zhang, Rebecca Balebako, and Lorrie Cranor, “Turtles, Locks, and Bathrooms: Understanding Mental Models of Privacy Through Illustration,” *Proceedings on Privacy*

- Enhancing Technologies (2018): 5–32, <https://petsymposium.org/2018/files/papers/issue4/popets-2018-0029.pdf>; Blase Ur, Pedro Giovanni Leon, Lorrie Faith Cranor, Richard Shay, and Yang Wang, “Smart, Useful, Scary, Creepy: Perceptions of Online Behavioral Advertising,” *Symposium on Usable Privacy and Security* (2012): 1–15, <https://dl.acm.org/doi/10.1145/2335356.2335362>; Cynthia E Schairer, Cynthia Cheung, Caryn Kseniya Rubanovich, Mildred Cho, Lorrie Faith Cranor, and Cinnamon S Bloss, “Disposition Toward Privacy and Information Disclosure in the Context of Emerging Health Technologies,” *Journal of the American Medical Informatics Association* 26, no. 7 (July 2019): 610–619, <https://doi.org/10.1093/jamia/ocz010>; Pardis Emami Naeini, Sruti Bhagavatula, Hana Habib, Martin Degeling, Lujo Bauer, Lorrie Cranor, and Norman Sadeh, “Privacy Expectations and Preferences in an IoT World,” *Proceedings of the Thirteenth USENIX Conference on Usable Privacy and Security* (2017): 399–412, <https://dl.acm.org/doi/10.5555/3235924.3235956>.
- 111 Rebecca Balebako, Florian Schaub, Idris Adjerid, Alessandro Acquisti, and Lorrie Faith Cranor, “The Impact of Timing on the Salience of Smartphone App Privacy Notices,” *Proceedings of the Fifth Annual ACM CCS Workshop on Security and Privacy in Smartphones and Mobile Devices* (2015): 63–74, <https://dl.acm.org/doi/10.1145/2808117.2808119>.
- 112 Habib et al., “It’s a Scavenger Hunt.”
- 113 Leon et al., “What Do Online Behavioral Advertising Privacy Disclosures Communicate to Users?”
- 114 See Habib et al., “Toggles, Dollar Signs, and Triangles.”
- 115 Pardis Emami-Naeini, Henry Dixon, Yuvraj Agarwal, and Lorrie Faith Cranor, “Exploring How Privacy and Security Factor into IoT Device Purchase Behavior,” *Proceedings of the 2019 CHI Conference on Human Factors in Computing Systems* (2019): 1–12, <https://doi.org/10.1145/3290605.3300764>.
- 116 Kathryn Whittenton, “The Two UX Gulfs: Evaluation and Execution,” March 11, 2018, <https://www.nngroup.com/articles/two-ux-gulfs-evaluation-execution/>.
- 117 Serge Egelman, Janice Tsai, Lorrie Faith Cranor, and Alessandro Acquisti, “Timing Is Everything? The Effects of Timing and Placement of Online Privacy Indicators,” *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems* (2009): 319–328, <https://dl.acm.org/doi/10.1145/1518701.1518752>.
- 118 Leon, “Why Johnny Can’t Opt Out”
- 119 Alita Joyce, “Formative vs. Summative Evaluations,” Nielsen Norman Group, July 28, 2019, <https://www.nngroup.com/articles/formative-vs-summative-evaluations/>.
- 120 Jakob Nielsen, “Thinking Aloud: The #1 Usability Tool,” Nielsen Norman Group, January 16, 2012, <https://www.nngroup.com/articles/thinking-aloud-the-1-usability-tool/>.
- 121 Douglas Schuler and Aki Namioka, *Participatory Design: Principles and Practices*, (New York, NY: CRC Press, 1993).
- 122 Eyal Peer, Laura Brandimarte, Sonam Samat, and Alessandro Acquisti, “Beyond the Turk: Alternative Platforms for Crowdsourcing Behavioral Research,” *Journal of Experimental Social Psychology* 70, (2017): 153–163, https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2594183.
- 123 Christopher Schepelle, “Despite GDPR: Up to 70% Analytics Opt-in Rates—Why Extensive Testing is Worth Every Minute of Effort, DHL Web Analytics, September 11, 2020, <https://analytics.dhl.com/despite-gdpr-up-to-70-analytics-opt-in-rates-why-extensive-testing-is-worth-every-minute-of-effort/>.
- 124 Hana Habib and Lorrie Faith Cranor, “Evaluating the Usability of Privacy Choice Mechanisms,” *Proceedings of the Eighteenth USENIX Conference on Usable Privacy and Security* (2022): 273–289, <https://dl.acm.org/doi/abs/10.5555/3563609.3563624>.
- 125 Patrick Gage Kelley, Lorrie Faith Cranor, and Norman Sadeh, “Privacy as Part of the App Decision-Making Process,” *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems* (2013): 3393–3402, <https://dl.acm.org/doi/10.1145/2470654.2466466>.
- 126 Hana Habib, Megan Li, Ellie Young, and Lorrie Faith Cranor, “Okay, Whatever”: An Evaluation of Cookie Consent Interfaces,” *Proceedings of the Conference on Human Factors in Computing Systems* (2022): 1–27, <https://doi.org/10.1145/3491102.3501985>.
- 127 Cristin Bravo-Lillo, Lorrie Faith Cranor, Julie Downs, Saranga Komanduri, Roert Reeder, Stuart Schechter, and Manya Sleeper, “Your Attention Please: Designing Security-Decision UIs to Make Genuine Risks Harder to Ignore,” *Proceedings of the Ninth Symposium On Usable Privacy and Security* (2013): 1–12, <https://dl.acm.org/doi/10.1145/2501604.2501610>.

CHAPTER 6

Tracking and Surveillance

Lorrie Faith Cranor, CIPT; Blase Ur, CIPT¹

In today's digital world, our communications and our actions—both online and offline—have the potential to be tracked and surveilled. Reasons for tracking are manifold. On one level, advertising companies wish to profile users so they can better target relevant ads. Other groups or individuals might wish to spy on a person to blackmail, extort, or embarrass them. On a grander scale, a government or other organization may hope to gather intelligence to thwart an act of terrorism or to spy on a group or individual for more insidious purposes.

These large-scale goals came into particular focus worldwide in 2013 with disclosures about the PRISM program in the United States.² In the PRISM program, intelligence organizations in the United States and Great Britain established partnerships with major internet companies to facilitate the handover of customers' communications upon request.³ The primary oversight mechanism of this program was a secret court system. These revelations led to public outcry. Though some individuals responded to the revelations with the familiar "I have nothing to hide" argument, privacy scholars argued the collection, processing, and indefinite retention of data about an individual can increase the power imbalance between a government and citizens, have a chilling effect on free communication, and leave individuals vulnerable.⁴ These patterns tend to repeat. Surveillance again received considerable media coverage in 2021 when numerous governments' use of Pegasus spyware to track activists and dissidents came to light.⁵

The degree to which all citizens, not just activists and dissidents, are tracked in their daily lives received widespread attention in 2018 with revelations that the firm Cambridge Analytica used data on 50 million Facebook users to identify Americans' personalities. This information was then used to try to influence the 2016 election.⁶ Tracking and surveillance are not restricted, however, to online behaviors. In a widely discussed example from 2012, one consumer's purchasing history led the retail chain Target to tailor pregnancy-related advertisements to her before her family learned she was pregnant.⁷ In short, individuals produce huge trails of data both online and offline. These trails are tracked, recorded, and used to draw conclusions about that individual.

Opportunities for surveillance are increasing, not decreasing. As a larger fraction of electronic devices, sensors, microphones, and cameras are connected to the Internet of Things (IoT), more data will be collected by those hoping to track or surveil others. The abilities of facial recognition software to identify individuals and machine-learning algorithms to uncover patterns in large amounts of data are quickly, and seemingly continually, increasing. Tensions between the benefits of ubiquitous data collection and the privacy perils of the same practices promise to become even more stark.

The goal of this chapter is to provide IT professionals with a broader understanding of the techniques that enable tracking and surveillance on a number of levels, along with both an explanation of the countermeasures to these techniques and the limitations of these countermeasures. As the people responsible for developing IT within a company, government agency, or other organization, IT professionals must be aware of the impact surveillance technology has on individual privacy.

We start by looking at how internet usage can be surveilled on a large scale. Following a brief overview of the main technologies underlying internet communication, we discuss how network traffic can be surveilled using techniques such as deep packet inspection. We also look at more localized approaches for tracking a user's communications, such as

eavesdropping on a Wi-Fi connection or monitoring a school or workplace network, before explaining how anonymizing systems can help defend against this sort of tracking.

Next, we turn our attention to web tracking, in which companies track the websites users visit, building user profiles for advertising and other purposes. We discuss how a combination of Hypertext Transfer Protocol (HTTP) cookies and an ecosystem in which a handful of advertising companies serve advertisements on many popular websites enables this sort of tracking. We then discuss additional mechanisms that enable tracking even when HTTP cookies are disabled or deleted, including the recent Federated Learning of Cohorts (FLoC) and Topics application programming interface (API) proposals from Google for post-cookie tracking. We also briefly survey how a user's web searches can be tracked, as well as how the sender of an email can employ tricks to determine exactly when an email recipient opens the message. A number of web-blocking tools have been designed to combat the myriad techniques through which a user's web browsing can be tracked. We introduce a number of these tools and their features and highlight the shortcomings and usability issues of each approach.

Tracking and surveillance are not limited to the interception of communications or logging of web-browsing behaviors. We show how the mere presence of a cell phone or radio frequency identification (RFID) chip in an individual's pocket can reveal their location, in addition to explaining the relationship between global positioning system (GPS) technologies and tracking. We then discuss how the use and misuse of location-sharing features on social media sites can leak potentially private information. We also explain how users can control the disclosure of location information at a finer-grained level.

We then turn to how mechanisms and technologies beyond typical computing devices are increasingly enabling the ubiquitous surveillance of spaces ranging from homes to rural public spaces. We outline audio and video surveillance techniques, including how popular voice assistants and video doorbells are extending the moments in daily life that can be tracked. We then discuss how the sensors embedded in everything from vehicles to wearable devices and household appliances cause new classes of privacy concerns and enable new types of private information to be inferred. Throughout and following the COVID-19 pandemic, as education and work increasingly took place online, educational and workplace connectivity tools provided many additional opportunities for surveillance and monitoring. We also briefly discuss how tracking and surveillance enable human behavior to be modeled.

We end the chapter with a short section highlighting how the technologies and mechanisms described have been used in practice. For instance, we discuss how these mechanisms have enabled the surveillance of activists, ethnic minority groups, intimate partners, and additional targets.

It is essential for IT professionals to understand the technologies that enable tracking and surveillance to prevent privacy violations. From a corporate standpoint, it is critical to avoid privacy violations that could lead to negative press reports, a tarnished reputation, or

regulatory or legal consequences. It is also important to avoid making users feel like their privacy has been violated, since they may stop using products from companies they do not trust. In addition, knowledge of tools that limit tracking and surveillance is valuable both to illuminate possible opportunities for a company to compete on privacy and to understand steps users can take to protect their own privacy. Furthermore, privacy is an important human value. Whether or not they realize they are doing so, IT professionals and other technologists shape how this human value is embedded in daily life for potentially billions of people.

6.1 Internet Monitoring

The internet provides a variety of opportunities for tracking and surveillance. These include a range of activities, from automated monitoring by network administrators in detecting malicious software to illegal monitoring by criminals who are trying to steal passwords and account information. Employers may monitor their employees' internet connections to enforce company policies. Police and government agencies may obtain warrants that allow them to monitor internet traffic to investigate a crime. Internet service providers (ISPs) or email providers may monitor web-browsing behavior or email to deliver targeted advertising. This section describes the basics of how data travels across the internet and how such data can be picked up in transit. It also outlines several defenses against internet monitoring and surveillance.

6.1.1 Overview of Internet Communications

To travel from source to destination on the internet, data must be directed across intermediate networking links and switches. Monitoring tools may be placed anywhere along the path that data travels.

6.1.1.1 Packets

When data is sent over the internet, it is broken down into segments and encapsulated in packets. Packets are formatted segments of data, typically with a small maximum size, combined with additional information that specifies how they should be directed over a network. In Internet Protocol (IP), which is the primary protocol used to transmit data on the internet, data is put into IP packets before being directed over a series of intermediate links and routers to reach its destination. Primarily, IP is concerned with delivering the data in a packet from a source to a destination based on an address called an IP address. An IP address is a numerical identifier given to internet-connected devices. The network adapters on devices ranging from laptops to smartphones are assigned IP addresses when they are connected to the internet. This assignment is typically temporary. The same device will be assigned a different IP address when connected to a different physical network, or perhaps even over time when connected to the same network. The IoT concept goes further and

proposes assigning an IP address to most electronic devices, from temperature sensors to toasters, to make them accessible over the internet.

As IP addresses are assigned hierarchically, they aid in the process of identifying how to route data to a particular device. A major transition from IPv4 addresses, which have effectively been exhausted, to much larger IPv6 addresses is currently occurring. An IPv4 address is 32 bits, or 2^{32} possible values, while IPv6 addresses are 128 bits, or 2^{128} possible values.

Each IP packet consists of a header and the data payload. The exact format of the packet depends on the protocol, but it includes the IP address of the data's source and the address of its destination. It also includes a checksum over the header for error checking, as well as information about how the packet should be routed and the protocol it is using.

In the typical case, the information included in an IP packet allows it to be transmitted across networks using packet routing. Using the information included in the header of the IP packet, each router passes a packet on to the next closest router to its destination. Once packets reach their destinations, the contents are reassembled into their original form, such as an image or other user-friendly file.

Two of the most popular protocols that sit on top of IP are the Transmission Control Protocol (TCP) and User Datagram Protocol (UDP). Whereas TCP guarantees delivery of a packet and encompasses mechanisms for verifying delivery, including resending packets that did not make their way to the destination, UDP makes no such guarantees. As a result, TCP is generally used when it is important that data is delivered in its entirety even if it takes longer. For instance, TCP would normally be used when downloading a photograph from a website. In contrast, by not making guarantees about the eventual delivery of data, UDP can operate more quickly and with less overhead. In cases where speed is more important than reliability, such as in a video stream of a live sports event, UDP is generally used. If, for a few seconds of this live video stream, the data were to be lost in transit, it would not be useful to invoke a retransmission procedure and receive this data at a later point since the moment would have passed.

6.1.1.2 Email

One of the myriad types of communications split into packets for transmission across the internet is electronic mail, or email. Emails are structured in two parts: a header containing information about the message and a body containing the message itself.

A user creates an email message using a mail user agent (MUA) at the application level of their computer. A desktop email client like Microsoft Outlook is an example of an MUA. The email message is made up of a message header and a body. The body includes the email message. The header includes a variety of addressing fields, such as the sender's and recipients' email addresses, the subject, and cc'd recipients.

The email message is transmitted to the user's outgoing mail server and then sent across the internet to its destination using the Simple Mail Transfer Protocol (SMTP). Once the email

reaches its destination mail server, it is available for access either directly or by using a mail server protocol, such as the Internet Message Access Protocol (IMAP) or the Post Office Protocol (POP). When using IMAP, the emails remain on the server for access later or for access by multiple clients, such as MUAs on desktop computers or smartphones. In contrast, in POP, the MUA typically removes the emails from the server after storing them locally. That said, in POP3, the email server can be configured to leave emails in the inbox.

6.1.1.3 Hypertext Transfer Protocols

Like emails, web pages are split into packets as they are sent across the internet. However, while SMTP specifies how emails are sent between servers, HTTP specifies how web pages are transmitted to browsers.

Users typically visit web pages using web browsers, such as Mozilla Firefox, Google Chrome, Microsoft Edge, or Apple Safari. The address a user types into the browser is known as the Uniform Resource Locator (URL), and it contains four main parts. For instance, a user might send a request to the IAPP's website using the following URL:

`https://www.iapp.org/about/`
[] [] []
service host (:port) resource

The “service” component of a URL specifies the protocol used for the request. Most commonly, web pages use HTTP for communication between a web browser and the web server that hosts the page. Messages sent over HTTP are in plaintext. As a result, they are susceptible to monitoring and tampering by any of the intermediary nodes through which the HTTP packets are sent.

To prevent monitoring or tampering of data traveling over the internet, Hypertext Transfer Protocol Secure (HTTPS) can be used. This protocol is similar to HTTP except data is encrypted using transport layer security (TLS), which improves upon its predecessor protocol, Secure Sockets Layer (SSL). An encrypted connection is specified by HTTPS in place of HTTP in the URL. Historically, many websites preferred to send traffic over HTTP, rather than HTTPS, for performance reasons. Unfortunately, this decision to use HTTP, and therefore send web traffic in plaintext, also meant the bulk of web traffic could be monitored. However, the adoption of HTTPS greatly accelerated around 2017.⁸ A number of factors spurred HTTPS adoption, ranging from how web browsers began to flag the insecurity of sites served over HTTP to the nonprofit Let's Encrypt certificate authority (CA) beginning to offer the X.509 certificates required for HTTPS deployment for free.² As of 2023, the vast majority of traffic on the internet appeared to be encrypted, at least from the Chrome browser's vantage point.¹⁰

The “host” portion of the URL specifies who will receive the request, most often a computer server owned or contracted by the group represented by the website. The host is typically the site's domain. Along with the host, a “port” can optionally be specified. Ports allow numerous programs and processes on one computer to communicate simultaneously

with many other machines without accidentally jumbling the conversations. This is similar to the way mail is correctly routed to a resident of a large apartment building with a single street address by specifying an apartment number. Although a single computer has 65,535 ports for use by both TCP and UDP, there are default ports to which requests following particular protocols are often made. For instance, HTTP requests are sent to TCP port 80 by default, while HTTPS requests are sent to TCP port 443. Since no port was specified in the example URL above, the default port for the HTTPS protocol will be used. Finally, the “resource” portion of the URL specifies exactly which page, image or other object should be returned.

An HTTP request for web content is first initiated by a user’s web browser, which sends a request message to the host. First, the name of the host is converted to an IP address. For instance, the IAPP’s host name *iapp.org* is converted to the IPv4 address 34.225.38.165 at the time of press. Once the host’s IP address is known, the request can be broken into packets and accurately routed to its recipient.

A browser can make one of several types of HTTP request, of which GET and POST requests are most relevant for surveillance techniques. In the case of a GET request, the browser simply requests a particular resource be returned. A POST request is similar to a GET request except the body of a POST request can contain information sent from the browser to the server, such as the data that a user typed into an online form. A GET request can also send data to the server when it is embedded in the URL itself, such as through key-value pairs known as “query parameters.” For either type of request, the server replies with a short status code indicating the success of the request. For instance, the code 200 indicates a successful request, whereas 404 indicates the resource was not found. For successful requests, the content is also included in the body of the response. In HTTP, a single request results in a single reply. Furthermore, the connection is stateless, which means the server is not required to recall anything about past requests to fulfill future requests.

Both HTTP requests and HTTP responses include headers, which are short messages containing additional information. For instance, HTTP requests include the commands “GET,” “POST” or “HEAD” along with the resource requested. They can include the date and time the request was sent in the date field, as well as identifiers and version numbers for the web browser and operating system. Other data can be included too, depending on the request and the browser used. When a user clicks on a hyperlink on a page, an HTTP request for the new page is initiated. For these sorts of requests, a “referrer” header is included to indicate to the new page the identity of the page on which the link was clicked. The HTTP response headers can include fields such as “content-language,” specifying the natural language in which the page is written.

6.1.2 Network-Scale Monitoring and Deep Packet Inspection

Only the IP header, the first part of a packet, is required for network hardware to accurately route a packet to its destination. It is possible for network hardware to examine header information for other protocols or the full body of the packet for a variety of purposes. Nodes looking at this additional data is called “deep packet inspection.”

Deep packet inspection serves multiple purposes. For example, the ability to examine additional information within packets before they pass into a local organizational network can help determine whether the packets contain malicious content, such as known viruses. Alternatively, examining packets before they leave a network can help prevent data leaks, assuming the organization can scan these packets to detect sensitive information that should not leave the organization.

Deep packet inspection is also used for a variety of nonorganizational purposes. It is used by advertisers to track users’ online behavior to better target ads and by government entities to censor or track citizens’ online behaviors. Both activities raise privacy concerns.¹¹ In China, deep packet inspection is used as part of the “Great Firewall,” which the government uses to perform large-scale censorship on potentially sensitive topics.¹²

Some opponents of deep packet inspection note it can be used to violate the principle of net neutrality because it allows network traffic and bandwidth shaping based on the content of a packet. In the United States, for example, the Federal Communications Commission (FCC) previously ordered Comcast to stop using deep packet inspection to limit the bandwidth of peer-to-peer connections, called “rate-limiting.”¹³ Because deep packet inspection can be used to determine the type of content being sent from one host to another, Comcast was able to rate-limit its customer internet use based on whether the use was for peer-to-peer networking apps or file sharing. Note political changes regarding net neutrality in the United States, however, call into question future applications of this argument.

6.1.3 Wi-Fi Eavesdropping

Monitoring can also occur on Wi-Fi networks. It is possible to eavesdrop on data being sent over a wireless network at the packet level. Several systems for Wi-Fi eavesdropping, including packet sniffing and analysis tools, are freely available.

Unsecured communications sent over an open or shared wireless network can be intercepted easily by others. This risk is often present in Wi-Fi hotspots in public spaces, such as hotels or coffee shops, where many users share a common Wi-Fi network that is either unprotected or protected with a password known to a large group of users. Packet-sniffing systems capture packets sent over such networks. If the data is unencrypted, these packets can be examined and reassembled. These reassembled packets can then provide information about all the network user’s activities, including websites they visited, emails and files sent, and the data included in session cookies, such as website authentication information. Wireshark is one example of a packet sniffing and network analysis tool.¹⁴ It captures packet-level data on wired or wireless networks a user has access to, allowing them

to examine and reassemble packet content. Other examples of packet sniffers include Kismet for Unix and Eavesdrop for Mac.¹⁵

There are also more specialized Wi-Fi eavesdropping systems. One such tool previously enabled HTTP session hijacking, or “side-jacking,” attacks. When a user logs into an internet site, the initial login process is usually encrypted. Sites often subsequently store a token on the user’s computer, and this token is sent along with future HTTP requests as proof that the user has logged in. However, some popular sites previously used HTTP, rather than HTTPS, to send this token, which means the token was sent unencrypted. Firesheep, a Firefox extension released in 2010 but later removed from the Firefox store, enabled an adversary listening to a Wi-Fi connection to hijack these tokens and impersonate users who were logged in.¹⁶ It captured tokens it saw transmitted across the wireless network to which the user was connected. It then displayed information about the captured accounts, e.g., the site, the username, and the user’s photo, and allowed the adversary to send requests to the applicable website as if they had originally logged in as that user. At the time of its deployment in 2010, Firesheep allowed users to log in to Facebook using other users’ accounts. In response to tools like Firesheep, many popular sites began using HTTPS for all traffic, not just the transmission of passwords.

Tools like Wireshark are intended to allow users to purposefully eavesdrop on network information included in the body of packets for benevolent or malicious purposes. However, companies using eavesdropping tools can run into trouble when they are careless about how much data they record. In a 2010 case involving Google’s Street View cars, Google captured data from unencrypted Wi-Fi networks using packet sniffers that were installed on these cars. The discovery that the captured data included passwords, personal information and other network traffic consumers never expected to be collected resulted in a public outcry and an investigation by the FCC, as well as actions by other governments across the world. In 2013, Google acknowledged these actions were a privacy violation as part of a USD7 million settlement in the United States.¹⁷

There are several potential defenses against Wi-Fi eavesdropping. First, Wi-Fi eavesdropping requires the eavesdropper to have access to the Wi-Fi network and be able to read the packets that are sent. Ensuring Wi-Fi networks are encrypted using strong passwords can limit the danger of Wi-Fi eavesdropping by preventing some adversaries from reading the traffic passing across the network. However, one Wi-Fi encryption scheme that is still in limited use, Wired Equivalent Privacy (WEP), has significant vulnerabilities and can often be broken within seconds.¹⁸ The Wi-Fi Protected Access (WPA) encryption scheme is also considered insecure and should not be used. At the time of press, however, its successors WPA2 and WPA3 were still considered secure. That said, protocols for Wi-Fi routers can sometimes be attacked, which means strong Wi-Fi passwords may not be sufficient to protect this communication channel.¹⁹ Virtual private networks (VPNs), which allow users to create secure, encrypted tunnels to send data through more trusted channels, offer a

defense against interception on unsecured networks. Additionally, regardless of the security of the network itself, encrypting web requests using HTTPS can prevent eavesdroppers from intercepting sensitive or personally identifiable data.

6.1.4 Internet Monitoring for Employers, Schools, and Parents

There are also systems that allow people in positions of power or authority to monitor local networks. Some of these systems are specifically designed for employers, schools, and parents. Such monitoring may be used to ensure both security and appropriate behavior on the network, often by blacklisting or blocking access to websites considered inappropriate.

Employers in the United States are legally allowed to monitor their employees' internet usage on their organization's network or company-owned machines.²⁰ Companies monitor email and internet usage for a variety of reasons, including tracking employee productivity, maintaining security within the corporate network, and ensuring appropriate behavior among employees. As of 2007, the American Management Association (AMA) found 66% of surveyed companies monitored internet browsing, 65% blocked access to blacklisted websites, and 43% monitored email to limit security breaches and prevent potential lawsuits.²¹ For example, some companies add themselves as a CA on company-owned machines, which enables them to intercept and decrypt SSL and TLS traffic on that machine. This is equivalent to a machine-in-the-middle (MiTM) attack, allowing employers to read and intercept communications on their internal networks.

The U.S. Children's Internet Protection Act (CIPA) requires schools and public libraries to install filters to prevent children from viewing inappropriate content online.²² Many schools also track students' internet usage to prevent inappropriate behavior, such as illegal downloading.²³

Parents, too, can monitor their children's internet usage. A variety of tools allow parents to limit the types of sites their children are allowed to visit, typically using blacklists or keyword filters. Parents can also track the sites their children visit and view the emails and chat messages they send. These tools are designed to help protect children from online predators, as well as to allow parents to better supervise their children's online activities.

6.1.5 Spyware

Beyond monitoring network connections, there is also potential for malicious software to surveil data before it even leaves the user's own computer. "Spyware" is malicious software covertly installed on a user's computer, often by tricking users through social engineering attacks. Spyware can directly monitor what a user does on their computer, including by performing screen capture and transmitting an image of the user's screen back to the attacker or by performing keylogging. In keylogging, malware that tracks all the user's keystrokes is installed. This data is then sent back to the attacker, allowing them to capture sensitive information typed by the user, such as passwords.

Antivirus providers offer antispymware programs that can be used to protect against known spyware. These systems use antimalware signatures created from components of the malware code to detect and remove spyware from installed software. However, these programs are often reactive. While they often successfully detect well-known malware, they typically fail to detect new types of spyware. Additionally, it is possible for systems to track known spyware websites and block installations coming from those sites at the firewall level.²⁴

The distribution channels and difficulty of installation for spyware vary greatly. For instance, given physical access to a potential victim's phone, which is often the case in intimate partner violence and domestic abuse, an attacker might simply download an app that functions as spyware.²⁵ In contrast, the Pegasus spyware used by nation-states has been distributed by sophisticated spear-phishing attacks or, in some cases, even by exploiting previously unreported zero-click vulnerabilities in messaging software.²⁶ The end of this chapter discusses both applications of surveillance technologies in more detail.

6.1.6 Preventing Network-Level Surveillance

Even if packets are encrypted when a user accesses the internet, it is often possible for an observer, such as an ISP or government, to learn what sites the user accesses by examining metadata. Broadly, HTTPS does not provide anonymity. Network observers still can see the source and destination of traffic, which are left unencrypted in the packet headers so the request or response can be routed to the right destination. For instance, a user who visits *example.com* over HTTPS will reveal to network observers that their IP address is communicating with *example.com*'s IP address. While the body of the request or response, such as the precise page requested and delivered, is encrypted, the privacy provided can be imperfect. The page being viewed can sometimes be inferred simply based on the size and the timing of the encrypted data returned, even without observing the unencrypted data itself.²⁷

This type of tracking is problematic in a variety of circumstances, such as when citizens who live under a hostile regime wish to access political websites secretly. To prevent such tracking, anonymizers can be used to mask the link between the source—the user—and the destination of the network traffic. Two major types of anonymizers are anonymous proxies and onion routers.

“Anonymous proxies” allow users to anonymize their network traffic by forwarding the traffic through an intermediary. Thus, the user's traffic appears to come from the proxy server's IP address, rather than the original user's IP address. For example, JonDonym was a service that anonymized traffic by routing packets through a mix of multiple user-chosen anonymous proxies.²⁸ However, the use of an anonymous proxy requires the user to trust the anonymous proxy, and this approach runs the risk of presenting a single point of failure. “Onion-routing systems” or “mix networks” are an alternative to anonymous proxies. Like the layers of an onion, packets sent through an onion-routing system are encrypted in layers and then sent through a series of relays in a way that is difficult to trace without full visibility

of all the networks traversed. At each stage of the circuit, a node receives a packet from the previous node, strips off a layer of encryption and sends it on to the next node. Because there are multiple nodes within the circuit, each internal node does not know anything beyond the node it received the packet from and the node it needs to forward the packet to. This configuration allows a layer of anonymity to be inserted into network traffic. However, encryption is still required to keep the data itself anonymous once it leaves the virtual circuit.²⁹ Tor is an implementation of the onion-routing protocol that uses a network of volunteer-run relay nodes to enable a variety of anonymous services.³⁰

A particular concern for users is who controls their data. For instance, even if a user has transmitted their data securely across a network using encryption and even if the company follows industry best practices in storing this data securely, the user often still needs to worry whether personal data will be disclosed to a government or other organization through the cooperation of an internet company, typically without the user's knowledge. The extent of this type of cooperation in supporting government surveillance was one of the major surprises of the 2013 PRISM revelations.³¹ Users must also carefully evaluate promises made by companies, yet they often have no way to do so. For instance, even though for years Skype asserted for years that it could not intercept users' communications, the PRISM revelations showed this assertion to be patently false.³²

6.1.7 Effective Practices

A variety of tools are available for internet monitoring. There are several effective practices to keep in mind, both when performing such monitoring and when trying to prevent such monitoring from occurring.

To minimize privacy impacts, internet monitoring should have a stated and narrow goal. If it is necessary to monitor online activities—for example, within a corporate environment—it should be done in a manner that best respects the privacy and agency of the monitored individuals while achieving the desired goals. Neglecting privacy in pursuit of a goal can result in negative consequences.

As was apparent in the Google Street View example, this often means determining what data is necessary to achieve the desired goal and then capturing only this data, an approach that falls under the concept of “data minimization.” Additionally, whenever possible, this data should be captured in an aggregate or anonymized fashion. See chapter 4 for more details on data aggregation, sanitization, and anonymization. For example, if deep packet inspection is performed for network statistics, data should be examined in aggregate. The contents of individual packets should not be examined. To further protect privacy and limit liability, data should not be retained or shared beyond a necessary level.

Conducting surveillance at a level that exceeds consumers' expectations can have direct financial implications for an organization, including regulatory fines and lost business. For instance, major companies like Google and Facebook have paid fines as part of settling

privacy complaints with the U.S. Federal Trade Commission (FTC) in recent years. In addition, in the wake of the PRISM revelations, 10% of survey respondents indicated they canceled a project to use a cloud provider based in the United States.³³

There are several effective practices to prevent monitoring. First, HTTPS should always be used for web traffic. Additionally, sensitive information should not be sent over unsecured Wi-Fi networks, nor should a user rely on a Wi-Fi network's security to provide confidentiality. VPNs provide some protection in such an environment, although they require one to trust the VPN operator. Finally, sensitive information, such as confidential emails, should also be encrypted to provide an additional layer of protection.

6.2 Web Tracking

Companies and websites have many reasons for wanting to track users on the internet, ranging from analysis and personalization on an individual website to targeting advertisements to users based on their activities across multiple websites.

Many websites personalize their content or user experience for each visitor. For instance, if a user changes their language settings for a website from English to Romanian, the website wants to identify that user when they return and automatically show the page in the correct language. Furthermore, many websites calculate analytics about their own pages, such as how users navigate the layout of the page. Websites also might want to show a particular user the stories or products they believe are most relevant based on the person's past actions or purchases on that website.

Online advertising companies create detailed profiles about what websites a particular user visits so they can target advertisements and offers to that user. For instance, if a company tracks exactly what pages a user visits across the internet over a long period of time, the company can infer information ranging from general categories of user interests to potentially detailed personal information.

On a technical level, the amount of information a company could collect about a particular user is nearly limitless. For instance, based on the articles a user views on health websites and the terms they enter into search engines, a company could likely infer the user's health status, including what diseases they have. Furthermore, even seemingly anonymous data can sometimes be connected to a particular individual. For instance, in 2006, AOL publicly released supposedly anonymized search queries for research purposes, yet some of the users were identified in real life based on searches they made about themselves, their relatives, or their neighborhoods.³⁴

In practice, many companies on the internet say they collect far less information than is theoretically possible, usually outlining in a privacy policy what information they collect and how they will use it. However, it is not possible for an end user to verify what information is actually collected, and a user would need to expend hundreds of hours a year to read the privacy policies for every site they visit.³⁵ Furthermore, it is difficult for users to grasp how

data from different online sources can be combined or, particularly, how online data can be combined with data from offline sources, e.g., Wi-Fi hotspot data collected in the Google Street View incident.

To better understand what types of information can be collected and by whom, in the rest of this section we delve into common mechanisms for tracking internet users. We begin by discussing how web pages remember settings for a particular user using HTTP cookies and then show how these cookies can be used for tracking that user across the internet. We then talk about post-cookie tracking, including browser fingerprinting and recent proposals for performing tracking locally in a browser. Overall, these techniques have applications that even privacy-sensitive users might consider benign, yet they can also easily be used for potentially privacy-invasive purposes.

6.2.1 Web Tracking Using HTTP Cookies

As previously detailed, web browsers typically communicate with web servers using HTTP or HTTPS to access websites. Although these protocols are stateless, which means they are not expected to remember past transactions, it is useful for websites to be able to save states about a particular user. For instance, a website should be able to remember that a particular user is logged in. If a user were required to log in to a website anew each time they clicked on a link or navigated to a new page, they would likely be quite annoyed. Similarly, if a user places an item in an online shopping cart or updates their preferences for how the site is displayed, it is useful for the website to remember these changes not just for that particular visit, but for all future visits from the same user.

To remember states, websites can request the web browser to save small text files, known as “HTTP cookies,” on the user’s computer. In an HTTP response from a server, one possible header is “set-cookie,” which is followed by the values the site would like to store in the web browser. Along with the values to be stored, a cookie will contain an expiration date, as well as the origin, meaning the domain and path, for which that cookie is valid. Taken together, the domain and path define the scope of the cookie, which specifies the parts of a domain to which the cookie applies.

Every major web browser has a particular location where it stores these cookies on the hard drive of a user’s computer. Users can examine their cookies, which contain plaintext. However, while some cookies may contain words indicating what has been saved, cookies more commonly contain codes that are intended to be understood only by the website that originally set each cookie.

When a particular website has set one or more cookies on the user’s computer, the web browser will include the contents of those cookies as part of the header in HTTP requests sent to that site if the resource being requested falls within the cookie’s scope and if the same browser is being used. Cookies are included regardless of the type of content being requested. Therefore, requests for content ranging from the main page of a website to a single

image from the web server will include the cookies. If the cookie contains a unique identifier, then the website will be able to determine the user associated with that identifier has returned to the website and track their activity on the site.

Cookies can be set just for a particular visit to a website or for extended periods of time. “Session cookies” are stored only until the web browser is closed and thus contain information only for a particular visit to a page. For instance, a token used to prove to a website that a particular user has successfully logged into their email account might be saved as a session cookie and thus sent along with every HTTP request to that site during that particular browsing session, meaning until the browser is closed. As closing a browser is becoming less common over time, session cookies often remain active for long periods of time. In contrast, “persistent cookies” can be saved indefinitely and are often used to save website preferences or a unique identifier to correlate multiple visits over especially long periods of time.

Web domains can only read and write cookies they have set, a practice that falls under the “same-origin policy,” a wide-ranging security mechanism specifying how web content from different origins, such as different companies’ domains, may interact. Thus, Facebook cannot directly read cookies set by Google, nor can Google directly read cookies placed by Facebook. However, often visiting a single website will result in cookies from multiple companies being placed on a user’s computer because websites that appear as a single entity to the user are often cobbled together transparently from many different sources. For instance, a news website might load articles from its own internet domain, for instance <https://www.news-website.com>. These sorts of cookies from the primary page the user visits are known as “first-party cookies.” However, images on this page might be downloaded from another company, such as <https://photography-aggregator.com>, while each advertisement on the page might be served by a different advertising network, such as <https://www.xyz-advertising.com>. Each of these domains can also set its own cookies. Cookies set from all companies other than the primary website whose URL is displayed in a browser are known as “third-party cookies.”

The content contributed by these different third-party companies may not be visible to the user, for example because they are allocated 0 pixels on the screen. Elements used for tracking that are not visible to the user in the rendered web page are known as “beacons” or “web bugs.” Beacons are loaded onto a page using elements of the Hyper Text Markup Language (HTML), which is the most widely used language for specifying the layout of a web page. In general, HTML allows text and multimedia from a variety of different sources to be brought together to form a web page. For instance, the HTML tag `<img>` instructs a web browser to download an image from a remote web server and include it in the web page, which is how images are commonly displayed on the internet. Similarly, the `<iframe>` tag specifies that an entire web page should be included inside another web page, while the `<script>` tag runs computer code written in certain other languages, such as JavaScript.

Since HTTP requests for all types of content include both the cookie and the referring URL, or the referer header, as HTTP headers, and since the cookie can contain an identifier unique to that user, beacons can enable tracking. The most canonical example of a beacon is a zero- or one-pixel image whose sole purpose is to generate an HTTP request. If a user visits website A and website A embeds third-party content, such as a beacon or an advertisement, the browser will visit the third-party site to get the content and will receive a cookie alongside it. The third-party tracker receives the cookie with the user's unique ID, as well as the referring URL, thereby concluding that this particular pseudonymous user visited this particular URL. When the user visits website B, a completely different site, that site might also reference content from the same third party. If it does, the browser again visits the third party to fetch that content, and the cookie received on the visit to website A is sent back to the third party. The third party then knows the user has visited both website A and website B.

Although a company can only track a user's visits to websites on which it serves content, widespread tracking is still possible since a small number of companies include their content and beacons on many popular websites across the internet. For instance, a 2009 study identified ten domains that served content on 70% of one thousand popular websites examined.³⁶ More recently, a 2016 study of the top one million websites observed 123 different third parties each present on at least 1% of those websites, with the most prevalent third party, Google, present on the majority of those websites.³⁷

Furthermore, recent years have seen a rise in "cookie syncing," a process through which different companies can synchronize and merge the pseudonymous identifiers they have assigned to a given user.³⁸ For the purpose of example, imagine Company A uses the web domain *companyA.com* and has assigned a user the identifier "123," while Company B uses the web domain *companyB.com* and has independently assigned the same user the identifier "789." These companies' respective identifiers are stored as cookies. As previously described, the same-origin policy prevents Company A from reading Company B's cookies and vice versa because the origins of *companyA.com* and *companyB.com* do not match. However, JavaScript code from Company A, running under the *companyA.com* origin, could indeed read its own cookies and thus access its own identifier, subsequently embedding this identifier in an HTTP request sent to Company B. For instance, Company A's JavaScript code could read its "123" identifier from its own cookies and then send a request to a URL like <https://sync.companyb.com/?partner=companyA&partnerid=123>. This example URL notably embeds Company A's identifier for the user as a URL parameter. Because web browsers automatically send cookies set by a particular origin as part of future HTTP traffic to that origin until those cookies expire or are deleted, Company B's "789" identifier stored in a cookie is automatically sent with this request as an HTTP header. Upon receiving this HTTP request, Company B will be able to match Company A's identifier of "123" for that user from the URL parameters with its own identifier of "789" from the associated cookie. Company B now learns the mapping to Company A's identifier for that user and can either communicate

this mapping out of band to Company A, or Company B can follow an analogous process in causing an HTTP request to be sent to Company A.

Much of this tracking across popular sites supports “online behavioral advertising,” also known as “targeted advertising,” which is the practice of targeting advertisements using a profile of a user based on the websites they visit. A common method of profiling involves assigning a user to a subset of items in a list of interest categories, such as “cacti and succulent aficionados.” These interest categories are either selected or unselected for a particular user based on inferences the company makes. As a basis for these inferences, the company can consider which web pages the user has visited. The company can also leverage information collected from other sources, both online and offline, that is funneled through data brokers.³⁹ They might also misuse personal data provided to them for other purposes, such as security purposes, for targeted advertising.⁴⁰ Based on this data, advertisers can potentially choose from among tens of thousands of different characteristics on which to target an advertisement.⁴¹

Online behavioral advertising has attracted substantial attention in the media and from regulators, and it has also raised privacy concerns for consumers. For instance, in the United States, both the FTC and the White House released privacy reports discussing concerns about online behavioral advertising in 2012.⁴² Consumers themselves worry about the potential for discrimination in targeted advertising, and they have a wide spectrum of privacy perceptions based on the particular characteristics that have been inferred.⁴³

Social media sites like Meta also serve content on many different websites, allowing these social media companies to track a user’s activities across a broad swath of the internet.⁴⁴ The content served by such companies can take the form of social widgets. For instance, the social network Facebook places a “Like” button on many pages, allowing users to click a button and share that article on their Facebook profile. Whether or not a user clicks on the button, and whether or not the user is logged in to Facebook at the time, Facebook notices the user’s visit to that page.⁴⁵ On the one hand, these widgets provide a frictionless way for a user to share articles and information with their contacts. On the other hand, they raise privacy concerns since they allow the social networking companies to track a user’s movement across many websites.

Websites can also track the links a user clicks on a web page. Using a technique known as “URL rewriting,” a website can be crafted to determine whether a user has clicked on an individual link. Understanding how a user has navigated a page can be useful for analytics, such as helping a search engine determine which of the links it presented to a user were actually clicked. For example, if a user goes to Google and searches for “privacy organizations,” the results would likely include a link to the IAPP. However, rather than presenting a direct link to the IAPP’s website at <https://iapp.org>, Google might instead present a link of the form:

http://www.google.com/url?query=privacy_organization&user=2fE6SDa&url=iapp.org

Such a link would automatically redirect the user to the IAPP website. However, by first directing the user's browser to Google's own server, Google is able to learn which link a particular user clicked from a particular set of results. The unique identifier for the user can be the same unique identifier contained in a cookie that Google stored on the user's computer, allowing that action to be associated with that user. Furthermore, by analyzing the time and IP address associated with this redirection request, Google can reconstruct the order in which the user clicked on links in search results, as well as the geographic location and ISP from which the user is connecting to the internet.

JavaScript, a programming language used to create dynamic and interactive websites, can be used to track how a user navigates a web page in even greater detail than simple URL rewriting. To enable web pages that dynamically change as a user interacts with the page, JavaScript has functions for determining where a user's mouse cursor is placed on the page, when a user has placed the mouse cursor over a particular element of the page, what the user has typed, and in what sequence. Of course, these functions can be used to capture navigation information in great detail and then to send it to a remote web server for analysis.

6.2.2 Web Tracking Using Other Storage Media

While third-party cookies are a primary means of tracking a user's web browsing, many additional technological mechanisms enable tracking. Some of these technologies have been used to respawn cookies that have been deleted by the user, while others present entirely different tracking and surveillance paradigms. In the early 2010s, cookie-like objects such as "supercookies" received much attention, whereas in the late 2010s much of the attention on tracking beyond cookies has focused on browser fingerprinting.

Though a user's IP address might initially seem to be a promising mechanism for tracking, the potentially large number of users who share an IP address, e.g., because they are all connected to the same Wi-Fi router, and the frequency with which users acquire new IP addresses as they move between locations make the use of IP addresses for tracking less attractive. Users can instead be tracked more reliably using some of their computers' local storage mechanisms that are accessible to web browsers, as well as through techniques that subtly misuse features of web browsers to glean information about a user. That said, as more devices transition to IPv6, some implementations of which use a device's permanent media access control (MAC) address, tracking by means of the IP address may become more viable.

Web browsers or their plug-ins can write data to the hard drive of the user's computer in numerous ways beyond simple HTTP cookies. Many of these mechanisms have been used for tracking purposes. For instance, the Adobe Flash plug-in used to display videos and other interactive content on a number of sites has its own means of storing information, commonly called either local shared objects (LSOs) or "Flash cookies." A particular plug-in will generally be configured to run in each web browser on a user's computer. As a result, a website that utilizes the plug-in can access the same cookies regardless of which web browser

is being used. Furthermore, LSOs are stored in a location on the hard drive separate from HTTP cookies, which means hitting the “clear cookies” button in a web browser may not clear LSOs unless the browser has been specifically designed to do so. While LSOs can be used for purposes such as remembering the volume setting for watching videos on a particular website, they can also be used for storing unique identifiers for users that may not be deleted when a user deletes their cookies.

A 2009 study examined the 100 most popular websites and found that more than 50% were using LSOs.⁴⁶ While some of these sites seemed to be using LSOs for caching data, many others, including U.S. government websites, were using them to store unique identifiers about the user. For many years, LSOs were not deleted when a user cleared the cookies in their web browser, during which time some of these sites used LSOs to respawn deleted HTTP cookies. These respawned cookies often contained the same unique identifier as before deletion and thus seemingly contradicted the wishes of a user to clear this information. Notably, a 2014 study of 100,000 top websites observed deleted HTTP cookies being respawned with the same unique identifier based on information stored in other LSOs, even though prior legal settlements had attempted to disincentivize this behavior.⁴⁷ Following controversy over the use of LSOs for tracking, the Flash plug-in and some browsers, including Firefox and Chrome, were updated so choosing to clear the history in the browser would also delete LSOs.

There are a number of similar techniques for using a web browser to store tracking information on a user’s computer. For instance, Silverlight isolated storage provides an analogous function to LSOs for Microsoft’s Silverlight framework, which competes with Adobe Flash. In addition to these plug-ins, core features of many modern websites, including JavaScript and HTML5, can enable tracking. The JavaScript programming language can store data using a property called `window.name`, which was originally designed for web designers to assign each browser window a name they could reference in computer code. This JavaScript property allows up to two megabytes of data to be stored during a particular web-browsing session.⁴⁸ Unlike HTTP cookies, the `window.name` property is initially empty each time a new browser window or browser tab is opened, limiting the amount of time a unique identifier will persist. Of course, this method can be used in conjunction with other methods to retain data over a long period of time.

The Internet Explorer browser itself is also able to store information on the local hard drive using `userData` storage, which enables each domain to store up to one megabyte of data. Like the other alternatives to HTTP cookies, a user who deletes their cookies will not delete information stored in `userData`. A more subtle method is a “pixel hack,” in which a unique identifier is written into a minuscule image, generated on the fly, in the form of the color values for one or more pixels. Since images are often cached, or stored locally by the browser to avoid having to download the resource again in the future, these tracking values can often be retrieved later.

Furthermore, HTML5, an updated specification of the HTML markup language for web pages that enables the embedding of videos, audio, and visual canvas elements in web pages, also specifies methods for storing information locally, which can lead to tracking. These storage methods, which have been separated from HTML5 for specification purposes and are currently known as either web storage or Document Object Model (DOM) storage, are currently supported by all major web browsers. The session storage method can save information for a particular web-browsing window. Other web-browsing windows, even those containing the same app or website, cannot access this information, which is removed when the window is closed. In contrast, the local storage method stores data semipermanently. This stored information is available to all resources on the web domain that stored the data.

Additional methods for DOM Storage have been proposed and debated. For instance, Mozilla Firefox previously supported a storage mechanism called Global Storage, but support for this feature was removed in version 13 of the browser.⁴⁹ Similarly, Database Storage using SQLite was considered as a possible W3C standard and was implemented in some browsers, but official efforts toward its standardization ended in 2010.⁵⁰

Yet another mechanism for a browser to store information locally leverages the way web browsers cache data. Entity tags (“ETags”) are HTTP headers that allow a browser to permanently tag a previously viewed resource, such as a web page or an object contained in the page, with an identifier. They were originally designed to enhance performance when loading previously viewed websites. When a user views a website, browsers generally save a copy of objects viewed on the user’s hard drive so identical content does not need to be downloaded multiple times. A site can tag content with an HTTP ETag identifier, which changes each time the content is updated on the server. As a result, a browser can request a resource from a website while specifying that the resource should be returned only if it has changed, based on the ETag. If the resource has not changed, the site only needs to confirm this fact so the browser can use the local copy. To enable tracking, a web server need only change and track ETags during each transaction to reidentify a visitor across multiple transactions. ETags are generally not deleted when a user clears their cookies; rather, ETags may be deleted when a user clears the browser’s cache of previously viewed pages. Thus, ETags enable tracking even if cookies are deleted.

In recent years, there have been rapid changes in tracking techniques. For instance, a 2011 study found a substantial decline in the proportion of popular websites using LSOs compared to the 2009 study that initially brought attention to the issue.⁵¹ However, a separate 2011 study noted HTML5 (DOM Storage) and ETags were being used for the same tracking purposes.⁵² In 2010, a security researcher prototyped a tracking mechanism, the “Evercookie,” designed to be extremely difficult to delete.⁵³ The Evercookie combined many of the previously described techniques, storing unique identifiers in more than ten different

locations on a user's computer. If data from one storage location were deleted, this data would be respawned from other locations.

6.2.3 Browser Fingerprinting

Features of web browsers designed to enhance users' experience on the web can also be misused for tracking purposes even if cookies are disabled or regularly deleted. We first describe a conceptually simple example that has been partially mitigated before describing the more general, and far more common, concept of browser fingerprinting.

By default, web browsers show links on a page that have already been visited in one color, while links that have not yet been visited are displayed in a different color. Although it cannot directly access a user's browsing history, JavaScript can access the color of any element on a web page, including links. Therefore, in a technique known as "browser history stealing" or "sniffing," an unscrupulous page can include thousands of invisible links to popular sites and then use JavaScript to query the color of those links and learn whether a particular page has been visited by the client browser.⁵⁴ While browsers have tried to close such history sniffing loopholes, in recent years researchers have discovered new vectors for conducting such attacks.⁵⁵

Another technique that misuses features of JavaScript and HTML for tracking purposes is "browser fingerprinting," which has become widely used in recent years.⁵⁶ Websites can adjust their pages to match the configuration of a particular user's computer using JavaScript functions that reveal the time zone and screen resolution, as well as fonts and plug-ins that have been installed on a particular computer. These features, in combination, can create a fairly unique profile of a given user. A 2010 study found, even among a sample of potentially privacy-conscious users, 94.2% of browser configurations with Flash or Java installed could be uniquely fingerprinted.⁵⁷ That same study also captured an array of browser fingerprinting techniques in use. These fingerprinting techniques leverage the unique characteristics of an individual user's browser—the fonts installed, the particular version of the browser running, the idiosyncrasies of a particular graphics card—as a semistable, unique identifier in place of cookies, but for much the same purpose.⁵⁸ Measurement studies conducted in 2014 and 2016 observed increasing use of browser fingerprinting in the wild, establishing browser fingerprinting as a major frontier in future tracking efforts.⁵⁹ At the time of press, an arms race continued between companies developing new methods of fingerprinting browsers, new techniques for defending against browser fingerprinting and additional methods in response that aimed to subvert those defenses.⁶⁰

6.2.4 Google's FLoC and Topics API Proposals

As detailed in section 6.3, an increasing number of web browsers and third-party privacy tools make it easy for consumers to block the third-party cookies that enable the previously described types of web tracking described. Responding to this changing ecosystem, in 2021 Google began widely testing a new approach, Federated Learning of Cohorts (FLoC), that

enable targeted advertising without using third-party cookies.⁶¹ The core idea of FLoC is that the user would be assigned to a cohort containing on average thousands of other users through processing on their device, rather than a server collecting and processing data as would be typical when using third-party cookies. Specifically, as described in the project's GitHub repository, "the browser uses machine learning algorithms to develop a cohort based on the sites that an individual visits. The algorithms might be based on the URLs of the visited sites, on the content of those pages, or other factors."⁶² A cohort was intended to represent a set of users with related interests. Despite FLoC's name containing the phrase "federated learning," the proposal did not require the use of federated learning, a particular machine-learning technique that trains a model in a decentralized manner, for determining the user's cohort, although that was listed on the project's GitHub as a potential approach. Instead, initial prototype deployments included techniques like "applying a SimHash algorithm to the registrable domains of the sites visited by the user in order to cluster users that visit similar sites together. Other ideas include adding other features, such as the full path of the URL or categories of pages provided by an on-device classifier."⁶³

Privacy advocates widely criticized the FLoC proposal. Some characterized the proposal as "privacy theater" because the public relations campaign touting FLoC as an improvement to privacy clashed with its potentially negative privacy implications upon detailed consideration of the technical proposals.⁶⁴ For instance, one critique labeled FLoC as a "terrible idea" and note the cohort ID would make a user's browser far easier to fingerprint and enable companies whose users logged in to tie a cohort ID to the user's personal information. It would also be likely that a given cohort would overrepresent a particular demographic group, further enabling discrimination and other issues of unfairness.⁶⁵ Another critique further highlighted how FLoC would make information about the user available to many advertisers and publishers that previously did not have access to that information, and it would also expand tracking to include sites that did not previously participate in the tracking or surveillance capitalism ecosystems.⁶⁶

In response to this criticism, Google abandoned the FLoC approach a year later, in 2022. In its place, the company announced the Topics API. Like FLoC, the Topics API profiles a user in their browser, without sending data to a server. Whereas FLoC assigned a user to a cohort, however, the Topics API instead assigned a user to five interest categories.⁶⁷ Initially, the Topics API included around 350 interest categories, though this was envisioned to expand to thousands, none of which would include categories that Google labeled as sensitive.⁶⁸ While the Topics API received less vociferous pushback regarding privacy than the FLoC proposal, privacy advocates still noted it enabled Google, rather than users, to decide what information was sensitive, to choose where the user would be tracked, and to enable targeted advertising everywhere in the first place.⁶⁹

6.2.5 Cross-Device Tracking

Cross-device tracking is the process of tracking a user across multiple devices, such as computers, smartphones, tablets, and smart TVs. This can be useful to users when it allows them to suspend a video on one device and resume watching it on another or to maintain state between other types of sessions, e.g., web browsing sessions, across their devices. However, cross-device tracking can also be used to build rich user profiles across multiple devices, which companies may use for advertising or other purposes. Companies use both deterministic and probabilistic approaches to facilitate cross-device tracking. When users log into a service on each of their devices, companies can use deterministic approaches to know it is most likely the same user on each device. However, when users do not log in, companies can use probabilistic approaches like matching IP addresses to determine that the same user is likely logged into two devices simultaneously. Cookies, location, and behavioral data can also be used for probabilistic cross-device tracking. Companies build device graphs based on the inferences they have made about the devices used by a particular user. Users are largely unaware that this is occurring. In a 2016 study, researchers reviewed 100 popular websites and observed multiple ways that almost all the sites could engage in cross-device tracking. However, they were unable to determine definitively from the websites' behaviors or privacy policies which sites actually engaged in cross-device tracking.⁷⁰

6.2.6 Tracking Email Recipients

Many of the mechanisms that can be used to track what websites are visited from a particular computer can also be used to determine whether or not an email has been opened. Knowing when an email has been opened or when a particular link in the email has been clicked on can be useful for advertising companies to evaluate the effectiveness of a campaign, but it can also have more pernicious uses. Two common techniques for tracking email recipients are variants of the beacon and URL rewriting techniques used for web tracking.

Popular email programs, such as Microsoft Outlook and Gmail, can display emails containing HTML code, the markup language used to format many websites. HTML code enables emails to contain different colors, advanced formatting, and images, just like websites. Images can be attached to the email, or they can be downloaded automatically from a remote server. To determine whether a particular recipient has opened an email, the HTML code sent in an email to that user can request content uniquely tied to that user, e.g., accessed via a unique URL, to be downloaded automatically from a remote server when the message is opened by the recipient.

For instance, when Bob opens an email from ABC Advertising, the email's HTML code can instruct the email program to download a one-pixel image with a file name unique to Bob from ABCAdvertising.com. Since the advertising company controls the server, it can tell whether it has ever received a request for the image at that URL, which is unique to Bob. If it has, then it knows Bob opened the email, along with exactly when this occurred. If it has not

received a request for the image, Bob may not have opened the email, or he may have opened the email using a mail client configured not to download images by default.

As on web pages, links to websites that are included in an email can also be customized to track whether a user has clicked on them. An email might contain a link that will eventually bring the email recipient to a specific website, such as *www.big-sale.com*, if they click on the link. However, rather than containing a direct link to that page, the email might contain a link to *www.big-sale.com/174cx3a*, where *174cx3a* is an identifier sent only to Bob. Therefore, if *big-sale.com* receives a request for the page *174cx3a*, it knows this request originated from the email it sent to Bob.

Alarmingly, a 2018 study found personally identifiable information (PII), such as the recipient's email address, is frequently leaked to third-party email trackers.⁷¹ Unfortunately, the same study also observed that many existing defenses are insufficient for fully stopping email tracking. These defenses include filtering HTML, accessing content through a proxy, blocking cookies, and disabling HTTP referer headers.

6.2.7 Effective Practices

In crafting a system that tracks the activities of users on the internet for any purpose, it is essential to adhere to the core privacy principles of “notice” and “consent.” Key goals include providing clear notice about any tracking that occurs, asking users to consent to the collection of data, and explaining what information is collected, how it is used and stored, and with whom it may be shared.

Some jurisdictions have legal or regulatory requirements that mandate specific forms of notice or consent, or that restrict the use of trackers. For instance, the General Data Protection Regulation (GDPR), which came into effect in 2018 as the flagship privacy law in the EU, requires that:

Consent should be given by a clear affirmative act establishing a freely given, specific, informed and unambiguous indication of the data subject's agreement to the processing of personal data relating to him or her, such as by a written statement, including by electronic means, or an oral statement. This could include ticking a box when visiting an internet website, choosing technical settings for information society services or another statement or conduct...Silence, pre-ticked boxes or inactivity should not therefore constitute consent.⁷²

As a result of the GDPR and the earlier EU ePrivacy Directive, which came into effect in 2013, most websites have provided opt-in boxes when visitors from the EU first visit their websites. While website should set cookies only if a user has clicked a button or performed a similar opt-in action, a 2019 study found this not to be the case.⁷³

Violating either the privacy expectations or the trust of users can lead to serious repercussions in both the legal and public relations domains. For instance, a series of class-action lawsuits was brought over the use of LSOs for surreptitious tracking. Furthermore, privacy concerns about some of the tracking technologies discussed in this chapter led to

front-page coverage in major media outlets.⁷⁴ On the other hand, communicating clearly with users can directly benefit companies and organizations. For instance, a 2012 study revealed a confluence of privacy concerns and misconceptions that advertisers collect more personal information than they generally do leads users to oppose behaviorally targeted advertisements, suggesting openly communicating about practices the average user would deem reasonable might lead to increased user acceptance of tracking.⁷⁵

6.3 Blocking and Controlling Web Tracking

Users who wish to either block or limit web tracking have several options at their disposal. In recent years, some web browsers have begun including strong privacy features and privacy-protective default settings. Unfortunately, there is no single solution that protects a user against most tracking threats. Software that automatically protects users' privacy, such as an email client that blocks images from being downloaded by default, is simplest from the perspective of a user. More commonly, users are able to control web tracking to some degree by taking action, either by adjusting default settings in software they likely already have, configuring settings using a web-based interface, or downloading additional software designed primarily for privacy. Of course, for all but the automatic tools, the user must know to take certain steps, perhaps having learned to do so from the news media, a software vendor, or a friend.

Tools for blocking or controlling web tracking are often provided by groups that would not benefit directly from the tracking that is being blocked. For example, some tools are provided by organizations or companies that focus on protecting consumer privacy either as a public service or as a business goal. Other tools are provided by companies with a broad mission, including the makers of web browsers. As of 2019, web browsers like Mozilla Firefox, Apple Safari, and Brave Browser tout their privacy-protective features as a competitive advantage against other web browsers. The companies or organizations conducting the tracking themselves sometimes also provide tools for blocking or controlling web tracking, often for regulatory compliance or due to pressure from policymakers.

Beyond a user choosing to cease doing business with a particular company, tracking by first parties is much more difficult to prevent than tracking by third parties. Tools that block all requests to trackers, including first parties, break the functionality of most websites. Furthermore, in the United States, first parties are generally exempt from legal and regulatory frameworks concerning tracking. As a result, one of the few resources left to a user who chooses to engage with those sites is reading privacy policies to understand their practices. Unfortunately, past research found reading long privacy policies leads to unrealistic opportunity costs for the user,⁷⁶ these privacy policies are written at an advanced reading level, and privacy policies sometimes are not translated into the same languages as the rest of the site.⁷⁷

In this section, we discuss ways a user can block or limit web tracking by third parties, which include companies whose domains are not shown in the URL bar. After focusing primarily on how a user can block third-party web tracking designed to profile behavior across many websites, we also discuss how a user can prevent their web searches from being tracked and how a user can block email tracking.

6.3.1 Blocking Web Tracking

Web browsers' settings are a primary way for users to disable tracking based on HTTP cookies. In some browsers, privacy-protective processes are automatic, and this has increased substantially in recent years.

6.3.1.1 Privacy Settings in Browsers and Do Not Track

Browsers differ in the prominence and types of cookie settings they provide. If a browser blocks third-party cookies, third-party tracking becomes more difficult. Unfortunately, blocking all third-party cookies might cause some nontracking websites to work incorrectly, creating a usability tension between privacy and functionality. This tension between privacy and functionality, specifically that privacy-protective measures can “break” website functionality in numerous ways, has received increased attention in recent years.⁷⁸

At a high level, web browsers generally enable users to allow all cookies, allow only first-party cookies, or block all cookies. For many years, changing a browser's default settings for cookies has been one of the more straightforward ways to limit, but not completely stop, third-party tracking. As of 2023, browsers differ notably in the prominence of these settings in their user interfaces. Mozilla Firefox's cookie settings are featured prominently in its Privacy & Security menu, with a series of checkboxes to allow users to block third-party tracking cookies or all third-party cookies. On the other hand, Google Chrome's cookie settings are buried three menus deep. On the Settings page, the user must click “Privacy and Security,” and then the submenu Cookies and Other Site Data to see the option for third-party cookies. Rather than requiring users to change a number of settings, some browsers have begun to focus on providing a small number of privacy-level modes to minimize the burden on users. For example, Microsoft Edge allows users to choose between “unrestricted,” “balanced,” and “strict” modes of increasing privacy protection.⁷⁹

Default settings are a powerful tool for privacy because most users do not change default settings. When third-party cookie blocking is not on by default, users hoping to block third-party cookies must change the browser's default setting, which many users never do.⁸⁰ Crucially, at the time of press, browsers again differ in their default settings for cookies. Apple Safari was the first major browser to block all third-party cookies by default.⁸¹ As of 2023, Mozilla Firefox similarly blocks third-party cookies from known trackers by default.⁸² In contrast, Google Chrome and Microsoft Edge allow third-party cookies by default.

To strike a balance between privacy and usability, Firefox uses a list of known trackers curated by Disconnect to decide which third-party cookies to block, though the user can

choose to reconfigure Firefox to block all third-party content at the risk of a functionality loss. The idea of having a blacklist identifying tracking domains, as Mozilla Firefox and Microsoft Edge now offer based on the Disconnect list, has a long history in privacy.⁸³ For example, the long-deprecated Microsoft Internet Explorer 9 included Tracking Protection Lists (TPLs). With TPLs, third parties could curate lists of domains, and users could download these lists specifying whether or not requests to particular domains should be blocked. Notably, TPLs and browser-based cookie blocking do not require users to rely on websites to honor their requests since communication to those sites is actually blocked.⁸⁴

The Safari and Firefox default settings for blocking third-party cookies are part of their respective Intelligent Tracking Protection and Enhanced Tracking Protection features, which bring together a number of subtle privacy-protective design decisions for minimizing major tracking vectors.⁸⁵ For example, Safari's Intelligent Tracking Protection sets time limits for the retention of the cookies it does allow.⁸⁶ Even more aggressively, the privacy-focused Brave Browser offers the ability to block third-party tracking in a multitude of ways under its concept of browsing "shields," including using blocklists of known tracking domains, disabling third-party cookies, and using heuristics to detect and block attempts at fingerprinting.⁸⁷

Of course, at best, these methods only prevent tracking that uses cookies exclusively. Even without third-party cookies, allowing third-party requests can still enable tracking if the third party uses browser fingerprinting or employs other technical tricks, like the previously listed LSOs. In response, browsers have begun to make fingerprinting more difficult. For example, Mozilla Firefox introduced antifingerprinting features in 2019.⁸⁸

Furthermore, all major browsers offer private browsing modes that disable the storage of browsing data on a user's computer while the mode is enabled. Private browsing can provide a small amount of protection from tracking by deleting the cookies accumulated during that session when the browser is closed. A 2010 study demonstrated, however, that these modes are far from perfect technically. They also offer minimal protection from tracking and surveillance.⁸⁹ Furthermore, a 2018 study demonstrated users' expectations about the privacy protections provided by these modes often differ from the actual protections they provide.⁹⁰ Browsers like Firefox bundle independent tracking protection features with private browsing mode, potentially adding to confusion about the protections provided across browsers.

Recent years have seen the release of new web browsers designed specifically to be privacy protective. For example, the aforementioned Brave Browser, initially released in 2016, and the Epic Browser, initially released in 2013, utilize many of the previously described types of tracking protection, such as blocking trackers or always running in the equivalent of other browsers' private browsing modes.⁹¹ While the market share of these privacy-focused browsers remains small, some of the same protections have made their way into the default settings of widely used browsers.

In contrast to technical mechanisms that attempt to disallow or circumvent tracking technologies, an idea that received attention a decade ago was a Do Not Track (DNT) setting. The core idea of DNT was that it would be an HTTP header sent alongside requests for web content. This header would indicate that the user has requested not to be tracked, has actively chosen not to make this request, or no preference has been set. Since DNT does not actually block communication with a particular tracker, a user who has enabled this feature relies on companies to honor this request. After Mozilla implemented DNT in Firefox, all other major browsers added the setting. Notably, Microsoft automatically enabled DNT as the default setting in Internet Explorer 10, which led to protracted debate among industry and standards-body groups about whether or not trackers may ignore such default settings.²² In contrast, Google implemented DNT in Chrome in late 2012, well after the other major browsers, and buried the setting in an advanced menu and provided a message discouraging users from activating DNT.²³

Unfortunately, DNT was mostly a failure for meaningful privacy protection. The exact details of both the meaning and mechanism of DNT were debated over nearly a decade within the World Wide Web Consortium (W3C) as part of the Tracking Protection Working Group.²⁴ For example, one protracted debate about the DNT proposal centered on whether enabling this feature would mean that trackers could not collect information about a user, the preferred position of many privacy advocates, or whether they could collect information but not use the information to target advertising, the preferred position of many ad industry representatives. Questions also persisted about how websites should respond upon receiving a DNT signal. These debates, alongside low voluntary adoption by websites, led to DNT being mostly abandoned as of the time of press, including being removed entirely from Apple Safari.²⁵

The complex intersection between policy and technology is also visible in the design of deployment of browsers' user interfaces regarding cookies. While Microsoft Internet Explorer has since been replaced by Microsoft Edge, an example of the user interface for cookie preferences from earlier versions of Internet Explorer remains instructive. In contrast to other contemporaneous browsers, Microsoft Internet Explorer had a slider on which users could choose their privacy level, which thereby dictated their cookie settings. The settings for directly disabling third-party cookies, or disabling all cookies, were buried in an Advanced menu. A user's preferences based on this slider were evaluated using websites' Platform for Privacy Preferences Project (P3P) tokens. P3P is a machine-readable language with which websites can express their privacy practices, such as the information they collect and how this information is used. Microsoft Internet Explorer used P3P policies to decide whether to accept or block a cookie from a particular site. Thus, cookie decisions could be made on the basis of how cookies would be used. The default setting in the Internet Explorer 6 through 10 web browsers blocked third-party cookies when they do not have P3P tokens and when they have P3P tokens, indicating a privacy policy considered unsatisfactory by Microsoft's criteria.

Although P3P is a W3C standard, Internet Explorer was the only major web browser that used P3P, and P3P was not widely adopted by websites. Furthermore, some sites misrepresented their privacy policies by using nonsensical or sample P3P tokens, rendering P3P unreliable.⁹⁶ Microsoft sought to combat this loophole by including a Strict P3P Validation feature in Internet Explorer 10. If a user enabled this feature, which was off by default, the browser blocked “cookies from third-party sites that don’t have valid P3P policies.”⁹⁷

6.3.1.2 Web-Based Privacy Tools

Beyond using software tools already available on their computers, users can take advantage of web-based tools to learn about tracking. Some of these tools can also be used to control tracking in limited circumstances.

For example, a few companies that track users provide web-based dashboards through which users can view and sometimes edit the profiles these companies have constructed of their interests. Google, Facebook, Oracle BlueKai, and Nielsen all provide dashboards or equivalent ad-preference pages indicating advertising and targeting preferences.⁹⁸ Unfortunately, these dashboards tend to provide an incomplete view of the information that has been collected. In particular, the raw data collected is almost never shown to users. Furthermore, a 2018 study found even the high-level data shown to users was often incomplete and sometimes misleading.⁹⁹

A handful of advertising networks have begun to provide user-facing explanations of why they received a particular ad. These efforts are crucial both because humans struggle to understand the algorithmic processes underlying targeted advertising and because outside nations have used targeted advertising for influencing elections, such as in the 2016 U.S. election.¹⁰⁰ Unfortunately, these explanations are again incomplete. Predating detailed ad explanations, the industry standardized AdChoices icon and accompanying tagline has been used to identify targeted advertisements. However, a 2012 study found these icons and taglines poorly communicated to consumers that advertisements were being targeted to them or that consumers could click on these icons as a step in choosing not to receive targeted ads.¹⁰¹ Studies of the more detailed explanations provided by companies like Facebook have shown them to be factually inaccurate or incomplete, as well as insufficient from a usability perspective.¹⁰² Complicating this ecosystem, targeting can be based on data collected directly by a company, as well as by data purchased from outside data brokers.¹⁰³

Notifications about cookies are another mechanism of web-based transparency. As previously mentioned, an informed consent requirement for cookies that is part of the laws in the EU has prompted many websites to provide prominent notices about cookie options. As a result of the passing of the EU Directive 2009/136EC (“EU Cookie Directive”), implicit consent is no longer considered sufficient notice to consumers in certain cases when websites wish to set cookies.¹⁰⁴ As a result, in 2012, some sites began providing consumers with conspicuous notices about the use of cookies, often with options to disallow certain types of

cookies on that site. This requirement was reinforced when the GDPR came into effect in 2018 with similar consent requirements. Notifications about the use of cookies are now nearly ubiquitous for users in the EU upon their first visit to a website after clearing cookies. Nevertheless, websites sometimes still set cookies before consent is given, and a user who does not wish to accept the cookies is often resigned to not use the website.¹⁰⁵

A number of companies engaged in tracking also offer a system of opt-out cookies. Rather than being used for tracking, opt-out cookies are HTTP cookies indicating a consumer chose to opt out of receiving targeted advertising. Although users who have opted out will not receive targeted ads from a particular company, some companies will still track those users' online activities. Opt-out cookies are also problematic from a usability perspective since users who delete their cookies, as many privacy-conscious users might, also delete their opt-out cookies. Furthermore, setting opt-out cookies for each of the hundreds of tracking companies a user might encounter would take a long time. Centralized websites organized by industry groups offer a single place where a user can opt out from many companies at once.¹⁰⁶ However, research has identified major usability problems with these centralized websites.¹⁰⁷

6.3.1.3 Third-Party Browser Extensions

Browser extensions designed for privacy purposes are an additional mechanism for stopping web tracking. Some companies offer tools specifically designed to stop web tracking conducted by advertising networks, social networks and other companies interested in collecting what websites a user visits. For example, the partially open-source tool Disconnect is provided by a company of the same name. The company Cliqz offers Ghostery. Similar tools include the open-source Privacy Badger from the nonprofit Electronic Frontier Foundation (EFF).

These tools generally work by blocking the mechanisms used for tracking to varying extents. While some tools completely prevent the user's browser from communicating with those domains or trying to download those resources, others allow the request to go through, yet prevent the request from including cookies. Additional subtle modifications to requests, such as removing the HTTP referer field, can also protect the user's privacy in limited ways.

Some general-purpose browser add-ons can limit web tracking to an extent. For instance, the popular Firefox and Chrome extension Adblock Plus, designed to block large fractions of the advertising on the web, blocks requests to the domains of a number of advertisers and thereby limits the collection of tracking data by those particular advertisers. Similarly, NoScript, a Firefox add-on designed to prevent websites from executing JavaScript code and plug-ins like Flash, can prevent tracking that occurs using those plug-ins. Notably, HTTP cookies are sometimes created using JavaScript, and blocking the Flash plug-in can prevent LSOs from being set.

A major dilemma with all these tools is the burden they impose on users, who must take a number of steps to protect their privacy. Generally, these tools first require a user to install the tool, either from the developer's website or from a centralized repository. Following installation, tools often ask a user to choose configuration options. Over time, the tool may automatically update itself, or user intervention may be required to install the newest version.

Unfortunately, neither specific privacy tools nor general-purpose add-ons are necessarily easy for an average consumer to use. For example, a 2012 study of web-tracking privacy tools revealed serious usability flaws in all nine of the popular tools it tested.¹⁰⁸ Pervasive usability flaws identified by the authors included nonprotective default configurations incommensurate with the goals of a privacy tool, confusing interfaces, and jargon. In addition, study participants found it difficult to make decisions required by the tools about what advertising companies to block, what blacklists or whitelists to choose, and what tracking technologies to disallow. Furthermore, a 2016 follow-up study found major gaps in users' understanding of the tracking ecosystem even after using these types of tools.¹⁰⁹

6.3.1.4 Deciding What to Block

Many privacy tools ask users to configure settings and decide what to block. However, a user's decision about what to block can be fraught with complexity. Based on interviews with forty-eight nontechnical users, a 2012 study concluded that users have great difficulty reasoning about tracking technologies and evaluating companies to block; they also hold major misconceptions about how behavioral advertising works.¹¹⁰ However, users are not alone in facing this difficulty. Software designed for blocking also must decide what to block. If a tool blocks too little, it will be ineffective. However, if it blocks too much, it may break web functionality, leading users to be annoyed and potentially abandon the tool.¹¹¹ Furthermore, widespread adoption of a tool that thoroughly blocks existing tracking methods might lead trackers to adopt increasingly surreptitious and subtle methods of tracking.

Instead of asking the user to make a decision about each potential tracker, organizations or individual experts can compile a list of domains or patterns to block. Precompiled lists have been used by tools ranging from the Adblock Plus browser extension to Internet Explorer's Tracking Protection lists. Although they can ease the decision-making process for users, lists have their own drawbacks. Some tools, such as the Disconnect browser extension and Mozilla Firefox's built-in Tracking Protection feature, which also uses Disconnect's default Level 1 block list, maintain a default blacklist of domains or resources tied to tracking.¹¹² In these cases, users can achieve a fair amount of privacy by keeping the default list, though Disconnect's more aggressive Level 2 block list would achieve greater privacy, albeit at the expense of website functionality. Other tools, however, require users to choose a list from many options. The since-deprecated Internet Explorer's Tracking Protection feature took this approach. However, users need to be aware they must select a list, and they also must be able

to evaluate potential choices, both of which have been shown to be difficult.¹¹³ Furthermore, by their nature, lists will not conform exactly to an individual user's privacy preferences, which tend to be complex. It is also possible for lists created by one organization to cause competitors' pages to be blocked or to serve business interests, further complicating the compilation of lists. The advantage of lists is they provide users a simple one-size solution that can be tailored to fit their needs.

Some tools use partially automated metrics for determining what to block. For instance, the EFF's Privacy Badger browser extension uses heuristics and algorithmic methods to identify potential tracking and automatically choose what to block.¹¹⁴ In contrast, the since-deprecated Microsoft Internet Explorer used P3P tokens specified by websites to determine what to block. Furthermore, some versions of Internet Explorer determined when to block cookies from a domain using frequency counts, which are running totals of the number of different first-party domains on which a particular tracker has been seen by that user's browser.¹¹⁵

Other tools are designed to help users visualize this sort of frequency information. Prototype browser extensions developed by privacy researchers in recent years have sought to provide richer and more granular information about what data companies collect about users and what those companies can infer about the user from that data.¹¹⁶

Differences in the extent to which tools block tracking add more complexity to users' efforts. A tool that blocks too little leaves the user easily vulnerable to tracking, whereas a tool that blocks too much can break the functionality of the websites that the user hopes to visit. Some tools, including the general-purpose script-blocking tool NoScript and web-tracking-privacy tool Ghostery, break functionality on websites in ways that may be obvious or opaque to users. To proceed with their browsing, users might try to unblock specific elements until a page loads, disable the tool entirely or adopt ad hoc solutions, such as using a different browser without the privacy tool.

Researchers have coined the term "functional privacy" to capture users' willingness to aim for as much privacy as they can get without breaking the functionality of what they hope to accomplish on the web.¹¹⁷ However, it remains to be seen whether such a conception would incentivize trackers to break the functionality of pages intentionally. Along these lines, tools that aim to provide privacy without breaking website functionality have been proposed. Other tools try to create decoy traffic to obscure the user's true behavior. For instance, the AdNauseum browser extension automatically tries to click on every ad it observes.¹¹⁸

In place of a web-based tool or software, some users create ad hoc strategies or adopt overriding strategies. For instance, some users might use different browsers with different privacy settings, using a less privacy-protective browser when a site's functionality breaks with a more privacy-protective setup. In contrast, other users employ privacy-preserving proxies that are designed to scrub their web requests from potential identifying information, such as cookies, HTTP headers, and their IP address, along with tunneling requests from

many users through the same channel. Like all other solutions, proxies are not a perfect solution and can certainly still leak information about a user. They can also break web functionality.

Implicit among the challenges of protecting user privacy against web tracking is the complex nature of privacy decision-making. Past research has demonstrated that privacy is often a personal process in which different users will have very different preferences.¹¹⁹ Furthermore, privacy depends on context, which is a notion currently unsupported by major privacy tools.¹²⁰ Overall, a user has many tough choices and few easy solutions when attempting to stop web tracking.

6.3.2 Blocking Tracking of Web Searches

Users who wish to protect their privacy when using search engines also have a handful of mechanisms available. However, this task is more complex since most privacy tools for limiting web tracking focus on third-party tracking. Disabling tracking mechanisms on first-party sites will often break those sites' functionality. As a result, the simplest and most secure way for a user to minimize having private information leaked through web searches is to use a search engine that promises not to track the user. Alternatively, users can download tools that help them obscure their searches by inserting a large number of decoy requests, or they may use proxies or other general-purpose tools to make their searches more private, although only to an extent.

In recent years, a handful of search engines have begun to use privacy-protective practices as a competitive advantage. The most popular search engines generally save a user's search history, including their search queries, when these queries occurred and information such as the user's IP address and unique identifiers from cookies. In contrast, privacy-protective search engines, such as DuckDuckGo, promise to neither collect nor share a user's personal information. By default, DuckDuckGo does not use HTTP cookies except to save preferences about the page layout a user has chosen, nor does it allow the HTTP referer field to contain information about the search query. However, users must trust DuckDuckGo and similar sites to fulfill their privacy promises.

Users who wish to hide their search history can also download a tool to assist them, although few tools exist for this purpose. TrackMeNot, an add-on for Firefox and Chrome, protects a user's privacy by issuing decoy queries to major search engines.¹²¹ As such, it operates by achieving security through obscurity, creating ambiguity about whether a particular query was issued by a user, or whether it was issued automatically by the program. The plug-in's behavior is meant to mimic that of a real user. For example, it sometimes performs a large number of queries in a short amount of time, and it selectively chooses whether or not to click through to a link.

Users can also use general or ad hoc techniques to prevent their searches from being tracked. For instance, a proxy or an anonymizing network such as Tor can strip some or all

the identifying information from web traffic, making a user's searches more difficult or impossible to track. However, it is possible for private information to leak even when using techniques such as the TrackMeNot plug-in and anonymizing services. Researchers have shown that users who enter their own name or other PII in searches can still be vulnerable to having their searches tracked even if they would otherwise be anonymous.¹²²

6.3.3 Blocking Email Tracking

In contrast to web tracking, the issue of email tracking has become a less pervasive problem in recent years without direct user intervention. A number of modern email clients block beacons, images, and other content loaded from external sites since this external content could be used for tracking. This behavior disables one of the most widespread techniques for determining whether an email has been read. Unfortunately, not all email clients block outgoing requests by default, nor implement related privacy-protective measures.¹²³

Furthermore, users are unlikely to realize the privacy-protective benefits of blocking images, and they might turn off this feature without considering the implications as email clients' user interfaces rarely explain why external resources and images are blocked by default.

However, since tracking can still be accomplished through URL rewriting, it is important privacy-conscious users also do not follow links contained in emails. If a user does not follow links contained in emails, tracking using URL rewriting cannot succeed. Furthermore, due to the threat of phishing attacks, it is generally considered good practice not to follow links in emails whenever the user must enter information at the destination. Even if a link in an email does not seem to contain any type of unique identifier, users who follow the link or otherwise access that information on a site are subject to web-tracking techniques.

Mail servers themselves can also handle external images and beacons in a way that makes emails less able to be tracked. For instance, Gmail automatically serves all images in emails through its own proxy, meaning Gmail users reveal when they open an email to trackers, but not where they are as indicated by their IP address.¹²⁴ Alternatively, to prevent trackers from even knowing when a user opens an email, mail servers could automatically download external content immediately upon receipt, although this technique again has numerous subtleties in practice.

Finally, a common ad hoc technique to prevent email tracking is for a user to maintain multiple personas online. As it is often free to create an email account, and many users have multiple email accounts. If a user has created an account exclusively for receiving email solicitations, they may not mind if a company knows when that account has read an email since the account may not be tied to any real-life identity. Of course, subtle information leaks are possible. For instance, the date and time the email has been read, as well as a user's IP address, browser configuration, and HTTP cookies, can reveal substantial information about that user to a company. In addition, a person who uses a separate email account and then makes a purchase tied to that email address from one company is at risk for having their

identity tied to that account, even by other companies with whom this purchase data is shared or to whom this data is sold.

6.3.4 Effective Practices

Currently, a user who hopes to prevent their activities on the web from being tracked is put in a difficult position. To protect against the myriad different tracking threats, a privacy-conscious user must often use a patchwork of tools. Even with substantial effort, it is unlikely the user will feel fully in control of their privacy. For instance, there are always potential tracking mechanisms that a researcher or newspaper may soon reveal have been put into use, and the data that has been collected about a user's activities is rarely made available to the user. Furthermore, whereas some tools provide a technological solution by blocking one or more mechanisms used for tracking, other tools require a user to trust that a company or website will respect a set preference or follow a practice the company has advertised.

While there are no perfect solutions for users to protect themselves against tracking, there are many effective practices that should be followed by the companies or organizations providing users with tools to protect their privacy. The inclusion of a graphical user interface and colorful icons does not magically make a privacy tool easy to use. Rather, to craft a tool that actually helps consumers protect their privacy, careful consideration and substantive feedback from user testing is essential, albeit often overlooked.

It is important for users to be made aware of tracking in the first place. User education can take many forms, ranging from prominent disclosures from trackers themselves to media stories warning of privacy risks. Regardless of the type of communication, it is essential for communication to be both clear and prominent. This issue has taken on particular importance following debate over the EU's disclosure requirements for cookies, in which regulators deemed it insufficient when a user is considered to have implicitly consented to tracking after being informed of this practice only by a lengthy privacy policy. In contrast, it is considered effective practice to provide users with conspicuous, clear and understandable notice about tracking and to give them the opportunity to choose not to be tracked. Unfortunately, the implementation of EU cookie notices in practice has been of questionable usability and utility for users.

Of course, the mechanisms for allowing users to choose not to be tracked have their own effective practices. First, users should not be expected to make decisions about particular technologies. When a user expresses a preference not to be tracked, the developer might wonder whether the user wants to block tracking accomplished using LSOs, only tracking using HTTP cookies, or both. However, this is likely the wrong question to ask. Users' preferences are often technology neutral. It is essential for privacy tools to match this expectation to the greatest extent possible. Furthermore, privacy-protective default behaviors should be chosen when they will not interfere with desired functionality. For instance, in the case of preventing beacons from tracking whether an email has been read, email clients

automatically block these requests without requiring the user to do anything. Any actions for which user intervention is required should be able to be completed quickly, and any interfaces presented to the user should be tested extensively in usability studies to ensure they can be used with few or no errors.

6.4 Location Tracking

With the ubiquity of mobile phones with location-tracking capabilities, the ability to draw on constant location information has become prevalent. Social networking apps, employee-tracking systems, and location-enabled media, such as photos that contain metadata, are among the technologies that use this location data to enhance their systems.

Location tracking also extends beyond the mobile phone. RFID chips are often embedded in smart cards and consumer products. If an RFID reader detects a particular RFID chip at a given location, a particular user's location can be revealed. GPS and other tracking technologies are emerging in consumer hardware like cars and cameras. In such a world, those deploying tracking technologies should be aware of their capabilities as well as their potential privacy implications.

This section outlines location-tracking technologies and services, techniques for blocking location tracking, and effective practices for those employing location-tracking technologies.

6.4.1 Location-Tracking Technologies

Devices can contain a wide variety of location-tracking technologies, each of which relies on slightly different types of underlying systems. We describe several of the most common location-tracking technologies: Wi-Fi and cell tower triangulation, GPS, RFID chips, and phone tracking, as well as the use of location data stored in content metadata.

6.4.1.1 Wi-Fi and Cell Tower Triangulation

Wi-Fi and cellular signals can be used to allow a device that is enabled for Wi-Fi or cellular communication to determine its location. Cellular phones communicate with cellular towers that receive their signal and connect phones to a global network. The time it takes messages from a particular cell phone tower to arrive to a phone, the strength of the signal from that tower, and, most simply, the towers a phone can communicate with all reveal information about the phone's location. After determining the phone's position relative to a handful of towers whose locations are known by the cellular provider, the position of the phone can then be determined geometrically through triangulation.

In addition to signals from cell towers, the Wi-Fi signals a phone receives can help determine its location. Wi-Fi signals have a shorter range, allowing for more fine-grained location information. Cell towers provide a more permanent location marker but less granular location data. Wi-Fi and cell tower triangulation requires the creation of a preexisting database of Wi-Fi access points and cell tower locations that cover the region

where the location tracking will occur. Thus, this type of location tracking is primarily beneficial in urban areas where there is a high density of Wi-Fi access points and cell towers.

6.4.1.2 GPS

GPS satellites can also be used to determine location, specifically the device's longitude, latitude, and altitude. Many consumer devices, including mobile phones, are equipped with GPS capabilities for location tracking. Cameras and similar devices can also include GPS capabilities for tagging the location of photographs, and automobile infotainment systems can include GPS capabilities to pull regional content, such as weather and news-related information, into the vehicle's navigation system.

From a technological point of view, it is important to understand that GPS involves a device locating itself using signal it receives from satellites, rather than sending any signals to satellites. Specifically, GPS calculates a device's location using signals received from at least four of a set of dozens of geosynchronous satellites positioned in space and run by the U.S. government.¹²⁵ Based on the differences in the time it takes messages from these different satellites to arrive to a receiver, a GPS receiver can determine its position relative to each satellite. Since these satellites' positions are known and constant relative to the earth, the GPS receiver can determine its own position geometrically. Because devices receive and do not transmit any signals in the GPS process, devices do not automatically reveal their locations by using GPS. However, devices with GPS can also include transmitters that can reveal the device's location to other parties and services. For example, a smartphone that determines its own location by receiving signals from GPS satellites might subsequently, and automatically, share that information with an app or the phone provider.

6.4.1.3 RFIDs

RFID chips are microchips that can be as small as a fraction of a millimeter. Each microchip is identified by a unique serial number and contains an antenna it uses to transmit information, such as its serial number, to an RFID reader.

RFID chips can be placed on products or cards or implanted in animals, such as household pets, for tracking purposes. They are commonly used in supply-chain management to allow companies to track inventory. Passive RFID chips, which do not contain their own power source, are the most common. When power is applied by an RFID reader, these chips transmit a signal encoding their identifier. Active RFID chips contain their own power source, which allows them to transmit farther than passive chips. Depending on the type of chip and its power, particularly whether it contains its own power source, the signal can be picked up at varying distances. RFID chips transmitting at low frequencies have a range of about half a meter, while those transmitting at ultrahigh frequencies can reach readers located dozens of meters away.¹²⁶ The unique serial number associated with each RFID tag allows for location tracking. Tagged items are tracked as the readers pick up the tag IDs at different

locations. If additional information is stored on the tag, the reader is also able to pick up that information and associate it with the tag's location.

6.4.1.4 Phone Tracking

The location of a mobile phone and the individual it belongs to can be tracked using receivers installed within a building complex. The FCC also requires phone companies to be able to track phones when an emergency call is placed via 911.¹²⁷

An application of phone-tracking technology came to light during the 2011 holiday shopping season, when two U.S. shopping malls tested a system to track shoppers within the mall based on the locations of their cell phones as part of a "mobile phone survey." Signs notified the shoppers that the tracking was taking place, and shoppers had the option to opt out by turning off their cell phones. The malls ended the survey early after concerns about shopper privacy and the legality of the survey were raised.¹²⁸

6.4.1.5 Bluetooth-Based Tracking Tags

In recent years, Bluetooth-based tracking hardware has become a common way to track luggage, keys, and other possessions. The list of such hardware includes Tiles, SmartTags, and, perhaps the most popular, Apple AirTags. For example, AirTags use Bluetooth to connect to any nearby Apple devices with the "find my" feature enabled, and these devices do not necessarily belong to the same person who owns the AirTag.¹²⁹ As a result, AirTags can plausibly work anywhere in the world where Apple devices are nearby. When an AirTag connects to a compatible device, the connected device sends this information alongside its own geographic location to the owner of the AirTag. This process is encrypted, which means Apple does not learn the location information of the AirTag or connected device, and the owner of the AirTag does not learn about the device used to forward this information.¹³⁰

Despite the anonymous design of these communications, which seem to embody privacy principles, AirTags and similar devices still raise important privacy concerns. Most notably, a stalker could surreptitiously place an AirTag on a victim's possessions, rather than their own, enabling them to receive digital updates about the victim's location. In the first year after they were introduced in 2021, over 150 police cases documented AirTags being used for stalking, leading to a class-action lawsuit.¹³¹ In response, Apple and Google began developing new techniques to alert users that an unknown AirTag was regularly near them.¹³²

6.4.1.6 Metadata

Location information can also be automatically stored in the metadata of content, like photos. Metadata is information automatically or manually added to content that can be later accessed and used during processing or by applications. For photos taken with GPS-enabled devices, such as cell phones or GPS-capable cameras, location is often automatically stored in the camera metadata, sometimes without the user's awareness. When the photos are loaded into photo-browsing or -editing apps, this information is then accessible to the user or app, potentially raising privacy concerns.¹³³

6.4.2 Location-Based Services

Location-based services draw on the data provided by location-tracking technologies to augment a variety of systems, including social media and other location-based apps.

Emerging uses of location-based services include tracking individuals, such as employees or children, and location-based advertising. Location-based information can also be combined with other data to create new apps.

6.4.2.1 Social Media

A variety of social media apps use location tracking as the basis for, or to augment, their services. Some apps are primarily focused on allowing a user to notify others of their location and to track others' locations. One such app is Foursquare, a mobile app that allows users to "check in" at locations and view their friends' check-ins. Users are further motivated to check in by the ability to earn badges and receive coupons for participation. Similarly, Find My Friends is an Apple app for iPhones, iPads, or iPods that shows the location of a user's friends who use the service.¹³⁴

Other apps include location-based features to augment their services. Facebook Places allows users to check in at locations and tag shared items with location data.¹³⁵ Yelp, a site that allows users to rate restaurants and other services, includes a feature with which users can physically check in to the locations of the service providers.

6.4.2.2 Location-Based Apps

A variety of other apps rely on location-based services for functionality. These include apps that provide maps and directions on cell phones or GPS units, local weather apps, and apps that query a user's location to provide information on nearby services, items, or individuals.

Apps that provide maps or directions typically rely on location-based services to pinpoint a user's location. The app then provides a map of the user's current location based on a database. GPS navigation is often used in car-based units to help users navigate street maps. The user's location is provided using GPS, and maps are provided based on a database of street maps. In both examples, direction routing is performed based on mapping algorithms.

Smartphones also often provide map and direction functionality, which use a combination of GPS, Wi-Fi, and cell tower triangulation to calculate a user's location. Google Maps for mobile devices is one example of such a mapping app.

Other apps use location information to provide location-specific content. For example, weather apps track a user to provide location-specific weather alerts or updates. Additional apps provide information about services, items, or individuals in a user's vicinity. Many mapping apps allow users to search for the nearest restaurants, gas stations, or other services.

When a smartphone or other location-enabled computing device is lost or stolen, location-based apps can also help the owner locate the device. For example, major smartphone manufacturers have built competing apps with names like Find My Phone for this purpose.¹³⁶ Upon logging into such an app from another device, the user can often view the

device's location on a map. Many of these apps also enable a user to remotely trigger the device to play a sound or make other audible signals of its location.

The widespread availability of location information on smartphones also enables apps to geotag data, which means labeling the data with the geographic location where it was created. For example, users of the popular image-sharing service Instagram frequently geotag their photographs.¹³⁷ Carelessly assigning geographic metadata to content can create privacy and security risks. For instance, geotagged information posted to social media can alert robbers that an individual is away from home or leak an individual's precise address to stalkers.¹³⁸ In 2007, geotagged photographs posted online enabled enemy combatants to locate and destroy U.S. Army helicopters on a military installation.¹³⁹ Similarly, over a decade later journalists highlighted how geotagged information from the fitness app Strava inadvertently showed the outlines and paths of overseas U.S. military bases.¹⁴⁰

6.4.2.3 Tracking Children and Employees

Location-based services can also allow users to explicitly track others. Parents can use the GPS in their children's cell phones to perform location tracking. For instance, dozens of parental control apps allow parents to remotely track their child's smartphone.¹⁴¹ Some online services also allow parents to see where their children are throughout the day using either a specialized cell phone or a normal calling plan.¹⁴² Use of these types of location-based apps for parental controls can exacerbate tensions between children and their parents, as parents struggle to adapt their parenting strategies to the technologically filled world in which their children live.¹⁴³

Just as employers can use online surveillance to monitor employee computer usage, they can also use location tracking to monitor or track employee whereabouts. This can be done to reduce company liability, address potential threats to security, and track operational efficiency. Employee tracking can be performed using RFID chips or GPS trackers carried by the employees.¹⁴⁴

Due to the COVID-19 pandemic, the prevalence of work-from-home arrangements for employees increased dramatically, enabling a new frontier of tracking and impacting employees' emotional well-being.¹⁴⁵ Sometimes with and sometimes without the knowledge of the employees being surveilled, companies use tools to log remote workers' keystrokes, take screenshots of what they are doing, monitor the websites the employee is visiting, and calculate analytics that purport to describe the employee's productivity and engagement.¹⁴⁶

6.4.2.4 Location-Based Ads

Location-based information also provides a rich data source to advertisers, allowing them to create advertising that specifically takes an individual's location into account. Advertisers can offer advertisements or marketing offers tailored to a specific location based on data from mobile devices with location identification or a user's self-identified location on services like social networks. Advertisers can take advantage of user location in a variety of ways. The first

is to specifically identify the consumer's physical location, often by determining the location of their smartphone. An advertiser can either constantly track the consumer's phone or use a "geofence" to determine when the consumer is in the vicinity of a specific, targeted location. Advertisers can also use consumer's location check-ins on various services like Facebook or Foursquare to determine the consumer's location and offer targeted advertising.

Mobile devices equipped with near-field communication (NFC) are another technology that can support location-based advertising. NFC allows devices in close proximity, or that are touching, to transmit information via radio waves. This allows consumers to access content at a specific location.¹⁴⁷ However, location-based advertising presents privacy concerns. In 2011, a study of theoretical sharing preferences by Patrick Gage Kelley et al. found users had significant privacy concerns about sharing their location with advertisers, but these concerns were somewhat mitigated when users had the ability to restrict sharing based on their location or the time of day.¹⁴⁸

6.4.2.5 Combining with Data from Other Sources

Location information drawn, for example from mobile devices, can be combined with data from other sources to allow inferences that would not be possible with each data source taken individually. For instance, the Please Rob Me website gained media attention in 2010 for its possible privacy implications. This site aggregated information from users' Foursquare and Twitter accounts to create a list of people who were likely not at home since they were currently checked in elsewhere. Controversy over the privacy implications of combining location data with data from other sources erupted again in early 2012 when the Girls Around Me phone app used gender information from Foursquare accounts, as well as location information provided by check-ins, to allow users to search for women in their vicinity. Foursquare found the app violated its policies and shut off the developer's access to *its* data.¹⁴⁹ However, this scenario provides an example of how inferences can be drawn from location-based data and can lead to privacy concerns.

6.4.3 Geographic Information Systems

A geographic information system (GIS), such as a computer database or imaging tool, is a technology used to view and manipulate stored geographic information. Such geographic content could relate to any quantities associated with a particular location, including maps, population or other census statistics, or data about a specific resource at a location. Uses for GIS range widely. They can include logistics systems used for businesses, such as airlines that need to track passengers, utility companies that need to direct crews, and agricultural applications for planting decisions.¹⁵⁰

6.4.4 Preventing and Controlling Location Tracking

The range of location-tracking technologies and the uses for location tracking can present privacy concerns. It is possible to block some types of location tracking on mobile devices.

However, even when a mobile phone is turned off, it is often still possible to use the triangulation techniques discussed in this chapter to track its location as long as the phone's battery is connected. Furthermore, it is not always preferable to block location tracking, as the addition of location data can augment a service. Thus, systems are also being developed to allow more granular control over location sharing for location-based apps. Additionally, current research examines ways to preserve privacy in location-sharing technologies.

6.4.4.1 Blocking Tracking

Depending on the type of location-tracking technology, users can block or limit tracking to varying degrees. For location-based services that automatically include location data or include it when the user opts in, such as checks in on a social network, a user can either opt out of location tracking or remove location data from content after the fact. The mechanism for opting out of location tracking varies based on the technology used. For some services, like location-based services that rely on check-ins, users are opted out by default and are required to check in to be tracked. For other services, like adding location data to posts on the social platform X, the user can choose to turn location tracking on or off. Still other services, like some smartphone apps, require users to decide whether to enable location tracking when they download the app. In this case, a user can opt out only by choosing not to use the service.

Users can also remove location data from some content after it has been added by the app. For example, it is possible to use photo-editing apps to delete location metadata from photos after they are taken.

Tracking through RFID chips can be physically blocked, or in some cases, the RFID chip can be physically removed. Because RFID chips rely on a radio wave signal for tracking, a protective sleeve can be placed over an item that contains an RFID chip to prevent the chip from being read until the user desires the chip to be readable. This is useful for items like passports, which include chips containing information that users do not want to be accessible until a certain time. RFID chips can also be removed from items like clothing or other products to prevent tracking, although such techniques prevent the use of the information on the RFID chip later.

6.4.4.2 User Controls

Although it is possible to block tracking to various degrees, sometimes it is more desirable to control who has access to different types of location data at different times. Technologies like geofences let users control the boundaries of location tracking using geographic guidelines. Location-based services can enable users to set privacy settings to different levels of granularity, giving users control over who has access to their location information at what times. At a basic level, Foursquare allows users to prevent anyone they have not accepted as a “friend” from viewing their check-in location data.¹⁵¹ This is known as setting a whitelist, or setting up a group of people who always have access to the data.

It is also possible to allow privacy settings along more granular dimensions. For example, a 2017 study served as a proof of concept for restricting Android phones' sharing of location data and other types of information to contextually appropriate circumstances.¹⁵² In earlier work, researchers found users' location-sharing preferences varied based on the types of information they planned to share, group they planned to share it with, time of day, day of the week, and their location.¹⁵³

An important first step in encouraging user control of location data is making them aware their location is being shared or used in the first place, as Apple and Google attempted to do for AirTags in response to their use by stalkers. The information that ought to be communicated to users, though, often varies based on the technological context. A 2013 study prototyped an interface for notifying users about data leaks on smartphones.¹⁵⁴ A subsequent 2015 study demonstrated how quantifying these leaks of location information can nudge users toward more privacy-protective behaviors.¹⁵⁵

6.4.4.3 Research into Privacy Protections for Location

Beyond methods for controlling location sharing, research has been conducted on methods for providing the benefits of location sharing while preserving a level of user privacy. Privacy-preserving, location-based services are difficult to achieve. It is difficult to completely deidentify an individual's location trace. Patterns in an individual's location, such as their home and workplace, can uniquely identify many people.¹⁵⁶ In 2011, a group of researchers prototyped a system for detecting, in a privacy-preserving manner, whether two users of a location-based service were near each other. They used location tags, which are signatures associated with a location, to allow users to detect whether they are in proximity to another user without giving away either user's exact location, detecting another user's exact location, or revealing locations to any other users.¹⁵⁷

6.4.5 Effective Practices

There are numerous location-tracking technologies and opportunities to include them in location-based apps. Additionally, there are a variety of potential uses for such location-based apps. However, when creating and using systems that use location-tracking technology, it is necessary to keep in mind the privacy implications of tracking an individual's location. Location tracking should be included in a system only if it provides a direct benefit, and, wherever possible, should be an opt in rather than opt out. Once data is collected, users should be able to easily see what information has been stored about them and delete or update any past location data.

Collected location data should be considered privacy sensitive. Users should be informed, through a privacy policy or other means, of how their location information will be used. If it is going to be used in an unexpected manner, it is effective practice to ensure users know about this ahead of time. Additionally, before making location data more publicly available, it is effective practice to carefully consider how it might be reused or combined with other

datasets. Combining location data with other sources can provide a rich dataset, as many GIS systems show. However, as Foursquare's Girls Around Me app demonstrated, it can also be privacy invasive.

When using location-based apps to track others, such as in a workplace setting, it is effective practice to limit such tracking to instances with a clear need and to inform employees about the tracking whenever possible. Additionally, tracking should take place only while the employee is working. If tracking is done through a mobile phone an employee also carries during nonwork hours, tracking should be limited to the workday. Once tracking data is collected, it should be used only for necessary purposes and access should be minimized.

6.5 Audio and Video Surveillance

In this section, we consider the role of audio and video devices in enabling surveillance. In recent years, audio and video devices have been widely deployed. Consumer smartphones typically contain both a microphone and a camera. Cameras are being deployed in urban and private environments. Drones are being used to capture images over wider areas and to relocate video surveillance dynamically. Household voice assistants, such as Amazon Echo and Google Home, are widely deployed in homes. The combined effect of these trends is a large-scale network for audio and video surveillance.

6.5.1 Hidden Cameras and Microphones

Hidden cameras and microphones can provide video and audio surveillance without a person's awareness. Such devices can be purpose-built for surveillance, while smartphones, laptops, or other consumer electronic devices can be repurposed through malware to serve as hidden cameras or microphones. Form factors also vary. For example, some hidden cameras and microphones can be very small or disguised as other objects, as is the case with "nanny cams." They can either record information wirelessly or transmit data back to the person performing surveillance.

6.5.1.1 Smartphones as Hidden Cameras and Microphones

An individual's smartphone can be transformed into a hidden camera and/or microphone. Smartphones contain microphones and cameras that can be remotely activated, as well as a connection to the internet that allows for the remote activation and transmission of the surveillance data. This use of a remotely activated smartphone microphone is called a "roving bug."

Under the U.S. Wiretap Act, it was found legal for the Federal Bureau of Investigation (FBI) to use remotely activated cell phone-based audio surveillance in the case of *United States v. Jon Tomero*.¹⁵⁸ In the example that led to this case, the FBI used roving bugs on two mob bosses' cell phones to provide surveillance on conversations that occurred near the phones.¹⁵⁹

Through malware on the phones, remote attackers can also install roving bugs. Smartphones have little antimalware protection, and smartphone malware is a growing attack vector.¹⁶⁰ Through smartphone malware, an attacker can gain control of the microphone and camera to capture surveillance on an individual.¹⁶¹ In addition, intimate partner abusers sometimes install apps on their partners' smartphones that enable them to spy on the victims and transmit audio, video, location data, text messages, and call logs to the abuser.¹⁶²

6.5.1.2 Monitoring through Laptop and Desktop Computers

Laptop and desktop computers also allow for audio and video surveillance. Like smartphones, computers typically have microphones and cameras with network connections. This makes them vulnerable to eavesdropping. As with smartphones, surveillance can occur after a user inadvertently installs malware on their computer, allowing an attacker to take control of the camera and/or microphone. In a chapter of *Emerging Challenges for Security, Privacy and Trust*, Ryan Farley and Xinyuan Wang describe an example of how malware can be uploaded onto a computer, take control of a user's microphone for audio surveillance, and simultaneously hide its own existence.¹⁶³ These types of malware, often known as Remote Access Trojans (RATs), are controlled by a complex web of operators, as shown in a 2017 measurement study.¹⁶⁴

Surveillance through computer cameras or microphones can also occur when the computer is owned by one entity and used by another, such as when computers are distributed by an employer or school. However, the use of hidden surveillance has legal implications that are still becoming apparent as privacy issues emerge.

A recent case illustrates this legal issue. In 2010, it a Pennsylvania school district was discovered using the webcam feature on district-owned laptops to remotely take pictures while the laptops were in student homes. This remote monitoring became apparent after pictures taken at a student's home were used to confront the student about potentially inappropriate behavior in their home. While the district claimed the purpose of this feature was to track lost laptops, it did not inform the parents or students that it was able to remotely perform video monitoring using the laptops, despite using the feature 42 times over a 14-month period.¹⁶⁵ The parents of the student whose surveillance photo initiated the case sued the school district for violation of privacy, leading to a settlement of over USD600,000.¹⁶⁶ There were additional federal and state investigations of whether the district had violated federal wiretap or other privacy laws.¹⁶⁷

6.5.1.3 Smart Televisions and Their Use in Audio Surveillance

In recent years, televisions have begun to support richer interactions by connecting to the internet, as well as by sometimes including microphones for voice control. While these new features can improve the user experience and enable seamless access to a wider array of content, they unfortunately can also enable surveillance.

For most smart televisions to recognize voice commands from users, they transmit the recorded audio to a remote computer server to handle the computationally intensive speech recognition tasks that interpret the spoken command. For example, Samsung SmartTVs transmit voice commands to a third party for processing, as well as for research into improvements of the speech-recognition algorithms. As a result, these smart televisions are continually recording even the incidental conversations that take place in range of their microphones, leading to a number of privacy issues.¹⁶⁸ The collection of audio data from microphones is not the only privacy concern for these devices. Many smart televisions employ automated content recognition (ACR) to determine what the user is watching. Consumers may not be aware that their detailed viewing habits are being transmitted outside their homes, potentially to entities ranging from the device manufacturer to advertisers.¹⁶⁹

As with smartphones and computers, malware can illicitly repurpose these microphones into surveillance devices for others. For example, in 2017 WikiLeaks revealed a CIA program dubbed “Weeping Angel” that deployed malware to transmit the audio from microphones on Samsung smart televisions to the CIA.¹⁷⁰ Notably, this malware kept the microphone enabled even when the television appeared to be turned off.

6.5.1.4 Drones and Their Use in Video Surveillance

Unmanned aerial vehicles (UAVs), commonly called drones, are aircrafts without human pilots onboard. Long used for military applications, low-cost consumer drones became popular in the 2010s for recreation, aerial photography, and surveillance. Drones may be operated remotely by a human or autonomously by software.

Drones frequently include video cameras, but they may also include infrared cameras, radar, or other sensors.¹⁷¹ In the United States, drones are restricted from flying near airports and other areas where they may cause hazards by Federal Aviation Administration (FAA) regulations. There have been a handful of high-profile incidents of consumers shooting down other consumers’ drones, including a 2015 case in which a Kentucky man shot down a neighbor’s drone in his backyard when he deemed it an invasion of his privacy.¹⁷² Broadly, the practice of consumers shooting down drones has been deemed a federal crime.¹⁷³ It is not just consumers, but also other nations, that shoot down surveillance drones. In a highly publicized June 2019 incident, forces in Iran shot down a U.S. military surveillance drone.¹⁷⁴

In addition to militaries, a number of law enforcement agencies have also begun using drones for surveillance.¹⁷⁵ Over the last decade, companies began to sell surveillance drones directly to consumers explicitly for home security and surveillance applications, rather than simply recreation or photography.¹⁷⁶

6.5.2 CCTV

Closed-circuit television (CCTV) is a type of video-monitoring system commonly used by governments for preventing crime or terrorism, but it can also be used in private environments for purposes such as preventing shoplifting, providing security for a private

facility, or tracking employees in a workplace.¹⁷⁷ Analysts have estimated there are over one billion CCTV cameras installed worldwide as of 2021, with particularly dense deployments in China, India, and Russia.¹⁷⁸ While privacy debates over CCTV cameras have occurred for decades, it has become an especially important topic in recent years as a result of two intertwined technological advances. Recent years have seen the rapid deployment of ubiquitous cameras in urban settings, and vast improvements in the accuracy of facial-recognition software enable these images to be processed and acted upon for tracking on a large scale.

In CCTV systems, cameras are set up allowing images to be transferred to a remote destination where footage is available to law enforcement or security personnel for either real-time or post-hoc monitoring. CCTV can encompass a variety of different types of cameras at different levels of sophistication, including both mobile and permanently mounted cameras, and can capture images of varying quality.¹⁷⁹

CCTV analysis systems can also be augmented with additional technology. For example, biometrics and other facial-recognition capabilities are used to try to recognize terrorists in a crowd or in an airport. In the United States, general use of CCTV in public spaces by the government is legal, as long there is not a “reasonable expectation of privacy.”¹⁸⁰ CCTV can also be used for workplace surveillance, such as for employers to observe employees within the workplace. In this environment, the use of video surveillance is typically legal if it is limited to public areas.¹⁸¹

6.5.3 Facial Recognition

One of the new frontiers in large-scale tracking involves facial recognition. Rather than tracking an electronic device an individual carries around, such as a smartphone, tracking that relies on facial recognition necessitates blanketing the area where an individual is likely to travel with cameras. A rapidly increasing density of cameras, combined with recent advances in the machine-learning techniques underpinning facial-recognition technologies, have enabled large-scale tracking based solely on images from public cameras, giving rise to fierce debates about privacy.¹⁸²

While London has long been known as one of the cities with the highest density of CCTV cameras, China rapidly deployed cameras in the late 2010s and incorporated these camera feeds into facial recognition software.¹⁸³ Facial recognition software is being used in major Chinese cities to identify jaywalkers, delivering fines via text message.¹⁸⁴ As further discussed toward the end of this chapter, it is also used to track ethnic minorities in China.¹⁸⁵ Notably, this software was designed to algorithmically assign ethnicity labels for the individuals observed in these camera feeds.¹⁸⁶

A major inflection point in privacy debates around facial recognition was the rising popularity of Clearview AI, a controversial company that trained facial recognition algorithms on billions of images scraped from the internet, including from social media sites.

Clearview AI collected most of these images without the permission of the data subjects or even the social media sites,¹⁸⁷ and it markets its software primarily to police.¹⁸⁸ As a result of a 2022 settlement with the American Civil Liberties Union, it can no longer sell its database to private businesses in the United States.¹⁸⁹ Clearview AI has also faced increasing resistance and fines elsewhere in the world, including the United Kingdom.¹⁹⁰

The potential use of facial recognition technologies for large-scale tracking and applications like these led the City of San Francisco to ban police and municipal agencies from using these technologies.¹⁹¹ While bans on facial recognition initially increased, with dozens of cities and towns in the United States banning the use of facial recognition between 2019 and 2021, some of these bans have been lifted in recent years in response to pressure from governments and police.¹⁹²

Fairly accurate facial recognition is increasingly available directly to consumers. For instance, the PimEyes search engine takes input photographs of an individual and then uses facial-recognition techniques to identify other images of them on the internet.¹⁹³

6.5.4 Video Doorbells and Citizen Surveillance

For many years, mass surveillance systems centered on video data required deploying cameras, such as CCTV systems, at great cost to the entities wishing to conduct surveillance. In recent years, the widespread adoption of the Amazon Ring and other internet-connected doorbells upended this assumption, creating a system of civilian mass surveillance that, some commentators noted, creates a culture of fear that potentially increases violence rather than improving safety.¹⁹⁴ Amazon's Ring line of products feature internet-connected doorbells with video cameras, enabling residents of a home to see who is at their door and communicate with them from afar. Typically, the doorbells record video of people who have come to the door. Through both nudging users to share data collected from their Ring doorbells with police and simply accessing data stored on their internal servers, Amazon and the other video doorbell manufacturers enabled warrantless surveillance on a large scale, sharing data with more than one in ten U.S. police departments as of 2021.¹⁹⁵

Although it may seem obvious that Ring doorbells record and retain video and audio data when someone rings the doorbell, far more data is collected. A doorbell press is not always necessary, as these devices typically feature motion-activated modes. Furthermore, Amazon also collects how a user interacts with the video and audio data stored by their Ring doorbell and characteristics of their home network and home itself.¹⁹⁶ Beyond the availability of this data to police creating widespread surveillance of citizens, the ubiquity of Ring doorbells and similar devices particularly impacts specific types of workers. For example, delivery drivers and domestic gig workers are surveilled extensively by these devices, forcing delivery drivers to accede to customer demands and increasing power differentials.¹⁹⁷

6.5.5 Tracking voice over IP Conversations

In recent years, voice over IP (VoIP) technologies like Skype have become a popular way to make voice or video calls. These VoIP technologies, however, can also be tracked in both unintentional and intentional ways. Like computer systems, VoIP systems can suffer from vulnerabilities that unintentionally enable eavesdropping.¹⁹⁸ Researchers have demonstrated that simply having access to the encrypted version of a message may be sufficient for using linguistic techniques to reconstruct the call if certain types of encryption are used.¹⁹⁹

A number of intentional mechanisms can also be used to surveil VoIP communications. In the United States, the FCC interpreted the 1994 Communications Assistance for Law Enforcement Act (CALEA), which requires companies to be able to intercept communications in response to authorized legal requests, to include VoIP services. Although Skype made “affirmative promises to users about their inability to perform wiretaps,” it was among the services revealed to be accessible as part of the PRISM program in the United States.²⁰⁰

Even if the body of the communication is encrypted by the sender, the metadata about a communication can often leak a large amount of the communication. For example, a 2016 study empirically reidentified telephone metadata and used it to infer locations and relationships between individuals.²⁰¹

6.5.6 Speech Recognition

In addition to microphones becoming ubiquitous in smartphones and laptops, stand-alone smart speakers with voice assistants have rapidly become popular. Common examples include the Google Home and Amazon Echo, commonly referred to by the name of its voice assistant, Alexa. As of 2018, over one-quarter of U.S. households owned one of these smart speakers.²⁰² In other words, many households now have a microphone in their living rooms or other personal spaces. Furthermore, smart assistants such as Apple’s Siri, Microsoft’s Cortana, and Samsung’s Bixby play a similar role on smartphones.

As previously mentioned in the context of voice recognition for smart televisions, the computationally intensive processing involved in turning speech data to text is often performed on a remote computer server outside the consumer’s home, not on the standalone smart speaker or smartphone. As a result, a consumer’s conversations may inadvertently, or maliciously, be recorded and transmitted. A 2019 study highlighted many privacy concerns raised by users of voice assistants in the home, even though these users perceived voice assistants to also provide important benefits.²⁰³

A number of incidents brought the privacy of smart speaker voice recordings to newspaper headlines. For instance, in a 2018 incident, an Amazon Echo reportedly recorded and transmitted a conversation to one of a user’s contacts unintentionally.²⁰⁴ In November 2018, the right of access to the recordings made by an Amazon Echo at the scene of a murder was litigated in a New Hampshire court.²⁰⁵ Finally, in April 2019, it was revealed that Amazon

employs a team of people to listen to recordings made by Amazon Echo's voice assistant Alexa to improve its speech recognition algorithm.²⁰⁶ Users expressed privacy concerns.

6.5.7 Audio and Video Surveillance in Educational Technology

For years, the increasing use of new technologies and data-driven insights in education have enabled additional surveillance of students in educational settings.²⁰⁷ Beyond the typical privacy risks and harms of data-driven tracking, surveillance in educational settings presents unique risks. Students are often children and are therefore vulnerable individuals, as they rarely have an active voice in choices about what data-driven educational tools are deployed, and their data is increasingly collected by third-party educational technology providers outside of their schools.²⁰⁸ The COVID-19 pandemic and multiple years of virtual schooling caused an increase in the use of educational technology, which naturally coincided with increased abilities for teachers, administrators, and educational technology companies to surveil students.²⁰⁹ For example, the video-conferencing software many schools used to replace classroom settings during the COVID-19 pandemic enabled detailed analytics of student attendance and attention, using window focus as a proxy for attention.

Furthermore, high-stakes testing for university admissions and professional licensure was increasingly conducted remotely from students' own homes during the pandemic. In response to concerns about academic integrity, remote proctoring services and software extensively monitored test-takers' computers and surrounding environments, including recording screens and conducting virtual room scans.²¹⁰ In 2022, a federal judge in the United States ruled these room scans were an unconstitutional search.²¹¹

6.5.8 Protecting against Audio and Video Surveillance

User protection against audio and video surveillance on computers and smartphones can take place on several levels. First, it is possible to prevent potential surveillance by avoiding the malware that would allow attackers to take over a camera or microphone using antivirus software. Additionally, malware is often delivered through untrustworthy downloaded software, especially on smartphones. Avoiding such software can help lower the risk of an attacker implementing audio or video surveillance.

It is also possible to try to avoid audio and video surveillance by blocking the hardware and software features necessary for surveillance to occur. For example, on some computers, it is possible to physically turn off or block a webcam when it is not in use. From the user's perspective, two primary types of action can combat the misuse of their computers for video surveillance. First, many, but not all, computers include indicator lights to reveal when a camera is active. While the most sophisticated malware can sometimes evade triggering these indicator lights, and while users may not notice or understand these indicators, they are an important first step. A low-tech, yet more effective, solution is to cover the camera when not in use.²¹² Stickers, plastic covers, and household tape can all serve this purpose.²¹³ Unfortunately, the solutions for covering or otherwise disabling microphones are nowhere

near as simple.²¹⁴ While researchers have prototyped wearable microphone jammers, effective and inexpensive microphone jammers are not yet available commercially.²¹⁵ Tracking incoming and outgoing network connections and potentially using a firewall to block potentially suspicious activity can also help prevent surveillance, although this process likely requires technical expertise to understand the purposes of different types of traffic transmitted on home networks.²¹⁶

6.5.9 Effective Practices

When performing audio or video surveillance, especially within a work environment, it is effective practice to ensure the minimal amount of surveillance is performed for the necessary objective and it is conducted in a legal manner.

Video and audio surveillance can be very privacy invasive and should not be performed unless a necessary objective, such as security or efficiency, outweighs the privacy drawbacks. Wherever possible, those under surveillance should be informed about the system to lower the impact of the privacy violation. Additionally, a group should check local privacy laws before putting surveillance in place. In the United States, a first step for employers is making sure the surveillance does not take place in an environment where employees have an expectation of privacy, such as inside a bathroom.

As evidenced by the privacy debate following the 2019 revelation that Amazon employees manually listen to Alexa conversations to improve the speech recognition algorithms, it is important not to surprise users. Empirical user research is invaluable in eliciting and documenting consumers' expectations, preferences, and mental models about how the audio and video data collected by a device is used.

Once audio and video surveillance data has been gathered, it is effective practice to take proper measures to maintain data security and limit exposure of the content. Whenever possible, use automated systems to analyze the data or employ a separation of duties, in which the analyst examines the audio or video and only reports the finding to others. This avoids exposing the raw audio and video to unauthorized repurposing or snooping. In these situations, it is important to securely retain the raw audio or video in the event the finding is ever challenged. To ensure the data is not misused, one should track access to the data and limit it to necessary personnel. A clear policy should be put in place for who has access to the data and under what circumstances, and for how long the data will be retained. Data should be purged when it is no longer needed for the intended purpose.

6.6 Sensor-Based Surveillance

With the rise of smartphones, wearable devices, and the IoT in the last decade, sensing technologies are being widely deployed. This sort of ubiquitous sensing can enable tracking and surveillance of individual users. It can also allow private information embedded in the aggregated data of many users to be leaked, enabling societal-scale tracking in new domains.

In this section, we introduce new technologies that frequently embed sensors, identify the key risks to tracking and surveillance, and highlight how some of these risks can be partially minimized.

6.6.1 Ubiquitous Computing

The broad concept of ubiquitous computing (“ubicom”) refers to the transition of computing from purpose-built, independent computing devices to computing that occurs at all times and in all places. As computing occurs ubiquitously, absent of the visible boundaries present when interacting with a device like a traditional laptop computer, the types and amount of data that can be collected at scale raise important concerns about privacy, tracking, and surveillance. Early research on ubiquitous computing highlighted important requirements for end-user acceptance of this paradigm from a privacy perspective: The system should have obvious value, the retention of data should be limited, and users should be provided both feedback and control.²¹⁷ While many of the domains discussed in the rest of this section arguably also fall under the umbrella of ubiquitous computing, in this subsection, we focus on two particular types of ubiquitous computing: smart cities and augmented reality.

At the time of press, the concept of smart cities began to attract substantial attention. However, what precisely the term refers to is somewhat ill-defined. Sometimes, the concept of a smart city refers to a city that aggregates and makes existing data from its traditional functions available in an open format to all citizens. For example, the U.S. city of Chicago has an open data portal that provides information on everything from streets that have been plowed to restaurant inspections to vaccination centers.²¹⁸ While these open data portals can have important advantages for government transparency and sometimes the efficiency of government, they can often have important implications for privacy. For instance, even sparse, pseudonymous datasets can often be deanonymized if combined with other datasets.²¹⁹

The concept of a smart city is also used to describe cities that introduce large numbers of new sensors and actuators, adding computerized sensing and control to systems that did not previously have such capabilities. For example, smart cities might deploy tracking devices on government-owned vehicles and automated license plate readers to track nongovernment vehicles similarly. They might deploy detailed analytics for utility systems, as well as cameras for a multitude of purposes. They also might deploy street-corner sensors to detect environmental factors, gunshots, or the movement of pedestrians.²²⁰ In the remainder of this subsection, we mostly discuss the tracking implications of this type of smart city.

The large-scale collection of data in smart cities can enable substantial amounts of surveillance. For instance, the ability for a government to monitor the identity and movements of the populace on a large scale can also have chilling effects on the exercise of rights to protest and dissent.²²¹ Furthermore, many smart cities have used their large sensing

networks for the explicit purpose of policing, which critics highlight can create urban surveillance panopticons despite having debatable impacts on public safety.²²² In all these cases, figuring out how to notify everyone in the city about what data is collected and to obtain meaningful consent from them is challenging.²²³ It is also challenging for users to determine what information can be inferred from data streams. For example, research has shown smart meters can infer what a household is watching on TV from granular information about power consumption, which is impacted by the colors on screen.²²⁴ These kinds of information leakages can be vexingly difficult for users to predict.

Current developments in the Canadian city of Toronto provide an important privacy case study. At the time of press, Sidewalk Labs, which is owned by Google parent company Alphabet, is working with the city to develop a smart city in Toronto's Quayside. The core technological aspects of the project focus on providing a network of sensors focused on noise, energy usage, and transportation, in addition to deploying a large number of autonomous vehicles.²²⁵ The idea that a combination of companies and government officials would collect large amounts of data from the public in open spaces in the city led critics to use the term "surveillance capitalism" to describe the project.²²⁶ The project's decision to allow third parties to access identifiable information from the smart city ignited particular controversy, leading one of the leading privacy scientists on the project to quit in 2018.²²⁷

While smart cities instantiate ubiquitous computing principles through large-scale data and sensing, the idea of augmented reality (AR) brings data to an individual user. In current technologies, users experience AR through special glasses they wear, projections they see, or other interfaces that overlay computer-generated content with the real world in front of them. Because AR typically requires rich sensor data to physically overlay the virtual world accurately and properly, large amounts of data must be collected, inherently creating privacy tensions.²²⁸ Furthermore, because multiple applications will likely need to interact in AR, and because user input will be provided in a variety of forms, it may become difficult to control data flows in AR. In a 2018 study that used Microsoft HoloLens headsets to make the privacy concerns of AR more tangible, participants surfaced additional concerns, including the use of virtual objects for privacy-related obstruction and the ways AR applications could invade the privacy of their physical world simply through observation.²²⁹

6.6.2 Mobile Device Sensors

Smartphones and similar mobile devices are a nearly constant companion for many individuals in the modern world. To enable their functionality, they also contain myriad sensors. This combination of constant proximity to the user and rich sensing capabilities has led scholars to note "smartphones are effectively surveillance devices."²³⁰ As discussed elsewhere in this chapter, microphones, cameras, and location-awareness devices all have important implications for surveillance. A typical smartphone has all these sensors and more.²³¹

Accelerometers are one type of sensor frequently found on mobile devices, yet infrequently encountered on other computing devices. Accelerometers enable phones to know when to rotate the screen, measure the speed of devices in motion as users walk or bike, and permit physical interaction with smartphone games. However, the data from an accelerometer can also be used for surveillance. For example, researchers have shown how an accelerometer alone, even without persistent location awareness, can determine the distance traveled and therefore leak information about the user's location relative to a previous position.²³² It can also leak information about the passwords a user types into their phone.²³³

As smartphones are an integral part of many users' daily lives, users need to authenticate to unlock their phone frequently throughout the day.²³⁴ Because PINs, passwords, and other methods can be cumbersome for frequent unlocking, biometric authentication through an onboard fingerprint sensor has become common in part because of major usability advantages.²³⁵ While this fingerprint data is typically kept on the device itself and not sent to the manufacturer in current implementations, one can imagine how the widespread collection of biometric data like fingerprints would arouse privacy concerns.²³⁶ Notably, fingerprints are a unique identifier. They are also impossible to replace.

Mobile device sensors, when used creatively, can enable important societal applications. For instance, the mobile health movement has parlayed smartphone sensors into everything from fitness self-tracking devices, discussed elsewhere in this chapter, to health care devices. For example, researchers have shown how to detect blood hemoglobin using smartphone cameras.²³⁷ While these sensors can be used for such positive applications, they can unfortunately also be misused in the wrong hands.

6.6.3 Internet of Things

The IoT is the concept of imbuing everyday, physical objects with internet connectivity. Similar to the concept of smart cities, the precise meaning of IoT can differ substantially in different contexts and for different audiences. Other parts of this chapter cover applications often discussed as part of IoT: wearable health devices, home automation, smart transportation, voice assistants, and aspects of smart cities. In this subsection, however, we focus on three tracking-related IoT applications that are not discussed elsewhere in this chapter: internet-connected toys, internet-connected security systems, and the use of IoT for eldercare. Across all these IoT devices, providing privacy notices and enabling choices about privacy become difficult because of the frequent lack of traditional user interfaces.²³⁸

In the last few years, manufacturers have begun to connect children's toys to the internet, enabling them to perform speech recognition, converse with the children, and access extra information. Like speech recognition for smart speakers and voice assistants, this design presents privacy issues because the recordings are sent to a server. However, the primary users of these toys are even less likely to be aware of the consequences of this tracking or understand what is happening because they are so young. For example, a 2017 study of IoT

toys found the children who participated were often unaware of who might have access to the recordings made by these toys, and even that their toys functionally remembered what they were told through recordings.²³⁹ Even worse, some of the popular IoT toys were shipped with major security vulnerabilities, enabling hackers to turn the microphone on at all times, fully turning these IoT toys into surveillance devices.²⁴⁰

To improve household safety, internet-connected variants of home-security devices have been introduced in recent years. For example, internet-connected locks can log when they are unlocked, in addition to providing the homeowner the ability to unlock the door remotely to let people into their house. Internet-connected security cameras can give a homeowner peace of mind that their home is safe when they are away. However, a 2014 study showed how the same characteristics that enable constant monitoring of the home can also functionally place other members of the household under surveillance, creating tensions between parents and teenagers.²⁴¹

Related issues appear for using IoT technology with the elderly. A number of efforts aim to use technology to help the elderly live independently in their own homes longer than might be possible otherwise. These efforts often use technology to help the senior citizen remember things they might forget, see things they might have trouble seeing, and stay connected with their family and friends. However, even when well-intentioned, these efforts can also cause the senior citizen to feel a loss of control and agency, and sometimes to perceive that their caregivers and family are surveilling them.²⁴² These issues can be particularly acute with the use of vision-based technologies to help elders see.²⁴³

6.6.4 Home Automation

Beyond the home-security IoT applications and previously discussed uses of video doorbells, a number of other household appliances and control systems have been connected to the internet toward the vision of a smart home. For instance, IoT thermostats like the Nest thermostat can adjust to learned patterns about the home's inhabitants and permit remote changes in temperature. Similarly, IoT lighting can be configured to react to outside events. Internet-connected motion sensors can be configured to trigger different behaviors in the home. Unfortunately, connecting these household devices to the internet has important ramifications for tracking and surveillance.

Historically, the home has been considered a private space, yet the actions of a home can be tracked if data is collected inside the home and then shared outside the home. While home-automation systems could conceptually be designed so the data never leaves the home, many current home-automation systems, such as Samsung SmartThings and Apple HomeKit, funnel sensor data and control through cloud interfaces. Notably, media attention in 2019 focused on how Amazon and Google aimed both to increase their own devices' data collection in the home and to urge other companies to send them data from within homes as well.²⁴⁴ These types of decisions enable companies to track and surveil what happens in

consumers' homes, in addition to the insights they already have into users' mobility patterns and communications through their smartphones. Unsurprisingly, a 2019 survey found privacy was consumers' top concern related to smart homes.²⁴⁵

A 2018 study of smart-home owners revealed they make a cost-benefit trade-off when deploying smart-home devices, yet researchers found these smart-home owners tend to be unaware of how inference algorithms can operate on the data collected.²⁴⁶ Similar to the way home security systems can enable parents to track teenagers, the technical administrators of home automation systems exert control over the other members of their household, or the passive users of the system.²⁴⁷ They can often track what other members of their household are doing, inadvertently or intentionally.

On a technical level, privacy in homes can be difficult to reason about, which makes tracking especially pernicious. The "smartness" of home automation depends on data being able to flow across devices, yet chains of these information flows can sometimes leak private information outside the home.²⁴⁸ Furthermore, consumers' preferences about access to data and control within their homes rely heavily on context, which few current home-automation systems support.²⁴⁹

6.6.5 Vehicle Sensors

Modern automobiles are incredibly complex. In addition to the many mechanical parts that were typical decades ago, recent automobiles tether together a network of sensors and computers.²⁵⁰ While potentially a boon for adding new features and improving the connectedness of vehicles, these sensors and computers also bring security and privacy risks. Sensors in modern vehicles measure driving speed, braking, tire pressure, proximity to other vehicles, and many detailed aspects of how the driver interacts with the vehicle. What happens in a vehicle, and where it travels in the first place, can be highly sensitive. For example, a major decision in the Supreme Court case *United States v. Jones* hinged on whether attaching a GPS device to a suspect's car to track his location was a search and therefore required a warrant.²⁵¹

Cars collecting large amounts of data raises questions about which third parties can access that data, in which circumstances, and with what level of informed consent from the driver and passengers.²⁵² Whether information from the car might be made available to law enforcement, auto insurance companies, mapmakers, advertisers, or others is an important open question. Furthermore, the large amount of data stored in vehicles makes it easy for users to overlook some aspects. For example, newspaper articles in 2018 recounted how borrowers frequently forgot to erase or did not know they had to erase information from rental cars' Bluetooth entertainment and communication systems, leaking their information to subsequent users of those cars.²⁵³

Where data is stored is often a critical aspect in privacy, and cars have a number of locations where data might be stored. All new cars sold after 2013, as well as many sold before, must

contain a “black box,” similar to airplanes, which records a number of sensor readings and characteristics.²⁵⁴ These black boxes are often examined after accidents and collisions, though one might reasonably be concerned this data could be used for surveillance.²⁵⁵

While black-box data is typically kept in the car itself, modern cars are becoming increasingly connected to the outside world through networks. From the popular OnStar systems that enable remote control and richer media to the vast array of connections required for operating and updating the self-driving cars of the future, there are many opportunities for data to be transmitted from a car over the network.²⁵⁶ Oftentimes, this data transmission is intentional. For example, vehicular networks, sometimes called vehicular social networks, are based on the premise that communications between vehicles can enable more efficient usage of roadways as well as richer communications between vehicles to increase safety and security.²⁵⁷

Data about vehicles does not necessarily need to come from the car itself, however. Transportation-mapping apps like Google Maps typically show real-time information about traffic. This information is generally collected from the phones of other users of the mapping app. In particular, users’ apps transmit information about their routes and speed to the mapping company’s servers. This data is processed, traffic conditions are inferred, and this real-time information is transmitted to others.

Highly connected cars also present risks for computer security. As cars became more complex, computer security researchers began to deconstruct their attack surface and search for potential vulnerabilities. Early researchers noted, for instance, readings from tire pressure sensors were not properly authenticated, allowing attackers to spoof the sensor readings.²⁵⁸ Subsequently, researchers systematically analyzed vehicles’ centralized control system, the Electronic Control Unit (ECU).²⁵⁹ Their research showed controlling the ECU could lead to attacks that disable brakes, control acceleration, and perform other nefarious acts. Over the last few years, car hacking has become even more sophisticated. Proof-of-concept exploits have taken over cars remotely, showing attacks against cars are a threat on a large scale.²⁶⁰

While the aforementioned technologies are located inside individual cars, other technologies are located outside cars. Most notably, governments, police departments, and private companies have deployed automated license plate readers (ALPRs) throughout the United States.²⁶¹ Based on both past misuses of data collected from ALPRs and the potential for large-scale privacy invasion, civil liberties groups have raised concerns about ALPRs and called for limits on the use and retention of data collected from them.²⁶² Furthermore, journalists have expressed concern that state and local governments in the United States might use data collected from ALPRs to track individuals seeking abortions or other medical procedures, noting that tracking from densely situated ALPRs can begin to resemble GPS tracking.²⁶³

6.6.6 Wearable Devices

In a major transition in recent years, many wearable devices have embedded substantial computing capabilities. Individuals often use these wearable devices for tracking their fitness or other athletic activities, or for more traditional health care monitoring.

Popular wearable fitness monitors, such as Fitbit devices, enable a user to monitor how many steps they take each day, in addition to other activities. These devices, however, present a number of risks for tracking and surveillance. While they collect fitness data, this data is not typically characterized as health data and therefore is not afforded the higher privacy protections of health data.²⁶⁴ Furthermore, a user's data is typically sent to the manufacturer's computer server through a connected app on a companion device like a smartphone, creating a centralized repository of fitness data.

Fitness enthusiasts also frequently track their own running or biking routes, which enables them to keep track of their fitness over time, track personal records, and share routes with others. Strava is one such app popular with joggers and bikers. However, the data collected and sometimes shared socially embeds potentially private information. For instance, in 2018, it was revealed heat maps of popular fitness routes collected from Strava users released by the company functionally outlined U.S. military bases in foreign countries.²⁶⁵ In essence, data about where an individual went for a run, in concert with similar information from many other users, can reveal important secrets.

While many of the devices and services just mentioned are focused on recreational fitness, other apps seek to bring the types of health care monitoring typical of medical professionals to wearable devices. For instance, implantable medical devices, such as pacemakers, can be easier to maintain and monitor if they are wirelessly accessible or even internet connected. However, further increasing the connectivity of these devices introduces numerous risks to privacy and security. For instance, data meant to be transmitted wirelessly to a doctor from a pacemaker could be sent elsewhere, not to mention the security risks of an attacker being able to control a victim's pacemaker. Even the usage of certain classes of medical devices might be sensitive, and these devices' unique serial numbers can ease tracking of the individual if they broadcast a unique identifier.²⁶⁶

While the ability of connected health care to enable medical providers to remotely monitor their patients in real time brings both treatment advantages and privacy disadvantages, the long-term storage of this data raises many important privacy questions. For instance, how long should data be kept, and who should be able to access it? Beyond the potential for wearable health care devices to enable tracking and surveillance, electronic health records (EHR) that bring together all a patient's medical records in a standardized form can leak large amounts of private information.²⁶⁷

6.6.7 The Metaverse

In 2021, the company known as Facebook rebranded as Meta as part of its increasing focus on the metaverse, a virtual- and augmented-reality space in which participants can interact

with each other's avatars and move through virtual worlds.²⁶⁸ This vision is enabled by hardware like headsets, like those made by the company Oculus that Meta acquired and folded into its Reality Labs, and in the future by full-body sensors and similar hardware. In 2023, Apple also entered the space of virtual reality by announcing its Apple Vision Pro virtual reality headset, emphasizing the potential that the metaverse or similar technologies will eventually become widespread.²⁶⁹ Companies have begun to release advanced sensing technologies focused on the metaverse. For instance, in 2023 Sony introduced a full-body tracking system that could translate an individual's nuanced movements into a digital avatar.²⁷⁰

The all-encompassing sensing of the human body promised in visions of the Metaverse, as well as the inherent trackability of movement through virtual spaces, promises to increase surveillance. As a result, the metaverse promises to present numerous challenges for privacy and surveillance, including the creation of wide-ranging digital footprints of users' full spectrum of actions and interactions in the virtual worlds of the metaverse.²⁷¹ The new hardware capabilities of virtual reality headsets used in the metaverse also promise new types of tracking. For instance, detailed eye tracking information could be used to record a user's gaze and attention, bootstrapping even more highly targeted advertising and profiling of a user's inner thought processes.²⁷²

6.7 Behavioral Modeling

With the increasing ease of data collection on devices ranging from smartphones to IoT devices, large-scale data is often available. This data can be used to model human behavior, albeit at a privacy cost. In this short section, we briefly outline the role of data in behavioral modeling related to life stages and human behavior, as well as mobility and geography.

6.7.1 Learning Life Stages and Demographics

The concept of targeted advertising makes inferences about users based on their online activities. Frequently, demographics and life stages are among the characteristics inferred about the user. However, beyond inferring demographics for advertising and personalization, research efforts have aimed at learning aspects of society from this data. For example, researchers have used smartphones to collect data on how quickly people speak in conversations, the structure of people's days, and where people spend their time.²⁷³ Other work has modeled the dynamics of groups, shedding light into the interactions between people with different functions in the group and at different life stages.²⁷⁴

6.7.2 Mobile and Social Patterns

The patterns revealed by data from smartphones and other sources can provide large amounts of insight into mobility patterns and social patterns. In recent years, a number of efforts have

sought to use data collected from these sources to infer aspects of urban geography, socioeconomic factors, and the ways people move throughout their environment.

For example, in a 2016 study, researchers used cell phone records to construct urban mobility patterns at a far greater granularity, and at far less expense, than could be collected through typical travel surveys.²⁷⁵ Other researchers have also used data from mobile phones to predict socioeconomic indicators like poverty and illiteracy.²⁷⁶

While those projects used cell phone records for prediction, other efforts have used data from location-based social media apps. The Livelihoods Project used location check-in data from the phones of users participating in a location-based social network to map mobility patterns in urban areas.²⁷⁷ From this data, they concluded the boundaries of neighborhoods experienced by residents of these cities sometimes differed from the officially established boundaries of those neighborhoods. Researchers used similar types of location check-in data to identify users' mobility patterns and map their purpose-driven activities.²⁷⁸

6.8 Uses and Abuses of Tracking and Surveillance Technologies

To this point, this chapter has focused on presenting the technical mechanisms that enable tracking and surveillance. In this section, we briefly highlight some uses of these technical mechanisms that have demonstrated the perils of such mechanisms being widely available.

6.8.1 Tracking and Surveillance of Black Activists in the United States

For decades, the U.S. government has surveilled Black activists.²⁷⁹ Over fifty years ago, the FBI conducted the covert Counterintelligence Program (“COINTELPRO”) in an attempt to track and disrupt the civil rights movement. These programs leveraged early electronic surveillance technologies, such as wiretaps. However, scholars have noted the surveillance of Black communities can be traced through history, such as to the “panoptic slave ships of the Middle Passage.”²⁸⁰

In recent years, the U.S. government has again engaged in the surveillance of Black activists, this time tracking electronic communications.²⁸¹ With the rise of the Black Lives Matter (BLM) movement, government agencies used facial recognition technologies at protests, keyword searches of BLM-related topics on social media sites, and other technological mechanisms to track both the leaders and followers of the BLM movement.²⁸² In response to widespread concerns about the surveillance of peaceful protests in support of BLM, numerous media outlets published guides for novice protesters. These guides commonly included advice to disable biometric authentication on phones and rely instead on passwords or PIN codes, set phones to airplane mode to disable data transmissions, use end-to-end encrypted messaging apps like Signal, and exercise caution when posting identifiable images to social media.²⁸³

6.8.2 Tracking and Surveillance of Racial and Ethnic Groups Worldwide

The technology-aided surveillance of members of particular racial or ethnic groups is not unique to the United States. For instance, China's surveillance of Uyghurs, a Turkic ethnic group native to China's Xinjiang region, has received widespread media attention in recent years.²⁸⁴

Technology plays a major role in China's surveillance of Uyghurs. The surveillance apparatus used combines cameras at numerous checkpoints through the Xinjiang region with extensive databases of its citizens featuring billions of records, including extensive amounts of personally identifiable information. Notably, the data collected includes DNA and other biological information contained in blood samples, photographs from multiple angles to bootstrap facial-recognition systems, and iris scans.²⁸⁵ Surveillance cameras used to identify specific individuals using facial-recognition software and thus document citizen's activities are widespread in Xinjiang.²⁸⁶ In an analogous case outside of China, the Israeli military uses similar techniques, including databases of citizen's histories tied into smartphone apps that leverage facial-recognition techniques, to surveil Palestinians.²⁸⁷

6.8.3 Mass Surveillance of Citizens

More broadly than specific racial or ethnic minority groups, some governments have aimed to track large swaths of its citizens. For instance, Edward Snowden's 2013 National Security Agency (NSA) revelations highlighted how the U.S. government illegally collected telephone records of its own citizens en masse.²⁸⁸ At the same time, the Snowden revelations also highlighted the U.S. government's PRISM program, mentioned at the beginning of this chapter, that collected records from internet communications. In an example with even more directly visible implications, China employs what is termed a social credit system that aggregates entries from many databases and uses these entries to automatically determine an individual's trustworthiness, making everything from decisions about finance to decisions about whether someone should be allowed to use particular transportation systems based on the information.²⁸⁹ This system uses numerous features of both economic and social data to define both "good" and "bad" behaviors.²⁹⁰ The social credit system increasingly relies on facial-recognition technologies. In one widely reported incident, the system mistakenly flagged an individual pictured in an advertisement on the side of a bus for a jaywalker, publicly posting the name and ID number of the supposed offender.²⁹¹

6.8.4 Tracking and Surveillance of Intimate Partners

It is not just governments that engage in surveillance. For instance, domestic abusers and other perpetrators of intimate partner violence use digital tracking technologies to surveil their partners, enabling further abuse.²⁹² To do so, abusers leverage various types of spyware, especially on smartphones, to track their partner's location, communications, and contacts.²⁹³ In many cases, abusers share information with each other on online forums,

trading strategies and recommendations for software to use.²⁹⁴ While some of the researchers involved in this work found success hosting in-person clinical consulting sessions to help victims identify and remove the spyware used to track them, this task became more difficult during lockdowns throughout the COVID-19 pandemic and afterward, especially as even more aspects of daily life moved to digital communication.²⁹⁵

6.8.5 Tracking and Surveillance of Specific Targets

In recent years, governments and other organizations have used advanced tools like the NSO Group's Pegasus spyware to spy on specific targets, including high-ranking politicians and other specific, high-value targets.²⁹⁶ This spyware uses zero-day exploits and other critical, unpatched security vulnerabilities to take control of a victim's phone, enabling access to communications and photographs, and the ability to activate the phone's camera and microphone for surveillance purposes. This spyware often targets messaging apps like WhatsApp or Apple's iMessage. While early versions of the spyware often used spear-phishing techniques to trick a victim into clicking on an exploit, later versions exploited more subtle vulnerabilities that did not require any action from the victim.²⁹⁷ Pegasus spyware has been found on the phones of numerous high-ranking political leaders, highlighting the vast scale and reach of modern surveillance.²⁹⁸

6.8.6 Effective Practices

In choosing whether to employ tracking and surveillance technologies for a particular purpose, individuals with decision-making power in governments, relationships, or organizations ought to take care in weighing the benefits and costs of those uses. Such individuals should ask themselves a number of questions. For example, who is being impacted by surveillance? What are the chilling effects of that surveillance? Does the information gained really outweigh the privacy harms? What information beyond the particular target will inadvertently be collected? Furthermore, companies ought to consider what responsibilities they have both in choosing not to make technological tools that enable surveillance and in disclosing their cooperation with governments engaging in surveillance to consumers. Over a decade ago, companies began to issue transparency reports about their compliance with governmental requests for user data, though this practice of issuing transparency reports faded in recent years.²⁹⁹ Companies ought to reconsider the societal value of issuing transparency reports and more generally being transparent and accountable for their technological practices.

6.9 Summary

In this chapter, we presented an overview of tracking and surveillance techniques and countermeasures. We began by explaining how the packets that encapsulate communication over the internet can be surveilled. We then demonstrated how surveillance of low-level

communications over the internet can be made more difficult by encrypting web requests using the HTTPS protocol, by sending traffic through an encrypted VPN tunnel, or by using an anonymizing network to obfuscate the identity of a message's sender from the message itself.

We then discussed numerous technologies that can be used to collect information about the websites a particular user has visited, often for the purpose of better targeting advertisements to that person. While we explained in depth how HTTP cookies enable this sort of tracking, we also introduced technologies that can be used either as alternatives to HTTP cookies or in conjunction with them to respawn deleted cookies. These technologies include LSOs, DOM Storage, and more subtle techniques, such as browser history stealing and browser fingerprinting. We also highlighted ongoing attempts to replace cookies with browser-based tracking technologies, noting the pushback these proposals have received from privacy advocates. We then explained a number of ways users can block certain types of web tracking. For instance, we introduced the controls built into web browsers and how that ecosystem has evolved in recent years, illuminated the debate over the ultimately unsuccessful DNT mechanism, and delved into third-party browser extensions for blocking web tracking. Alongside these methods, we explained their shortcomings, as well as effective practices in the design of privacy tools. We also briefly described ways to prevent tracking of web searches and email messages.

Next, we provided an overview of location-tracking technologies, describing how the location of a phone can be triangulated based on the signal from cell towers and how devices can use GPS to determine their location. We also explained the complex interaction between utility and privacy as users share information about their location on social networking sites, in addition to proposals for limiting the privacy perils of these disclosures.

We then discussed methods for audio and video surveillance. In addition to more canonical examples of surveillance, such as placing hidden cameras and microphones in public or private locations, we demonstrated how smartphones, personal computers, and smart televisions can be co-opted by malware to surveil users. We also highlighted current privacy debates over the intentional use of drones for video surveillance, as well as how audio data from smart speakers and other voice assistants can enable surveillance, intentionally or otherwise. In addition, we showed how technological advances in facial recognition algorithms combined with both the widespread availability of photographs labeled with people's names and deployment of cameras in public to enable widespread tracking based on faces. This development spurred important societal debates about the role of facial recognition and other machine-learning techniques, including some bans on the use of these technologies.

Subsequently, we explained how the rise of the IoT and rich sensing has brought privacy debates to the home, wearable devices, children's toys, and vehicles. We also provided an overview of behavioral modeling based on sensor data and how the era of big data and

ubiquitous sensing will contribute to the next decade's privacy debates, including in virtual and augmented reality spaces like the metaverse. Finally, we concluded with a brief discussion of concrete applications of tracking and surveillance technologies by governments, domestic abusers, and specific individuals, highlighting the dangers and impacts of these technologies.

Endnotes

- 1 Manya Sleeper cowrote this chapter in the first edition of this book, titled *Introduction to IT Privacy: A Handbook for Technologists*.
- 2 Charlie Savage, Edward Wyatt, and Peter Baker, "U.S. Confirms That It Gathers Online Data Overseas," *The New York Times*, June 6, 2013, <https://www.nytimes.com/2013/06/07/us/nsa-verizon-calls.html>.
- 3 Barton Gellman and Laura Poitras, "U.S., British Intelligence Mining Data from Nine U.S. Internet Companies in Broad Secret Program," *The Washington Post*, June 6, 2013, https://www.washingtonpost.com/investigations/us-intelligence-mining-data-from-nine-us-internet-companies-in-broad-secret-program/2013/06/06/3a0c0da8-cebf-11e2-8845-d970ccb04497_story.html.
- 4 Daniel J. Solove, "'I've Got Nothing to Hide' and Other Misunderstandings of Privacy," *San Diego Law Review* 44 (2007).
- 5 Stephen Shankland, "Pegasus Spyware and Citizen Surveillance: Here's What You Should Know," *CNET*, July 19, 2022, <https://www.cnet.com/tech/mobile/pegasus-spyware-and-citizen-surveillance-what-you-need-to-know/>.
- 6 Kevin Granville, "Facebook and Cambridge Analytica: What You Need to Know as Fallout Widens," *The New York Times*, March 19, 2018, <https://www.nytimes.com/2018/03/19/technology/facebook-cambridge-analytica-explained.html>.
- 7 Charles Duhigg, "How Companies Learn Your Secrets," *The New York Times*, February 15, 2012, <https://www.nytimes.com/2012/02/19/magazine/shopping-habits.html>.
- 8 Adrienne Porter Felt, Richard Barnes, April King, Chris Palmer, Chris Bentzel, and Parisa Tabriz, "Measuring HTTPS Adoption on the Web," *Proceedings of the 26th USENIX Security Symposium* (2017): 1323–1338, <https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/felt>.
- 9 "HTTPS adoption has reached the tipping point," *Troy Hunt* (blog), January 30, 2017, <https://www.troyhunt.com/https-adoption-has-reached-the-tipping-point>.
- 10 Google Transparency Report, "HTTPS Encryption on the Web," accessed June 29, 2023, <https://transparencyreport.google.com/https/overview?hl=en>.
- 11 Peter Whoriskey, "Every Click You Make," *The Washington Post*, April 3, 2008, <https://www.washingtonpost.com/wp-dyn/content/article/2008/04/03/AR2008040304052.html>.
- 12 Robert Sheldon, "The Situation Is Under Control: Cyberspace Situation Awareness and the Implications of China's Internet Censorship," *Strategic Insights* 10, no. 11 (2011).
- 13 "Commission Orders Comcast to End Discriminatory Network Management Practices," Federal Communications Commission, August 1, 2008, <https://www.fcc.gov/document/commission-orders-comcast-end-discriminatory-network-management>.
- 14 WireShark, accessed April 2024, <https://www.wireshark.org>.
- 15 Kismet, accessed November 2019, www.kismetwireless.net; EavesDrop, Informer Technologies, accessed May 2024, <https://macdownload.informer.com/eavesdrop/>.
- 16 Codebutler, accessed November 1, 2019, <https://codebutler.com/firesheep>.
- 17 David Streitfeld, "Google Concedes That Drive-By Prying Violated Privacy," *The New York Times*, March 12, 2013, <https://www.nytimes.com/2013/03/13/technology/google-pays-fine-over-street-view-privacy-breach.html>.
- 18 Nikita Borisov, Ian Goldberg, and David Wagner, "Intercepting Mobile Communications: The Insecurity of 802.11," *Proceedings of the 7th Annual International Conference on Mobile Computing and Networking* (2001): 180–189, <https://doi.org/10.1145/381677.381695>.
- 19 "WiFi Protected Setup (WPS) PIN Brute Force Vulnerability" (Vulnerability Note VU#723755), Cert Coordination Center, Carnegie Mellon University, December 27, 2011, revised May 10, 2012, <https://www.kb.cert.org/vuls/id/723755>.

- 20 G. Daryl Nord, Tipton F. McCubbins, and Jeretta Horn Nord, "E-Monitoring in the Workplace: Privacy, Legislation, and Surveillance Software," *Communications of the ACM* 49, no. 8, (2006): 72–77, <https://dl.acm.org/doi/10.1145/1145287.1145290>.
- 21 American Management Association, "Over Half of All Employers Combined Fire Workers for Email and Internet Abuse," 2007 Electronic Monitoring & Surveillance Survey, February 28, 2008, <http://www.epolicyinstitute.com/2007-survey-results>.
- 22 Children's Internet Protection Act, Federal Communications Commission, updated December 30, 2019, <https://www.fcc.gov/guides/childrens-internet-protection-act>.
- 23 John Schwartz, "Schools Get Tool to Track Students' Use of Internet," *The New York Times*, May 21, 2001, <https://www.nytimes.com/2001/05/21/business/schools-get-tool-to-track-students-use-of-internet.html>.
- 24 Michael McCardle, "How Spyware Fits into Defense in Depth," SANS Institute: InfoSec Reading Room (2003).
- 25 Rahul Chatterjee, Periwinkle Doerfler, Hadas Orgad, Sam Havron, Jackeline Palmer, Diana Freed, Karen Levy, Nicola Dell, Damon McCoy, and Thomas Ristenpart, "The Spyware Used in Intimate Partner Violence," *IEEE Symposium on Security and Privacy* (2018), <https://ieeexplore.ieee.org/document/8418618>.
- 26 David Pegg and Sam Cutler, "What is Pegasus Spyware and How Does It Hack Phones?," *The Guardian*, July 18, 2021, <https://www.theguardian.com/news/2021/jul/18/what-is-pegasus-spyware-and-how-does-it-hack-phones>.
- 27 Shuo Chen, Rui Wang, XiaoFeng Wang, and Kehuan Zhang, "Side-Channel Leaks in Web Applications: A Reality Today, a Challenge Tomorrow," in *Proceedings of the 2010 IEEE Symposium on Security and Privacy* (2010): 191–206, <https://dl.acm.org/doi/10.1109/SP.2010.20>.
- 28 JonDonym, accessed April 2024, <https://anonymous-proxy-servers.net/>.
- 29 David M. Goldschlag, Michael G. Reed, and Paul F. Syverson, "Hiding Routing Information," *Proceedings of the 1st Workshop on Information Hiding*, Lecture Notes in Computer Science, 1174 (1996): 137–150, Cambridge, UK.
- 30 Tor, accessed April 2024, <https://www.torproject.org>.
- 31 Savage, Wyatt and Baker, "U.S. Confirms That It Gathers Online Data Overseas."
- 32 Gellman and Poitras, "U.S., British Intelligence Mining Data from Nine U.S. Internet Companies in Broad Secret Program."
- 33 Cloud Security Alliance, *Government Access to Information Survey Results*, July 2013, https://cloudsecurityalliance.org/research/surveys/#_nsa_prism.
- 34 Michael Barbaro and Tom Zeller, Jr., "A Face Is Exposed for AOL Searcher No. 4417749," *The New York Times*, August 9, 2006, www.nytimes.com/2006/08/09/technology/09aol.html.
- 35 Aleecia McDonald and Lorrie Faith Cranor, "The Cost of Reading Privacy Policies," *I/S: A Journal of Law and Policy for the Information Society* 4, no. 3 (2008).
- 36 Balachander Krishnamurthy and Craig E. Wills, "Privacy Diffusion on the Web: A Longitudinal Perspective," *Proceedings of the 18th International Conference on World Wide Web* (2009).
- 37 Steven Englehardt and Arvind Narayanan, "Online Tracking: A 1-million-site Measurement and Analysis," *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security* (2016).
- 38 Panagiotis Papadopoulos, Nicolas Kourtellis, and Evangelos P. Markatos, "Cookie Synchronization: Everything You Always Wanted to Know but Were Afraid to Ask," *Proceedings of the 2019 World Wide Web Conference* (2019).
- 39 Muhammad Ahmad Bashir, Umar Farooq, Maryam Shahid, Muhammad Fareed Zaffar, and Christo Wilson, "Quantity vs. Quality: Evaluating User Interest Profiles Using Ad Preference Managers," *Proceedings of the Network and Distributed System Security Symposium* (2019).
- 40 Giridhari Venkatadri, Elena Lucherini, Piotr Sapiezynski, and Alan Mislove, "Investigating Sources of PII Used in Facebook's Targeted Advertising," *Proceedings on Privacy Enhancing Technologies* (2019).
- 41 Stuart A. Thompson, "These Ads Think They Know You," *The New York Times*, April 30, 2019, <https://www.nytimes.com/interactive/2019/04/30/opinion/privacy-targeted-advertising.html>.
- 42 "Consumer Data Privacy in a Networked World: A Framework for Protecting Privacy and Promoting Innovation in the Global Digital Economy," The White House, February 2012, <https://obamawhitehouse.archives.gov/sites/default/files/privacy-final.pdf>.
- 43 Angelisa C. Plane, Elissa M. Redmiles, Michelle L. Mazurek, and Michael Carl Tschantz, "Exploring User Perceptions of Discrimination in Online Targeted Advertising," *Proceedings of the 26th USENIX Security Symposium* (2017); Claire

- Dolin, Ben Weinshel, Shawn Shan, Chang Min Hahn, Euirim Choi, Michelle L. Mazurek, and Blase Ur, “Unpacking Perceptions of Data-Driven Inferences Underlying Online Targeting and Personalization,” *Proceedings of the 2018 CHI Conference on Human Factors in Computing Systems* (2018).
- 44 Englehardt and Narayanan, “Online Tracking.”
- 45 Jennifer Valentino-DeVries, “Facebook Defends Getting Data from Logged-Out Users,” *Digits* (blog), *The Wall Street Journal*, September 26, 2011, <https://blogs.wsj.com/digits/2011/09/26/facebook-defends-getting-data-from-logged-out-users/>.
- 46 Ashkan Soltani, Shannon Canty, Quentin Mayo, Lauren Thomas, Chris Jay Hoofnagle, “Flash Cookies and Privacy,” Social Science Research Network, August 10, 2009, https://papers.ssrn.com/sol3/papers.cfm?abstract_id=1446862.
- 47 Gunes Acar, Christian Eubank, Steven Englehardt, Marc Juarez, Arvind Narayanan, and Claudia Diaz, “The Web Never Forgets: Persistent Tracking Mechanisms in the Wild,” *Proceedings of the 2014 ACM SIGSAC Conference on Computer and Communications Security* (2014).
- 48 Thomas Frank, “Session Variables Without Cookies,” January 20, 2008.
- 49 “Web Storage API,” Mozilla Developer Network, accessed April 2024, https://developer.mozilla.org/en-US/docs/Web/API/Web_Storage_API.
- 50 W3C, Web SQL Database, W3C Working Group Note 18, November 2010, www.w3.org/TR/webdatabase/.
- 51 Aleecia McDonald and Lorrie Faith Cranor, “A Survey of the Use of Adobe Flash Local Shared Objects to Respawn HTTP Cookies,” CMU-CyLab-11-001 Technical Report, January 31, 2011; Soltani et al., “Flash Cookies and Privacy.”
- 52 Mika Ayenson, Dietrich James Wambach, Ashkan Soltani, Nathan Good, Chris Jay Hoofnagle, “Flash Cookies and Privacy II: Now with HTML5 and ETag Respawning,” Social Science Research Network, July 29, 2011, https://papers.ssrn.com/sol3/papers.cfm?abstract_id=1898390.
- 53 Samy Kamkar, “Evercookie,” October 11, 2010, <https://samy.pl/evercookie/>.
- 54 Jeremiah Grossman, “I Know Where You’ve Been” (blog post), August 11, 2006, <https://jeremiahgrossman.blogspot.ro/2006/08/i-know-where-youve-been.html>.
- 55 Michael Smith, Craig Disselkoen, Shravan Narayan, Fraser Brown, and Deian Stefan, “Browser History Re:visited,” *Proceedings of WOOT @ the USENIX Security Symposium* (2018).
- 56 Englehardt and Narayanan, “Online Tracking.”
- 57 Peter Eckersley, “How Unique Is Your Web Browser?” *Proceedings of the 10th International Conference on Privacy Enhancing Technologies* (2010).
- 58 Englehardt and Narayanan, “Online Tracking.”
- 59 Plane et al., “Exploring User Perceptions of Discrimination in Online Targeted Advertising”; Dolin et al., “Unpacking Perceptions of Data-Driven Inferences Underlying Online Targeting and Personalization”; Englehardt and Narayanan, “Online Tracking.”
- 60 Pierre Laperdrix, Nataliia Bielova, Benoit Baudry, and Gildas Avoine, “Browser Fingerprinting: A Survey,” *ACM Transactions on the Web* 14, no. 8 (2020): 1–33, <https://dl.acm.org/doi/10.1145/3386040>.
- 61 Justin Schuh, “Privacy Sandbox in 2021: Testing a More Private Web,” *Chromium Blog*, January 25, 2021, <https://blog.chromium.org/2021/01/privacy-sandbox-in-2021.html>.
- 62 Web Incubator CG, “floc,” GitHub repository, accessed June 30, 2023, <https://github.com/WICG/floc>.
- 63 Web Incubator CG, “floc.”
- 64 Gilad Edelman, “Google and the Age of Privacy Theater,” *Wired*, March 18, 2021, <https://www.wired.com/story/google-floc-age-privacy-theater/>.
- 65 Bennett Cyphers, “Google’s FLoC Is a Terrible Idea,” Electronic Frontier Foundation Deeplinks Blog, March 3, 2021, <https://www EFF.org/deeplinks/2021/03/googles-floc-terrible-idea>.
- 66 Peter Snyder and Brendan Eich, “Why Brave Disables FLoC,” *Brave Software Blog*, April 12, 2021, <https://brave.com/why-brave-disables-floc/>.
- 67 Emma Roth, “Google Abandons FLoC, Introduces Topics API to Replace Tracking Cookies,” *The Verge*, January 25, 2022, <https://www.theverge.com/2022/1/25/22900567/google-floc-abandon-topics-api-cookies-tracking>.
- 68 Private Advertising Technology Community Group, “topics,” GitHub Repository, accessed July 3, 2023, <https://github.com/patcg-individual-drafts/topics>.

- 69 Peter Snyder, "Google's Topics API: Rebranding FLoC Without Addressing Key Privacy Issues," *Brave*, January 26, 2022, <https://brave.com/web-standards-at-brave/7-google-topics-api/>.
- 70 Justin Brookman, Phoebe Rouge, Aaron Alva, and Christina Yeung, "Cross-Device Tracking: Measurement and Disclosures," *Proceedings on Privacy Enhancing Technologies* 113 (2017): 117–22, <https://petsymposium.org/2017/papers/issue2/paper29-2017-2-source.pdf>.
- 71 Steven Englehardt, Jeffrey Han, and Arvind Narayanan, "I Never Signed Up for This! Privacy Implications of Email Tracking," *Proceedings on Privacy Enhancing Technologies* (2018): 109–126, <https://petsymposium.org/popets/2018/popets-2018-0006.pdf>.
- 72 Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), <https://data.europa.eu/eli/reg/2016/679/oj>.
- 73 Martino Trevisan, Stefano Traverso, Eleonora Bassi, and Marco Mellia, "4 Years of EU Cookie Law: Results and Lessons Learned," *Proceedings on Privacy Enhancing Technologies*, 2019.
- 74 Tanzina Vega, "Code That Tracks Users' Browsing Prompts Lawsuits," *The New York Times*, September 20, 2010, <https://www.nytimes.com/2010/09/21/technology/21cookie.html>; Tanzina Vega, "New Web Code Draws Concern Over Privacy Risks," *The New York Times*, October 10, 2010, <https://www.nytimes.com/2010/10/11/business/media/11privacy.html>.
- 75 Blase Ur, Pedro Giovanni Leon, Lorrie Faith Cranor, Richard Shay, and Yang Wang, "Smart, Useful, Scary, Creepy: Perceptions of Online Behavioral Advertising," *Proceedings of the Eighth Symposium on Usable Privacy and Security* (2012): 1–15, <https://dl.acm.org/doi/10.1145/2335356.2335362>.
- 76 McDonald and Cranor, "The Cost of Reading Privacy Policies"; Mark A. Graber, Donna M. D'Alessandro, and Jill Johnson-West, "Reading Level of Privacy Policies on Internet Health Web Sites," *Journal of Family Practice* 51, no. 7 (2002).
- 77 Blase Ur, Manya Sleeper, and Lorrie Faith Cranor, "{Privacy, Privacidad} Policies in Social Media: Providing Translated Privacy Notice," *Proceedings of the WWW Workshop on Privacy and Security in Online Social Media* (2012).
- 78 Alexandra Nisenoff, Arthur Borem, Madison Pickering, Grant Nakanishi, Maya Thumpasery, and Blase Ur, "Defining 'Broken': User Experiences and Remediation Tactics When Ad-Blocking or Tracking-Protection Tools Break a Website's User Experience," *Proceedings of the 32nd USENIX Security Symposium* (2023), <https://dl.acm.org/doi/10.5555/3620237.3620440>.
- 79 Martin Brinkmann, "Microsoft Unveils New Edge Privacy Tools Concept," *Ghacks* (blog), May 6, 2019, <https://www.ghacks.net/2019/05/06/microsoft-unveils-new-edge-privacy-tools-concept/>.
- 80 Steve Lohr, "The Default Choice, So Hard to Resist," *The New York Times*, October 15, 2011, <https://www.nytimes.com/2011/10/16/technology/default-choices-are-hard-to-resist-online-or-not.html>.
- 81 Nick Statt, "Advertisers are Furious with Apple for New Tracking Restrictions in Safari 11," *The Verge*, September 14, 2017, <https://www.theverge.com/2017/9/14/16308138/apple-safari-11-advertiser-groups-cookie-tracking-letter>.
- 82 Emil Protalinski, "Firefox Starts Blocking Third-party Cookies by Default," *Venture Beat*, June 4, 2019, <https://venturebeat.com/2019/06/04/firefox-enhanced-tracking-protection-blocks-third-party-cookies-by-default/>.
- 83 "Tracking Protection Lists," *Disconnect*, accessed July 7, 2023, <https://disconnect.me/trackerprotection>.
- 84 Lorrie Faith Cranor, "A First Look at Internet Explorer 9 Privacy Features," *Technology|Academics|Policy*, March 16, 2011.
- 85 Ur et al., "Smart, Useful, Scary, Creepy"; Mike Wuerthele, "Here's how Apple protects your Privacy in Safari with Intelligent Tracking Protection 2.0," *Apple Insider*, June 20, 2018, <https://appleinsider.com/articles/18/06/20/heres-how-apple-protects-your-privacy-in-safari-with-intelligent-tracking-protection-20>.
- 86 Lohr, "The Default Choice, So Hard to Resist."
- 87 Chethan Rao, "Brave Browser's Latest Addition Outmaneuvers Shifty Trackers," *Android Police*, May 15, 2023, <https://www.androidpolice.com/brave-browser-forgetful-browsing-web-android/>.
- 88 "Firefox Blocks Fingerprinting," *Mozilla*, accessed April 2024, <https://blog.mozilla.org/firefox/how-to-block-fingerprinting-with-firefox>.
- 89 Gaurav Aggarwal, Elie Bursztein, Collin Jackson, and Dan Boneh, "An Analysis of Private Browsing Modes in Modern Browsers," *Proceedings of the 19th USENIX Security Symposium* (2010).
- 90 Yuxi Wu, Panya Gupta, Miranda Wei, Yasemin Acar, Sascha Fahl, and Blase Ur, "Your Secrets Are Safe: How Browsers' Explanations Impact Misconceptions About Private Browsing Mode," *Proceedings of the Web Conference* (2018).

- 91 Gregg Keizer, "The Brave Browser Basics: What it Does, How it Differs from Rivals," *Computer World*, July 24, 2018, <https://www.computerworld.com/article/3292619/the-brave-browser-basics-what-it-does-how-it-differs-from-rivals.html>;
- Gregg Keizer, "What is the Epic Browser (and What Makes it Different)?" *Computer World*, July 3, 2018, <https://www.computerworld.com/article/3286605/what-is-the-epic-browser-and-what-makes-it-different.html>.
- 92 Peter Bright, "Microsoft Sticks to Its Guns, Keeps Do Not Track on by Default in IE10," *Ars Technica*, August 7, 2012, <https://arstechnica.com/information-technology/2012/08/microsoft-sticks-to-its-guns-keeps-do-not-track-on-by-default-in-ie10/>.
- 93 Michael Muchmore, "Google Chrome's Sham 'Do Not Track' Feature," *PCMag*, November 9, 2012, <https://www.pcmag.com/archive/google-chromes-sham-do-not-track-feature-304790>.
- 94 W3C Tracking Protection Working Group, www.w3.org/2011/tracking-protection/; Robert X. Cringely, "The Myth of Do Not Track—and the Tragedy of Internet Privacy," *InfoWorld*, July 31, 2013, <https://www.infoworld.com/article/2611570/the-myth-of-do-not-track---and-the-tragedy-of-internet-privacy.html>;
- Matthew Humphries, "Safari Drops 'Do Not Track' Support As It Allows Users to Be Tracked," *PC Magazine*, February 7, 2019, <https://www.pcmag.com/news/366407/safari-drops-do-not-track-support-as-it-allows-users-to-be>; Glenn Fleishman, "How the Tragic Death of Do Not Track Ruined the Web for Everyone," *Fast Company*, March 17, 2019, <https://www.fastcompany.com/90308068/how-the-tragic-death-of-do-not-track-ruined-the-web-for-everyone>.
- 95 Keizer, "The Brave Browser Basics"; Keizer, "What is the Epic Browser."
- 96 Pedro Giovanni Leon, Lorrie Faith Cranor, Aleecia M. McDonald, and Robert McGuire, "Token Attempt: The Misrepresentation of Website Privacy Policies Through the Misuse of P3P Compact Policy Tokens," *Proceedings of the 9th Annual Workshop on Privacy in the Electronic Society* (2010): 93–100, <https://dl.acm.org/doi/abs/10.1145/1866919.1866932>.
- 97 Microsoft, Internet Explorer 10 Privacy Statement for Windows 7, last updated July 2014, <https://windows.microsoft.com/en-US/internet-explorer/ie10-win7-privacy-statement>.
- 98 Google, My Ad Center, accessed April 2024, <https://myadcenter.google.com/home>; Microsoft, Ad Settings, accessed April 2024 <https://account.microsoft.com/privacy/ad-settings/>; Yahoo! Terms International, accessed April 2024, <https://legal.yahoo.com/index.html>.
- 99 Athanasios Andreou, Giridhari Venkatadri, Oana Goga, Krishna Gummadi, Patrick Loiseau, and Alan Mislove, "Investigating Ad Transparency Mechanisms in Social Media: A Case Study of Facebook's Explanations," *Proceedings of the Network and Distributed System Security Symposium* (2018).
- 100 Motahhare Eslami, Sneha R Krishna Kumaran, Christian Sandvig, and Karrie Karahalios, "Communicating Algorithmic Process in Online Behavioral Advertising," *Proceedings of the 2018 CHI Conference on Human Factors in Computing Systems* (2018): 1–13; Filipe N. Ribeiro, Koustuv Saha, Mahmoudreza Babaei, Lucas Henrique, Johnnatan Messias, Fabricio Benevenuto, Oana Goga, Krishna Gummadi, and Elissa Redmiles, "On Microtargeting Socially Divisive Ads: A Case Study of Russia-linked Ad Campaigns on Facebook," *Proceedings of the Conference on Fairness, Accountability, and Transparency* (2019).
- 101 Pedro Giovanni Leon, Justin Cranshaw, Lorrie Faith Cranor, Jim Graves, Manoj Hastak, Blase Ur, and Guzi Xu, "What Do Online Behavioral Advertising Privacy Disclosures Communicate to Users?" *Proceedings of the 2012 Workshop on Privacy in the Electronic Society* (2012): 19–30.
- 102 Leon et al, "Token Attempt."
- 103 Giridhari Venkatadri, Piotr Sapiezynski, Elissa Redmiles, Alan Mislove, Oana Goga, Michelle Mazurek, and Krishna Gummadi, "Auditing Offline Data Brokers via Facebook's Advertising Platform," *Proceedings of The Web Conference* (2019).
- 104 "Guidance on the Rules on Use of Cookies and Similar Technologies, V.3" Information Commissioner's Office, May 2012, https://ico.org.uk/media/for-organisations/documents/1545/cookies_guidance.pdf.
- 105 Englehardt et al, "I Never Signed Up for This! Privacy Implications of Email Tracking."
- 106 Network Advertising Initiative, accessed April 2024, <https://www.networkadvertising.org/>; Digital Advertising Alliance, accessed April 2024, <https://optout.aboutads.info>.
- 107 Pedro Giovanni Leon, Blase Ur, Richard Shay, Yang Wang, Rebecca Balebako, and Lorrie Faith Cranor, "Why Johnny Can't Opt Out: A Usability Evaluation of Tools to Limit Online Behavioral Advertising," *Proceedings of the SIGCHI*

- Conference on Human Factors in Computing Systems (2012): 589-598
<https://dl.acm.org/doi/10.1145/2207676.2207759>.
- 108 Leon et al., “Why Johnny Can’t Opt Out.”
- 109 Florian Schaub, Aditya Marella, Pranshu Kalvani, Blase Ur, Chao Pan, Emily Forney, and Lorrie Faith Cranor, “Watching Them Watching Me: Browser Extensions’ Impact on User Privacy Awareness and Concern,” *Proceedings of the NDSS Workshop on Usable Security* (2016).
- 110 Blase Ur et al., “Smart, Useful, Scary, Creepy.”
- 111 Nisenoff et al., “Defining ‘Broken.’”
- 112 Mozilla Support, Content Blocking, accessed June 27, 2019, <https://support.mozilla.org/en-US/kb/content-blocking>.
- 113 Leon et al., “Why Johnny Can’t Opt Out.”
- 114 Georg Merzdovnik, Markus Huber, Damjan Buhov, Nick Nikiforakis, Sebastian Neuner, Martin Schmiedecker, and Edgar Weippl, “Block Me If You Can: A Large-Scale Study of Tracker-Blocking Tools,” *Proceedings of the 2017 IEEE European Symposium on Security and Privacy* (2017).
- 115 Jennifer Valentino-DeVries, “How to Use Microsoft’s InPrivate Filtering,” *Digits (blog)*, *The Wall Street Journal*, August 1, 2010, <https://blogs.wsj.com/digits/2010/08/01/how-to-use-microsofts-inprivate-filtering/>.
- 116 Ben Weinschel, Miranda Wei, Mainack Mondal, Euirim Choi, Shawn Shan, Claire Dolin, Michelle L. Mazurek, and Blase Ur, “Oh, the Places You’ve Been! User Reactions to Longitudinal Transparency About Third-Party Web Tracking and Inferencing,” *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security* (2019).
- 117 Robert Walls, Shane Clark, and Brian Neil Levine, “Functional Privacy or Why Cookies Are Better with Milk,” *Seventh USENIX Workshop on Hot Topics in Security* (2012).
- 118 AdNauseum, accessed June 27, 2019, <https://adnauseam.io/>.
- 119 Blase Ur et al., “Smart, Useful, Scary, Creepy.”
- 120 Helen F. Nissenbaum, “Privacy as Contextual Integrity,” *Washington Law Review* 79, no. 1, (2004).
- 121 Daniel C. Howe and Helen Nissenbaum, “TrackMeNot: Resisting Surveillance in Web Search,” in Ian Kerr, Carole Lucock, and Valerie Steeves, eds., *Lessons from the Identity Trail: Anonymity, Privacy, and Identity in a Networked Society* (New York: Oxford University Press, 2009), 417–436.
- 122 Christopher Soghoian, “The Problem of Anonymous Vanity Searches,” *I/S: A Journal of Law and Policy for the Information Society* 3, no. 2 (2007).
- 123 Englehardt and Narayanan, “Online Tracking.”
- 124 Official Gmail Blog, “Images Now Showing,” December 12, 2013, <https://gmail.googleblog.com/2013/12/images-now-showing.html>.
- 125 “Satellite Navigation—Global Position System (GPS),” Federal Aviation Administration, updated November 16, 2023, https://www.faa.gov/about/office_org/headquarters_offices/ato/service_units/techops/navservices/gnss/gps/.
- 126 Ari Juels, “RFID Security and Privacy: A Research Survey,” *IEEE Journal on Selected Areas in Communications* 24, no. 2 (February 6, 2006).
- 127 Joel Johnson, “Is Your Carrier Tracing You via GPS and 911 Calls?” *Popular Mechanics*, October 1, 2009, <https://www.popularmechanics.com/technology/how-to/4258805>.
- 128 Sean Gallagher, “Mall Owners Pull Plug on Cellular Tracking (For Now),” *Wired*, November 29, 2011, <https://www.wired.com/business/2011/11/mall-pull-plug-cell-tracking/>; Sean Gallagher, “We’re Watching: Malls Track Shoppers’ Cellphone Signals to Gather Marketing Data,” *Wired*, November 28, 2011, <https://www.wired.com/business/2011/11/malls-track-phone-signals/>.
- 129 Clare Mulroy, “Tagging Your Items? What to Know About How Apple AirTags Locate Your Belongings,” *USA Today*, May 25, 2023, <https://www.usatoday.com/story/tech/tips/2023/05/25/how-do-apple-airtags-work/70189351007/>.
- 130 Apple, “AirTag: Lose Your Knack for Losing Things,” accessed July 1, 2023, <https://www.apple.com/airtag/>.
- 131 Ashley Belanger, “Stalkers’ ‘Chilling’ Use of AirTags Spurs Class-Action Suit Against Apple,” *Ars Technica*, December 6, 2022, <https://arstechnica.com/tech-policy/2022/12/apple-airtags-are-now-the-weapon-of-choice-for-stalkers-lawsuit-says/>.
- 132 Emma Roth, “Apple and Google Are Working Together to Limit AirTag Stalking,” *The Verge*, May 2, 2023, <https://www.theverge.com/2023/5/2/23707920/apple-google-airtag-stalking-bluetooth-tracker-alert-standard>.

- 133 Shane Ahern, Dean Eckles, Nathaniel Good, Simon King, Mor Naaman, and Rahul Nair, "Over-exposed? Privacy Patterns and Considerations in Online and Mobile Photo Sharing," *Proceedings of the 2007 SIGCHI conference on Human factors in computing systems* (2007).
- 134 "Find My Friends," Apple, accessed April 2024, <https://itunes.apple.com/us/app/find-my-friends/id466122094?mt=8>.
- 135 "Facebook and Location," Facebook, accessed April 2024, <https://www.facebook.com/about/location/>.
- 136 Bledi Memishaj, "Find My Phone: Track Your Misplaced Android, iPhone, or Windows Phone," *Gadget Detected*, April 24, 2017, <https://www.gadgetdetected.com/2017/04/find-my-phone/>.
- 137 Laura M. Holson, "Is Geotagging on Instagram Ruining Natural Wonders? Some Say Yes," *The New York Times*, November 29, 2018, <https://www.nytimes.com/2018/11/29/travel/instagram-geotagging-environment.html>.
- 138 "Geotagging on Social Media: Beware of the Risks," *Silkstream* (blog), August 2016, <https://www.silkstream.net/blog/2016/08/geotagging-social-media-risks.html>.
- 139 Cheryl Rodewig, "Geotagging Poses Security Risks," U.S. Army, March 7, 2012, https://www.army.mil/article/75165/Geotagging_poses_security_risks.
- 140 Alex Hern, "Fitness Tracking App Strava Gives Away Location of Secret US Army Bases," *The Guardian*, January 28, 2018, <https://www.theguardian.com/world/2018/jan/28/fitness-tracking-app-gives-away-location-of-secret-us-army-bases>.
- 141 Lindsay Modglin and April McCormick, "11 Parental Control and Monitoring Apps We Recommend in 2023," *Parents*, updated January 10, 2024, <https://www.parents.com/parentsirl/best-parental-monitoring-apps/>.
- 142 David Pogue, "Cellphones That Track the Kids," *The New York Times*, December 21, 2006, <https://www.nytimes.com/2006/12/21/technology/21pogue.html>.
- 143 Alexei Czeskis, Ivayla Dermendjieva, Hussein Yapit, Alan Borning, Batya Friedman, Brian Gill, and Tadayoshi Kohno, "Parenting From the Pocket: Value Tensions and Technical Directions For Secure and Private Parent-Teen Mobile Safety," *Proceedings of the Sixth Symposium on Usable Privacy and Security* (2010); Lorrie Faith Cranor, Adam L. Durity, Abigail Marsh, and Blase Ur, "Parents' and Teens' Perspectives on Privacy in a Technology-Filled World," *Proceedings of the Tenth Symposium on Usable Privacy and Security* (2014).
- 144 Gundars Kaupins and Robert Minch, "Legal and Ethical Implications of Employee Location Monitoring," *Proceedings of the 38th Hawaii International Conference on System Sciences* (2005).
- 145 Debora Jeske, "Remote Workers' Experiences With Electronic Monitoring During Covid-19: Implications and Recommendations," *International Journal of Workplace Health Management* 15, no. 3 (2022): 393-409.
- 146 Matthew Finnegan, "The New Normal: When Work-From-Home Means the Boss Is Watching," *Computerworld*, October 29, 2020, <https://www.computerworld.com/article/3586616/the-new-normal-when-work-from-home-means-the-boss-is-watching.html>.
- 147 "Location-based Advertising—Relevant Trends and Technologies," Frost & Sullivan, February 16, 2012, <https://www.frost.com/sublib/display-report.do?id=9838-00-31-00-00>.
- 148 Patrick Gage Kelley, Michael Benisch, Lorrie Faith Cranor, and Norman Sadeh, "When Are Users Comfortable Sharing Location with Advertisers?" *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems* (2011).
- 149 Andrew Dowell, "Tracking Women: Now There's Not An App For That," *Digits* (blog), *The Wall Street Journal*, March 31, 2012, <https://blogs.wsj.com/digits/2012/03/31/tracking-women-now-theres-not-an-app-for-that/>.
- 150 Michael F. Goodchild, "Unit 002—What Is Geographic Information Science?" *NCGIA Core Curriculum in GIScience*, 1997, accessed April 2024, <https://escholarship.org/uc/item/5k52c3kc>.
- 151 Foursquare, accessed April 2024, <https://foursquare.com/privacy/>.
- 152 Lynn Tsai, Primal Wijesekera, Joel Reardon, Irwin Reyes, Serge Egelman, David Wagner, Nathan Good, and Jung-Wei Chen, "Turtle Guard: Helping Android Users Apply Contextual Privacy Preferences," *Proceedings of the Thirteenth Symposium on Usable Privacy and Security*, (2017).
- 153 Michael Benisch, Patrick Gage Kelley, Norman Sadeh, and Lorrie Faith Cranor, "Capturing Location-Privacy Preferences: Quantifying Accuracy and User-Burden Tradeoffs," *Personal and Ubiquitous Computing* 15, no. 7 (2011).
- 154 Rebecca Balebako, Jaeyeon Jung, Wei Lu, Lorrie Faith Cranor, and Carolyn Nguyen, "Little Brothers Watching You: Raising Awareness of Data Leaks on Smartphones," *Proceedings of the Ninth Symposium on Usable Privacy and Security* (2013).

- 155 Hazim Almuhiemedi, Florian Schaub, Norman Sadeh, Idris Adjerid, Alessandro Acquisti, Joshua Gluck, Lorrie Faith Cranor, and Yuvraj Agarwal, "Your Location Has Been Shared 5,398 Times! A Field Study on Mobile App Privacy Nudging," *Proceedings of the 33rd Annual ACM Conference on Human Factors in Computing Systems* (2015).
- 156 Yves-Alexandre de Montjoye, César Hidalgo, Michel Verleysen, and Vincent Blondel, "Unique in the Crowd: The Privacy Bounds of Human Mobility," *Scientific Reports* 3, March 25, 2013, <https://dx.doi.org/10.1038/srep01376>.
- 157 Arvind Narayanan et al., "Location Privacy via Private Proximity Testing," *Proceedings of the 18th Annual Network and Distributed Systems Symposium* (2011).
- 158 Lewis A. Kaplan, United States District Court, S. D. New York, United States of America v. John Tomero et al, Defendants, No. S2 06 Crim. 0008(LAK), November 27, 2006.
- 159 Declan McCullagh and Anne Broache, "FBI Taps Cell Phone Mic as Eavesdropping Tool," *ZDNET*, December 1, 2006, <https://www.zdnet.com/article/fbi-taps-cell-phone-mic-as-eavesdropping-tool/>.
- 160 Neal Leavitt, "Mobile Phones: The Next Frontier for Hackers?" *Computer* 38, no. 4, (2005).
- 161 Ryan Farley and Xinyuan Wang, "Roving Bugnet: Distributed Surveillance Threat and Mitigation," *Emerging Challenges for Security, Privacy and Trust. IFIP Advances in Information and Communications Technologies* 297, (2009).
- 162 Farley and Wang, "Roving Bugnet: Distributed Surveillance Threat and Mitigation."
- 163 Farley and Wang, "Roving Bugnet: Distributed Surveillance Threat and Mitigation."
- 164 Brown Farinholt, Mohammad Rezaeirad, Paul Pearce, Hitesh Dharmdasani, Haikuo Yin, Stevens Le Blond, Damon McCoy, and Kirill Levchenko, "To Catch a Ratter: Monitoring the Behavior of Amateur DarkComet RAT Operators in the Wild," *Proceedings of the 2017 IEEE Symposium on Security and Privacy*, (2017).
- 165 Suzan Clark, "Pa. School Faces FBI Probe, Lawsuit for Using Webcams on Laptops to Watch Students at Home," *ABC Good Morning America*, February 22, 2010, <https://abcnews.go.com/GMA/Parenting/pennsylvania-school-fbi-probe-webcam-students-spying/story?id=9905488>.
- 166 John P. Martin, "Lower Merion District's Laptop Saga Ends with \$610,000 Settlement," *The Inquirer*, October 12, 2010, https://www.inquirer.com/philly/news/year-in-review/20101012_Lower_Merion_district_s_laptop_saga_ends_with_610_000_settlement.html.
- 167 Clark, "Pa. School Faces FBI Probe, Lawsuit for Using Webcams on Laptops to Watch Students at Home."
- 168 David Goldman, "Your Samsung TV is Eavesdropping on Your Private Conversations," *CNN Business*, February 10, 2015, <https://money.cnn.com/2015/02/09/technology/security/samsung-smart-tv-privacy/index.html>.
- 169 Ben Popken, "Your Smart TV is Watching You Watching TV, Consumer Reports Finds," *NBC News*, February 7, 2018, <https://www.nbcnews.com/tech/security/your-smart-tv-watching-you-watching-tv-consumer-reports-finds-n845456>.
- 170 Sam Biddle, "WikiLeaks Dump Shows CIA Could Turn Smart TVs into Listening Devices," *The Intercept*, March 7, 2017, <https://theintercept.com/2017/03/07/wikileaks-dump-shows-cia-could-turn-smart-tvs-into-listening-devices/>.
- 171 "Surveillance Drones," *Electronic Frontier Foundation*, accessed June 27, 2019, <https://www.eff.org/issues/surveillance-drones>.
- 172 Bruce Schneier, "Is it OK to Shoot Down a Drone Over Your Backyard?" *CNN*, September 9, 2015, <https://www.cnn.com/2015/09/09/opinions/schneier-shoot-down-drones/index.html>.
- 173 Kelsey D. Atherton, "It Is a Federal Crime To Shoot Down A Drone, Says FAA," *Popular Science*, April 15, 2016, <https://www.popsci.com/it-is-federal-crime-to-shoot-down-drone-says-faa/>.
- 174 Nick Patton Walsh, "What Shooting Down a \$110M US Drone Tells Us About Iran," *CNN*, June 25, 2019, <https://www.cnn.com/2019/06/25/middleeast/iran-drone-shooting-capabilities-npw-intl/index.html>.
- 175 Jake Laperruque and David Janovsky, "These Police Drones are Watching You," *POGO*, September 25, 2018, <https://www.pogo.org/analysis/2018/09/these-police-drones-are-watching-you/>.
- 176 Nick Statt, "Sunflower Labs is Building a Drone Surveillance System for High-end Homes," *The Verge*, December 7, 2018, <https://www.theverge.com/2018/12/7/18129308/sunflower-labs-system-drone-surveillance-bee-hive-home-security-startup>.
- 177 Joyce W. Luk, "Identifying Terrorists: Privacy Rights in the United States and the United Kingdom," *Hastings International and Comparative Law Review* 25 (2002); "Workplace Privacy," *Electronic Privacy Information Center*, accessed April 2024, <https://epic.org/issues/data-protection/workplace-privacy/>.
- 178 Paul Bischoff, "Surveillance Camera Statistics: Which Cities Have the Most CCTV Cameras?" *Comparitech*, May 23, 2023, <https://www.comparitech.com/vpn-privacy/the-worlds-most-surveilled-cities/>.

- 179 Martin Gill and Angela Spriggs, *Home Office Research Study 292: Assessing the Impact of CCTV* (London: Home Office Research, Development and Statistics Directorate (2005)).
- 180 Joyce W. Luk, "Identifying Terrorists: Privacy Rights in the United States and the United Kingdom," *Hastings International and Comparative Law Review* 25, no. 2 (2002).
- 181 "Workplace Privacy," Electronic Privacy Information Center.
- 182 Parmy Olson and Sam Schechner, "AI, Surveillance Tools Scrutinized by European Regulators," *The Wall Street Journal*, June 26, 2019, <https://www.wsj.com/articles/ai-surveillance-tools-scrutinized-by-european-regulators-11561562155>.
- 183 Jonathan Ratcliffe, "How Many CCTV Cameras Are There in London?" *CCTV.co.uk*, November 18, 2020, <https://www.cctv.co.uk/how-many-cctv-cameras-are-there-in-london/>.
- 184 Christina Zhao, "Jaywalking in China: Facial Recognition Surveillance Will Soon Fine Citizens Via Text Message," *Newsweek*, March 27, 2018, <https://www.newsweek.com/jaywalking-china-facial-recognition-surveillance-will-soon-fine-citizens-text-861401>.
- 185 Paul Mozur, "One Month, 500,000 Face Scans: How China Is Using A.I. to Profile a Minority," *The New York Times*, April 14, 2019, <https://www.nytimes.com/2019/04/14/technology/china-surveillance-artificial-intelligence-racial-profiling.html>.
- 186 Zak Doffman, "China Is Using Facial Recognition to Track Ethnic Minorities, Even in Beijing," *Forbes*, May 3, 2019, <https://www.forbes.com/sites/zakdoffman/2019/05/03/china-new-data-breach-exposes-facial-recognition-and-ethnicity-tracking-in-beijing/>.
- 187 Melissa Heikkilä, "The Walls Are Closing in on Clearview AI," *MIT Technology Review*, May 24, 2022, <https://www.technologyreview.com/2022/05/24/1052653/clearview-ai-data-privacy-uk/>.
- 188 Kashmir Hill, "Clearview AI, Used by Police to Find Criminals, Is Now in Public Defenders' Hands," *The New York Times*, September 18, 2022, <https://www.nytimes.com/2022/09/18/technology/facial-recognition-clearview-ai.html>.
- 189 Caroline Haskins, "Controversial Facial Recognition Company Clearview AI Banned From Selling Face Database to Private US Businesses," *Business Insider*, May 9, 2022, <https://www.businessinsider.com/clearview-ai-facial-recognition-lawsuit-us-businesses-private-companies-2022-05>.
- 190 Heikkilä, "The Walls Are Closing in on Clearview AI."
- 191 Official Gmail Blog, "Images Now Showing."
- 192 Paresh Dave, "U.S. Cities Are Backing Off Banning Facial Recognition as Crime Rises," *Reuters*, May 12, 2022, <https://www.reuters.com/world/us/us-cities-are-backing-off-banning-facial-recognition-crime-rises-2022-05-12/>.
- 193 Kashmir Hill, "A Face Search Engine Anyone Can Use is Alarming Accurate," *The New York Times*, May 26, 2022, <https://www.nytimes.com/2022/05/26/technology/pimeyes-facial-recognition-search.html>.
- 194 Evan Greer and Anna Bonesteel, "America's Ring Doorbell Camera Obsession Highlights the Scourge of Mass Surveillance," *NBC News*, November 1, 2022, <https://www.nbcnews.com/think/opinion/amazons-ring-doorbell-videos-make-america-less-safe-crime-rcna55143>.
- 195 Lauren Bridges, "Amazon's Ring is the Largest Civilian Surveillance Network the US Has Ever Seen," *The Guardian*, May 18, 2021, <https://www.theguardian.com/commentisfree/2021/may/18/amazon-ring-largest-civilian-surveillance-network-us>.
- 196 Matt Burgess, "All the Data Amazon's Ring Cameras Collect About You," *Wired*, August 5, 2022, <https://www.wired.com/story/ring-doorbell-camera-amazon-privacy/>.
- 197 Edward Ongweso Jr, "Ring Cameras Are Being Used to Control and Surveil Overworked Delivery Workers," *Vice Motherboard*, October 19, 2022, <https://www.vice.com/en/article/7k8dx4/ring-cameras-are-being-used-to-control-and-surveil-overworked-delivery-workers>.
- 198 Robert Westervelt, "Cisco Warns Serious VoIP Vulnerability Enables Eavesdropping," *CRN*, January 11, 2013, <https://www.crn.com/news/security/240146127/cisco-warns-serious-voip-vulnerability-enables-eavesdropping.htm>.
- 199 Andrew M. White, Austin R. Matthews, Kevin Z. Snow, and Fabian Monrose, "Phonotactic Reconstruction of Encrypted VoIP Conversations: Hookt on fon-iks," *Proceedings of the 32nd IEEE Symposium on Security and Privacy* (May 2011).
- 200 Glenn Greenwald, Ewen MacAskill, Laura Poitras, Spencer Ackerman, Dominic Rushe, "Microsoft Handed the NSA Access to Encrypted Messages," *The Guardian*, July 12, 2013, <https://www.theguardian.com/world/2013/jul/11/microsoft-nsa-collaboration-user-data>.

- 201 Jonathan Mayer, Patrick Mutchler, and John C. Mitchell, "Evaluating the privacy properties of telephone metadata," *Proceedings of the National Academy of Sciences* 113.20: 5536–5541 (2016).
- 202 Micah Singleton, "Nearly a quarter of US households own a smart speaker, according to Nielsen," *The Verge*, September 30, 2018, <https://www.theverge.com/circuitbreaker/2018/9/30/17914022/smart-speaker-40-percent-us-households-nielsen-amazon-echo-google-home-apple-homepod>.
- 203 Noura Abdi, Kopo M. Ramokapane, and Jose M. Such, "More than Smart Speakers: Security and Privacy Perceptions of Smart Home Personal Assistants," *Proceedings of the Fifteenth Symposium on Usable Privacy and Security* (2019).
- 204 Lindsey O'Donnell, "Alexa Eavesdropping Flub Re-Sparks Voice Assistant Privacy Debate," *Threat Post*, May 25, 2018, <https://threatpost.com/alexa-eavesdropping-flub-re-sparks-voice-assistant-privacy-debate/132284/>.
- 205 Andrew Guthrie Ferguson, "Alexa, What Is Probable Cause?" *Slate*, November 20, 2018, <https://slate.com/technology/2018/11/amazon-echo-alexa-murder-case-new-hampshire-warrant.html>.
- 206 Jordan Valinsky, "Amazon Reportedly Employs Thousands of People to Listen to your Alexa Conversations," *CNN Business*, April 11, 2019, <https://www.cnn.com/2019/04/11/tech/amazon-alexa-listening/index.html>.
- 207 Elana Zeide, "The Structural Consequences of Big Data-Driven Education," *Big Data* 5, no. 2 (2017): 164-172.
- 208 Elana Zeide, "Education Technology and Student Privacy," *The Cambridge Handbook of Consumer Privacy* (2018): 70–84.
- 209 Britt Paris, Rebecca Reynolds, and Catherine McGowan, "Sins of Omission: Critical Informatics Perspectives on Privacy in E-Learning Systems in Higher Education," *Journal of the Association for Information Science and Technology* 73, no. 5 (2022): 708–725.
- 210 Emma Bowman, "Scanning Students' Rooms During Remote Tests Is Unconstitutional, Judge Rules," *NPR*, August 26, 2022, <https://www.npr.org/2022/08/25/1119337956/test-proctoring-room-scans-unconstitutional-cleveland-state-university>.
- 211 Taylor Swaak, "Students Say Room Scans During Online Tests Are Invasive. Now a Judge Agrees," *The Chronicle of Higher Education*, August 24, 2022, <https://www.chronicle.com/article/students-say-room-scans-during-online-tests-are-invasive-now-a-judge-agrees>.
- 212 Rebecca S. Portnoff, Linda N. Lee, Serge Egelman, Pratyush Mishra, Derek Leung, and David Wagner, "Somebody's Watching Me? Assessing the Effectiveness of Webcam Indicator Lights," *Proceedings of the 33rd Annual ACM Conference on Human Factors in Computing Systems* (2015).
- 213 Alex Hern, "Mark Zuckerberg Tapes Over His Webcam. Should You?" *The Guardian*, June 22, 2016, <https://www.theguardian.com/technology/2016/jun/22/mark-zuckerberg-tape-webcam-microphone-facebook>.
- 214 Kellen Beck, "Taping Over Your Computer Microphone Does Nothing—Here's What to do Instead," *Mashable*, June 22, 2016, <https://mashable.com/article/computer-microphone-hack>.
- 215 Yuxin Chen, Huiying Li, Shan-Yuan Teng, Steven Nagels, Zhijing Li, Pedro Lopes, Ben Y. Zhao, and Haitao Zheng, "Wearable Microphone Jamming," *Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems* (2020).
- 216 "IoT Inspector 2," accessed April 2024, <https://inspector.engineering.nyu.edu/>.
- 217 Jason I. Hong and James A. Landay, "An Architecture for Privacy-Sensitive Ubiquitous Computing," *Proceedings of the 2nd International Conference on Mobile Systems, Applications, and Services* (2004).
- 218 Chicago Data Portal," accessed June 20, 2019, <https://data.cityofchicago.org/>.
- 219 Arvind Narayanan and Vitaly Shmatikov, "Robust De-Anonymization of Large Sparse Datasets," *Proceedings of the IEEE Symposium on Security and Privacy* (2008).
- 220 "Shedding Light on Smart City Privacy," *Future of Privacy Forum*, March 30, 2017, <https://fpf.org/2017/03/30/smart-cities/>.
- 221 "Smart Cities," Privacy International, <https://privacyinternational.org/learn/smart-cities>, accessed April 2024.
- 222 "From Smart Cities to Safe Cities: Normalising the Police State?" Privacy International, August 15, 2018, <https://privacyinternational.org/long-read/2231/smart-cities-safe-cities-normalising-police-state>.
- 223 Emilie Scott, "The Trouble with Informed Consent in Smart Cities," *IAPP*, February 28, 2019, <https://iapp.org/news/a/the-trouble-with-informed-consent-in-smart-cities/>.
- 224 Elinor Mills, "Researchers Find Smart Meters Could Reveal Favorite TV Shows," *CNET*, January 24, 2012, <https://www.cnet.com/news/researchers-find-smart-meters-could-reveal-favorite-tv-shows/>.

- 225 Peter Kotecki, "Google's Parent Company Revealed its Plan for a High-Tech Neighborhood in Toronto—and It Could Be the World's Largest Tall Timber Project," *Business Insider*, August 15, 2018, <https://www.businessinsider.com/alphabets-sidewalk-labs-reveals-plan-for-quayside-in-toronto-2018-8>.
- 226 Leyland Cecco, "'Surveillance Capitalism': Critic Urges Toronto to Abandon Smart City Project," *The Guardian*, June 6, 2019, <https://www.theguardian.com/cities/2019/jun/06/toronto-smart-city-google-project-privacy-concerns>.
- 227 Gabrielle Canon, "'City of Surveillance': Privacy Expert Quits Toronto's Smart-City Project," *The Guardian*, October 23, 2018, <https://www.theguardian.com/world/2018/oct/23/toronto-smart-city-surveillance-ann-cavoukian-resigns-privacy>.
- 228 Franziska Roesner, Tadayoshi Kohno, and David Molnar, "Security and Privacy for Augmented Reality Systems," *Communications of the ACM* 57, no. 4 (2014): 88–96.
- 229 Kiron Lebeck, Kimberly Ruth, Tadayoshi Kohno and Franziska Roesner, "Towards Security and Privacy for Multi-User Augmented Reality: Foundations With End Users," *Proceedings of the 2018 IEEE Symposium on Security and Privacy* (2018).
- 230 Vivian Ng and Catherine Kent, "Smartphone Data Tracking Is More Than Creepy—Here's Why You Should Be Worried," *The Conversation*, February 7, 2018, <https://theconversation.com/smartphone-data-tracking-is-more-than-creepy-heres-why-you-should-be-worried-91110>.
- 231 Manisha Priyadarshini, "Which Sensors Do I Have in My Smartphone? How Do They Work?" *FOSS Bytes*, September 25th, 2018, <https://fossbytes.com/which-smartphone-sensors-how-work/>.
- 232 Jun Han, Emmanuel Owusu, Le T. Nguyen, Adrian Perrig, and Joy Zhang, "ACComplice: Location Inference Using Accelerometers on Smartphones," *Proceedings of the 2012 Fourth International Conference on Communication Systems and Networks* (2012).
- 233 Emmanuel Owusu, Jun Han, Sauvik Das, Adrian Perrig, and Joy Zhang, "ACcessory: Password Inference Using Accelerometers on Smartphones," *Proceedings of the Twelfth Workshop on Mobile Computing Systems & Applications* (2012).
- 234 Marian Harbach, Emanuel von Zezschwitz, Andreas Fichtner, Alexander De Luca, and Matthew Smith, "It's a Hard Lock Life: A Field Study of Smartphone (Un)Locking Behavior and Risk Perception," *Proceedings of the 10th Symposium on Usable Privacy and Security* (2014).
- 235 Chandrasekhar Bhagavatula, Blase Ur, Kevin Iacovino, Su Mon Kywe, Lorrie Faith Cranor, and Marios Savvides, "Biometric Authentication on iPhone and Android: Usability, Perceptions, and Influences on Adoption," *Proceedings of the NDSS Workshop on Usable Security* (2015).
- 236 Ivan Cherapau, Ildar Muslukhov, Nalin Asanka, and Konstantin Beznosov, "On the Impact of Touch ID on iPhone Passcodes," *Proceedings of the 11th Symposium on Usable Privacy and Security* (2015).
- 237 Edward Jay Wang, William Li, Doug Hawkins, Terry Gernsheimer, Colette Norby-Slycord, and Shwetak N. Patel, "HemaApp: Noninvasive Blood Screening of Hemoglobin Using Smartphone Cameras," *Proceedings of the 2016 ACM International Joint Conference on Pervasive and Ubiquitous Computing* (2016).
- 238 Florian Schaub, Rebecca Balebako, Adam L. Durity, and Lorrie Faith Cranor, "A Design Space for Effective Privacy Notices," *Proceedings of the Eleventh Symposium on Usable Privacy and Security* (2015).
- 239 Emily McReynolds, Sarah Hubbard, Timothy Lau, Aditya Saraf, Maya Cakmak, and Franziska Roesner, "Toys that Listen: A Study of Parents, Children, and Internet-Connected Toys," *Proceedings of the 2017 CHI Conference on Human Factors in Computing Systems* (2017).
- 240 Samuel Gibbs, "Hackers Can Hijack Wi-Fi Hello Barbie to Spy on Your Children," *The Guardian*, November 26, 2015, <https://www.theguardian.com/technology/2015/nov/26/hackers-can-hijack-wi-fi-hello-barbie-to-spy-on-your-children>.
- 241 Blase Ur, Jaeyeon Jung and Stuart Schechter, "Intruders Versus Intrusiveness: Teens' and Parents' Perspectives on Home-Entryway Surveillance," *Proceedings of the 2014 ACM International Joint Conference on Pervasive and Ubiquitous Computing* (2014).
- 242 Anita Melander-Wikman, Ylva Fältholm, and Gunvor Gard. "Safety vs. Privacy: Elderly Persons' Experiences of a Mobile Safety Alarm," *Health & Social Care in the Community* 16, no. 4 (2008).
- 243 George Demiris, Debra Parker Oliver, Jarod Giger, Marjorie Skubic, and Marilyn Rantz, "Older Adults' Privacy Considerations for Vision Based Recognition Methods of Eldercare Applications," *Technology and Health Care* 17, no. 1, (2009): 41–48.

- 244 Matt Day, "Your Smart Light Can Tell Amazon and Google When You Go to Bed," *Bloomberg*, February 12, 2019, <https://www.bloomberg.com/news/articles/2019-02-12/your-smart-light-can-tell-amazon-and-google-when-you-go-to-bed>.
- 245 Rob Marvin, "Privacy Tops List of Consumer Smart Home Concerns," *PC Magazine*, March 4, 2019, <https://www.pcmag.com/news/366783/privacy-tops-list-of-consumer-smart-home-concerns>.
- 246 Serena Zheng, Noah Apthorpe, Marshini Chetty, and Nick Feamster, "User Perceptions of Smart Home IoT Privacy," *Proceedings of the ACM on Human-Computer Interaction* (2018).
- 247 Eric Zeng, Shrirang Mare, and Franziska Roesner, "End User Security and Privacy Concerns with Smart Homes," *Proceedings of the Thirteenth Symposium on Usable Privacy and Security* (2017).
- 248 Milijana Surbatovich, Jassim Aljuraidan, Lujo Bauer, Anupam Das, and Limin Jia, "Some Recipes Can Do More Than Spoil Your Appetite: Analyzing the Security and Privacy Risks of IFTTT Recipes," *Proceedings of the 26th International Conference on World Wide Web* (2017).
- 249 Weijia He, Maximilian Golla, Roshni Padhi, Jordan Ofek, Markus Dürmuth, Earlene Fernandes, and Blase Ur, "Rethinking Access Control and Authentication for the Home Internet of Things (IoT)," *Proceedings of the 27th USENIX Security Symposium* (2018).
- 250 Ben Wojdyla, "How it Works: The Computer Inside Your Car," *Popular Mechanics*, February 21, 2012, <https://www.popularmechanics.com/cars/how-to/a7386/how-it-works-the-computer-inside-your-car/>.
- 251 "United States v. Jones," *SCOTUSblog*, accessed June 20, 2019, <https://www.scotusblog.com/case-files/cases/united-states-v-jones/>.
- 252 Byron V. Acohido, "The Dark Sides of Modern Cars: Hacking and Data Collection," *Threat Post*, February 26, 2019, <https://threatpost.com/modern-car-warning/142190/>.
- 253 Rebekah L. Sanders, "Car Renters Beware: Bluetooth Use Can Reveal Your Private Data," *USA Today*, January 30, 2018, <https://www.usatoday.com/story/money/cars/2018/01/30/car-renters-beware-bluetooth-use-can-reveal-your-private-data/1080225001/>.
- 254 Kim Komando, "Your Car's Hidden 'Black Box' and How to Keep It Private," *USA Today*, December 26, 2014, <https://www.usatoday.com/story/tech/columnist/komando/2014/12/26/keep-your-car-black-box-private/20609035/>.
- 255 Sean Cleary, "Can Your Car's Black Box Help in Case of a Car Accident?" *The Law Offices of Sean M. Cleary* (blog), December 14, 2017, <https://www.seanclareypa.com/blog/car-black-box-car-accident/>.
- 256 OnStar, accessed April 2024, <https://www.onstar.com/>.
- 257 Zhaolong Ning, Feng Xia, Noor Ullah, Xiangjie Kong, and Xiping Hu, "Vehicular Social Networks: Enabling Smart Mobility," *IEEE Communications Magazine* 55, no. 5 (May 2017).
- 258 Ishtiaq Rouf, Rob Miller, Hossen Mustafa, Travis Taylor, Sangho Oh, Wenyan Xu, Marco Gruteser, Wade Trappe, and Ivan Seskar, "Security and Privacy Vulnerabilities of In-Car Wireless Networks: A Tire Pressure Monitoring System Case Study," *Proceedings of the 19th USENIX Security Symposium* (2010).
- 259 Karl Koscher, Alexei Czeskis, Franziska Roesner, Shwetak Patel, Tadayoshi Kohno, Stephen Checkoway, Damon McCoy, Brian Kantor, Danny Anderson, Hovav Shacham, and Stefan Savage, "Experimental Security Analysis of a Modern Automobile," *Proceedings of the 2010 IEEE Symposium on Security and Privacy* (2010).
- 260 Solove, "'I've Got Nothing to Hide' and Other Misunderstandings of Privacy."
- 261 "Street-Level Surveillance: Automated License Plate Readers (ALPRs)," Electronic Frontier Foundation, updated October 1, 2023, <https://www EFF.org/pages/automated-license-plate-readers-alpr>.
- 262 "You Are Being Tracked: How License Plate Readers Are Being Used to Record Americans' Movements," American Civil Liberties Union, accessed June 19, 2023, <https://www.aclu.org/issues/privacy-technology/location-tracking/you-are-being-tracked>.
- 263 Thor Benson, "The Danger of License Plate Readers in Post-Roe America," *Wired*, July 7, 2022, <https://www.wired.com/story/license-plate-reader-alpr-surveillance-abortion/>.
- 264 Greig Paul and James Irvine, "Privacy Implications of Wearable Health Devices," *Proceedings of the Seventh International Conference on Security of Information and Networks* (2014).
- 265 Jeremy Hsu, "The Strava Heat Map and the End of Secrets," *Wired*, January 29, 2018, <https://www.wired.com/story/strava-heat-map-military-bases-fitness-trackers-privacy/>.

- 266 Daniel Halperin, Tadayoshi Kohno, Thomas S. Heydt-Benjamin, Kevin Fu, and William H. Maisel, "Security and Privacy for Implantable Medical Devices," *IEEE Pervasive Computing* 7, no. 1 (2008): 30–39.
- 267 Sciforce, "IoT in Healthcare: Are We Witnessing a New Revolution?" *Medium*, March 7, 2019, <https://medium.com/sciforce/iot-in-healthcare-are-we-witnessing-a-new-revolution-6bb0ecf55991>.
- 268 Kevin Roose, "The Metaverse Is Mark Zuckerberg's Escape Hatch," *The New York Times*, October 29, 2021, <https://www.nytimes.com/2021/10/29/technology/meta-facebook-zuckerberg.html>.
- 269 Derek Robertson, "Apple and the Two-track Future for the Metaverse," *Politico*, June 6, 2023, <https://www.politico.com/newsletters/digital-future-daily/2023/06/06/apple-and-the-two-track-future-for-the-metaverse-00100456>.
- 270 Steve Dent, "Sony Steps into the Metaverse with the 'Mocopi' Motion Tracking System," *Engadget*, November 29, 2022, <https://www.engadget.com/sony-mocopi-movement-tracker-metaverse-avatars-131721036.html>.
- 271 Yuntao Wang, Zhou Su, Ning Zhang, Rui Xing, Dongxiao Liu, Tom H. Luan, and Xuemin Shen, "A Survey on Metaverse: Fundamentals, Security, and Privacy," *IEEE Communications Surveys & Tutorials* 25, no. 1 (2023): 319–352.
- 272 Janus Rose, "Eye-Tracking Tech Is Another Reason the Metaverse Will Suck," *Vice*, March 10, 2022, <https://www.vice.com/en/article/93b8v8/eye-tracking-tech-is-another-reason-the-metaverse-will-suck>; Tom Wheeler, "If the Metaverse Is Left Unregulated, Companies Will Track Your Gaze and Emotions," *Time*, June 20, 2022, <https://time.com/6188956/metaverse-is-left-unregulated-companies-will-track-gaze-emotions/>.
- 273 Gabriella M. Harari, Nicholas D. Lane, Rui Wang, Benjamin S. Crosier, Andrew T. Campbell, and Samuel D. Gosling, "Using Smartphones to Collect Behavioral Data in Psychological Science: Opportunities, Practical Considerations, and Challenges," *Perspectives on Psychological Science* 11, no. 6 (2016): 838–854.
- 274 Malgorzata Turalska and Bruce J. West, "Fractional Dynamics of Individuals in Complex Networks," *Frontiers in Physics* 6 (2018).
- 275 Shan Jiang, Yingxiang Yang, Siddharth Gupta, Daniele Veneziano, Shounak Athavale, and Marta C. González, "The TimeGeo Modeling Framework for Urban Mobility Without Travel Surveys," *Proceedings of the National Academy of Sciences* 113, no. 37 (2016).
- 276 Pål Sundsøy, "Measuring Patterns of Human Behavior Through Large-Scale Mobile Phone Data: Big Data for Social Sciences," PhD thesis, University of Oslo (2017).
- 277 Justin Cranshaw, Raz Schwartz, Jason Hong, and Norman Sadeh, "The Livelihoods Project: Utilizing Social Media to Understand the Dynamics of a City," *Proceedings of the Sixth International AAAI Conference on Weblogs and Social Media* 6, no. 1 (2012).
- 278 Samiul Hasan, Xianyuan Zhan, and Satish V. Ukkusuri, "Understanding Urban Human Activity and Mobility Patterns Using Large-Scale Location-Based Data From Online Social Media," *Proceedings of the 2nd ACM SIGKDD International Workshop on Urban Computing* (2013).
- 279 Andrea Dennis, "Mass Surveillance and Black Legal History," *American Constitution Society Blog*, February 18, 2020, <https://www.acslaw.org/expertforum/mass-surveillance-and-black-legal-history/>.
- 280 Sidney Fussell, "How Surveillance Has Always Reinforced Racism," *Wired*, June 19, 2020, <https://www.wired.com/story/how-surveillance-reinforced-racism/>.
- 281 Alice Speri, "The FBI Spends a Lot of Time Spying on Black Americans," *The Intercept*, October 29, 2019, <https://theintercept.com/2019/10/29/fbi-surveillance-black-activists/>.
- 282 Nicol Turner Lee and Caitlin Chin, "Police Surveillance and Facial Recognition: Why Data Privacy is Imperative for Communities of Color," *Brookings*, April 12, 2022, <https://www.brookings.edu/research/police-surveillance-and-facial-recognition-why-data-privacy-is-an-imperative-for-communities-of-color/>.
- 283 Maia J. Boyd, Jamar L. Sullivan Jr., Marshini Chetty, and Blase Ur, "Understanding the Security and Privacy Advice Given to Black Lives Matter Protesters," *Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems* (2021).
- 284 Steven Feldstein, "China's High-Tech Surveillance Drives Oppression of Uyghurs," *Bulletin of the Atomic Scientists*, October 27, 2022.
- 285 Chris Buckley and Paul Mozur, "How China Uses High-Tech Surveillance to Subdue Minorities," *The New York Times*, May 22, 2019, <https://www.nytimes.com/2019/05/22/world/asia/china-surveillance-xinjiang.html>.
- 286 Johana Bhuiyan, "'There's Cameras Everywhere': Testimonies Detail Far-Reaching Surveillance of Uyghurs in China," *The Guardian*, September 30, 2021, <https://www.theguardian.com/world/2021/sep/30/uyghur-tribunal-testimony->

surveillance-china.

- 287 Omar Shakir and Maya Wang, “Mass Surveillance Fuels Oppression of Uyghurs and Palestinians,” *Al Jazeera*, November 24, 2021, <https://www.aljazeera.com/opinions/2021/11/24/mass-surveillance-fuels-oppression-of-uyghurs-and-palestinians>.
- 288 Raphael Satter, “U.S. Court: Mass Surveillance Program Exposed by Snowden Was Illegal,” *Reuters*, September 2, 2020, <https://www.reuters.com/article/us-usa-nsa-spying/u-s-court-mass-surveillance-program-exposed-by-snowden-was-illegal-idUSKBN25T3CK>.
- 289 John Feng, “How China’s Social Credit System Works,” *Newsweek*, December 22, 2022, <https://www.newsweek.com/china-social-credit-system-works-explained-1768726>.
- 290 Severin Engelmann, Mo Chen, Felix Fischer, Ching-yu Kao, and Jens Grossklags. “Clear Sanctions, Vague Rewards: How China’s Social Credit System Currently Defines ‘Good’ and ‘Bad’ Behavior,” *Proceedings of the Conference on Fairness, Accountability, and Transparency* (2019): 69–78.
- 291 Jon Fingas, “Chinese Facial Recognition System Confuses Bus Ad With a Jaywalker,” *Engadget*, November 22, 2018, <https://www.engadget.com/2018-11-22-chinese-facial-recognition-confuses-bus-ad-with-jaywalker.html>.
- 292 Tara Matthews, Kathleen O’Leary, Anna Turner, Manya Sleeper, Jill Palzkill Woelfer, Martin Shelton, Cori Manthorne, Elizabeth F. Churchill, and Sunny Consolvo. “Stories From Survivors: Privacy & Security Practices When Coping with Intimate Partner Abuse,” *Proceedings of the 2017 CHI Conference on Human Factors in Computing Systems* (2017).
- 293 Chatterjee et al., “The Spyware Used in Intimate Partner Violence.
- 294 Emily Tseng, Rosanna Bellini, Nora McDonald, Matan Danos, Rachel Greenstadt, Damon McCoy, Nicola Dell, and Thomas Ristenpart, “The Tools and Tactics Used in Intimate Partner Surveillance: An Analysis of Online Infidelity Forums,” *Proceedings of the 29th USENIX Security Symposium* (2020).
- 295 Emily Tseng, Diana Freed, Kristen Engel, Thomas Ristenpart, and Nicola Dell, “A Digital Safety Dilemma: Analysis of Computer-Mediated Computer Security Interventions for Intimate Partner Violence during COVID-19,” *Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems* (2021).
- 296 Ronan Farrow, “How Democracies Spy on Their Citizens,” *The New Yorker*, April 18, 2022, <https://www.newyorker.com/magazine/2022/04/25/how-democracies-spy-on-their-citizens>.
- 297 Pegg and Cutler, “What is Pegasus Spyware and How Does It Hack Phones?”
- 298 Jon Fingas, “Pegasus Spyware Found on Phones of Mexican President’s Close Ally,” *Engadget*, May 24, 2023, <https://www.engadget.com/pegasus-spyware-found-on-phones-of-mexican-presidents-close-ally-154511274.html>.
- 299 Rob Pegoraro, “Tech Companies Are Quietly Phasing Out a Major Privacy Safeguard,” *The Atlantic*, September 29, 2019, <https://www.theatlantic.com/technology/archive/2019/09/what-happened-transparency-reports/599035/>.

CHAPTER 7

Interference

Travis D. Breaux, CIPT¹

Interference is an act that prevents or obstructs a process from continuing or being carried out properly.² For individual privacy, interference can be informed by Samuel Warren and Louis Brandeis' privacy right "to be let alone" and Alan Westin's notions of solitude and reserve, wherein an individual's preference not to be bothered includes avoiding outside interference from others. Interference can also be thought of as any disruption of individual autonomy.³ Surveillance and tracking technologies, such as those described in chapter 6,

enable interference because they provide access to the individual's physical person as well as to information about the individual's behaviors and preferences. Society's need to protect itself from nefarious individuals sometimes justifies the use of surveillance and tracking technologies. Machine learning (ML), which is discussed in chapter 8, is increasingly a source of interference when a person is characterized in a way that shapes what information and opportunities they have access to. Surveillance, tracking, and ML are all used by businesses that need to create accurate information models about individuals to ensure routine and reliable business activities. However, the risk of interference for individuals increases with the amount of information collected and maintained. Example activities include an individual's ability to use health care, transportation, and banking services; to earn a living wage by finding employment; or to exercise a vote in a democratic society. These activities rely on establishing a person's identity and authorization to use services or perform actions, for example establishing that a person is licensed to drive, is creditworthy, or is not a criminal felon. If an error exists in a person's data, such as a credit report, or if a person is incorrectly placed on a "no-fly" list, they would suffer from interference with their private matters. In this chapter, we begin by introducing interference in the context of current legal views, definitions, and privacy harms. Afterward, we examine interference from different technological perspectives, such as spam, software application programming interfaces (APIs), behavioral advertising, cyberbullying, social engineering, and, finally, remote desktop administration. We conclude with lessons the information technology (IT) professional may use in the context of their professional responsibilities.

7.1 Framework for Understanding Interference

Unlike ensuring an IT system keeps personal information confidential, which is often achievable with cryptographic systems such as those described in chapter 3, interference is a threat to privacy that can result from a sequence of steps in an IT system. Some of these steps may be innocuous, such as collecting a person's zip code, whereas other steps are more prone to error, such as drawing conclusions about someone based on their purchase history.⁴ Other actions can lead to a process obstruction or unwanted attention, such as sending advertising to a person based on an attribute inferred from their data.

Whether an inferred attribute is accurate or not does not lessen the perception of the intrusion, often referred to as "creepiness."⁵ From the perspective of a business, sending an advertisement based on correlations from behavioral data may have almost no downside. If the correlations are accurate, then the individual may be more inclined to make a purchase. If not, the business is simply out the cost of one advertisement. However, from the perspective of the consumer, the downside risk is much greater. Whether the ad is welcome or unwelcome often depends on the person's privacy preferences. For some pregnant women, advertising can introduce them to products that increase daily comfort. For others who wish to control the time, location, and circumstances around revealing pregnancy, their status is a

private family matter. In the second case, advertising can interfere with a pregnant woman's personal matters by circumventing her ability to control access to her personal information.

In this chapter, we introduce a framework that classifies three general types of interference by the object that IT interferes with, whether that object is a decision, a personal feeling, or a social engagement. The three types borrow heavily from the work by Daniel Solove and William Prosser, which we discuss.

1. Obstruction or decisional interference: Any action to interfere with decisions that affect the person's daily life, such as whether to allow them to travel, borrow money, or obtain lawful employment. This form of interference is often difficult to detect as it can be concealed in complex business or IT processes. Consequently, this form may not be easily recognizable by the person about whom the decision is made, as they may be unaware of the decision-making process or the decision itself may be hidden from them.
2. Intrusion into physical, psychological, or informational spaces: Any action that affects a person's solitude, including their desire to be alone or to be among a few chosen confidantes, and their desire to control who has access to their visual and thoughtful attention or their information. Such actions include searches of private spaces, curfews or other restrictions of movement, and alerts and notifications that grab and divert the attention of the person. While these actions may constitute objective harms under Ryan Calo's classification in "The Boundaries of Privacy Harm," the act of surveillance is a psychological intrusion and subjective harm, because it can affect whether people feel comfortable behaving as they would without persistent monitoring.⁶
3. Interference with representation of self: Any action that alters how an individual is represented, such as a person's marriage, financial, or employment status; race, gender, or sexual orientation; political views; or any other affinity toward specific ideas or social groups. Regardless of whether the representation is accurate or a misrepresentation, individuals may wish to control access to the representation to avoid unwanted attention.

The act of interference may be direct or indirect. In direct interference, the person whose privacy is most affected is involved in the interference, and thus they may have an opportunity to recognize or challenge the decision. In indirect interference, however, the effects of the interference may occur separately from the interference act. Type 1 interference can be indirect if the decision occurs without directly involving the person, such as with a decision of creditworthiness. Type 2 interference can be direct, if the act interacts with the person's physical, psychological, or informational space, such as by sending a person unwanted notifications on their phone.

The three types of interference are not orthogonal or independent of one another. Intrusion can influence obstruction. For example, surveillance of a person’s movement can interfere with that person’s feeling of oppression and thus affect their decision about whether to meet their counterparts. Assumptions about the same person’s associations that lead to a negative representation of them may be used to interfere with their movement, for example by prompting the person to take a different path or by detaining the person for questioning. Lastly, misrepresentation can influence obstruction. If a person is misrepresented as a convicted felon, that person may be denied certain types of employment, which is a decision made by a prospective employer.

The three types of interference are based on privacy scholarship, which lends credibility to their application in IT. William Prosser, a scholar on tort law, codified specific types of interference from hundreds of civil privacy cases in his law review article titled “Privacy.”² This analysis resulted in four distinct torts that appear in Table 7-1. In 2002, Daniel Solove expanded upon Prosser’s torts in his own taxonomy of privacy harms. We compare Prosser’s and Solove’s categories in Table 7-1.⁸

Table 7-1: Comparing Prosser’s and Solove’s classifications of interference-related privacy acts

William Prosser’s Four Kinds of Torts	Daniel Solove’s Taxonomy of Privacy
Intrusion upon seclusion or solitude	Intrusion, decisional interference
Public disclosure of private facts	Breach of confidentiality, disclosure, exposure, increased accessibility
Presentation of an individual in a false light	Distortion
Use of an individual’s name or likeness without permission	Appropriation

Solove’s taxonomy distinguishes between different categories of intrusion and information disclosure, which results in multiple categories mapping to a single tort in Prosser’s view on privacy. For example, intrusion is recategorized into two forms of invasion: decisional interference, which includes acts by a person to insert themselves into a decision-making process about another individual, and intrusion, which includes acts that disrupt a person’s physical or psychological sense of solitude.² We adopted this distinction separately in our framework Types 1 and 2, respectively. Solove further refines public disclosure of private facts through various means: Breach of confidentiality is a broken promise to keep facts private, disclosure is revealing private facts to yield negative consequences, exposure is a revelation resulting from revealing private facts, and increased accessibility results when otherwise obscure or hard-to-access public information becomes easier to access due to more pervasive collection, distribution, and retention practices. We narrowly consider the second tort and corresponding taxonomic categories as they relate to interfering to obtain a person’s private information under Type 2. Whereas these four taxonomic categories are about revealing private facts, the activities of disclosure can also lead to factual inaccuracies

about a person, which Solove labels distortion. Lastly, the intentional use of a person’s likeness without permission is called appropriation. We consider the last three torts narrowly as they relate to interfering with a person’s self-representation. While Solove appropriately distinguishes the subtleties between these categories, the result is similar for an IT professional: Interference can affect how a person is perceived.

The challenge for IT professionals is that technology does not inherently interfere with individual privacy, and the technological advantages to the individual may outweigh the harms. Telemarketing calls may be welcome or unwanted depending on the person’s privacy preferences. Creditworthiness allows the institutions of banking to make better decisions, which makes it easier for higher-risk individuals to obtain loans or make use of bank accounts for safeguarding money. Similarly, public safety in aviation depends upon prohibiting dangerous individuals from boarding aircraft. In situations where the risk exceeds the harm, we recommend IT professionals use a risk strategy to identify specific harms and use appropriate privacy controls to avoid, transfer, or mitigate those risks. Furthermore, after discussing real-world scenarios where interference occurred, we discuss several recommendations IT professionals may use to specifically evaluate how any technology may contribute to interference.

7.2 Interference from a Technology Perspective

In this section, we examine different technological perspectives on interference with user or consumer privacy concerns. Table 7-2 summarizes the perspectives and how they illustrate the three types of interference in different situations and under different technologies. First, we quickly review the familiar situation of unwanted messages. Then we explore how software APIs can enable access to personal data and result in unwanted disclosure and exposure. Behavioral profiling, the next topic, leads to building complex representations of a person based on surveilling their behavior and then using these profiles to make decisions about them or to personalize their experiences. Like unwanted disclosure and exposure, cyberbullying often requires exposing a person’s private details or recharacterizing the person beyond their control. Next, we illustrate how social engineering directly interferes in security processes to gain control of a person’s online persona. Finally, we conclude by briefly discussing how administrative activities that manage IT systems can intrude on personal privacy.

Table 7-2: Technology perspectives and their classifications in the interference framework

Technology topic	Type 1:obstruction	Type 2: intrusion	Type 3: self-representation
Unwanted messaging		✓	
Software APIs		✓	✓
Behavioral profiling	✓	✓	✓

Content filtering		✓	✓
Administrative decisions	✓	✓	✓
Cyberbullying		✓	✓
Disinformation	✓	✓	✓
Social engineering	✓		✓
Administrative intrusions	✓	✓	

As we examine these cases, consider the following questions: How do companies learn about interference? Where does it come from? How does interference affect individuals? What can be done to prevent, mitigate or respond to interference? What are the differences between an action that causes interference and a failure to act to prevent interference?

7.2.1. Notifications, Unsolicited Messages, and Spam

Frequent notifications and unsolicited messages, also called “spam,” can be used to capture an individual’s attention for advertising or other purposes. Spam is often restricted to email, but, increasingly, unwanted messages can be sent using other means, such as mobile or wearable app notifications and Short Message Service (SMS) texts. Spam is estimated to be roughly 78% of the total volume of email sent, and it has grown into a serious security and economic threat.¹⁰ In 2003, the United States passed the Controlling the Assault of Non-Solicited Pornography and Marketing (CAN-SPAM) Act in an effort to regulate spammers, and the U.S. Federal Trade Commission (FTC) implemented the act by providing guidelines for businesses that include offering individuals the opportunity to opt out.¹¹ Spam is often not directed at one specific individual any more than another individual, and response rates to spam are often extremely low compared with other forms of advertising. Under the CAN-SPAM Act, companies are required to provide one-click access within commercial bulk email messages to unsubscribe from mailing lists and future bulk messages. The link to unsubscribe must be prominently displayed, and the receiving website must quickly allow the user to unsubscribe. This means the receiving website cannot require collecting additional information from the user, nor can it create obstacles to unsubscribing, such as requiring the creation of user accounts. Under other jurisdictions, such as Europe, companies must first obtain individual consent before sending marketing messages. This is called opt-in consent. Thus, organizations often collect a person’s residency status in Europe to determine which mechanism must be applied to such communications.

Unwanted messages generally fall under Type 2 interference as an intrusion into psychological spaces. Depending on the type of message and time of day, the interference can affect individuals differently. Unwanted email is generally easy to filter using Bayesian algorithms, which use statistical and probabilistic approaches to classify likely spam messages based on keywords and email headers. Email users often customize Bayesian approaches to ensure a low false positive rate so desirable messages are delivered. Unwanted

app notifications and SMS texts, however, are more intimate, as they arrive on a person's cell phone or wearable device, which are typically used to receive personal calls or check the time of day. By employing the appropriate opt-in or opt-out mechanism, companies can communicate more effectively with potential customers, while affording these individuals with controls over unwanted interference.

7.2.2 Exposing Personal Data through Software APIs

In early February 2012, a social networking app called Path made newspaper and blog headlines for interfering with user control over their contacts. Path was a social network built primarily through mobile phone apps on iPhone and Android devices.¹² Path focused on photo sharing and competed with the Instagram network, which is owned by Meta. A programmer from Singapore named Arun Thampi discovered the interference while creating a social networking app using the Path API.¹³ He began investigating the Path API while using a man-in-the-middle proxy tool to examine specific API calls and learn how the calls operate.¹⁴ As Arun stated on his blog:¹⁵

*Upon inspecting closer, I noticed that my **entire address book (including full names, emails and phone numbers)** was being sent as a plist to Path. Now I don't remember having given permission to Path to access my address book and send its contents to its servers, so I created a completely new 'Path' and repeated the experiment and I got the same result—my address book was in Path's hands. [Emphasis in original.]*

Thampi discovered users signing up with Path would have their mobile address book copied to Path's servers without notification. Users responded to Thampi's discovery quickly. Many left negative reviews on Apple's App Store. The technical press picked up the story, and it eventually spread to larger media outlets like *USA Today* and *The New York Times*.¹⁶ Dave Morin, the CEO and Cofounder of Path as well as an early employee at Facebook, responded to Thampi's blog post by saying, in part, "We upload the address book to our servers in order to help the user find and connect to their friends and family on Path quickly and efficiently as well as to notify them when friends and family join Path." Eventually, Morin also apologized at length on Path's company blog:

*We believe you should have control when it comes to sharing your personal information. We also believe that actions speak louder than words. So, as a clear signal of our commitment to your privacy, **we've deleted the entire collection of user uploaded contact information from our servers.** Your trust matters to us and we want you to feel completely in control of your information on Path. [Emphasis in original.]*

Path's privacy violation is strikingly similar to the 2010 violation by Google Buzz, which is a different social networking service.¹⁷ Google users were invited to "Try Buzz in Gmail." Those who accepted the invitation, found Buzz had automatically begun following Google users contained in the invitee's Gmail contacts, which were also made publicly available for

others to see. Like Google Buzz, Path wanted users to connect conveniently with friends on their network. To that end, both Google and Path used contact information that was originally collected for one purpose, private emails and phone calls, for another secondary purpose, bootstrapping social network relationships. Users formally complained about Google Buzz to the FTC, which found Google had used deceptive business practices. As a part of the settlement, Google was required to have third-party companies audit its privacy practices for the next 20 years.

Consider one important difference between Google Buzz's and Path's uses of address book information: Who was responsible for the interference? Since Google maintained copies of both the contacts and the app that used them for the secondary purpose, the Google Buzz violation is rather clear. However, the other case is not as simple. Path obviously created the app and infrastructure to upload users' contact information. However, as a part of Apple's App Store policies, Apple claims to verify that third-party apps meet their standards. Apple is also responsible for providing the API platform that enabled Path programmers to gain access to the user's contact list. It is reasonable to say both companies, Apple and Path, share the responsibility for this interference and are exposed to litigation risks.

The FTC has received multiple complaints regarding mobile access to contact lists. A class-action lawsuit was filed against more than a dozen mobile app makers, including Path and Apple, for their use of address book information without user consent.¹⁸ At the time of this writing, the outcome of this lawsuit has not been decided. However, based on newspaper accounts of the situation, Path appears to have violated the first three Fair Information Practice Principles (FIPPs) recommended by the FTC: notice/awareness, choice/consent, and access/participation.¹⁹ Users were not aware of the collection, they were not provided a choice regarding whether they would like to share their contacts when they started using Path, and they were not given appropriate access to all the information Path obtained about them. Each of these points has since been addressed as a part of the API calls that allow third-party developers to access address book information on Apple's iOS.²⁰

While the Google Buzz and Path cases both illustrate a privacy violation, technologies that mine email inboxes and contact lists to populate social networking sites are available in ways that conform to the FIPPs. For example, Facebook and LinkedIn both use technologies in which the user chooses whether to mine their contacts to expand their network. By offering a choice, these IT systems allow users to decide whether the advantage of easily improving their social networking experience through automated contact population is valued over the risk of exposing their personal information to unwanted contacts. Moreover, other safeguards could be used to ensure these services do not exceed their intended purposes, including controls in the software to ensure the service does not collect complementary information, such as the dates, subjects, or contents of email messages or dates when calls were placed on mobile phones. Organizations that provide APIs to access their users' data should consider

introducing purpose-based access controls, while organizations that use third-party APIs to collect user data should consider filtering that data to avoid over collection.

7.2.3 Behavioral Advertising as Decisional Interference

Electronic commerce on the internet often depends on advertising-based revenue models. The FTC reported to Congress that internet advertising revenues for 1996 totaled USD301 million.²¹ Only five years later, in 2001, internet advertising revenues rose to USD7.2 billion. By 2007, this number rose to USD21.2 billion a year, with search-based advertising from companies like Google and Yahoo comprising 41% of that total.²² In 2018, advertising revenues surpassed USD100 billion for the first time, reaching USD189.3 billion in 2021, with USD135 billion on mobile devices that did not exist in 2007.²³ Advertisers spend billions of dollars every year on advertising, and, increasingly, they aim to target ads at users whose behavior indicates they are more likely to purchase the products.²⁴ This can be a win for consumers and for advertisers: Consumers hear about new products that improve the quality of their lives, while advertisers are able to spread the word about their products more efficiently.

However, behavioral advertising technologies can raise concerns about interference. The FTC stated some uses of behavioral advertising interfere with consumer expectations of privacy.²⁵ Government interest in protecting consumers from unfair interference has continued since those reports. In 2007 and 2009, the FTC issued separate documents with guidelines for balancing consumer interests with those of advertisers, both of which were based on discussions held by the FTC prior to release.²⁶ Unfortunately, the difficulty of estimating the value of privacy hampers efforts to balance economic interests with individual privacy expectations.²⁷ An empirical study on the effectiveness of behavioral advertising reported it could improve advertising effectiveness by at least 670%.²⁸ This is a powerful economic motivator for advertising companies, and it resulted in scrutiny from the FTC, U.S. Senate, and U.S. House of Representatives.²⁹

Early internet advertising consisted primarily of static banner ads placed on sites thought to have visitors who would be interested in the advertised products. Google's Gmail popularized contextual advertising, which leverages user-provided content to deliver ads. Contextual advertising uses an algorithm to examine the content of a page and determine which ad is most relevant to that content. If you were reading an email on Gmail about genealogy, you might be served an advertisement for genealogy software. Behavioral advertising works differently, by constructing a longitudinal profile of an individual's interests and serving ads based on that profile, rather than the content on the page. For example, a NASCAR fan might spend considerable time online reading about the latest NASCAR news, following the races, and reading personal biographies of the drivers. Behavioral advertising would detect this trend and select ads based on auto-sports

advertising across other websites, even when the user was not browsing sites related to that topic.

There are two approaches to behavioral advertising: first party and third party. In first-party behavioral advertising, the party with which the user-initiated communication is also the party collecting user behavior to create the profile. There are many approaches to first-party behavioral advertising, and not all of them involve sophisticated technology.³⁰ Amazon.com's recommendation service illustrates first-party behavioral advertising.³¹ Amazon monitors which products a user views before making a purchase, and its site recommends similar products to users who have demonstrated interest in related products. The assumption is that similar behavioral profiles will be interested in similar products, or that some products complement each other. Direct access to customer behavior and purchasing decisions is only possible in first-party behavioral advertising systems.³²

In third-party behavioral advertising, the ad is delivered by a party different from the party with which the user initiates the communication. Websites regularly partner with third-party advertisers to support their website's business. Third parties may work with numerous first-party websites, collecting user profile data across multiple types of sites, such as news, weather, entertainment, and travel websites, and delivering ads to users as they surf from one website to another. For effective third-party behavioral advertisers, the accuracy and relevance of the ads is assumed to improve as the number of websites a third-party advertiser works with increases.³³ Behavioral advertising has also been shown to be more effective over short sessions than over long-term profiles.³⁴

Advertisers using third-party behavioral advertising can use one of two techniques to construct behavioral profiles: web-based profiling and network-based profiling. Web-based profiling uses browser-based technology to track users as they surf the internet. This technique can only collect information on websites the advertiser has partnered with. Network-based profiling provides more access to user behavior by partnering with internet service providers (ISPs) that provide users with connectivity to the internet. With this level of access and deep packet inspection (DPI), these advertisers can create behavior profiles based on a user's network traffic. Network-based behavioral advertising provides ISPs with an additional revenue source to improve the quality of their infrastructure, but it poses the most serious risk of interference because of the exceptional level of access to user data.³⁵ Browser plug-ins that users may employ to obstruct behavioral advertisers from monitoring their website-usage behavior are ineffective against network-based behavioral advertising. End-to-end encryption can be used to conceal the content of messages, but often not the original headers needed to route the information across the network.

When customers are aware of behavioral profiles and have control over them, behavioral advertising can be mutually beneficial. Consider Amazon's recommendation service. Users often appreciate that they are introduced to products relevant to their interests.³⁶ Behavioral profiles can be used in numerous ways to personalize consumer experiences. For example,

someone interested in true crime dramas may want product lists for television shows and fiction books to display those options more prominently. Personalization is explicitly not advertising. Individuals who sign up for Netflix or a similar television- and movie-streaming service may want their behavioral profile to influence the displayed options simply for convenience and usability. Consider personalized web search engines that consider the types of searches previously performed and the types of links the user found useful. Some users may find such an engine far more efficient for their needs, if the personalized search results more effectively address what they are looking for. These personalized services require the construction and maintenance of at least a minimal behavioral profile, even if it is as simple as grouping individuals into broad consumer groups or market segments.

The existence of behavior profiles requires responsible organizations to follow safe privacy practices. If organizations maintain but never use the behavior profiles they create, they should still notify users that the profiles exist, explain the purpose of the profiles to the users, and seek consent while providing users an opportunity to participate. The mere existence of a behavioral profile may constitute a subjective privacy harm under Calo's taxonomy.³⁷ When users are unaware that they are being profiled and have no control over it, many become concerned. In May 2008, Charter Communications, a U.S. internet service provider, partnered with NebuAd, a behavioral advertising company, to create network-based behavioral profiles and serve ads to customers. Unfortunately, customers were mostly unaware of the program, and those who were aware complained to U.S. Congress, which held hearings regarding the use of the technology. Although the hearings themselves did not directly result in damages, NebuAd lost its ISP partners, and the company eventually stopped developing behavioral advertising technologies.³⁸

The 2008 U.S. congressional hearings on behavioral advertising technologies did not result in specific legislation. However, advertising has historically been the subject of extensive regulation designed for consumer protection.³⁹ It is worth noting the European regulation of behavioral advertising technologies has decreased consumer satisfaction with purchasing decisions based on advertising.⁴⁰ Losses in advertising effectiveness adversely affect smaller businesses that do not have the resources for larger, traditional advertising campaigns to promote their innovations.⁴¹

Behavioral advertising is regulated differently depending on the jurisdiction. In 2008, Richard Clayton from the University of Cambridge posted an analysis of Phorm's Webwise system, which tracks user behavior for the purpose of serving ads.⁴² He argued Phorm's system violated the U.K. Regulation of Investigatory Powers Act of 2000, which makes interception of electronic communications illegal. Phorm's system intercepted communications using DPI and altered the way ads were served to users. For this system to work, Phorm needed to partner with ISPs willing to provide access to their infrastructure and allow the modification of in-flight communications. In the United Kingdom, its partner was

British Telecom, which eventually dropped Phorm as a partner because of the privacy concerns raised.⁴³

Behavioral advertising technologies have been shown to be effective. What lessons can we learn from an examination of them? Amazon's success may suggest providing users control over how they are tracked is more acceptable than network-based approaches to behavioral advertising, such as those used by Phorm and NebuAd. In addition, behavioral advertising is a unique combination of interference-prone technologies: the behavioral model, which aims to represent who the person is (Type 2), thus enabling decision-making (Type 1), sending the personalized ad that describes this person's behavior, revealing that behavior to others who see the ad, and thus exposing this person to intrusions on their self-representation (Type 3). As more behavioral data became available for processing, new statistical analysis techniques proved capable of capturing and modeling ever more nuanced correlations based on this data. These methods, called ML methods, also often capture and model latent or explicit biases in the data they are provided.

7.2.4 Content Filtering and Recommendations

Apps are increasing the use of content filtering and personalization to tailor user experiences to increase engagement with apps or to better support an individual's preferences and needs. This includes recognizing return shoppers by name, managing lists of recommended products in online stores, or recommending music based on a user's playlists. Behavioral advertising, described in the previous section, is built on the same philosophy that filtering content to fit an individual's personal attributes yields improved outcomes.

In a landmark study of manipulating social media feeds, researchers at Facebook conducted an experiment aimed at increasing user engagement with the social media platform.⁴⁴ Using a technology called sentiment analysis, the researchers were able to label Facebook user posts as primarily relaying either positive or negative emotions. Users were assigned to one of three groups in the experiment: users in group one were shown their regular feed of posts, except 10% of posts relaying negative emotions were removed; in group two users were shown the regular feed, except 10% of posts relaying positive emotions were removed; and in group three users were shown the regular feed of posts with no manipulation. The researchers then measured the overall positivity or negativity of posts made by users assigned to each of the three groups. The results found users assigned to group two, where the feed was biased toward posts relaying negative emotions, were more likely to post messages relaying negative emotions. The same effect of "emotional contagion" was less pronounced in users assigned to group one, where users were more likely to see posts relaying positive emotions. The research also found users in group three were less likely to engage by posting messages than users in groups one and two. These findings demonstrate how content filtering can be used to manipulate the emotional state of users, which we describe as a Type 2 interference.

Different technologies can be used to filter and recommend content. For example, ML can predict labels for content, and those labels can be used to direct labeled content to some users but not others. For example, sentiment analysis algorithms work by automatically labeling text based on whether words in the text have a positive or negative sentiment, as predicted using lists of prelabeled words. Models can also be used to label people or objects in images, for example, by labeling a person's race, age, or gender.⁴⁵ Models can also be trained to predict correlations between information, such as correlations among different products that are frequently purchased together.

7.2.5 Administrative Decision-Making

ML systems based on statistical analyses of large amounts of data are nearly ubiquitous and almost unavoidable.⁴⁶ These systems are becoming crucial in a wide range of human endeavors, including credit scoring, financial trading, dispute resolution, search engines, recommendation systems, public health, medicine, policing, dating, political campaigns, and scientific discovery.⁴⁷ In practice, these systems are composed of models used to perform classification and prediction, which are created using an algorithm to train the model using examples of "ground truth," often based on historical observations.

ML systems can produce results that are uncannily accurate and undeniably useful. When they fail, however, explaining the how and why of a particular result from typical ML systems is extraordinarily difficult.⁴⁸ And, although ML systems can do surprisingly powerful things, such as beating *Jeopardy!* champions, they can also be biased.⁴⁹ For example, in 2013, Latanya Sweeney found personalized advertising from search engines differed depending on the ethnicity of a person's name being searched.⁵⁰ For example, searching for names like Latanya and Latisha resulted in advertising suggestive of arrest records and criminal activity, whereas names like Kristin and Jill did not. It is believed algorithms use ML to select which ads to present to search users. Sweeney suggests considering how search results like this might impact someone applying for a job, if their name is used in such a search.⁵¹ From the perspective of job applicants, this constitutes interference under both Type 1, because such a result could obstruct them from obtaining the job, and Type 2, because this result affects how they are perceived. Another example of ML impacting employment decisions includes Amazon's development of an ML model to predict which candidates would be the best hires among thousands of job applicants.⁵² The model was trained to predict the best hires using data from previously collected resumes and hiring decisions. After analyzing the results, it was discovered the model penalized women, specifically those whose resumes used the possessive noun "women's," such as in "women's chess club captain," and it downgraded applicants from two all-women's colleges. In addition, the algorithm rewarded resumes with male-gendered language, such as using the words "executed" or "captured." Bias and fairness in ML concerns when the data used to train a model includes bias, such as discriminatory

bias, and whether the decisions are unfair. This topic is further discussed in chapter 8 on ML and privacy.

The *Loomis v. Wisconsin* case demonstrates another important example.⁵³ Eric Loomis was arrested in February 2013 and eventually convicted of eluding the police.⁵⁴ During his sentencing, an algorithm called COMPAS was used to estimate the risk that Loomis would commit another crime.⁵⁵ Northpointe, Inc., the company that developed COMPAS, claimed that its system is backed by research but did not explain how it works. For the moment, consider that this algorithm could be built using an ML system. The input data could simply be historical rates of recidivism calculated using arrest records from the last several decades. Calculating a recidivism risk for someone like Loomis, a 34-year-old registered sex offender arrested for driving a car that was used in a shooting, would be relatively easy, but would it be fair? If bias exists in the data used to train the machine, such as bias about over policing minority neighborhoods or underenforcement of white-collar crimes, then recidivism rates will be similarly biased.⁵⁶ One could argue using historical records generated by an imperfect justice system with both known and implicit structural biases is patently unfair, and any resulting ML system would only serve to hide problems in the current justice system behind the authority of a computed result. This argument holds, despite the fact that the algorithm correctly predicts historical examples from the training data. In our classification, this could be representative of all three types of intrusion. Loomis claimed the use of a secret, proprietary algorithm violated his due process rights under the Fifth Amendment of the U.S. Constitution and appealed the case to the Supreme Court, where certiorari was denied.⁵⁷ For technologists building information systems, however, the question remains: What makes such ML systems fair?

Transparency is a tempting answer, but under examination it proves less useful than it might appear at first. Although transparency may make information accessible, that information may remain incomprehensible.⁵⁸ Also, transparency may simply provide too much data to examine manually, forcing either a direct evaluation by another algorithm or an indirect evaluation by comparing other approaches. Imagine Northpointe chose to release the data and algorithms used in COMPAS to make sentencing recommendations. Could Loomis be satisfied that he was treated fairly if there was so much data it could only be examined using another ML system? If the data was regularly updated, then would due process requirements for transparency force Northpointe to store each incremental update used? These are nontrivial questions to answer, and they are similar to problems with transparency in ML systems.

Bias and fairness in ML, including current definitions, trade-offs, and technical approaches to mediate this threat to privacy are discussed in chapter 8.

7.2.6 Cyberbullying as Interference with Personal Identity

Warren and Brandeis were originally inspired to write their law review article defining privacy as “the right to be let alone” by the invention of the snap camera, a then-new concept that allowed a photographer to quickly take a clear picture without requiring individuals to pose.⁵⁹ Today, such technology is common, and although it continues to enable interference with privacy, a culture has developed around the use of cameras that allows us to craft reasonably stable social policies to deal with violations. In this section, we examine modern privacy concerns involving real images captured from remotely accessible web cameras and fake images generated and used for malicious purposes.

On September 22, 2010, a freshman at Rutgers University named Tyler Clementi committed suicide.⁶⁰ Three days prior, his roommate Dharun Ravi and Ravi’s friend Molly Wei used a webcam to spy on Clementi to confirm Ravi’s suspicions that Clementi was gay. After recording Clementi with another man, Ravi posted the video and tweeted about the incident, stating, “Roommate asked for the room till midnight. I went into Molly’s room and turned on my webcam. I saw him making out with a dude. Yay.”⁶¹ Clementi read the tweet the next day and requested a room change. Ravi continued to spy on Clementi and invited Twitter followers to watch a second video.⁶² Shortly thereafter, Clementi killed himself.

Clementi’s suicide became an international news story about the seriousness of cyberbullying that was picked up by ABC News, CNN, *USA Today*, the BBC, and numerous other major media outlets. Ellen DeGeneres said Clementi was “outed as being gay on the internet, and he killed himself. Something must be done.”⁶³ Ravi and Wei were indicted on two charges of invasion of privacy, one for each spying incident. Ravi was additionally indicted on witness- and evidence-tampering charges. Wei reached a plea agreement for her testimony against Ravi, who was convicted and sentenced to a 30-day jail term.⁶⁴

In 2011, New Jersey enacted the Anti-Bullying Bill of Rights, which was prompted in part by Clementi’s suicide.⁶⁵ The Anti-Bullying Bill of Rights was designed to address concerns that Ravi’s trial and conviction were not adequate responses to his actions. In particular, it explicitly states students have a right not to be bullied and speech that “substantially disrupts or interferes with” a student’s rights is a violation of the law.⁶⁶ Although the law may be overly restrictive of speech, it is clearly based in the traditional definition of privacy as the right to be let alone.⁶⁷

IT enables a fundamentally different type of bullying: One that is no longer ephemeral or confined to the event or instance but instead persists and compounds as others gain access to participate through the use of IT communications. Researchers Alice Marwick and danah boyd have written extensively about youth culture and bullying. They note teenagers want to view themselves as “in control of their lives,” so they downplay the things they cannot control as mere drama when those things could be quite serious.⁶⁸ This was certainly true of Tyler Clementi. Shortly after Ravi tweeted about the first time he spied on Clementi kissing another man, Clementi spoke with Hannah Yang, a friend of his from high school.⁶⁹ When

Yang suggested the incident was a serious violation of Clementi's privacy, Clementi downplayed it.⁷⁰

Clementi's case demonstrates how devastating a personal privacy intrusion may be, but cyberbullying no longer requires physical access to an individual to violate their privacy. Fake content or interactions with fake users can constitute interference without any physical access, and intrusions based on fake content can affect millions of people at once because these interactions do not require physical access. While IT professionals may not be able to prevent users from cyberbullying, they can introduce mechanisms to reduce or thwart the effects of bullying by allowing users to report it and quickly responding to those reports. Planning in advance for cyberbullying through one's product or platform is a much stronger position than reacting later by downplaying the frequency or seriousness of an event or diminishing one's role as only the technology provider. In fact, section 230 of the U.S. Communications Decency Act (CDA) was explicitly designed to protect companies that take a proactive approach to addressing detrimental conduct on their platforms.⁷¹

7.2.7 Disinformation and Fake Representations

Disinformation is the intent to mislead by creating and disseminating false information. Fake product reviews are a common form of interference based on fake information.⁷² Consumers trust product reviews and rely on them when making purchasing decisions.⁷³ In "Born Unequal: A Study of the Helpfulness of User-Generated Product Reviews," Yue Pan and Jason Zhang describe in some detail what makes a product review helpful from the perspective of a consumer.⁷⁴ Nefarious actors can take advantage of this trust to create extremely effective fake product reviews and boost sales, whether they are the product creator, platform owner, or an entity in the middle of the supply chain. With public access to large language models (LLMs), such as ChatGPT and Bard, anyone with an internet connection can generate fake content on demand in any common language for a small cost.⁷⁵ In addition, LLMs are known to generate "hallucinations" or inaccurate responses. See chapter 8 for more information on AI and Privacy. There are concerns that AI generated content could even become the dominant form of content online.⁷⁶

This use of modern technology violates ethical norms that guided advertising in the decades prior to the internet's widespread adoption, and this sort of deception is precisely the kind of consumer protection the FTC was created to enforce.⁷⁷ To that end, the FTC has produced and updated disclosure guidelines for advertisers to ensure consumers are able to differentiate between legitimate user-generated content and paid or faked reviews.⁷⁸ The FTC also began bringing cases against companies purchasing fake reviews.⁷⁹ Fake product reviews intended to trick consumers into making purchases are examples of Type 1 violations.

Fake users present another increasingly common form of interference. The internet has always allowed people to create fake interactions, ranging from a single fake profile targeted to deceive a single person, called "catfishing," to whole armies of fake profiles designed to

change public opinion, called “sockpuppeting” or “astroturfing.” The rise of social media along with new, powerful artificial intelligence (AI) technologies, however, has made this much more efficient, effective, and dangerous.⁸⁰ Social bots can “mislead, exploit, and manipulate social media discourse with rumors, spam, malware, misinformation, slander, or even just noise.”⁸¹ Social bots have been used to stoke political unrest, manipulate the stock market, and systematically abuse women and minorities online.⁸² All these examples constitute interference. Surreptitious efforts to sway public opinion are inherently Type 1 violations because their goal is to affect decision-making. Other examples, particularly abusive examples, are Type 2 violations because they seek to intrude on or damage psychological or informational spaces. Social bots are increasingly difficult to distinguish from actual human users, and they can be used to capture one’s attention in ways paid ads cannot, thus new technologies are needed to detect this growing privacy threat.⁸³

Advances in AI and ML have allowed for the creation of realistic—but entirely fake—audio, video, and photographic content called “deepfakes.”⁸⁴ Supasorn Suwajanakorn et al. developed an early example of this technology by capturing President Obama’s speech patterns and lip syncing them to an arbitrary audio file using recurrent neural networks.⁸⁵ Their results produced a realistic video of President Obama saying something he never actually said.⁸⁶ Perhaps the first real-world intrusive use of this technology was the creation of pornographic videos using the faces of well-known celebrities. This technology is generalizable and may profoundly affect many areas of our lives, even threatening our national security or democracy itself.⁸⁷ In a related story, in February 2023, high school students at Carmel Central School District in New York State allegedly created deepfake videos in which a middle school principal appears to go on a 37-second tirade against Black people.⁸⁸ While the local sheriff’s department did not find evidence of a crime, and the school district reported safety was not compromised, the principal suffered a Type 3 violation, in which their representation of self was hijacked and used to advance racist threats against the middle school population.

Deepfakes present profound technical and social challenges. From a technical standpoint, the most effective means of detecting deepfakes uses the same technology that created them: neural networks.⁸⁹ This pits one AI system against another in a never-ending arms race of more realistic creation and more sophisticated detection. Detection is also only useful against some of the harms caused by deepfakes. For example, platforms that can detect a deepfake quickly can filter it out, exposing relatively few people and limiting the harm. This can be an extremely important tool for platforms. People acquire information from a wide variety of sources without easily verifying its accuracy, and people tend to share negative and novel information more readily than positive or unsurprising information.⁹⁰ Both these tendencies make compelling, realistic deepfakes extremely dangerous for society.

At the individual level, detection alone may be largely ineffective. Consider a recent app called DeepNude, which realistically removed woman’s clothes from online images using

generative adversarial networks.²¹ Although the dataset used to create this app was relatively small, it produced frighteningly realistic results. If a malicious actor simply wants to embarrass or threaten a particular woman, they do not necessarily need mass distribution, because simply providing the images to select individuals would suffice. A rape threat accompanied by realistic imagery may be more difficult for the victim.²² Worse, conclusively proving images are deepfakes to protect oneself in a court proceeding, to save an otherwise sabotaged relationship, or for any number of other reasons, may be more intrusive than the images themselves. Although these examples all focus on deepfakes, other convincingly faked individual content, such as faked handwriting, financial records, legal documents, and so on, may prove similarly challenging to address.

The technologies used to create social bots and deepfakes are also being developed by companies for legitimate business purposes. Companies now use chatbots to engage with customers for financial services, initial health care triage, technical support, customer service, scheduling, and legal services.²³ In 2011, Gartner predicted eventually 85% of online interactions with customers would be through chatbots.²⁴ At Google's I/O Developers Conference in 2018, Google introduced a voice assistant called Duplex developed using ML technologies that sounds remarkably similar to an actual human, even mimicking human interjections and nonlexical conversation sounds like, “mmhmm” and “uhh” to appear more realistic.²⁵ Initial reactions to this hyper-realistic voice indicated it was “scary as hell” and it had potential to further erode privacy.²⁶ More recently, Apple introduced a feature called “FaceTime Attention Correction” in a beta of iOS 13.²⁷ The goal of this feature is to make FaceTime calls feel more like actual face-to-face conversations by adjusting users' eyes, which are normally looking at the screen, to appear as if they were looking directly at the camera above the screen.²⁸ Initial reactions to this feature range from calling it “actually a huge improvement” to “overstepping a line of creepiness.”²⁹

The technical achievement and promise of social bots and ML technologies is impressive. They could, for example, eventually be used with augmented reality (AR) glasses to overlay driving directions directly onto the driver's field of vision.¹⁰⁰ However, cyberbullying and other malicious uses also seem to have unlimited potential. AR glasses could just as easily be developed to virtually undress women as they could be to help drivers. Intelligent assistant technologies designed to help with appointment scheduling, shopping for clothes, or assisting with banking could be used to gaslight, catfish, or scam unknowing victims at a scale only possible with modern computing platforms.

In this section, we observe how information collection, specifically surveillance, can be used to expose otherwise hidden details about an individual to a broader audience or to fabricate information about an individual to such an audience, in a Type 3 interference. In an earlier case, Path used an API to gain access to the user's contact list. This activity was a design decision implemented as part of the company's product offerings. In this section, however, we have a situation in which individuals use technology to interfere with the affairs

of other individuals with the intent to pressure those individuals. When these cases arise, they may use a company's products to disseminate the covertly collected or fake information. While companies may not be able to monitor all uses of their technology, they can include features that help good citizens report abuses that limit the overall impact of the interference. In addition, they can contractually obligate users to conform to a code of conduct that requires them to respect the privacy of other users and avoid using the technology in inappropriate ways.

7.2.8 Social Engineering and Interconnected Systems

On August 6, 2012, a hacker used security flaws at Amazon and Apple to compromise Mat Honan's digital identity.¹⁰¹ His Twitter account, Gmail account, Apple ID, and Amazon account all appeared to have been compromised.¹⁰² He first noticed his iPhone rebooting. Before he noticed he wasn't able to connect to his Google calendar, his laptop rebooted and started asking for a four-digit pin he hadn't set, and his iPad became inaccessible.¹⁰³ Meanwhile his Twitter account, which was connected to a company Twitter account, was tweeting racist and homophobic messages.¹⁰⁴ Honan initially believed his password had been cracked using a brute-force attack, because the password he used was only seven characters long and rather outdated.¹⁰⁵ Instead, the hacker claimed to have gained access to the Twitter account by exploiting two flaws in Apple's and Amazon's account recovery services.¹⁰⁶ First, the hacker called Amazon by phone to add a credit card to Honan's account. At the time, Amazon allowed any caller to add a credit card if they provided the customer's name, email address, and physical address, all of which were easily obtained. In addition, Amazon only required the last four digits of a credit card on file to change the email address on an account. Thus, the hacker called back a second time and used the last four digits of the credit card they had provided to reset the email address. Once the email address was changed to an account the hacker had access to, he was able to reset the Amazon password and view the account details.

With complete access to Honan's Amazon account, the hacker was able to see the last four digits of the Honan's credit card on file. He assumed this was the same card on file with Honan's Apple ID account, and he proceeded to use those digits to gain a temporary password for Honan's Apple ID account. Surprisingly, Apple reset the password despite the the hacker's inability to correctly answer the security questions Honan established for his Apple ID; this was a violation of Apple's policies.¹⁰⁷ Using Honan's Apple ID, the hacker was able to reset Honan's Twitter password and Gmail password through Honan's Apple-based email service. At this point, the hacker had control of the Twitter account, so he proceeded to remotely wipe Honan's various Apple products to prevent Honan from recovering access to the Twitter account.¹⁰⁸ To the credit of both Amazon and Apple, both companies remedied these security flaws after the story was published.¹⁰⁹ However, this section illustrates how social engineering tricks can be used to manipulate people and IT systems to gain access to a

person's information and, in this case, the Twitter accounts used to represent both Mat Honan and his company.

“Social engineering” is any means of using psychology to manipulate people to do something that divulges valuable information or provides access to valuable property. When combined with even rudimentary knowledge of technology, social engineering is a powerful technique attackers can use to interfere with user privacy. Kevin Mitnick is famous for extensively using social engineering techniques to access computers and avoid capture by the U.S. Federal Bureau of Investigation (FBI).¹¹⁰ Mitnick would prey on people who wanted to be helpful. Most folks find it hard to say no to someone in need. The employees at Amazon and Apple didn't know the hacker was not really Mat Honan, and the security measures required to prevent such an imposter were insufficient.

Malicious users can interfere with security processes to obtain access to another user's account and information. In Honan's case, social engineering was used to manipulate a human decision process in the customer service center to transfer the data needed to exploit an automated process to reset an account password. This form of interference was further used to gain access to a Twitter account, after which the malicious user made misrepresentations of the actual account holder. IT architects and other professionals should consider how their supported business processes, both human and machine-controlled, are vulnerable to exploitation by social engineering for conducting privacy attacks.

7.2.9 Administrative Intrusions into Personal Spaces

Organizations often use supervisors to ensure employees or other members of the organization conform to organizational practices and procedures. This can occur within workplaces, schools, and other environments affected by social and political power relationships. In 2010, the FBI investigated the Lower Merion School District in Pennsylvania for using webcams on school-issued laptops to spy on students at home.¹¹¹ School administrators ensured student laptops had installed software to allow them to remotely control the machine and ensure students were not violating school rules. Although breaking school rules is often less serious than committing a crime, students are usually not free to leave or choose a competing school as a customer might be in a traditional business environment. In most jurisdictions, education is compulsory for children of a certain age, and students are considered a protected population. Similarly, employees have rights at a workplace that may supersede an employer's right to monitor their actions.

For students at Lower Merion, this administrative monitoring extended outside the school environment because students were permitted to bring the laptops home. When an administrator claimed a student was involved in inappropriate behavior because they observed the student in their home, the presence of this monitoring came to light. Parents and students brought a class-action lawsuit against the school district that was eventually settled out of court.¹¹² The idea of creating software to ensure students do not misuse school-

issued equipment is compelling to school administrators.¹¹³ The challenge presented by mobile computing in these situations is companies or schools that issue property to their employees or students may think their policies may be extended to places where these devices can be carried.

Consider the 2010 U.S. Supreme Court decision in *City of Ontario v. Quon*, which concerned employee privacy rights in the use of employer-provided mobile communications technology.¹¹⁴ The police department for the Ontario, California purchased electronic pagers for officers in its special weapons and tactics (SWAT) unit. These pagers were covered by an internal policy document that allowed some limited personal use of the device. When Sergeant Jeff Quon exceeded his messaging limit several times, the police department obtained transcripts of his messages to determine whether his overages were work related. Many of Quon's messages were personal and sexually explicit in nature, and he was disciplined. Quon sued, claiming the monitoring was an interference with his privacy. Eventually, the Supreme Court decided the Ontario Police Department performed a work-related audit, and therefore it was not a violation of Quon's privacy.

While there are valid reasons for this kind of monitoring, for example protecting intellectual and physical property or auditing employee use of work-related equipment, as in the Quon case, organizations must assess the extent to which this kind of monitoring would interfere with the broader sense of privacy their employees or students would normally enjoy. No organization should be eager to find itself in a legal battle over administrative monitoring of employees, students, or other protected populations. Within our framework, administrative intrusions include encroaching on personal spaces (Type 2) and potentially decisional interference (Type 1), as the information obtained can be used to invoke policies that would otherwise govern the individual under the administration of their organization.

7.3 Summary of Lessons Learned and Recommended Actions

As noted in Table 7-2, each of the five cases illustrates different examples in which interference led to privacy harm. For IT professionals, the challenge is to design their systems and business practices in ways that can reduce the risk or negative outcome of privacy harms. In addition to following the FIPPs or another set of accepted privacy principles, we make the following recommendations based on our review of technological perspectives, while we note this list is by no means complete.

Recommendation 1: Acquire insight into the privacy preferences of individuals directly or indirectly impacted by your data practices. Focus groups, such as those discussed in chapter 2, can be used to survey users and understand how they view privacy under different scenarios. Focus groups can be conducted anonymously so the company's brand is protected, and the data can be used to avoid consumer churn that may result in gross

violations of privacy. In addition, consumer protection agencies, civil liberties groups and other nongovernmental organizations may be able to help define and codify privacy norms for the individuals in various jurisdictions. For example, in the United States, the FTC maintains extensive recommendations for data privacy practices.

Recommendation 2: If data collection can be used for any kind of interference, notify the individual about the purpose and, if possible or required by law, allow the individual to opt in or opt out. Data collection processes exist in virtually every organization, and the data collected by business processes can be extremely sensitive and valuable. In addition to limiting the uses of data to the original purposes for which it was collected, the organization should engage with the person to ensure uses are consistent with user preferences. In the second perspective, repurposing the contact list to provide new services was unwanted and could have been avoided for users who would not have opted in. Avoiding unnecessary reuse of sensitive information or asking for permission to use collected data for new purposes can reduce interference.

Recommendation 3: Before intruding into a person's private physical, psychological, or self-representative affairs, ensure the technology provides an opportunity for the person to control or limit the intrusion to appropriate times. When a technology is likely to engage with a person in a physical location, attempt to understand the consequences of that engagement. Is the person at work or attending an intimate event with family members? Understand how the engagement might affect the person emotionally. Would the engagement violate contextual integrity by expanding access to sensitive personal information?¹¹⁵ Finally, consider how the engagement can affect a person's self-image and recognize individuals control these personas by limiting who has access to different versions of themselves.

Recommendation 4: If data is used to make critical decisions that can deny individuals specific benefits, introduce safeguards to detect inaccuracies. Allow individuals to be aware of the decisions through notices and allow them opportunities to review the data for accuracy. Increasingly, decision-makers are finding novel ways to gain insight into people's behaviors. As we observed in the third perspective, data can be used to personalize services to individuals. Other examples of decision-making include financial and employment decisions, or decisions about granting access to private information. When data is inaccurate, such as with Mat Honan's altered email address at Amazon, the effects of automated decisions can be unpredictable and prone to violate a person's privacy. Even without explicitly inaccurate data, the data available may be biased. Using incarceration data in a ML system to produce sentencing recommendations could result in unfair outcomes if the law enforcement system that created the incarceration data were biased.

Recommendation 5: React quickly to customer concerns. Monitor customer reactions and events and take immediate action to reconcile unwanted interference. Path's reaction to customer complaints was swift and likely saved the company quite a bit of bad press.

Similarly, Amazon and Apple reacted quickly to change the policies that led to Mat Honan's hacking. Understand reacting quickly to customer concerns requires preparation and planning. Reading about these technological perspectives in retrospect can inform the planning required to ensure a company can quickly respond when a customer complains. Responding to a complaint reestablishes an individual's sense of control over the situation when that control is lost through interference.

Recommendation 6: Assume interference will occur, and plan for it. General-purpose technologies likely have both ethically good and ethically bad uses. No IT developer, designer, or organization can prevent all forms of privacy violations or security breaches. Therefore, it is critical to have a response plan in place and to practice implementing it. Conducting interference response drills can prepare a company for potential privacy violations caused by its products and improve awareness so it can understand how its existing policies and technologies help it respond to privacy threats.¹¹⁶ Consider the Tyler Clementi case. Ravi attempted to delete derogatory tweets and conversations. He was eventually convicted of evidence tampering. What policies and procedures needed to be put in place to ensure Ravi's actions were not irreversible? How should employees of the University of Cambridge, Twitter, and the other organizations involved ensure they can respond appropriately? Answering these questions requires planning and practice.

7.4 Summary

In this chapter, we described privacy, and thus interference, as an inherently individualistic social concern. We have also shown the nature of privacy is such that it is impossible to develop a finite list of clearly defined ways interference can occur. To address and mitigate interference, we discussed several technological perspectives and generalized from these situations to report actionable steps IT professionals can take. Because privacy is a social construct, however, no technological solution or mitigation indefinitely addresses interference concerns. Engineers must continually examine additional cases of interference, generalize new recommended practices they can adopt to address similar concerns in their products, and apply those recommendations diligently. By taking appropriate action, both engineers and lawyers can enable society to reap the benefits of IT, while limiting the dangers it presents to personal privacy.

Endnotes

1 Aaron Massey and Travis Breaux co-wrote the original chapter. Travis Breaux provided updates for this edition.

2 New Oxford American Dictionary, 3rd ed. (2010), s.v. "interference."

3 Samuel Warren and Louis Brandeis, "The Right to Privacy," *Harvard Law Review* 4, no. 5, (1890): 193–220; Alan Westin, *Privacy and Freedom*, (New York: Atheneum, 1967).

4 Charles Duhigg, "How Companies Learn Your Secrets," *The New York Times*, February 16, 2012. In 2010, the retail store chain Target began inferring when a woman was pregnant by her purchase of unscented lotions, special vitamins, and large tote bags, among other items.

- 5 Omer Tene and Jules Polonetsky, "A Theory of Creepy: Technology, Privacy and Shifting Social Norms," *Yale Journal of Law & Technology* 16, no. 59 (2013), <https://papers.ssrn.com/abstract=2326830>.
- 6 Ryan Calo, "The Boundaries of Privacy Harm," *Indiana Law Review* 86, no. 3 (2011).
- 7 William Prosser, "Privacy," *California Law Review* 48, no. 383 (1960).
- 8 Daniel J. Solove, *Understanding Privacy*, (Boston: Harvard University Press, 2008).
- 9 Solove, *Understanding Privacy*.
- 10 Dan Fletcher, "A Brief History of Spam," *Time*, November 2, 2009, <https://content.time.com/time/business/article/0,8599,1933796,00.html>.
- 11 "CAN-SPAM Act: A Compliance Guide for Business," Federal Trade Commission, updated January 2024, <https://www.ftc.gov/business-guidance/resources/can-spam-act-compliance-guide-business>.
- 12 Previously available at <https://path.com>. Path shut down in September 2018.
- 13 Arun Thampi, "Path Uploads Your Entire iPhone Address Book to its Servers," February 2012, <https://mclov.in/2012/02/08/path-uploads-your-entire-address-book-to-their-servers.html>.
- 14 Mitmproxy, accessed June 2024, <https://mitmproxy.org/>.
- 15 Thampi, "Path Uploads Your Entire iPhone Address Book."
- 16 Byron Acohido, "Apple Moves to Quell Path Privacy Gaffe," *USA Today*, February 16, 2012, <https://content.usatoday.com/communities/technologylive/post/2012/02/apple-moves-to-quell-path-privacy-gaff/1>; Nicole Perlroth and Nick Bilton, "Mobile Apps Take Data Without Permission," *The New York Times*, February 15, 2012, <https://bits.blogs.nytimes.com/2012/02/15/google-and-mobile-apps-take-data-books-without-permission/>.
- 17 "FTC Charges Deceptive Privacy Practices in Google's Rollout of Its Buzz Social Network," Federal Trade Commission, March 30, 2011, <https://www.ftc.gov/news-events/press-releases/2011/03/ftc-charges-deceptive-privacy-practices-googles-rollout-its-buzz>.
- 18 Elinor Mills, "Privacy Suit Filed Against Path, Twitter, Apple, Facebook, Others," *CNET News*, March 16, 2012, <https://www.cnet.com/news/privacy-suit-filed-against-path-twitter-apple-facebook-others/>.
- 19 *Privacy Online: A Report to Congress*, Federal Trade Commission, June 1998, <https://www.ftc.gov/sites/default/files/documents/reports/privacy-online-report-congress/priv-23a.pdf>.
- 20 John Paczkowski, "Apple: App Access to Contact Data Will Require Explicit User Permission," *All Things D*, February 15, 2012, <http://allthingsd.com/20120215/apple-app-access-to-contact-data-will-require-explicit-user-permission/>.
- 21 *Online Profiling: A Federal Trade Commission Report to Congress*, Federal Trade Commission, June 2000, <https://www.ftc.gov/reports/online-profiling-federal-trade-commission-report-congress-june-2000>.
- 22 *IAB Internet Advertising Revenue Report: 2001 Full Year Results*, PriceWaterhouseCoopers, June 2002, https://www.iab.com/wp-content/uploads/2015/05/resources_adrevenue_pdf_IAB_PWC_2001Q4.pdf; *IAB Internet Advertising Revenue Report: 2007 Full Year Results*, PriceWaterhouseCoopers, May 2008, https://www.iab.com/wp-content/uploads/2015/05/IAB_PwC_2007_full_year.pdf.
- 23 *IAB Internet Advertising Revenue Report: 2018 Full Year Results*, PriceWaterhouseCoopers, May 2019, <https://www.iab.com/wp-content/uploads/2019/05/Full-Year-2018-IAB-Internet-Advertising-Revenue-Report.pdf>; https://www.iab.com/wp-content/uploads/2022/04/IAB_Internet_Advertising_Revenue_Report_Full_Year_2021.pdf.
- 24 Avi Goldfarb and Catherine Tucker, "Online Advertising, Behavioral Targeting, and Privacy," *Communications of the ACM* 54, no. 5 (May 2011): 25–27, <http://doi.acm.org/10.1145/1941487.1941498>.
- 25 *Online Profiling: A Federal Trade Commission Report to Congress, Part 2*, Federal Trade Commission, 2000, <https://www.ftc.gov/reports/online-profiling-federal-trade-commission-report-congress-part-2>; *Online Profiling: A Federal Trade Commission Report to Congress*, Federal Trade Commission.
- 26 "Online Behavioral Advertising Moving the Discussion Forward to Possible Self-Regulatory Principles," Federal Trade Commission, December 2007, <https://web.archive.org/web/20080216182326/http://www.ftc.gov/os/2007/12/P859900stmt.pdf>; *FTC Staff Report: Self-Regulatory Principles for Online Behavioral Advertising: Tracking, Targeting, and Technology*, Federal Trade Commission, March 2009, <https://web.archive.org/web/20090312054035/http://www.ftc.gov/os/2009/02/P085400behavadreport.pdf>.
- 27 Berin Szóka and Adam Thierer, "Online Advertising & User Privacy: Principles to Guide the Debate," *Progress Snapshot* 4, no. 19 (September 2008), https://papers.ssrn.com/sol3/papers.cfm?abstract_id=1348600; Solove, *Understanding Privacy*.

- 28 Jun Yan, Ning Liu, Gang Wang, Wen Zhang, Yun Jiang, and Zheng Chen, "How Much Can Behavioral Targeting Help Online Advertising?" *Proceedings of the 18th International Conference on World Wide Web* (2009): 261–270, <https://dl.acm.org/citation.cfm?doi=1526709.1526745>.
- 29 *Online Profiling: A Federal Trade Commission Report to Congress*, Federal Trade Commission; *Online Profiling: A Federal Trade Commission Report to Congress, Part 2*, Federal Trade Commission; "Online Behavioral Advertising Moving the Discussion Forward to Possible Self-Regulatory Principles," Federal Trade Commission; *FTC Staff Report: Self-Regulatory Principles for Online Behavioral Advertising*, Federal Trade Commission; U. S. House of Representatives, "What Your Broadband Provider Knows About Your Web Use: Deep Packet Inspection and Communications Laws and Policies," *Hearing before the Committee on Energy and Commerce, Subcommittee on Telecommunications and the Internet*, vol. 110 Cong. 1, 2008; U. S. Senate, "Privacy Implications of Online Advertising," *Hearing before Committee on Commerce, Science, and Technology*, vol. 110 Cong. 1, 2008.
- 30 Aaron Massey and Annie Antón, "Behavioral Advertising Ethics," in *Information Assurance and Security Ethics in Complex Systems: Interdisciplinary Perspectives*, (Hershey, PA: Information Science Reference, 2010), 162–182.
- 31 Massey and Antón, "Behavioral Advertising Ethics."
- 32 Massey and Antón, "Behavioral Advertising Ethics."
- 33 Massey and Antón, "Behavioral Advertising Ethics."
- 34 Yan et al, "How Much Can Behavioral Targeting Help Online Advertising?"
- 35 Massey and Antón, "Behavioral Advertising Ethics."
- 36 Massey and Antón, "Behavioral Advertising Ethics."
- 37 Calo, "The Boundaries of Privacy Harm"
- 38 Harlan Yu, "Lessons from the Fall of NebuAd," *Freedom to Tinker*, October 8, 2008, <https://freedom-to-tinker.com/2008/10/08/lessons-fall-nebuad/>.
- 39 Massey and Antón, "Behavioral Advertising Ethics."
- 40 Goldfarb and Tucker, "Online Advertising, Behavioral Targeting, and Privacy."
- 41 Goldfarb and Tucker, "Online Advertising, Behavioral Targeting, and Privacy."
- 42 Richard Clayton, "The Phorm 'Webwise' System," (University of Cambridge, May 2008), <http://www.cl.cam.ac.uk/~rnc1/080518-phorm.pdf>.
- 43 Richard Wray, "BT Drops Plan to Use Phorm Targeted Ad Service After Outcry Over Privacy," *The Guardian*, July 5, 2009, <https://www.theguardian.com/business/2009/jul/06/btgroup-privacy-and-the-net>.
- 44 Adam Kramer, Jamie Guillory, Jeffrey Hancock, "Experimental Evidence of Massive-Scale Emotional Contagion through Social Networks," *PNAS*, June 2, 2104, <https://www.pnas.org/doi/10.1073/pnas.1320040111>.
- 45 Hu Han, Anil Jain, Fang Wang, Shiguang Shan, Xilin Chen, "Heterogeneous Face Attribute Estimation: A Deep Multi-Task Learning Approach," in *IEEE Transactions on Pattern Analysis and Machine Intelligence* 40, no. 11 (2018): 2597–2609, <https://doi.org/10.1109/TPAMI.2017.2738004>.
- 46 Viktor Mayer-Schönberger and Kenneth Cukier, *Big Data: A Revolution That Will Transform How We Live, Work, and Think*, (Boston: Houghton Mifflin Harcourt, 2013), <https://www.goodreads.com/book/show/15815598-big-data>; S. Zuboff, *The Age of Surveillance Capitalism: The Fight for a Human Future at the New Frontier of Power*, (New York: Hachette Book Group, 2019), https://www.goodreads.com/book/show/26195941-the-age-of-surveillance-capitalism?from_search=true; Julia Angwin, *Dragnet Nation: A Quest for Privacy, Security, and Freedom in a World of Relentless Surveillance*, (New York: St. Martin's Press, 2014), <https://www.goodreads.com/book/show/18465585-drag-net-nation>.
- 47 Shion Guha, "Everyday Algorithmic Decisions and Their Consequences," (2016), https://sociotechethics.files.wordpress.com/2016/10/group2016ethics_guha.pdf; John Danaher, "The Threat of Algocracy: Reality, Resistance and Accommodation," *Philosophy and Technology* 29, no. 3 (2016): 245–268; Brent Mittelstadt, Patrick Allo, Mariarosaria Taddeo, Sandra Wachter, and Luciano Floridi, "The Ethics of Algorithms: Mapping the Debate," *Big Data & Society* 3, no. 2, (December 2016): 68; Andrew Tutt, "An FDA for Algorithms" (2016): 1–26; Bruno Lepri, Jacopo Staiano, David Sangokoya, Emmanuel Letouzé, and Nuria Oliver, "The Tyranny of Data? The Bright and Dark Sides of Data-Driven Decision-Making for Social Good," *Transparent Data Mining for Big and Small Data* (2016), 1–22.
- 48 Lepri et al, "The Tyranny of Data?"

49 John Kelly and Steve Hamm, *Smart Machines: IBM's Watson and the Era of Cognitive Computing*, (New York: Columbia University Press, 2013), <https://www.jstor.org/stable/10.7312/kell16856>.

50 Latanya Sweeney, "Discrimination in Online Ad Delivery," *Queue* 11, no. 3, (March 2013): 10–29, <http://doi.acm.org/10.1145/2460276.2460278>.

51 Sweeney, "Discrimination in Online Ad Delivery."

52 Jeffrey Dastin, "Insight – Amazon Scraps Secret AI Recruiting Tool that Showed Bias Against Woman," *Reuters*, October 10, 2018, <https://www.reuters.com/article/us-amazon-com-jobs-automation-insight/amazon-scraps-secret-ai-recruiting-tool-that-showed-bias-against-women-idUSKCN1MK08G>.

53 *Loomis v. Wisconsin*, 881 N.W.2d 749 (Wis. 2016), vol. 137 S.Ct. 2290 (2017).

54 Mitch Smith, "In Wisconsin, a Backlash Against Using Data to Foretell Defendants' Futures," *The New York Times*, June 22, 2016, <https://www.nytimes.com/2016/06/23/us/backlash-in-wisconsin-against-using-data-to-foretell-defendants-futures.html>.

55 Smith, "In Wisconsin, a Backlash Against Using Data to Foretell Defendants' Futures."

56 Smith, "In Wisconsin, a Backlash Against Using Data to Foretell Defendants' Futures."

57 *Loomis v. Wisconsin*.

58 Mittelstadt et al., "The Ethics of Algorithms."

59 Sam D. Warren and Louis D. Brandeis, "The Right to Privacy," *Harvard Law Review* 4, no. 5, (1890): 193–220.

60 Ian Parker, "The Story of a Suicide: Two College Roommates, a Webcam, and a Tragedy," *The New Yorker*, January 29, 2012, <https://www.newyorker.com/magazine/2012/02/06/the-story-of-a-suicide>.

61 Parker, "The Story of a Suicide."

62 Parker, "The Story of a Suicide."

63 Parker, "The Story of a Suicide."

64 Ashley Hayes, "Prosecutors to Appeal 30-day Sentence in Rutgers Gay Bullying Case," *CNN*, May 2012, <https://www.cnn.com/2012/05/21/justice/new-jersey-rutgers-sentencing/index.html>.

65 Derek Bambauer, "Cyberbullying and the Cheese-Eating Surrender Monkeys," *Concurring Opinions*, 2012.

66 Bambauer, "Cyberbullying and the Cheese-Eating Surrender Monkeys."

67 Bambauer, "Cyberbullying and the Cheese-Eating Surrender Monkeys."

68 Alice Marwick and Danah Boyd, "The Drama! Teen Conflict, Gossip, and Bullying in Networked Publics," *A Decade in Internet Time: Symposium on the Dynamics of the Internet Society* (September 2011), <https://papers.ssrn.com/abstract=1926349>.

69 Parker, "The Story of a Suicide."

70 Parker, "The Story of a Suicide."

71 Jeff Kosseff, *The Twenty-Six Words That Created the Internet*, (New York: Cornell University Press, April 2019).

72 Myle Ott, Yejin Choi, Claire Cardie, and Jeffrey Hancock, "Finding Deceptive Opinion Spam by Any Stretch of the Imagination," *Proceedings of the 49th Annual Meeting of the Association for Computational Linguistics: Human Language Technologies 1* (2011): 309–319; Tommaso Fornaciari and Massimo Poesio, "Identifying Fake Amazon Reviews as Learning from Crowds," *Proceedings of the 14th Conference of the European Chapter of the Association for Computational Linguistics* (2014): 279–287.

73 Yue Pan and Jason Zhang, "Born Unequal: A Study of the Helpfulness of User-Generated Product Reviews," *Journal of Retailing* 87, no. 4 (December 2011): 598–612, <http://www.sciencedirect.com/science/article/pii/S0022435911000406>.

74 Pan and Zhang, "Born Unequal."

75 Thor Benson, "This Disinformation Is Just For You," *Wired*, August 1, 2023, <https://www.wired.com/story/generative-ai-custom-disinformation/>.

76 Sofie Hvitved, "What if 99% of the Metaverse is Made by AI?" Copenhagen Institute for Future Studies, February 24, 2022, <https://cifs.dk/news/what-if-99-of-the-metaverse-is-made-by-ai>.

77 Massey and Antón, "Behavioral Advertising Ethics."

78 "FTC Staff Revises Online Advertising Disclosure Guidelines 'Dot Com Disclosures' Guidance Updated to Address Current Online and Mobile Advertising Environment," Federal Trade Commission, March 12, 2013, <https://www.ftc.gov/news-events/press-releases/2013/03/ftc-staff-revises-online-advertising-disclosure-guidelines>.

- 79 “FTC Brings First Case Challenging Fake Paid Reviews on an Independent Retail Website,” Federal Trade Commission, February 26, 2019, <https://www.ftc.gov/news-events/press-releases/2019/02/ftc-brings-first-case-challenging-fake-paid-reviews-independent>.
- 80 Onur Varol, Emilio Ferrara, Clayton Davis, Filippo Menczer, and Alessandro Flammini, “Online Human-Bot Interactions: Detection, Estimation, and Characterization,” *Proceedings Eleventh International AAAI Conference on Web and Social Media* 11, no. 1 (2017), <https://www.aaai.org/ocs/index.php/ICWSM/ICWSM17/paper/view/15587>; Emilio Ferrara, Onur Varol, Clayton Davis, Filippo Menczer and Alessandro Flammini, “The Rise of Social Bots,” *Communications of the ACM* 59, no. 7 (June 2016): 96–104, <http://doi.acm.org/10.1145/2818717>.
- 81 Ferrara et al., “The Rise of Social Bots.”
- 82 Ferrara et al., “The Rise of Social Bots”; Shannon Van Sant, “Nearly 30 Percent Of Anti-Semitic Online Attacks Are Bots,” *NPR National News*, October 31, 2018, <https://www.npr.org/2018/10/31/662630534/nearly-30-percent-of-anti-semitic-online-attacks-are-bots>.
- 83 Varol et al., “Online Human-Bot Interactions.”
- 84 Robert Chesney and Danielle Keats Citron, “Deep Fakes: A Looming Challenge for Privacy, Democracy, and National Security,” *California Law Review* 107 (2019): 1753–1819 <https://papers.ssrn.com/abstract=3213954>.
- 85 Supasorn Suwajanakorn, Steven Seitz, and Ira Kemelmacher-Shlizerman, “Synthesizing Obama: Learning Lip Sync from Audio,” *ACM Transactions on Graphics* 36, no. 4 (July 2017): 1–13, <http://doi.acm.org/10.1145/3072959.3073640>.
- 86 Suwajanakorn et al., “Synthesizing Obama.”
- 87 Alec Banks, “Deepfakes & Why the Future of Porn is Terrifying,” *Highsnobity*, February 14, 2018, <https://www.highsnobity.com/p/what-are-deepfakes-ai-porn/>; Chesney and Citron, “Deep Fakes.”
- 88 Maria Luisa Paúl, “Students Made a Racist Deepfake of a Principal. It Left Parents in Fear,” *The Washington Post*, March 14, 2023, <https://www.washingtonpost.com/nation/2023/03/14/racist-deepfakes-carmel-tiktok/>.
- 89 David Güera and Edward Delp, “Deepfake Video Detection Using Recurrent Neural Networks,” *2018 15th IEEE International Conference on Advanced Video and Signal Based Surveillance (AVSS)*, (2018): 1–6, <https://ieeexplore.ieee.org/document/8639163>.
- 90 Chesney and Citron, “Deep Fakes.”
- 91 Samantah Cole, “This Horrifying App Undresses a Photo of Any Woman With a Single Click,” *Motherboard: Tech by Vice*, June 26, 2019, https://www.vice.com/en_us/article/kzm59x/deepnude-app-creates-fake-nudes-of-any-woman; Phillip Isola, Jun-Yan Zhu, Tinghui Zhou, and Alex Efros, “Image-To-Image Translation With Conditional Adversarial Networks,” *The IEEE Conference on Computer Vision and Pattern Recognition* (2017), <https://ieeexplore.ieee.org/document/8100115>.
- 92 Chesney and Citron, “Deep Fakes.”
- 93 Daniel Faggella, “7 Chatbot Use Cases That Actually Work,” *Emerj*, updated December 13, 2019, <https://emerj.com/ai-sector-overviews/7-chatbot-use-cases-that-actually-work/>.
- 94 Gartner, “Gartner Customer 360 Summit,” Los Angeles, CA, March 2011.
- 95 Chris Welch, “Google Just Gave a Stunning Demo of Assistant Making an Actual Phone Call,” *The Verge*, May 8, 2018, <https://www.theverge.com/2018/5/8/17332070/google-assistant-makes-phone-call-demo-duplex-io-2018>.
- 96 Alex Cranz, “Uhh, Google Assistant Impersonating a Human on the Phone Is Scary as Hell to Me,” *Gizmodo*, May 8, 2012, <https://gizmodo.com/uhh-google-assistant-impersonating-a-human-is-scary-as-1825861987>.
- 97 John Porter, “Apple’s iOS 13 Update Will Make FaceTime Eye Contact Way Easier,” *The Verge*, July 3, 2019, <https://www.theverge.com/2019/7/3/20680681/ios-13-beta-3-facetime-attention-correction-eye-contact>.
- 98 Porter, “Apple’s iOS 13 update.”
- 99 Porter, “Apple’s iOS 13 update.”
- 100 Macro Arment, Casey Liss, and John Siracusa, “Your Face is Not Your Face,” *Accidental Tech Podcast*, July 2019, <https://atp.fm/episodes/336>.
- 101 Mat Honan, “Yes, I Was Hacked. Hard.” *EMPTYAGE*, August 3, 2012, <https://web.archive.org/web/20121101160737/http://www.emptyage.com/post/28679875595/yes-i-was-hacked-hard>; Mat Honan, “How Apple and Amazon Security Flaws Led to My Epic Hacking,” *Wired*, August 6, 2012, <https://www.wired.com/2012/08/apple-amazon-mat-honan-hacking/>.
- 102 Honan, “Yes, I Was Hacked. Hard.”; Honan, “How Apple and Amazon Security Flaws Led to My Epic Hacking.”
- 103 Honan, “Yes, I Was Hacked. Hard.”; Honan, “How Apple and Amazon Security Flaws Led to My Epic Hacking.”

- 104 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 105 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 106 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 107 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 108 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 109 Nathan Olivarez-Giles, "Amazon Quietly Closes Security Hole After Journalist's Devastating Hack," *Wired Gadget Lab*, August 7, 2012, <https://www.wired.com/2012/08/amazon-changes-policy-wont-add-new-credit-cards-to-accounts-over-the-phone/>; Nathan Olivarez-Giles Nathan and Mat Honan, "After Epic Hack, Apple Suspends Over-the-Phone AppleID Password Resets," *Wired Gadget Lab*, August 7, 2012, <https://www.wired.com/2012/08/apple-icloud-password-freeze/>.
- 110 Kevin Mitnick and William Simon, *The Art of Deception: Controlling the Human Element of Security*, (New York: John Wiley and Sons, 2002).
- 111 Jacquie Cheng, "School Settles Laptop Spying Case to 'Protect Taxpayers,'" *Ars Technica*, December 10, 2010, <https://arstechnica.com/tech-policy/2010/10/school-settles-laptop-spying-case-to-protect-taxpayers/>.
- 112 Cheng, "School Settles Laptop Spying Case to 'Protect Taxpayers'."
- 113 Bruce Schneier, "Security and Function Creep," *IEEE Security Privacy* 8, no. 1 (2010): 88, <https://ieeexplore.ieee.org/document/5403161>.
- 114 City of Ontario, California, et al. V. Quon et al. 560 U.S. 746, vol. 130 S. Ct. 2619, 2010.
- 115 Helen F. Nissenbaum, "Privacy as Contextual Integrity," *Washington Law Review* 79, no. 1 (2004).
- 116 Although this book is not about information security or incident response, both these fields have demonstrated the value of actually practicing by conducting realistic response drills.

CHAPTER 8

AI and Machine Learning

Zhiwei Steven Wu

8.1 Overview

Artificial intelligence (AI) has increasingly dominated news headlines. The primary driver behind the growth of AI has been in the subfield of machine learning (ML). Modern ML algorithms can now build models by processing massive collections of text, images, audio, code, and other forms of rich data. We are only beginning to see how these technologies will

revolutionize business, science, health care, entertainment, and many other domains. However, as we explore the incredible capabilities of modern ML, there is growing concern about the potential privacy risks that can arise from its use.

In this chapter, we first provide a brief introduction to modern ML, including its basic paradigms and more modern advances such as the recent development of generative AI. We then explore how the collection, analysis, and utilization of vast amounts of data in ML can inadvertently lead to various forms of privacy risk. From the inadvertent disclosure of sensitive information to the potential for algorithmic bias and discrimination, we look at the multifaceted challenges that arise when ML intersects with privacy. Finally, we discuss ways to mitigate these risks, ensuring a responsible and privacy-aware approach to the application of ML technologies.

8.2 Basics of Machine Learning

ML is a broad discipline that aims to enable computers to learn from patterns of data and their interactions with the world, without programmer intervention. The three main paradigms of ML are “supervised learning,” “unsupervised learning,” and “reinforcement learning.” We provide a brief introduction to these paradigms later in this section. However, as we elaborate later in this chapter, the boundaries of each paradigm have become vague in modern advances on ML, such as generative AI.

Supervised learning is arguably the most developed paradigm within ML. The paradigm is “supervised” in the sense that an algorithm learns from a dataset labeled with the correct answers or desired outputs. In other words, the dataset can be thought of as a supervisor or teacher who guides its learning process. The outcome of the training process is a predictive model that maps observable features to a predicted outcome.

To illustrate the core components of supervised learning, let’s think about a hospital that develops a model to predict the likelihood of a patient being at risk for a certain disease. The initial phase involves data collection, wherein the hospital compiles a dataset of patient records, each labeled as “at risk” or “not at risk”. The subsequent step is pinpointing features that predict the presence or absence of risk, which might encompass the patient’s age, genetic markers, lifestyle habits, previous medical history, and any other pertinent data in the dataset. The model is then trained to use the chosen features to predict the designated label for each patient. When introduced to a new patient, the hospital can predict whether this patient is likely to be at risk for the disease.

Unsupervised learning, in contrast, deals with unlabeled data. While supervised learning has a clear objective of maximizing predictive accuracy, unsupervised learning aims to explore and discover the inherent structure or patterns within the data. A quick way to recognize the difference between supervised and unsupervised learning is the form of data we deal with. In supervised learning, the data looks like (x, y) pairs, and the goal is to predict y

when given x . In unsupervised learning, there are just examples of x , and the goal is to uncover patterns among these examples.

A canonical example of unsupervised learning is called “clustering,” which organizes the examples into a number, called k , of different clusters. For example, to inform its business strategies, a company may wish to gain an understanding of its customer segmentation by dividing customers into groups of individuals that have similar characteristics, such as age, gender, interests, or spending habits. Dimensionality reduction is another common example of unsupervised learning that focuses on reducing the number of input variables or features in a dataset. It aims to capture the most essential information from the data while removing redundant or less important features. By doing so, dimensionality reduction can simplify complex datasets, making them more manageable and interpretable without significantly compromising their integrity or the quality of insights derived from them. In biology, dimensionality reduction techniques like principal component analysis are used to visualize and interpret genetic variations among subpopulations.¹ Another application of dimensionality reduction is anomaly detection, since in some cases, anomalies or outliers may become more evident in a reduced-dimensional space, aiding in their detection. In a cybersecurity context, this can be used to recognize malicious network traffic data when attacks may be occurring.

Reinforcement learning involves agents who make increasingly informed decisions when interacting with an environment. While supervised and unsupervised learning are about making predictions based on identified data patterns, reinforcement learning is fundamentally about learning to interact with the world through trial and error. Reinforcement learning typically deals with a dynamic environment in which the learning agent observes the state of the current environment, takes an action, receives feedback in the form of rewards or punishments, and repeats. As an illustrative example, consider a recommendation system that selects and ranks items, such as movies, music, or goods, to recommend to users. In this case, the recommendation system acts as the learning agent and treats user-item interactions as the environment, which may include the user’s browsing history or past purchases. Agent actions refer to selecting and presenting ranked items to the user. The agent receives rewards based on user feedback, like ratings or click-through rates, which measures the frequency that users click on the recommended items over the total number of recommendations. As the recommendation system continuously interacts with the user, it becomes better at delivering personalized recommendations. This approach could, for example, be used to learn which accessories are most likely to be purchased together with electronics or clothing. The recommender can improve its recommendations when they are reinforced by other users clicking on the suggested accessories.

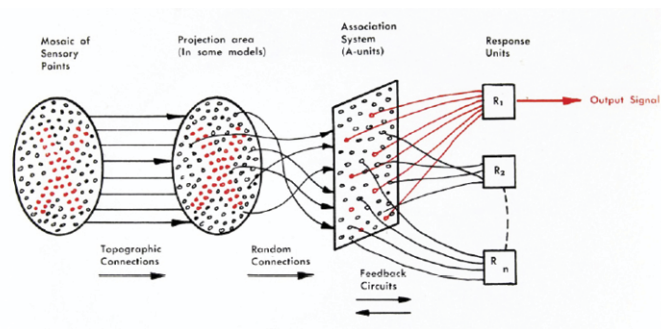
8.2.1 Neural Networks and Deep Learning

There are many algorithms and models to choose from to build ML applications. Each algorithm has benefits and weaknesses. For example, decision trees and random forests are highly regarded in ML due to their simplicity and versatility. Decision trees offer an intuitive structure that is easy to understand and interpret, while random forests, which are ensembles of decision trees, provide improved accuracy. However, one downside of these models is that data scientists need to perform “feature engineering” to select which features should be used to make the best predictions.

Recent advancements in ML are largely attributable to deep learning, an approach that uses multilayered neural networks to perform complex tasks more effectively. We briefly talk about how deep learning transforms all three paradigms of supervised learning, unsupervised learning, and reinforcement learning and, in fact, brings together ideas from these paradigms to make breakthroughs in generative AI.

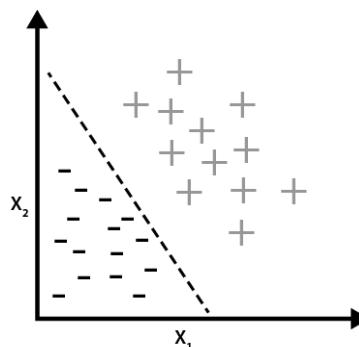
Neural networks were inspired by the functioning of the human brain, but they do not accurately reflect all the intricacies of neurobiological systems. They are, in fact, very simplified models of how brains compute information. The first artificial neural network, called the Perceptron, was introduced by Frank Rosenblatt in 1957. See Figure 8-1.²

Figure 8-1: Organization of a Perceptron from Frank Rosenblatt’s “The Design of an Intelligent Automaton”³



The Perceptron can solve simple supervised learning problems, where the labeled data is linearly separable, meaning it can be divided by a straight line or a flat plane, shown in Figure 8-2.

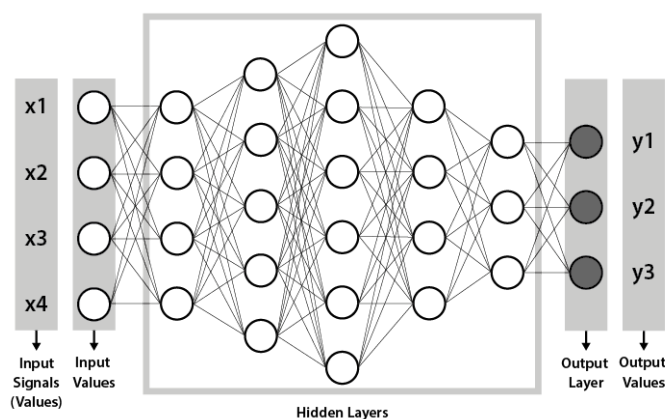
Figure 8-2: Example of a linear decision boundary for binary classification⁴



However, we have learned the world is full of nonlinear problems. For instance, recognizing the content of an image or understanding spoken or written language are tasks that involve

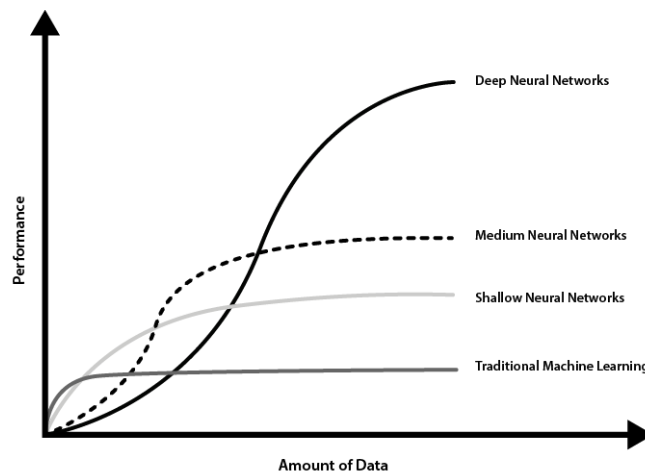
complex, nonlinear relationships between pixels of an image or words in a sentence. Since the Perceptron only captures linear relationships, it is not expected to handle such complex tasks. However, if we build neural networks with multiple layers of perceptron, we can start tackling nonlinear problems. A multilayer neural network is essentially a stack of Perceptrons. It consists of an input layer that we feed our data into, an output layer that gives us our result, and one or more hidden layers in between, as outlined in Figure 8-3. When there is more than one hidden layer, it is considered “deep learning.” Each layer consists of multiple nodes or neurons. The key idea is each hidden layer of the network extracts or learns the features from the input data, with each subsequent hidden layer using the output of the previous layer to form a more complex representation of the original input. This is in contrast to other algorithms used in ML, wherein the data scientist needs to choose the features manually.

Figure 8-3: Example multilayer neural network⁵



Even though the idea of deep neural networks has been around since Rosenblatt’s early work in the late 1950s, the modern era of deep learning did not begin until the mid-2000s. The key factors that came together have been a game changer in computer automation. First, largely thanks to the internet, the availability of large datasets allows deep neural networks to show their strength in learning from vast amounts of data. Compared to traditional ML methods like decision trees and random forests, deep neural networks require a lot more training data to achieve superior performance. See Figure 8-4 for the trade-offs between performance and data requirements.

Figure 8-4: Trade-offs between predictive performance and data requirements in different ML models⁶



Second, the number of computations required to update the weights in the deep neural networks has exceeded what commercially available hardware could perform for a long time. The development of powerful graphical processing units (GPUs), originally developed to compute realistic, smooth graphics for video games, has made it feasible to train and deploy large deep neural network models. Finally, developments in ML research have led to more advanced designs of large neural network architectures and training algorithms. For example, one key development in deep learning is the introduction of new activation functions, such as the Rectified Linear Unit (ReLU) that connects consecutive layers of neural networks. Another key development is more advanced training algorithms, such as the stochastic gradient descent (SGD), which have shown to be effective in optimizing neural networks. Another development was the introduction of attention mechanisms, which allow deep neural networks to learn relationships across longer spans of data and have played a critical role in generative AI.

In short, given the right neural network architecture and training algorithm, vast amounts of data and computational power can be harnessed to develop remarkably advanced deep learning models. While the simplest application of deep learning is supervised learning, e.g., image recognition, deep learning has also transformed unsupervised learning and reinforcement learning. In unsupervised learning, deep neural networks have been used to generate different types of content, including dialog, audio, and images.

This leads us to the next topic: generative AI. In addition, deep learning was also the primary driver for the groundbreaking successes in applying reinforcement learning to game playing. For example, AlphaGo, a program trained on human-played games of the board game Go, made history by defeating Go champion Lee Sedol 4–1. However, its successor, AlphaGo Zero, revolutionized AI game playing by mastering Go through self-play via reinforcement learning, without human data. This resulted in a stunning 100–0 victory over AlphaGo, showcasing superior strategies and previously unseen moves.

8.2.2 The Era of Generative AI

The emergence of generative AI is arguably the most exciting development in ML over recent years. Generative AI models, powered by deep neural networks, are trained on massive amounts of data, including text, code, and images. These advanced models possess the capability to generate cohesive and captivating narratives, news articles, poems, song lyrics, artistic renderings, and even computer programs on command. We are only beginning to understand the potential of generative AI and how it will transform our lives. But the applications of generative AI are already reshaping domains ranging from creative content production to personalized assistants to copywriting to code generation.

The underpinning of generative AI draws ideas from all three paradigms of supervised learning, unsupervised learning, and reinforcement learning, while also leveraging advanced deep learning models such as general adversarial networks (GANs), autoregressive convolutional neural networks (AR-CNN), and transformer-based models. It is useful to start with large language models (LLMs) to understand how generative AI combines these ideas. First and foremost, LLMs are trying to solve an unsupervised learning task of generating realistic text, when given a prompt that includes an instruction directing the model to select a specific task for completion. For example, when given the prompt: “Explain why large language models are so cool and use less than 20 words,” the LLM GPT-4 returns “Large language models generate creative, coherent text, answering questions and simulating human-like conversation.”

Even though text generation is typically identified as an unsupervised learning task, the training of these LLMs also use an idea called next-word prediction, which is a form of supervised learning. To explain this idea, we will consider a polling thought experiment thanks to Micheal Kearns.² Suppose we have a beginning fragment of the sentence “The cat climbed the” and ask people to fill in the next word. Some may say “tree” and others may say “roof,” “stairs,” and “table,” but few or nobody would suggest words like “spaceship” or “black hole.” If we poll a sufficiently large population, we will gradually learn a probability distribution over the next possible word, in which some words are more likely to be suggested than other words. By processing a large collection of text, LLMs are essentially learning these distributions whenever they are given a sequence of words. Then, simply by predicting the next words one by one, LLMs can generate entire paragraphs, arguments, and even short stories.

Reinforcement learning also plays a role in improving LLMs. While next-word prediction has led to impressive performance, text generated by LLMs is not always coherent, correct, or appropriate. An increasingly common paradigm to handle this issue is called reinforcement learning with human feedback (RLHF). At a high level, RLHF tries to reward or penalize the LLM based on human feedback. For example, RLHF was used to train ChatGPT by iteratively refining its responses through human feedback. Human trainers rated generated texts from the model, which in turn guided the model toward more accurate, contextually

appropriate, and helpful outputs. This method combines human judgment with reinforcement learning algorithms to improve ChatGPT's performance over time.

Of course, generative AI goes beyond text generation. By harnessing rich datasets of different types, complex neural networks can also generate images, music, video, 3D models, architecture design, and even molecular structures. In fact, multiple forms of data can be combined. For example, diffusion models like DALL·E 2 can generate realistic paintings when given a prompt such as “A Shiba Inu dog wearing a beret and black turtleneck,” as shown in Figure 8-5. Building such models uses more sophisticated techniques than next-word prediction. As the models need to establish relationships between text and images, the training process involves data such as images with descriptive captions.

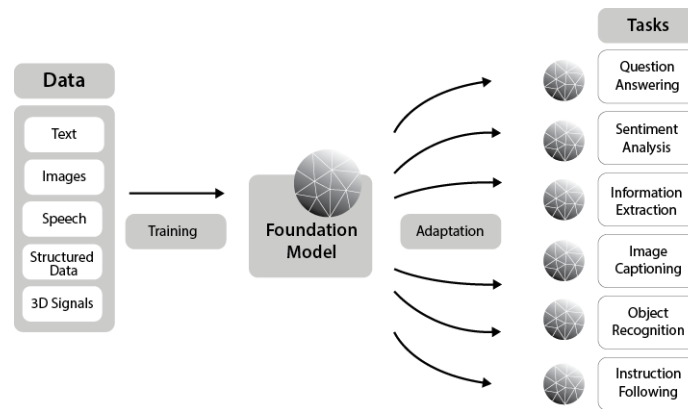
Figure 8-5: Image generated by the model DALL·E 2 when given the prompt: “A Shiba Inu dog wearing a beret and black turtleneck” ⁸



Beyond entertainment, generative AI has enabled an increasing number of practical applications, and we are barely scratching the surface. One reason generative AI can quickly adapt to new domains and applications is the availability of “foundation models” and the “fine-tuning technique.” As previously described for LLMs, foundation models are pretrained on a broad and diverse dataset, usually encompassing a wide range of topics, domains, and types of knowledge shown in Figure 8-6. The fine-tuning technique *lightly* trains the foundation models on relatively small amounts of data so they can adapt quickly to new domains and applications. For example, fine-tuning has led to specialized models of BERT—for biomedical content (BioBERT), legal content (Legal-BERT), and French text (CamemBERT)—and variations of GPT-3 for a wide range of purposes.

Because generative AI systems can also create offensive or undesired outputs, such as information about self-harm, how to build weapons, or human trafficking, most operators include a substantial number of “filters.” These are essentially rule-based ML controls that apply to the output and may divert to controlled responses as a form of content moderation. This is why the model will sometimes answer “I cannot provide that information” or other preprogrammed overrides to the generated answer.

Figure 8-6: Example of a foundation model²



8.2.3 Behind the Scenes of ML Systems

Many components propel the success of large-scale ML systems from behind the scenes.

8.2.3.1 The Role of Data

Just as an engine relies on fuel to run, ML models depend on data to function and learn. Without data, these models have no basis for learning patterns, making predictions, or improving over time. Several aspects of data significantly influence the performance and effectiveness of ML systems.

The volume of data available for training and validation is an important factor. First, the amount of data significantly influences the choice of ML models and techniques. Different models have varying data requirements, and the quantity of data can dictate the feasibility and effectiveness of these models. With too little data, simple models such as linear regression or decision trees, can be more appropriate than neural networks. These models are less prone to “overfitting,” in which the model overweighs noise and specific patterns from the training data that don not generalize well to new data. In contrast, with large datasets, more complex models like deep neural networks become viable. These models have more parameters that support learning intricate patterns, but they also require significantly more data to be trained effectively without overfitting.

The quality of data is often even more important than the quantity. Clean data, free from errors, inconsistencies, and outliers, is essential for the reliable performance of ML models. For example, a good set of features, i.e., highly predictive fields in a dataset, can significantly enhance the model’s learning ability by providing relevant information and reducing noise. They enable the model to capture the true underlying patterns in the data, leading to improved accuracy and efficiency. In contrast, poor-quality data and poorly selected features can lead to models that are biased, inaccurate, or overfit, when they learn the noise in the training data rather than the actual relationships.

Data diversity and representation ensures ML models are exposed to a wide range of situations, making them more robust and capable of handling real-world variability and even previously unseen situations. Diverse data helps reduce biases and ensures the model’s predictions are representative of the entire population or scenario it was designed to address.

The variety and types of data determine the range of problems a ML model can solve. From structured numerical data to unstructured text, images, and audio, the diversity of data expands the ML applications into various domains.

As the datasets used to build ML systems continue to grow, there is a corresponding trend toward constructing increasingly large ML models. However, these are not necessarily environmentally sustainable. As a result, a significant amount of money and electricity go into developing these ML systems. Because some of these models have upwards of a billion parameters, training them requires tremendous computational resources, including powerful GPUs and other specialized hardware. These hardware resources are typically expensive to purchase and maintain and consume a significant amount of electricity. While most AI companies such as OpenAI have not publicly disclosed the exact costs of training their LLMs, there is no doubt that tens of millions of dollars were spent on individual models and billions of dollars were spent training them, globally. As a renowned example, GPT-3 has 175 billion parameters and was trained on a staggering forty-five terabytes of data. It was reported training GPT-3 amounted to a substantial investment of at least USD12 million.¹⁰ In comparison, Wu Dao 2.0, a formidable model originating from China, boasts a monumental 1.75 trillion parameters.¹¹ The size of LLM training datasets and models is continuing to increase. Researchers at the University of Massachusetts found training a single AI model may emit as much carbon dioxide as over sixty gas-powered cars driven for a full year.¹²

8.2.3.2 The Roles of Professionals

There are usually teams of very diverse professionals who create and maintain ML systems. The areas of professional specialization are also likely to grow over time. Typical roles behind ML systems include data engineers, data scientists, software engineers, research scientists, and prompt engineers.

Data engineers are responsible for building and maintaining the systems that gather, store, and process the data used by ML models. They often have a strong background in software engineering and database management. They are often concerned about storing and processing data at high volumes and about ensuring and maintaining high quality data.

Data scientists, who create, implement, test, and refine ML models. They typically have a strong background in computer science, specializing in ML and statistics, and are often concerned about the accuracy of the model's performance when a "gold" standard or ground truth exists to perform an evaluation.

Software engineers, who build the infrastructure to support ML systems, integrate these systems with other software, and maintain and update the software over time. They typically have a strong background in computer science and software engineering, and are often concerned by the reliability, safety, and privacy of a system, particularly when that system is constructed from multiple components, including ML models.

In certain companies or organizations, there are also research scientists, who focus on conducting cutting-edge ML research and may try to deploy their research to different applications. They typically have a deep understanding of the underlying principles and state-of-the-art techniques in ML and have earned doctorate degrees in ML, statistics, or other relevant disciplines.

As ML and AI applications have a profound societal impact, many companies now have responsible AI teams that consist of researchers who investigate the ethical implications of different AI technologies and help ensure the system is aligned with legal and ethical standards. The emergence of generative AI has created a new type of professional called prompt engineers, who design the right “prompt”—or more often, a series of prompts—to give AI models to generate a desired output.

More broadly speaking, generative AI, such as LLMs, is changing the workflow of many of these professionals. For example, tools from generative AI can generate simple pieces of code, potentially automating some tasks for software engineers. More recent tools from OpenAI’s ChatGPT can quickly process data, run descriptive analyses, test out basic ML models, and generate basic reports. These tools will dramatically reduce the workloads of data scientists. As a result, there are rising concerns that these generative AI tools might eventually replace a lot of professionals, even those who run ML systems behind the scenes.

8.2.4 Privacy Risks in Modern ML

The application of ML can cause a wide variety of privacy harms. We now review types of privacy harm due to modern ML, as mapped out by Solove’s taxonomy of harms.¹³

8.2.4.1 Confidentiality Harm

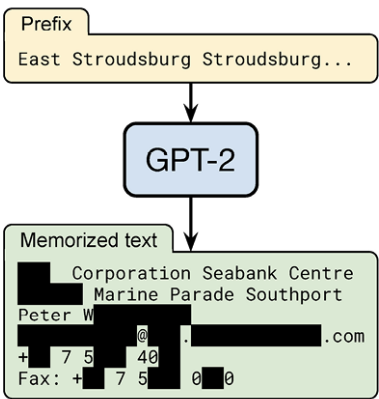
As ML applications increasingly rely on different types of personal data, such as medical history, location tracking, and online behavior, there is paramount concern that these applications may reveal sensitive information about the data subjects or individuals described by the data. In Daniel Solove’s taxonomy of privacy harms, this type of harm is related to a “breach of confidentiality” or the disclosure of private information to a third party without the owner’s consent.

To understand how modern ML can lead to a breach of confidentiality, it is helpful to look at the related ML of overfitting mentioned in section 8.2.3.1. As we discussed in section 8.2.1, large ML models such as deep neural networks have a high capacity to learn complex patterns in the training data. However, these large models also have a higher risk of overfitting, when the models learn the noise or idiosyncrasies of the training data instead of the general phenomenon of the underlying data. In general, overfitting goes against a common principle of ML, which is to learn models or patterns that generalize to unseen data. In supervised learning, a model that overfits may achieve near-perfect accuracy on training data but have substantially lower accuracy on test data or data it did not see during training. In general, overfitting is undesirable and can hurt the goal of learning. However, in practice,

data scientists have the tendency to repeatedly reuse the same dataset and apply different tricks and techniques to drive the training errors down, which can potentially lead to overfitting.¹⁴

Perhaps an extreme form of overfitting is “memorization,” in which individual training examples can be extracted from the released ML model. In a well-known example of memorization attacks, a group of researchers were able to extract entire sentences in training data by prompting language model GPT-2.¹⁵ In the example, shown with some information redacted in Figure 8-7, by inserting a highly specific prompt “East Stroudsburg Stroudsburg...” and asking GPT-2 to complete the sentence, the model returns an individual person’s name, email address, phone number, fax number, and physical address.

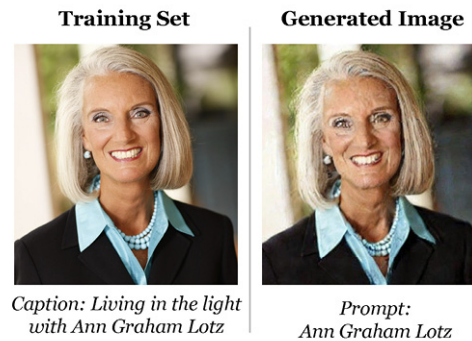
Figure 8-7: Example of a memorization extraction attack¹⁶



This type of extraction is especially concerning since language models are often trained on highly sensitive data. For example, autocomplete models, such as by Gmail, are trained on private text communications between users, so the extraction of snippets of their private communication would be a breach of confidentiality.¹⁷

Such extraction of training data is also possible for other types of generative AI models. As discussed in section 8.2.2, diffusion models such as DALL-E are trained on captioned images and, at test time, can generate images upon different input prompts. A recent study showed these large-scale diffusion models tend to memorize training data, which can be extracted by providing relevant prompts.¹⁸ For example, as shown in Figure 8.8, under the prompt “Ann Graham Lotz,” the diffusion model generates an image that is nearly identical to a training image with the caption “Living in the light with Ann Graham Lotz.”

Figure 8-8: Example of a diffusion model extraction¹⁹



Generative AI models are typically trained on massive amounts of data from a wide variety of sources, including books, websites, and other texts. In general, we do not know whether sensitive information was included in the training data. Thus, memorization of training data raises privacy concerns that these large models can inadvertently reveal private information.

In addition to memorization, generative AI also opens new risks of breaching confidentiality. When using generative AI models, users need to think twice about what sort of private information might leak to the platforms hosting the model. For example, if you're using a large language model to summarize a sensitive document, some APIs may ask you to upload the document to initiate the interaction. However, in certain cases, the platform may not be sufficiently trusted to retain the sensitive data. As generative AI models can simulate companionship or emotional support, users may also share highly intimate information with the models. AI chatbots can now generate human-like text conversations, providing users with a semblance of emotional connection and interaction. Companies, such as Replika, have built apps that simulate friends and even lovers for users. Data privacy, among other ethical considerations, needs to be carefully dealt with as users tend to share highly intimate information with these AI models.

8.2.4.2 Appropriation Harms

Generative AI and ML applications have also led to new forms of "appropriation risk," which refers to the possibility that an individual's personal information is used in ways that were not originally intended or consented to. Deepfakes are perhaps one of the most disturbing examples of how AI technologies bring appropriation harm and risks to individuals. Powered by deep neural networks, Deepfakes are fake images, videos, or audio created by generative AI in ways that are highly realistic and difficult to detect as fake. A typical use of deepfake is to create a fake narrative by imposing a person's face onto another person's body. For example, pornographers have used deepfakes to impose celebrities' faces onto people in sex videos. However, as the technology is more broadly adopted and becomes easier to use, deepfakes have been used to generate fake sex videos of ordinary citizens.²⁰

In addition to images, deepfakes can yield fake audio, including a person's voice. With only three seconds of recorded voice audio, a generative AI model can be fine-tuned to replicate a person's voice in short sentences.²¹ This capability has led to new security risks, as banking

call centers use a person's voice to validate that they are indeed the customer associated with an account. While current deep voice fakes have been reported to include audio defects that indicate a potential attack is taking place, improvements in these models could make these attacks much harder to detect.

There are also other, more nuanced examples of how the use of ML can cause appropriation harms. Many digital platforms and services collect user data under the premise of improving user experience with ML algorithms. However, some companies might also share or sell this data to third parties without explicit user consent, a practice that raises serious privacy concerns. For instance, shared data may be subsequently used for a different purpose, such as targeting advertisements or making decisions that could affect a user's opportunities.

8.2.4.3 Decisional Interference

"Decisional interference" is defined as an intrusion into an individual's personal decision-making process concerning their private affairs. Applications of ML have led to new forms of decisional inference across many domains.

When ML models are used to impact consequential decisions on individuals, potential unfair bias and illegal discrimination can limit individuals' opportunities or access to resources. In 2019, a high-profile research study found a widely used predictive model, which was designed to identify patients who would benefit most from additional medical care, had significantly underestimated the health needs of Black patients.²² While the model did not consider race as part of its training data, the prediction targets or labels were given by medical costs. Given the disparate health spending by Black patients in the United States, this led to the false assumption that Black patients were healthier than equally ill white patients, thus influencing the care provided. As a result, it has further perpetuated an existing racial disparity in health care by excluding this demographic from the model's recommendations.

This type of decisional interference caused by unfair biases in ML training data happens across many other domains. Targeted advertising platforms powered by ML models may also discriminate unfairly against certain demographic groups. Research has shown that Facebook's ad delivery system was skewing ad delivery along largely demographic lines. For example, job ads in the lumber industry are delivered disproportionately to white men, while jobs for janitorial positions go disproportionately to Black women.²³ Similarly, an AI resume-selection tool developed by Amazon was scrapped because it was shown to discriminate against women candidates.²⁴ In both examples, the impact of ML models was to unfairly interfere with individuals' job-seeking decision processes.

8.2.4.4 Intrusion

According to Solove's definition, "intrusion" concerns invasive acts that disturb one's tranquility or solitude.²⁵ Certainly, trespassing into someone's home is a form of intrusion and a clear violation of privacy. However, intrusion does not need to be limited to physical

space. An increasingly common form of intrusion includes different types of unwanted messaging, such as spam emails or texts, and telemarketing.

Modern ML technologies, especially generative AI, have taken unwanted messaging to an entirely different level. LLMs are being used by scammers to present highly believable messages to victims.²⁶ Their adaptability makes them potent tools for manipulation. With the advent of open-source LLMs, such as Meta's LLaMA, scammers can run intricate scams on standard personal computers. This technology enables a single individual to operate thousands of global, multilingual scams concurrently, leveraging tools like ChatGPT and LangChain to convincingly mimic human online interactions. Scams are evolving from the stereotypical prince offering riches to more complex ruses involving romance, cryptocurrencies, and financial returns—enticements made more believable through LLMs.²⁷

Even without the use of advanced generative AI technologies, the simple misuse of ML could also lead to severe intrusion. In Pasco County, Florida, Sheriff Chris Nocco decided to build an intelligence program, a predictive model intended to preemptively prevent crimes before they occur in a real-life version of the movie *Minority Report* starring Tom Cruise. However, his intelligence program morphed into a system of ongoing surveillance and harassment, according to a Tampa Bay Times investigation. The sheriff's office developed lists of potential lawbreakers, based on various, often arbitrary, criteria. Without sufficient legal grounds, deputies then frequently interrogated those listed, disrupted homes, issued petty citations, and repeated visits with the aim of arrest. The strategy, described as "making lives miserable," affected nearly 1,000 people in five years, with at least 10% of victims being minors.²⁸

8.2.5 Mitigations and Solutions

The privacy risks we have mentioned are concerning, and the recent developments in generative AI have taken these risks to a whole new level. Addressing privacy risks from AI indeed requires comprehensive efforts from a diverse array of communities. By now, there is a broad research agenda called "responsible AI" that aims to address societal concerns such as privacy. We briefly discuss efforts for mitigating privacy risks caused by the misuse of ML.

To safeguard confidentiality, it is crucial to curate training datasets for ML applications meticulously, ensuring the exclusion or removal of sensitive information when it is not essential for the application's functionality. When sensitive data can provide insights, a growing field called privacy-preserving machine learning (PPML) aims to develop useful ML methods without revealing sensitive information. One compelling approach called "differential privacy" ensures any individual piece of training data has negligible effects on the trained ML models.²⁹ See chapter 4 for a more in-depth discussion on differential privacy. Differential privacy prevents memorization attacks, among other attacks. However, as differential privacy typically introduces noise or randomness into the training process, the

resulting models tend to have lower utility, meaning the models might have lower predictive accuracy or generate lower-quality data. A persistent challenge in the deployment of differential privacy is how to manage the trade-offs between utility and privacy.

“Federated learning” is a method that trains algorithms across various devices or servers, utilizing only their local data, thus eliminating the need to share this data externally. The key idea is to have multiple devices or servers exchanging information about how to update the parameters of the ML model, without sharing the training data used to prepare the update. Although not sharing raw data seems to reduce privacy risks, recent studies indicate model updates shared during federated learning can inadvertently disclose substantial information about sensitive data.³⁰ There have been ongoing efforts to combine federated learning with differential privacy so the transmitted model update information does not reveal information about individual pieces of the training data.³¹

To prevent decisional interference caused by unfair biases in ML, there are also growing efforts to investigate fairness issues in ML. This includes whether it makes sense to introduce ML as a tool for certain consequential decision-making processes, such as financial services, employment contexts, or the criminal justice system. Before the deployment of ML tools, it is essential to identify the different sources of unfairness and unwanted bias, including skewed or incomplete training data, biased decision-making processes within organizations, or discriminatory practices. There is also a family of algorithmic approaches for preventing unfairness that often involves techniques such as fairness-aware learning, which considers fairness constraints during model training, or post-processing methods, which adjust model outputs to ensure fair treatment.³²

Although many technical definitions of fairness have been proposed by researchers and practitioners, inherent trade-offs exist among these concepts. In fact, research has shown that some entirely reasonable criteria for fairness are fundamentally incompatible with each other.³³ The research was spurred by the controversies around Correctional Offender Management Profiling for Alternative Sanctions (COMPAS), which is a risk assessment tool designed to help judges, parole officers, and probation officers make decisions about defendants’ and offenders’ levels of risk and needs. A ProPublica article then highlighted concerns about racial bias in COMPAS by showing the software was more likely to falsely label Black defendants as higher risk for future criminality compared to white defendants.³⁴ In more technical terms, the false positive rate, of wrongly predicting future criminal behavior, is much higher among Black defendants than white defendants. However, Northpointe, the maker of COMPAS, argued the tool is accurately calibrated, meaning it predicts recidivism consistently across racial groups. Calibration here implies the proportion of individuals who reoffend is proportionate to the predicted risk scores, regardless of race. Researchers later showed the criterion of equal false-positive rates across different groups, such as racial groups, is mutually exclusive from the criterion of calibration among all

groups.³⁵ This also motivated subsequent studies on involving stakeholders in the management of trade-offs across different fairness notions in AI systems.³⁶

In general, the advances of responsible AI efforts also involve synergies between public policy and technical innovation. For example, the technical research on machine unlearning is particularly relevant to regulations like the European Union's General Data Protection Regulation (GDPR), which gives individuals the "right to be forgotten." This means an EU member-state citizen can request that an organization delete all data it holds about them. In terms of ML models, this means not only the data related to the individual should be deleted. Machine unlearning offers a way to fulfill this requirement without the need to entirely retrain models, making it a potentially valuable tool for GDPR compliance. This motivates a recent problem called "machine unlearning mechanisms" that explores whether one can make an ML model forget or discard the knowledge it acquired from specific training examples, without having to retrain the model from scratch. However, this technical problem is generally very challenging, and broadly applicable solutions do not yet exist.³⁷ Finally, the EU AI Act requires organizations to conduct assessments to score the risk of decisional interference and surveillance, two prominent privacy harms, and to introduce verification and validation activities to mitigate those risks for high-risk ML applications.³⁸

Generative AI is transforming privacy risk mitigation by introducing complex challenges. Its ability to synthesize and potentially expose sensitive information necessitates innovative safeguards. Organizations must now implement advanced data governance and encryption protocols and design robust access controls. Additionally, there is a growing need for transparent data policies and development of AI systems that can operate with minimal data without compromising functionality, thereby safeguarding user privacy across many types of applications.

8.3 Summary

In this chapter, we explored the advancement of ML and AI, and the potential privacy harms modern ML systems may cause. We discussed the transformative potential of AI, especially regarding generative models, and highlighted some privacy concerns inherently in these technological developments. To effectively mitigate these risks, it is imperative to collectively develop and implement a holistic strategy that integrates ethical considerations, fosters technical innovations, encourages robust policy discussions, and promotes interdisciplinary collaboration.

Endnotes

1 John Novembre et al., "Genes Mirror Geography Within Europe," *Nature* 456 (2008): 98–101, <https://www.ncbi.nlm.nih.gov/pmc/articles/PMC2735096/>.

2 Melanie Lefkowitz, "Professors Perception Paved the Way for AI—60 Years too Soon," *Cornell Chronicle*, September 25, 2019, <https://news.cornell.edu/stories/2019/09/professors-perceptron-paved-way-ai-60-years-too-soon>.

- 3 Frank Rosenblatt, "The Design of an Intelligent Automaton," *Research Trends* 6, no. 2 (1958): 1–7; Lefkowitz, "Professors Perception Paved the Way for AI—60 Years too Soon."
- 4 Sebastian Rashka, "Single-Layer Neural Networks and Gradient Descent," *Sebastian Rashka* (blog), March 24, 2015, https://sebastianrashka.com/Articles/2015_singlelayer_neurons.html.
- 5 Gabor Melli, "Multi Hidden-Layer (Deep) Neural Network," Gabor Melli's Research Knowledge Base, updated February 27, 2024, [https://www.gabormelli.com/RKB/Multi_Hidden-Layer_\(Deep\)_Neural_Network](https://www.gabormelli.com/RKB/Multi_Hidden-Layer_(Deep)_Neural_Network).
- 6 An Tang, et al., "Canadian Association of Radiologist White Paper on Artificial Intelligence in Radiology," *Canadian Association of Radiologists Journal* 69 (2018): 12–135, <http://dx.doi.org/10.1016/j.carj.2018.02.002>.
- 7 Micheal Kearns, "Responsible AI in the Generative Era," *Amazon Science* (blog), May 3, 2023, <https://www.amazon.science/blog/responsible-ai-in-the-generative-era>.
- 8 OpenAI, DALL-E 2, accessed April 2024, <https://labs.openai.com/>.
- 9 Rishi Bommasani et al., "On the Opportunities and Risks of Foundation Models," Center for Research on Foundation Models (CRFM) and Stanford Institute for Human-Centered Artificial Intelligence (HAI) Stanford University (July 12, 2022), <https://arxiv.org/pdf/2108.07258.pdf>.
- 10 Thomas Davenport and Niin Mittal, "How Generative AI is Changing Creative Work," *Havard Business Review*, November 14, 2022, <https://hbr.org/2022/11/how-generative-ai-is-changing-creative-work>.
- 11 Alex Zhavoronkov, "Wu Dao 2.00—Bigger, Stronger, Faster AI from China," *Forbes*, July 19, 2021, <https://www.forbes.com/sites/alexzhavoronkov/2021/07/19/wu-dao-20bigger-stronger-faster-ai-from-china/?sh=77cdc5246fb2>.
- 12 Emma Strubell, Ananya Ganesh, and Andrew McCallum, "Energy and Policy Considerations for Deep Learning in NLP," *College of Information and Computer Sciences, University of Massachusetts Amherst*, June 5, 2019, <https://arxiv.org/abs/1906.02243>.
- 13 Daniel Solove, "A Taxonomy of Privacy," *University of Pennsylvania Law Review* 154, no. 3 (January 2006): 477–560, https://scholarship.law.gwu.edu/cgi/viewcontent.cgi?article=2074&context=faculty_publications.
- 14 Cynthia Dwork, Vitaly Feldman, Mortiz Hardt, Toniann Pitassi, Omer Reingold, and Aaron Roth, "The Reusable Holdout: Preserving Validity in Adaptive Data Analysis," *Science* 349, no. 6248 (August 7, 2015): 636–638, <https://www.science.org/doi/10.1126/science.aaa9375>.
- 15 Nicolas Carlini, et al., "Extracting Training Data from Large Language Models," *Proceedings of the 30th USENEX Security Symposium* (2021): 2633–2650, <https://www.usenix.org/system/files/sec21-carlini-extracting.pdf>.
- 16 Carlini, et al., "Extracting Training Data from Large Language Models."
- 17 Mia Xu Chen et al., "Gmail Smart Compose: Real-Time Assisted Writing," *Proceedings of the 25th ACM SIGKDD International Conference on Knowledge Discovery & Data Mining* (July 2019): 2287–2295, <https://arxiv.org/pdf/1906.00080.pdf>.
- 18 Nicholas Carlini et al., "Extracting Training Data from Diffusion Models," January 30, 2023, <https://arxiv.org/pdf/2301.13188.pdf>.
- 19 Carlini et al., "Extracting Training Data from Diffusion Models."
- 20 Douglas Harris, "Deepfakes; False Pornography is Here and the Law Cannot Protect You," *Duke Law & Technology Review* 17 (2019): 99–127, <https://scholarship.law.duke.edu/dltr/vol17/iss1/4/>.
- 21 Emily Flitter and Stacy Cowley, "Voice Deepfakes are Coming for Your Bank Balance," *The New York Times*, August 30, 2023, <https://www.nytimes.com/2023/08/30/business/voice-deepfakes-bank-scams.html>.
- 22 Ziad Obermeyer, Brian Powers, Christine Vogeli, and Sendhil Mullainathan, "Dissecting Racial Bias in an Algorithm Used to Manage the Health of Populations," *Science* 366, no. 6464 (October 25, 2019): 447–453, <https://www.science.org/doi/10.1126/science.aax2342>.
- 23 Muhammad Ali et al., "Discrimination through Optimization: How Facebook's Ad Delivery Can Lead to Skewed Outcomes," *Proceedings of the ACM on Human-Centric Interaction* 3 (2019): 1–30, <https://arxiv.org/abs/1904.02095>.
- 24 Jeffrey Dastin, "Insight – Amazon Scraps Secret AI Recruiting Tool that Showed Bias Against Women," *Reuters*, October 10, 2018, <https://www.reuters.com/article/us-amazon-com-jobs-automation-insight/amazon-scraps-secret-ai-recruiting-tool-that-showed-bias-against-women-idUSKCN1MK08G>.
- 25 Solove, "A Taxonomy of Privacy."

- 26 Mathew Gault, "AI Spam is Already Flooding the Internet and It Has an Obvious Tell," *Vice*, April 24, 2023, <https://www.vice.com/en/article/Sd9bvn/ai-spam-is-already-flooding-the-internet-and-it-has-an-obvious-tell>.
- 27 "Brace Yourself for a Tidal Wave of ChatGPT Email Scams," *Wired*, April 4, 2023, <https://www.wired.com/story/language-model-phishing-scams/>.
- 28 Kathleen McGrory and Neil Bedi, "Targeted," *Tampa Bay Times*, September 3, 2020, <https://projects.tampabay.com/projects/2020/investigations/police-pasco-sheriff-targeted/intelligence-led-policing/>.
- 29 Cynthia Dwork, Frank McSherry, Kobbi Nissim, and Adam Smith, "Calibrating Noise to Sensitivity in Private Data Analysis," *Lecture Notes in Computer Science* 3876 (2006): 265–284, https://link.springer.com/chapter/10.1007/11681878_14.
- 30 Franziska Boenisch et al., "When the Curious Abandon Honesty: Federated Learning is Not Private," *Proceedings of IEEE 8th European Symposium on Security and Privacy* (2023): 175-199, <https://arxiv.org/abs/2112.02918>.
- 31 Peter Kairouz et al., "Practical and Private (Deep) Learning without Sampling or Shuffling," December 13, 2021, <https://arxiv.org/abs/2103.00039>.
- 32 Fairlearn, accessed May 2023, <https://fairlearn.org/>.
- 33 John Kleinberg, Sendhil Mullainathan, Manish Ragavan, "Inherent Trade-Offs in the Fair Determination of Risk Scores," November 17, 2016, <https://arxiv.org/abs/1609.05807>; Alexandra Chouldechova, "Fair Production with Disparate Impact: A Study of Bias in Recidivism Prediction," *Big Data* 5, no. 2 (2017): 153-163, <https://www.liebertpub.com/doi/abs/10.1089/big.2016.0047>.
- 34 Julia Angwin, Jeff Larson, Sura Mattu, and Luren Kirchner, "Machine Bias," *ProPublica*, May 23, 2016, <https://www.propublica.org/article/machine-bias-risk-assessments-in-criminal-sentencing>.
- 35 Kleinberg, "Inherent Trade-Offs in the Fair Determination of Risk Scores"; Chouldechova, "Fair Production with Disparate Impact."
- 36 Bowen Yu, Ye Yaun, Loren Terveen, Zhiwei Steve Wu, Jodi Forlizzi, Haiyi Zhu, "Keeping Designers in the Loop: Communicating Inherent Algorithmic Trade-Offs Across Multiple Objectives," *Proceedings of ACM Designing Interactive Systems Conference* (2020): 1245-1257, <https://dl.acm.org/doi/10.1145/3357236.3395528>.
- 37 Youyang Qu, Xin Yuan, Ming Ding, Wei Ni, Thierry Rakotoarivelo, David Smith, "Learn to Unlearn: A Survey on Machine Unlearning," October 26, 2023, <https://arxiv.org/abs/2305.07512>.
- 38 "High-Level Summary of the AI Act," *EU Artificial Intelligence Act*, February 27, 2024, <https://artificialintelligenceact.eu/high-level-summary/>.

CHAPTER 9

Cybersecurity and Privacy

Hanan Hibshi¹

Computer security—commonly also called cybersecurity and information technology (IT) security—seeks to maintain the correct and intended functioning of computer systems in the face of attacks.

Security and privacy in computer systems are closely connected but are not the same. Probably the most visible aspect of this connection is that many privacy breaches are the result of security failures—unpatched software bugs, poorly configured security

mechanisms, or reuse of credentials—that enable an attacker to compromise a computer system and steal sensitive private data. A system can have security measures in place that protect against malicious actors, but these same security measures do not guarantee stakeholders’ privacy. However, a system cannot protect privacy without enforcing the privacy promise using security mechanisms like encryption.

In the May 2017 Equifax data breach, for example, over 100 million people’s sensitive information was stolen, including names, Social Security numbers, dates of birth, and credit card numbers.² Two failures conspired to make this breach possible. The first was a bug in the software that Equifax used to build its web apps.³ This bug made it possible for an attacker to trick the web server hosting the Equifax website into running software created by the attacker. Clearly, this bug could be taken advantage of to perpetrate a range of harms, including stealing data, which is what happened. The second failure was a process failure. It turns out that the software bug in question was fixed by the vendor in March of 2017—two months before it was taken advantage of to perpetrate the breach. It was public knowledge that the bug had been fixed and an updated version of the software was available in March. If appropriate processes had been instituted for reacting to newly disclosed vulnerabilities, Equifax’s website might have been updated, and this particular method of attacking the website would not have succeeded.

The Equifax example shows software vulnerabilities and failures in security processes can lead to privacy breaches. There are many other connections between computer security and privacy, however. To mention but a few: Many of the aspects of computer security that concern themselves with process and regulation, rather than directly with technical security mechanisms, have analogues that specifically concern privacy rather than, or in addition to, security. The specific security goals we try to achieve by implementing security mechanisms are often also privacy goals, but sometimes achieving a security goal will come at the expense of privacy. Security mechanisms themselves can have software vulnerabilities or other flaws that allow an attacker to circumvent the protection mechanism.

This chapter provides an overview of the aspects of computer security that are most relevant to privacy. We will start by discussing the different places in the systems development life cycle where security activities need to take place, referring to the categories of computer security work defined by the U.S. National Institutes of Standards and Technology’s (NIST’s) National Initiative for Cybersecurity Education (NICE) Framework.⁴

Next, we will provide an overview of the ways software fails, either in the face of an attack or when left to its own devices. Following that, we examine the so-called CIA triad of properties—confidentiality, integrity, and availability—that security mechanisms commonly seek to provide. The careful reader will immediately notice one of these, confidentiality, is important for achieving privacy goals. It turns out the others are significant as well and not just because they are tightly connected to each other. We will also discuss “access control,” the process by

which a computer system tries to ensure data is only accessed or modified by the users who have the right to do so.

Then, we review some of the basic principles for designing secure software, like the least privilege principle and the defense in-depth principle, both of which are important even when the main focus is on preventing privacy leaks that are not the result of security failures.

Finally, this chapter discusses a collection of operational processes or issues that impact security and privacy. Some of these processes are for detecting and reacting to breaches or for learning about and reacting to discovered vulnerabilities—either of which could have helped avoid most of the data theft that took place during the Equifax breach. Another concern is today’s common practice of allowing employees to use their personal computers or mobile devices for company needs, usually referred to this as “bring your own device” (BYOD). We examine how managing these operational issues causes privacy to sometimes be traded off for convenience or security.

9.1 The Breadth of Computer Security Work

Keeping computer systems and their data secure is a large task composed of many specialized ones. As part of many of these tasks, privacy goals also need to be specifically considered and privacy considerations weighed. One taxonomy of computer security work, i.e., of the tasks that need to be accomplished to keep computer systems secure, is advanced by NIST’s NICE Framework. The NICE Framework divides computer security work into the following categories: securely provision, operate and maintain, protect and defend, and investigate, which can be thought of as focusing on a specific computer system, and analyze, oversee and govern, and collect and operate, which generally have a broader scope. A summary of categories and their descriptions are shown in Table 9-1.

Table 9-1: NICE Framework computer security work categories²

Category	Code	Description
Securely provision	SP	Conceptualizes, designs, procures, and/or builds secure IT systems with responsibility for aspects of system and/or network development.
Operate and maintain	OM	Provides the support, administration, and maintenance necessary to ensure effective and efficient IT system performance and security.
Protect and defend	PR	Identifies, analyzes, and mitigates threats to internal IT systems and/or networks.
Investigate	IN	Investigates cybersecurity events or crimes related to IT systems, networks, and digital evidence.
Oversee and govern	OV	Provides leadership, management, direction, or development and advocacy so the organization may effectively conduct cybersecurity work.
Collect and	CO	Provides specialized denial and deception operations and collection of cybersecurity

operate		information that may be used to develop intelligence.
Analyze	AN	Performs highly specialized review and evaluation of incoming cybersecurity information to determine its usefulness for intelligence.

9.1.1 Securely Provision

This category encompasses the tasks narrowly focused on developing software to be secure. Software development starts with system requirements planning, during which both security and privacy requirements must be defined. These are drawn from various stakeholders, such as potential customers, and may include legal and regulatory considerations. For example, the software may need to be designed to support the controls mandated by the EU General Data Protection Regulation (GDPR), such as the ability to efficiently identify all the personal data stored in a computer system that belongs to a single individual.

After requirements are defined and before writing the software starts, the architecture of a system is designed. This may include deciding on the technologies that will be needed or the way the tasks or data of the system will be organized to fulfill both the functional requirements and security and privacy requirements of the system. For example, a large system that has users from multiple countries may partition its data storage into multiple databases that can be geographically located to comply with national privacy regulations that specify where the data of a country's nationals may be held.

Technology research and development may be needed during the early phases of system design if existing solutions cannot meet the requirements.

After a system is architected, software development starts. In this system-creation phase, the requirements and system architecture are turned into a functional computer system. This may involve writing new software to implement desired functionality or, more commonly, modifying and building on existing software.

As system elements become sufficiently developed, they are subjected to tests and evaluation. This phase of systems development ensures each component of the system, as well as the system as a whole, meets its requirements.

Two additional work areas span the aforementioned phases of developing a system. One, simply called "systems development," focuses on ensuring all the phases—from gathering requirements to testing the finished system—take place and that each phase is subdivided into the activities needed to effectively carry it out. The other work area, "risk management," is responsible for identifying, documenting, and managing any risks posed by the system. These risks may be related to software quality as defined by the internal standards of the organization creating the software, compliance with regulations, or security and privacy. Some risks may be identified in the requirements phase and mitigated through system architecture design. Other risks may be mitigated after the system is deployed; for example, by providing additional training to users to prevent them from creating easily guessed passwords.

9.1.2 Operate and Maintain

The operation and maintenance of a system is just as critical to its security and privacy goals as the way the system was created in the first place. “Systems administration” ensures a system is installed and configured, both initially and over time, to meet security and privacy goals. “Network services” concern similar tasks for the computer networks across which a system is deployed or that users employ to interact with the system. “Customer service” and technical support are sometimes overlooked when it comes to thinking about the security and privacy of a system, with dire consequences. Many attacks on computer systems—for instance, those that lead to theft of proprietary or personal data—target customer service and technical support. An example is phone SIM-card-swapping attacks, where an attacker tricks a mobile phone service provider into switching a victim’s phone number to the attacker’s device.⁶ The attacker can then use the stolen phone number to reset the victim’s online banking and other passwords and thus gain access to the victim’s private information and more.

Systems often generate or accumulate large volumes of potentially sensitive data. “Data administration” is concerned with managing the databases that house this information. Other aspects of operating a system as defined by the NICE Framework include “systems analysis,” which examines the interoperation of an organization’s systems, and “knowledge management,” which focuses on the processes and tools for ensuring an organization can keep track of the systems it has created and how to operate them.

9.1.3 Protect and Defend

In addition to the previously described activities, part of attempting to ensure a system will not be compromised is actively protecting the system. This includes “vulnerability assessment and management,” assessing and developing plans to address threats posed by attackers and defending vulnerabilities in the system. Preventing or detecting attacks often requires infrastructure such as firewalls that prevent malicious network traffic and monitoring systems that make it possible to detect attacks. Systems that detect patterns of bad behavior, usually by monitoring the network, are referred to as intrusion detection systems (IDS). If these systems can further take action to block the malicious activity, then they are intrusion prevention systems (IPS). With the increased adoption of artificial intelligence (AI), IDS and IPS are becoming smarter, more efficient, and an active area of research and development. A simple example how banking systems detect possible fraudulent operations. The algorithms in the software detect anomalies or unusual transactions, such as those in large amounts, repeatedly from the same merchant, or with different geo-locations. The system can inform the customer (detection) or block the transaction (prevention). This practice of pattern matching can further be applied anywhere one can find a pattern in the system. For examples, anomalies can be detected in network packets (e.g., spoofed IPS, requests to contact known bad services such as malware servers, large file transfers to a remote server,

certain foreign IP addresses, etc.) and the software can be limited to detection and inform system admins, or further take action to prevent the malicious activity. Pattern-matching algorithms can benefit from the advances in machine learning (ML) and AI, which makes researching new AI solutions to improve IDS/IPS a promising area of research to help detect more complex attacks like advanced persistent threats (APTs). The 2017 Equifax data breach is a good example of an advanced persistent threat that could be prevented with a reliable IDS/IPS. Creating and managing these is called “cyber defense infrastructure support.” Using these defensive components to prevent or detect attacks is called “cyber defense analysis.”

Finally, “incident response” takes place when attacks do occur. It is the process of documenting the details of the attack, determining the impact of the attack on the system, and deciding on the appropriate actions. The actions may include remedial measures to restore the system to a working state, notifications to users who may have been affected, and development of plans to fix any software vulnerabilities that made the attack possible.

The importance of these tasks is highlighted by recent data breaches, such as the Equifax breach and earlier Target credit card breach, in which some of these tasks seem not to have been effectively carried out and this failure significantly contributed to the success of the attack or its fallout.² In the Equifax breach, for example, knowledge of the vulnerability exploited by the attacker, as well as the fix for that vulnerability, was disseminated across standard channels; yet the vulnerability was not sufficiently addressed to prevent the attack. Unfortunately, Equifax was not an exception. Multiple surveys indicate many successful attacks would have been prevented by patching systems more promptly.⁸

Protecting and defending systems, as well as operating and maintaining them, involves trade-offs between privacy and security, one of which relates to how much data is collected about how an app, system, or network is used. Collecting more data may make it possible to detect attacks that might otherwise remain hidden and to better diagnose why a system did not perform as expected. In doing so, collecting more data may make it possible to make systems more secure and indirectly lower privacy risks associated with security breaches. On the other hand, collecting detailed usage information itself increases privacy risks, for example, for users whose detailed behavioral information is now stored and could be misused or lost, as well as for the organizations that take on the risks associated with safeguarding this information. One way of mitigating the risk of collecting more information is to carefully anonymize or pseudonymize any personal identifiers.

9.1.4 Investigate

If a system is compromised through an attack, a thorough, timely investigation is important for the following reasons:

1. to discover what specific data may have been compromised, for example so consumers can be notified;

2. to discover the specific method of compromise, so similar attacks can be avoided in the future; and
3. to identify who perpetrated an attack, so they can be prosecuted.

As previously alluded to, the success of an investigation may hinge on how much data is collected about a system's operation. The NIST NICE Framework includes several other cybersecurity work categories that impact individual systems but also have a broader scope.

9.1.5 Oversee and Govern

This category of work deals with aspects of cybersecurity work such as legal advice, executive leadership, and training and education. Relevant legal aspects could include awareness of and adherence to privacy laws, such as the GDPR. Training could include requiring a subset of developers to be trained in privacy engineering.

9.1.6 Collect and Operate and Analyze

These two areas of work deal with the collection of intelligence, including information about potential attackers' capabilities, intentions, and possible ongoing activities. Activities in these work areas inform activities in the other work areas. For example, if an attack seems likely, then the effort invested into defense might increase or the requirements might reflect that a system needs to be constructed to be more robust to attacks.

9.2 Attacks and What Makes Them Possible

Attacks that involve breaking into computer systems usually involve some combination of exploiting a software flaw, using malicious software, and acquiring and using stolen login credentials. On the other hand, denial-of-service (DoS) attacks do not involve breaking into systems but can cause substantial harm.

9.2.1 Software Vulnerabilities

Many attacks on computer systems involve a software error or bug. "Software vulnerabilities" are software bugs that an attacker can take advantage of to carry out an attack. Not every bug is a vulnerability. For example, if a programmer incorrectly implemented some mathematical operation so it gives the wrong answer, we would call it a bug. If this mistake does not present an attacker with a way to attack the program that performed this computation, we would not call it a vulnerability.

Probably the most well-known type of software vulnerability is a "buffer overflow." A buffer is a contiguous area in the memory used by a program. When copying data into a buffer, it is important to make sure the data is smaller than the buffer. If the data being copied into the buffer is bigger than the buffer, and appropriate checks to detect this are not in place, then the data that does not fit in the buffer may overwrite memory immediately next to the buffer—

hence the name buffer overflow. Suppose the attacker is able to control the data being copied into memory. In that case, they may be able to choose how memory is overwritten in a way that allows them to alter the intended behavior of the program. With enough sophistication, such alterations can allow attackers to execute arbitrary code on the victim's machine. Since the famous internet Morris Worm in 1988, buffer overflow vulnerabilities continue to rise and are seen in almost every system. Examples of apps affected by buffer overflows include macOS, IOS, Whatsapp, OpenSSL libraries, and others. The buffer overflow vulnerability that was discovered in WhatsApp in 2019 had a serious impact on privacy, as attackers could gain access to private messages and turn on cameras and microphones.²

An “input-validation flaw” is a closely related type of software flaw that makes it possible for an attacker to exploit a buffer overflow. Software often receives input from untrusted sources that it uses to guide its computation. For example, a search engine allows a user to type in a search string, which is input to the program that implements the search functionality. If this input string contains characters or sequences of characters the program is unprepared for, it might execute unexpectedly. As previously described, common attacks that take advantage of input-validation flaws are buffer overflow attacks, “cross-site scripting” (XSS), and “structured query language (SQL) injection attacks.” XSS attacks take advantage of input-validation flaws in a website or web app to inject code into a user's web browser, which can then take any data available to a legitimate user and send it to the attacker. XSS was allegedly responsible for a 2018 breach of the British Airways website that led to the theft of financial and personal data belonging to 380,000 customers.¹⁰ In SQL injection attacks, specially crafted inputs that are not expected by the app cause database queries to go awry. An SQL injection attack was responsible for the theft of over 100 million debit and credit card numbers from Heartland Payment Systems in 2012, which was at the time the biggest data breach ever.¹¹

9.2.2 Malware

Attacks on computer systems often involve “malware,” which are malicious programs designed by the attacker. Malware can be installed on a victim user's computer in many ways including using embedded malicious links in phishing emails, exploiting a software vulnerability, or at times when the attacker has unfettered access to the computer; for example, when software is being loaded onto the computer before it is sold. Malware causes a wide range of harms. “Keyloggers,” for example, are a type of malware that records a user's keystrokes, including when typing usernames and passwords. A keylogger was used as part of an attack on Cathay Pacific Airways in 2018, which led to the information of more than nine million passengers being exposed.¹²

Malware often changes the behavior of a computer system to avoid being detected. Such malware is commonly called a “rootkit.” Because they are hard to detect, rootkits can run on an infected computer for a long time, potentially stealing user information or using the

computer for nefarious purposes, such as distributing spam. Malware sometimes coordinates with “command-and-control servers” to put large sets of computers under the control of a single organization. Such a set of computers is called a “botnet,” and each infected computer is called a “bot.” Attackers often use botnets to mount “distributed denial-of-service” (DDoS) attacks, in which the computers that are part of a botnet are instructed to connect to or interact with a victim server. If the botnet is large enough, the victim server may be overwhelmed with requests and crash. In 2016, a DDoS attack on domain name servers, a part of the internet infrastructure, disabled many high-profile sites such as Twitter, Netflix, and CNN.¹³ According to the 2019 Verizon Data Breach and Incident Report, DDoS attacks in fact account for the majority of all security incidents.

9.2.3 Stolen Credentials

Most attacks in which an attacker breaches a computer system involve stolen credentials.¹⁴ Attackers obtain legitimate users’ usernames and passwords and then access a victim system under the guise of a legitimate user. The credentials can come from many sources. They may have been stolen in previous attacks and made available on the internet, free of charge or for a fee. They may have been captured by keyloggers installed by the attackers themselves, or they may have been collected through “phishing.”

Phishing is a type of “social engineering attack” in which a victim is tricked into logging in to what they think to be a legitimate site, but which is actually a front set up by the attacker to collect users’ login credentials. Phishing attacks are commonly delivered via email, for example in the guise of messages asking users to reset their passwords. Besides tricking users into revealing their credentials, phishing attacks might trick or coerce victims into sending money to the attackers, for example by asking to send money to a relative stranded on a trip or by threatening to release nonexistent compromising information about the victim. Most phishing attacks are not customized to specific potential victims. the same phishing email asking to send money to a stranded relative might be sent to many potential victims. In “spear phishing,” on the other hand, attackers customize their messages to include personal information they have already uncovered about the victim, such as by using the actual name of a relative of the victim when asking for money to be sent. Spear phishing attacks sometimes target high-value individuals, for example executives whose credentials may be particularly valuable. This variant of phishing is called “whaling.”

Spear-phishing attacks are particularly successful. They are made easier by the amount of information that can easily be discovered about potential victims, for example on both professional networking sites like LinkedIn and social networking sites like Facebook.

9.2.4 Misconfiguration, Insider Threats, and Other Types of Attacks

Another common cause of breaches is misconfiguration. Sometimes, one of several security mechanisms is misconfigured, which does not leave the system or its data completely exposed but makes it easier for an attack to succeed. A misconfigured firewall, for example,

was part of the cause of a 2019 breach of 109 million records from Capital One.¹⁵ Misconfiguration often leaves sensitive data publicly accessible to anyone who stumbles across it, even though stumbling across it may be unlikely. UW Medicine inadvertently exposed more than a million customers' records containing personal health information in 2018. In that case, not only had internal files containing sensitive data accidentally been made publicly accessible, but they also became accessible to internet search engines. The leak was discovered by a patient finding the sensitive files when they searched for their name via Google.¹⁶

Many attacks are perpetrated by or take advantage of insiders, who are users with elevated access or knowledge that can benefit the attacker. Insiders with access to sensitive information may decide to change jobs and take the sensitive information with them. In a famous recent alleged insider data breach, a Google employee working in its autonomous car division left the company and took thousands of files related to its autonomous car technology. The lawsuit was settled.¹⁷ An even more famous example is Edward Snowden's theft of thousands of classified documents, some of which he was authorized to access with his credentials and others he accessed with credentials from coworkers.¹⁸ Insider threats are particularly challenging to manage. Doing so can involve instituting additional monitoring, often at the cost of employees' privacy, instituting additional access-control checks, discussed in section 9.4, and other safeguards such as prohibiting the use of USB devices, which can interfere with efficiency and convenience.

Another challenge is possible security issues with service providers. Software systems evolved over the years to become systems of systems, and it is common for systems to use third-party service providers like cloud providers, networks, or web email. A breach in the service provider's system would affect the systems of all other organizations and industry partners. For example, a 2022 data breach that targeted LastPass, a widely adopted password manager tool, affected end-users and all organizations where users used LastPass to store their passwords.¹⁹ Moreover, service providers are trusted and could have increased access privileges that increase their capability of violating security properties due to attacks or insider threats at the provider level.

9.3 Security Properties and Types of Adversaries

So far, we have not discussed what it means for a computer system to be secure. For such a discussion to be meaningful, security must be defined more concretely, in terms of specific properties. The properties most used to describe the security goals of a computer system are confidentiality, integrity, and availability.

"Confidentiality," also called secrecy, refers to keeping sensitive data away from unauthorized users, including attackers. Depending on the data in question, a failure to protect confidentiality may also be a failure to protect privacy. The various data breaches discussed in this chapter are violations of confidentiality goals, and, because the data in

question is sensitive and associated with individuals, they are also violations of privacy. “Integrity” refers to preventing unauthorized modification of data, which could include replacing a correct value with an incorrect one or deleting data. While the link between integrity and privacy may not be as immediately clear as the link between confidentiality and privacy, there is nevertheless a strong connection between the two. Privacy regulations such as the GDPR explicitly call data quality a requirement. This typically refers to collected personal information being correct and complete, which it could fail to be either because of errors or omissions at data collection time or because of failures to maintain the integrity of the data once it has entered a computer system. The last of the CIA triad properties, “availability,” focuses on ensuring computer systems are available to legitimate users even when attacked. Availability is also important for privacy, as implementing fair information practices often requires positive action, such as notifying consumers of a change in data usage policy or providing consumers with timely access to their data. Interfering with the availability of systems that support these positive actions may also interfere with those actions, which are in support of privacy.

The CIA triad requirements are in tension with each other. Many ways to achieve one requirement may make another harder to accomplish, so computer systems typically try to balance the extent to which they achieve these requirements. For example, to prevent the inadvertent or malicious deletion of data, which is part of ensuring the data’s integrity, many copies of the data may be kept. However, this may increase the risks to confidentiality, since it may now be possible for an attacker to gain access to the data if they successfully breach any one of the systems on which the data is replicated. As another example, databases are sometimes replicated in multiple locations to ensure data can be accessed quickly and when network links are down. This improves availability but may pose challenges to integrity. If a data item is changed in multiple locations in different ways, it may be difficult to determine which change should be considered the right one.

In addition to the CIA triad, other properties such as authentication, authorization, and accountability need to be considered, as threats to these properties not only put security at risk but could lead to data breaches impacting privacy. Hence, a good approach is to analyze security risk using the word STRIDE as an acronym for the following threats:²⁰

- **Spoofing** an entity, which can be mitigated by authentication.
- **Tampering** and altering data, which can be mitigated by integrity.
- **Repudiation** that involves denying responsibility for an action and can be mitigated with nonrepudiation. For example, digital signatures and audit logs can help provide the nonrepudiation property.
- **Information disclosure** of data, which can be mitigated with confidentiality or secrecy.

- **Denial of service** that impacts the availability property.
- **Elevation of privilege** where attackers gain unauthorized access to data and resources they could potentially use to leak data and information about users. Elevation of privilege can be mitigated by proper authorization.

A critical concept in computer security is that of an adversary. As previously discussed, desired security properties may be in tension with each other. To understand the degree to which a particular set of mechanisms will be able to achieve these properties, it is also necessary to consider the computational capabilities and knowledge available to an adversary. For example, the mechanisms employed to maintain data integrity against an external attacker may not be adequate to protect against insider threats. On the other hand, the mechanisms needed to achieve a property even in the face of a very powerful adversary—for example through adding expensive cryptographic protection and many security checks—may make a system so painful to use that it interferes with its availability, which might, in turn, make the system unappealing to potential users.

9.4 Access Control

Protecting the integrity and confidentiality of data while it is stored on disk (data-at-rest), while it is used (data-in-use), or while it is in transit (data-in-motion), is typically accomplished through the use of cryptography. See chapter 3 for definitions of data-in-use, data-at-rest, and data-in-motion. Cryptographic primitives are algorithms that provide the building blocks of cryptographic protocols and include hash functions like Secure Hash Algorithm 256 (SHA-256), symmetric keys like Advanced Encryption Standard (AES), and public key cryptographic algorithms like Rivest, Shamir, and Adleman's (RSA).

Cryptography is discussed in more detail in chapter 3. For now, we will say only that the functionality of the most commonly used cryptographic primitives is defined specifically in terms of their ability to provide secrecy or integrity. Encryption provides secrecy, although many implementations of encryption do not provide integrity. Integrity is provided by digital signatures and message authentication codes, although these accomplish nothing for secrecy. Hence, when using cryptography to protect data, it is critical to choose the cryptographic primitive that provides the property we wish to achieve.

For data to be useful, it needs to be accessed, either to be shown to consumers, used in a computation, or updated, as in the case of a database entry that holds a consumer's home address after they have moved. Some methods of accessing data to use it in a computation rely on a variant of encryption called "homomorphic encryption" to perform these computations without ever decrypting the data. In most practical cases, however, when data needs to be read or written, there is no technical mechanism to stop a user who was permitted to access data from using it or changing it in potentially unexpected or unwelcome ways. Hence, it is very important to ensure data can only be accessed by authorized users,

and these users can only manipulate the data in specific, permitted ways. For example, designated users within an enterprise may be authorized to access clients' email addresses in a database, but only for the purpose of retrieving them. The same users may not have been authorized to change those addresses. "Access control" is the process of controlling which users have access to which data and in which way. In enterprise settings, access control is sometimes called identity management. Access control consists of two major parts: "authentication," or determining the identity of the user who is attempting to access a resource, and "authorization," or determining whether a request to access a resource typically, but not always, by an authenticated user should be granted.

9.4.1 Authentication

For the purpose of specifying access-control policy, as well as for making access-control decisions, the identity of a human user is typically abstracted in a computer system as their username or another similar label. Before allowing access to protected resources, however, the computer system must identify the actual human being sitting behind the keyboard. This process is called "authentication" and is discussed in detail in chapter 4. Informally, authenticating to a computer system is often called "logging in."

Different methods of authenticating a user may lead to different confidence levels that this identification was correct. For example, an authentication based on a username and a password will not be as confident as an authentication requiring the user to input a temporary code generated by an app on their mobile phone. This is because an attacker is more likely to have stolen a username and password than to have done that and also stolen the user's mobile phone. Access-control systems, such as Microsoft's Dynamic Access Control, can capture this distinction in authentication confidence. Policy can specify, for example, that particularly sensitive files can be accessed only by a permitted set of users, and only when those users have confirmed their identity via a method in addition to providing the correct username and password.

In many situations, the system component that authenticates a user learns various private information about the user, such as their phone number, date of birth, or mother's maiden name. Authentication systems can also ask users to supply answers to security questions, which are typically personal questions with correct answers that are unlikely to be known to people other than the specific user. Such additional personal information and answers to security questions are often used to authenticate users who have forgotten their password. This kind of authentication is called "backup authentication" since it takes place only when the main approach to authentication cannot be used. This additional information may also be used when more confidence is desired of the authentication decision, such as at the time of the first observed authentication attempt from a different computer than the one the user previously authenticated. The fact that the authentication component learns various private information about users has consequences for privacy. Among them, users may be forced to

divulge personal information they would prefer not to share and the accumulation of such personal information raises the chance of harm, should the authentication component be compromised by an attack and the information stolen by an attacker.

9.4.2 Authorization (or Access-Control) Mechanisms

Authorization consists of “mechanism,” which is the technical means for allowing or denying access, and “policy,” which is the specification of who should be allowed or denied which kind of access and under what circumstances. Ideally, the capabilities of an access-control mechanism match what the access-control policy seeks to accomplish. For example, if an access-control policy states some users should have only read access to data and others should have both read and write access, then the access-control mechanism should provide the capability of giving access to data in a mode in which it can be read but not changed, as well as a mode in which it can be both read and changed.

Deployed access-control mechanisms are sometimes not flexible enough to implement the policies we wish to implement. For example, a financial advisor at a bank may work with a specific set of clients, so ideally the advisor’s access to the bank’s customer database should be constrained to just the data belonging to their clients, which may correspond to specific rows in a relational database. Yet, some popular databases, like MySQL, do not natively implement access-control mechanisms that control access at a per-row level. In such a situation, either additional access-control mechanisms need to be manually added through software, which can be laborious and prone to errors, or it may be impossible to give users access to only specific rows in the database.

As these examples show, access-control mechanisms can differ in the granularity at which they protect data as well as in the type of access they are able to regulate. With respect to the granularity of access, we discussed access to database tables versus access to rows in database tables. Access to data stored in files on a computer system is typically regulated at the granularity of files. In other words, it is rarely possible to specify that a user be allowed access to just part of a file. Access control applies not just to users but also to programs, which often run on behalf of a user or set of users. A program may run on behalf of a specific user, in which case it can typically access only the data and resources for which that user is authorized. Some programs run on behalf of any user and so may, in principle, need to be able to access any data that any of their users can access. Web server software is typically in this category since it often needs to provide services to anyone on the internet. Hence, the program that implements a banking website may have access to the financial information of all the bank’s clients, but it would implement additional mechanisms to try to ensure any specific instance of the web server program accesses only the data of the specific client who logged into it.

With respect to the type of access, we discussed the distinction between *read* and *write* access to data. The types of access sometimes supported are far richer. For example, the New

Technology File System (NTFS) by recent versions of Microsoft Windows also supports read and execute access, modify access, and list folder contents access. Hence, it is possible to specify that a user may read a program file but not execute the program, or that a user is allowed to change the content of a file but not delete it.

9.4.3 Access-Control Models

Access-control systems differ in their approaches to specifying policy. The different approaches to specifying policy are often called “access-control models.” Access-control models are typically based around subjects, the users or programs who may be granted or denied access, and objects, the resources to which access is regulated. We have so far discussed files and database tables as examples of objects. Other objects we might want to control access to could be functions—to distinguish who may invoke sensitive functions, for instance—and other computer resources, such as network interfaces.

Access-control mechanisms help enforce access-control models. One mechanism for specifying access-control policy is using access-control lists (ACLs). In this approach, every object is annotated with a list of the subjects who are allowed to access it, and the type of access that they are allowed. The subjects could be identified individually, but they could also be consolidated into groups, such as administrators. In this case, the group name is used as the subject, and a separate specification describes which individuals belong to which groups. Modern versions of Linux generally support ACLs.

User-based access control (UBAC) or identity-based access control is the most straightforward to understand. Permissions are defined by each user, allowing for fine granularity. For example, the manager of a project can have access to all files without needing to give group access to other members of the project to avoid leakage of sensitive information. However, one can imagine defining and managing access control at the user level can have practical implementation problems. When using mechanisms like ACLs in Linux, it might become tedious to provide file/object/resource permissions at a user level, so in practice, user groups are used. If these groups are course-grained, then users will have more access privileges than needed.

Another popular model, “role-based access control” (RBAC), specifies who is allowed access in terms of roles. A user may be associated with several roles, for example for each of their responsibilities within an enterprise. The right to access data objects, such as files on a file system, is similarly associated with roles rather than directly with individual users. The access-control system will then give a user access to a file based on whether the file is labeled with the role has been assigned to that user. Because permission to access specific files and resources is specified through roles, it can be easier to keep up to date than if permission is specified in terms of individual users. For example, when a user is assigned a new role within an enterprise, in RBAC it is automatically possible for the user to access any new resources associated with that role, and it will remove the user’s ability to access resources associated

with roles they no longer hold. RBAC systems rely on administrators to specify roles and different permissions associated with roles, which could be a tedious process especially if finer granularity is needed.²¹

A variation that adds context to RBAC is “attribute-based access control” (ABAC) or “policy-based access control” (PBAC), which allows access-control policy to be specified in terms of attributes that could describe users, objects, or properties of the environment. This flexibility makes it easier to translate a desired policy from how we would naturally express it in English to a specification in the access-control system. For example, the policy “Charlie is allowed to access sensitive files related to his projects only from the corporate network but may access nonsensitive files related to his projects from anywhere” might use roles to give Charlie access to specific projects and attribute-based rules to capture the constraint that sensitive files should be accessible only from the corporate network. ACLs are an example of a possible mechanism to use to enforce certain policies but need to be combined with other mechanisms, such as firewall rules, in order to have better policy granularity.

Access-control systems differ by who is authorized to configure the access-control policy. In “mandatory access control” (MAC), the policy is set by administrators, and users cannot change the policy, even for their own data. An example of MAC is the multilevel security (MLS) system used in the U.S. Department of Defense where levels of top secret, secret, confidential, and unclassified are assigned to objects and principals. Users can only read files at the same level as their clearance level or lower, with no read up. In contrast, “discretionary access control” (DAC) systems allow users to change the access-control policies for the data they own. For example, a file owner on Unix-based systems can choose to change the ACL of that file at their discretion.

Many access-control systems used in practice, such as Microsoft’s Dynamic Access Control introduced with Windows Server 2012, combine ideas from these various access-control models and approaches. This makes it possible, for example, to specify policy following the RBAC paradigm when convenient, but also to fall back on ACLs and specify when users can change the access-control policy DAC and when they cannot.

If the data protected by an access control system is personal information, then the method of specifying policy, as well as the granularity of objects and the type of access given to them, can all impact privacy. For example, if an analyst must have access to specific rows in a database, say corresponding to specific individuals’ data, but the access-control system only supports giving access at the granularity of database tables, then we might be forced to allow access to the entire table. The consequence is that the analyst will have access to many database rows and hence the user data of many individuals that they do not need to access, increasing the risk of data tempering if the analyst turns malicious or their authentication credentials are stolen by an attacker.

It might seem like an access-control system that allows more fine-grained control and more ways of specifying policy is always better, since it exposes the least amount of data to

unnecessary risk. However, if more fine-grained control also means the access-control system is more complex to configure, that complexity could increase the number of mistakes administrators make when specifying policy, and these mistakes could start being the dominant reason why data is unnecessarily exposed. Such an access-control system configuration mistake led to the apparent theft of memoranda from a computer system in the U.S. Congress in 2003.²²

Another practical challenge in access control is that the system administrators who configure access-control systems are not the same people who decide what policy should be implemented. The person deciding on a policy is often a manager who instructs a system administrator to implement that policy, such as giving an employee access to resources they require to complete a new task. But when this task is complete, the manager might easily forget to remind the system administrator to revoke the access the employee was given. A 2009 study showed these challenges on the human side of configuring access-control policy frequently led to access-control systems being misconfigured, typically in ways that unnecessarily gave access to data.²³ This implies that the method of specifying policy can impact privacy too: If the abstractions in the access-control system are a good match for the abstractions using which decision makers—or laws and regulations—express policy, then it is more likely that desired policy will be correctly implemented.

9.4.4 Federated Identity

The discussion of access control and authentication thus far did not tackle the important challenge of how these processes can work effectively in a setting where many enterprises and organizations maintain their own separate computer systems, with independent methods of authenticating users and access-control systems that implement different access-control models.

Historically, each computer system that needed to authenticate users did so independently. If usernames and passwords were used for authentication, this meant a user would have to create a username and password for each computer system that they would need to authenticate to. When individuals access many computer systems—today it is common for people to have accounts on dozens or hundreds of systems—keeping track of so many usernames and passwords is inconvenient, to put it mildly.²⁴ Another reason to seek a better solution is each computer system that authenticates users will need to safeguard the users' credentials, lest they be stolen and misused.

An early solution to this problem was in the form of protocols like Kerberos, which separated authentication into a service independent of the computer system or service a user wanted to access.²⁵ This service could then authenticate users on behalf of different computer systems. Essentially, the authentication service would vouch for the user. Kerberos was typically used within a single organization or enterprise, allowing that organization to have a single point for authenticating users.

Kerberos was a precursor or an early form of “federated identity management,” which is the practice of outsourcing authentication not just to a different service within an organization, but to a different organization. In federated identity management, the service that authenticates users is called the “identity provider” (IdP) and the services that rely on the IdP to authenticate users are called “service providers” (SPs). Federated identity management is also called “single sign on” (SSO), since once a user authenticates or signs on with the identity provider, the identity provider can vouch for their identity to any service provider without requiring the user to authenticate again. Today, websites frequently allow users to authenticate with Google or Facebook instead of with the website itself.

Federated identity management can go beyond just authenticating users. Identity providers can also supply service providers with attributes that describe users. For example, if an identity provider knows a user’s age or nationality, it can provide this information to service providers in addition to, or even instead of, the user’s name. For example, if a service only cares that users are at least 18 years old, then the identity provider’s assertion to the service provider could include this information, without any additional information about the user’s identity. This has clear benefits for privacy, since the user’s identity can be kept hidden from the service provider.

Federated identity management also has other advantages for both users and service providers. Users no longer have to remember multiple sets of authentication credentials, and service providers are relieved of the burden of implementing authentication and protecting users’ authentication information. This comes with a cost, however. Every time a service provider needs to authenticate a user, the identity provider will be consulted. Hence, the identity provider learns all the service providers each user visits, in what order, at what times of day, and from what locations. This can add up to a far more detailed picture of a user’s behavior and preferences than users may be comfortable sharing with an identity provider—clearly a privacy concern.

Federated identity management is closely related to “cross-enterprise authentication and authorization,” in which two enterprises may each run their own identity provider, primarily intended to authenticate users within each enterprise. For business reasons, however, the two or more enterprises may trust each other’s identity providers. This enables company A to allow users from company B to access its computer systems, while relying on B’s identity provider to authenticate these users. Unlike the case in typical uses of federated identity management, these identity providers would be configured to work only with service providers from the two enterprises. In a cross-enterprise setting, it is also more common for identity providers to give service providers information about the roles and other attributes of authenticated users.

9.5 Principles for Building and Operating Systems to Be More Secure

There is no recipe, unfortunately, for how to build or operate a computer system so it will not be compromised by an attacker. However, following a set of basic principles can reduce the chance of an attack succeeding and the harm a successful attack can cause. The principles we will discuss have stood almost unchanged since being introduced by J.H. Saltzer and M.D. Schroeder “The Protection of Information in Computer Systems” in 1975.²⁶

9.5.1 Economy of Mechanism

A simpler mechanism is less likely to have flaws than a more complex one. Hence, all other things being equal, the simplest security mechanism that suffices for a given task is likely the best one.

9.5.2 Open Design

A long-standing principle is that the defender should not rely on the details of their security mechanisms remaining secret from the attacker, also called “security by obscurity,” to keep their system secure. A determined attacker can often bribe, steal, or reverse-engineer their way into understanding the system they are attacking sufficiently to develop effective attacks when possible. Not relying on the details of the mechanism remaining secret does not mean, however, that the defender cannot keep any information secret. In particular, most cryptographic mechanisms rely on the defender possessing a secret that the attacker is assumed to be unable to learn.

This principle is sometimes used as an argument to use “open-source software,” which is publicly available source code of software instead of “closed-source software.” In most cases, however, the choice between the two is more complicated. The open-design principle does not unequivocally point to using open-source software. It merely asserts that if closed-source software is used, then it should not be considered more resistant to attacks merely because the attacker cannot readily access it. For example, an attacker or a penetration tester can still try to examine different input strings on a closed-source software to find the input that would crash the software or cause a buffer overflow without the need to know the source code. This method of testing is referred to in software engineering as “closed testing.” While one can find arguments for and against open-source software, research that examined operating software OpenBSD showed an open design is beneficial to vulnerability testing and repair.²⁷

In recent years, open-source software has gained popularity due to the rise in bug bounty programs and the increased use of open-source software.²⁸ An increasing number of software vendors are offering “bug-bounty” programs, where ethical hackers and penetration testers are encouraged to examine software and report vulnerabilities to the vendor in exchange for a monetary award. Bug-bounty programs have significantly improved security testing, and more companies are finding the benefits of using open-source software in a bug bounty. With the increased use of open-source software, several organizations and software vendors

are joining efforts to improve the security of open-source software by inviting more ethical hackers to examine it, especially with the increased attacks on the open-source supply chain.

In December 2021, the Log4j vulnerability discovered by Chen Zhaojun, a member of Alibaba Cloud Security Team who reported the bug to Apache, drew the attention to the complexity of the open-source supply chain.²⁹ Log4j is an open-source logging tool found in the majority of apps and web servers. Even if an app is not directly using the tool in their front-end or back-end code, the app is still vulnerable due to third party libraries that are likely to use the tool. The security vulnerability allowed for remote code execution, which would give attackers the privilege to fully access systems and steal sensitive information like passwords and log-in credentials, putting everyone's privacy at risk. The vulnerability affected almost every software and long list of companies and organizations were affected, including Apple, Google, Cisco, and Microsoft.³⁰ Even though the vulnerability is patched, a 2023 report examining open-source software showed Log4j vulnerabilities remains unpatched in some existing open-source libraries.³¹

Other important issues to consider when choosing what software to rely on are its track record, how quickly vulnerabilities are fixed by its developers, and the extent to which the software has been tested in practice or by software analyses.

9.5.3 Complete Mediation

Complete mediation is achieved when every avenue by which a resource can be accessed is protected by a security check. This is akin to putting a lock on every door to a house. It seems obvious that this is an important principle to follow, but it can be surprisingly easy to forget. In an access-control setting, the principle of complete mediation also implies that access-control policy must be carefully protected, for example, so a user who is not authorized to change a file also cannot change the policy to allow themselves to change the file.

This principle also has ramifications beyond software design. It implies that if some information can only be accessed by authenticated and authorized users of a software, then similar restrictions should be put on how that information can be accessed if a user calls a help desk.

9.5.4 Least Privilege

Echoing the economy of mechanism principle, the least-privilege principle asserts that any user, computer system, or component of a computer system should have only the privileges it needs to do its job, and no more. If a component is compromised, any privileges or capabilities it possesses are transferred to an adversary. The least-privilege principle ensures that harm is minimized.

This principle too applies beyond the design of software and computer systems. It should also be followed by users of computer systems, particularly those who normally have elevated privileges, such as system administrators, developers, and sometimes help desk staff. Users with higher privileges than normal could be a tempting target for attackers who may

attempt to compromise those users through either digital means, e.g., by installing a keylogger on their computer, or through more traditional means, also called rubber-hose attacks like physical threats and blackmail.

9.5.5 Multiple Layers of Defense or Defense-in-Depth

When possible, the security of a system should be protected redundantly or with complementary mechanisms that are unlikely to all be compromised by the same attack. A mistake that can compromise a computer system can creep in at many points, such as during design or implementation, through improper configuration, or during operation and maintenance. Relying on a single mechanism, a single layer of defense, means an unlucky mistake might expose a system to attack.

9.5.6 Psychological acceptability

Systems have users, and security mechanisms that make unreasonable demands on the users—on their attention, their knowledge, or their ability—are likely to fail. These failures may be caused by intentional misuse by benign users, who may find a security mechanism so inconvenient that they purposefully work around it. A common example is sharing passwords. Users are typically asked to keep passwords secret and make them unique, but in many workspaces, passwords are written down on Post-it notes to enable employees to access the computer systems they need to do their jobs. In this case, the inflexibility of a security mechanism and the unreasonable demands it puts on users cause it to be willfully circumvented. Hence, to be effective, security mechanisms must be usable by their intended operators.

Another example of a clash between security and practicality occurs surrounding the BYOD phenomenon. BYOD is the increasingly accepted practice of allowing employees to use their own mobile phones and laptops to perform work-related tasks, specifically work-related tasks that require those devices to be used to access potentially sensitive data or internal company networks. From a security and privacy standpoint, allowing BYOD is a risk. Employees' personal devices may contain untrustworthy software or hardware, and so could be leveraged by attackers to steal user credentials or other sensitive data, or even as vehicles for further infiltrating company systems. Technical solutions, such as installing monitoring software on personal devices before they can be used to access company systems, may mitigate the risks, but only to a small degree. Yet, despite the obvious risks, practical concerns such as cost savings and convenience often outweigh the safer choice.

Work from home (WFH), which gained more popularity during the COVID-19 pandemic and continued post-pandemic as an acceptable practice, is another illustration of security and practicality trade-offs. During the pandemic, WFH was enforced at even the most sensitive agencies and organizations that traditionally adopt tighter security practices. Since WFH is now more widespread and acceptable among many sectors, the U.S. Cybersecurity and Infrastructure Agency (CISA) developed telework guidance and resources to help

different organizations and stakeholders continue to WFH while maintaining a secure hybrid workplace.³²

9.5.7 Safe Defaults

Systems should be configured to provide security out of the box, without any intervention. Systems that fail to do so run the risk of being attacked before they are reconfigured to be more secure and encourage users to leave them in an unsafe default state, since that may be more convenient for users who may not have sufficient awareness of the consequences of this behavior for security. Finally, systems that are in an unsafe state by default may be more vulnerable to attacks in which the first step is to reset the system to a prior or default state.

A notorious example of overly permissive defaults is Facebook's 2009 decision to guide users to, by default, share their posts and status updates with everyone when the safe default would have been to share only with those a user explicitly indicated they wished to share.³³

9.6 Summary

This chapter provides an introduction to computer security. This introduction is by no means complete, as discussions of additional attacks and defenses and many operational aspects of computer security are missing. In addition, we did not cover important topics to understand the current state of affairs in computer security practice, such as security economics, which explains why users may not always act to preserve the security of a system, for example, and legal and ethical aspects related to attacking and defending computer systems.

This chapter did cover, however, a number of concepts that are critical to understanding computer security but that may not have been evident to a technologist who had not studied computer security, from the breadth of roles needed to keep computer systems secure and the most common methods of attacking computer systems to the principles for controlling access and designing and operating computer systems to be secure.

Endnotes

1 Original Chapter written by Lujó Bauer. Updates for this edition made by Hanan Hibshi.

2 Alvaro Puig, "The Equifax Data Breach: What to Do," *FTC Consumer Information* (blog), July 22, 2019, <https://www.consumer.ftc.gov/blog/2017/09/equifax-data-breach-what-do>.

3 Dan Goodin, "Failure to Patch Two-Month-Old Bug Led to Massive Equifax Breach," *Ars Technica*, September 13, 2017, <https://arstechnica.com/information-technology/2017/09/massive-equifax-breach-caused-by-failure-to-patch-two-month-old-bug/>.

4 *National Initiative for Cybersecurity Education, Cybersecurity Workforce Framework (NICE Framework), Special Publication 800-181*, U.S. Dept. of Commerce/National Institute of Standards and Technology (NIST), updated November 13, 2020, <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-181.pdf>.

5 NICE Framework Resource Center, National Institute of Standards and Technology (NIST), accessed April 2024, <https://www.nist.gov/itl/applied-cybersecurity/nice/nice-framework-resource-center>.

6 Dan Goodin, "FTC's Chief Technologists Gets Her Mobile Phone Number Hijacked by ID Thief," *Ars Technica*, June 7, 2016, <https://arstechnica.com/tech-policy/2016/06/ftcs-chief-technologist-gets-her-mobile-phone-number-hijacked-by->

id-thief/.

- 7 Melanie Eversley and Kim Hjelmgaard, "Target Confirms Massive Credit-Card Data Breach," *USA Today*, December 18, 2013, <https://www.usatoday.com/story/news/nation/2013/12/18/secret-service-target-data-breach/4119337/>.
- 8 Roger A. Grimes, "8 Ways Your Patch Management Policy is Broke (and How to Fix It)," *CSO*, October 3, 2019, <https://www.csoonline.com/article/3025807/why-patching-is-still-a-problem-and-how-to-fix-it.html>; Ray Lapena, "Unpatched Vulnerabilities Caused Breaches in 27% of Orgs, Finds Study," *The State of Security, Tripwire*, June 3, 2019, <https://www.tripwire.com/state-of-security/vulnerability-management/unpatched-vulnerabilities-breaches/>.
- 9 "WhatsApp Security Advisories," *WhatsApp.com*, accessed June 2023, https://www.whatsapp.com/security/advisories/archive?lang=en_US.
- 10 Sam Varghese, "BA Site Breach Through XSS Flaw, Says Tech Firm Chief," *ITWire*, September 8, 2016, <https://www.itwire.com/security/84379-ba-site-breach-through-xss-flaw-says-tech-firm-chief.html>.
- 11 Paul Ionescu, "Inside the Mind of a Hacker: Attacking Databases with SQL Injection," *SecurityIntelligence*, May 12, 2016, <https://securityintelligence.com/inside-the-mind-of-a-hacker-attacking-databases-with-sql-injection/>.
- 12 Howard Solomon, "Keylogger, Vulnerable Server Led to Cathay Pacific Airlines Breach, Says Report," *IT World Canada*, June 7, 2019, <https://www.itworldcanada.com/article/keylogger-vulnerable-server-led-to-cathay-pacific-airlines-breach-says-report/418805>.
- 13 Nicky Woolf, "DDoS Attack that Disrupted Internet was Largest of its Kind in History, Experts Say," *The Guardian*, October 26, 2019, <https://www.theguardian.com/technology/2016/oct/26/ddos-attack-dyn-mirai-botnet>.
- 14 2019 Data Breach Investigations Report: Results and Analysis, Verizon, accessed April 2024, <https://enterprise.verizon.com/en-gb/resources/reports/dbir/>.
- 15 Emily Flitter and Karen Weise, "Capitol One Data Breach Compromises Data of Over 100 Million," *The New York Times*, July 29, 2019, <https://www.nytimes.com/2019/07/29/business/capital-one-data-breach-hacked.html>.
- 16 Erin Dietsche, "Data error exposes 974K UW Medicine patients' information," *MedCity News*, February 22, 2019, <https://medcitynews.com/2019/02/974k-uw-medicine-patients/>.
- 17 Adam Lashinsky, "What's Most Stunning About Uber's Settlement with Waymo," *Fortune*, February 12, 2018, <https://fortune.com/2018/02/12/google-waymo-uber-surprising-case/>.
- 18 Jaikumar Vijahan, "Snowden Serves Up Another Lesson on Insider Threats," *Computerworld*, November 8, 2013, <https://www.computerworld.com/article/2485759/snowden-serves-up-another-lesson-on-insider-threats.html>.
- 19 Karim Toubba, "Security Incident and Recommended Actions," *LastPass (Blog)*, March 1, 2023, <https://blog.lastpass.com/2023/03/security-incident-update-recommended-actions/>.
- 20 Adam Shostack, *Threat Modeling: Designing for Security*, (Indianapolis: John Wiley and Sons, 2014).
- 21 Paul van Oorschot, *Computer Security and the Internet: Tools and Jewels*, (Cham, Switzerland: Springer International Publishing, 2020).
- 22 U.S. Senate Sergeant at Arms, *Report on the Investigation into Improper Access to the Senate Judiciary Committees Computer System*, March 5, 2004.
- 23 Lujo Bauer, Lorrie Faith Cranor, Robert Reeder, Michael Reiter and Kami Vaniea, "Real Life Challenges in Access-Control Management," *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems* (2009): 899–908, <https://dl.acm.org/citation.cfm?doid=1518701.1518838>.
- 24 "Average Business User Has 191 Passwords," *Security Magazine*, November 6, 2017, <https://www.securitymagazine.com/articles/88475-average-business-user-has-191-passwords>.
- 25 Memorandum by L. Zhu and B. Tung, "Public Key Cryptography for Initial Authentication in Kerberos (PKINIT)," June 2006, The Internet Society, RFC 4556, <https://www.rfc-editor.org/pdf/rfc/rfc4556.txt.pdf>.
- 26 J.H. Saltzer and M.D. Schroeder, IEEE Xplore Digital Library, "The Protection of Information in Computer Systems," *Proceedings of the IEEE* 63, no. 9 (1975): 1278–1308, <https://ieeexplore.ieee.org/document/1451869>.
- 27 Ross Anderson, *Security Engineering: A Guide to Building Dependable Distributed Systems, Third Edition*, (Indianapolis: John Wiley & Sons, 2020); Andy Ozment and Stuart Schechter, "Milk or Wine: Does Software Security Improve with Age?" *Proceedings of 15th USENIX Security Symposium* 6 (2006): 93–104, <https://www.usenix.org/conference/15th-usenix-security-symposium/milk-or-wine-does-software-security-improve-age>.
- 28 Anderson, *Security Engineering*.
- 29 "Security," *Apache Log4j, Logging Services*, March 6, 2024, <https://logging.apache.org/log4j/2.x/security.html>.

- 30 “Intro: Log4j Impact on Manufacturers and Components Summary from the Internet Community,” GitHub, accessed April 2024, <https://github.com/YfryTchsGD/Log4jAttackSurface>.
- 31 Fred Bals, “2023 OSSRA Deep Dive: jQuery and Open Source Security,” Synopsys, May 10, 2023, <https://www.synopsys.com/blogs/software-security/deep-dive-2023-ossra-report.html>.
- 32 “Telework Guidance and Resources,” Cybersecurity and Infrastructure Security Agency, accessed April 2024, <https://www.cisa.gov/topics/risk-management/coronavirus/telework-guidance-and-resources>.
- 33 Kevin Bankston, “Facebook’s New Privacy Changes: The Good, The Bad, and The Ugly,” *Electronic Frontier Foundation*, December 9, 2009, <https://www.eff.org/deeplinks/2009/12/facebooks-new-privacy-changes-good-bad-and-ugly>.

CHAPTER 10

Privacy Governance

David James Marcos, AIGP, CIPM, CIPT; Kira Fuller, CIPM; Nicole Uribe, CIPP/US

10.1 Privacy and IT: Roles and Responsibilities

Two decades into the twenty-first century, it is manifestly clear that our physical lives are becoming inseparable from our digital lives. Amid this profound societal transformation, information technology (IT) takes center stage in the safeguarding of individual privacy. The centrality of IT in modern privacy programs demands a focus on scalable technical solutions,

developed at once to balance the ever-increasing scope, volume, and complexity of IT, as well as the challenges of translating privacy principles and safeguards against privacy harms into engineering requirements. In short, the essence of privacy engineering is bringing the complementary perspectives of privacy professionals and engineers together, grounded in practical solutions capable of measuring and monitoring the ever-changing state of privacy within IT.

This chapter will focus on the role of IT in privacy, with notable attention on achieving a practical and measurable governance program designed to enable effective privacy engineering that connects the objectives outlined in a privacy program with tangible tools and capabilities within IT. Critically, the following pages detail how to work across various domains and the myriad stakeholders entrusted to cultivate privacy, as well as security and responsible artificial intelligence (AI), within an organization. This cross-domain approach is crucial to effective privacy engineering in an era of increasingly complex and intertwined regulatory obligations.

Building on a cross-domain approach, this chapter further describes how to make pivotal connections between disparate aspects of a privacy program, the impetus of which is grounded in the technical solutions actually safeguarding privacy within systems. Tying these pieces together is one of the biggest challenges for a modern privacy program, taking high-level privacy objectives and controls designed to protect against privacy harms and translating them into meaningful, measurable, and above all, practical controls that privacy engineers can implement and monitor.

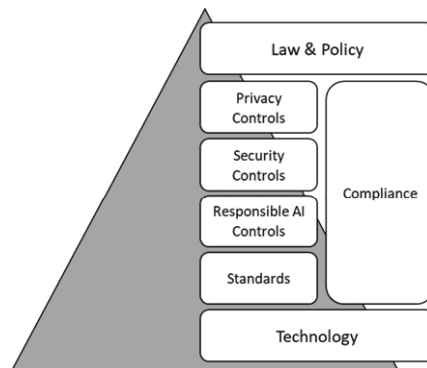
Throughout, the chapter also details the various controls availed to privacy professionals and engineers that enable the systematic management of a privacy governance program, as well as the complementary overlap with adjacent domains of security and responsible AI. Many of these controls overlap in functionality and many are complementary. How best to both use and organize these controls to develop a successful privacy governance program is described in the following section.

10.2 Privacy Governance and Engineering: Bridging the Gap

Understanding the role of IT in privacy first starts with identifying the elements and associated stakeholders of a privacy governance program. Figure 10-1 illustrates the various elements of a privacy governance program. As this chapter proceeds, we additively describe these elements, explaining how each layer builds upon and is reinforced by the others. Recognizing these different elements is critical, as each component can easily achieve primacy over others. However, they are in fact interdependent and must be interleaved. Absent a structured approach to balance the disparate elements of a privacy program, IT's ability to safeguard privacy greatly diminishes. Merely summarizing legal or regulatory

requirements is insufficient to develop effective engineering solutions. While laws and regulations are no doubt fundamental to understanding baseline privacy requirements, additional detail is necessary to make legal requirements tangible and practical for engineering.

Figure 10-1: Conceptualizing a privacy governance program



Understanding these different elements and the ways they are interwoven in a holistic privacy governance model greatly helps ensure the success and increased maturity of a privacy program. Manifest in this recognition is identifying not just the specific roles each element plays, but critically, how to translate between the boundaries of each element of the privacy program. In fact, translation is perhaps the most important aspect of a privacy program to recognize. The privacy professional, ultimately, is a translator, sitting at the center, balancing the requirements espoused by various stakeholders, and organizing those requirements into structured themes and elements that enable the success of each stakeholder, as well as the overall success of the enterprise-wide privacy governance program. Once understood, this decidedly organizational, and not technical, aspect immensely increases the ability of IT to contribute successfully to the effectiveness and maturity of a privacy program. Moreover, once understood and established, this framework enables iterative improvements as the translations across the elements help different stakeholders see how their needs and requirements affect, or do not affect, the overall health of the privacy program. This is equally critical as it aids in both understanding and maintaining the critical needs of the privacy program, again in practical terms, and their implementation within IT.

10.2.1 Understanding Risk

A holistic privacy governance model will require a comprehensive framework that accounts for privacy risks and their mitigating controls, which surround the framework depicted in Figure 10-1. A risk is a hypothetical scenario that describes an unwanted event and all the threats that would allow it to occur. Example scenarios include how risk sources could exploit the vulnerabilities of company assets in the context of threats and allow feared events to occur on personal data, thus generating impacts on the privacy of data subjects.¹ In other words, these privacy risks are derived from the processing of personal data that contributes to the inherent risk a business holds. Examples of inherent privacy risks include the type of

personal data that is collected, the location from which it is collected, and the use or purpose of this collection. Not all personal data holds the same level of risk to the business or to the individual. Sensitive data, children’s data, and data collected from certain jurisdictions may be considered higher risk compared to personal data that is publicly available and collected from adults. These factors must be assessed by the privacy professional in collaboration with the other domains previously mentioned, such as legal, security, responsible AI, and IT. This cross-domain collaboration leads to identification of the business’s agreed key risk indicators (KRI’s) which signifies the threshold for the business’s risk appetite.

Identification and measurement of inherent privacy risks can be built into a scalable, automated solution. Examples of privacy risk frameworks and/or key components of these frameworks have been published by multiple regulatory bodies and privacy institutions.

Table 10-1: Select industry and regulatory privacy risk framework components

Industry and regulatory body	Components
France’s data protection authority, the Commission nationale de l’informatique et des libertés (CNIL) ²	Context • Gains a clear understanding of the personal data processing operations • Acts as the project owner and group owners in charge of data protection practices
	Fundamental principles • Assesses controls protecting data and the necessity of processing • Performs risk evaluation and classification
	Risks • Assesses of design and operating effectiveness of controls • Provides controls bearing specifically on data, security, and governance
	Validation • Consolidates and documents findings • Determines appropriate actions and plans based on risk tolerance
U.S. National Institute of Standards and Technology (NIST) ³	Core • Provides an increasingly granular set of activities and outcomes that enable an organizational dialogue about

	managing privacy risk
	Profiles • Selects of specific functions, categories, and subcategories from the core that an organization has prioritized to help it manage privacy risk
	Implementation Tiers • Supports communication about whether an organization has sufficient processes and resources in place to manage privacy risk and achieve its target profile.

Once the inherent privacy risks have been identified and measured according to the organization's agreed framework, a catalog of related controls will need to be mapped to each inherent risk. Organizations will leverage administrative, technical, and physical controls that are meant to ensure compliance with applicable legal and regulatory privacy requirements. Examples of mitigating controls includes stringent limiting access controls to personal data and a written and technologically implemented record retention policy. We further explore the role of controls in privacy governance in multiple sections throughout the rest of this chapter.

The result of mapping inherent risks and mitigating controls is the business's remaining residual risk. The business will then be able to prioritize its resources according to the residual risk that may need further mitigation. Creation and maintenance of the privacy risk framework can serve two key purposes, allowing the business visibility into what risks it holds to 1) prioritize its risks and mitigations, as well as 2) respond to legal and regulatory inquiries related to its privacy practices.

Coordination between privacy, legal, security, responsible AI, and IT leads to the identification of the business's agreed KRIs, which signify the threshold for the business's risk appetite. KRIs allow the business to have early identification of potential risks it will want to mitigate immediately, insight into potential weaknesses in the aforementioned controls, and for a systematic approach to monitoring. Examples of KRIs include details of the people, software, and processing necessary for the business's daily operations, and metrics to identify the threshold upon which a risk becomes a serious threat to its operations.

Another component of robust privacy risk management includes privacy audits. These audits should be conducted regularly based on the business's KRIs. The function of the audit is to test the effectiveness of privacy controls to mitigate the prioritized risks. This testing, in combination with regular review of KRIs, allows for early insights, proactive planning, and quick reactive responses. The feedback loop between the stakeholders, leveraging the risk

review and the audit results, strengthens an organization’s ability to operate smoothly. Refer to chapter 2 for more on the fundamentals of privacy risk management.

10.2.2 Law, Regulation, and Policy

Law, regulation, and policy sit at the pinnacle of the privacy governance program pyramid. Ultimately, the aim is to translate these fundamental requirements—whether foundational legal requirements or organizational privacy policies—into tooling that is manageable and scalable with the organization’s IT needs.

In the modern era, an increasing number of privacy-impacting legal frameworks are coming into existence. Paramount among modern regulation is the EU General Data Protection Regulation (GDPR).⁴ After the passage of the GDPR, many non-EU countries, such as Brazil, India, and China, enacted similar comprehensive privacy and data protection laws. Alongside these regulations are earlier laws and sector-specific laws, such as the U.S. Health Insurance Portability and Accountability Act (HIPAA).⁵ Moreover, as demonstrated by the passage of the EU AI Act, AI is fast becoming a major focus for legislators worldwide, bringing with it significant, and overlapping, regulation for IT.⁶

At first blush, the many legal frameworks both currently in existence and on the horizon ostensibly present a major challenge for IT. Each framework is similar to and different from the others. Each one may or may not be tailored to specific areas. For instance, the GDPR focuses broadly on personal data and on EU residents. HIPAA focuses narrowly on protected health information (PHI) and is tailored to the United States. See Table 10-2, which illustrates the similar confidentiality requirements across both HIPAA and GDPR.

Table 10-2: Examples of privacy law

Privacy law	HIPAA - 42 USC §1320a-7e(b)(3): Confidentiality: In determining what information is required... [regulation]...shall include procedures to assure that the privacy of individuals receiving health care services is appropriately protected. ⁷
	GDPR - Article 28(3)(b): Ensures that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality. ⁸

From an IT perspective, this can seem unmanageable. IT itself is ever-changing and evolving, just as law is. The timescale at which IT changes is also significantly faster than that of law. Moreover, developing tailored engineering solutions for one law may lead to overly complicated and costly engineering solutions—and solutions for one law may outright contradict the requirements of another.

In the face of this reality, IT professionals will immediately gravitate toward two questions: What can practically be done? And how can solutions be future-proofed to forestall the need for additional investment or unnecessary complexity that negatively affects organizational performance or outweighs business value?

Privacy professionals and engineers must look first to the organization’s legal team to help identify the core requirements of disparate privacy laws and the various associated legal risks.

This work involves identifying the core policies and associated objectives a given organization deems necessary for it to fulfill its obligations. It is important to note these policies may not stipulate technical solutions. Instead, top-level organizational policies will likely only identify key objectives that must be met. This is acceptable—and desirable—as it affords privacy professionals and engineers flexibility to define the governance program and identify manual and automated controls. This flexibility also enables iterative maturation. As the privacy governance program and supporting IT solutions evolve, previously manual components of the program will become automated. This natural evolution not only enables the privacy program to become more effective, it also allows the program to evolve with the pace and scale of IT; a necessity given the continued and exponential growth of technology. Building upon the legal examples of HIPAA and GDPR from Table 10-2, consider the following organizational policy in Table 10-3, which identifies a key confidentiality objective to cover both laws’ requirements.

Table 10-3: Additive example of an illustrative organizational policy

Privacy law	HIPAA: Confidentiality: In determining what information is required...[regulation]...shall include procedures to assure that the privacy of individuals receiving health care services is appropriately protected.
	GDPR: Ensures that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.
Privacy policy	Organizational policy: Employees processing personal data require a legitimate business need.

10.2.3 Compliance

Compliance is one of the most important parts of a privacy governance program. Building upon law and established organizational policy, compliance begins the *translation* into practical and measurable requirements and the process through which privacy can be implemented and evaluated.

Responsibility for compliance within an organization may sit in various places. Compliance may be part of the legal team, it may be integrated with security, or it may be its own department. Privacy itself may be embedded under compliance. Regardless, compliance offers a strong framework upon which the privacy program can be built. Compliance begins the process of establishing practical controls through which privacy engineers can build effective IT solutions to safeguard privacy.

For privacy professionals and engineers, a short primer identifying key concepts in compliance is valuable. Not only does this help establish common terminology with which to engage compliance teams, the concepts themselves are of immense value when creating the governance model and associated standards necessary to manage an organization’s privacy program and ultimately implement it within IT.

The concept of “reasonable assurance” is fundamental. Reasonable assurance means requirements and objectives are not absolute, but rather based upon some criteria that is deemed practical to implement and manage. This concept is absolutely key when safeguarding privacy in IT. It affords flexibility and is greatly valuable for managing the potential overengineering of solutions. It also grounds solutions in common sense. Take, for instance, a technical solution designed to identify people to delete their data. An absolute guarantee would necessitate knowing an individual perfectly, in effect creating one privacy harm in order to resolve another. What, instead, is reasonable? What practical measures can be taken to resolve the need to identify a user in order to delete their data, while not overengineering and invading privacy as an unintended consequence?

With reasonable assurance as a backdrop, compliance programs aim to develop internal controls. Internal controls are objectives tied to practical measurements and designed to evaluate components governed by the privacy program.² For instance, an internal control might be to review access logs to a system with the objective of identifying unauthorized access. Implementation of the control may be manual, automated, or a mix of both.

Internal controls come in two primary flavors. One kind is preventive: designed to stop an activity, a priori, from occurring.¹⁰ The second is detective: identifying problematic activity after an event has occurred.¹¹ Continuing with the example from the prior section, consider the following in Table 10-4.

Table 10-4: Additive example of an illustrative privacy compliance internal control

Privacy law	HIPAA: Confidentiality: In determining what information is required...[regulation]...shall include procedures to assure that the privacy of individuals receiving health care services is appropriately protected.
	GDPR: Ensures that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.
Privacy policy	Organizational policy: Employees processing personal data require a legitimate business need.
Compliance internal controls	Preventive privacy internal control: Limit access of personal data only to authorized personnel.

In mature compliance programs, internal controls are continuously monitored, ideally through IT capabilities. This enables faster identification of issues and remediation thereof. Alongside, internal controls are often designed to overlap. Overlapping controls are key, as they improve the resiliency of a compliance program and assure objectives can continue to be measured and issues can be identified amid failures of other controls. Overlapping controls and reasonable assurance strongly reinforce one another and, importantly, justify the application of *reasonable* assurance rather than *absolute* assurance.

The value compliance and its basic concepts offer a privacy governance program is simple: structure. A grounded privacy governance program is reasonably assured, where overlapping

detective and preventive controls enable a clear, measurable, and understandable framework through which translation across the various elements of a privacy program can be achieved. It is the first step in translating law, regulation, and policy into practicable objectives and metrics, and it further provides the mechanism through which to pivot between elements of the privacy program.

10.2.4 Security

Security and privacy are deeply intertwined. For privacy, security is where the governance program begins to become significantly technical. Security engineers necessarily deal with more technical aspects tied to IT, given the nature of security threats to modern technology. Moreover, security is a necessary precursor to privacy: It is difficult to achieve and maintain privacy without security. Privacy and security, however, have clearly different roles with respect to IT. Principally, security is about protecting against unauthorized access and malicious actions.¹² Security risk is often framed in terms of confidentiality, integrity, and availability (CIA triad).

Privacy, comparatively, is about enforcing *appropriate use* within a secure environment.¹³ In other words, security can reasonably ensure two parties exchange personal data securely, but it is privacy that reasonably assures that the authorized parties use the personal data appropriately.

As different sides of the same coin, security and privacy often rely on similar controls and, ultimately, the same IT capabilities. Access control presents one of the more obvious capabilities that is leveraged to the mutual benefit of security and privacy protections alike. Table 10-5 illustrates security compliance internal control, which is nearly identical to the example of privacy internal control provided in Table 10-4.

Table 10-5: Additive example of an illustrative security compliance internal control

Privacy law	HIPAA: Confidentiality: In determining what information is required...[regulation]...shall include procedures to assure that the privacy of individuals receiving health care services is appropriately protected.
	GDPR: Ensures that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.
Privacy policy	Organizational policy: Employees processing personal data require a legitimate business need.
Compliance internal controls	Preventive privacy internal control: Limit access of personal data to authorized personnel only.
	Preventive security internal control: Limit access of sensitive data to authorized personnel only.

Security provides multiple benefits to privacy in consequence. Notably, information security is more mature, technologically, than privacy. Likewise, security frameworks and certifications are well established and, again, more mature in terms of technological

implementation than those related to privacy. Security thus provides privacy an avenue through which meaningful IT solutions can be developed to safeguard privacy. In addition, as security and compliance are as intertwined as privacy and compliance, reasonably assured internal controls can be repurposed, or extended, as necessary to mature the privacy governance program and inculcate privacy safeguards into IT.

The fact that security is naturally a technical undertaking and, comparatively, technically mature, provides an additional and profoundly important benefit for privacy: the ability to translate privacy into meaningful and understandable terminology for engineers. Given that privacy can often be abstract and difficult to describe, it is notoriously challenging to frame it in understandable terms to engineers and computer scientists. In leveraging security terminology—both with respect to adopting the same terminology or contrasting with it—privacy can more effectively describe fundamental requirements and safeguards in ways that lead to truly effective IT safeguards that engineers can readily comprehend and utilize within IT infrastructure.

Considered in this context—with security as a mature, technologically oriented element already understood by engineers—security becomes a critical pillar upon which privacy can rely. Moreover, as much as privacy benefits from security, security likewise benefits from privacy, backstopping security solutions and processes with privacy legal requirements and, in consequence, reinforcing the mutual value of integrated privacy and security governance. Additional detail regarding security and its relationship to privacy is described in chapter 9.

10.2.5 Responsible AI

Responsible AI is a new and fast-growing area of focus for IT. Generative AI is now breaking out and quickly imposing demanding requirements upon technology and supporting engineers. Responsible AI is uniquely situated: at once leveraging and building upon privacy policy and principles while simultaneously imposing deeply technical requirements and measures to monitor and assure appropriate processing of data. Whether it is building upon the privacy concept of transparency, expanding into detailed areas such as fairness, or evaluating the attributes and technical measures of machine learning (ML) models, responsible AI sits with one foot squarely grounded in privacy and security practices and the other quickly stepping into new areas of policy and technology to safeguard human-computer interactions in an era of AI-driven computing.

This situates responsible AI in a unique position, building upon and reinforcing privacy and security controls while building new controls to reasonably assure the safe processing of data in AI capabilities. It is consequently important for privacy professionals to understand how and where responsible AI controls are applied. In some cases, controls may be complementary, while in others, controls might be in opposition. For example, AI tends to require significant data to produce accurate models. Such requirements may pose challenges to a privacy program with strict management of user data or, in converse, may pose

challenges for effective AI solutions. Regardless, consideration of responsible AI in concert with privacy is critical to identify challenges and for organizations to make informed risk decisions.

Building upon Table 10-5, responsible AI adds yet an additional compliance internal control as we continue our example. Here, the internal control necessitates a straightforward and specific form of transparency that augments privacy. For responsible AI, it is important to highlight to users where and how AI generates responses that may have previously been created by humans. Consequently, just-in-time notice is needed to emphasize in the moment that AI is involved.

Table 10-6: Additive example of an illustrative responsible AI compliance internal control

Privacy law	HIPAA: Confidentiality: In determining what information is required...[regulation]...shall include procedures to assure that the privacy of individuals receiving health care services is appropriately protected.
	GDPR: Ensures that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.
Privacy policy	Organizational policy: Employees processing personal data require a legitimate business need.
Compliance internal controls	Preventive privacy internal control: Limit access of personal data to authorized personnel only.
	Preventive security internal control: Limit access of sensitive data to authorized personnel only.
	Preventive responsible AI internal control: Display conspicuous notice where AI-generated text is displayed to a user.

10.2.6 Technology

The foundational base of a modern privacy governance program is technology. In the modern era, technology is where a privacy governance program becomes realized and actionable. At the same time, technology presents at once the greatest challenge and the biggest opportunity for privacy, and also AI. While security greatly assists privacy in translating objectives into meaningful and understandable terms for engineers to implement effective IT solutions, ultimately privacy must reconcile directly with the nature of IT, the best way to leverage it to the advantage of privacy governance programs, and the effective safeguarding of privacy within IT.

Perhaps the greatest challenge for privacy is not technology itself, in terms of the risks it poses to individual privacy, but rather in how to utilize it to safeguard privacy. The persistent challenge privacy programs have faced in recent years is the translation of safeguards against privacy harms into tangible, measurable, and controllable IT capabilities. In addition, the issue of scalability comes to the fore if one is considering managing privacy across a cloud. Moreover, IT is continually developing capabilities that promise to improve privacy, be it

differential privacy, homomorphic encryption, or various deidentification techniques. But how best to use these capabilities? How should these capabilities be rationalized in regard to a privacy governance program? Which risks do these capabilities mitigate? Which controls do they support? Is it possible to thematically organize them, and other capabilities, in a manner that facilitates a comprehensive and cohesive set of IT capabilities that support, automate, and continuously monitor all or a subset of a privacy governance program?

The first step toward effectively understanding IT with respect to privacy is to recognize the capabilities IT generally provides for users. A computer has only so many components with which to interact with a human and manipulate data. Simplistically, the fundamental computational functions of a computer are “create, read, update, and delete” (CRUD). Considering IT in light of CRUD, although an oversimplification, is valuable to support practical translations of law and compliance controls into tangible solutions. This means in the end, all the innumerable existing or future privacy laws worldwide must, in some fashion, be implemented by IT. That implementation comes down to permutations of CRUD. Like DNA, different combinations of CRUD yield different, and infinite, potential. But ultimately, everything comes down to those base functions of CRUD.

Recognizing this begins the process of making privacy practical and implementable in IT. It also enables effective risk-based discussions as well as the development of consistent controls applicable across a broad range of legal frameworks. In other words, it takes the *metaphysical* conceptualization of privacy across law, policy, and ethics and *discretizes* it into the discrete functionality of computers. The additive examples illustrated in the tables throughout this chapter exemplify precisely how to methodically undertake the breakdown of high-level statements and instrument practical, measurable controls into IT itself.

Moreover, these fundamental building blocks can be additively employed, much like DNA, to develop higher-level functionality. Iterating through, sophisticated solutions, such as differential privacy, suddenly become rationalized in the light of a privacy program. Similarly, internal compliance controls can also be rationalized. Ultimately, this leads to being able to connect the top of the pyramid—law and policy—to the lowest tier, technology.

Additively employing the fundamental building blocks also enables the reasonable iteration of the discretized components of IT in a manner that makes transparent 1) which controls exist to mitigate abstract privacy harms and 2) whether those controls sufficiently discretize the metaphysical aspects of a given privacy harm. It also clearly reveals the control’s practical performance impacts on IT infrastructure. This transparency is a profound and critical aspect of an IT-centric privacy governance program as it separates myth from reality and grounds privacy in measurable and real componentry within IT. Sections 10.2.7 and 10.3 elaborate on both how this can be undertaken and what core pieces must be considered when bringing IT and privacy together in a privacy governance program.

10.2.7 Industry Standards

As privacy has increasingly challenged IT, privacy-minded industry standards have equally increased as efforts have been undertaken to organize, rationalize, and comprehend privacy in meaningful ways for engineers. Many of these standards began with security and, as previously noted, privacy has a strong security-centric foundation that can be leveraged to connect privacy with meaningful technical controls in IT. For example, National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53 was initially conceived as a security-centric document. However, by Revision 3, the SP 800-53 document had been augmented with privacy controls, detailed in the publication’s Appendix J.¹⁴

Industry standards offer two principal benefits for IT-focused privacy governance. First and foremost is the establishment of a common language to describe privacy controls. When dealing with international standards, this is especially valuable, as the controls represent what industry experts, vetted through an international organization, deem critical to identify and measure across a wide swath of legal frameworks and privacy considerations.

The establishment of this common language results in the second benefit: transparency. It goes without saying that each organization has its own tailored privacy governance program and, alongside, its own IT architecture. Some aspects may be considered confidential—notably IT architecture. Standards provide a mechanism through which an organization can transparently describe its controls tied to governance and IT in common and accessible terms that do not inadvertently undermine confidentiality. This helps build trust between an organization and its key stakeholders or customers and, in addition, provides auditability through independent third-party certification. Building upon Table 10-6, consider the mapping in Table 10-7 of the privacy and security internal controls to NIST SP 800-53 and the responsible AI control to the NIST AI Risk Management Framework (RMF).¹⁵

Table 10-7: Additive example of SP 800-53 controls mapped to illustrative compliance internal controls

Privacy law	HIPAA: Confidentiality: In determining what information is required...[regulation]...shall include procedures to assure that the privacy of individuals receiving health care services is appropriately protected.	
	GDPR: Ensures that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.	
Privacy policy	Organizational policy: Employees processing personal data require a legitimate business need.	
Compliance internal controls	Preventive privacy internal control: Limit access of personal data to authorized personnel only.	
	Preventive security internal control: Limit access of sensitive data to authorized personnel only.	
	Preventive Responsible AI Internal Control: Display conspicuous notice where AI-generated text is displayed to a user.	
Industry standard mapping	Preventive privacy internal control: Limit access of personal data to authorized personnel only.	UL-1: Internal use: Uses...PII internally only for authorized purpose(s). ¹⁶

Preventive security internal control: Limit access of sensitive data to authorized personnel only.	AC-3: Access enforcement: The information system enforces approved authorizations. ¹⁷
Preventive responsible AI internal control: Display conspicuous notice where AI-generated text is displayed to a user.	Measure 2: AI system trustworthiness evaluation: Measure 2.8 notes risks associated with transparency and accountability...are examined and documented. ¹⁸

Industry standards cover the gamut worldwide, with a mix of international and local standards in play. Depending on the sector or locality, a privacy governance program may need to certify against one industry standard or more. In consequence, understanding the basics of varying standards is crucial. Here again, as described in prior sections of this chapter, translating the controls of a privacy governance program into various controls identified in varied standards is critical to success.

Standards have different purposes. Some attempt to rationalize privacy and IT holistically for a privacy program, and others describe specific aspects deemed beneficial. Above all, the standards attempt to support privacy professionals and engineers through structure and recommended methods of measurement. The myriad standards in play can prove daunting, notably when attempting to decide which standard or standards should be selected to backstop a privacy governance program. Many of these standards thus provide tables that cross-map different standards, assisting in portability or reusability.

Table 10-8 describes some of the more prominent standards in effect, or soon forthcoming, that are valuable when building a privacy governance program supported by IT. It should be stressed that the standards listed in Table 10-8 represent only a subset. Again, myriad standards worldwide cover international needs, localized needs, or sectoral particularities.

Table 10-8: Select industry privacy standards

Standard	Description
ISO 19944 ¹⁹	ISO 19944, Cloud Services and Devices: Data Flow, Data Categories, and Data Use , is an International Organization for Standardization (ISO) standard designed to support transparent description of cloud ecosystems, focusing on taxonomic categories of data, use, and data flow within cloud services.
ISO 270XX series ²⁰	The ISO 270XX series covers an array of information security controls. ISO 27001 predominates as the primary security standard. ISO 27018 provides privacy-centric controls for personally identifiable information (PII).
PIMS – ISO 27701 ²¹	Privacy Information Management System (PIMS) is a developed ISO standard designed specifically to enhance privacy safeguards for ISO 27001. This standard accounts for controls identified in the GDPR and provides a more fulsome description of privacy controls for data controllers and data processors. PIMS further provides mapping to other standards and laws to facilitate portability.
NISTIR 8062 ²²	NISTIR 8062, An Introduction to Privacy Engineering and Risk Management in Federal Systems , is a U.S. standard that introduces basic privacy engineering and risk management concepts. Notably, it calls out the concepts of protectability, manageability, and

	disassociability, the privacy parallels to security's CIA triad concepts.
NIST Privacy Framework ²³	The NIST Privacy Framework is a voluntary enterprise risk management tool alongside the NIST Cybersecurity Framework. The framework is intended to assist organizations in communicating and organizing privacy risk, rationalizing privacy to build or evaluate a privacy governance program.
NIST Special Publication 800-53 ²⁴	NIST SP 800-53, Security and Privacy Controls for Federal Information Systems and Organizations , is the primary standard for U.S. government agencies. The standard is also broadly used by private sector entities and has mappings to ISO 270XX controls. Privacy controls are identified in Appendix J and aligned with the Fair Information Practice Principles (FIPPs).
SOC 2 Type 2 ²⁵	Systems and Organization Controls (SOC) focuses on security, availability, processing integrity, confidentiality, and privacy. SOC has differing levels of standardization, with SOC 2 Type 2 being the more in-depth standard to assess assurance of the controls of a service organization.
NIST AI RMF 1.0 ²⁶	In collaboration with the private and public sectors, the NIST has developed a framework to better manage risks to individuals, organizations, and society associated with AI. The NIST AI RMF is intended for voluntary use to improve the ability to incorporate trustworthiness considerations into the design, development, use, and evaluation of AI products, services, and systems.
AIMS – ISO 42001 ²⁷	ISO 42001, the AI Management System (AIMS) , is a draft standard in development by ISO. Similar to PIMS but for AI, the standard is intended to help organizations perform their roles with respect to AI systems and address considerations such as automated decision-making, use of data for ML, and monitoring of changing behavior of AI systems.

10.2.8 Putting it Together: Privacy Governance

As previously described, there are myriad elements and stakeholders at play within a privacy governance program. All these elements must be integrated to produce meaningful privacy-centric safeguards in IT. Implementing a privacy governance program depends on the effective *choreography* of elements and stakeholders alike. How best can a program be implemented that interweaves these elements to benefit IT and effectively leverage IT to safeguard privacy?

Figure 10-1 offers a conceptualization of the varying elements at play in a privacy governance program, summarizing the top-down descriptions of the components described in previous sections of this chapter. Alongside, Tables 10-2 through 10-7 additively illustrate how a privacy governance program builds out across its varied elements.

At the top is, of course, law and policy and, below it, the various elements of privacy, security, responsible AI, compliance, and industry standards. Providing the base is technology. This depiction differentiates varied elements and organizes them in a manner conducive to structuring the overall governance model for a privacy program.

As explained earlier, the compliance program provides the foundational structure on which to organize the core elements of the program. Across the possibly overlapping privacy, security, and responsible AI controls, compliance is the structure on which internal controls are reasonably defined and managed. Standards provide a mechanism both to fact check if

the controls meet minimum expectations as defined by outside parties and to translate the governance program to auditors, customers, and the general public.

While technology serves as the foundation and, ultimately, defined privacy controls must be implemented within IT, the privacy controls defined in the governance program should strive to be agnostic about manual or automated means. This sets the stage for IT to support privacy engineering of safeguards, as will be described in section 10.3.

The overall privacy governance program should aim to be structured and enduring. Designed controls should focus on structuring objectives and activities in measurable and discrete ways that connect, but do not embed, higher order legal requirements or lower-level technological solutions. This intentional design enables flexibility. If laws change, the governance program can absorb and adjust with little perturbation. Likewise, the governance program can also persist through technological change. The key, again, is the structure, which enables a robust, enduring model. Moreover, this also aids continual maturation and evolution of the governance program. As technology advances, the program can adapt, and controls previously undertaken in manual capacity can be automated. This latter point is perhaps the most powerful, as it enables an enduring framework that can scale with the IT infrastructure of an organization, whether it is a small-scale system or a hyper-scale cloud.

Digging deeper, it is further valuable to contrast the abstract model of a privacy governance program, depicted in Figure 10-1, with the actual activities typical privacy governance programs manage. Table 10-9 summarizes core activities of a privacy governance program.

Table 10-9: Core activities typical of a privacy program

Privacy program activities	Description
Privacy and data protection impact assessments	Assessments evaluating privacy harms and issues for major activities undertaken by an organization.
Privacy reviews	Individual design reviews of systems or activities to evaluate the sufficiency of privacy safeguards employed.
Training and awareness	Educational and awareness activities for personnel supporting privacy functions within the organization. Awareness may also include external engagement and transparency activities.
Privacy incident management	Management and response for privacy-related incidents within the organization.
Third-party relationships	Requirements and privacy safeguards when interacting and sharing personal data with external organizations.
Consent and notice	Practices and requirements to provide notice and appropriate consent for users of organizational services.
Data subject rights	Management and honoring of user rights to access, export, delete, and edit their data.

Privacy reviews present an illustrative example to connect the activities of a privacy program with the abstract model of privacy governance in Figure 10-1. In short, the illustration of Figure 10-1 can be implemented for each activity within a privacy program, providing a structured methodology to take key activities, such as privacy reviews, and turn them into tangible and measurable controls that can be implemented by privacy engineers.

Continuing with the example, privacy reviews are fundamentally intended to assess and verify the design of a given service. Privacy reviews evaluate, among other things, the data and uses of a given service, and will further evaluate dataflows across systems as well as geographic boundaries, consent/notice in keeping with organizational requirements, access control, and other aspects as defined by an organization's privacy program.

These facets, e.g., data, use, data flow, and consent/notice, of a privacy review have their foundation in, law, regulation, and policy. At the same time, it is clear they also have grounding in real IT capabilities. Take data flow: Top-down, from the legal viewpoint, the EU-U.S. Data Privacy Framework enforces data protection requirements when transferring data between Europe and the United States.²⁸ Bottom-up, enforcement depends on technical solutions to assure transfers are appropriate and in line with legal requirements. Moreover, data flow is a control tightly interwoven with both security and responsible AI. Here the connection and opportunity are clear. Upholding of the law is dependent upon IT and, given that security and responsible AI have an equal stake in data flow safeguards, privacy can augment existing controls. In addition, such controls are clearly identified in various industry standards, bringing the pieces together into a theme. Compliance further helps bring the pieces together in a framework that defines the controls across overlapping preventive and detective controls to reasonably ensure that cross-border data flow fulfills legal and policy requirements.

Another key component of every privacy program is the identification and tracking of personal data to meet the requirements of laws and regulations, and expectations of customers. Data subjects, or individuals, are granted various rights that may differ across the globe in terms of standards or expectations, but there are key principles that ground the expectations holistically: the right to access, right to delete, right to edit, right to export, right to restrict, and right to object to the processing of certain types of data. The fundamental principle behind these rights is allowing individuals to maintain a certain level of control over their personal data. These foundational rights are then connected to expectations set forth in various global laws and regulations, notably GDPR Articles 12–23.²⁹

To meet the requirements of data subject rights requirements, strong partnerships and technical controls implemented early on via privacy by design is necessary. This can be accomplished with targeted planning between IT, legal, and privacy departments and then documented in privacy reviews. For example, the right to access requires companies to give individuals access to the personal information collected by the organization. To meet this requirement, companies must leverage their data inventories, accurate data tagging, and

controls that link the data collected about individuals to each person. Furthermore, knowledge of where the information is collected from will determine which laws and regulations are triggered in order to satisfy the minimum requirements, which may take the form of a record of processing activities (RoPA).

This structuring sets the stage for the actual privacy engineering within IT architecture. It establishes the choreography in which the high-level legal requirement—in this example, safeguarding of cross-border data flows per the Data Privacy Framework—is organized into a set of measurable privacy and security controls and in consequence can be mapped to the control points and capabilities built into an organization's IT infrastructure. With this stage set, the remaining sections of this chapter detail how this structure is leveraged to ultimately implement a privacy governance program within IT infrastructure. Refer to chapter 2, for an in-depth examination of the role of IT systems engineering in protecting personal privacy.

10.3 Privacy Engineering: Effective Implementation within an Organization's IT Infrastructure

The preceding section broke down the various elements and associated stakeholders at play within an organization's privacy governance program. Given a structured privacy governance program, the next step is understanding how to enable IT to effectively implement privacy safeguards within technology in a measurable and, above all, practical way.

Three key concepts are useful to understand in this endeavor: data governance, technological controls, and the engineering development life cycle. Effective privacy engineering rests upon these concepts, as they offer a technical framework in which a privacy governance program can be implemented. Ultimately, the aim is to provide a mechanism to translate various internal controls defined in the privacy governance program into automated and continuously monitored technological controls across the IT infrastructure.

10.3.1 Data Governance: Conceptualizing Privacy in IT

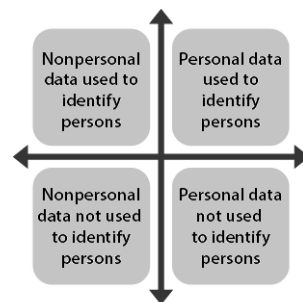
In modern data-driven IT, data governance holds primacy and is critical to understand for effective privacy engineering. Understanding data and associated uses is key, as it enables the creation of effective privacy safeguards and monitoring capabilities in line with the objectives of a privacy governance program.

10.3.1.1 Understanding Data and Use

Figure 10-2 provides a useful depiction to begin the rationalization of data and use toward practical data governance. In Figure 10-2, the x-axis spans from nonpersonal data to personal data, and the y-axis spans from uses not intended to identify persons to uses intended to identify persons. Herein, it becomes clear where general risks lie and how to begin to model data and use it in a manner easy for an organization to grasp.

The figure illustrates where challenges can arise when addressing privacy in technology and, in consequence, what needs to be done to safeguard privacy. When embarking on data governance, organizations initially focus solely on understanding personal data. However, as is evident in the illustration, it is necessary, but insufficient, merely to understand whether personal data is present in an IT system. It is key to understand the use or uses applied as much as the presence of personal data. Immediately, both obvious and nonobvious issues are recognized. For instance, using personal data to identify people is an obvious scenario—as is using nonpersonal data for uses other than identifying people. Trickier is where personal data is used not to identify people, and trickiest of all is where nonpersonal data is used to identify people. Imagine an internet of things (IoT) device collecting nonpersonal data sufficiently detailed to identify the unique behavior of a person as they interact with the device.

Figure 10-2: Framing data and use



As IT shifts from stove-piped solutions into more cloud-centric systems where data-driven operations predominate, the framing illustrated in Figure 10-2 enables the privacy engineer to understand how differing uses may alter privacy risk for given datasets. Notably, in a cloud, where myriad datasets are processed for unlimited uses, the diagram forces a necessary question: How can you model data and use it to continuously monitor changes that affect privacy in IT? Section 10.3.2 expounds on this further, building on the running example throughout this chapter.

10.3.1.2 Modeling and Tagging Data and Use

The modeling and tagging of data and use is core to data governance and is a necessary precondition for measuring and understanding how privacy harms may arise within IT. Fundamentally, the aim is to discretize two key aspects of privacy: data and use.

Modeling data and use is one of the most challenging undertakings of a privacy governance program. It forces different stakeholders across the governance program to come together to create a common taxonomy. It necessitates a governing model to track and manage data. And, in data-driven systems, it requires tagging and tracking data and uses within the IT infrastructure itself. In addition, organizations often struggle with identifying the proper level of detail. What granularity is needed for data? For uses? How much is overkill, and can it be managed over the long term?

Here is where the structure of the privacy governance program described in the prior section can be leveraged to the benefit of privacy engineering. As the program necessarily must balance the differing needs across the stakeholders of the privacy governance program, it establishes the framework in which the taxonomic model for data and use can be created and ultimately governed. In addition, industry standards, such as ISO 19944, are invaluable, as they offer tangible taxonomic models to aid the development of a meaningful and explainable framework for data and use. Separate from and alongside ISO 19944, the following three steps are helpful to conceptualize a taxonomic model for data and use specifically tailored to an organization's needs and goals.

1. Business objective and purpose: Identifying the business objectives and associated purposes is a first step toward scoping the model necessary for data and use. It grounds a taxonomy in the fundamental business needs of an organization and is valuable to help stakeholders remain focused on the key uses and associated data necessary to achieve business goals.
2. Law and policy: Once business objectives and purposes are understood, law and policy help shape the limits of what is and is not allowable. This results in the development of discretized rules tied to data and use or uses and affords the privacy engineer a structure in which to rationalize what to do when data is processed toward the fulfilment of a business objective.
3. Technology: Ultimately, the data and uses, tied to business objectives and constrained by rules, must be channeled through technological controls. Building upon the prior section's discussion on CRUD, understanding the control model as implemented in IT ultimately shapes how privacy is safeguarded pursuant to the data, uses, and rules fulfilling a given business objective. The following section describes this in more detail.

With the previous three steps in mind, coupled with industry standards such as ISO 19944, a privacy governance program can develop a scalable and practical taxonomy of data and use based upon the core business objectives of an organization. Thus established, a taxonomy of data and use enables a privacy governance program to begin the process of automating the program within IT. Critically, it provides a language in which to translate key privacy needs and safeguards against harms in an accessible and usable fashion for privacy engineers. Taxonomy in hand, the next step is to understand how to control data and use within the IT infrastructure. The following section describes this second critical concept of privacy engineering: technological controls.

10.3.2 Technological Controls

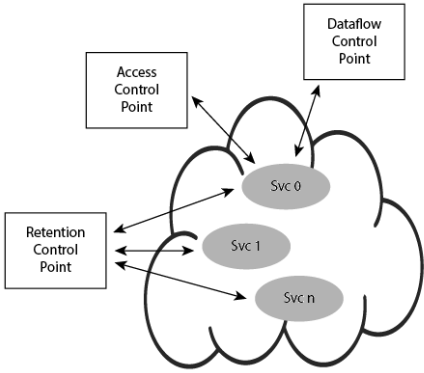
As depicted in Figure 10-1, technology serves as the foundation of a privacy governance program. Tying established internal controls to technological controls implemented within IT is key to enabling IT-centric privacy governance. Here is where the crux of compliance internal controls, security, and IT come together to effectuate meaningful privacy engineering.

10.3.2.1 Mapping Technological Controls to Internal Controls

Implementation of internal controls may be manual, automated, or a mix of both. In the scheme of an effective privacy governance program, this is an expected and desirable aim. When engineering privacy into IT, internal controls—in part or in full—must be translated into technology—specifically, technological controls. Recalling the discussion on CRUD, this means discretizing an internal control into the set of technological control points within the IT infrastructure that monitor various user and system actions.

Figure 10-3 provides an example of some technological control points that may exist within IT infrastructure. The illustration imagines a data-driven environment like a cloud with three such control points: access, data flow, and retention, designed to be used by various services to constrain how data is processed. Note that these controls may exist not merely for privacy, but also for security and responsible AI, reinforcing the value of leveraging preexisting safeguards for the benefit of privacy.

Figure 10-3: Conceptual depiction of technological control points for cloud services



Using Figure 10-3 as a backdrop, reconsider the privacy and security internal controls described in Table 10-7 as shown in Table 10-10.

Table 10-10: Privacy, security, and responsible AI compliance internal controls

Preventive privacy internal control	Limit access of personal data to authorized personnel only.
Preventive security internal control	Limit access of sensitive data to authorized personnel only.
Preventive responsible AI internal control	Display conspicuous notice where AI-generated text is displayed to a user.

These internal controls, at first glance, are insufficiently detailed to be of value to an engineer. However, contrasted against Figure 10-3, it becomes evident how to discretize, and

thus translate, the internal controls into existing technological control points available in the infrastructure. For example, fulfillment of these high-level internal controls could be met as shown in Table 10-11, adding atop the prior buildout of Table 10-7.

Table 10-11: Additive example of illustrative technological controls

Privacy law	HIPAA: Confidentiality: In determining what information is required...[regulation]...shall include procedures to assure that the privacy of individuals receiving health care services is appropriately protected.	
	GDPR: Ensures that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.	
Privacy policy	Organizational policy: Employees processing personal data require a legitimate business need.	
Compliance internal controls	Preventive privacy internal control: Limit access of personal data to authorized personnel only.	
	Preventive security internal control: Limit access of sensitive data to authorized personnel only.	
	Preventive responsible AI internal control: Display conspicuous notice where AI-generated text is displayed to a user.	
Industry-standard mapping	Preventive privacy internal control: Limit access of personal data to authorized personnel only.	UL-1: Internal use: Uses...PII internally only for authorized purpose(s). ³⁰
	Preventive security internal control: Limit access of sensitive data to authorized personnel only.	AC-3: Access enforcement: The information system enforces approved authorizations. ³¹
	Preventive responsible AI internal control: Display conspicuous notice where AI-generated text is displayed to a user.	Measure 2: AI system trustworthiness evaluation: Measure 2.8 notes risks associated with transparency and accountability...are examined and documented. ³²
Technological controls	Data flow control point: (1) Minimize personal data allowed into the system itself, thereby reducing potential harms by removing data superfluous to organizational business objectives. (2) Identify AI-generated text for tailored notice display downstream.	
	Retention control point: Age data off on a periodic basis aligned to where older data is no longer valuable toward business objectives.	

As shown in this simple example, the internal control has been rationalized and discretized into the available control points within the IT infrastructure. Manual controls may still exist beyond those mentioned as overlapping safeguards to meet the high-level internal controls, such as manual review of access logs to ensure the access control point is functioning properly. Second, the discretization of the internal controls into technological controls enables a meaningful discussion of privacy risk. The technological control points may or may not be sufficient to mitigate a privacy harm. Discretizing the internal control makes patently clear the power, and limit, of IT. Here is where things come together: The privacy governance program, from the top of the Figure 10-1 pyramid on down, can identify exactly how privacy

safeguards are fulfilled within IT and enable productive discussion among stakeholders across law, policy, compliance, security, responsible AI, and privacy on the sufficiency and effectiveness of established privacy safeguards.

10.3.2.2 Data Governance and Technological Controls

Technological controls are further augmented by the tagging of data and use established through data governance. Especially in data-driven systems, the technological control points will need to take into consideration data and use to effectively enforce privacy controls. Again, take the high-level internal controls from Table 10-11 as an example. The internal controls stipulate access is limited to personal data. The control points must understand what personal data is to tailor controls accordingly. Likewise, use must also be understood, particularly if an internal control limits access not merely to types of data, as previously exemplified, but refines control to a narrow set of authorized uses. Consider the following data categories, qualifiers, and uses, which are a subset of the full categories described in ISO 19944 and provide for refinement of the technological controls described in Table 10-12.

Table 10-12: Data categories, qualifiers, and uses from ISO 19944³³

Customer content data	Credentials	Data provided by the customer to identify a user.
	Personal health and medical records	Personal health data and medical records.
End user identifiable data	Demographic data	[D]emographic information about end users.
	Biometric and health data	Metrics about the...user’s inherent characteristics. For example... voice prints, posture maintained when walking.
Data identification qualifiers	Identified data	Data that can unambiguously be associated with a specific person.
	Pseudonymized data	Data for which all identifiers are substituted by aliases.
Data processing and use	Provide	Offer capabilities to the customer.
	Market	Promote specified products and services to users.

With these categories in hand from ISO 19944, reimagine the following technological controls, now enhanced to consider data- and use-driven processing as shown in Table 10-13.

Table 10-13: Additive examples of refined, illustrative data- and use-driven technological controls

Privacy Law	HIPAA: Confidentiality: In determining what information is required...[regulation]...shall include procedures to assure that the privacy of individuals receiving health care services is appropriately protected.
	GDPR: Ensures that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.
Privacy policy	Organizational policy: Employees processing personal data require a legitimate business need.
Compliance	Preventive privacy internal control: Limit access of personal data to authorized personnel

internal controls	only.	
	Preventive security internal control: Limit access of sensitive data only to authorized personnel only.	
	Preventive responsible AI internal control: Display conspicuous notice where AI-generated text is displayed to a user.	
Industry-standard mapping	Preventive privacy internal control: Limit access of personal data only to authorized personnel.	UL-1: Internal use: Uses... PII internally only for authorized purpose(s). ³⁴
	Preventive security internal control: Limit access of sensitive data to authorized personnel only.	AC-3: Access enforcement: The information system enforces approved authorizations. ³⁵
	Preventive responsible AI internal control: Display conspicuous notice where AI-generated text is displayed to a user.	Measure 2: AI system trustworthiness evaluation: Measure 2.8 notes risks associated with transparency and accountability...are examined and documented. ³⁶
Technological controls	Access control point: 1. Limit access of identified personal health and medical records only to authorized users to provide medical insurance. 2. Prevent access of identified biometric and health data and identified personal health and medical records from authorized users for marketing.	
	Data flow control point: 1. Minimize the collection of demographic data. 2. Allow the collection of credentials and identified personal health and medical records. 3. Tag AI-generated text provided to customers for all uses to display tailored notice.	
	Retention control point: 1. Age-off all identified data after one year. 2. Age-off all pseudonymized data after five years.	

Just as the discretization of an internal control into technological control points enables a meaningful and productive risk-based discussion, so does the modeling of data and use as applied across the technological control points within IT infrastructure. Taken together, stakeholders across the privacy governance program can holistically evaluate the sufficiency and effectiveness of privacy safeguards instrumented across technological control points, data, and uses. In so doing, privacy engineering is actualized, translating the highest-order objectives of a privacy governance program into actionable, practical technical controls that are rationalized against an organization's evaluation of privacy risk and the fundamental capabilities available within its IT infrastructure.

10.3.3 Engineering Development Life Cycle: Enforcing Privacy Automation at Scale

Modern IT is driven by the engineering development life cycle. The engineering development life cycle aims to build solutions in support of business objectives while addressing reliability and scaling to organizational needs. In modern organizations, such as cloud providers, the engineering development life cycle is an integral part of business processes. While the engineering development life cycle is described further in chapter 2, it is valuable to summarize here, as the engineering development life cycle represents the third concept necessary to effectuate privacy engineering.

The engineering development life cycle is the process engineers leverage daily to scale and deliver solutions reliably and securely. Inculcation of privacy into the engineering life cycle will result in privacy becoming an intrinsic component of the development process. Once privacy engineering has been embedded and standardized into IT infrastructure and development practice, a profound goal can be realized: De facto use of an organization's IT infrastructure becomes an implicit act of privacy compliance. Following on the heels of security, which has similarly been embedded into the engineering development life cycle, this achievement ultimately simplifies privacy governance. It further enables inherent enforcement of privacy controls by embedding privacy into standardized tools and infrastructure. And as privacy controls become more embedded into infrastructure and development processes, engineers can leverage inherent privacy safeguards, simplifying and speeding the delivery of privacy-protective solutions in line with business needs. Not only does this strengthen the privacy program, it makes privacy itself a core component of business solutions, which is an increasingly critical desire of users of modern IT. Embedding privacy into the engineering development life cycle ultimately translates privacy into the terminology, practices and culture of engineers. With privacy thus made meaningful to software developers, privacy engineering can be realized in practice, bringing natural, inherent, and scalable enforcement of privacy safeguards to IT solutions.

10.3.4 Driving and Tracking Progress: Key Performance Indicators

One of the most powerful ways privacy can be incorporated into engineering development life cycles is to create key performance indicators (KPIs). KPIs may be used in concert, or overlapping with, objective key results (OKRs) and key results (KRs). The measures may be quantitative or qualitative, depending upon the nature of the desired measure sought by an organization.

KPIs, OKRs, and KRs are fundamental ways modern software development is tracked and executed by engineering teams and leadership. As much as it is important to drive technologically oriented privacy requirements, it is equally important to tie requirements to KPIs that enable engineers to track progress alongside other measures of success. Once

incorporated, privacy engineers will see their requirements implemented at scale alongside other business objectives.

Working with developers, privacy engineers can craft a variety of KPIs that can be used to track implementation. Examples include customer satisfaction scores (CSAT), customer effort scores (CES), and net promoter scores (NPS). These measures enable privacy engineers to see how privacy capabilities are received by customers, and they positively influence developers by providing tangible evidence of what is and is not valued in given products.

10.3.5 Putting it Together: Creating a Culture of Privacy among Engineers

As much as embedding privacy into IT infrastructure and development practices is critical for the success of a privacy governance program, the establishment of a culture of privacy within engineering communities is equally critical. Engineers, ultimately, must be mindful that the designs and solutions they build respect privacy considerations.

Taken together, data governance, technological controls, and, in particular, both key performance indicators and the engineering development life cycle, can help realize the foundation of a culture of privacy within an organization's engineering community.

In making privacy meaningful and practical for engineers, culture will naturally evolve to be more mindful of privacy challenges. Herein, enforcement thus becomes not an external action by the privacy governance program but an intrinsic mindset of engineers. Moreover, through the building blocks of data governance, technological controls and the engineering development life cycle, training programs can be developed for privacy engineering. And, as awareness increases, an additional benefit equally comes about wherein engineers can explain IT solutions to other stakeholders across the privacy governance program. This achievement brings the privacy governance program full circle. In this, the role of privacy in IT not just establishes itself, but demonstrably strengthens the governance program as a whole, founded upon IT itself as illustrated in Figure 10-1. With privacy thus institutionalized in IT, privacy engineering in consequence becomes professionalized. In these twin goals, a culture of privacy naturally arises throughout the engineering community.

10.4 Evaluating Success: Assessing Sufficiency and Effectiveness of IT Privacy Governance

IT itself enables and increases the ability to measure the effectiveness and sufficiency of a privacy governance program. As the thread of a privacy governance program gets pulled from the top down, evaluating the program becomes at once clearer and more measurable.

Assessing effectiveness begins with the structure of the compliance program underpinning privacy governance, as it establishes the key objectives and associated internal controls to evaluate the health of the overall program, fundamentally grounded in reasonable assurance.

This structure provides the framework wherein risk assessments can be conducted in accordance with standard risk management methodologies.³⁷

As this skeletal structure of the privacy governance program is translated into the IT infrastructure, fine-grained, measurable controls take shape, spanning both the discretized technical controls safeguarding privacy throughout the infrastructure as well as the data governance established to enable tailored control of data and use accordingly. With this structure, the privacy governance program can begin to evaluate various aspects of the program—in real time—to measure when, where, and how internal controls are enforced. Coupled with data governance, the program can further understand where personal data is and how and when it is used, thus providing greater insight into the overall privacy health of the organization and the sufficiency of the varied overlapping controls emplaced.

Importantly, not only does this enable both greater insight and faster evaluation, but it also enables meaningful and understandable evaluation of the technological controls as constructed in IT. Considering Figure 10-3 for instance, access, data flow, and retention are not necessarily sufficient controls to safeguard against privacy harms, nor do they adequately address necessary internal controls in all situations. Additional control points may be needed pursuant to certain scenarios. Through the structure of the privacy governance program, top to bottom, tangible risk evaluation can be developed and, in consequence, improvements in privacy governance become backstopped—and grounded—by empirical evidence from measurements arising from the technological controls within the IT infrastructure itself. Reasonable assurance in mind, empirically backed risk evaluation can be undertaken to determine whether IT solutions sufficiently safeguard against the privacy harms the governance program is designed to prevent. Together with the engineering development life cycle, adjustments to control structures can be made quickly, enabling rapid response and improvement across the entirety of the IT infrastructure. And ultimately, leveraging the structure depicted in Figure 10-1 and exemplified in the built-out example in Table 10-13, such adjustments can be translated across the components and associated stakeholders of the privacy governance program, enabling transparent understanding of where and how privacy risk is mitigated.

Data governance also enables improved ability to assess—and iterate upon—the proper modeling of data and use. Just as data and use must be modeled to align with business objectives, they must similarly be modeled sufficiently to identify data types and uses with enough granularity to reasonably safeguard against privacy harms. For instance, if a model only includes email addresses and individuals' names, this personal data is likely insufficient to support providing of medical or financial services. Data governance makes this apparent to all stakeholders in the program and, in consequence, refinement can be had to ensure technological implementation and modeling can adequately safeguard privacy within IT, thereby improving existing technological controls in place.

10.5 Summary

Ultimately, as a privacy governance program evolves and matures to address the privacy challenges of IT, IT itself reciprocally improves the ability, fidelity and effectiveness of the program itself. Moreover, in light of the engineering development life cycle, it enables the privacy governance program to scale with technology, which is a necessity in the Information Age. The role of IT in privacy, once established, inherently strengthens the privacy governance program, as it forces the development of structured, measurable and scalable controls. This modernized approach to privacy governance, established through the strengthened role of IT in privacy, enables deep insight into privacy-impacting activities within an organization. This chapter has presented a structured approach in which such insight can be achieved, interweaving the various aspects of privacy governance—law, policy, compliance, security, and technology—into a coherent choreography of activities fundamentally underpinned by and demonstrating the value of IT’s role in privacy.

Endnotes

- 1 “Privacy Impact Assessment (PIA) Methodology,” Commission Nationale Informatique & Libertés (CNIL), February 2018, <https://www.cnil.fr/sites/cnil/files/atoms/files/cnil-pia-1-en-methodology.pdf>.
- 2 “Privacy Impact Assessment (PIA) Methodology,” CNIL.
- 3 Privacy Framework, National Institute of Standard and Technology (NIST), accessed October 2019, <https://www.nist.gov/privacy-framework>.
- 4 Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation); EUR-Lex, <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.
- 5 “Your Rights Under HIPAA,” U.S. Department of Health and Human Services, January 19, 2022, <https://www.hhs.gov/hipaa/for-individuals/guidance-materials-for-consumers/index.html>.
- 6 EU Artificial Intelligence Act, Future of Life Institute, accessed April 2024, <https://artificialintelligenceact.eu/>.
- 7 Health Insurance Portability and Accountability Act of 1996 (HIPAA), U.S. Congress, <https://www.congress.gov/104/plaws/publ191/PLAW-104publ191.pdf>.
- 8 General Data Protection Regulation, European Union.
- 9 COSO defines internal controls as “a process...designed to provide reasonable assurance regarding the achievement of objectives relating to operations, reporting, and compliance.” *Internal Control - Integrated Framework*, Committee of Sponsoring Organizations (COSO), accessed April 2024, <https://www.coso.org/guidance-on-ic>.
- 10 COSO, Preventive controls are “designed to avoid an unintended event...at the time of initial occurrence.” *Internal Control - Integrated Framework*, Committee of Sponsoring Organizations (COSO), accessed April 2024, <https://www.coso.org/guidance-on-ic>.
- 11 COSO, Detective controls are “designed to discover an unintended event...after the initial processing has occurred” *Internal Control - Integrated Framework*, Committee of Sponsoring Organizations (COSO), accessed April 2024, <https://www.coso.org/guidance-on-ic>.
- 12 NIST SP 800-53 Rev. 5, *Security and Privacy Controls for Information Systems and Organizations*, U.S. Department of Commerce (DOC), September 2020, <https://csrc.nist.gov/publications/detail/sp/800-53/rev-4/final>.
- 13 NIST IR 8062, *An Introduction to Privacy Engineering and Risk Management in Federal Systems*, U.S. Department of Commerce (DOC), January 2017, <https://csrc.nist.gov/publications/detail/nistir/8062/final>.
- 14 NIST SP 800-53 Rev. 5, *Security and Privacy Controls for Information Systems and Organizations*.
- 15 NIST AI 100-1, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, U.S. Department of Commerce (DOC), January 2023, <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>.

- 16 NIST SP 800-53 Rev. 5, *Security and Privacy Controls for Information Systems and Organizations*.
- 17 NIST SP 800-53 Rev. 5, *Security and Privacy Controls for Information Systems and Organizations*.
- 18 NIST AI 100-1, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*.
- 19 ISO/IEC 19944-1:2020 *Cloud Computing and Distributed Platforms—Data Flow, Data Categories and Data Use*, International Organization for Standardization (ISO), 2020, <https://www.iso.org/standard/79573.html>.
- 20 ISO/IEC 27001:2022 *Information Security, Cybersecurity and Privacy Protection*, International Organization for Standardization (ISO), 2022, <https://www.iso.org/standard/27001>.
- 21 ISO/IEC 27701:2019 *Security Techniques, Extension to ISO/IEC 27001 and ISO/IEC 27002 for Privacy Information Management*, International Organization for Standardization (ISO), 2019, <https://www.iso.org/standard/71670.html>
- 22 NIST IR 8062, *An Introduction to Privacy Engineering and Risk Management in Federal Systems*.
- 23 *Privacy Framework*, National Institute of Standard and Technology (NIST).
- 24 NIST SP 800-53 Rev. 5, *Security and Privacy Controls for Information Systems and Organizations*.
- 25 *System and Organization Controls: SOC Suite of Services*, American Institute of Certified Professional Accountants (AICPA), accessed June 2019, <https://www.aicpa.org/soc>.
- 26 NIST AI 100-1, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*.
- 27 ISO/IEC 42001:2023 *Information Technology, Artificial Intelligence, Management System*, International Organization for Standardization (ISO), 2023, <https://www.iso.org/standard/81230.html>.
- 28 “Questions & Answers: EU-U.S. Data Privacy Framework,” European Commission, July 10, 2023, https://ec.europa.eu/commission/presscorner/detail/en/qanda_23_3752.
- 29 *General Data Protection Regulation, Articles 12–23*.
- 30 NIST SP 800-53 Rev. 5, *Security and Privacy Controls for Information Systems and Organizations*.
- 31 NIST SP 800-53 Rev. 5, *Security and Privacy Controls for Information Systems and Organizations*.
- 32 NIST AI 100-1, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*.
- 33 ISO/IEC 19944-1:2020 *Cloud Computing and Distributed Platforms—Data Flow, Data Categories and Data Use*.
- 34 NIST SP 800-53 Rev. 5, *Security and Privacy Controls for Information Systems and Organizations*.
- 35 NIST SP 800-53 Rev. 5, *Security and Privacy Controls for Information Systems and Organizations*.
- 36 NIST AI 100-1, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*.
- 37 An example of a risk management methodology is ISO 31000, which provides standard guidelines, principles, frameworks, and processes for assessing risk. *ISO 31000 Risk Management*, International Organization for Standardization (ISO), accessed April 2023, <https://www.iso.org/iso-31000-risk-management.html>.

About the Contributors

Executive Editor

Travis D. Breaux, CIPT

Travis D. Breaux is an associate professor of computer science at Carnegie Mellon University (CMU), where he conducts research on developing new methods and tools to build privacy-preserving, secure, and trustworthy information systems that are accountable to law and society. Breaux designed CMU's first privacy engineering course, which is part of the MSIT-Privacy Engineering program, and he has published numerous award-winning papers on privacy and software accountability in Institute of Electrical and Electronics Engineers (IEEE) and Association for Computing Machinery (ACM) journals and conference proceedings.

He is the director of CMU's Master of Software Engineering programs and of the Requirements Engineering Laboratory, which conducts research in privacy sponsored by the National Science Foundation (NSF), Department of Homeland Security (DHS), and the National Security Agency (NSA).

Breaux served as chair of the U.S. Association for Computational Mechanics (USACM) privacy and security committee, on the USACM executive council, and as associate editor of *ACM Transactions on Software Engineering and Methodology*. Breaux holds a doctorate in computer science from North Carolina State University, a Bachelor of Science in computer science from the University of Oregon, and a Bachelor of Arts in anthropology from the University of Houston.

Contributors

Chris Clifton

Chris Clifton is a professor of computer science and, by courtesy, statistics at Purdue University. He works on data privacy, particularly with respect to analysis of private data. This includes privacy-preserving data mining, data deidentification and anonymization, and limits on identifying individuals from data mining models. He also works more broadly on data mining, including fairness issues, data mining of text, and techniques applied to interoperation of heterogeneous information sources. Fundamental data mining challenges posed by these include skew and bias in learning, extraction of knowledge from noisy data, identification of knowledge in highly skewed data, including a few examples of "interesting" behavior, and limits on learning. He also works on database support for widely distributed and autonomously controlled information, particularly issues related to data privacy.

Prior to joining Purdue in 2001, Clifton was a principal scientist in the Information Technology Division at the MITRE Corporation. Before joining MITRE in 1995, he was an assistant professor of computer science at Northwestern University. He has doctorate and Master of Arts degrees from Princeton University, earned in 1991 and 1988 respectively, and Bachelor of Science and Master of Science degrees from the Massachusetts Institute of Technology, both earned in 1986. From 2013 to 2015, he served as a rotating program director in the Division of Information and Intelligent Systems and the Secure and Trustworthy Cyberspace Program at the National Science Foundation (NSF). From 2023-2024, he served as interim head of computer science at Purdue.

Lorrie Faith Cranor, CIPT, Westin Emeritus Fellow

Lorrie Faith Cranor is the director and Bosch Distinguished Professor in Security and Privacy Technologies of CyLab and the FORE Systems University professor of computer science and of engineering and public policy at CMU. She also directs the CyLab Usable Privacy and Security Laboratory (CUPS) and co-directs the privacy engineering program. In 2016 she served as chief technologist at the U.S. Federal Trade Commission (FTC). She is also a cofounder of Wombat Security Technologies, a security awareness training company that was acquired by Proofpoint.

Cranor has authored more than 200 research papers on online privacy, usable security, and other topics. She coedited the seminal book *Security and Usability* and founded the Symposium On Usable Privacy and Security (SOUPS). She also chaired the Platform for Privacy Preferences Project (P3P) Specification Working Group at the World Wide Web Consortium (W3C). She has served on the Electronic Frontier Foundation (EFF) board of directors, the Future of Privacy Forum (FPF) advisory board, the Computing Research Association (CRA) board of directors, and the Aspen Institute cybersecurity group. She was elected to the ACM Computer Human Interaction (CHI) Academy, named an American Association for the Advancement of Science (AAAS) fellow, named an ACM fellow for her contributions to usable privacy and security research and education, and named an IEEE fellow for her contributions to privacy engineering. She also received the 2018 ACM CHI Social Impact Award, the 2018 IAPP Privacy Leadership Award, and the 2018 IEEE Cybersecurity Award for Practice along with her colleagues. She was previously a researcher at AT&T Labs Research. She holds a doctorate in engineering and policy from Washington University in St. Louis.

Kira Fuller, CIPM

Kira Fuller has over 20 years of experience in the U.S. federal government and at Microsoft, including unique and specialized knowledge in compliance, audit, and internal policy and compliance standards development. She is adept at leading high-performing teams of personnel with widely disparate backgrounds and skills in complex and heavily regulated data-driven environments.

Presently she is a senior director within Microsoft's company-wide Regulatory Governance program in the global Privacy, Safety, and Regulatory Affairs (PSRA) organization, developing strategies, governance controls, training, and community outreach activities to continuously build company buy-in and public trust in critical domains such as privacy, digital safety, responsible artificial intelligence (AI), and accessibility regulation.

Prior to joining Microsoft, Kira was the chief of the Office of Compliance Awareness at the NSA. This office played a key role in the continued evolution of the NSA's compliance program through integrated compliance-related training, communications, events, and customer service activities, providing assurance that agency employees were aware of compliance responsibilities, principles, and initiatives; had sufficient training to conduct their jobs in a compliant manner; and were able to execute the agency's missions to the full extent of its authorities while protecting civil liberties and privacy.

Prior to joining the NSA's compliance program, Kira worked as a federal auditor in the Offices of Inspector General at the NSA and at the Department of Veterans Affairs.

Kira is a Certified Information Privacy Manager (CIPM) and holds a master's degree in business administration and a bachelor's degree in health care administration and policy.

Simson L. Garfinkel, CIPP/US

Simson Garfinkel is the chief scientist of BasisTech, a technology accelerator in Somerville, Massachusetts. He is currently working on projects at the intersection of AI, privacy, data management, and digital forensics. He holds seven U.S. patents and has published dozens of research articles in computer security and digital forensics. He is a fellow of AAAS, ACM and IEEE.

Garfinkel is the author or co-author of seventeen books on computing. His most recent book is *Law and Privacy for the Quantum Age*, which discusses quantum computing, quantum cryptography, and quantum sensing. He is also known for *Database Nation*, which explored privacy issues Practical UNIX, and internet security and sold more than 250,000 copies. He is a member of the National Association of Science Writers and has won the national Jesse H. Neal National Business Journalism Award for his commentary on computer security.

As an entrepreneur, Garfinkel founded five companies between 1989 and 2000, including Vineyard.NET, which provided internet service on Martha's Vineyard to more than a thousand customers from 1995 through 2005, and Sandstorm Enterprises, an early developer of computer forensic tools.

Garfinkel received three Bachelor of Science degrees from the Massachusetts Institute of Technology (MIT) in 1987, a Master of Science in journalism from Columbia University in 1988, and a doctorate in computer science from MIT in 2005.

Hanan Hibshi

Hanan Hibshi is an assistant teaching professor at the Information Networking Institute at CMU, one of CMU Cylab's core faculty, and an affiliated faculty with the Software and Societal Systems Department (S3D).

Hibshi's research area includes usable security, cybersecurity education, security requirements, and expert decision-making. Hibshi is experienced in conducting ethical research with human subjects, and her work has involved collecting empirical data from security experts to improve the security of composable systems. Her work intersects security education, software engineering, usable security, human factors, blockchain, and AI.

Hibshi is the research lead investigator for the picoCTF educational platform. Her work focuses on increasing diversity in capture-the-flag (CTF) security competitions, improving the user experience on the platform, and enhancing the educational outcome of cybersecurity CTFs. Her work includes investigating the challenges facing developers and security experts when working hands-on on security problems. Hibshi is also investigating usable security and privacy challenges facing the field's developers, experts, and professionals. As a security and privacy educator, Hibshi investigates how to improve cybersecurity skills in future engineers.

David James Marcos, AIGP, CIPM, CIPT

David Marcos is the senior director of governance and enablement within Microsoft's Office of Responsible AI, driving cross-company efforts to institutionalize AI governance, awareness, and training. Prior to this role, he was chief privacy officer of Microsoft's Cloud and AI division, enabling governance and privacy engineering solutions for the EU General Data Protection Regulation (GDPR). Before employment with Microsoft, Marcos held a variety of positions at the NSA, including technical director of the NSA Office of Civil Liberties and Privacy, deputy technical director of the NSA Office of the Director of Compliance, and privacy research lead in the NSA Research Directorate. Marcos holds a Bachelor of Science in computer engineering from Pennsylvania State University ("Penn State") and an Master of Science in strategic intelligence from the National Intelligence University. He is also a Certified Information Privacy Manager and Technologist (CIPM/CIPT) and an AI Governance Professional (AIGP).

Florian Schaub, CIPP/US, CIPT

Florian Schaub is associate professor of information and of electrical engineering and computer science at the University of Michigan. His interdisciplinary research combines privacy, human-computer interaction, emerging technologies, and public policy. He studies people's privacy needs and behavior, investigates technology-related privacy implications, and develops human-centric privacy solutions that help people better manage their privacy in technology contexts. Schaub holds a doctorate in computer science from the University of Ulm and was a postdoctoral fellow in CMU's School of Computer Science. His research has been honored with the 2019 Caspar Bowden Award for Outstanding Research in Privacy

Enhancing Technologies and with best paper awards at the ACM Special Interest Group on Computer–Human Interaction (SIGCHI) Conference on CHI, the USENIX Security Symposium, and SOUPS. Schaub is a Defense Advanced Research Projects Agency (DARPA) Young Faculty Award recipient. His research has directly impacted industry practice and public policy, including the rulemaking process for the California Consumer Privacy Act (CCPA).

Stuart S. Shapiro, CIPP/G, CIPP/US

Stuart S. Shapiro is a principal cybersecurity and privacy engineer at the MITRE Corporation, a not-for-profit company performing technical research and consulting primarily for the U.S. government. At MITRE, he supports a wide range of security and privacy activities involving, among others, critical infrastructure protection, policy frameworks, risk and control assessment, and incident response. In particular, he has led multiple research and operational efforts in the areas of privacy engineering, privacy risk management, and privacy-enhancing technologies (PETs) for government sponsors, including those focused on connected vehicles, deidentification, and privacy threat modeling. He has also held several academic positions and has taught courses on the history, politics, and ethics of information and communication technologies. His professional affiliations include the IAPP, ACM and ACM's Technology Policy Council.

Blase Ur, CIPT

Blase Ur is an associate professor of computer science at the University of Chicago, where he researches computer security, privacy, human-computer interaction, and ethical AI. He directs the UChicago Security, Usability, & Privacy Education & Research group ("SUPERgroup"), which uses data-driven methods to improve the usability of complex computer systems and to help users make better security and privacy decisions. He has received an NSF CAREER Award, Quantrell Award for Undergraduate Teaching, five best/distinguished paper awards, and five honorable mention paper awards. His research has been covered in *The New York Times*, *Wired*, *Forbes*, and *Ars Technica*, among others. He has also received the Allen Newell Award for Research Excellence, SIGCHI Outstanding Dissertation Award, IEEE Cybersecurity Award for Practice, and a Fulbright scholarship. He holds doctorate and Master of Science degrees from CMU and a Bachelor of Arts from Harvard University.

Nicole Uribe, CIPP/US

Nicole Uribe is senior director of global privacy operations at Intuitive. She leads a team of privacy professionals and engineers to drive operational efficiency in the technical and administrative application of privacy controls across products, services, and privacy vendor management. She previously held leadership roles focused on regulatory governance and privacy operations at Microsoft and Meta, where she led teams that worked on privacy by design and risk management.

Zhiwei Steven Wu

Zhiwei Steven Wu is an assistant professor in the School of Computer Science at CMU. His research aims to make machine learning (ML) and algorithmic decision-making more reliable and better aligned with societal values. Toward this goal, his research investigates both core algorithmic questions and the rich interactions between AI systems and humans.

Wu's research has been generously supported by the NSF, the Okawa Foundation, CMU's Block Center for Technology and Society, Apple, and Cisco Research, as well as through an NSF CAREER Award, an Amazon Research Award, a Google Faculty Research Award, J.P. Morgan Faculty Awards, Meta Research awards, and a Mozilla Research Grant.

Index of Searchable Terms

A

- ABAC. *See* Attribute-based access control
- A/B testing
- Accelerometers
- Acceptance testing
- Access control
 - authentication and
 - authorization mechanisms
 - defined
 - federated identity management
 - identity and
- Access-control lists (ACLs)
- Access-control models
- Accessibility
- Accountability
- ACL. *See* Access-control list
- ACM. *See* Association for Computing Machinery
- Acquisti, Alessandro
- ACR. *See* Automated content recognition
- Adblock Plus browser extension
- AdChoices icon
- Address book, unwanted access to
- Adleman, Len
- Administrative controls
- Administrative monitoring of personal spaces
- Administrators, privacy protection
- AdNauseum browser extension
- Adobe Acrobat
 - application-level encryption
 - client-side PKI
 - symmetric encryption
- Adobe Flash plug-in
- Advanced Encryption Standard (AES)
- Advanced persistent threats (APTs)
- Adversary
 - in computer security
 - in security engineering
- Advertising
 - location-based
 - online behavioral (*See also* Online advertising)
 - violation of traditional ethical norms
- AE. *See* Authenticated encryption
- AEAD. *See* Authenticated encryption with associated data

- AES. *See* Advanced Encryption Standard
- AES algorithm
- Aggregation, privacy problem taxonomy
- Agile designs
- AICPA. *See* American Institute of Certified Public Accountants
- AI. *See* Artificial intelligence
- AI Management System (AIMS)
- AI Risk Management Framework (RMF)
- Alexa. *See* Amazon Echo (Alexa)
- Algorithmic Foundations of Differential Privacy, The” (Dwork and Roth)
- Algorithms. *See* Encryption algorithms
- Almuhimedi, Hazim
- Alphabet, Toronto smart city project
- AlphaGo
- Alpha testing
- ALPRs. *See* Automated license plate readers
- Altman, Irwin
- Amazon
 - AI resume-selection tool
 - behavioral advertising on
 - crowdsourcing platform
 - recommendation service
 - security flaws and digital identity
 - surveillance of Alexa conversations
- Amazon Echo (Alexa)
- Amazon Ring doorbells
- American Civil Liberties Union (ACLU), Clearview AI settlement
- American Institute of Certified Public Accountants (AICPA), Generally Accepted Privacy Principles
- American Management Association (AMA), employee monitoring survey
- Anchoring
- Android platform. *See also* Smartphones
 - digital signatures and
 - location data sharing
 - Path API and
 - third-party developers and
- Anonymity
- Anonymization
 - aggregation-based approaches
 - approaches to
 - client-side control
 - of microdata
 - quasi identifiers
 - strong *vs.* weak identifiers
- Anonymous proxies
- Anti-Bullying Bill of Rights (New Jersey)
- Antigoals
- Antispyware programs
- AOL
 - anonymous data release
 - pseudonymous data and
 - search term release
- APEC. *See* Asia-Pacific Economic Cooperation

- API. *See* Topics application programming interface
- APIs. *See* Application programming interfaces
- Apple
 - AirTags
 - App Tracking Transparency (ATT) options
 - FaceTime Attention Correction
 - HomeKit
 - iMessage
 - Siri
 - third-party app policies
- Apple FaceID
- Apple iOS
 - encryption
 - third-party developers and
- Apple iPhone. *See also* Smartphones
 - data encryption
 - Find My Friends app
 - Find My Phone app
 - Path API and
 - security flaws
 - third-party developers and
- Application-level encryption
- Application programming interfaces (APIs)
 - exposing personal data through
 - reusing
 - testing
- Appropriation
 - In privacy problem taxonomy
 - as problematic data action
- Appropriation harms
- App Tracking Transparency (ATT) options
- APTs. *See* Advanced persistent threats
- AR. *See* Augmented reality
- AR-CNN. *See* Autoregressive convolutional neural networks
- Arm TrustZone
- Artificial intelligence (AI)
 - AI Management System (AIMS)
 - AI Risk Management Framework (RMF)
 - generative (*See* Generative AI)
 - machine learning and (*See also* Machine learning)
 - responsible AI
- Artificial Intelligence (AI) Act (EU)
- Asia-Pacific Economic Cooperation (APEC)
- Association for Computing Machinery (ACM)
- Astroturfing
- Asymmetric encryption. *See* Public key (asymmetric) encryption
- At setup interfaces
- ATT. *See* App Tracking Transparency (ATT) options
- Attribute-based access control (ABAC)
- Attribution, identity and
- Audio and video surveillance
 - closed-circuit television (CCTV)

- drones
- educational technology and
- effective practices
- facial recognition software
- hidden cameras and microphones
- protecting against
- smart televisions
- speech recognition
- video doorbells and citizen surveillance
- voice over IP (VoIP) conversations
- Auditory privacy interfaces
- Augmented reality (AR)
- Augmented reality (AR) glasses
- Authenticated encryption (AE)
- Authenticated encryption with associated data (AEAD)
- Authentication
 - access control and
 - backup
 - biometric
 - biometrics and
 - device-based
 - location-based
 - mechanisms of
 - multifactor
 - passwords
 - Security Assertion Markup Language (SAML)
 - as security property
 - single-sign-on system
- Authorization
 - access control and
 - mechanisms
 - as security property
- Autocomplete models
- Automated content recognition (ACR)
- Automated license plate readers (ALPRs)
- Automation
- Autoregressive convolutional neural networks (AR-CNN)
- Availability
 - privacy design and
 - as security property
- Availability heuristic

B

- Back doors
- Backup authentication
- Bahatia, Jaspreet
- Balancing Agility and Discipline: A Guide for the Perplexed* (Boehm & Turner)
- Balebako, Rebecca
- Bard, large language model (LLM)
- Baumer, David L.
- Beacons
- Behavior. *See also* Privacy behavior; Privacy decision-making and behavior
 - authentication using

- privacy preferences *vs.*
 - in usability testing
- Behavioral advertising
 - approaches to
 - benefits to users
 - as decisional interference
 - regulation of
 - types of interference and
- Behavioral modeling
- Bernstein, Daniel J.
- Beta testing
- Biham, Eli
- Biometric authentication
- Biometrics
 - authentication and
 - identity and
 - privacy-specific trade space and
- Bitcoin
 - blockchain technology and
 - cryptographic hash functions and
 - database encryption and
- Black Lives Matter movement
- Blackmail threat
- Blockchain technology
 - cryptocurrency and
 - cryptographic certificates
 - database encryption and
- Block ciphers
- Block encryption algorithms
- Blocking location tracking
- Blocking privacy controls
- Blocking web tracking
 - browser privacy settings
 - deciding what to block
 - effective practices to prevent
 - email tracking
 - third-party browser extensions
 - web-based privacy tools
 - web searches and
- Block-level disk encryption
- Bluetooth
 - rental car
 - tracking tags
 - USB security tokens and
- Boehm, Barry
- “Born Unequal: A Study of the Helpfulness of User-Generated Product Reviews” (Pan and Zhang)
- Bot
 - infected computer
 - social
- Botnet
- “Boundaries of Privacy Harm, The” (Calo)
- Boundary regulation process

- Bounded rationality
- boyd, danah
- Brandeis, Louis
- Brave Browser
- Bravo-Lillo, Cristin
- Breaux, Travis D.
- Bring your own device (BYOD)
- Browser extensions, third-party
- Browser fingerprinting
- Browsers. *See also* Web browsers
- Brute force attack
- Buffer overflow vulnerability
- Bug bounty programs
- Bugs
 - cryptographic system
 - software vulnerabilities
- Bug tracking
- BYOD. *See* Bring your own device

C

- CA. *See* Certificate authority
- CAA. *See* Certification Authority Authorization
- CAC smart cards. *See* Common access card (CAC) smart cards
- CALEA. *See* Communications Assistance for Law Enforcement Act
- California Civil Code
- California Consumer Privacy Act (CCPA)
 - opt-out link
 - privacy controls
 - privacy design requirements
- California Privacy Protection Act
- Calo, Ryan
- Cambridge Analytica
- Cameras, hidden
- Canadian Institute of Chartered Accountants
- CAN-SPAM. *See* Controlling the Assault of Non-Solicited Pornography and Marketing (CAN-SPAM) Act
- Capability Maturity Model Integration (CMMI)
- Cars
 - Google's Street View
 - self-driving
 - sensor-based surveillance
 - tracking technologies in
- Catfishing
- CBC. *See* Cipher block chaining
- CCTV. *See also* Closed-circuit television
- CDA. *See* U.S. Communications Decency Act
- Cell phones. *See* Mobile phones; Smartphones
- Cell tower triangulation
- Center for Democracy and Technology
- Central Intelligence Agency (CIA), "Weeping Angel" program
- CEO. *See* Chief executive officer (CEO)
- Certificate authority (CA)
- Certificate revocation list (CRL)
- Certificate signing request (CSR)

- Certification Authority Authorization (CAA)
- ChaCha20 algorithm
- Challenge response authentication
- Charter Communications
- Chatbots
 - business uses
 - personal uses
- ChatGPT
 - as large language model (LLM)
 - open-source LLMs and
 - reinforcement learning algorithms and
 - tools
- Checklist on Disclosure Potential of Proposed Data Releases
- Chief executive officer (CEO)
- Chief information security officer (CISO)
- Chief privacy officer (CPO)
- Children
 - accessibility to
 - data-driven education tools and
 - internet-connected toys and
 - monitoring internet usage of
 - privacy design considerations
 - privacy risks and
 - tracking, using location-based services
- Children's Internet Protection Act (CIPA)
- Children's Online Privacy Protection Act (COPPA)
 - compliant user registration process
 - IP addresses as PII
 - Parental Consent
- Chilling effects
- China
 - deep packet inspection in
 - facial recognition software use in
 - social credit system
 - tracking and surveillance of ethnic groups
- C-HIP. *See* Communication-human information processing (C-HIP) model
- Choice architecture
- CIA (confidentiality, integrity, availability) triad
 - NIST privacy engineering objectives and
 - security risk and
 - significance of elements
 - tension among elements
- CIPA. *See* Children's Internet Protection Act
- Cipher block chaining (CBC)
- Cipher suites
- Ciphertext
- CISA. *See* U.S. Cybersecurity and Infrastructure Agency
- CISO. *See* Chief information security officer (CISO)
- Citizen surveillance
- Civilian mass surveillance
- Clayton, Richard
- Clearview AI

- Clementi, Tyler
- Client-server TLS1.3 communication
- Clifton, Chris
- Clipper chip
- Cliqz
- Closed-circuit television (CCTV)
- Closed-source software
- Closed testing
- Cloud-based computing
- Cloud services, technological controls for
- Clustering
- CMMI. *See* Capability Maturity Model Integration
- Code reviews
- Coding practices
- Cohen, Julie
- Comcast, deep packet inspection
- Common access card (CAC) smart cards
- Communication-human information processing (C-HIP) model
- Community of practice
- COMPAS. *See* Correctional Offender Management Profiling for Alternative Sanctions
- Complete mediation principle
- Compliance
 - check, in privacy design process
 - completeness arguments and
 - internal controls for
 - IT infrastructure and
 - legal rules and
 - privacy design process and
 - privacy governance and
 - requirements template
 - transparency reports about
 - user needs *vs.*
- Compliance model
- Comprehension testing
- Computer
 - authentication via
 - surveillance via
- Computer security. *See also* Security
 - access control (*See* Access control)
 - adversary concept
 - breadth of the work
 - defined
 - properties
 - vehicle sensors and
- Computer security attacks
 - insider threats
 - malware
 - misconfiguration
 - software vulnerabilities
 - stolen credentials
- Computer security principles
 - complete mediation

- defense-in-depth
- economy of mechanism
- least privilege
- open design
- psychological acceptability
- safe defaults
- Concept of operations (CONOPs)
- Concurrent Versions System (CVS)
- Confidentiality
 - breach of
 - encryption and
 - privacy design and
 - privacy law and policy on
 - safeguarding, ML applications and
 - as security property
- Confidentiality harm
- Consent
 - opt-in
 - passive *vs.* implied
 - web tracking, GDPR and
- Consent interfaces
- Consequence modeling
 - combining models
 - compliance model
 - Fair Information Practice Principles (FIPPs)
 - problems for individuals (NIST)
 - Subjective/Objective dichotomy (S/OD)
 - taxonomy of privacy problems
- Content filtering
- Context, of privacy preferences
- Context collapse
- Context-dependent privacy interfaces
- Contextual integrity (Nissenbaum)
- Controlled rounding
- Controlling the Assault of Non-Solicited Pornography and Marketing (CAN-SPAM) Act
- Control paradox
- Cookies. *See also* HTTP cookies
 - accept/reject
 - Flash
 - notifications about
 - opt-out
 - third-party
- Cookie syncing
- COPPA. *See* Children's Online Privacy Protection Act
- Correctional Offender Management Profiling for Alternative Sanctions (COMPAS)
- Counter mode (CTR)
- Coupling
- COVID-19 pandemic
 - employee tracking during
 - intimate partner abuse and
 - surveillance and monitoring during
 - virtual schooling and

- work from home (WFH) and
- CPO. *See* Chief privacy officer (CPO)
- Cranor, Lorrie Faith
- Create, read, update, delete (CRUD)
- Credentials, stolen
- CRL. *See* Certificate revocation list
- Cross-border data flows, safeguarding
- Cross-site scripting (XSS)
- Crowdsourcing platforms
- CRUD. *See* Create, read, update, delete
- Cryptanalysis
- Cryptanalyst
- Cryptocurrencies
 - cryptographic hash functions and
 - database encryption and
 - scams involving
- Cryptographer
- Cryptographic certificates
- Cryptographic hash functions
- Cryptographic system
 - defined
 - email encryption
 - World Wide Web and Transport Layer Security
- Cryptography. *See also* Encryption
 - computer security and
 - erasure and retention rules
 - public key [*See* Public key (asymmetric) encryption]
- Cryptosystem
- CSAT. *See* Customer satisfaction score
- CSR. *See* Certificate signing request
- CTR. *See* Counter mode
- Customer effort score (CES)
- Customer experience. *See* User experience (UX) design
- Customer satisfaction score (CSAT)
- Customer service, computer security system and
- CVS. *See* Concurrent Versions System
- Cyberbullying
- Cyber defense analysis
- Cybersecurity. *See also* Computer security
- Cybersecurity and information technology (IT) security. *See* Computer security

D

- DAA. *See* Digital Advertising Alliance
- DAC. *See* Discretionary access control
- Daemen, Joan
- DALL-E diffusion model
- Dark patterns
- Data
 - encryption of (*See* Encryption)
 - frequency *vs.* magnitude
 - individually identifiable
 - linkable *vs.* linked
 - personal, GDPR definition

- synthetic
- Data administration, computer security system and
- Data at rest encryption
- Database, encrypted
- Database reconstruction
- Database schemas
- Data collection types of
- Data Encryption Standard (DES)
- Data engineers, machine learning and
- Data governance
 - privacy engineering and
 - privacy governance program and
 - technological controls and
- Data in flight encryption
- Data in motion encryption. *See also* Data in flight encryption
- Data in use encryption
- Data life cycle
 - completeness argument and
 - data retention
 - extremes (maximize utility *vs.* minimize risk)
 - flow chart
 - passive *vs.* implied consent
 - privacy objectives, business practices and
 - repurposing data
 - types of data collection
- Data masking
- Data minimization
 - internet monitoring and
 - in privacy design process
- Data practice
- Data protection authorities (DPAs) (EU)
- Data protection officer (DPO)
- Data retention
- Data scientists, machine learning and
- Data subject access requests (DSARs)
- Data transformation
- DDoS. *See* Distributed denial-of-service
- Decisional interference
 - behavioral advertising as
 - defined
 - as invasion form
 - machine learning and
 - ML fairness and
 - privacy problem taxonomy and
- Decision making, privacy. *See* Privacy decision making and behavior
- Decision trees
- Decoupled opt-out
- Decoupled privacy controls
- Decrypting key
- Deep Crack computer
- Deepfakes
- Deep learning

- DeepNude app
- Deep packet inspection
- Default bias
- Defect, software
- Defense-in-depth principle
- Delegated consent
- Denial-of-service (DoS) attacks
- Deployment, in software development
- DES. *See* Data Encryption Standard
- Design, in software development
- “Design of an Intelligent Automaton, The” (Rosenblatt)
- Design patterns
 - deceptive
 - details on demand
- “Design Space for Effective Privacy Notices, A” (Schaub)
- Design strategies
- Design tactics
- Development, security, and operations (DevSecOps)
- Device-based authentication
- Device-level encryption
- DevOps model of software development
- DevSecOps model of software development
- DHE. *See* Diffie-Hellman key exchange
- DHS. *See* U.S. Department of Homeland Security
- Dictionary attack
- Differential cryptanalysis
- Differential identifiability
- Differential privacy
- Diffie, Whitfield
- Diffie-Hellman key exchange (DHE)
- Diffusion model, DALL-E
- Digital Advertising Alliance (DAA)
 - Digital certificate
- Digital fingerprint, use of term
- Digital rights management (DRM)
- Digital Signature Algorithm (DSA)
- Digital signature certificates
- Digital signatures
 - blockchain technologies and
 - encryption and
 - hash functions and
 - properties of
 - relying party (RP)
 - signing and verifying
- Digital twin
- Dimensionality reduction
- Direct interference
- Disassociability
- Disclosure
 - defined
 - privacy problem taxonomy and
- Disconnect browser extension

Disconnect tool
Discoverability, privacy interface design and
Discretionary access control (DAC)
Disinformation
Disassociability, privacy design and
Distortion

- privacy problem taxonomy and
- as problematic data action

Distributed denial-of-service (DDoS)
DNT. *See* Do Not Track (DNT) setting
Document Object Model (DOM) storage
DOD. *See* U.S. Department of Defense
DOM. *See* Document Object Model (DOM) storage
Do Not Track (DNT) setting
DPO. *See* Data protection officer
DRM. *See* Digital rights management
Drones, video surveillance via
DSARs. *See* Data subject access requests
DuckDuckGo
Dwork, Cynthia

E

ECB. *See* Electronic codebook
ECC. *See* Elliptic Curve Cryptography
ECDHE. *See* Elliptic curve Diffie-Hellman key exchange
Eckersley, Peter
Ecological validity
E-commerce, encryption prior to
ECPA. *See* Electronic Communications Privacy Act of 1986
ECU. *See* Electronic Control Unit
EDPB. *See* European Data Protection Board
Educational technology, video surveillance and
EFF. *See* Electronic Frontier Foundation
Egelman, Serge
Einstein, A.
Elderly, IoT technology for
Electronic codebook (ECB)
Electronic Communications Privacy Act of 1986 (ECPA)
Electronic Control Unit (ECU)
Electronic Frontier Foundation (EFF)

- Deep Crack computer
- Privacy Badger

Elliptic Curve Cryptography (ECC)
Elliptic curve Diffie-Hellman key exchange (ECDHE)
Email. *See also* Gmail

- address, as identifier
- blocking tracking of
- encryption
- filtering unwanted
- tracking recipients
- transmission

Emami-Naeni, Pardis
Emergency access to personal information

Emerging Challenges for Security, Privacy and Trust (Farley and Wang)

Emotional contagion

Employees

- access control and
- administrative monitoring of
- authenticating
- BYOD and
- expectations of privacy
- insider threats and
- monitoring communications of
- phishing and
- Pretty Good Privacy standards and
- stealing customer information
- tracking

Employers. *See also* Employees

- CCTV use
- employee monitoring by

Enciphering

Encoding

Encrypting key

Encryption

- algorithms and keys
- computer security and
- cryptographic systems (*See* Cryptographic systems)
- database
- data in flight, data at rest, data in use
- defined
- digital rights management and
- before e-commerce
- end-to-end
- keys *vs.* passwords
- metaphor for
- public key (asymmetric) encryption
- quantum computing
- secret key (symmetric) encryption
- synonyms for
- Universal Serial Bus security tokens
- vocabulary of

Encryption algorithms

- blocks
- broken
- comparison of (table)
- cryptanalysis and
- encryption
- hash functions
- public key (asymmetric) encryption
- secret key (symmetric) encryption

Encryption keys

Encryption passwords

End-to-end encryption

Engineering to protect privacy

- data governance

- engineering development life cycle
- high-level design
- information technology ecosystem and
- low-level design
- privacy governance and
- privacy interfaces (*See* Privacy interfaces)
- requirements engineering
- risk management
- technological controls
- testing, validation, verification

Engineers

- culture of privacy among
- data
- privacy
- prompt
- software

Entity-relationship (ER) diagrams

Entropy

Entropy pool

Ephemeral/transitory borders, privacy violations and

Epic Browser

Equifax data breach

Equifax Security CA

Error, in software engineering

Ethical codes

- privacy engineering and
- usability testing/user studies

European Commission

PRIPARE

Working Party (WP29)

European Data Protection Board (EDPB)

European Union (EU)

- Artificial Intelligence (AI) Act

- Cookie Directive

- cookie notices

- General Data Protection Regulation (*See* General Data Protection Regulation)

- national data protection authorities (DPAs)

EU-U.S. Data Privacy Framework

Event identification, privacy risk management framework

Evercookie

Exceptions, completeness argument

Exclusion, privacy problem taxonomy and

Export controls, cryptography and

Exposure

- defined

- privacy problem taxonomy and

Externally created identifiers

External threats

F

Facebook

- address-book mining choice

- agile designs

- Application Developer API
- Cambridge Analytica and
- context-dependent privacy and
- data sharing with third parties
- default audience option
- encryption
- explanations for ads
- fines for privacy complaints
- Firesheep eavesdropping extension
- Like button
- location check-ins
- nudges
- permissive defaults
- rebranded as Meta
- same-origin policies and
- sentiment analysis and
- spear-phishing attacks on
- website authentication via
- Facebook Places
- Facial recognition software
- Factor Analysis of Information Risk for Privacy (FAIR-P)
- Failure in software engineering
- Fair Information Practice Principles (FIPPs)
 - as consequence model
- Federal Trade Commission and
- frequent use of
- Path API violation of
- Fair Information Practices (FIPs)
- Fairness
 - machine learning and
 - privacy design and
- FAIR-P. *See* Factor Analysis of Information Risk for Privacy
- Fake audio
- Fake representations
- False hierarchy
- Farley, Ryan
- Fault, in software engineering
- Feature engineering
- Federal Aviation Administration (FAA), drone regulations
- Federal Bureau of Investigation (FBI)
 - Counterintelligence Program
 - Lower Merion School District case
 - United States v. Jon Tomero
- Federal Communications Commission (FCC)
 - on cell phone tracking
 - Comcast's deep packet inspection
 - Communications Assistance for Law Enforcement Act
 - Google's Street View cars
- Federal Information Processing Standard (FIPS)
 - Data Encryption Standard (Publication 46)
 - Digital Signature Algorithm
- Federal Trade Commission (FTC)

- on access to contact lists
- as authority to regulate privacy
- CAN-SPAM Act
- disclosure guidelines for advertising
- Fair Information Practice Principles (FIPPs)
- fines to settle privacy complaints
- guidelines for behavioral advertising
- internet advertising revenue report
- as national privacy regulator
- third-party developer case
- Federated architectures and systems
- Federated identity management
- Federated learning
- Federated Learning of Cohorts (FLoC)
- Filters, generative AI systems
- Find My Friends app
- Fine-tuning technique, for foundational models
- Fingerprint
 - authentication using
 - sensor, for mobile devices
- Fingerprinting browser
- FIPPs. *See* Fair Information Practice Principles (FIPPs)
- FIPS. *See* Federal Information Processing Standard
- Firefox
 - Adblock Plus extension
 - cookie settings
 - Enhanced Tracking Protection
 - Firesheep eavesdropping extension
 - Global Storage
 - NoScript add-on
 - Tracking Protection feature
 - TrackMeNot add-on
- First-party privacy settings
- Flash cookies
- FLoC. *See* Federated Learning of Cohorts
- Formative evaluations in usability testing
- Format preserving encryption (FPE)
- Foundational models, generative AI
- Foursquare, Girls Around Me phone app
- Four States of Privacy (Westin)
- FPE. *See* Format preserving encryption
- France, data protection authority in
- Frequency data
- Freund, Jack
- Fried, Charles
- Friedman, Batya
- FTC. *See* Federal Trade Commission
- Fuller, Kira
- Functional privacy
- Functional requirements

G

Gamma, Erich

- GANs. *See* General adversarial networks
- GAPP. *See* Generally Accepted Privacy Principles
- Garfinkel, Simson L.
- Garg, Praerit
- Garmisch report
- Gartner, chatbot prediction
- GDPR. *See* General Data Protection Regulation
- General adversarial networks (GANs)
- General Data Protection Regulation (GDPR) (EU)
 - data life cycle and
 - data protection officers and
 - data quality requirement
 - EU Cookie Directive and
 - individually identifiable data and
 - length of privacy policies before and after
 - privacy design requirements
 - privacy governance and
 - right to be forgotten
 - transparency and user rights
 - web tracking practices
- Generalization approach to anonymization
- Generally Accepted Privacy Principles (GAPP)
- Generative adversarial networks
- Generative AI
 - applications of
 - appropriation harms and
 - confidentiality breaches and
 - deepfakes (*See* Deepfakes)
 - era of
 - filters and
 - learning paradigms and
 - model training
 - neural networks and
 - privacy risks and
 - prompts and
 - responsible AI and
 - social engineering and
 - unwanted messaging and
- Geographic information system (GIS)
- Geotagged data
- GET request
- Ghostery
- Girls Around Me phone app
- GLBA. *See* Gramm-Leach-Bliley Act
- Global positioning system (GPS)
 - as location-based app
 - as location tracking technology
 - privacy threat
 - smartphones
 - tracking and
 - as vehicle sensor
- Gluck, Joshua

Gmail

- autocomplete models
- contextual advertising on
- email tracking and
- message recall opportunity

Google

- advertising on
- AirTags
- completeness argument
- delegated opt-outs and
- Duplex voice assistant
- Federated Learning of Cohorts (FLoC)
- finances for privacy complaints
- Nest Secure hub
- same-origin policies and
- website authentication via

Google Buzz

Google Chrome

- Adblock Plus extension
- cookie settings
- digital certificate
- TrackMeNot add-on

Google Home

Google Maps

- API testing and
- vehicle sensors and

Google Street View

- cars, packet sniffers on
- data minimization and

GPS. *See* Global positioning system

GPT-2

GPT-3

GPUs. *See* Graphical processing units

Gramm-Leach-Bliley Act (GLBA)

- privacy reminders and
- requirements engineering and

Graphical processing units (GPUs)

Great Britain, PRISM program

Grossklags, Jens

Grover's Algorithm

Guidelines on the Protection of Privacy and Transborder Flows of Personal Data

H

Habib, Hana

Halverson, Casey

Haptic privacy interfaces

Harbarch, Marian

Harm. *See also* Privacy harms

- in software engineering

Harm Dimensions (Calo)

Hash algorithms

Hash functions, cryptographic. *See* Cryptographic hash functions

Headsets

- Microsoft Hololens
- Oculus
- Health, Education, Welfare (HEW), Advisory Committee on Automated Data Systems
- Health care devices, wearable
- Health Insurance Portability and Accountability Act (HIPAA)
 - individually identifiable data
 - limited datasets and (LDSs)
 - Privacy Rule
 - privacy governance and
 - pseudonymity and
 - safe harbor provision
 - Security Rule
- Hellman, Martin
- Helm, Richard
- HEW. *See* Health, Education, Welfare
- Hibshi, Hanan
- Hidden cameras and microphones
 - laptop and desktop computers
 - smartphones
 - smart televisions
 - surveillance via
- High-level design
 - design representations (*See also* Privacy design)
 - information technology architectures
 - quality attributes
- HILP. *See* Human in the loop (HILP) model
- Hollan, Jim
- Home automation sensor-based surveillance
- Home-security devices internet-connected
- Homomorphic encryption
- Honan, Mat
- Household voice assistants, surveillance by
- “How Short is Too Short” (Gluck et al.)
- How to Measure Anything in Cybersecurity Risk* (Hubbard & Sierersen)
- HSTS. *See* HTTP Strict Transport Security
- HTML5
- HTTP. *See* Hypertext Transfer Protocol
- HTTP cookies. *See also* Cookies
 - cookie syncing
 - first-party cookies
 - online shopping cart
 - opt-out cookies
 - persistent cookies
 - same-origin policy
 - session cookies
 - targeted advertising and
 - third-party cookies
- HTTPS. *See* Hypertext Transfer Protocol Secure
- HTTP Strict Transport Security (HSTS)
- Hubbard, Douglas
- Human in the loop (HILP) model
- Hutchins, Ed

- Hyperbolic discounting
- Hyper Text Markup Language (HTML)
 - beacons loaded via
 - codes, tracking emails via
- Hypertext Transfer Protocol (HTTP)
 - information technology architecture and
 - internet communications and
 - session hijacking
 - as source of identifying information
 - tracking and
 - typical request
- Hypertext Transfer Protocol Secure (HTTPS)
 - as source of identifying information
 - surveillance protection and
 - Wi-Fi eavesdropping and

I

- IaaS. *See* Infrastructure as a service
- IAB. *See* Interactive Advertising Bureau
- Identifiability, privacy design and
- Identification, privacy problem taxonomy and
- Identification badges
 - Identified individual
- Identity
 - authentication and
 - biometrics and
 - forms of
 - incidental or unplanned sources
 - individually identifiable data
 - pseudonymous data
 - representing
 - uses of
- Identity provider (IdP)
- Identity theft
 - encryption to prevent
 - Javelin Strategy & Research Report on
 - optimism bias and
 - Social Security number and
 - “what you know authentication” and
- IdP. *See* Identity provider
- IDS. *See* Intrusion detection system
- IEEE. *See* Institute of Electrical and Electronics Engineers
- IMAP. *See* Internet Message Access Protocol
- “Impact of Timing on the Saliency of Smartphone App Privacy Notices” (Balebako et al.)
- Implementation, software development
- Implied consent
- Incidental users, identifying
- Incident response, computer security system and
- Indirect interference
- Individual, identified
- Individually identifiable data
- Individuals
 - privacy expectations

- problems for
- Induced disclosure
- Industry standards for privacy governance
- Informational privacy resources
- Information collection
- Information dissemination
- Information processing
- Information technology (IT). *See also* IT *entries*
 - anonymity and
 - individual privacy safeguarding and
 - as revolutionary
 - stakeholders
- Information technology (IT) architectures
 - client-server architecture
 - cloud-based computing
 - federated architectures and systems
 - front end/back end
 - peer-to-peer architecture
 - plug-in-based architecture
 - service-oriented architectures
- Information technology (IT) ecosystem
 - defect, fault, error, failure, harm
 - engineering landscape
 - flowchart, software ecosystem for privacy
 - frameworks
 - privacy engineer
 - software process models
- Information technology (IT) systems engineering. *See* Engineering to protect privacy
- Informed consent prompts
- Infrastructure as a service (IaaS)
- Input-validation flaw
- Insecurity
 - privacy problem taxonomy and
 - as problematic data action
- Insider threats
- Institute of Electrical and Electronics Engineers (IEEE)
- Institute of Operational Privacy Design (IOPD) Design Process Standard
- Institutional review board (IRB), useability testing/user studies
- Integrated consent prompt
- Integrated opt-out
- Integrated privacy notices
- Integration testing
- Integrity
 - of encryption
 - privacy design and
 - security and
 - as security property
- Intel Software Guard Extensions (SGX)
- Interactive Advertising Bureau (IAB), delegated opt-outs and
- Interference
 - defined
 - direct *vs.* indirect

- framework for understanding
- lessons and recommended actions
- technology perspective (*See* Interference from a technology perspective)
- types of

Interference from a technology perspective

- administrative decision-making and
- administrative intrusions into personal spaces
- behavioral advertising
- content filtering and recommendations
- cyberbullying
- disinformation and fake representations
- notifications
- social engineering and interconnected systems
- software APIs
- spam
- unsolicited messages

Internal controls

- mapping to technological controls
- preventive
- preventive and detective
- security compliance (example)

International Association of Privacy Professionals (IAPP), workshops and seminars

International Electrotechnical Commission (IEC)

International Organization for Standardization (ISO)

- design process standard

- ISO 270XX series

- ISO-9421-11

- ISO 19944

- ISO 27000

- ISO 31000

- ISO 31700PbD standard

- ISO 42001

- ISO/IEC 27550

- privacy guidelines and controls

Internet advertising. *See also* Behavioral advertising

Internet communications

- email

- hypertext transfer protocol (HTTP)

- packets and

Internet Engineering Task Force (IETF)

Internet Explorer

- Tracking Projection Lists (TPLs)

- userData storage

Internet Message Access Protocol (IMAP)

Internet monitoring

- deep packet inspection

- effective practices

- employers, schools, and parents

- internet communications overview

- network-level surveillance

- network-scale monitoring

- spyware

- Wi-Fi networks and
- Internet of Things (IoT). *See also* IoT (Internet of Things) devices
 - nonpersonal data collection
 - sensor-based surveillance
 - as surveillance opportunity
- Internet Protocol (IP)
- Internet service provider (ISP)
 - IP address as PII
 - monitoring web browsing
 - network-based profiling and
- Interrogation, privacy problem taxonomy and
- Intrusion
 - “creepiness” of
 - defined
 - in interference framework
 - machine learning (ML) and
 - privacy problem taxonomy and
- Intrusion detection system (IDS)
- Intrusion prevention system (IPS)
- Invasion, forms of
- IOPD. *See* Institute of Operational Privacy Design
- IoT (Internet of Things) devices. *See also* Internet of Things (IoT)
 - in engineering landscape
 - privacy interface modality
 - privacy notices
- IP address
 - data packets and
 - device-based authentication and
 - as personally identifiable information (PII)
- IPS. *See* Intrusion prevention system
- IRB. *See* Institutional review board
- ISO. *See* International Organization for Standardization
- IT acquisition professionals
- IT administration
- IT automation
- IT developers
- IT innovation

J

- JavaScript
 - browser fingerprinting
 - browser history stealing
 - preventing cookies creation with
 - same-origin policy and
 - tracking web navigation via
 - web page building and
 - window.name
- Javelin Strategy & Research Report (2023) on identity theft
- Johnson, Ralph
- Jones, Jack
- Just-in-time interfaces

K

- k*-anonymity
- Kearns, Michael
- Kelley, Patrick Gage
- Kerberos protocol
- Keyloggers
- Keylogging
- Key performance indicators (KPI)
- Key results (KRs)
- Key risk indicators (KRIs)
- Keys, encryption
- Key search attack
- Knowledge management computer security system and
- Kohnfelder, Loren
- KPI. *See* Key performance indicators
- KRIs. *See* Key risk indicators
- KRs. *See* Key results

L

- LangChain
- Large language models (LLMs)
 - disinformation and
 - foundation models and
 - generative AI and
 - open-source
 - training costs
- LastPass
- Laws, privacy. *See* Privacy laws
- Lawyers, role in privacy protection
- l*-diversity
- Least-privilege principle
- Legal notices. *See* Privacy notices
- Leon, Pedro
- Let's Encrypt certificate authority (CA)
- Limited datasets and (LDSs)
- LINDDUN threat modeling
- Linear decision boundary
- LinkedIn
 - address-book mining choice
 - spear-phishing attacks on
- Livehoods Project
- LLMs. *See* Large language models
- Local differential privacy
- Local shared objects (LSOs)
- Location-based apps
- Location-based authentication
- Location-based data, inferences from
- Location-based services
 - combining with data from other sources
 - location-based ads
 - location-based apps
 - social media
 - tracking children and employees
- Location tracking

- blocking
- effective practices
- geographic information services (GIS)
- location-based services
- preventing and controlling
- research
- technologies
- user controls
- Location tracking technologies
 - Bluetooth-based tracking tags
 - cellular signals
 - GPS satellites
 - metadata
 - mobile phones
 - radio frequency identification (RFID) chips
 - Wi-Fi signals
- Log4j vulnerability
- Log analysis, post-deployment testing
- Logging in
- Login name
- Loomis v. Wisconsin
- Loss aversion
- Low-level design
 - coding practices and code reviews
 - standard libraries and frameworks
- LSOs. *See* Local shared objects
- Lucifer algorithm

M

- MAC. *See* Mandatory access control
- MacDonald, Alicia
- Machine-in-the-middle (MiTM) attack
- Machine learning (ML)
 - administrative decision-making and
 - appropriation harms
 - basics
 - behavioral advertising and
 - confidentiality harm
 - decisional interference
 - deep learning and
 - generative AI and (*See also* Generative AI)
 - as interference source
 - intrusion and
 - Loomis v. Wisconsin case
 - main paradigms
 - mitigations and solutions
 - neural networks and deep learning
 - predictive performance *vs.* data requirements
 - privacy-preserving
 - privacy risks in
 - responsible AI and
 - role of data in
 - role of professional in

- transparency and
- Magnitude data
- Mail servers, email tracking and
- Mail user agent (MUA)
- Maintenance activity, software development
- Malware
 - computer security attacks via
 - roving bugs
- Manageability, privacy design and
- Mandatory access control (MAC)
- Man-in-the-middle attack
- Man-in-the middle proxy tool
- Marcos, David James
- Marketing professionals, role in privacy protection
- Marwick, Alice
- Marx, Gary T.
- Mass citizen surveillance
- Mass surveillance of citizens
- MBSE. *See* Model-based systems engineering
- Measuring and Managing Information Risk* (Freund & Jones)
- Mechanical Turk crowdsourcing platform
- Memorization, as form of overfitting
- Merkle, Ralph
- Messages, unsolicited, as interference
- Meta
 - delegated opt-outs and
 - LLaMA
 - Reality Labs
 - tracking users on multiple sites
- Metadata
 - defined
 - location tracking technology
- Metaverse, sensor-based surveillance and
- Metrics, usability testing
- Microdata, anonymization of
- Microphones, hidden, surveillance via
- Microsoft
 - Cortana
 - Dynamic Access Control
 - Hololens headsets
 - Outlook
- Microsoft Edge, privacy-level modes
- Microsoft Internet Explorer
 - Platform for Privacy Preferences Project (P3P) tokens
 - Tracking Protection Lists (TPLs)
- Microsoft Office, symmetric encryption and
- Microsoft Outlook, HTML code tracking
- Microsoft Windows
 - Dynamic Access Control
 - New Technology File System (NTFS)
- Misconfiguration
- MiTM. *See* Machine-in-the-middle attack

- Mitnick, Kevin
- MITRE Corporation, PANOPTIC
- Mix networks
- ML. *See* Machine learning
- MLS. *See* Multilevel security system
- Mobile apps
 - awareness of privacy notices
 - privacy interface modality
 - privacy nudging
- Mobile device sensors
- Mobile phones. *See also* Smartphones
 - as location tracking technology
 - privacy risks and
 - two-factor authentication and
- Mobility, privacy design and
- Model-based systems engineering (MBSE)
- Morin, Dave
- Morris Worm
- Mosaic effect
- Multifactor authentication
- Multilevel security system (MLS)
- Multiparty computation
- MySQL database

N

- NAI. *See* Network Advertising Initiative
- Nanny cams
- National Bureau of Standards (NBS)
- National Initiative for Cybersecurity Education (NICE) Framework
- National Institute of Standards and Technology (NIST)
 - AI Risk Management Framework (RMF)
 - cloud-based computing
 - Introduction to Privacy Engineering and Risk Management in Federal Systems
 - lightweight cryptography standards
 - NICE framework
 - NISTIR 8062
 - Post-Quantum Cryptography program
 - Privacy Engineering Program, CIA triad
 - Privacy framework
 - Privacy Risk Assessment Methodology
 - privacy risk framework components
 - Privacy Workforce Taxonomy
 - problematic data action model
 - problems for individuals
 - Rijndael algorithm
 - Special Publication 800-53
 - Special Publication 800-88, App A
- NATO. *See* North Atlantic Trade Organization
- Natural borders, privacy violations and
- Near field communication (NFC)
- NebuAd
- Netflix
 - pseudonymous data and

- release of anonymized data
- Net promoter score (NPS)
- Netscape Navigator, encryption
- Network Advertising Initiative (NAI)
- Network-based profiling
- Network centrality, privacy design and
- Network-level surveillance
- Network services, computer security system and
- Neural networks
 - deepfakes and
 - generative AI and
 - human brain function and
 - machine learning (ML) and
 - multilayer
- New Jersey, Anti-Bullying Bill of Rights
- Newport, Kenneth
- New Technology File System (NTFS)
- New York Times, The*, Privacy Project
- NFC. *See* Near field communication
- Nguyen, Duc
- NICE Framework. *See* National Initiative for Cybersecurity Education (NICE) Framework
- Nielsen, Jakob
- Nissan Leaf entertainment system
- Nissenbaum, Helen
- NIST. *See* National Institute of Standards and Technology (NIST)
- Nocco, Chris
- Noise addition approach to anonymization
- Nonblocking privacy controls
- Nonfunctional requirements
- Norman, Don
- North Atlantic Trade Organization (NATO), Garmisch report
- Northpointe, Inc.
 - COMPAS software
- NoScript tool
- Notice and choice model
- Notifications, as interference
- NPS. *See* Net promoter score
- NSA. *See* U.S. National Security Agency
- NSO Group, Pegasus spyware
- NTFS. *See* New Technology File System

O

- OASIS. *See* Organization for the Advancement of Structured Information Standards
- Obama, Barack, deepfake video of
- Objective harms
- Objective key results (OKRs)
- Object models
- Oblivious Random-Access Memory (ORAM)
- Obstruction
 - defined
 - in interference framework
- OCSP. *See* Online Certificate Status Protocol
- Oculus headsets

- OECD. *See* Organization for Economic Cooperation and Development
- OKRs. *See* Objective key results
- Olfactory privacy interfaces
- On-demand interfaces
- Onion-routing networks
- Onion-routing systems
- Online advertising
 - targeted platforms, ML models
 - web tracking and
- Online behavioral advertising. *See also* Targeted advertising
- Online Certificate Status Protocol (OCSP)
- OnStar systems
- OPE. *See* Order-preserving encryption
- OpenAI
 - ChatGPT
 - cost of LLM training
- Open design principle
- Open-source software
- Operational technology (OT)
- Optimism bias
- Opt-in consent, to marketing messages
- Opt-in/opt-out consent
- Opt-out cookies
- Opt-out link, California Consumer Privacy Act (CCPA)
- Opt-out prompts, user comprehension of
- ORAM. *See* Oblivious Random-Access Memory
- Order-preserving encryption (OPE)
- Organisation for Economic Co-operation and Development (OECD)
 - Use Limitation Principle
 - Privacy Guidelines
- Organization for the Advancement of Structured Information Standards (OASIS)
- OT. *See* Operational technology
- Overfitting

P

- P3P. *See* Platform for Privacy Preferences Project (P3P) tokens
- PaaS. *See* Platform as a service
- Packet-sniffing systems
- Pan, Yue
- PANOPTIC. *See* Pattern and Action Nomenclature of Privacy Threats in Context
- Parental consent
- Parents, internet monitoring by
- Passive consent
- Password
 - encryption
 - sharing
 - as “what you know” authentication
- Password management tool
- Passwork attack
- Path API
 - access to users contact lists
 - personal data exposure and
- Pattern and Action Nomenclature of Privacy Threats in Context (PANOPTIC)

PBAC. *See* Policy-based access control

PbD. *See* Privacy by design

Pegasus spyware

Pennsylvania Lower Merion School District

Perception of Risk, The (Slovic)

Perceptron

Periodic reminders

Persistent cookies

Persistent privacy indicators

Persistent VPNs

Personal data, GDPR definition

Personal identification number (PIN)

- authentication and
- smart cards

Personal identity, cyberbullying and

Personal identity verification (PIV)

Personal information, emergency access to

Personalization, identity and

Personally identifiable information (PII)

- disclosure to third party
- IP addresses as
- privacy interface transparency and
- third-party email trackers and

Personal spaces, administrative intrusions into

PGP. *See* Pretty Good Privacy

PHI. *See* Protected health information

Phishing

- e-mail tracking and
- as external threat
- as social engineering attack

Phorm, Webwise system

Physical controls

PII. *See* Personally identifiable information

PimEyes search engine

PIMS. *See* Privacy Information Management System

PIN. *See* Personal identification number

PIR. *See* Private information retrieval

PIV. *See* Personal identity verification

Pixel hack

Plaintext

Platform as a service (PaaS)

Platform for Privacy Preferences Project (P3P) tokens

Platform privacy settings

Please Rob Me website

Pluggable cryptographic protocol

PMRM. *See* Privacy Management Reference Model and Methodology

Podolsky, B.

Policy-based access control (PBAC)

POP. *See* Post Office Protocol

Post-deployment testing

Post Office Protocol (POP)

POST request

- PPML. *See* Privacy-preserving machine learning
- Preconditions, completeness argument
- Predictability, privacy design and
- Preparing Industry to Privacy-by-design by supporting its Application in Research (PRIPARE)
- Pretty Good Privacy (PGP)
- Primary channel, for privacy interface
- Primary users, identifying
- PRIPARE. *See* Preparing Industry to Privacy-by-design by supporting its Application in Research
- PRISM program
 - disclosures about
 - Skype metadata accessibility and
 - Snowden revelations
- Privacy
 - data governance and
 - defined
 - engineering to protect (*See* Engineering to protect privacy)
 - individual expectations of privacy
 - principles and standards
 - as “right to be let alone” (Warren and Brandeis)
 - security and
- Privacy acts, interference-related
- “Privacy as Part of the App Decision-Making Process” (Kelley et al.)
- Privacy attitude
- Privacy Badger
- Privacy behavior
 - defined
 - manipulation of
- Privacy by design (PbD)
- Privacy choices, communicating
- Privacy completeness arguments
- Privacy concern
- Privacy controls. *See also* Privacy notices
 - communicating
 - delivery of
 - design space for
 - layered
- Privacy dashboards
- Privacy decision
- Privacy decision-making and behavior
 - bounded rationality
 - common concepts
 - complex nature of
 - context dependence
 - incomplete information and uncertainty
 - privacy-seeking behavior
- Privacy design. *See also* High-level design; Low-level design
 - dark patterns
 - design patterns
 - model-based systems engineering (MBSE)
 - object and data models
 - process models
 - strategies and tactics

tools

trade studies

user-centered

Privacy design process

assessment, management, and engineering practice

global *vs.* local laws

identifying users and privacy needs

integrating privacy interfaces in UX

leveraging available design space

steps in

unexpected data practices

user testing

Privacy engineer

Privacy expectation

Privacy governance

compliance and

core activities of privacy program

effective implementation

engineering and

evaluating success

industry standards

integration of elements

law, regulation, and privacy

program (conceptual chart)

responsible AI and

risk and

roles and responsibilities

security and

technology and

transparency and

Privacy harms

appropriation

breach of confidentiality

objective or subjective

taxonomy of (Solove)

Privacy impact assessment (PIA)

privacy design process and

UX research and

Privacy indicators

Privacy Information Management System (PIMS)

Privacy interface design

consent interfaces

discoverability

principles of (*See* Privacy interface design principles)

privacy dashboards

privacy notices

privacy settings

process

take-it-or-leave-it choices

types of privacy interfaces

usability issues (*See also* Usability of privacy interfaces)

user experience (UX) integration

Privacy interface design principles

- actionable
- integration
- relevance
- understandability
- user-centric design

Privacy interfaces

- communication channels
- confusing
- control
- design of (*See* Privacy interface design)
- discoverability of
- integrated into UX
- modality
- natural interaction with
- privacy decision making and behavior
- privacy paradox
- privacy preferences *vs.* behavior
- timing
- transparency and
- usability and user experience (UX)
- usability testing (*See also* Usability testing)
- usable and useful

Privacy invasion social isolation *vs.*

Privacy laws. *See also* Privacy governance

- compliance with (*See* Compliance)
- confidentiality and
- global *vs.* local, privacy design process and
- identifying core requirements of
- identity issues and
- implementation of
- informed consent and
- refining by refrainment
- regulatory goal and
- third-party services and
- trace matrix for understanding
- as variable among states and countries
- usability requirements in
- user-centered privacy design and

Privacy Management Reference Model and Methodology (PMRM)

Privacy notices

- compliance *vs.* usability
- design space for
- integrated
- layered
- types of
- user-centric

Privacy paradox

Privacy patterns

Privacy policies

Privacy preference

Privacy preferences, contextual

- Privacy-preserving machine learning (PPML)
- Privacy Project (*The New York Times*)
- Privacy protections, misconceptions about
- Privacy regret
- Privacy reminders
- Privacy right “to be let alone” (Warren and Brandeis)
- Privacy Risk Assessment Methodology (PRAM)
- Privacy risk framework
- Privacy risk management. *See also* Privacy risk management framework
 - framework for (*See* Privacy risk management framework)
 - privacy risk modeling (*See also* Privacy risk modeling)
- Privacy risk management framework
 - characterization
 - ISO 31000
 - monitor and review
 - risk assessment
 - risk control implementation
 - risk response determination
 - threat, vulnerability, and event identification
- Privacy risk modeling
 - consequence models
 - threat models
 - vulnerability models
- Privacy risks
- Privacy settings
 - browser
 - privacy interface design
- Privacy threats
 - identifying
 - in privacy risk management framework
- Private information retrieval (PIR)
- Private information turbulence
- Problematic data action model
- Process models privacy design
 - Product reviews, fake
- Programmers
 - role in privacy protection
 - small projects and
- Programming languages
- Project managers, role in privacy protection
- Prompt engineers
- Prompts
 - generative AI
 - informed consent and
- Prosser, William
- Protected health information (PHI)
- “Protection of Information in Computer Systems, The” (Saltzer and Schroeder)
- Proxy attack
- Pseudonymity
 - HIPAA and
 - as identity form
- Psychological acceptability principle

- Public channel, for privacy interface
- Public data
- Public key cryptographic algorithms
- Public key (asymmetric) encryption
 - algorithms and key sizes
 - digital signatures
 - infrastructure [See Public key (asymmetric) encryption infrastructure]
- Public key (asymmetric) encryption infrastructure
 - certificate revocation
 - certificates
 - client-side PKI systems
 - extended valuation certificates
 - limitations
 - time and
- Purchased data

Q

- QKD. *See* Quantum key distribution
- Quality attributes in software engineering
 - availability
 - confidentiality
 - disassociability
 - fairness
 - identifiability
 - integrity
 - manageability
 - mobility
 - network centricity
- Quantum computing
- Quantum key distribution (QKD)
- Quantum networking
- Quantum technology
- Quasi identifiers
- Query parameters
- Quon, Jeff

R

- Radio frequency identification (RFID) chip
 - authentication and
 - employee tracking with
 - as location tracking technology
 - tracking through
- Random forests
- Rate-limiting
- RATs. *See* Remote Access Trojans
- RBAC. *See* Role-based access control
- RC4 algorithm
- Reasonable assurance concept
- Reasonable expectation of privacy, CCTV and
- Recommendations, content filtering and
- Rectified Linear Unit (ReLU)
- Reencryption process
- Regression testing

- Regulators, role in privacy protection
- Regulatory goal, completeness argument
- Reinforcement learning
- Reinforcement learning with human feedback (RLHF)
- ReLU. *See* Rectified Linear Unit
- Relying party (RP)
- Remote Access Trojans (RATs)
- Replay attack
- Representative datasets
- Representative heuristic
- Repurposing data
- Requirements engineering
 - acquiring and eliciting requirements
 - documenting requirements
 - privacy completeness arguments
 - privacy threats
 - software development
 - trace matrices
- Requirements engineers, role in privacy protection
- Responsible AI
- RFID chip. *See* Radio frequency identification (RFID) chip
- RFPA. *See* Right to Financial Privacy Act of 1978
- Right to Financial Privacy Act of 1978 (RFPA)
- Rijmen, Vincent
- Rijndael algorithm
- Risk
 - defined
 - privacy risk framework
- Risk assessment
- Risk controls
- Risk management. *See* Privacy risk management
 - computer security software
 - privacy (*See* Privacy risk management)
- Rivest, Ronald
- RLHF. *See* Reinforcement learning with human feedback
- RMF. *See* AI Risk Management Framework
- Role, identity *vs.*
- Role-based access control (RBAC)
- Rootkit
- Rosen, N.
- Rosenblatt, Frank
- Roth, Aaron
- Rounding, as generalization form
- Roving bugs
- RP. *See* Relying party
- RSA (Rivest, Shamir, Adleman) algorithm
- Rubber-hose attacks

S

- SaaS. *See* Software as a service
- Safari Intelligent Tracking Protection
- Safe harbor provision
- Salespeople, role in privacy protection

- Saltzer, J.H.
- Same-origin policy
- SAML. *See* Security Assertion Markup Language
- Samsung
 - Bixby
 - SmartThings
 - SmartTV
- Sarbanes-Oxley (SOX)
- Schaub, Florian
- Schools
 - administrative monitoring by
 - internet monitoring by
- Schroeder, M.D.
- SCM. *See* Source configuration management (SCM) systems
- Scrum agile development model
- Search engines. *See also* Web browsers
 - health information and
 - misconfiguration breaches and
 - personalized
 - PimEyes
 - privacy-protective
- Search history, hiding
- Secondary channel, for privacy interface
- Secondary use, privacy problem taxonomy and
- Secondary users, identifying
- Secrecy. *See also* Confidentiality
 - as security property
- Secret key (symmetric) encryption
 - algorithms and key sizes
 - applications
 - attacks and threats
 - entropy and
 - key generation and
 - modes of operation
 - random numbers and
- Secret sharing
- Secure enclaves
- Secure Hash Algorithm 256 (SHA-256)
- Secure multiparty computation
- Secure/Multipurpose internet Mail Extensions (S/MIME)
- Secure sockets layer (SSL)
- Security. *See also* Computer security
 - defined
 - privacy governance and
- Security APIs
- Security Assertion Markup Language (SAML)
- Security breach, service providers
- Security by obscurity
- Seiersen, Richard
- Self-censorship, privacy concerns and
- Self-representation, interference and
- Sensor-based surveillance

- home automation
- Internet of Things (IoT)
- Metaverse
- mobile device sensors
- ubiquitous computing
- vehicle sensors
- wearable devices
- Sentiment analysis
- Service providers (SPs)
 - federated identity management
 - security issues with
- Session cookies
- SGD. *See* Stochastic gradient descent
- Shamir, Adi
- Shapiro, Stuart S.
- Short Message Service (SMS) texts. *See also* Text message
- Side-jacking attacks
- Signing key
- Silverlight (Microsoft)
- Simple Mail Transfer Protocol (SMTP)
- Single sign on (SSO)
- Skype
- Slovic, Paul
- Smart assistant, interacting with privacy interfaces
- Smart cards
 - authentication using
 - personal identification number (PIN)
- Smart cities, data collection in
- Smart homes, privacy concerns
- Smartphones. *See also* Mobile phones
 - location-based apps for
 - mobility and social patterns
 - privacy interface modality
 - as surveillance devices
 - surveillance malware on
 - tracking children via
- Smart televisions, audio surveillance via
- S/MIME. *See* Secure/Multipurpose internet Mail Extensions
- SMS. *See* Short Message Service (SMS) texts; Text message
- SMTP. *See* Simple Mail Transfer Protocol
- Sniffing
- Snowden, Edward
- SOC. *See* Systems and Organization Controls
- Social borders, privacy violations and
- Social bots, misleading
- Social credit system
- Social engineering
 - attack, phishing as
 - defined
 - generative AI
 - interference and
 - phishing

- Social media
 - fake users
 - as location-based service
- Social patterns, revealed by smartphones
- Social Security number
- Sockpuppeting
- S/OD. *See* Subjective/objective dichotomy
- Software
 - application programming interfaces (APIs)
 - developing secure
 - open- *vs.* closed-source
 - vulnerabilities, computer security attacks and
- Software applications, location-based
- Software as a service (SaaS)
- Software designers, role in privacy protection
- Software development and operations (DevOps)
- Software engineers, in machine learning
- Software process models
 - development activities
 - DevOps model of software development
 - DevSecOps model of software development
 - Scrum agile development model
 - spiral software development model
- Software users, role in privacy protection
- Solove, Daniel
- Source configuration management (SCM) systems
- SOX. *See* Sarbanes-Oxley
- Spam
- Spatial/temporal borders, privacy violations and
- Spear-phishing
- Speech recognition
 - audio surveillance and
 - technology
- Spiekermann, Sarah
- Spiral software development model
- Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service and Elevation of Privilege (STRIDE)
- SPs. *See* Service providers
 - Spyware
- SQL. *See* Structured query language
- SQLite
- SSL. *See* Secure sockets layer
- SSO. *See* Single sign on
- Stochastic gradient descent (SGD)
 - Stored Communications Act
- Stream ciphers
- STRIDE. *See* Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service and Elevation of Privilege
- Structured query language (SQL), injection attacks
- Subjective harm
- Subjective/Objective dichotomy (S/OD)
- Subversion system
- Summative evaluations, in usability testing
- Supervised learning

- Suppression approach to anonymization
- Surveillance. *See also* Tracking and surveillance
 - network-level
 - opportunities for
 - privacy problem taxonomy and
 - as problematic data action
- Surveillance capitalism
- “Survey of Value Sensitive Design Methods, A” (Friedman)
- Suwajanakorn, Supasorn
- Sweeney, Latanya
- Symmetric encryption. *See* Secret key (symmetric) encryption
- Symmetric keys
- Synthetic data
- SysML. *See* Systems Modeling Language
- Systems administration, computer security system and
- Systems analysis, computer security system and
- Systems and Organization Controls (SOC)
- Systems development, computer security software
- Systems Modeling Language (SysML)
- System testing
- System-Theoretic Process Analysis for Privacy (STPA-Priv)

T

- Targeted advertising
 - algorithmic processes and
 - HTTP cookies and
- Taxonomy of Privacy (Solove)
- Taxonomy of privacy harms (Solove)
- t*-closeness
- Technical controls
- Technological controls to protect privacy
 - cloud services
 - culture of privacy among engineers
 - data governance and
 - engineering development life cycle
 - key performance indicators (KPI)
 - mapping to internal controls
- Technology
 - interference and (*See* Interference from a technology perspective)
 - privacy governance and
- Telemarketing, privacy preferences and
- Testers, role in privacy protection
- Testing, in software development
 - phases of testing
 - post-deployment testing
 - representative datasets
 - testing with live users
 - types of testing
 - verification and validation
- Text message (SMS). *See also* Short Message Service (SMS) texts
 - two-factor authentication and
 - unsolicited
- Thampi, Arun

- Thermostat, IoT
- Third-party behavioral advertising
- Third-party browser extensions
- Third-party cookies, blocking
- Third-party data collection
- Threat modeling
- “Timing Is Everything? The Effects of Timing and Placement of Online Privacy Indicators” (Egelman et al.)
- TLS. *See* Transport layer security
- Topics API
- Topics application programming interface (API)
- Tort law, privacy and
- TouchID
- Toys, internet-connected
- TPLs. *See* Tracking Protection Lists
- Trace matrices
- Tracing, completeness argument
- Tracking, third-party
- Tracking and surveillance. *See also* Surveillance; Tracking
 - audio and video surveillance
 - behavioral modeling
 - Black activists
 - blocking and controlling (*See also* Blocking web tracking)
 - domestic abuse and
 - effective practices
 - internet monitoring
 - location tracking (*See* Location tracking)
 - mass surveillance of citizens
 - racial and ethnic groups
 - sensor-based surveillance
 - specific targets
 - uses and abuses of
 - web tracking
- Tracking Protection Lists (TPLs)
- TrackMeNot plug-in
- Trade tree
- Traffic analysis
- Transformed data
- Transformer-based models
- Transmission Control Protocol (TCP)
- Transparency
 - machine learning (ML) and
 - privacy governance program
 - privacy interfaces and
 - short privacy notice and
- Transportation mapping app
- Transport layer security (TLS)
 - adoption of
 - bulk data transmission and
 - decrypting proxy
 - HTTPS and
 - securing World Wide Web with
- Trap door functions

Turner, Richard
Twitter account, compromised
Two-factor authentication
Two-step verification

U

UBAC. *See* User-based access control
Ubiquitous computing (ubicom)
UML. *See* Unified Modeling Language
UML object-oriented class diagram
Unanticipated revelation as problematic data action
Unified Modeling Language (UML)
Uniform Resource Locator (URL)
United Kingdom, Regulation of Investigatory Powers Act of 2000
United States
 Advanced Encryption Standard (AES)
 Data Encryption Standard (DES)
 PRISM program
 tracking and surveillance of Black activists in
United States v. Jones
United States v. Jon Tomero
Unit testing
Universal Serial Bus (USB), security tokens
University of California, Berkeley School of Information
University of Massachusetts, LLM training datasets
University research, ethical considerations
Unmanned aerial vehicles (UAVs). *See also* Drones
Unsupervised learning
Unwarranted restriction, as problematic data action
Ur, Blase
Uribe, Nicole
URL. *See* Uniform Resource Locator
URL rewriting
Usability
 components that determine
 pervasive flaws in
Usability of privacy interfaces
Usability testing. *See also* User studies
 A/B testing
 awareness and attention
 behavior
 best practices
 comprehension
 context
 deception
 discoverability
 ecological validity
 ethical considerations
 formative and summative evaluations
 how to test
 metrics
 representative and specific user populations
 small-scale testing

- utility
- what to test
- why test
- USB. *See* Universal Serial Bus
- U.S. Census
 - data
 - differential privacy and
- U.S. Children's Internet Protection Act (CIPA)
- U.S. Communications Decency Act (CDA)
- U.S. Congress
 - behavioral advertising scrutiny
 - theft of memoranda, access control system and
- U.S. Constitution, violation of due process rights (Fifth Amendment)
- U.S. Cybersecurity and Infrastructure Agency (CISA)
- U.S. Department of Defense (DOD)
 - email encryption
 - multilevel security system (MLS)
- U.S. Department of Homeland Security (DHS), FIPP adoption
- User-based access control (UBAC)
- User-centered privacy design. *See also* Privacy interfaces
 - choices and controls
 - communicating privacy protections
 - legal obligations and
 - minimizing surprise
 - reducing user regret opportunities
- User Centered System Design* (Hutchins et al.)
- User Datagram Protocol (UDP)
- User experience (UX) design
 - goal of
 - holistic perspective of
 - privacy engineering and
 - process [*See* User experience (UX) design process]
 - usability and
 - utility and
 - value-sensitive design
- User experience (UX) design process
 - design
 - evaluation
 - research
- User-generated content, fake reviews *vs.*
- User ID
- User rights privacy interfaces and
- User stories
- User studies. *See also* Usability testing
 - awareness of privacy notices
 - crowdsourcing services
 - deciding what to block
 - online panels
 - privacy actions
- "Using Personal Examples to Improve Risk for Security & Privacy Decisions" (Harbach et al.)
- U.S. Internal Revenue Service (IRS)
- U.S. military

- Strava fitness data and surveillance drones
- U.S. National Security Agency (NSA)
 - Snowden revelations
 - top secret data encryption
- U.S. Privacy Act of 1974
- U.S. Supreme Court
 - City of Ontario v. Quon
 - United States v. Jones
- U.S. Wiretap Act
- Utility, UX design and
-  **V**
- Validation
- Value-sensitive design
- Value swapping
- Vehicle sensors
- Verification
- Verifying key
- Verizon Data Breach and Incident Report
- Video doorbells
- Video surveillance. *See* Audio and video surveillance
- Virginia, data breach notification law
- Virtual private network (VPN)
 - authentication and encryption and
 - internet monitoring and persistent
 - Wi-Fi eavesdropping and
- Visual privacy interfaces
- Vlissides, John
- Voice assistants
 - privacy concerns
 - speech recognition and
- Voice audio, fake
- Voice authentication
- Voice command
- Voice-controlled systems, interacting with privacy interfaces in
- Voice over IP (VoIP)
- VPN. *See* Virtual private network
- Vulnerability
 - modeling
 - in privacy risk management framework

W

- W3C. *See* World Wide Web Consortium (W3C)
- Wang, Lingyu
- Wang, Xinyuan
- Warren, Samuel
- Wearable devices, surveillance via
- Web-based profiling
- Web browsers. *See also* Search engines
 - digital certificate (Google Chrome)

- hypertext transfer protocols and
- privacy-protective features
- privacy settings
- TLS encryption and
- Web bugs
- Web tracking
 - Adobe Flash
 - blocking (*See* Blocking web tracking)
 - browser fingerprinting
 - cross-device tracking
 - effective practices to prevent
 - email recipients
 - entity tags (ETags)
 - Evercookie
 - Federated Learning of Cohorts (FLoC)
 - HTTP cookies
 - online advertising
 - pixel hack
 - supercookies
 - Topics API
- WEP. *See* Wired Equivalent Privacy
- Wesley, Charles
- Westin, Alan
- WFH. *See* Work from home
- Whaling
- WhatsApp
 - buffer overflow vulnerability in
 - spyware that targets
- “What you have” authentication
- “What you know” authentication
- Wi-Fi, as location tracking technology
- Wi-Fi networks
 - eavesdropping via
 - sensitive information and
- Wi-Fi Protected Access (WPA)
- WikiLeaks, “Weeping Angel” program revelation (CIA)
- Wired Equivalent Privacy (WEP)
- Wireless networks, symmetric encryption
- Wireshark
- Wogalter, Michael
- Work factor
- Work from home (WFH), computer security and
- Working Party (WP29), European Commission
- Workplace surveillance, CCTV and
- World Wide Web, securing with Transport Layer Security
- World Wide Web Consortium (W3C)
- WPA. *See* Wi-Fi Protected Access
- WPA2
- WPA3
- WPA3 encryption
- Wu, Zhiwei Steven
- Wu Dao 2.0

X

X.500 standard

XSS. *See* Cross-site scripting

Y

Yahoo, advertising on

“Your Attention Please: Designing Security-Decision UIs to Make Genuine Risks Harder to Ignore” (Bravo-Lillo et al.)

YouTube, encryption

Z

Zhang, Jason

Zhaojun, Chen